This text is meant purely as a documentation tool and has no legal effect. The Union's institutions do not assume any liability for its contents. The authentic versions of the relevant acts, including their preambles, are those published in the Official Journal of the European Union and available in EUR-Lex. Those official texts are directly accessible through the links embedded in this document

►B REGULATION (EU) 2024/1689 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 13 June 2024

laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act)

(Text with EEA relevance)

(OJ L 1689, 12.7.2024, p. 1)

Amended by:

		Official Journal		
		No	page	date
►M1	Regulation (EU) 2026/1744 of the European Parliament and of the Council of 8 July 2026	L 1744	1	24.7.2026

▼B

REGULATION (EU) 2024/1689 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 13 June 2024

laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act)

(Text with EEA relevance)

CHAPTER I

GENERAL PROVISIONS

Article 1

Subject matter'

1. The purpose of this Regulation is to improve the functioning of the internal market and promote the uptake of human-centric and trustworthy artificial intelligence (AI), while ensuring a high level of protection of health, safety, fundamental rights enshrined in the Charter, including democracy, the rule of law and environmental protection, against the harmful effects of AI systems in the Union and supporting innovation.

2. This Regulation lays down:

(a) harmonised rules for the placing on the market, the putting into service, and the use of AI systems in the Union;

(b) prohibitions of certain AI practices;

(c) specific requirements for high-risk AI systems and obligations for operators of such systems;

(d) harmonised transparency rules for certain AI systems;

(e) harmonised rules for the placing on the market of general-purpose AI models;

(f) rules on market monitoring, market surveillance, governance and enforcement;

▼M1

(g) measures to support innovation, with a particular focus on small mid-cap enterprises (SMCs) and small and medium-sized enterprises (SMEs), including start-ups.

▼B

Article 2

Scope

1. This Regulation applies to:

(a) providers placing on the market or putting into service AI systems or placing on the market general-purpose AI models in the Union, irrespective of whether those providers are established or located within the Union or in a third country;

(b) deployers of AI systems that have their place of establishment or are located within the Union;

▼B

(c) providers and deployers of AI systems that have their place of establishment or are located in a third country, where the output produced by the AI system is used in the Union;

(d) importers and distributors of AI systems;

(e) product manufacturers placing on the market or putting into service an AI system together with their product and under their own name or trademark;

(f) authorised representatives of providers, which are not established in the Union;

(g) affected persons that are located in the Union.

▼M1

2. For AI systems classified as high-risk AI systems in accordance with Article 6(1) related to products covered by the Union harmonisation legislation listed in Section B of Annex I, only Article 6(1), Article 60a and Articles 102 to 112 shall apply. Articles 57, 58 and 59 shall apply only in so far as the requirements for high-risk AI systems under this Regulation have been integrated in that Union harmonisation legislation.

▼B

3. This Regulation does not apply to areas outside the scope of Union law, and shall not, in any event, affect the competences of the Member States concerning national security, regardless of the type of entity entrusted by the Member States with carrying out tasks in relation to those competences.

This Regulation does not apply to AI systems where and in so far they are placed on the market, put into service, or used with or without modification exclusively for military, defence or national security purposes, regardless of the type of entity carrying out those activities.

This Regulation does not apply to AI systems which are not placed on the market or put into service in the Union, where the output is used in the Union exclusively for military, defence or national security purposes, regardless of the type of entity carrying out those activities.

4. This Regulation applies neither to public authorities in a third country nor to international organisations falling within the scope of this Regulation pursuant to paragraph 1, where those authorities or organisations use AI systems in the framework of international cooperation or agreements for law enforcement and judicial cooperation with the Union or with one or more Member States, provided that such a third country or international organisation provides adequate safeguards with respect to the protection of fundamental rights and freedoms of individuals.

5. This Regulation shall not affect the application of the provisions on the liability of providers of intermediary services as set out in Chapter II of Regulation (EU) 2022/2065.

6. This Regulation does not apply to AI systems or AI models, including their output, specifically developed and put into service for the sole purpose of scientific research and development.

▼M1

7. Union law on the protection of personal data, privacy and the confidentiality of communications applies to personal data processed in connection with the rights and obligations laid down in this Regulation. Without prejudice to Articles 4a and 59 of this Regulation, this Regulation shall not affect Regulation (EU) 2016/679 or (EU) 2018/1725, or Directive 2002/58/EC or (EU) 2016/680.

▼B

8. This Regulation does not apply to any research, testing or development activity regarding AI systems or AI models prior to their being placed on the market or put into service. Such activities shall be conducted in accordance with applicable Union law. Testing in real world conditions shall not be covered by that exclusion.

9. This Regulation is without prejudice to the rules laid down by other Union legal acts related to consumer protection and product safety.

10. This Regulation does not apply to obligations of deployers who are natural persons using AI systems in the course of a purely personal non-professional activity.

11. This Regulation does not preclude the Union or Member States from maintaining or introducing laws, regulations or administrative provisions which are more favourable to workers in terms of protecting their rights in respect of the use of AI systems by employers, or from encouraging or allowing the application of collective agreements which are more favourable to workers.

12. This Regulation does not apply to AI systems released under free and open-source licences, unless they are placed on the market or put into service as high-risk AI systems or as an AI system that falls under Article 5 or 50.

▼M1

13. For high-risk AI systems referred to in Article 6(1), the application of specific requirements or obligations laid down in Articles 9 to 15 and 17 to 25 may be limited, where and to the extent that:

(a) Union harmonisation legislation listed in Section A of Annex I lays down requirements or obligations providing an equivalent or higher level of protection of health, safety or fundamental rights as the requirement or obligation concerned; and

(b) such limitation does not reduce the overall level of protection provided for by this Regulation.

By 2 August 2027, the Commission shall adopt delegated acts in accordance with Article 97 in order to supplement this Regulation by specifying the high-risk AI systems concerned, the requirements or obligations that may be limited, the conditions under which such limitation applies, and the scope of the limitation.

▼B

Article 3

Definitions

For the purposes of this Regulation, the following definitions apply:

(1) ‘AI system’ means a machine-based system that is designed to operate with varying levels of autonomy and that may exhibit adaptiveness after deployment, and that, for explicit or implicit objectives, infers, from the input it receives, how to generate outputs such as predictions, content, recommendations, or decisions that can influence physical or virtual environments;

(2) ‘risk’ means the combination of the probability of an occurrence of harm and the severity of that harm;

(3) ‘provider’ means a natural or legal person, public authority, agency or other body that develops an AI system or a general-purpose AI model or that has an AI system or a general-purpose AI model developed and places it on the market or puts the AI system into service under its own name or trademark, whether for payment or free of charge;

(4) ‘deployer’ means a natural or legal person, public authority, agency or other body using an AI system under its authority except where the AI system is used in the course of a personal non-professional activity;

(5) ‘authorised representative’ means a natural or legal person located or established in the Union who has received and accepted a written mandate from a provider of an AI system or a general-purpose AI model to, respectively, perform and carry out on its behalf the obligations and procedures established by this Regulation;

(6) ‘importer’ means a natural or legal person located or established in the Union that places on the market an AI system that bears the name or trademark of a natural or legal person established in a third country;

(7) ‘distributor’ means a natural or legal person in the supply chain, other than the provider or the importer, that makes an AI system available on the Union market;

(8) ‘operator’ means a provider, product manufacturer, deployer, authorised representative, importer or distributor;

(9) ‘placing on the market’ means the first making available of an AI system or a general-purpose AI model on the Union market;

(10) ‘making available on the market’ means the supply of an AI system or a general-purpose AI model for distribution or use on the Union market in the course of a commercial activity, whether in return for payment or free of charge;

(11) ‘putting into service’ means the supply of an AI system for first use directly to the deployer or for own use in the Union for its intended purpose;

▼B

(12) ‘intended purpose’ means the use for which an AI system is intended by the provider, including the specific context and conditions of use, as specified in the information supplied by the provider in the instructions for use, promotional or sales materials and statements, as well as in the technical documentation;

(13) ‘reasonably foreseeable misuse’ means the use of an AI system in a way that is not in accordance with its intended purpose, but which may result from reasonably foreseeable human behaviour or interaction with other systems, including other AI systems;

▼M1

(14) ‘safety component’ means a component of a product or of an AI system which fulfils a safety function for that product or AI system, or the failure or malfunctioning of which endangers the health and safety of persons or property; for the purposes of this definition, a component fulfils a safety function where its intended purpose is to prevent or mitigate risks to health and safety of persons or property;

(14a) ‘micro, small and medium-sized enterprise’ or ‘SME’ means a micro, small or medium-sized enterprise as defined in Article 2 of the Annex to Recommendation 2003/361/EC;

(14b) ‘small mid-cap enterprise’ or ‘SMC’ means a small mid-cap enterprise as defined in point (2) of the Annex to Recommendation (EU) 2025/1099;

▼B

(15) ‘instructions for use’ means the information provided by the provider to inform the deployer of, in particular, an AI system’s intended purpose and proper use;

(16) ‘recall of an AI system’ means any measure aiming to achieve the return to the provider or taking out of service or disabling the use of an AI system made available to deployers;

(17) ‘withdrawal of an AI system’ means any measure aiming to prevent an AI system in the supply chain being made available on the market;

(18) ‘performance of an AI system’ means the ability of an AI system to achieve its intended purpose;

(19) ‘notifying authority’ means the national authority responsible for setting up and carrying out the necessary procedures for the assessment, designation and notification of conformity assessment bodies and for their monitoring;

(20) ‘conformity assessment’ means the process of demonstrating whether the requirements set out in Chapter III, Section 2 relating to a high-risk AI system have been fulfilled;

(21) ‘conformity assessment body’ means a body that performs third-party conformity assessment activities, including testing, certification and inspection;

(22) ‘notified body’ means a conformity assessment body notified in accordance with this Regulation and other relevant Union harmonisation legislation;

▼B

(23) ‘substantial modification’ means a change to an AI system after its placing on the market or putting into service which is not foreseen or planned in the initial conformity assessment carried out by the provider and as a result of which the compliance of the AI system with the requirements set out in Chapter III, Section 2 is affected or results in a modification to the intended purpose for which the AI system has been assessed;

(24) ‘CE marking’ means a marking by which a provider indicates that an AI system is in conformity with the requirements set out in Chapter III, Section 2 and other applicable Union harmonisation legislation providing for its affixing;

(25) ‘post-market monitoring system’ means all activities carried out by providers of AI systems to collect and review experience gained from the use of AI systems they place on the market or put into service for the purpose of identifying any need to immediately apply any necessary corrective or preventive actions;

(26) ‘market surveillance authority’ means the national authority carrying out the activities and taking the measures pursuant to Regulation (EU) 2019/1020;

(27) ‘harmonised standard’ means a harmonised standard as defined in Article 2(1), point (c), of Regulation (EU) No 1025/2012;

(28) ‘common specification’ means a set of technical specifications as defined in Article 2, point (4) of Regulation (EU) No 1025/2012, providing means to comply with certain requirements established under this Regulation;

(29) ‘training data’ means data used for training an AI system through fitting its learnable parameters;

(30) ‘validation data’ means data used for providing an evaluation of the trained AI system and for tuning its non-learnable parameters and its learning process in order, inter alia, to prevent underfitting or overfitting;

(31) ‘validation data set’ means a separate data set or part of the training data set, either as a fixed or variable split;

(32) ‘testing data’ means data used for providing an independent evaluation of the AI system in order to confirm the expected performance of that system before its placing on the market or putting into service;

(33) ‘input data’ means data provided to or directly acquired by an AI system on the basis of which the system produces an output;

(34) ‘biometric data’ means personal data resulting from specific technical processing relating to the physical, physiological or behavioural characteristics of a natural person, such as facial images or dactyloscopic data;

(35) ‘biometric identification’ means the automated recognition of physical, physiological, behavioural, or psychological human features for the purpose of establishing the identity of a natural person by comparing biometric data of that individual to biometric data of individuals stored in a database;

▼B

(36) ‘biometric verification’ means the automated, one-to-one verification, including authentication, of the identity of natural persons by comparing their biometric data to previously provided biometric data;

(37) ‘special categories of personal data’ means the categories of personal data referred to in Article 9(1) of Regulation (EU) 2016/679, Article 10 of Directive (EU) 2016/680 and Article 10(1) of Regulation (EU) 2018/1725;

(38) ‘sensitive operational data’ means operational data related to activities of prevention, detection, investigation or prosecution of criminal offences, the disclosure of which could jeopardise the integrity of criminal proceedings;

(39) ‘emotion recognition system’ means an AI system for the purpose of identifying or inferring emotions or intentions of natural persons on the basis of their biometric data;

(40) ‘biometric categorisation system’ means an AI system for the purpose of assigning natural persons to specific categories on the basis of their biometric data, unless it is ancillary to another commercial service and strictly necessary for objective technical reasons;

(41) ‘remote biometric identification system’ means an AI system for the purpose of identifying natural persons, without their active involvement, typically at a distance through the comparison of a person’s biometric data with the biometric data contained in a reference database;

(42) ‘real-time remote biometric identification system’ means a remote biometric identification system, whereby the capturing of biometric data, the comparison and the identification all occur without a significant delay, comprising not only instant identification, but also limited short delays in order to avoid circumvention;

(43) ‘post-remote biometric identification system’ means a remote biometric identification system other than a real-time remote biometric identification system;

(44) ‘publicly accessible space’ means any publicly or privately owned physical place accessible to an undetermined number of natural persons, regardless of whether certain conditions for access may apply, and regardless of the potential capacity restrictions;

(45) ‘law enforcement authority’ means:

(a) any public authority competent for the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security; or

(b) any other body or entity entrusted by Member State law to exercise public authority and public powers for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security;

▼B

(46) ‘law enforcement’ means activities carried out by law enforcement authorities or on their behalf for the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including safeguarding against and preventing threats to public security;

(47) ‘AI Office’ means the Commission’s function of contributing to the implementation, monitoring and supervision of AI systems and general-purpose AI models, and AI governance, provided for in Commission Decision of 24 January 2024; references in this Regulation to the AI Office shall be construed as references to the Commission;

(48) ‘national competent authority’ means a notifying authority or a market surveillance authority; as regards AI systems put into service or used by Union institutions, agencies, offices and bodies, references to national competent authorities or market surveillance authorities in this Regulation shall be construed as references to the European Data Protection Supervisor;

(49) ‘serious incident’ means an incident or malfunctioning of an AI system that directly or indirectly leads to any of the following:

(a) the death of a person, or serious harm to a person’s health;

(b) a serious and irreversible disruption of the management or operation of critical infrastructure;

(c) the infringement of obligations under Union law intended to protect fundamental rights;

(d) serious harm to property or the environment;

(50) ‘personal data’ means personal data as defined in Article 4, point (1), of Regulation (EU) 2016/679;

(51) ‘non-personal data’ means data other than personal data as defined in Article 4, point (1), of Regulation (EU) 2016/679;

(52) ‘profiling’ means profiling as defined in Article 4, point (4), of Regulation (EU) 2016/679;

(53) ‘real-world testing plan’ means a document that describes the objectives, methodology, geographical, population and temporal scope, monitoring, organisation and conduct of testing in real-world conditions;

(54) ‘sandbox plan’ means a document agreed between the participating provider and the competent authority describing the objectives, conditions, timeframe, methodology and requirements for the activities carried out within the sandbox;

(55) ‘AI regulatory sandbox’ means a controlled framework set up by a competent authority which offers providers or prospective providers of AI systems the possibility to develop, train, validate and test, where appropriate in real-world conditions, an innovative AI system, pursuant to a sandbox plan for a limited time under regulatory supervision;

▼B

(56) ‘AI literacy’ means skills, knowledge and understanding that allow providers, deployers and affected persons, taking into account their respective rights and obligations in the context of this Regulation, to make an informed deployment of AI systems, as well as to gain awareness about the opportunities and risks of AI and possible harm it can cause;

(57) ‘testing in real-world conditions’ means the temporary testing of an AI system for its intended purpose in real-world conditions outside a laboratory or otherwise simulated environment, with a view to gathering reliable and robust data and to assessing and verifying the conformity of the AI system with the requirements of this Regulation and it does not qualify as placing the AI system on the market or putting it into service within the meaning of this Regulation, provided that all the conditions laid down in Article 57 or 60 are fulfilled;

(58) ‘subject’, for the purpose of real-world testing, means a natural person who participates in testing in real-world conditions;

(59) ‘informed consent’ means a subject’s freely given, specific, unambiguous and voluntary expression of his or her willingness to participate in a particular testing in real-world conditions, after having been informed of all aspects of the testing that are relevant to the subject’s decision to participate;

(60) ‘deep fake’ means AI-generated or manipulated image, audio or video content that resembles existing persons, objects, places, entities or events and would falsely appear to a person to be authentic or truthful;

(61) ‘widespread infringement’ means any act or omission contrary to Union law protecting the interest of individuals, which:

(a) has harmed or is likely to harm the collective interests of individuals residing in at least two Member States other than the Member State in which:

(i) the act or omission originated or took place;

(ii) the provider concerned, or, where applicable, its authorised representative is located or established; or

(iii) the deployer is established, when the infringement is committed by the deployer;

(b) has caused, causes or is likely to cause harm to the collective interests of individuals and has common features, including the same unlawful practice or the same interest being infringed, and is occurring concurrently, committed by the same operator, in at least three Member States;

(62) ‘critical infrastructure’ means critical infrastructure as defined in Article 2, point (4), of Directive (EU) 2022/2557;

▼B

(63) ‘general-purpose AI model’ means an AI model, including where such an AI model is trained with a large amount of data using self-supervision at scale, that displays significant generality and is capable of competently performing a wide range of distinct tasks regardless of the way the model is placed on the market and that can be integrated into a variety of downstream systems or applications, except AI models that are used for research, development or prototyping activities before they are placed on the market;

(64) ‘high-impact capabilities’ means capabilities that match or exceed the capabilities recorded in the most advanced general-purpose AI models;

(65) ‘systemic risk’ means a risk that is specific to the high-impact capabilities of general-purpose AI models, having a significant impact on the Union market due to their reach, or due to actual or reasonably foreseeable negative effects on public health, safety, public security, fundamental rights, or the society as a whole, that can be propagated at scale across the value chain;

(66) ‘general-purpose AI system’ means an AI system which is based on a general-purpose AI model and which has the capability to serve a variety of purposes, both for direct use as well as for integration in other AI systems;

(67) ‘floating-point operation’ means any mathematical operation or assignment involving floating-point numbers, which are a subset of the real numbers typically represented on computers by an integer of fixed precision scaled by an integer exponent of a fixed base;

(68) ‘downstream provider’ means a provider of an AI system, including a general-purpose AI system, which integrates an AI model, regardless of whether the AI model is provided by themselves and vertically integrated or provided by another entity based on contractual relations.

▼M1

Article 4

AI literacy

1. Providers and deployers of AI systems shall take measures to support the development of AI literacy of their staff and other persons dealing with the operation and use of AI systems on their behalf, taking into account their technical knowledge, experience, education and training and the context the AI systems are to be used in, and considering the persons or groups of persons on whom the AI systems are to be used. This obligation does not require providers or deployers to guarantee any specific level of AI literacy of any individual.

2. The Commission and the Member States shall support and facilitate the efforts of providers and deployers of AI systems, in particular SMEs, in fulfilling their obligation under paragraph 1 of this Article. For that purpose, the Commission shall publish practical examples of how to comply with that obligation on the single information platform referred to in Article 62(3), point (b).

▼M1

3. The Board shall adopt recommendations, taking into account European competence frameworks, to support the Commission and Member States in the promotion of AI literacy required under paragraph 1, including by setting out common objectives.

Article 4a

Processing of special categories of personal data for bias detection and correction

1. To the extent strictly necessary to ensure bias detection and correction in relation to high-risk AI systems in accordance with Article 10(2), points (f) and (g), of this Regulation, providers of such systems may exceptionally process special categories of personal data, subject to appropriate safeguards for the fundamental rights and freedoms of natural persons. In addition to the provisions set out in Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680, as applicable, all the following conditions shall be met in order for such processing to occur:

(a) the bias detection and correction cannot be effectively fulfilled by processing other data, including synthetic or anonymised data;

(b) the special categories of personal data are subject to technical limitations on the re-use of personal data, and state-of-the-art security and privacy-preserving measures, including pseudonymisation;

(c) the special categories of personal data are subject to measures to ensure that the personal data processed are secured and protected, subject to suitable safeguards, including strict controls and documentation of the access, to avoid misuse and to ensure that only authorised persons have access to those personal data with appropriate confidentiality obligations;

(d) the special categories of personal data are not transmitted, transferred or otherwise accessed by other parties;

(e) the special categories of personal data are deleted once the bias has been corrected or the personal data has reached the end of its retention period, whichever comes first; and

(f) the records of processing activities pursuant to Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680 include the reasons why the processing of special categories of personal data was strictly necessary to detect and correct biases, and why that objective could not be achieved by processing other data.

2. Providers and deployers of other AI systems and models and deployers of high-risk AI systems may exceptionally process special categories of personal data to the extent that:

(a) such processing is strictly necessary to ensure bias detection and correction in view of possible biases that are likely to affect the health and safety of persons, have a negative impact on fundamental rights or lead to discrimination prohibited pursuant to Union law, especially where data outputs influence inputs for future operations; and

(b) all of the conditions and safeguards set out in paragraph 1 are applied.

▼M1

This paragraph does not create any obligation to conduct such bias detection and correction.

▼B

CHAPTER II

PROHIBITED AI PRACTICES

Article 5

Prohibited AI practices

1. The following AI practices shall be prohibited:

(a) the placing on the market, the putting into service or the use of an AI system that deploys subliminal techniques beyond a person's consciousness or purposefully manipulative or deceptive techniques, with the objective, or the effect of materially distorting the behaviour of a person or a group of persons by appreciably impairing their ability to make an informed decision, thereby causing them to take a decision that they would not have otherwise taken in a manner that causes or is reasonably likely to cause that person, another person or group of persons significant harm;

(b) the placing on the market, the putting into service or the use of an AI system that exploits any of the vulnerabilities of a natural person or a specific group of persons due to their age, disability or a specific social or economic situation, with the objective, or the effect, of materially distorting the behaviour of that person or a person belonging to that group in a manner that causes or is reasonably likely to cause that person or another person significant harm;

▼M1

(ba) the placing on the market, the putting into service or the use of an AI system that generates or manipulates realistic images, videos, audio or similar material of an identifiable natural person's intimate parts, or of an identifiable natural person engaged in sexually explicit activities, without that person's freely-given, specific, informed, unambiguous and explicit consent for that generation or manipulation;

(bb) the placing on the market, the putting into service or the use of an AI system that generates or manipulates material or performance within the meaning of Article 2, points (c) and (e), of Directive 2011/93/EU, except where a 'without right' defence applies under national law;

▼B

(c) the placing on the market, the putting into service or the use of AI systems for the evaluation or classification of natural persons or groups of persons over a certain period of time based on their social behaviour or known, inferred or predicted personal or personality characteristics, with the social score leading to either or both of the following:

(i) detrimental or unfavourable treatment of certain natural persons or groups of persons in social contexts that are unrelated to the contexts in which the data was originally generated or collected;

▼B

(ii) detrimental or unfavourable treatment of certain natural persons or groups of persons that is unjustified or disproportionate to their social behaviour or its gravity;

(d) the placing on the market, the putting into service for this specific purpose, or the use of an AI system for making risk assessments of natural persons in order to assess or predict the risk of a natural person committing a criminal offence, based solely on the profiling of a natural person or on assessing their personality traits and characteristics; this prohibition shall not apply to AI systems used to support the human assessment of the involvement of a person in a criminal activity, which is already based on objective and verifiable facts directly linked to a criminal activity;

(e) the placing on the market, the putting into service for this specific purpose, or the use of AI systems that create or expand facial recognition databases through the untargeted scraping of facial images from the internet or CCTV footage;

(f) the placing on the market, the putting into service for this specific purpose, or the use of AI systems to infer emotions of a natural person in the areas of workplace and education institutions, except where the use of the AI system is intended to be put in place or into the market for medical or safety reasons;

(g) the placing on the market, the putting into service for this specific purpose, or the use of biometric categorisation systems that categorise individually natural persons based on their biometric data to deduce or infer their race, political opinions, trade union membership, religious or philosophical beliefs, sex life or sexual orientation; this prohibition does not cover any labelling or filtering of lawfully acquired biometric datasets, such as images, based on biometric data or categorizing of biometric data in the area of law enforcement;

(h) the use of 'real-time' remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement, unless and in so far as such use is strictly necessary for one of the following objectives:

(i) the targeted search for specific victims of abduction, trafficking in human beings or sexual exploitation of human beings, as well as the search for missing persons;

(ii) the prevention of a specific, substantial and imminent threat to the life or physical safety of natural persons or a genuine and present or genuine and foreseeable threat of a terrorist attack;

(iii) the localisation or identification of a person suspected of having committed a criminal offence, for the purpose of conducting a criminal investigation or prosecution or executing a criminal penalty for offences referred to in Annex II and punishable in the Member State concerned by a custodial sentence or a detention order for a maximum period of at least four years.

Point (h) of the first subparagraph is without prejudice to Article 9 of Regulation (EU) 2016/679 for the processing of biometric data for purposes other than law enforcement.

▼M1

1a. For the purposes of paragraph 1, first subparagraph, points (ba) and (bb):

(a) the placing on the market or putting into service of an AI system that generates or manipulates the material or performance referred to in paragraph 1, first subparagraph, point (ba) or (bb) is only prohibited where:

(i) that generation or manipulation is the intended purpose of the AI system; or

(ii) the system's design, training, architecture, capabilities or user-facing functionalities make that generation or manipulation a reasonably foreseeable and reproducible outcome, without requiring significant technical modification, and the system does not have reasonable and adequate technical safety measures and other safeguards to reliably prevent that generation or manipulation, taking into account reasonably foreseeable misuse, and to correct observed or reported misuse;

(b) the use of an AI system that generates or manipulates the material or performance referred to in paragraph 1, first subparagraph, points (ba) and (bb) is only prohibited where the deployer uses the system for the purpose of generating or manipulating such material or performance.

1b. For the purposes of paragraph 1, first subparagraph, point (ba), an AI system that manipulates material in a way that does not increase the exposure of any depicted intimate parts or alter the nature of any depicted sexually explicit activities shall not constitute manipulation.

▼B

2. The use of 'real-time' remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement for any of the objectives referred to in paragraph 1, first subparagraph, point (h), shall be deployed for the purposes set out in that point only to confirm the identity of the specifically targeted individual, and it shall take into account the following elements:

(a) the nature of the situation giving rise to the possible use, in particular the seriousness, probability and scale of the harm that would be caused if the system were not used;

(b) the consequences of the use of the system for the rights and freedoms of all persons concerned, in particular the seriousness, probability and scale of those consequences.

In addition, the use of 'real-time' remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement for any of the objectives referred to in paragraph 1, first subparagraph, point (h), of this Article shall comply with necessary and proportionate safeguards and conditions in relation to the use in accordance with the national law authorising the use thereof, in particular as regards the temporal, geographic and personal limitations. The use of the 'real-time' remote biometric identification system in publicly accessible spaces shall be authorised only if the law enforcement authority has completed a fundamental rights impact assessment as provided for in Article 27 and has registered the system in the EU database according to Article 49. However, in duly justified cases of urgency, the use of such systems may be commenced without the registration in the EU database, provided that such registration is completed without undue delay.

▼B

3. For the purposes of paragraph 1, first subparagraph, point (h) and paragraph 2, each use for the purposes of law enforcement of a ‘real-time’ remote biometric identification system in publicly accessible spaces shall be subject to a prior authorisation granted by a judicial authority or an independent administrative authority whose decision is binding of the Member State in which the use is to take place, issued upon a reasoned request and in accordance with the detailed rules of national law referred to in paragraph 5. However, in a duly justified situation of urgency, the use of such system may be commenced without an authorisation provided that such authorisation is requested without undue delay, at the latest within 24 hours. If such authorisation is rejected, the use shall be stopped with immediate effect and all the data, as well as the results and outputs of that use shall be immediately discarded and deleted.

The competent judicial authority or an independent administrative authority whose decision is binding shall grant the authorisation only where it is satisfied, on the basis of objective evidence or clear indications presented to it, that the use of the ‘real-time’ remote biometric identification system concerned is necessary for, and proportionate to, achieving one of the objectives specified in paragraph 1, first subparagraph, point (h), as identified in the request and, in particular, remains limited to what is strictly necessary concerning the period of time as well as the geographic and personal scope. In deciding on the request, that authority shall take into account the elements referred to in paragraph 2. No decision that produces an adverse legal effect on a person may be taken based solely on the output of the ‘real-time’ remote biometric identification system.

4. Without prejudice to paragraph 3, each use of a ‘real-time’ remote biometric identification system in publicly accessible spaces for law enforcement purposes shall be notified to the relevant market surveillance authority and the national data protection authority in accordance with the national rules referred to in paragraph 5. The notification shall, as a minimum, contain the information specified under paragraph 6 and shall not include sensitive operational data.

5. A Member State may decide to provide for the possibility to fully or partially authorise the use of ‘real-time’ remote biometric identification systems in publicly accessible spaces for the purposes of law enforcement within the limits and under the conditions listed in paragraph 1, first subparagraph, point (h), and paragraphs 2 and 3. Member States concerned shall lay down in their national law the necessary detailed rules for the request, issuance and exercise of, as well as supervision and reporting relating to, the authorisations referred to in paragraph 3. Those rules shall also specify in respect of which of the objectives listed in paragraph 1, first subparagraph, point (h), including which of the criminal offences referred to in point (h)(iii) thereof, the competent authorities may be authorised to use those systems for the purposes of law enforcement. Member States shall notify those rules to the Commission at the latest 30 days following the adoption thereof. Member States may introduce, in accordance with Union law, more restrictive laws on the use of remote biometric identification systems.

▼B

6. National market surveillance authorities and the national data protection authorities of Member States that have been notified of the use of 'real-time' remote biometric identification systems in publicly accessible spaces for law enforcement purposes pursuant to paragraph 4 shall submit to the Commission annual reports on such use. For that purpose, the Commission shall provide Member States and national market surveillance and data protection authorities with a template, including information on the number of the decisions taken by competent judicial authorities or an independent administrative authority whose decision is binding upon requests for authorisations in accordance with paragraph 3 and their result.

7. The Commission shall publish annual reports on the use of real-time remote biometric identification systems in publicly accessible spaces for law enforcement purposes, based on aggregated data in Member States on the basis of the annual reports referred to in paragraph 6. Those annual reports shall not include sensitive operational data of the related law enforcement activities.

8. This Article shall not affect the prohibitions that apply where an AI practice infringes other Union law.

CHAPTER III

HIGH-RISK AI SYSTEMS

SECTION 1

Classification of AI systems as high-risk

Article 6

Classification rules for high-risk AI systems

1. Irrespective of whether an AI system is placed on the market or put into service independently of the products referred to in points (a) and (b), that AI system shall be considered to be high-risk where both of the following conditions are fulfilled:

(a) the AI system is intended to be used as a safety component of a product, or the AI system is itself a product, covered by the Union harmonisation legislation listed in Annex I;

(b) the product whose safety component pursuant to point (a) is the AI system, or the AI system itself as a product, is required to undergo a third-party conformity assessment, with a view to the placing on the market or the putting into service of that product pursuant to the Union harmonisation legislation listed in Annex I.

▼M1

1a. For the purposes of this Regulation, including paragraph 1 of this Article, AI systems that are solely used for non-safety related aspects of user assistance, performance optimisation, service efficiency, automation or convenience or quality control shall not qualify as safety components.

1b. Notwithstanding paragraph 1a, AI systems the failure or malfunctioning of which would endanger health and safety shall qualify as safety components.

▼M1

1c. A product that is required to undergo a third-party conformity assessment solely due to risks other than risks to health and safety, in particular risks relating to the distribution of radio spectrum or electromagnetic interference that do not affect health and safety, shall not be considered as fulfilling the condition in paragraph 1, point (b).

▼B

2. In addition to the high-risk AI systems referred to in paragraph 1, AI systems referred to in Annex III shall be considered to be high-risk.

3. By derogation from paragraph 2, an AI system referred to in Annex III shall not be considered to be high-risk where it does not pose a significant risk of harm to the health, safety or fundamental rights of natural persons, including by not materially influencing the outcome of decision making.

The first subparagraph shall apply where any of the following conditions is fulfilled:

(a) the AI system is intended to perform a narrow procedural task;

(b) the AI system is intended to improve the result of a previously completed human activity;

(c) the AI system is intended to detect decision-making patterns or deviations from prior decision-making patterns and is not meant to replace or influence the previously completed human assessment, without proper human review; or

(d) the AI system is intended to perform a preparatory task to an assessment relevant for the purposes of the use cases listed in Annex III.

Notwithstanding the first subparagraph, an AI system referred to in Annex III shall always be considered to be high-risk where the AI system performs profiling of natural persons.

4. A provider who considers that an AI system referred to in Annex III is not high-risk shall document its assessment before that system is placed on the market or put into service. Such provider shall be subject to the registration obligation set out in Article 49(2). Upon request of national competent authorities, the provider shall provide the documentation of the assessment.

5. The Commission shall, after consulting the European Artificial Intelligence Board (the ‘Board’), and no later than 2 February 2026, provide guidelines specifying the practical implementation of this Article in line with Article 96 together with a comprehensive list of practical examples of use cases of AI systems that are high-risk and not high-risk.

6. The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend paragraph 3, second subparagraph, of this Article by adding new conditions to those laid down therein, or by modifying them, where there is concrete and reliable evidence of the existence of AI systems that fall under the scope of Annex III, but do not pose a significant risk of harm to the health, safety or fundamental rights of natural persons.

▼B

7. The Commission shall adopt delegated acts in accordance with Article 97 in order to amend paragraph 3, second subparagraph, of this Article by deleting any of the conditions laid down therein, where there is concrete and reliable evidence that this is necessary to maintain the level of protection of health, safety and fundamental rights provided for by this Regulation.

8. Any amendment to the conditions laid down in paragraph 3, second subparagraph, adopted in accordance with paragraphs 6 and 7 of this Article shall not decrease the overall level of protection of health, safety and fundamental rights provided for by this Regulation and shall ensure consistency with the delegated acts adopted pursuant to Article 7(1), and take account of market and technological developments.

Article 7

Amendments to Annex III

1. The Commission is empowered to adopt delegated acts in accordance with Article 97 to amend Annex III by adding or modifying use-cases of high-risk AI systems where both of the following conditions are fulfilled:

(a) the AI systems are intended to be used in any of the areas listed in Annex III;

(b) the AI systems pose a risk of harm to health and safety, or an adverse impact on fundamental rights, and that risk is equivalent to, or greater than, the risk of harm or of adverse impact posed by the high-risk AI systems already referred to in Annex III.

2. When assessing the condition under paragraph 1, point (b), the Commission shall take into account the following criteria:

(a) the intended purpose of the AI system;

(b) the extent to which an AI system has been used or is likely to be used;

(c) the nature and amount of the data processed and used by the AI system, in particular whether special categories of personal data are processed;

(d) the extent to which the AI system acts autonomously and the possibility for a human to override a decision or recommendations that may lead to potential harm;

(e) the extent to which the use of an AI system has already caused harm to health and safety, has had an adverse impact on fundamental rights or has given rise to significant concerns in relation to the likelihood of such harm or adverse impact, as demonstrated, for example, by reports or documented allegations submitted to national competent authorities or by other reports, as appropriate;

▼B

(f) the potential extent of such harm or such adverse impact, in particular in terms of its intensity and its ability to affect multiple persons or to disproportionately affect a particular group of persons;

(g) the extent to which persons who are potentially harmed or suffer an adverse impact are dependent on the outcome produced with an AI system, in particular because for practical or legal reasons it is not reasonably possible to opt-out from that outcome;

(h) the extent to which there is an imbalance of power, or the persons who are potentially harmed or suffer an adverse impact are in a vulnerable position in relation to the deployer of an AI system, in particular due to status, authority, knowledge, economic or social circumstances, or age;

(i) the extent to which the outcome produced involving an AI system is easily corrigible or reversible, taking into account the technical solutions available to correct or reverse it, whereby outcomes having an adverse impact on health, safety or fundamental rights, shall not be considered to be easily corrigible or reversible;

(j) the magnitude and likelihood of benefit of the deployment of the AI system for individuals, groups, or society at large, including possible improvements in product safety;

(k) the extent to which existing Union law provides for:

(i) effective measures of redress in relation to the risks posed by an AI system, with the exclusion of claims for damages;

(ii) effective measures to prevent or substantially minimise those risks.

3. The Commission is empowered to adopt delegated acts in accordance with Article 97 to amend the list in Annex III by removing high-risk AI systems where both of the following conditions are fulfilled:

(a) the high-risk AI system concerned no longer poses any significant risks to fundamental rights, health or safety, taking into account the criteria listed in paragraph 2;

(b) the deletion does not decrease the overall level of protection of health, safety and fundamental rights under Union law.

SECTION 2

Requirements for high-risk AI systems

Article 8

Compliance with the requirements

1. High-risk AI systems shall comply with the requirements laid down in this Section, taking into account their intended purpose as well as the generally acknowledged state of the art on AI and AI-related technologies. The risk management system referred to in Article 9 shall be taken into account when ensuring compliance with those requirements.

▼B

2. Where a product contains an AI system, to which the requirements of this Regulation as well as requirements of the Union harmonisation legislation listed in Section A of Annex I apply, providers shall be responsible for ensuring that their product is fully compliant with all applicable requirements under applicable Union harmonisation legislation. In ensuring the compliance of high-risk AI systems referred to in paragraph 1 with the requirements set out in this Section, and in order to ensure consistency, avoid duplication and minimise additional burdens, providers shall have a choice of integrating, as appropriate, the necessary testing and reporting processes, information and documentation they provide with regard to their product into documentation and procedures that already exist and are required under the Union harmonisation legislation listed in Section A of Annex I.

Article 9

Risk management system

1. A risk management system shall be established, implemented, documented and maintained in relation to high-risk AI systems.

2. The risk management system shall be understood as a continuous iterative process planned and run throughout the entire lifecycle of a high-risk AI system, requiring regular systematic review and updating. It shall comprise the following steps:

(a) the identification and analysis of the known and the reasonably foreseeable risks that the high-risk AI system can pose to health, safety or fundamental rights when the high-risk AI system is used in accordance with its intended purpose;

(b) the estimation and evaluation of the risks that may emerge when the high-risk AI system is used in accordance with its intended purpose, and under conditions of reasonably foreseeable misuse;

(c) the evaluation of other risks possibly arising, based on the analysis of data gathered from the post-market monitoring system referred to in Article 72;

(d) the adoption of appropriate and targeted risk management measures designed to address the risks identified pursuant to point (a).

3. The risks referred to in this Article shall concern only those which may be reasonably mitigated or eliminated through the development or design of the high-risk AI system, or the provision of adequate technical information.

4. The risk management measures referred to in paragraph 2, point (d), shall give due consideration to the effects and possible interaction resulting from the combined application of the requirements set out in this Section, with a view to minimising risks more effectively while achieving an appropriate balance in implementing the measures to fulfil those requirements.

5. The risk management measures referred to in paragraph 2, point (d), shall be such that the relevant residual risk associated with each hazard, as well as the overall residual risk of the high-risk AI systems is judged to be acceptable.

▼B

In identifying the most appropriate risk management measures, the following shall be ensured:

(a) elimination or reduction of risks identified and evaluated pursuant to paragraph 2 in as far as technically feasible through adequate design and development of the high-risk AI system;

(b) where appropriate, implementation of adequate mitigation and control measures addressing risks that cannot be eliminated;

(c) provision of information required pursuant to Article 13 and, where appropriate, training to deployers.

With a view to eliminating or reducing risks related to the use of the high-risk AI system, due consideration shall be given to the technical knowledge, experience, education, the training to be expected by the deployer, and the presumable context in which the system is intended to be used.

6. High-risk AI systems shall be tested for the purpose of identifying the most appropriate and targeted risk management measures. Testing shall ensure that high-risk AI systems perform consistently for their intended purpose and that they are in compliance with the requirements set out in this Section.

7. Testing procedures may include testing in real-world conditions in accordance with Article 60.

8. The testing of high-risk AI systems shall be performed, as appropriate, at any time throughout the development process, and, in any event, prior to their being placed on the market or put into service. Testing shall be carried out against prior defined metrics and probabilistic thresholds that are appropriate to the intended purpose of the high-risk AI system.

9. When implementing the risk management system as provided for in paragraphs 1 to 7, providers shall give consideration to whether in view of its intended purpose the high-risk AI system is likely to have an adverse impact on persons under the age of 18 and, as appropriate, other vulnerable groups.

10. For providers of high-risk AI systems that are subject to requirements regarding internal risk management processes under other relevant provisions of Union law, the aspects provided in paragraphs 1 to 9 may be part of, or combined with, the risk management procedures established pursuant to that law.

Article 10

Data and data governance

▼M1

1. High-risk AI systems which make use of techniques involving the training of AI models with data shall be developed on the basis of training, validation and testing data sets that meet the quality criteria referred to in paragraphs 2, 3 and 4 of this Article and in Article 4a(1) whenever such data sets are used.

▼B

2. Training, validation and testing data sets shall be subject to data governance and management practices appropriate for the intended purpose of the high-risk AI system. Those practices shall concern in particular:

(a) the relevant design choices;

(b) data collection processes and the origin of data, and in the case of personal data, the original purpose of the data collection;

(c) relevant data-preparation processing operations, such as annotation, labelling, cleaning, updating, enrichment and aggregation;

(d) the formulation of assumptions, in particular with respect to the information that the data are supposed to measure and represent;

(e) an assessment of the availability, quantity and suitability of the data sets that are needed;

(f) examination in view of possible biases that are likely to affect the health and safety of persons, have a negative impact on fundamental rights or lead to discrimination prohibited under Union law, especially where data outputs influence inputs for future operations;

(g) appropriate measures to detect, prevent and mitigate possible biases identified according to point (f);

(h) the identification of relevant data gaps or shortcomings that prevent compliance with this Regulation, and how those gaps and shortcomings can be addressed.

3. Training, validation and testing data sets shall be relevant, sufficiently representative, and to the best extent possible, free of errors and complete in view of the intended purpose. They shall have the appropriate statistical properties, including, where applicable, as regards the persons or groups of persons in relation to whom the high-risk AI system is intended to be used. Those characteristics of the data sets may be met at the level of individual data sets or at the level of a combination thereof.

4. Data sets shall take into account, to the extent required by the intended purpose, the characteristics or elements that are particular to the specific geographical, contextual, behavioural or functional setting within which the high-risk AI system is intended to be used.

▼M1

_____

6. For the development of high-risk AI systems not using techniques involving the training of AI models, paragraphs 2, 3 and 4 of this Article and Article 4a(1) shall apply only to the testing data sets.

▼B

Article 11

Technical documentation

1. The technical documentation of a high-risk AI system shall be drawn up before that system is placed on the market or put into service and shall be kept up-to date.

▼M1

That technical documentation shall be drawn up in such a way as to demonstrate that the high-risk AI system complies with the requirements set out in this Section and to provide national competent authorities and notified bodies with the necessary information in a clear and comprehensive form to assess the compliance of the AI system with those requirements. It shall contain, at a minimum, the elements set out in Annex IV. SMEs, including start-ups, and SMCs, may provide the elements of the technical documentation specified in Annex IV in a simplified manner. To that end, the Commission shall establish a simplified technical documentation form targeted at the needs of SMEs, including start-ups, and SMCs. Where an SME, including a start-up, or an SMC, opts to provide the information required in Annex IV in a simplified manner, it shall use the form referred to in this paragraph. Notified bodies shall accept the form for the purposes of the conformity assessment.

▼B

2. Where a high-risk AI system related to a product covered by the Union harmonisation legislation listed in Section A of Annex I is placed on the market or put into service, a single set of technical documentation shall be drawn up containing all the information set out in paragraph 1, as well as the information required under those legal acts.

3. The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annex IV, where necessary, to ensure that, in light of technical progress, the technical documentation provides all the information necessary to assess the compliance of the system with the requirements set out in this Section.

Article 12

Record-keeping

1. High-risk AI systems shall technically allow for the automatic recording of events (logs) over the lifetime of the system.

2. In order to ensure a level of traceability of the functioning of a high-risk AI system that is appropriate to the intended purpose of the system, logging capabilities shall enable the recording of events relevant for:

(a) identifying situations that may result in the high-risk AI system presenting a risk within the meaning of Article 79(1) or in a substantial modification;

(b) facilitating the post-market monitoring referred to in Article 72; and

(c) monitoring the operation of high-risk AI systems referred to in Article 26(5).

▼B

3. For high-risk AI systems referred to in point 1 (a), of Annex III, the logging capabilities shall provide, at a minimum:

(a) recording of the period of each use of the system (start date and time and end date and time of each use);

(b) the reference database against which input data has been checked by the system;

(c) the input data for which the search has led to a match;

(d) the identification of the natural persons involved in the verification of the results, as referred to in Article 14(5).

Article 13

Transparency and provision of information to deployers

1. High-risk AI systems shall be designed and developed in such a way as to ensure that their operation is sufficiently transparent to enable deployers to interpret a system's output and use it appropriately. An appropriate type and degree of transparency shall be ensured with a view to achieving compliance with the relevant obligations of the provider and deployer set out in Section 3.

2. High-risk AI systems shall be accompanied by instructions for use in an appropriate digital format or otherwise that include concise, complete, correct and clear information that is relevant, accessible and comprehensible to deployers.

3. The instructions for use shall contain at least the following information:

(a) the identity and the contact details of the provider and, where applicable, of its authorised representative;

(b) the characteristics, capabilities and limitations of performance of the high-risk AI system, including:

(i) its intended purpose;

(ii) the level of accuracy, including its metrics, robustness and cybersecurity referred to in Article 15 against which the high-risk AI system has been tested and validated and which can be expected, and any known and foreseeable circumstances that may have an impact on that expected level of accuracy, robustness and cybersecurity;

(iii) any known or foreseeable circumstance, related to the use of the high-risk AI system in accordance with its intended purpose or under conditions of reasonably foreseeable misuse, which may lead to risks to the health and safety or fundamental rights referred to in Article 9(2);

(iv) where applicable, the technical capabilities and characteristics of the high-risk AI system to provide information that is relevant to explain its output;

▼B

(v) when appropriate, its performance regarding specific persons or groups of persons on which the system is intended to be used;

(vi) when appropriate, specifications for the input data, or any other relevant information in terms of the training, validation and testing data sets used, taking into account the intended purpose of the high-risk AI system;

(vii) where applicable, information to enable deployers to interpret the output of the high-risk AI system and use it appropriately;

(c) the changes to the high-risk AI system and its performance which have been pre-determined by the provider at the moment of the initial conformity assessment, if any;

(d) the human oversight measures referred to in Article 14, including the technical measures put in place to facilitate the interpretation of the outputs of the high-risk AI systems by the deployers;

(e) the computational and hardware resources needed, the expected lifetime of the high-risk AI system and any necessary maintenance and care measures, including their frequency, to ensure the proper functioning of that AI system, including as regards software updates;

(f) where relevant, a description of the mechanisms included within the high-risk AI system that allows deployers to properly collect, store and interpret the logs in accordance with Article 12.

Article 14

Human oversight

1. High-risk AI systems shall be designed and developed in such a way, including with appropriate human-machine interface tools, that they can be effectively overseen by natural persons during the period in which they are in use.

2. Human oversight shall aim to prevent or minimise the risks to health, safety or fundamental rights that may emerge when a high-risk AI system is used in accordance with its intended purpose or under conditions of reasonably foreseeable misuse, in particular where such risks persist despite the application of other requirements set out in this Section.

3. The oversight measures shall be commensurate with the risks, level of autonomy and context of use of the high-risk AI system, and shall be ensured through either one or both of the following types of measures:

(a) measures identified and built, when technically feasible, into the high-risk AI system by the provider before it is placed on the market or put into service;

(b) measures identified by the provider before placing the high-risk AI system on the market or putting it into service and that are appropriate to be implemented by the deployer.

▼B

4. For the purpose of implementing paragraphs 1, 2 and 3, the high-risk AI system shall be provided to the deployer in such a way that natural persons to whom human oversight is assigned are enabled, as appropriate and proportionate:

(a) to properly understand the relevant capacities and limitations of the high-risk AI system and be able to duly monitor its operation, including in view of detecting and addressing anomalies, dysfunctions and unexpected performance;

(b) to remain aware of the possible tendency of automatically relying or over-relying on the output produced by a high-risk AI system (automation bias), in particular for high-risk AI systems used to provide information or recommendations for decisions to be taken by natural persons;

(c) to correctly interpret the high-risk AI system's output, taking into account, for example, the interpretation tools and methods available;

(d) to decide, in any particular situation, not to use the high-risk AI system or to otherwise disregard, override or reverse the output of the high-risk AI system;

(e) to intervene in the operation of the high-risk AI system or interrupt the system through a 'stop' button or a similar procedure that allows the system to come to a halt in a safe state.

5. For high-risk AI systems referred to in point 1(a) of Annex III, the measures referred to in paragraph 3 of this Article shall be such as to ensure that, in addition, no action or decision is taken by the deployer on the basis of the identification resulting from the system unless that identification has been separately verified and confirmed by at least two natural persons with the necessary competence, training and authority.

The requirement for a separate verification by at least two natural persons shall not apply to high-risk AI systems used for the purposes of law enforcement, migration, border control or asylum, where Union or national law considers the application of this requirement to be disproportionate.

Article 15

Accuracy, robustness and cybersecurity

1. High-risk AI systems shall be designed and developed in such a way that they achieve an appropriate level of accuracy, robustness, and cybersecurity, and that they perform consistently in those respects throughout their lifecycle.

2. To address the technical aspects of how to measure the appropriate levels of accuracy and robustness set out in paragraph 1 and any other relevant performance metrics, the Commission shall, in cooperation with relevant stakeholders and organisations such as metrology and benchmarking authorities, encourage, as appropriate, the development of benchmarks and measurement methodologies.

3. The levels of accuracy and the relevant accuracy metrics of high-risk AI systems shall be declared in the accompanying instructions of use.

▼B

4. High-risk AI systems shall be as resilient as possible regarding errors, faults or inconsistencies that may occur within the system or the environment in which the system operates, in particular due to their interaction with natural persons or other systems. Technical and organisational measures shall be taken in this regard.

The robustness of high-risk AI systems may be achieved through technical redundancy solutions, which may include backup or fail-safe plans.

High-risk AI systems that continue to learn after being placed on the market or put into service shall be developed in such a way as to eliminate or reduce as far as possible the risk of possibly biased outputs influencing input for future operations (feedback loops), and as to ensure that any such feedback loops are duly addressed with appropriate mitigation measures.

5. High-risk AI systems shall be resilient against attempts by unauthorised third parties to alter their use, outputs or performance by exploiting system vulnerabilities.

The technical solutions aiming to ensure the cybersecurity of high-risk AI systems shall be appropriate to the relevant circumstances and the risks.

The technical solutions to address AI specific vulnerabilities shall include, where appropriate, measures to prevent, detect, respond to, resolve and control for attacks trying to manipulate the training data set (data poisoning), or pre-trained components used in training (model poisoning), inputs designed to cause the AI model to make a mistake (adversarial examples or model evasion), confidentiality attacks or model flaws.

SECTION 3

Obligations of providers and deployers of high-risk AI systems and other parties

Article 16

Obligations of providers of high-risk AI systems

Providers of high-risk AI systems shall:

(a) ensure that their high-risk AI systems are compliant with the requirements set out in Section 2;

(b) indicate on the high-risk AI system or, where that is not possible, on its packaging or its accompanying documentation, as applicable, their name, registered trade name or registered trade mark, the address at which they can be contacted;

(c) have a quality management system in place which complies with Article 17;

(d) keep the documentation referred to in Article 18;

(e) when under their control, keep the logs automatically generated by their high-risk AI systems as referred to in Article 19;

▼B

(f) ensure that the high-risk AI system undergoes the relevant conformity assessment procedure as referred to in Article 43, prior to its being placed on the market or put into service;

(g) draw up an EU declaration of conformity in accordance with Article 47;

(h) affix the CE marking to the high-risk AI system or, where that is not possible, on its packaging or its accompanying documentation, to indicate conformity with this Regulation, in accordance with Article 48;

(i) comply with the registration obligations referred to in Article 49(1);

(j) take the necessary corrective actions and provide information as required in Article 20;

(k) upon a reasoned request of a national competent authority, demonstrate the conformity of the high-risk AI system with the requirements set out in Section 2;

(l) ensure that the high-risk AI system complies with accessibility requirements in accordance with Directives (EU) 2016/2102 and (EU) 2019/882.

Article 17

Quality management system

1. Providers of high-risk AI systems shall put a quality management system in place that ensures compliance with this Regulation. That system shall be documented in a systematic and orderly manner in the form of written policies, procedures and instructions, and shall include at least the following aspects:

(a) a strategy for regulatory compliance, including compliance with conformity assessment procedures and procedures for the management of modifications to the high-risk AI system;

(b) techniques, procedures and systematic actions to be used for the design, design control and design verification of the high-risk AI system;

(c) techniques, procedures and systematic actions to be used for the development, quality control and quality assurance of the high-risk AI system;

(d) examination, test and validation procedures to be carried out before, during and after the development of the high-risk AI system, and the frequency with which they have to be carried out;

(e) technical specifications, including standards, to be applied and, where the relevant harmonised standards are not applied in full or do not cover all of the relevant requirements set out in Section 2, the means to be used to ensure that the high-risk AI system complies with those requirements;

▼B

(f) systems and procedures for data management, including data acquisition, data collection, data analysis, data labelling, data storage, data filtration, data mining, data aggregation, data retention and any other operation regarding the data that is performed before and for the purpose of the placing on the market or the putting into service of high-risk AI systems;

(g) the risk management system referred to in Article 9;

(h) the setting-up, implementation and maintenance of a post-market monitoring system, in accordance with Article 72;

(i) procedures related to the reporting of a serious incident in accordance with Article 73;

(j) the handling of communication with national competent authorities, other relevant authorities, including those providing or supporting the access to data, notified bodies, other operators, customers or other interested parties;

(k) systems and procedures for record-keeping of all relevant documentation and information;

(l) resource management, including security-of-supply related measures;

(m) an accountability framework setting out the responsibilities of the management and other staff with regard to all the aspects listed in this paragraph.

▼M1

2. The implementation of the aspects referred to in paragraph 1 shall be proportionate to the size of the provider's organisation, in particular, if the provider is an SME, including a start-up, or an SMC. Providers shall, in any event, respect the degree of rigour and the level of protection required to ensure the compliance of their high-risk AI systems with this Regulation.

▼B

3. Providers of high-risk AI systems that are subject to obligations regarding quality management systems or an equivalent function under relevant sectoral Union law may include the aspects listed in paragraph 1 as part of the quality management systems pursuant to that law.

4. For providers that are financial institutions subject to requirements regarding their internal governance, arrangements or processes under Union financial services law, the obligation to put in place a quality management system, with the exception of paragraph 1, points (g), (h) and (i) of this Article, shall be deemed to be fulfilled by complying with the rules on internal governance arrangements or processes pursuant to the relevant Union financial services law. To that end, any harmonised standards referred to in Article 40 shall be taken into account.

Article 18

Documentation keeping

1. The provider shall, for a period ending 10 years after the high-risk AI system has been placed on the market or put into service, keep at the disposal of the national competent authorities:

▼B

(a) the technical documentation referred to in Article 11;

(b) the documentation concerning the quality management system referred to in Article 17;

(c) the documentation concerning the changes approved by notified bodies, where applicable;

(d) the decisions and other documents issued by the notified bodies, where applicable;

(e) the EU declaration of conformity referred to in Article 47.

2. Each Member State shall determine conditions under which the documentation referred to in paragraph 1 remains at the disposal of the national competent authorities for the period indicated in that paragraph for the cases when a provider or its authorised representative established on its territory goes bankrupt or ceases its activity prior to the end of that period.

3. Providers that are financial institutions subject to requirements regarding their internal governance, arrangements or processes under Union financial services law shall maintain the technical documentation as part of the documentation kept under the relevant Union financial services law.

Article 19

Automatically generated logs

1. Providers of high-risk AI systems shall keep the logs referred to in Article 12(1), automatically generated by their high-risk AI systems, to the extent such logs are under their control. Without prejudice to applicable Union or national law, the logs shall be kept for a period appropriate to the intended purpose of the high-risk AI system, of at least six months, unless provided otherwise in the applicable Union or national law, in particular in Union law on the protection of personal data.

2. Providers that are financial institutions subject to requirements regarding their internal governance, arrangements or processes under Union financial services law shall maintain the logs automatically generated by their high-risk AI systems as part of the documentation kept under the relevant financial services law.

Article 20

Corrective actions and duty of information

1. Providers of high-risk AI systems which consider or have reason to consider that a high-risk AI system that they have placed on the market or put into service is not in conformity with this Regulation shall immediately take the necessary corrective actions to bring that system into conformity, to withdraw it, to disable it, or to recall it, as appropriate. They shall inform the distributors of the high-risk AI system concerned and, where applicable, the deployers, the authorised representative and importers accordingly.

▼B

2. Where the high-risk AI system presents a risk within the meaning of Article 79(1) and the provider becomes aware of that risk, it shall immediately investigate the causes, in collaboration with the reporting deployer, where applicable, and inform the market surveillance authorities competent for the high-risk AI system concerned and, where applicable, the notified body that issued a certificate for that high-risk AI system in accordance with Article 44, in particular, of the nature of the non-compliance and of any relevant corrective action taken.

Article 21

Cooperation with competent authorities

1. Providers of high-risk AI systems shall, upon a reasoned request by a competent authority, provide that authority all the information and documentation necessary to demonstrate the conformity of the high-risk AI system with the requirements set out in Section 2, in a language which can be easily understood by the authority in one of the official languages of the institutions of the Union as indicated by the Member State concerned.

2. Upon a reasoned request by a competent authority, providers shall also give the requesting competent authority, as applicable, access to the automatically generated logs of the high-risk AI system referred to in Article 12(1), to the extent such logs are under their control.

3. Any information obtained by a competent authority pursuant to this Article shall be treated in accordance with the confidentiality obligations set out in Article 78.

Article 22

Authorised representatives of providers of high-risk AI systems

1. Prior to making their high-risk AI systems available on the Union market, providers established in third countries shall, by written mandate, appoint an authorised representative which is established in the Union.

2. The provider shall enable its authorised representative to perform the tasks specified in the mandate received from the provider.

3. The authorised representative shall perform the tasks specified in the mandate received from the provider. It shall provide a copy of the mandate to the market surveillance authorities upon request, in one of the official languages of the institutions of the Union, as indicated by the competent authority. For the purposes of this Regulation, the mandate shall empower the authorised representative to carry out the following tasks:

(a) verify that the EU declaration of conformity referred to in Article 47 and the technical documentation referred to in Article 11 have been drawn up and that an appropriate conformity assessment procedure has been carried out by the provider;

▼B

(b) keep at the disposal of the competent authorities and national authorities or bodies referred to in Article 74(10), for a period of 10 years after the high-risk AI system has been placed on the market or put into service, the contact details of the provider that appointed the authorised representative, a copy of the EU declaration of conformity referred to in Article 47, the technical documentation and, if applicable, the certificate issued by the notified body;

(c) provide a competent authority, upon a reasoned request, with all the information and documentation, including that referred to in point (b) of this subparagraph, necessary to demonstrate the conformity of a high-risk AI system with the requirements set out in Section 2, including access to the logs, as referred to in Article 12(1), automatically generated by the high-risk AI system, to the extent such logs are under the control of the provider;

(d) cooperate with competent authorities, upon a reasoned request, in any action the latter take in relation to the high-risk AI system, in particular to reduce and mitigate the risks posed by the high-risk AI system;

(e) where applicable, comply with the registration obligations referred to in Article 49(1), or, if the registration is carried out by the provider itself, ensure that the information referred to in point 3 of Section A of Annex VIII is correct.

The mandate shall empower the authorised representative to be addressed, in addition to or instead of the provider, by the competent authorities, on all issues related to ensuring compliance with this Regulation.

4. The authorised representative shall terminate the mandate if it considers or has reason to consider the provider to be acting contrary to its obligations pursuant to this Regulation. In such a case, it shall immediately inform the relevant market surveillance authority, as well as, where applicable, the relevant notified body, about the termination of the mandate and the reasons therefor.

Article 23

Obligations of importers

1. Before placing a high-risk AI system on the market, importers shall ensure that the system is in conformity with this Regulation by verifying that:

(a) the relevant conformity assessment procedure referred to in Article 43 has been carried out by the provider of the high-risk AI system;

(b) the provider has drawn up the technical documentation in accordance with Article 11 and Annex IV;

(c) the system bears the required CE marking and is accompanied by the EU declaration of conformity referred to in Article 47 and instructions for use;

(d) the provider has appointed an authorised representative in accordance with Article 22(1).

▼B

2. Where an importer has sufficient reason to consider that a high-risk AI system is not in conformity with this Regulation, or is falsified, or accompanied by falsified documentation, it shall not place the system on the market until it has been brought into conformity. Where the high-risk AI system presents a risk within the meaning of Article 79(1), the importer shall inform the provider of the system, the authorised representative and the market surveillance authorities to that effect.

3. Importers shall indicate their name, registered trade name or registered trade mark, and the address at which they can be contacted on the high-risk AI system and on its packaging or its accompanying documentation, where applicable.

4. Importers shall ensure that, while a high-risk AI system is under their responsibility, storage or transport conditions, where applicable, do not jeopardise its compliance with the requirements set out in Section 2.

5. Importers shall keep, for a period of 10 years after the high-risk AI system has been placed on the market or put into service, a copy of the certificate issued by the notified body, where applicable, of the instructions for use, and of the EU declaration of conformity referred to in Article 47.

6. Importers shall provide the relevant competent authorities, upon a reasoned request, with all the necessary information and documentation, including that referred to in paragraph 5, to demonstrate the conformity of a high-risk AI system with the requirements set out in Section 2 in a language which can be easily understood by them. For this purpose, they shall also ensure that the technical documentation can be made available to those authorities.

7. Importers shall cooperate with the relevant competent authorities in any action those authorities take in relation to a high-risk AI system placed on the market by the importers, in particular to reduce and mitigate the risks posed by it.

Article 24

Obligations of distributors

1. Before making a high-risk AI system available on the market, distributors shall verify that it bears the required CE marking, that it is accompanied by a copy of the EU declaration of conformity referred to in Article 47 and instructions for use, and that the provider and the importer of that system, as applicable, have complied with their respective obligations as laid down in Article 16, points (b) and (c) and Article 23(3).

2. Where a distributor considers or has reason to consider, on the basis of the information in its possession, that a high-risk AI system is not in conformity with the requirements set out in Section 2, it shall not make the high-risk AI system available on the market until the system has been brought into conformity with those requirements. Furthermore, where the high-risk AI system presents a risk within the meaning of Article 79(1), the distributor shall inform the provider or the importer of the system, as applicable, to that effect.

▼B

3. Distributors shall ensure that, while a high-risk AI system is under their responsibility, storage or transport conditions, where applicable, do not jeopardise the compliance of the system with the requirements set out in Section 2.

4. A distributor that considers or has reason to consider, on the basis of the information in its possession, a high-risk AI system which it has made available on the market not to be in conformity with the requirements set out in Section 2, shall take the corrective actions necessary to bring that system into conformity with those requirements, to withdraw it or recall it, or shall ensure that the provider, the importer or any relevant operator, as appropriate, takes those corrective actions. Where the high-risk AI system presents a risk within the meaning of Article 79(1), the distributor shall immediately inform the provider or importer of the system and the authorities competent for the high-risk AI system concerned, giving details, in particular, of the non-compliance and of any corrective actions taken.

5. Upon a reasoned request from a relevant competent authority, distributors of a high-risk AI system shall provide that authority with all the information and documentation regarding their actions pursuant to paragraphs 1 to 4 necessary to demonstrate the conformity of that system with the requirements set out in Section 2.

6. Distributors shall cooperate with the relevant competent authorities in any action those authorities take in relation to a high-risk AI system made available on the market by the distributors, in particular to reduce or mitigate the risk posed by it.

Article 25

Responsibilities along the AI value chain

1. Any distributor, importer, deployer or other third-party shall be considered to be a provider of a high-risk AI system for the purposes of this Regulation and shall be subject to the obligations of the provider under Article 16, in any of the following circumstances:

(a) they put their name or trademark on a high-risk AI system already placed on the market or put into service, without prejudice to contractual arrangements stipulating that the obligations are otherwise allocated;

(b) they make a substantial modification to a high-risk AI system that has already been placed on the market or has already been put into service in such a way that it remains a high-risk AI system pursuant to Article 6;

(c) they modify the intended purpose of an AI system, including a general-purpose AI system, which has not been classified as high-risk and has already been placed on the market or put into service in such a way that the AI system concerned becomes a high-risk AI system in accordance with Article 6.

▼M1

2. Where the circumstances referred to in paragraph 1 occur, the provider that initially placed the AI system on the market or put it into service shall no longer be considered to be a provider of that specific AI system for the purposes of this Regulation.

That initial provider shall closely cooperate with new providers and shall make available the necessary information and provide the reasonably expected technical access and other assistance that are required for the fulfilment of the obligations set out in this Regulation, in particular with regard to compliance with the conformity assessment of high-risk AI systems.

In particular, the obligation laid down in the second subparagraph shall include, where relevant for the purposes specified therein, the following:

(a) making available of technical documentation sufficient to assess compliance with the requirements laid down in Article 16;

(b) informing the new providers about known limitations and failure modes; and

(c) providing the new providers with targeted technical access, including for testing and validation.

This paragraph shall not apply in cases where the initial provider has clearly specified that its AI system is not to be changed into a high-risk AI system and therefore does not fall under the obligation to cooperate with the new providers and hand over the documentation.

▼B

3. In the case of high-risk AI systems that are safety components of products covered by the Union harmonisation legislation listed in Section A of Annex I, the product manufacturer shall be considered to be the provider of the high-risk AI system, and shall be subject to the obligations under Article 16 under either of the following circumstances:

(a) the high-risk AI system is placed on the market together with the product under the name or trademark of the product manufacturer;

(b) the high-risk AI system is put into service under the name or trademark of the product manufacturer after the product has been placed on the market.

▼M1

4. The provider of a high-risk AI system and the third party that supplies an AI system, AI model, tools, services, components, or processes that are used or integrated in a high-risk AI system shall, by written agreement, specify the necessary information, capabilities, technical access and other assistance based on the generally acknowledged state of the art, in order to enable the provider of the high-risk AI system to fully comply with the obligations set out in this Regulation. This paragraph shall not apply to third parties making accessible to the public tools, services, processes, or components, other than general-purpose AI models, under a free and open-source licence.

▼B

The AI Office may develop and recommend voluntary model terms for contracts between providers of high-risk AI systems and third parties that supply tools, services, components or processes that are used for or integrated into high-risk AI systems. When developing those voluntary model terms, the AI Office shall take into account possible contractual requirements applicable in specific sectors or business cases. The voluntary model terms shall be published and be available free of charge in an easily usable electronic format.

5. Paragraphs 2 and 3 are without prejudice to the need to observe and protect intellectual property rights, confidential business information and trade secrets in accordance with Union and national law.

Article 26

Obligations of deployers of high-risk AI systems

1. Deployers of high-risk AI systems shall take appropriate technical and organisational measures to ensure they use such systems in accordance with the instructions for use accompanying the systems, pursuant to paragraphs 3 and 6.

2. Deployers shall assign human oversight to natural persons who have the necessary competence, training and authority, as well as the necessary support.

3. The obligations set out in paragraphs 1 and 2, are without prejudice to other deployer obligations under Union or national law and to the deployer's freedom to organise its own resources and activities for the purpose of implementing the human oversight measures indicated by the provider.

4. Without prejudice to paragraphs 1 and 2, to the extent the deployer exercises control over the input data, that deployer shall ensure that input data is relevant and sufficiently representative in view of the intended purpose of the high-risk AI system.

5. Deployers shall monitor the operation of the high-risk AI system on the basis of the instructions for use and, where relevant, inform providers in accordance with Article 72. Where deployers have reason to consider that the use of the high-risk AI system in accordance with the instructions may result in that AI system presenting a risk within the meaning of Article 79(1), they shall, without undue delay, inform the provider or distributor and the relevant market surveillance authority, and shall suspend the use of that system. Where deployers have identified a serious incident, they shall also immediately inform first the provider, and then the importer or distributor and the relevant market surveillance authorities of that incident. If the deployer is not able to reach the provider, Article 73 shall apply *mutatis mutandis*. This obligation shall not cover sensitive operational data of deployers of AI systems which are law enforcement authorities.

For deployers that are financial institutions subject to requirements regarding their internal governance, arrangements or processes under Union financial services law, the monitoring obligation set out in the first subparagraph shall be deemed to be fulfilled by complying with the rules on internal governance arrangements, processes and mechanisms pursuant to the relevant financial service law.

▼B

6. Deployers of high-risk AI systems shall keep the logs automatically generated by that high-risk AI system to the extent such logs are under their control, for a period appropriate to the intended purpose of the high-risk AI system, of at least six months, unless provided otherwise in applicable Union or national law, in particular in Union law on the protection of personal data.

Deployers that are financial institutions subject to requirements regarding their internal governance, arrangements or processes under Union financial services law shall maintain the logs as part of the documentation kept pursuant to the relevant Union financial service law.

7. Before putting into service or using a high-risk AI system at the workplace, deployers who are employers shall inform workers' representatives and the affected workers that they will be subject to the use of the high-risk AI system. This information shall be provided, where applicable, in accordance with the rules and procedures laid down in Union and national law and practice on information of workers and their representatives.

8. Deployers of high-risk AI systems that are public authorities, or Union institutions, bodies, offices or agencies shall comply with the registration obligations referred to in Article 49. When such deployers find that the high-risk AI system that they envisage using has not been registered in the EU database referred to in Article 71, they shall not use that system and shall inform the provider or the distributor.

9. Where applicable, deployers of high-risk AI systems shall use the information provided under Article 13 of this Regulation to comply with their obligation to carry out a data protection impact assessment under Article 35 of Regulation (EU) 2016/679 or Article 27 of Directive (EU) 2016/680.

10. Without prejudice to Directive (EU) 2016/680, in the framework of an investigation for the targeted search of a person suspected or convicted of having committed a criminal offence, the deployer of a high-risk AI system for post-remote biometric identification shall request an authorisation, *ex ante*, or without undue delay and no later than 48 hours, by a judicial authority or an administrative authority whose decision is binding and subject to judicial review, for the use of that system, except when it is used for the initial identification of a potential suspect based on objective and verifiable facts directly linked to the offence. Each use shall be limited to what is strictly necessary for the investigation of a specific criminal offence.

If the authorisation requested pursuant to the first subparagraph is rejected, the use of the post-remote biometric identification system linked to that requested authorisation shall be stopped with immediate effect and the personal data linked to the use of the high-risk AI system for which the authorisation was requested shall be deleted.

In no case shall such high-risk AI system for post-remote biometric identification be used for law enforcement purposes in an untargeted way, without any link to a criminal offence, a criminal proceeding, a genuine and present or genuine and foreseeable threat of a criminal offence, or the search for a specific missing person. It shall be ensured that no decision that produces an adverse legal effect on a person may be taken by the law enforcement authorities based solely on the output of such post-remote biometric identification systems.

▼B

This paragraph is without prejudice to Article 9 of Regulation (EU) 2016/679 and Article 10 of Directive (EU) 2016/680 for the processing of biometric data.

Regardless of the purpose or deployer, each use of such high-risk AI systems shall be documented in the relevant police file and shall be made available to the relevant market surveillance authority and the national data protection authority upon request, excluding the disclosure of sensitive operational data related to law enforcement. This subparagraph shall be without prejudice to the powers conferred by Directive (EU) 2016/680 on supervisory authorities.

Deployers shall submit annual reports to the relevant market surveillance and national data protection authorities on their use of post-remote biometric identification systems, excluding the disclosure of sensitive operational data related to law enforcement. The reports may be aggregated to cover more than one deployment.

Member States may introduce, in accordance with Union law, more restrictive laws on the use of post-remote biometric identification systems.

11. Without prejudice to Article 50 of this Regulation, deployers of high-risk AI systems referred to in Annex III that make decisions or assist in making decisions related to natural persons shall inform the natural persons that they are subject to the use of the high-risk AI system. For high-risk AI systems used for law enforcement purposes Article 13 of Directive (EU) 2016/680 shall apply.

12. Deployers shall cooperate with the relevant competent authorities in any action those authorities take in relation to the high-risk AI system in order to implement this Regulation.

Article 27

Fundamental rights impact assessment for high-risk AI systems

1. Prior to deploying a high-risk AI system referred to in Article 6(2), with the exception of high-risk AI systems intended to be used in the area listed in point 2 of Annex III, deployers that are bodies governed by public law, or are private entities providing public services, and deployers of high-risk AI systems referred to in points 5 (b) and (c) of Annex III, shall perform an assessment of the impact on fundamental rights that the use of such system may produce. For that purpose, deployers shall perform an assessment consisting of:

(a) a description of the deployer's processes in which the high-risk AI system will be used in line with its intended purpose;

(b) a description of the period of time within which, and the frequency with which, each high-risk AI system is intended to be used;

(c) the categories of natural persons and groups likely to be affected by its use in the specific context;

(d) the specific risks of harm likely to have an impact on the categories of natural persons or groups of persons identified pursuant to point (c) of this paragraph, taking into account the information given by the provider pursuant to Article 13;

▼B

(e) a description of the implementation of human oversight measures, according to the instructions for use;

(f) the measures to be taken in the case of the materialisation of those risks, including the arrangements for internal governance and complaint mechanisms.

2. The obligation laid down in paragraph 1 applies to the first use of the high-risk AI system. The deployer may, in similar cases, rely on previously conducted fundamental rights impact assessments or existing impact assessments carried out by provider. If, during the use of the high-risk AI system, the deployer considers that any of the elements listed in paragraph 1 has changed or is no longer up to date, the deployer shall take the necessary steps to update the information.

3. Once the assessment referred to in paragraph 1 of this Article has been performed, the deployer shall notify the market surveillance authority of its results, submitting the filled-out template referred to in paragraph 5 of this Article as part of the notification. In the case referred to in Article 46(1), deployers may be exempt from that obligation to notify.

▼M1

4. If any of the obligations laid down in this Article is already met through the data protection impact assessment conducted pursuant to Article 35 of Regulation (EU) 2016/679 or Article 27 of Directive (EU) 2016/680, the deployer may, when conducting the fundamental rights impact assessment referred to in paragraph 1 of this Article, include cross-references to the relevant sections of that data protection impact assessment or include relevant parts thereof in the fundamental rights impact assessment.

5. The AI Office shall develop a template for a questionnaire, including through an automated tool, to facilitate deployers in complying with their obligations under this Article in a simplified manner. This template shall, where relevant, give deployers the possibility to include cross-references to the relevant sections of the data protection impact assessment or include relevant parts thereof in the fundamental rights impact assessment pursuant to paragraph 4.

▼B

SECTION 4

Notifying authorities and notified bodies

Article 28

Notifying authorities

1. Each Member State shall designate or establish at least one notifying authority responsible for setting up and carrying out the necessary procedures for the assessment, designation and notification of conformity assessment bodies and for their monitoring. Those procedures shall be developed in cooperation between the notifying authorities of all Member States.

2. Member States may decide that the assessment and monitoring referred to in paragraph 1 is to be carried out by a national accreditation body within the meaning of, and in accordance with, Regulation (EC) No 765/2008.

▼B

3. Notifying authorities shall be established, organised and operated in such a way that no conflict of interest arises with conformity assessment bodies, and that the objectivity and impartiality of their activities are safeguarded.

4. Notifying authorities shall be organised in such a way that decisions relating to the notification of conformity assessment bodies are taken by competent persons different from those who carried out the assessment of those bodies.

5. Notifying authorities shall offer or provide neither any activities that conformity assessment bodies perform, nor any consultancy services on a commercial or competitive basis.

6. Notifying authorities shall safeguard the confidentiality of the information that they obtain, in accordance with Article 78.

7. Notifying authorities shall have an adequate number of competent personnel at their disposal for the proper performance of their tasks. Competent personnel shall have the necessary expertise, where applicable, for their function, in fields such as information technologies, AI and law, including the supervision of fundamental rights.

▼M1

8. Notifying authorities designated pursuant to this Regulation that are responsible for AI systems covered by the Union harmonisation legislation listed in Section A of Annex I shall ensure that the conformity assessment body that applies for designation both pursuant to this Regulation and the Union harmonisation legislation listed in Section A of Annex I is provided with the possibility to submit a single application and undergoes a unified assessment procedure to be designated pursuant to this Regulation and Union harmonisation legislation listed in Section A of Annex I, where the relevant Union harmonisation legislation provides for such single application and unified assessment procedure. To that end, notifying authorities designated pursuant to this Regulation and those designated pursuant to the Union harmonisation legislation listed in Section A of Annex I shall cooperate in their assessments.

The single application and the unified assessment procedure referred to in this paragraph shall also be made available to notified bodies already designated pursuant to the Union harmonisation legislation listed in Section A of Annex I, when those notified bodies apply for designation pursuant to this Regulation, provided that the relevant Union harmonisation legislation provides for such a procedure.

A conformity assessment body that is designated pursuant to more than one piece of Union harmonisation legislation listed in Section A of Annex I shall have to apply only once to be designated pursuant to this Regulation. A designation pursuant to this Regulation shall be applicable for all Union harmonisation legislation listed in Section A of Annex I for which the conformity assessment body is designated.

The single application and the unified assessment procedure shall avoid any unnecessary duplications, build on the existing procedures for designation in accordance with the Union harmonisation legislation listed in Section A of Annex I and ensure compliance with the requirements relating to notified bodies both in accordance with this Regulation and the relevant Union harmonisation legislation.

▼M1

9. A notifying authority that has been designated pursuant to the Union harmonisation legislation listed in Section A of Annex I is also the notifying authority for the application of the single application and unified assessment procedure referred to in paragraph 8, unless the Member State designates another notifying authority for this Regulation.

▼B

Article 29

Application of a conformity assessment body for notification

1. Conformity assessment bodies shall submit an application for notification to the notifying authority of the Member State in which they are established.

2. The application for notification shall be accompanied by a description of the conformity assessment activities, the conformity assessment module or modules and the types of AI systems for which the conformity assessment body claims to be competent, as well as by an accreditation certificate, where one exists, issued by a national accreditation body attesting that the conformity assessment body fulfils the requirements laid down in Article 31.

Any valid document related to existing designations of the applicant notified body under any other Union harmonisation legislation shall be added.

3. Where the conformity assessment body concerned cannot provide an accreditation certificate, it shall provide the notifying authority with all the documentary evidence necessary for the verification, recognition and regular monitoring of its compliance with the requirements laid down in Article 31.

▼M1

4. For notified bodies which are designated pursuant to any other Union harmonisation legislation, all documents and certificates linked to those designations may be used to support and expedite their designation procedure under this Regulation, as appropriate.

Notified bodies, which are designated pursuant to any of the Union harmonisation legislation listed in Section A of Annex I and which undergo the unified assessment procedure referred to in Article 28(8), shall submit the single application for assessment to the notifying authority designated pursuant to that Union harmonisation legislation.

The notified body shall update the documentation referred to in paragraphs 2 and 3 of this Article whenever relevant changes occur, in order to enable the authority responsible for notified bodies to monitor and verify continuous compliance with all the requirements laid down in Article 31.

▼B

Article 30

Notification procedure

1. Notifying authorities may notify only conformity assessment bodies which have satisfied the requirements laid down in Article 31.

▼M1

2. Notifying authorities shall notify the Commission and the other Member States, based on the list of codes, categories, and corresponding types of AI systems referred to in Annex XIV, and using the electronic notification tool developed and managed by the Commission, of each conformity assessment body referred to in paragraph 1.

The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annex XIV, in light of technical progress, advances in knowledge or new scientific evidence by adding to the list of codes, categories, and corresponding types of AI systems a new code, a category or a type of AI system, withdrawing an existing code, category or a type of AI system from that list or moving a code or type of AI system from one category to another.

▼B

3. The notification referred to in paragraph 2 of this Article shall include full details of the conformity assessment activities, the conformity assessment module or modules, the types of AI systems concerned, and the relevant attestation of competence. Where a notification is not based on an accreditation certificate as referred to in Article 29(2), the notifying authority shall provide the Commission and the other Member States with documentary evidence which attests to the competence of the conformity assessment body and to the arrangements in place to ensure that that body will be monitored regularly and will continue to satisfy the requirements laid down in Article 31.

4. The conformity assessment body concerned may perform the activities of a notified body only where no objections are raised by the Commission or the other Member States within two weeks of a notification by a notifying authority where it includes an accreditation certificate referred to in Article 29(2), or within two months of a notification by the notifying authority where it includes documentary evidence referred to in Article 29(3).

5. Where objections are raised, the Commission shall, without delay, enter into consultations with the relevant Member States and the conformity assessment body. In view thereof, the Commission shall decide whether the authorisation is justified. The Commission shall address its decision to the Member State concerned and to the relevant conformity assessment body.

Article 31

Requirements relating to notified bodies

1. A notified body shall be established under the national law of a Member State and shall have legal personality.

2. Notified bodies shall satisfy the organisational, quality management, resources and process requirements that are necessary to fulfil their tasks, as well as suitable cybersecurity requirements.

3. The organisational structure, allocation of responsibilities, reporting lines and operation of notified bodies shall ensure confidence in their performance, and in the results of the conformity assessment activities that the notified bodies conduct.

▼B

4. Notified bodies shall be independent of the provider of a high-risk AI system in relation to which they perform conformity assessment activities. Notified bodies shall also be independent of any other operator having an economic interest in high-risk AI systems assessed, as well as of any competitors of the provider. This shall not preclude the use of assessed high-risk AI systems that are necessary for the operations of the conformity assessment body, or the use of such high-risk AI systems for personal purposes.

5. Neither a conformity assessment body, its top-level management nor the personnel responsible for carrying out its conformity assessment tasks shall be directly involved in the design, development, marketing or use of high-risk AI systems, nor shall they represent the parties engaged in those activities. They shall not engage in any activity that might conflict with their independence of judgement or integrity in relation to conformity assessment activities for which they are notified. This shall, in particular, apply to consultancy services.

6. Notified bodies shall be organised and operated so as to safeguard the independence, objectivity and impartiality of their activities. Notified bodies shall document and implement a structure and procedures to safeguard impartiality and to promote and apply the principles of impartiality throughout their organisation, personnel and assessment activities.

7. Notified bodies shall have documented procedures in place ensuring that their personnel, committees, subsidiaries, subcontractors and any associated body or personnel of external bodies maintain, in accordance with Article 78, the confidentiality of the information which comes into their possession during the performance of conformity assessment activities, except when its disclosure is required by law. The staff of notified bodies shall be bound to observe professional secrecy with regard to all information obtained in carrying out their tasks under this Regulation, except in relation to the notifying authorities of the Member State in which their activities are carried out.

8. Notified bodies shall have procedures for the performance of activities which take due account of the size of a provider, the sector in which it operates, its structure, and the degree of complexity of the AI system concerned.

9. Notified bodies shall take out appropriate liability insurance for their conformity assessment activities, unless liability is assumed by the Member State in which they are established in accordance with national law or that Member State is itself directly responsible for the conformity assessment.

10. Notified bodies shall be capable of carrying out all their tasks under this Regulation with the highest degree of professional integrity and the requisite competence in the specific field, whether those tasks are carried out by notified bodies themselves or on their behalf and under their responsibility.

11. Notified bodies shall have sufficient internal competences to be able effectively to evaluate the tasks conducted by external parties on their behalf. The notified body shall have permanent availability of sufficient administrative, technical, legal and scientific personnel who possess experience and knowledge relating to the relevant types of AI systems, data and data computing, and relating to the requirements set out in Section 2.

▼B

12. Notified bodies shall participate in coordination activities as referred to in Article 38. They shall also take part directly, or be represented in, European standardisation organisations, or ensure that they are aware and up to date in respect of relevant standards.

Article 32

Presumption of conformity with requirements relating to notified bodies

Where a conformity assessment body demonstrates its conformity with the criteria laid down in the relevant harmonised standards or parts thereof, the references of which have been published in the *Official Journal of the European Union*, it shall be presumed to comply with the requirements set out in Article 31 in so far as the applicable harmonised standards cover those requirements.

Article 33

Subsidiaries of notified bodies and subcontracting

1. Where a notified body subcontracts specific tasks connected with the conformity assessment or has recourse to a subsidiary, it shall ensure that the subcontractor or the subsidiary meets the requirements laid down in Article 31, and shall inform the notifying authority accordingly.

2. Notified bodies shall take full responsibility for the tasks performed by any subcontractors or subsidiaries.

3. Activities may be subcontracted or carried out by a subsidiary only with the agreement of the provider. Notified bodies shall make a list of their subsidiaries publicly available.

4. The relevant documents concerning the assessment of the qualifications of the subcontractor or the subsidiary and the work carried out by them under this Regulation shall be kept at the disposal of the notifying authority for a period of five years from the termination date of the subcontracting.

Article 34

Operational obligations of notified bodies

1. Notified bodies shall verify the conformity of high-risk AI systems in accordance with the conformity assessment procedures set out in Article 43.

2. Notified bodies shall avoid unnecessary burdens for providers when performing their activities, and take due account of the size of the provider, the sector in which it operates, its structure and the degree of complexity of the high-risk AI system concerned, in particular in view of minimising administrative burdens and compliance costs for micro- and small enterprises within the meaning of Recommendation 2003/361/EC. The notified body shall, nevertheless, respect the degree of rigour and the level of protection required for the compliance of the high-risk AI system with the requirements of this Regulation.

▼B

3. Notified bodies shall make available and submit upon request all relevant documentation, including the providers' documentation, to the notifying authority referred to in Article 28 to allow that authority to conduct its assessment, designation, notification and monitoring activities, and to facilitate the assessment outlined in this Section.

Article 35

Identification numbers and lists of notified bodies

1. The Commission shall assign a single identification number to each notified body, even where a body is notified under more than one Union act.

2. The Commission shall make publicly available the list of the bodies notified under this Regulation, including their identification numbers and the activities for which they have been notified. The Commission shall ensure that the list is kept up to date.

Article 36

Changes to notifications

1. The notifying authority shall notify the Commission and the other Member States of any relevant changes to the notification of a notified body via the electronic notification tool referred to in Article 30(2).

2. The procedures laid down in Articles 29 and 30 shall apply to extensions of the scope of the notification.

For changes to the notification other than extensions of its scope, the procedures laid down in paragraphs (3) to (9) shall apply.

3. Where a notified body decides to cease its conformity assessment activities, it shall inform the notifying authority and the providers concerned as soon as possible and, in the case of a planned cessation, at least one year before ceasing its activities. The certificates of the notified body may remain valid for a period of nine months after cessation of the notified body's activities, on condition that another notified body has confirmed in writing that it will assume responsibilities for the high-risk AI systems covered by those certificates. The latter notified body shall complete a full assessment of the high-risk AI systems affected by the end of that nine-month-period before issuing new certificates for those systems. Where the notified body has ceased its activity, the notifying authority shall withdraw the designation.

4. Where a notifying authority has sufficient reason to consider that a notified body no longer meets the requirements laid down in Article 31, or that it is failing to fulfil its obligations, the notifying authority shall without delay investigate the matter with the utmost diligence. In that context, it shall inform the notified body concerned about the objections raised and give it the possibility to make its views known. If the notifying authority comes to the conclusion that the notified body no longer meets the requirements laid down in Article 31 or that it is failing to fulfil its obligations, it shall restrict, suspend or withdraw the designation as appropriate, depending on the seriousness of the failure to meet those requirements or fulfil those obligations. It shall immediately inform the Commission and the other Member States accordingly.

▼B

5. Where its designation has been suspended, restricted, or fully or partially withdrawn, the notified body shall inform the providers concerned within 10 days.

6. In the event of the restriction, suspension or withdrawal of a designation, the notifying authority shall take appropriate steps to ensure that the files of the notified body concerned are kept, and to make them available to notifying authorities in other Member States and to market surveillance authorities at their request.

7. In the event of the restriction, suspension or withdrawal of a designation, the notifying authority shall:

(a) assess the impact on the certificates issued by the notified body;

(b) submit a report on its findings to the Commission and the other Member States within three months of having notified the changes to the designation;

(c) require the notified body to suspend or withdraw, within a reasonable period of time determined by the authority, any certificates which were unduly issued, in order to ensure the continuing conformity of high-risk AI systems on the market;

(d) inform the Commission and the Member States about certificates the suspension or withdrawal of which it has required;

(e) provide the national competent authorities of the Member State in which the provider has its registered place of business with all relevant information about the certificates of which it has required the suspension or withdrawal; that authority shall take the appropriate measures, where necessary, to avoid a potential risk to health, safety or fundamental rights.

8. With the exception of certificates unduly issued, and where a designation has been suspended or restricted, the certificates shall remain valid in one of the following circumstances:

(a) the notifying authority has confirmed, within one month of the suspension or restriction, that there is no risk to health, safety or fundamental rights in relation to certificates affected by the suspension or restriction, and the notifying authority has outlined a timeline for actions to remedy the suspension or restriction; or

(b) the notifying authority has confirmed that no certificates relevant to the suspension will be issued, amended or re-issued during the course of the suspension or restriction, and states whether the notified body has the capability of continuing to monitor and remain responsible for existing certificates issued for the period of the suspension or restriction; in the event that the notifying authority determines that the notified body does not have the capability to support existing certificates issued, the provider of the system covered by the certificate shall confirm in writing to the national competent authorities of the Member State in which it has its registered place of business, within three months of the suspension or restriction, that another qualified notified body is temporarily assuming the functions of the notified body to monitor and remain responsible for the certificates during the period of suspension or restriction.

▼B

9. With the exception of certificates unduly issued, and where a designation has been withdrawn, the certificates shall remain valid for a period of nine months under the following circumstances:

(a) the national competent authority of the Member State in which the provider of the high-risk AI system covered by the certificate has its registered place of business has confirmed that there is no risk to health, safety or fundamental rights associated with the high-risk AI systems concerned; and

(b) another notified body has confirmed in writing that it will assume immediate responsibility for those AI systems and completes its assessment within 12 months of the withdrawal of the designation.

In the circumstances referred to in the first subparagraph, the national competent authority of the Member State in which the provider of the system covered by the certificate has its place of business may extend the provisional validity of the certificates for additional periods of three months, which shall not exceed 12 months in total.

The national competent authority or the notified body assuming the functions of the notified body affected by the change of designation shall immediately inform the Commission, the other Member States and the other notified bodies thereof.

Article 37

Challenge to the competence of notified bodies

1. The Commission shall, where necessary, investigate all cases where there are reasons to doubt the competence of a notified body or the continued fulfilment by a notified body of the requirements laid down in Article 31 and of its applicable responsibilities.

2. The notifying authority shall provide the Commission, on request, with all relevant information relating to the notification or the maintenance of the competence of the notified body concerned.

3. The Commission shall ensure that all sensitive information obtained in the course of its investigations pursuant to this Article is treated confidentially in accordance with Article 78.

4. Where the Commission ascertains that a notified body does not meet or no longer meets the requirements for its notification, it shall inform the notifying Member State accordingly and request it to take the necessary corrective measures, including the suspension or withdrawal of the notification if necessary. Where the Member State fails to take the necessary corrective measures, the Commission may, by means of an implementing act, suspend, restrict or withdraw the designation. That implementing act shall be adopted in accordance with the examination procedure referred to in Article 98(2).

▼B

Article 38

Coordination of notified bodies

1. The Commission shall ensure that, with regard to high-risk AI systems, appropriate coordination and cooperation between notified bodies active in the conformity assessment procedures pursuant to this Regulation are put in place and properly operated in the form of a sectoral group of notified bodies.

2. Each notifying authority shall ensure that the bodies notified by it participate in the work of a group referred to in paragraph 1, directly or through designated representatives.

3. The Commission shall provide for the exchange of knowledge and best practices between notifying authorities.

Article 39

Conformity assessment bodies of third countries

Conformity assessment bodies established under the law of a third country with which the Union has concluded an agreement may be authorised to carry out the activities of notified bodies under this Regulation, provided that they meet the requirements laid down in Article 31 or they ensure an equivalent level of compliance.

SECTION 5

Standards, conformity assessment, certificates, registration

Article 40

Harmonised standards and standardisation deliverables

1. High-risk AI systems or general-purpose AI models which are in conformity with harmonised standards or parts thereof the references of which have been published in the *Official Journal of the European Union* in accordance with Regulation (EU) No 1025/2012 shall be presumed to be in conformity with the requirements set out in Section 2 of this Chapter or, as applicable, with the obligations set out in of Chapter V, Sections 2 and 3, of this Regulation, to the extent that those standards cover those requirements or obligations.

2. In accordance with Article 10 of Regulation (EU) No 1025/2012, the Commission shall issue, without undue delay, standardisation requests covering all requirements set out in Section 2 of this Chapter and, as applicable, standardisation requests covering obligations set out in Chapter V, Sections 2 and 3, of this Regulation. The standardisation request shall also ask for deliverables on reporting and documentation processes to improve AI systems' resource performance, such as reducing the high-risk AI system's consumption of energy and of other resources during its lifecycle, and on the energy-efficient development of general-purpose AI models. When preparing a standardisation request, the Commission shall consult the Board and relevant stakeholders, including the advisory forum.

▼B

When issuing a standardisation request to European standardisation organisations, the Commission shall specify that standards have to be clear, consistent, including with the standards developed in the various sectors for products covered by the existing Union harmonisation legislation listed in Annex I, and aiming to ensure that high-risk AI systems or general-purpose AI models placed on the market or put into service in the Union meet the relevant requirements or obligations laid down in this Regulation.

The Commission shall request the European standardisation organisations to provide evidence of their best efforts to fulfil the objectives referred to in the first and the second subparagraph of this paragraph in accordance with Article 24 of Regulation (EU) No 1025/2012.

▼M1

The Commission shall request, in accordance with Regulation (EU) No 1025/2012 of the European Parliament and of the Council [1] and without undue delay, the European standardisation organisations to develop standardisation deliverables, including, as appropriate, harmonised standards, to facilitate the joint compliance and presumption of conformity with the requirements or obligations set out in Chapter III, Sections 2 and 3 of this Regulation, and the relevant requirements and obligations laid down in the Union harmonisation legislation listed in Annex I to this Regulation.

▼B

3. The participants in the standardisation process shall seek to promote investment and innovation in AI, including through increasing legal certainty, as well as the competitiveness and growth of the Union market, to contribute to strengthening global cooperation on standardisation and taking into account existing international standards in the field of AI that are consistent with Union values, fundamental rights and interests, and to enhance multi-stakeholder governance ensuring a balanced representation of interests and the effective participation of all relevant stakeholders in accordance with Articles 5, 6, and 7 of Regulation (EU) No 1025/2012.

Article 41

Common specifications

1. The Commission may adopt, implementing acts establishing common specifications for the requirements set out in Section 2 of this Chapter or, as applicable, for the obligations set out in Sections 2 and 3 of Chapter V where the following conditions have been fulfilled:

(a) the Commission has requested, pursuant to Article 10(1) of Regulation (EU) No 1025/2012, one or more European standardisation organisations to draft a harmonised standard for the requirements set out in Section 2 of this Chapter, or, as applicable, for the obligations set out in Sections 2 and 3 of Chapter V, and:

(i) the request has not been accepted by any of the European standardisation organisations; or

[1] Regulation (EU) No 1025/2012 of the European Parliament and of the Council of 25 October 2012 on European standardisation, amending Council Directives 89/686/EEC and 93/15/EEC and Directives 94/9/EC, 94/25/EC, 95/16/EC, 97/23/EC, 98/34/EC, 2004/22/EC, 2007/23/EC, 2009/23/EC and 2009/105/EC of the European Parliament and of the Council and repealing Council Decision 87/95/EEC and Decision No 1673/2006/EC of the European Parliament and of the Council (OJ L 316, 14.11.2012, p. 12, ELI: http://data.europa.eu/eli/reg/2012/1025/oj).

▼B

(ii) the harmonised standards addressing that request are not delivered within the deadline set in accordance with Article 10(1) of Regulation (EU) No 1025/2012; or

(iii) the relevant harmonised standards insufficiently address fundamental rights concerns; or

(iv) the harmonised standards do not comply with the request; and

(b) no reference to harmonised standards covering the requirements referred to in Section 2 of this Chapter or, as applicable, the obligations referred to in Sections 2 and 3 of Chapter V has been published in the *Official Journal of the European Union* in accordance with Regulation (EU) No 1025/2012, and no such reference is expected to be published within a reasonable period.

When drafting the common specifications, the Commission shall consult the advisory forum referred to in Article 67.

The implementing acts referred to in the first subparagraph of this paragraph shall be adopted in accordance with the examination procedure referred to in Article 98(2).

2. Before preparing a draft implementing act, the Commission shall inform the committee referred to in Article 22 of Regulation (EU) No 1025/2012 that it considers the conditions laid down in paragraph 1 of this Article to be fulfilled.

3. High-risk AI systems or general-purpose AI models which are in conformity with the common specifications referred to in paragraph 1, or parts of those specifications, shall be presumed to be in conformity with the requirements set out in Section 2 of this Chapter or, as applicable, to comply with the obligations referred to in Sections 2 and 3 of Chapter V, to the extent those common specifications cover those requirements or those obligations.

4. Where a harmonised standard is adopted by a European standardisation organisation and proposed to the Commission for the publication of its reference in the *Official Journal of the European Union*, the Commission shall assess the harmonised standard in accordance with Regulation (EU) No 1025/2012. When reference to a harmonised standard is published in the *Official Journal of the European Union*, the Commission shall repeal the implementing acts referred to in paragraph 1, or parts thereof which cover the same requirements set out in Section 2 of this Chapter or, as applicable, the same obligations set out in Sections 2 and 3 of Chapter V.

5. Where providers of high-risk AI systems or general-purpose AI models do not comply with the common specifications referred to in paragraph 1, they shall duly justify that they have adopted technical solutions that meet the requirements referred to in Section 2 of this Chapter or, as applicable, comply with the obligations set out in Sections 2 and 3 of Chapter V to a level at least equivalent thereto.

6. Where a Member State considers that a common specification does not entirely meet the requirements set out in Section 2 or, as applicable, comply with obligations set out in Sections 2 and 3 of Chapter V, it shall inform the Commission thereof with a detailed explanation. The Commission shall assess that information and, if appropriate, amend the implementing act establishing the common specification concerned.

▼B

Article 42

Presumption of conformity with certain requirements

1. High-risk AI systems that have been trained and tested on data reflecting the specific geographical, behavioural, contextual or functional setting within which they are intended to be used shall be presumed to comply with the relevant requirements laid down in Article 10(4).

2. High-risk AI systems that have been certified or for which a statement of conformity has been issued under a cybersecurity scheme pursuant to Regulation (EU) 2019/881 and the references of which have been published in the *Official Journal of the European Union* shall be presumed to comply with the cybersecurity requirements set out in Article 15 of this Regulation in so far as the cybersecurity certificate or statement of conformity or parts thereof cover those requirements.

▼M1

3. Where high-risk AI systems fall within the scope of Regulation (EU) 2024/2847 and the conditions laid down in Article 12(1) of that Regulation are fulfilled, such systems shall be deemed to comply with the cybersecurity requirements set out in Article 15 of this Regulation.

▼B

Article 43

Conformity assessment

1. For high-risk AI systems listed in point 1 of Annex III, where, in demonstrating the compliance of a high-risk AI system with the requirements set out in Section 2, the provider has applied harmonised standards referred to in Article 40, or, where applicable, common specifications referred to in Article 41, the provider shall opt for one of the following conformity assessment procedures based on:

(a) the internal control referred to in Annex VI; or

(b) the assessment of the quality management system and the assessment of the technical documentation, with the involvement of a notified body, referred to in Annex VII.

In demonstrating the compliance of a high-risk AI system with the requirements set out in Section 2, the provider shall follow the conformity assessment procedure set out in Annex VII where:

(a) harmonised standards referred to in Article 40 do not exist, and common specifications referred to in Article 41 are not available;

(b) the provider has not applied, or has applied only part of, the harmonised standard;

(c) the common specifications referred to in point (a) exist, but the provider has not applied them;

(d) one or more of the harmonised standards referred to in point (a) has been published with a restriction, and only on the part of the standard that was restricted.

▼B

For the purposes of the conformity assessment procedure referred to in Annex VII, the provider may choose any of the notified bodies. However, where the high-risk AI system is intended to be put into service by law enforcement, immigration or asylum authorities or by Union institutions, bodies, offices or agencies, the market surveillance authority referred to in Article 74(8) or (9), as applicable, shall act as a notified body.

2. For high-risk AI systems referred to in points 2 to 8 of Annex III, providers shall follow the conformity assessment procedure based on internal control as referred to in Annex VI, which does not provide for the involvement of a notified body.

▼M1

3. For high-risk AI systems covered by the Union harmonisation legislation listed in Section A of Annex I, the provider of the system shall follow the relevant conformity assessment procedure as required in accordance with the relevant Union harmonisation legislation. The requirements set out in Section 2 of this Chapter shall apply to those high-risk AI systems and shall be part of that assessment. Assessment of the quality management system set out in Article 17 shall also be undertaken, and points 3, 4.3, 4.4. and 4.5, the fifth paragraph of point 4.6 and point 5 of Annex VII shall apply.

For the purposes of that conformity assessment, notified bodies which have been notified under the Union harmonisation legislation listed in Section A of Annex I shall have the power to assess the conformity of high-risk AI systems with the requirements set out in Section 2 of this Chapter, provided that the compliance of those notified bodies with the requirements laid down in Article 31(4), (5), (10) and (11) has been assessed in the context of the notification procedure in accordance with the relevant Union harmonisation legislation, which is evidenced through the assessment as part of the existing notification. Without prejudice to Article 28, such notified bodies which have been notified under the Union harmonisation legislation in Section A of Annex I, shall apply for designation in accordance with Section 4 of this Chapter by 28 January 2028.

Where Union harmonisation legislation listed in Section A of Annex I provides the product manufacturer with an option to rely on a conformity assessment that does not involve a third-party, provided that that manufacturer has applied harmonised standards to ensure compliance with all the relevant requirements, that manufacturer may use that option only if it has also applied harmonised standards or, where applicable, common specifications referred to in Article 41, covering all requirements set out in Section 2 of this Chapter. The classification of a product as a high-risk AI system in accordance with Article 6(1) does not affect the choice of the conformity assessment procedure provided to the manufacturers of products covered by Union harmonisation legislation listed in Section A of Annex I, including, where applicable, an option to rely on harmonised standards. The manufacturers of such products are not required to choose a conformity assessment procedure involving third-party conformity assessment only because the product includes a high-risk AI system as a safety component, if this is not required by the Union harmonisation legislation listed in Section A of Annex I.

▼M1

Where a high-risk AI system is both covered by the Union harmonisation legislation listed in Section A of Annex I and it falls within one of the categories listed in Annex III, the provider of that system shall follow the relevant conformity assessment procedure as required pursuant to the relevant Union harmonisation legislation listed in Section A of Annex I.

▼B

4. High-risk AI systems that have already been subject to a conformity assessment procedure shall undergo a new conformity assessment procedure in the event of a substantial modification, regardless of whether the modified system is intended to be further distributed or continues to be used by the current deployer.

For high-risk AI systems that continue to learn after being placed on the market or put into service, changes to the high-risk AI system and its performance that have been pre-determined by the provider at the moment of the initial conformity assessment and are part of the information contained in the technical documentation referred to in point 2(f) of Annex IV, shall not constitute a substantial modification.

5. The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annexes VI and VII by updating them in light of technical progress.

6. The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend paragraphs 1 and 2 of this Article in order to subject high-risk AI systems referred to in points 2 to 8 of Annex III to the conformity assessment procedure referred to in Annex VII or parts thereof. The Commission shall adopt such delegated acts taking into account the effectiveness of the conformity assessment procedure based on internal control referred to in Annex VI in preventing or minimising the risks to health and safety and protection of fundamental rights posed by such systems, as well as the availability of adequate capacities and resources among notified bodies.

Article 44

Certificates

1. Certificates issued by notified bodies in accordance with Annex VII shall be drawn-up in a language which can be easily understood by the relevant authorities in the Member State in which the notified body is established.

2. Certificates shall be valid for the period they indicate, which shall not exceed five years for AI systems covered by Annex I, and four years for AI systems covered by Annex III. At the request of the provider, the validity of a certificate may be extended for further periods, each not exceeding five years for AI systems covered by Annex I, and four years for AI systems covered by Annex III, based on a re-assessment in accordance with the applicable conformity assessment procedures. Any supplement to a certificate shall remain valid, provided that the certificate which it supplements is valid.

▼B

3. Where a notified body finds that an AI system no longer meets the requirements set out in Section 2, it shall, taking account of the principle of proportionality, suspend or withdraw the certificate issued or impose restrictions on it, unless compliance with those requirements is ensured by appropriate corrective action taken by the provider of the system within an appropriate deadline set by the notified body. The notified body shall give reasons for its decision.

An appeal procedure against decisions of the notified bodies, including on conformity certificates issued, shall be available.

Article 45

Information obligations of notified bodies

1. Notified bodies shall inform the notifying authority of the following:

(a) any Union technical documentation assessment certificates, any supplements to those certificates, and any quality management system approvals issued in accordance with the requirements of Annex VII;

(b) any refusal, restriction, suspension or withdrawal of a Union technical documentation assessment certificate or a quality management system approval issued in accordance with the requirements of Annex VII;

(c) any circumstances affecting the scope of or conditions for notification;

(d) any request for information which they have received from market surveillance authorities regarding conformity assessment activities;

(e) on request, conformity assessment activities performed within the scope of their notification and any other activity performed, including cross-border activities and subcontracting.

2. Each notified body shall inform the other notified bodies of:

(a) quality management system approvals which it has refused, suspended or withdrawn, and, upon request, of quality system approvals which it has issued;

(b) Union technical documentation assessment certificates or any supplements thereto which it has refused, withdrawn, suspended or otherwise restricted, and, upon request, of the certificates and/or supplements thereto which it has issued.

3. Each notified body shall provide the other notified bodies carrying out similar conformity assessment activities covering the same types of AI systems with relevant information on issues relating to negative and, on request, positive conformity assessment results.

4. Notified bodies shall safeguard the confidentiality of the information that they obtain, in accordance with Article 78.

▼B

Article 46

Derogation from conformity assessment procedure

1. By way of derogation from Article 43 and upon a duly justified request, any market surveillance authority may authorise the placing on the market or the putting into service of specific high-risk AI systems within the territory of the Member State concerned, for exceptional reasons of public security or the protection of life and health of persons, environmental protection or the protection of key industrial and infrastructural assets. That authorisation shall be for a limited period while the necessary conformity assessment procedures are being carried out, taking into account the exceptional reasons justifying the derogation. The completion of those procedures shall be undertaken without undue delay.

2. In a duly justified situation of urgency for exceptional reasons of public security or in the case of specific, substantial and imminent threat to the life or physical safety of natural persons, law-enforcement authorities or civil protection authorities may put a specific high-risk AI system into service without the authorisation referred to in paragraph 1, provided that such authorisation is requested during or after the use without undue delay. If the authorisation referred to in paragraph 1 is refused, the use of the high-risk AI system shall be stopped with immediate effect and all the results and outputs of such use shall be immediately discarded.

3. The authorisation referred to in paragraph 1 shall be issued only if the market surveillance authority concludes that the high-risk AI system complies with the requirements of Section 2. The market surveillance authority shall inform the Commission and the other Member States of any authorisation issued pursuant to paragraphs 1 and 2. This obligation shall not cover sensitive operational data in relation to the activities of law-enforcement authorities.

4. Where, within 15 calendar days of receipt of the information referred to in paragraph 3, no objection has been raised by either a Member State or the Commission in respect of an authorisation issued by a market surveillance authority of a Member State in accordance with paragraph 1, that authorisation shall be deemed justified.

5. Where, within 15 calendar days of receipt of the notification referred to in paragraph 3, objections are raised by a Member State against an authorisation issued by a market surveillance authority of another Member State, or where the Commission considers the authorisation to be contrary to Union law, or the conclusion of the Member States regarding the compliance of the system as referred to in paragraph 3 to be unfounded, the Commission shall, without delay, enter into consultations with the relevant Member State. The operators concerned shall be consulted and have the possibility to present their views. Having regard thereto, the Commission shall decide whether the authorisation is justified. The Commission shall address its decision to the Member State concerned and to the relevant operators.

6. Where the Commission considers the authorisation unjustified, it shall be withdrawn by the market surveillance authority of the Member State concerned.

▼B

7. For high-risk AI systems related to products covered by Union harmonisation legislation listed in Section A of Annex I, only the derogations from the conformity assessment established in that Union harmonisation legislation shall apply.

Article 47

EU declaration of conformity

1. The provider shall draw up a written machine readable, physical or electronically signed EU declaration of conformity for each high-risk AI system, and keep it at the disposal of the national competent authorities for 10 years after the high-risk AI system has been placed on the market or put into service. The EU declaration of conformity shall identify the high-risk AI system for which it has been drawn up. A copy of the EU declaration of conformity shall be submitted to the relevant national competent authorities upon request.

2. The EU declaration of conformity shall state that the high-risk AI system concerned meets the requirements set out in Section 2. The EU declaration of conformity shall contain the information set out in Annex V, and shall be translated into a language that can be easily understood by the national competent authorities of the Member States in which the high-risk AI system is placed on the market or made available.

3. Where high-risk AI systems are subject to other Union harmonisation legislation which also requires an EU declaration of conformity, a single EU declaration of conformity shall be drawn up in respect of all Union law applicable to the high-risk AI system. The declaration shall contain all the information required to identify the Union harmonisation legislation to which the declaration relates.

4. By drawing up the EU declaration of conformity, the provider shall assume responsibility for compliance with the requirements set out in Section 2. The provider shall keep the EU declaration of conformity up-to-date as appropriate.

5. The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annex V by updating the content of the EU declaration of conformity set out in that Annex, in order to introduce elements that become necessary in light of technical progress.

Article 48

CE marking

1. The CE marking shall be subject to the general principles set out in Article 30 of Regulation (EC) No 765/2008.

2. For high-risk AI systems provided digitally, a digital CE marking shall be used, only if it can easily be accessed via the interface from which that system is accessed or via an easily accessible machine-readable code or other electronic means.

3. The CE marking shall be affixed visibly, legibly and indelibly for high-risk AI systems. Where that is not possible or not warranted on account of the nature of the high-risk AI system, it shall be affixed to the packaging or to the accompanying documentation, as appropriate.

▼B

4. Where applicable, the CE marking shall be followed by the identification number of the notified body responsible for the conformity assessment procedures set out in Article 43. The identification number of the notified body shall be affixed by the body itself or, under its instructions, by the provider or by the provider's authorised representative. The identification number shall also be indicated in any promotional material which mentions that the high-risk AI system fulfils the requirements for CE marking.

5. Where high-risk AI systems are subject to other Union law which also provides for the affixing of the CE marking, the CE marking shall indicate that the high-risk AI system also fulfil the requirements of that other law.

Article 49

Registration

1. Before placing on the market or putting into service a high-risk AI system listed in Annex III, with the exception of high-risk AI systems referred to in point 2 of Annex III, the provider or, where applicable, the authorised representative shall register themselves and their system in the EU database referred to in Article 71.

2. Before placing on the market or putting into service an AI system for which the provider has concluded that it is not high-risk according to Article 6(3), that provider or, where applicable, the authorised representative shall register themselves and that system in the EU database referred to in Article 71.

3. Before putting into service or using a high-risk AI system listed in Annex III, with the exception of high-risk AI systems listed in point 2 of Annex III, deployers that are public authorities, Union institutions, bodies, offices or agencies or persons acting on their behalf shall register themselves, select the system and register its use in the EU database referred to in Article 71.

4. For high-risk AI systems referred to in points 1, 6 and 7 of Annex III, in the areas of law enforcement, migration, asylum and border control management, the registration referred to in paragraphs 1, 2 and 3 of this Article shall be in a secure non-public section of the EU database referred to in Article 71 and shall include only the following information, as applicable, referred to in:

(a) Section A, points 1 to 10, of Annex VIII, with the exception of points 6, 8 and 9;

(b) Section B, points 1 to 5, and points 8 and 9 of Annex VIII;

(c) Section C, points 1 to 3, of Annex VIII;

(d) points 1, 2, 3 and 5, of Annex IX.

Only the Commission and national authorities referred to in Article 74(8) shall have access to the respective restricted sections of the EU database listed in the first subparagraph of this paragraph.

5. High-risk AI systems referred to in point 2 of Annex III shall be registered at national level.

▼B

CHAPTER IV

TRANSPARENCY OBLIGATIONS FOR PROVIDERS AND DEPLOYERS OF CERTAIN AI SYSTEMS

Article 50

Transparency obligations for providers and deployers of certain AI systems

1. Providers shall ensure that AI systems intended to interact directly with natural persons are designed and developed in such a way that the natural persons concerned are informed that they are interacting with an AI system, unless this is obvious from the point of view of a natural person who is reasonably well-informed, observant and circumspect, taking into account the circumstances and the context of use. This obligation shall not apply to AI systems authorised by law to detect, prevent, investigate or prosecute criminal offences, subject to appropriate safeguards for the rights and freedoms of third parties, unless those systems are available for the public to report a criminal offence.

2. Providers of AI systems, including general-purpose AI systems, generating synthetic audio, image, video or text content, shall ensure that the outputs of the AI system are marked in a machine-readable format and detectable as artificially generated or manipulated. Providers shall ensure their technical solutions are effective, interoperable, robust and reliable as far as this is technically feasible, taking into account the specificities and limitations of various types of content, the costs of implementation and the generally acknowledged state of the art, as may be reflected in relevant technical standards. This obligation shall not apply to the extent the AI systems perform an assistive function for standard editing or do not substantially alter the input data provided by the deployer or the semantics thereof, or where authorised by law to detect, prevent, investigate or prosecute criminal offences.

3. Deployers of an emotion recognition system or a biometric categorisation system shall inform the natural persons exposed thereto of the operation of the system, and shall process the personal data in accordance with Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680, as applicable. This obligation shall not apply to AI systems used for biometric categorisation and emotion recognition, which are permitted by law to detect, prevent or investigate criminal offences, subject to appropriate safeguards for the rights and freedoms of third parties, and in accordance with Union law.

4. Deployers of an AI system that generates or manipulates image, audio or video content constituting a deep fake, shall disclose that the content has been artificially generated or manipulated. This obligation shall not apply where the use is authorised by law to detect, prevent, investigate or prosecute criminal offence. Where the content forms part of an evidently artistic, creative, satirical, fictional or analogous work or programme, the transparency obligations set out in this paragraph are limited to disclosure of the existence of such generated or manipulated content in an appropriate manner that does not hamper the display or enjoyment of the work.

▼B

Deployers of an AI system that generates or manipulates text which is published with the purpose of informing the public on matters of public interest shall disclose that the text has been artificially generated or manipulated. This obligation shall not apply where the use is authorised by law to detect, prevent, investigate or prosecute criminal offences or where the AI-generated content has undergone a process of human review or editorial control and where a natural or legal person holds editorial responsibility for the publication of the content.

5. The information referred to in paragraphs 1 to 4 shall be provided to the natural persons concerned in a clear and distinguishable manner at the latest at the time of the first interaction or exposure. The information shall conform to the applicable accessibility requirements.

6. Paragraphs 1 to 4 shall not affect the requirements and obligations set out in Chapter III, and shall be without prejudice to other transparency obligations laid down in Union or national law for deployers of AI systems.

▼M1

7. The Commission shall encourage and facilitate the drawing up of codes of practice at Union level to facilitate the effective implementation of the obligations regarding the detection, marking and labelling of artificially generated or manipulated content. The Commission, taking utmost account of the opinion of the Board, shall assess whether adherence to those codes of practice is adequate to ensure compliance with the obligations laid down in paragraphs 2 and 4 of this Article, in accordance with the procedure laid down in Article 56(6). If it deems the code of practice to be inadequate, the Commission may adopt an implementing act specifying common rules for the implementation of those obligations in accordance with the examination procedure laid down in Article 98(2).

▼B

CHAPTER V

GENERAL-PURPOSE AI MODELS

SECTION 1

Classification rules

Article 51

Classification of general-purpose AI models as general-purpose AI models with systemic risk

1. A general-purpose AI model shall be classified as a general-purpose AI model with systemic risk if it meets any of the following conditions:

(a) it has high impact capabilities evaluated on the basis of appropriate technical tools and methodologies, including indicators and benchmarks;

(b) based on a decision of the Commission, *ex officio* or following a qualified alert from the scientific panel, it has capabilities or an impact equivalent to those set out in point (a) having regard to the criteria set out in Annex XIII.

▼B

2. A general-purpose AI model shall be presumed to have high impact capabilities pursuant to paragraph 1, point (a), when the cumulative amount of computation used for its training measured in floating point operations is greater than 10^{25}.

3. The Commission shall adopt delegated acts in accordance with Article 97 to amend the thresholds listed in paragraphs 1 and 2 of this Article, as well as to supplement benchmarks and indicators in light of evolving technological developments, such as algorithmic improvements or increased hardware efficiency, when necessary, for these thresholds to reflect the state of the art.

Article 52

Procedure

1. Where a general-purpose AI model meets the condition referred to in Article 51(1), point (a), the relevant provider shall notify the Commission without delay and in any event within two weeks after that requirement is met or it becomes known that it will be met. That notification shall include the information necessary to demonstrate that the relevant requirement has been met. If the Commission becomes aware of a general-purpose AI model presenting systemic risks of which it has not been notified, it may decide to designate it as a model with systemic risk.

2. The provider of a general-purpose AI model that meets the condition referred to in Article 51(1), point (a), may present, with its notification, sufficiently substantiated arguments to demonstrate that, exceptionally, although it meets that requirement, the general-purpose AI model does not present, due to its specific characteristics, systemic risks and therefore should not be classified as a general-purpose AI model with systemic risk.

3. Where the Commission concludes that the arguments submitted pursuant to paragraph 2 are not sufficiently substantiated and the relevant provider was not able to demonstrate that the general-purpose AI model does not present, due to its specific characteristics, systemic risks, it shall reject those arguments, and the general-purpose AI model shall be considered to be a general-purpose AI model with systemic risk.

4. The Commission may designate a general-purpose AI model as presenting systemic risks, *ex officio* or following a qualified alert from the scientific panel pursuant to Article 90(1), point (a), on the basis of criteria set out in Annex XIII.

The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annex XIII by specifying and updating the criteria set out in that Annex.

▼B

5. Upon a reasoned request of a provider whose model has been designated as a general-purpose AI model with systemic risk pursuant to paragraph 4, the Commission shall take the request into account and may decide to reassess whether the general-purpose AI model can still be considered to present systemic risks on the basis of the criteria set out in Annex XIII. Such a request shall contain objective, detailed and new reasons that have arisen since the designation decision. Providers may request reassessment at the earliest six months after the designation decision. Where the Commission, following its reassessment, decides to maintain the designation as a general-purpose AI model with systemic risk, providers may request reassessment at the earliest six months after that decision.

6. The Commission shall ensure that a list of general-purpose AI models with systemic risk is published and shall keep that list up to date, without prejudice to the need to observe and protect intellectual property rights and confidential business information or trade secrets in accordance with Union and national law.

SECTION 2

Obligations for providers of general-purpose AI models

Article 53

Obligations for providers of general-purpose AI models

1. Providers of general-purpose AI models shall:

(a) draw up and keep up-to-date the technical documentation of the model, including its training and testing process and the results of its evaluation, which shall contain, at a minimum, the information set out in Annex XI for the purpose of providing it, upon request, to the AI Office and the national competent authorities;

(b) draw up, keep up-to-date and make available information and documentation to providers of AI systems who intend to integrate the general-purpose AI model into their AI systems. Without prejudice to the need to observe and protect intellectual property rights and confidential business information or trade secrets in accordance with Union and national law, the information and documentation shall:

(i) enable providers of AI systems to have a good understanding of the capabilities and limitations of the general-purpose AI model and to comply with their obligations pursuant to this Regulation; and

(ii) contain, at a minimum, the elements set out in Annex XII;

(c) put in place a policy to comply with Union law on copyright and related rights, and in particular to identify and comply with, including through state-of-the-art technologies, a reservation of rights expressed pursuant to Article 4(3) of Directive (EU) 2019/790;

(d) draw up and make publicly available a sufficiently detailed summary about the content used for training of the general-purpose AI model, according to a template provided by the AI Office.

▼B

2. The obligations set out in paragraph 1, points (a) and (b), shall not apply to providers of AI models that are released under a free and open-source licence that allows for the access, usage, modification, and distribution of the model, and whose parameters, including the weights, the information on the model architecture, and the information on model usage, are made publicly available. This exception shall not apply to general-purpose AI models with systemic risks.

3. Providers of general-purpose AI models shall cooperate as necessary with the Commission and the national competent authorities in the exercise of their competences and powers pursuant to this Regulation.

4. Providers of general-purpose AI models may rely on codes of practice within the meaning of Article 56 to demonstrate compliance with the obligations set out in paragraph 1 of this Article, until a harmonised standard is published. Compliance with European harmonised standards grants providers the presumption of conformity to the extent that those standards cover those obligations. Providers of general-purpose AI models who do not adhere to an approved code of practice or do not comply with a European harmonised standard shall demonstrate alternative adequate means of compliance for assessment by the Commission.

5. For the purpose of facilitating compliance with Annex XI, in particular points 2 (d) and (e) thereof, the Commission is empowered to adopt delegated acts in accordance with Article 97 to detail measurement and calculation methodologies with a view to allowing for comparable and verifiable documentation.

6. The Commission is empowered to adopt delegated acts in accordance with Article 97(2) to amend Annexes XI and XII in light of evolving technological developments.

7. Any information or documentation obtained pursuant to this Article, including trade secrets, shall be treated in accordance with the confidentiality obligations set out in Article 78.

Article 54

Authorised representatives of providers of general-purpose AI models

1. Prior to placing a general-purpose AI model on the Union market, providers established in third countries shall, by written mandate, appoint an authorised representative which is established in the Union.

2. The provider shall enable its authorised representative to perform the tasks specified in the mandate received from the provider.

3. The authorised representative shall perform the tasks specified in the mandate received from the provider. It shall provide a copy of the mandate to the AI Office upon request, in one of the official languages of the institutions of the Union. For the purposes of this Regulation, the mandate shall empower the authorised representative to carry out the following tasks:

▼B

(a) verify that the technical documentation specified in Annex XI has been drawn up and all obligations referred to in Article 53 and, where applicable, Article 55 have been fulfilled by the provider;

(b) keep a copy of the technical documentation specified in Annex XI at the disposal of the AI Office and national competent authorities, for a period of 10 years after the general-purpose AI model has been placed on the market, and the contact details of the provider that appointed the authorised representative;

(c) provide the AI Office, upon a reasoned request, with all the information and documentation, including that referred to in point (b), necessary to demonstrate compliance with the obligations in this Chapter;

(d) cooperate with the AI Office and competent authorities, upon a reasoned request, in any action they take in relation to the general-purpose AI model, including when the model is integrated into AI systems placed on the market or put into service in the Union.

4. The mandate shall empower the authorised representative to be addressed, in addition to or instead of the provider, by the AI Office or the competent authorities, on all issues related to ensuring compliance with this Regulation.

5. The authorised representative shall terminate the mandate if it considers or has reason to consider the provider to be acting contrary to its obligations pursuant to this Regulation. In such a case, it shall also immediately inform the AI Office about the termination of the mandate and the reasons therefor.

6. The obligation set out in this Article shall not apply to providers of general-purpose AI models that are released under a free and open-source licence that allows for the access, usage, modification, and distribution of the model, and whose parameters, including the weights, the information on the model architecture, and the information on model usage, are made publicly available, unless the general-purpose AI models present systemic risks.

SECTION 3

Obligations of providers of general-purpose AI models with systemic risk

Article 55

Obligations of providers of general-purpose AI models with systemic risk

1. In addition to the obligations listed in Articles 53 and 54, providers of general-purpose AI models with systemic risk shall:

(a) perform model evaluation in accordance with standardised protocols and tools reflecting the state of the art, including conducting and documenting adversarial testing of the model with a view to identifying and mitigating systemic risks;

▼B

(b) assess and mitigate possible systemic risks at Union level, including their sources, that may stem from the development, the placing on the market, or the use of general-purpose AI models with systemic risk;

(c) keep track of, document, and report, without undue delay, to the AI Office and, as appropriate, to national competent authorities, relevant information about serious incidents and possible corrective measures to address them;

(d) ensure an adequate level of cybersecurity protection for the general-purpose AI model with systemic risk and the physical infrastructure of the model.

2. Providers of general-purpose AI models with systemic risk may rely on codes of practice within the meaning of Article 56 to demonstrate compliance with the obligations set out in paragraph 1 of this Article, until a harmonised standard is published. Compliance with European harmonised standards grants providers the presumption of conformity to the extent that those standards cover those obligations. Providers of general-purpose AI models with systemic risks who do not adhere to an approved code of practice or do not comply with a European harmonised standard shall demonstrate alternative adequate means of compliance for assessment by the Commission.

3. Any information or documentation obtained pursuant to this Article, including trade secrets, shall be treated in accordance with the confidentiality obligations set out in Article 78.

SECTION 4

Codes of practice

Article 56

Codes of practice

1. The AI Office shall encourage and facilitate the drawing up of codes of practice at Union level in order to contribute to the proper application of this Regulation, taking into account international approaches.

2. The AI Office and the Board shall aim to ensure that the codes of practice cover at least the obligations provided for in Articles 53 and 55, including the following issues:

(a) the means to ensure that the information referred to in Article 53(1), points (a) and (b), is kept up to date in light of market and technological developments;

(b) the adequate level of detail for the summary about the content used for training;

(c) the identification of the type and nature of the systemic risks at Union level, including their sources, where appropriate;

▼B

(d) the measures, procedures and modalities for the assessment and management of the systemic risks at Union level, including the documentation thereof, which shall be proportionate to the risks, take into consideration their severity and probability and take into account the specific challenges of tackling those risks in light of the possible ways in which such risks may emerge and materialise along the AI value chain.

3. The AI Office may invite all providers of general-purpose AI models, as well as relevant national competent authorities, to participate in the drawing-up of codes of practice. Civil society organisations, industry, academia and other relevant stakeholders, such as downstream providers and independent experts, may support the process.

4. The AI Office and the Board shall aim to ensure that the codes of practice clearly set out their specific objectives and contain commitments or measures, including key performance indicators as appropriate, to ensure the achievement of those objectives, and that they take due account of the needs and interests of all interested parties, including affected persons, at Union level.

5. The AI Office shall aim to ensure that participants to the codes of practice report regularly to the AI Office on the implementation of the commitments and the measures taken and their outcomes, including as measured against the key performance indicators as appropriate. Key performance indicators and reporting commitments shall reflect differences in size and capacity between various participants.

▼M1

6. The Commission and the Board shall regularly monitor and evaluate the achievement of the objectives of the codes of practice by the participants and their contribution to the proper application of this Regulation. The Commission, taking utmost account of the opinion of the Board, shall assess whether the codes of practice cover the obligations provided for in Articles 53 and 55, and shall regularly monitor and evaluate the achievement of their objectives. The Commission shall publish its assessment of the adequacy of the codes of practice.

▼B

7. The AI Office may invite all providers of general-purpose AI models to adhere to the codes of practice. For providers of general-purpose AI models not presenting systemic risks this adherence may be limited to the obligations provided for in Article 53, unless they declare explicitly their interest to join the full code.

8. The AI Office shall, as appropriate, also encourage and facilitate the review and adaptation of the codes of practice, in particular in light of emerging standards. The AI Office shall assist in the assessment of available standards.

9. Codes of practice shall be ready at the latest by 2 May 2025. The AI Office shall take the necessary steps, including inviting providers pursuant to paragraph 7.

▼B

If, by 2 August 2025, a code of practice cannot be finalised, or if the AI Office deems it is not adequate following its assessment under paragraph 6 of this Article, the Commission may provide, by means of implementing acts, common rules for the implementation of the obligations provided for in Articles 53 and 55, including the issues set out in paragraph 2 of this Article. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 98(2).

CHAPTER VI

MEASURES IN SUPPORT OF INNOVATION

Article 57

AI regulatory sandboxes

▼M1

1. Member States shall ensure that their competent authorities establish at least one AI regulatory sandbox at national level, which shall be operational by 2 August 2027. That sandbox may also be established jointly with the competent authorities of other Member States. The Commission may provide technical support, advice and tools for the establishment and operation of AI regulatory sandboxes.

▼B

The obligation under the first subparagraph may also be fulfilled by participating in an existing sandbox in so far as that participation provides an equivalent level of national coverage for the participating Member States.

2. Additional AI regulatory sandboxes at regional or local level, or established jointly with the competent authorities of other Member States may also be established.

▼M1

3. The European Data Protection Supervisor may establish an AI regulatory sandbox for Union institutions, bodies, offices and agencies. For this purpose, references to national competent authorities in this Chapter shall be construed as references to the European Data Protection Supervisor.

3a. The AI Office may establish an AI regulatory sandbox at Union level for AI systems covered by Article 75(1). For this purpose, references to national competent authorities in this Chapter shall be construed, where relevant, as references to the AI Office. That AI regulatory sandbox shall be implemented in close cooperation with relevant competent authorities, in particular where compliance with Union legislation other than this Regulation is supervised in the AI regulatory sandbox, and shall provide priority access to SMEs, including start-ups, and SMCs.

The establishment of a Union level AI regulatory sandbox by the AI Office shall be without prejudice to the competences of Member States to establish and supervise AI regulatory sandboxes for AI systems under their supervision.

▼B

4. Member States shall ensure that the competent authorities referred to in paragraphs 1 and 2 allocate sufficient resources to comply with this Article effectively and in a timely manner. Where appropriate, national competent authorities shall cooperate with other relevant authorities, and may allow for the involvement of other actors within the AI ecosystem. This Article shall not affect other regulatory sandboxes established under Union or national law. Member States shall ensure an appropriate level of cooperation between the authorities supervising those other sandboxes and the national competent authorities.

▼M1

5. AI regulatory sandboxes established under this Article shall provide for a controlled environment that fosters innovation and facilitates the development, training, testing and validation of innovative AI systems for a limited time before their being placed on the market or put into service pursuant to a specific sandbox plan agreed between the providers or prospective providers and the competent authorities, ensuring that appropriate safeguards are in place. Such sandboxes may include testing in real world conditions supervised therein. Where applicable, the sandbox plan shall incorporate the real-world testing plan referred to in Articles 60 and 60a.

▼B

6. Competent authorities shall provide, as appropriate, guidance, supervision and support within the AI regulatory sandbox with a view to identifying risks, in particular to fundamental rights, health and safety, testing, mitigation measures, and their effectiveness in relation to the obligations and requirements of this Regulation and, where relevant, other Union and national law supervised within the sandbox.

7. Competent authorities shall provide providers and prospective providers participating in the AI regulatory sandbox with guidance on regulatory expectations and how to fulfil the requirements and obligations set out in this Regulation.

Upon request of the provider or prospective provider of the AI system, the competent authority shall provide a written proof of the activities successfully carried out in the sandbox. The competent authority shall also provide an exit report detailing the activities carried out in the sandbox and the related results and learning outcomes. Providers may use such documentation to demonstrate their compliance with this Regulation through the conformity assessment process or relevant market surveillance activities. In this regard, the exit reports and the written proof provided by the national competent authority shall be taken positively into account by market surveillance authorities and notified bodies, with a view to accelerating conformity assessment procedures to a reasonable extent.

8. Subject to the confidentiality provisions in Article 78, and with the agreement of the provider or prospective provider, the Commission and the Board shall be authorised to access the exit reports and shall take them into account, as appropriate, when exercising their tasks under this Regulation. If both the provider or prospective provider and the national competent authority explicitly agree, the exit report may be made publicly available through the single information platform referred to in this Article.

▼B

9. The establishment of AI regulatory sandboxes shall aim to contribute to the following objectives:

(a) improving legal certainty to achieve regulatory compliance with this Regulation or, where relevant, other applicable Union and national law;

(b) supporting the sharing of best practices through cooperation with the authorities involved in the AI regulatory sandbox;

(c) fostering innovation and competitiveness and facilitating the development of an AI ecosystem;

(d) contributing to evidence-based regulatory learning;

▼M1

(e) facilitating and accelerating access to the Union market for AI systems, in particular when provided by SMEs, including start-ups, and SMCs.

10. National competent authorities shall ensure that, to the extent the innovative AI systems involve the processing of personal data or otherwise fall under the supervisory remit of other national authorities or competent authorities providing or supporting access to data, the competent data protection authorities and those other national or competent authorities are associated with the operation of the AI regulatory sandbox and involved in the supervision of those aspects to the extent of their respective tasks and powers.

▼B

11. The AI regulatory sandboxes shall not affect the supervisory or corrective powers of the competent authorities supervising the sandboxes, including at regional or local level. Any significant risks to health and safety and fundamental rights identified during the development and testing of such AI systems shall result in an adequate mitigation. National competent authorities shall have the power to temporarily or permanently suspend the testing process, or the participation in the sandbox if no effective mitigation is possible, and shall inform the AI Office of such decision. National competent authorities shall exercise their supervisory powers within the limits of the relevant law, using their discretionary powers when implementing legal provisions in respect of a specific AI regulatory sandbox project, with the objective of supporting innovation in AI in the Union.

12. Providers and prospective providers participating in the AI regulatory sandbox shall remain liable under applicable Union and national liability law for any damage inflicted on third parties as a result of the experimentation taking place in the sandbox. However, provided that the prospective providers observe the specific plan and the terms and conditions for their participation and follow in good faith the guidance given by the national competent authority, no administrative fines shall be imposed by the authorities for infringements of this Regulation. Where other competent authorities responsible for other Union and national law were actively involved in the supervision of the AI system in the sandbox and provided guidance for compliance, no administrative fines shall be imposed regarding that law.

13. The AI regulatory sandboxes shall be designed and implemented in such a way that, where relevant, they facilitate cross-border cooperation between national competent authorities.

▼M1

14. National competent authorities, the European Data Protection Supervisor and the AI Office, shall, as appropriate and within their respective competences, coordinate their activities and cooperate within the framework of the Board. They may support the joint establishment and operation of AI regulatory sandboxes, including in different sectors, and exchange best practices on related matters.

▼B

15. National competent authorities shall inform the AI Office and the Board of the establishment of a sandbox, and may ask them for support and guidance. The AI Office shall make publicly available a list of planned and existing sandboxes and keep it up to date in order to encourage more interaction in the AI regulatory sandboxes and cross-border cooperation.

16. National competent authorities shall submit annual reports to the AI Office and to the Board, from one year after the establishment of the AI regulatory sandbox and every year thereafter until its termination, and a final report. Those reports shall provide information on the progress and results of the implementation of those sandboxes, including best practices, incidents, lessons learnt and recommendations on their setup and, where relevant, on the application and possible revision of this Regulation, including its delegated and implementing acts, and on the application of other Union law supervised by the competent authorities within the sandbox. The national competent authorities shall make those annual reports or abstracts thereof available to the public, online. The Commission shall, where appropriate, take the annual reports into account when exercising its tasks under this Regulation.

17. The Commission shall develop a single and dedicated interface containing all relevant information related to AI regulatory sandboxes to allow stakeholders to interact with AI regulatory sandboxes and to raise enquiries with competent authorities, and to seek non-binding guidance on the conformity of innovative products, services, business models embedding AI technologies, in accordance with Article 62(1), point (c). The Commission shall proactively coordinate with national competent authorities, where relevant.

Article 58

Detailed arrangements for, and functioning of, AI regulatory sandboxes

▼M1

1. In order to avoid fragmentation across the Union, the Commission shall adopt implementing acts specifying the detailed arrangements for the establishment, development, implementation, operation, governance, and supervision of the AI regulatory sandboxes. Those implementing acts shall include common principles on the following issues:

▼B

(a) eligibility and selection criteria for participation in the AI regulatory sandbox;

(b) procedures for the application, participation, monitoring, exiting from and termination of the AI regulatory sandbox, including the sandbox plan and the exit report;

(c) the terms and conditions applicable to the participants;

▼M1

(d) the detailed rules applicable to the governance of AI regulatory sandboxes covered pursuant to Article 57, including as regards the involvement of and supervision by the competent data protection authorities, where relevant, and the coordination and co-operation at national and Union level.

▼B

Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 98(2).

2. The implementing acts referred to in paragraph 1 shall ensure:

(a) that AI regulatory sandboxes are open to any applying provider or prospective provider of an AI system who fulfils eligibility and selection criteria, which shall be transparent and fair, and that national competent authorities inform applicants of their decision within three months of the application;

(b) that AI regulatory sandboxes allow broad and equal access and keep up with demand for participation; providers and prospective providers may also submit applications in partnerships with deployers and other relevant third parties;

(c) that the detailed arrangements for, and conditions concerning AI regulatory sandboxes support, to the best extent possible, flexibility for national competent authorities to establish and operate their AI regulatory sandboxes;

(d) that access to the AI regulatory sandboxes is free of charge for SMEs, including start-ups, without prejudice to exceptional costs that national competent authorities may recover in a fair and proportionate manner;

(e) that they facilitate providers and prospective providers, by means of the learning outcomes of the AI regulatory sandboxes, in complying with conformity assessment obligations under this Regulation and the voluntary application of the codes of conduct referred to in Article 95;

(f) that AI regulatory sandboxes facilitate the involvement of other relevant actors within the AI ecosystem, such as notified bodies and standardisation organisations, SMEs, including start-ups, enterprises, innovators, testing and experimentation facilities, research and experimentation labs and European Digital Innovation Hubs, centres of excellence, individual researchers, in order to allow and facilitate cooperation with the public and private sectors;

(g) that procedures, processes and administrative requirements for application, selection, participation and exiting the AI regulatory sandbox are simple, easily intelligible, and clearly communicated in order to facilitate the participation of SMEs, including start-ups, with limited legal and administrative capacities and are streamlined across the Union, in order to avoid fragmentation and that participation in an AI regulatory sandbox established by a Member State, or by the European Data Protection Supervisor is mutually and uniformly recognised and carries the same legal effects across the Union;

▼B

(h) that participation in the AI regulatory sandbox is limited to a period that is appropriate to the complexity and scale of the project and that may be extended by the national competent authority;

(i) that AI regulatory sandboxes facilitate the development of tools and infrastructure for testing, benchmarking, assessing and explaining dimensions of AI systems relevant for regulatory learning, such as accuracy, robustness and cybersecurity, as well as measures to mitigate risks to fundamental rights and society at large.

3. Prospective providers in the AI regulatory sandboxes, in particular SMEs and start-ups, shall be directed, where relevant, to pre-deployment services such as guidance on the implementation of this Regulation, to other value-adding services such as help with standardisation documents and certification, testing and experimentation facilities, European Digital Innovation Hubs and centres of excellence.

4. Where national competent authorities consider authorising testing in real world conditions supervised within the framework of an AI regulatory sandbox to be established under this Article, they shall specifically agree the terms and conditions of such testing and, in particular, the appropriate safeguards with the participants, with a view to protecting fundamental rights, health and safety. Where appropriate, they shall cooperate with other national competent authorities with a view to ensuring consistent practices across the Union.

Article 59

Further processing of personal data for developing certain AI systems in the public interest in the AI regulatory sandbox

1. In the AI regulatory sandbox, personal data lawfully collected for other purposes may be processed solely for the purpose of developing, training and testing certain AI systems in the sandbox when all of the following conditions are met:

(a) AI systems shall be developed for safeguarding substantial public interest by a public authority or another natural or legal person and in one or more of the following areas:

(i) public safety and public health, including disease detection, diagnosis prevention, control and treatment and improvement of health care systems;

(ii) a high level of protection and improvement of the quality of the environment, protection of biodiversity, protection against pollution, green transition measures, climate change mitigation and adaptation measures;

(iii) energy sustainability;

(iv) safety and resilience of transport systems and mobility, critical infrastructure and networks;

(v) efficiency and quality of public administration and public services;

▼B

(b) the data processed are necessary for complying with one or more of the requirements referred to in Chapter III, Section 2 where those requirements cannot effectively be fulfilled by processing anonymised, synthetic or other non-personal data;

(c) there are effective monitoring mechanisms to identify if any high risks to the rights and freedoms of the data subjects, as referred to in Article 35 of Regulation (EU) 2016/679 and in Article 39 of Regulation (EU) 2018/1725, may arise during the sandbox experimentation, as well as response mechanisms to promptly mitigate those risks and, where necessary, stop the processing;

(d) any personal data to be processed in the context of the sandbox are in a functionally separate, isolated and protected data processing environment under the control of the prospective provider and only authorised persons have access to those data;

(e) providers can further share the originally collected data only in accordance with Union data protection law; any personal data created in the sandbox cannot be shared outside the sandbox;

(f) any processing of personal data in the context of the sandbox neither leads to measures or decisions affecting the data subjects nor does it affect the application of their rights laid down in Union law on the protection of personal data;

(g) any personal data processed in the context of the sandbox are protected by means of appropriate technical and organisational measures and deleted once the participation in the sandbox has terminated or the personal data has reached the end of its retention period;

(h) the logs of the processing of personal data in the context of the sandbox are kept for the duration of the participation in the sandbox, unless provided otherwise by Union or national law;

(i) a complete and detailed description of the process and rationale behind the training, testing and validation of the AI system is kept together with the testing results as part of the technical documentation referred to in Annex IV;

(j) a short summary of the AI project developed in the sandbox, its objectives and expected results is published on the website of the competent authorities; this obligation shall not cover sensitive operational data in relation to the activities of law enforcement, border control, immigration or asylum authorities.

2. For the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including safeguarding against and preventing threats to public security, under the control and responsibility of law enforcement authorities, the processing of personal data in AI regulatory sandboxes shall be based on a specific Union or national law and subject to the same cumulative conditions as referred to in paragraph 1.

▼B

3. Paragraph 1 is without prejudice to Union or national law which excludes processing of personal data for other purposes than those explicitly mentioned in that law, as well as to Union or national law laying down the basis for the processing of personal data which is necessary for the purpose of developing, testing or training of innovative AI systems or any other legal basis, in compliance with Union law on the protection of personal data.

Article 60

Testing of high-risk AI systems in real world conditions outside AI regulatory sandboxes

▼M1

1. Testing of high-risk AI systems in real world conditions outside AI regulatory sandboxes may be conducted by providers or prospective providers of high-risk AI systems listed in Annex III or covered by Union harmonisation legislation listed in Section A of Annex I, in accordance with this Article and the real-world testing plan referred to in this Article, without prejudice to the prohibitions under Article 5.

▼B

The Commission shall, by means of implementing acts, specify the detailed elements of the real-world testing plan. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 98(2).

This paragraph shall be without prejudice to Union or national law on the testing in real world conditions of high-risk AI systems related to products covered by Union harmonisation legislation listed in Annex I.

▼M1

2. Providers or prospective providers may conduct testing of high-risk AI systems referred to in Annex III or covered by Union harmonisation legislation listed in Section A of Annex I in real world conditions at any time before the placing on the market or the putting into service of the high-risk AI system on their own or in partnership with one or more deployers or prospective deployers.

▼B

3. The testing of high-risk AI systems in real world conditions under this Article shall be without prejudice to any ethical review that is required by Union or national law.

4. Providers or prospective providers may conduct the testing in real world conditions only where all of the following conditions are met:

(a) the provider or prospective provider has drawn up a real-world testing plan and submitted it to the market surveillance authority in the Member State where the testing in real world conditions is to be conducted;

(b) the market surveillance authority in the Member State where the testing in real world conditions is to be conducted has approved the testing in real world conditions and the real-world testing plan; where the market surveillance authority has not provided an answer within 30 days, the testing in real world conditions and the real-world testing plan shall be understood to have been approved; where national law does not provide for a tacit approval, the testing in real world conditions shall remain subject to an authorisation;

▼B

(c) the provider or prospective provider, with the exception of providers or prospective providers of high-risk AI systems referred to in points 1, 6 and 7 of Annex III in the areas of law enforcement, migration, asylum and border control management, and high-risk AI systems referred to in point 2 of Annex III has registered the testing in real world conditions in accordance with Article 71(4) with a Union-wide unique single identification number and with the information specified in Annex IX; the provider or prospective provider of high-risk AI systems referred to in points 1, 6 and 7 of Annex III in the areas of law enforcement, migration, asylum and border control management, has registered the testing in real-world conditions in the secure non-public section of the EU database according to Article 49(4), point (d), with a Union-wide unique single identification number and with the information specified therein; the provider or prospective provider of high-risk AI systems referred to in point 2 of Annex III has registered the testing in real-world conditions in accordance with Article 49(5);

(d) the provider or prospective provider conducting the testing in real world conditions is established in the Union or has appointed a legal representative who is established in the Union;

(e) data collected and processed for the purpose of the testing in real world conditions shall be transferred to third countries only provided that appropriate and applicable safeguards under Union law are implemented;

(f) the testing in real world conditions does not last longer than necessary to achieve its objectives and in any case not longer than six months, which may be extended for an additional period of six months, subject to prior notification by the provider or prospective provider to the market surveillance authority, accompanied by an explanation of the need for such an extension;

(g) the subjects of the testing in real world conditions who are persons belonging to vulnerable groups due to their age or disability, are appropriately protected;

(h) where a provider or prospective provider organises the testing in real world conditions in cooperation with one or more deployers or prospective deployers, the latter have been informed of all aspects of the testing that are relevant to their decision to participate, and given the relevant instructions for use of the AI system referred to in Article 13; the provider or prospective provider and the deployer or prospective deployer shall conclude an agreement specifying their roles and responsibilities with a view to ensuring compliance with the provisions for testing in real world conditions under this Regulation and under other applicable Union and national law;

(i) the subjects of the testing in real world conditions have given informed consent in accordance with Article 61, or in the case of law enforcement, where the seeking of informed consent would prevent the AI system from being tested, the testing itself and the outcome of the testing in the real world conditions shall not have any negative effect on the subjects, and their personal data shall be deleted after the test is performed;

▼B

(j) the testing in real world conditions is effectively overseen by the provider or prospective provider, as well as by deployers or prospective deployers through persons who are suitably qualified in the relevant field and have the necessary capacity, training and authority to perform their tasks;

(k) the predictions, recommendations or decisions of the AI system can be effectively reversed and disregarded.

5. Any subjects of the testing in real world conditions, or their legally designated representative, as appropriate, may, without any resulting detriment and without having to provide any justification, withdraw from the testing at any time by revoking their informed consent and may request the immediate and permanent deletion of their personal data. The withdrawal of the informed consent shall not affect the activities already carried out.

6. In accordance with Article 75, Member States shall confer on their market surveillance authorities the powers of requiring providers and prospective providers to provide information, of carrying out unannounced remote or on-site inspections, and of performing checks on the conduct of the testing in real world conditions and the related high-risk AI systems. Market surveillance authorities shall use those powers to ensure the safe development of testing in real world conditions.

7. Any serious incident identified in the course of the testing in real world conditions shall be reported to the national market surveillance authority in accordance with Article 73. The provider or prospective provider shall adopt immediate mitigation measures or, failing that, shall suspend the testing in real world conditions until such mitigation takes place, or otherwise terminate it. The provider or prospective provider shall establish a procedure for the prompt recall of the AI system upon such termination of the testing in real world conditions.

8. Providers or prospective providers shall notify the national market surveillance authority in the Member State where the testing in real world conditions is to be conducted of the suspension or termination of the testing in real world conditions and of the final outcomes.

9. The provider or prospective provider shall be liable under applicable Union and national liability law for any damage caused in the course of their testing in real world conditions.

▼M1

Article 60a

Testing of high-risk AI systems covered by Union harmonisation legislation listed in Section B of Annex I in real-world conditions outside AI regulatory sandboxes

1. Member States may allow, in accordance with this Article, the testing of high-risk AI systems in real world conditions outside AI regulatory sandboxes by providers or prospective providers of AI enabled products covered by the Union harmonisation legislation listed in Section B of Annex I, with a view to assessing and verifying the conformity of those systems with the requirements laid down in Articles 8 to 15.

▼M1

2. Member States that choose to allow testing as referred to in paragraph 1 shall, individually or jointly, adopt frameworks for real-world testing.

3. Each Member State shall notify the Commission of any real-world testing framework it adopts before implementing it. This shall not affect the competences of the Commission under the Union harmonisation legislation listed in Section B of Annex I.

4. Member States that have adopted real-world testing frameworks shall ensure that the relevant national competent authorities, relevant authorities and public authorities responsible for the management and operation of infrastructure and products covered by Union harmonisation legislation listed in Section B of Annex I cooperate closely with each other in good faith and remove any practical obstacles, including on procedural rules providing access to physical public infrastructure, where this is necessary, to successfully implement those real-world testing frameworks and test AI-enabled products covered by Union harmonisation legislation listed in Section B of Annex I.

5. The frameworks for real-world testing shall lay down the requirements under which testing in real-world conditions shall occur. Those frameworks shall:

(a) include the provision of a mandatory real-world testing plan to be agreed between the provider or prospective provider and the national competent authority or relevant authority in accordance with the Union harmonisation legislation listed in Section B of Annex I;

(b) ensure compliance with the requirements laid down in Article 60(2), (3), (4)(d)-(j) and (5)-(9), where any reference to market surveillance authorities in those provisions shall be read as a reference to the national competent authority or relevant authority, as appropriate in accordance with the Union harmonisation legislation listed in Section B of Annex I;

(c) include effective governance and accountability arrangements;

(d) ensure a high level of protection of health safety and fundamental rights.

6. The real-world testing shall comply with the applicable provisions laid down in the Union harmonisation legislation listed in Section B of Annex I. Any requirements laid down in those provisions shall not affect the application of this Article to the extent necessary to enable the testing referred to in paragraph 1.

▼B

Article 61

Informed consent to participate in testing in real world conditions outside AI regulatory sandboxes

1. For the purpose of testing in real world conditions under Article 60, freely-given informed consent shall be obtained from the subjects of testing prior to their participation in such testing and after their having been duly informed with concise, clear, relevant, and understandable information regarding:

▼B

(a) the nature and objectives of the testing in real world conditions and the possible inconvenience that may be linked to their participation;

(b) the conditions under which the testing in real world conditions is to be conducted, including the expected duration of the subject or subjects' participation;

(c) their rights, and the guarantees regarding their participation, in particular their right to refuse to participate in, and the right to withdraw from, testing in real world conditions at any time without any resulting detriment and without having to provide any justification;

(d) the arrangements for requesting the reversal or the disregarding of the predictions, recommendations or decisions of the AI system;

(e) the Union-wide unique single identification number of the testing in real world conditions in accordance with Article 60(4) point (c), and the contact details of the provider or its legal representative from whom further information can be obtained.

2. The informed consent shall be dated and documented and a copy shall be given to the subjects of testing or their legal representative.

Article 62

Measures for providers and deployers, in particular SMEs, including start-ups

1. Member States shall undertake the following actions:

(a) provide SMEs, including start-ups, having a registered office or a branch in the Union, with priority access to the AI regulatory sandboxes, to the extent that they fulfil the eligibility conditions and selection criteria; the priority access shall not preclude other SMEs, including start-ups, other than those referred to in this paragraph from access to the AI regulatory sandbox, provided that they also fulfil the eligibility conditions and selection criteria;

(b) organise specific awareness raising and training activities on the application of this Regulation tailored to the needs of SMEs including start-ups, deployers and, as appropriate, local public authorities;

(c) utilise existing dedicated channels and where appropriate, establish new ones for communication with SMEs including start-ups, deployers, other innovators and, as appropriate, local public authorities to provide advice and respond to queries about the implementation of this Regulation, including as regards participation in AI regulatory sandboxes;

(d) facilitate the participation of SMEs and other relevant stakeholders in the standardisation development process.

2. The specific interests and needs of the SME providers, including start-ups, shall be taken into account when setting the fees for conformity assessment under Article 43, reducing those fees proportionately to their size, market size and other relevant indicators.

▼B

3. The AI Office shall undertake the following actions:

(a) provide standardised templates for areas covered by this Regulation, as specified by the Board in its request;

(b) develop and maintain a single information platform providing easy to use information in relation to this Regulation for all operators across the Union;

(c) organise appropriate communication campaigns to raise awareness about the obligations arising from this Regulation;

(d) evaluate and promote the convergence of best practices in public procurement procedures in relation to AI systems.

Article 63

Derogations for specific operators

▼M1

1. SMEs, including start-ups, may comply with certain elements of the quality management system required by Article 17 in a simplified manner, provided that they do not have partner enterprises or linked enterprises within the meaning of Recommendation 2003/361/EC. For that purpose, the Commission shall develop guidelines on the elements of the quality management system which may be complied with in a simplified manner considering the needs of SMEs, without affecting the level of protection or the need for compliance with the requirements in respect of high-risk AI systems.

▼B

2. Paragraph 1 of this Article shall not be interpreted as exempting those operators from fulfilling any other requirements or obligations laid down in this Regulation, including those established in Articles 9, 10, 11, 12, 13, 14, 15, 72 and 73.

CHAPTER VII

GOVERNANCE

SECTION 1

Governance at Union level

Article 64

AI Office

1. The Commission shall develop Union expertise and capabilities in the field of AI through the AI Office.

2. Member States shall facilitate the tasks entrusted to the AI Office, as reflected in this Regulation.

▼M1

3. Without prejudice to the budgetary procedure, the AI Office shall be allocated adequate resources to effectively perform its duties and exercise its powers in relation to the enforcement of this Regulation.

▼B

Article 65

Establishment and structure of the European Artificial Intelligence Board

1. A European Artificial Intelligence Board (the ‘Board’) is hereby established.

2. The Board shall be composed of one representative per Member State. The European Data Protection Supervisor shall participate as observer. The AI Office shall also attend the Board’s meetings, without taking part in the votes. Other national and Union authorities, bodies or experts may be invited to the meetings by the Board on a case by case basis, where the issues discussed are of relevance for them.

3. Each representative shall be designated by their Member State for a period of three years, renewable once.

4. Member States shall ensure that their representatives on the Board:

(a) have the relevant competences and powers in their Member State so as to contribute actively to the achievement of the Board’s tasks referred to in Article 66;

(b) are designated as a single contact point vis-à-vis the Board and, where appropriate, taking into account Member States’ needs, as a single contact point for stakeholders;

(c) are empowered to facilitate consistency and coordination between national competent authorities in their Member State as regards the implementation of this Regulation, including through the collection of relevant data and information for the purpose of fulfilling their tasks on the Board.

5. The designated representatives of the Member States shall adopt the Board’s rules of procedure by a two-thirds majority. The rules of procedure shall, in particular, lay down procedures for the selection process, the duration of the mandate of, and specifications of the tasks of, the Chair, detailed arrangements for voting, and the organisation of the Board’s activities and those of its sub-groups.

6. The Board shall establish two standing sub-groups to provide a platform for cooperation and exchange among market surveillance authorities and notifying authorities about issues related to market surveillance and notified bodies respectively.

The standing sub-group for market surveillance should act as the administrative cooperation group (ADCO) for this Regulation within the meaning of Article 30 of Regulation (EU) 2019/1020.

The Board may establish other standing or temporary sub-groups as appropriate for the purpose of examining specific issues. Where appropriate, representatives of the advisory forum referred to in Article 67 may be invited to such sub-groups or to specific meetings of those subgroups as observers.

▼B

7. The Board shall be organised and operated so as to safeguard the objectivity and impartiality of its activities.

8. The Board shall be chaired by one of the representatives of the Member States. The AI Office shall provide the secretariat for the Board, convene the meetings upon request of the Chair, and prepare the agenda in accordance with the tasks of the Board pursuant to this Regulation and its rules of procedure.

Article 66

Tasks of the Board

The Board shall advise and assist the Commission and the Member States in order to facilitate the consistent and effective application of this Regulation. To that end, the Board may in particular:

(a) contribute to the coordination among national competent authorities responsible for the application of this Regulation and, in cooperation with and subject to the agreement of the market surveillance authorities concerned, support joint activities of market surveillance authorities referred to in Article 74(11);

(b) collect and share technical and regulatory expertise and best practices among Member States;

(c) provide advice on the implementation of this Regulation, in particular as regards the enforcement of rules on general-purpose AI models;

(d) contribute to the harmonisation of administrative practices in the Member States, including in relation to the derogation from the conformity assessment procedures referred to in Article 46, the functioning of AI regulatory sandboxes, and testing in real world conditions referred to in Articles 57, 59 and 60;

(e) at the request of the Commission or on its own initiative, issue recommendations and written opinions on any relevant matters related to the implementation of this Regulation and to its consistent and effective application, including:

(i) on the development and application of codes of conduct and codes of practice pursuant to this Regulation, as well as of the Commission's guidelines;

(ii) the evaluation and review of this Regulation pursuant to Article 112, including as regards the serious incident reports referred to in Article 73, and the functioning of the EU database referred to in Article 71, the preparation of the delegated or implementing acts, and as regards possible alignments of this Regulation with the Union harmonisation legislation listed in Annex I;

(iii) on technical specifications or existing standards regarding the requirements set out in Chapter III, Section 2;

▼B

(iv) on the use of harmonised standards or common specifications referred to in Articles 40 and 41;

(v) trends, such as European global competitiveness in AI, the uptake of AI in the Union, and the development of digital skills;

(vi) trends on the evolving typology of AI value chains, in particular on the resulting implications in terms of accountability;

(vii) on the potential need for amendment to Annex III in accordance with Article 7, and on the potential need for possible revision of Article 5 pursuant to Article 112, taking into account relevant available evidence and the latest developments in technology;

(f) support the Commission in promoting AI literacy, public awareness and understanding of the benefits, risks, safeguards and rights and obligations in relation to the use of AI systems;

(g) facilitate the development of common criteria and a shared understanding among market operators and competent authorities of the relevant concepts provided for in this Regulation, including by contributing to the development of benchmarks;

(h) cooperate, as appropriate, with other Union institutions, bodies, offices and agencies, as well as relevant Union expert groups and networks, in particular in the fields of product safety, cybersecurity, competition, digital and media services, financial services, consumer protection, data and fundamental rights protection;

(i) contribute to effective cooperation with the competent authorities of third countries and with international organisations;

(j) assist national competent authorities and the Commission in developing the organisational and technical expertise required for the implementation of this Regulation, including by contributing to the assessment of training needs for staff of Member States involved in implementing this Regulation;

(k) assist the AI Office in supporting national competent authorities in the establishment and development of AI regulatory sandboxes, and facilitate cooperation and information-sharing among AI regulatory sandboxes;

(l) contribute to, and provide relevant advice on, the development of guidance documents;

(m) advise the Commission in relation to international matters on AI;

(n) provide opinions to the Commission on the qualified alerts regarding general-purpose AI models;

(o) receive opinions by the Member States on qualified alerts regarding general-purpose AI models, and on national experiences and practices on the monitoring and enforcement of AI systems, in particular systems integrating the general-purpose AI models.

▼B

Article 67

Advisory forum

1. An advisory forum shall be established to provide technical expertise and advise the Board and the Commission, and to contribute to their tasks under this Regulation.

2. The membership of the advisory forum shall represent a balanced selection of stakeholders, including industry, start-ups, SMEs, civil society and academia. The membership of the advisory forum shall be balanced with regard to commercial and non-commercial interests and, within the category of commercial interests, with regard to SMEs and other undertakings.

3. The Commission shall appoint the members of the advisory forum, in accordance with the criteria set out in paragraph 2, from amongst stakeholders with recognised expertise in the field of AI.

4. The term of office of the members of the advisory forum shall be two years, which may be extended by up to no more than four years.

5. The Fundamental Rights Agency, ENISA, the European Committee for Standardization (CEN), the European Committee for Electrotechnical Standardization (CENELEC), and the European Telecommunications Standards Institute (ETSI) shall be permanent members of the advisory forum.

6. The advisory forum shall draw up its rules of procedure. It shall elect two co-chairs from among its members, in accordance with criteria set out in paragraph 2. The term of office of the co-chairs shall be two years, renewable once.

7. The advisory forum shall hold meetings at least twice a year. The advisory forum may invite experts and other stakeholders to its meetings.

8. The advisory forum may prepare opinions, recommendations and written contributions at the request of the Board or the Commission.

9. The advisory forum may establish standing or temporary sub-groups as appropriate for the purpose of examining specific questions related to the objectives of this Regulation.

10. The advisory forum shall prepare an annual report on its activities. That report shall be made publicly available.

Article 68

Scientific panel of independent experts

1. The Commission shall, by means of an implementing act, make provisions on the establishment of a scientific panel of independent experts (the ‘scientific panel’) intended to support the enforcement activities under this Regulation. That implementing act shall be adopted in accordance with the examination procedure referred to in Article 98(2).

▼B

2. The scientific panel shall consist of experts selected by the Commission on the basis of up-to-date scientific or technical expertise in the field of AI necessary for the tasks set out in paragraph 3, and shall be able to demonstrate meeting all of the following conditions:

(a) having particular expertise and competence and scientific or technical expertise in the field of AI;

(b) independence from any provider of AI systems or general-purpose AI models;

(c) an ability to carry out activities diligently, accurately and objectively.

The Commission, in consultation with the Board, shall determine the number of experts on the panel in accordance with the required needs and shall ensure fair gender and geographical representation.

3. The scientific panel shall advise and support the AI Office, in particular with regard to the following tasks:

(a) supporting the implementation and enforcement of this Regulation as regards general-purpose AI models and systems, in particular by:

(i) alerting the AI Office of possible systemic risks at Union level of general-purpose AI models, in accordance with Article 90;

(ii) contributing to the development of tools and methodologies for evaluating capabilities of general-purpose AI models and systems, including through benchmarks;

(iii) providing advice on the classification of general-purpose AI models with systemic risk;

(iv) providing advice on the classification of various general-purpose AI models and systems;

(v) contributing to the development of tools and templates;

(b) supporting the work of market surveillance authorities, at their request;

(c) supporting cross-border market surveillance activities as referred to in Article 74(11), without prejudice to the powers of market surveillance authorities;

(d) supporting the AI Office in carrying out its duties in the context of the Union safeguard procedure pursuant to Article 81.

4. The experts on the scientific panel shall perform their tasks with impartiality and objectivity, and shall ensure the confidentiality of information and data obtained in carrying out their tasks and activities. They shall neither seek nor take instructions from anyone when exercising their tasks under paragraph 3. Each expert shall draw up a declaration of interests, which shall be made publicly available. The AI Office shall establish systems and procedures to actively manage and prevent potential conflicts of interest.

▼B

5. The implementing act referred to in paragraph 1 shall include provisions on the conditions, procedures and detailed arrangements for the scientific panel and its members to issue alerts, and to request the assistance of the AI Office for the performance of the tasks of the scientific panel.

Article 69

Access to the pool of experts by the Member States

1. Member States may call upon experts of the scientific panel to support their enforcement activities under this Regulation.

▼M1

2. The Member States may be required to pay fees for the advice and support provided by the experts at a rate equivalent to the remuneration fees applicable to the Commission pursuant to the implementing act referred to in Article 68(1).

▼B

3. The Commission shall facilitate timely access to the experts by the Member States, as needed, and ensure that the combination of support activities carried out by Union AI testing support pursuant to Article 84 and experts pursuant to this Article is efficiently organised and provides the best possible added value.

SECTION 2

National competent authorities

Article 70

Designation of national competent authorities and single points of contact

1. Each Member State shall establish or designate as national competent authorities at least one notifying authority and at least one market surveillance authority for the purposes of this Regulation. Those national competent authorities shall exercise their powers independently, impartially and without bias so as to safeguard the objectivity of their activities and tasks, and to ensure the application and implementation of this Regulation. The members of those authorities shall refrain from any action incompatible with their duties. Provided that those principles are observed, such activities and tasks may be performed by one or more designated authorities, in accordance with the organisational needs of the Member State.

2. Member States shall communicate to the Commission the identity of the notifying authorities and the market surveillance authorities and the tasks of those authorities, as well as any subsequent changes thereto. Member States shall make publicly available information on how competent authorities and single points of contact can be contacted, through electronic communication means by 2 August 2025. Member States shall designate a market surveillance authority to act as the single point of contact for this Regulation, and shall notify the Commission of the identity of the single point of contact. The Commission shall make a list of the single points of contact publicly available.

▼B

3. Member States shall ensure that their national competent authorities are provided with adequate technical, financial and human resources, and with infrastructure to fulfil their tasks effectively under this Regulation. In particular, the national competent authorities shall have a sufficient number of personnel permanently available whose competences and expertise shall include an in-depth understanding of AI technologies, data and data computing, personal data protection, cybersecurity, fundamental rights, health and safety risks and knowledge of existing standards and legal requirements. Member States shall assess and, if necessary, update competence and resource requirements referred to in this paragraph on an annual basis.

4. National competent authorities shall take appropriate measures to ensure an adequate level of cybersecurity.

5. When performing their tasks, the national competent authorities shall act in accordance with the confidentiality obligations set out in Article 78.

6. By 2 August 2025, and once every two years thereafter, Member States shall report to the Commission on the status of the financial and human resources of the national competent authorities, with an assessment of their adequacy. The Commission shall transmit that information to the Board for discussion and possible recommendations.

7. The Commission shall facilitate the exchange of experience between national competent authorities.

▼M1

8. National competent authorities may provide guidance and advice on the implementation of this Regulation, in particular to SMEs, including start-ups, and SMCs, taking into account the guidance and advice of the Board and the Commission, as appropriate. Whenever national competent authorities intend to provide guidance and advice with regard to an AI system in areas covered by other Union law, the national competent authorities under that Union law shall be consulted, as appropriate.

▼B

9. Where Union institutions, bodies, offices or agencies fall within the scope of this Regulation, the European Data Protection Supervisor shall act as the competent authority for their supervision.

CHAPTER VIII

EU DATABASE FOR HIGH-RISK AI SYSTEMS

Article 71

EU database for high-risk AI systems listed in Annex III

1. The Commission shall, in collaboration with the Member States, set up and maintain an EU database containing information referred to in paragraphs 2 and 3 of this Article concerning high-risk AI systems referred to in Article 6(2) which are registered in accordance with Articles 49 and 60 and AI systems that are not considered as high-risk pursuant to Article 6(3) and which are registered in accordance with Article 6(4) and Article 49. When setting the functional specifications of such database, the Commission shall consult the relevant experts, and when updating the functional specifications of such database, the Commission shall consult the Board.

▼B

2. The data listed in Sections A and B of Annex VIII shall be entered into the EU database by the provider or, where applicable, by the authorised representative.

3. The data listed in Section C of Annex VIII shall be entered into the EU database by the deployer who is, or who acts on behalf of, a public authority, agency or body, in accordance with Article 49(3) and (4).

4. With the exception of the section referred to in Article 49(4) and Article 60(4), point (c), the information contained in the EU database registered in accordance with Article 49 shall be accessible and publicly available in a user-friendly manner. The information should be easily navigable and machine-readable. The information registered in accordance with Article 60 shall be accessible only to market surveillance authorities and the Commission, unless the prospective provider or provider has given consent for also making the information accessible the public.

5. The EU database shall contain personal data only in so far as necessary for collecting and processing information in accordance with this Regulation. That information shall include the names and contact details of natural persons who are responsible for registering the system and have the legal authority to represent the provider or the deployer, as applicable.

6. The Commission shall be the controller of the EU database. It shall make available to providers, prospective providers and deployers adequate technical and administrative support. The EU database shall comply with the applicable accessibility requirements.

CHAPTER IX

POST-MARKET MONITORING, INFORMATION SHARING AND MARKET SURVEILLANCE

SECTION 1

Post-market monitoring

Article 72

Post-market monitoring by providers and post-market monitoring plan for high-risk AI systems

1. Providers shall establish and document a post-market monitoring system in a manner that is proportionate to the nature of the AI technologies and the risks of the high-risk AI system.

2. The post-market monitoring system shall actively and systematically collect, document and analyse relevant data which may be provided by deployers or which may be collected through other sources on the performance of high-risk AI systems throughout their lifetime, and which allow the provider to evaluate the continuous compliance of AI systems with the requirements set out in Chapter III, Section 2. Where relevant, post-market monitoring shall include an analysis of the interaction with other AI systems. This obligation shall not cover sensitive operational data of deployers which are law-enforcement authorities.

▼M1

3. The post-market monitoring system shall be based on a post-market monitoring plan. The post-market monitoring plan shall be part of the technical documentation referred to in Annex IV. The Commission, taking utmost account of the opinion of the Board, shall adopt guidance, including a template, on the post-market monitoring plan by 2 September 2027.

▼B

4. For high-risk AI systems covered by the Union harmonisation legislation listed in Section A of Annex I, where a post-market monitoring system and plan are already established under that legislation, in order to ensure consistency, avoid duplications and minimise additional burdens, providers shall have a choice of integrating, as appropriate, the necessary elements described in paragraphs 1, 2 and 3 using the template referred in paragraph 3 into systems and plans already existing under that legislation, provided that it achieves an equivalent level of protection.

The first subparagraph of this paragraph shall also apply to high-risk AI systems referred to in point 5 of Annex III placed on the market or put into service by financial institutions that are subject to requirements under Union financial services law regarding their internal governance, arrangements or processes.

SECTION 2

Sharing of information on serious incidents

Article 73

Reporting of serious incidents

1. Providers of high-risk AI systems placed on the Union market shall report any serious incident to the market surveillance authorities of the Member States where that incident occurred.

2. The report referred to in paragraph 1 shall be made immediately after the provider has established a causal link between the AI system and the serious incident or the reasonable likelihood of such a link, and, in any event, not later than 15 days after the provider or, where applicable, the deployer, becomes aware of the serious incident.

The period for the reporting referred to in the first subparagraph shall take account of the severity of the serious incident.

3. Notwithstanding paragraph 2 of this Article, in the event of a widespread infringement or a serious incident as defined in Article 3, point (49)(b), the report referred to in paragraph 1 of this Article shall be provided immediately, and not later than two days after the provider or, where applicable, the deployer becomes aware of that incident.

4. Notwithstanding paragraph 2, in the event of the death of a person, the report shall be provided immediately after the provider or the deployer has established, or as soon as it suspects, a causal relationship between the high-risk AI system and the serious incident, but not later than 10 days after the date on which the provider or, where applicable, the deployer becomes aware of the serious incident.

▼B

5. Where necessary to ensure timely reporting, the provider or, where applicable, the deployer, may submit an initial report that is incomplete, followed by a complete report.

6. Following the reporting of a serious incident pursuant to paragraph 1, the provider shall, without delay, perform the necessary investigations in relation to the serious incident and the AI system concerned. This shall include a risk assessment of the incident, and corrective action.

The provider shall cooperate with the competent authorities, and where relevant with the notified body concerned, during the investigations referred to in the first subparagraph, and shall not perform any investigation which involves altering the AI system concerned in a way which may affect any subsequent evaluation of the causes of the incident, prior to informing the competent authorities of such action.

7. Upon receiving a notification related to a serious incident referred to in Article 3, point (49)(c), the relevant market surveillance authority shall inform the national public authorities or bodies referred to in Article 77(1). The Commission shall develop dedicated guidance to facilitate compliance with the obligations set out in paragraph 1 of this Article. That guidance shall be issued by 2 August 2025, and shall be assessed regularly.

8. The market surveillance authority shall take appropriate measures, as provided for in Article 19 of Regulation (EU) 2019/1020, within seven days from the date it received the notification referred to in paragraph 1 of this Article, and shall follow the notification procedures as provided in that Regulation.

9. For high-risk AI systems referred to in Annex III that are placed on the market or put into service by providers that are subject to Union legislative instruments laying down reporting obligations equivalent to those set out in this Regulation, the notification of serious incidents shall be limited to those referred to in Article 3, point (49)(c).

10. For high-risk AI systems which are safety components of devices, or are themselves devices, covered by Regulations (EU) 2017/745 and (EU) 2017/746, the notification of serious incidents shall be limited to those referred to in Article 3, point (49)(c) of this Regulation, and shall be made to the national competent authority chosen for that purpose by the Member States where the incident occurred.

11. National competent authorities shall immediately notify the Commission of any serious incident, whether or not they have taken action on it, in accordance with Article 20 of Regulation (EU) 2019/1020.

▼B

SECTION 3

Enforcement

Article 74

Market surveillance and control of AI systems in the Union market

1. Regulation (EU) 2019/1020 shall apply to AI systems covered by this Regulation. For the purposes of the effective enforcement of this Regulation:

(a) any reference to an economic operator under Regulation (EU) 2019/1020 shall be understood as including all operators identified in Article 2(1) of this Regulation;

(b) any reference to a product under Regulation (EU) 2019/1020 shall be understood as including all AI systems falling within the scope of this Regulation.

2. As part of their reporting obligations under Article 34(4) of Regulation (EU) 2019/1020, the market surveillance authorities shall report annually to the Commission and relevant national competition authorities any information identified in the course of market surveillance activities that may be of potential interest for the application of Union law on competition rules. They shall also annually report to the Commission about the use of prohibited practices that occurred during that year and about the measures taken.

3. For high-risk AI systems related to products covered by the Union harmonisation legislation listed in Section A of Annex I, the market surveillance authority for the purposes of this Regulation shall be the authority responsible for market surveillance activities designated under those legal acts.

By derogation from the first subparagraph, and in appropriate circumstances, Member States may designate another relevant authority to act as a market surveillance authority, provided they ensure coordination with the relevant sectoral market surveillance authorities responsible for the enforcement of the Union harmonisation legislation listed in Annex I.

4. The procedures referred to in Articles 79 to 83 of this Regulation shall not apply to AI systems related to products covered by the Union harmonisation legislation listed in section A of Annex I, where such legal acts already provide for procedures ensuring an equivalent level of protection and having the same objective. In such cases, the relevant sectoral procedures shall apply instead.

5. Without prejudice to the powers of market surveillance authorities under Article 14 of Regulation (EU) 2019/1020, for the purpose of ensuring the effective enforcement of this Regulation, market surveillance authorities may exercise the powers referred to in Article 14(4), points (d) and (j), of that Regulation remotely, as appropriate.

▼B

6. For high-risk AI systems placed on the market, put into service, or used by financial institutions regulated by Union financial services law, the market surveillance authority for the purposes of this Regulation shall be the relevant national authority responsible for the financial supervision of those institutions under that legislation in so far as the placing on the market, putting into service, or the use of the AI system is in direct connection with the provision of those financial services.

7. By way of derogation from paragraph 6, in appropriate circumstances, and provided that coordination is ensured, another relevant authority may be identified by the Member State as market surveillance authority for the purposes of this Regulation.

National market surveillance authorities supervising regulated credit institutions regulated under Directive 2013/36/EU, which are participating in the Single Supervisory Mechanism established by Regulation (EU) No 1024/2013, should report, without delay, to the European Central Bank any information identified in the course of their market surveillance activities that may be of potential interest for the prudential supervisory tasks of the European Central Bank specified in that Regulation.

8. For high-risk AI systems listed in point 1 of Annex III to this Regulation, in so far as the systems are used for law enforcement purposes, border management and justice and democracy, and for high-risk AI systems listed in points 6, 7 and 8 of Annex III to this Regulation, Member States shall designate as market surveillance authorities for the purposes of this Regulation either the competent data protection supervisory authorities under Regulation (EU) 2016/679 or Directive (EU) 2016/680, or any other authority designated pursuant to the same conditions laid down in Articles 41 to 44 of Directive (EU) 2016/680. Market surveillance activities shall in no way affect the independence of judicial authorities, or otherwise interfere with their activities when acting in their judicial capacity.

9. Where Union institutions, bodies, offices or agencies fall within the scope of this Regulation, the European Data Protection Supervisor shall act as their market surveillance authority, except in relation to the Court of Justice of the European Union acting in its judicial capacity.

10. Member States shall facilitate coordination between market surveillance authorities designated under this Regulation and other relevant national authorities or bodies which supervise the application of Union harmonisation legislation listed in Annex I, or in other Union law, that might be relevant for the high-risk AI systems referred to in Annex III.

11. Market surveillance authorities and the Commission shall be able to propose joint activities, including joint investigations, to be conducted by either market surveillance authorities or market surveillance authorities jointly with the Commission, that have the aim of promoting compliance, identifying non-compliance, raising awareness or providing guidance in relation to this Regulation with respect to specific categories of high-risk AI systems that are found to present a serious risk across two or more Member States in accordance with Article 9 of Regulation (EU) 2019/1020. The AI Office shall provide coordination support for joint investigations.

▼B

12. Without prejudice to the powers provided for under Regulation (EU) 2019/1020, and where relevant and limited to what is necessary to fulfil their tasks, the market surveillance authorities shall be granted full access by providers to the documentation as well as the training, validation and testing data sets used for the development of high-risk AI systems, including, where appropriate and subject to security safeguards, through application programming interfaces (API) or other relevant technical means and tools enabling remote access.

13. Market surveillance authorities shall be granted access to the source code of the high-risk AI system upon a reasoned request and only when both of the following conditions are fulfilled:

(a) access to source code is necessary to assess the conformity of a high-risk AI system with the requirements set out in Chapter III, Section 2; and

(b) testing or auditing procedures and verifications based on the data and documentation provided by the provider have been exhausted or proved insufficient.

14. Any information or documentation obtained by market surveillance authorities shall be treated in accordance with the confidentiality obligations set out in Article 78.

Article 75

▼M1

Market surveillance and control of AI systems and mutual assistance

1. The AI Office shall be exclusively competent for the supervision and enforcement of the obligations under this Regulation in relation to the following AI systems:

(a) AI systems based on general-purpose AI models where the model and the system are developed by the same provider, or by providers forming part of the same undertaking as that provider, with the exception of:

(i) AI systems related to products covered by the Union harmonisation legislation listed in Annex I;

(ii) AI systems referred to in point 2 of Annex III;

(iii) AI systems provided by law enforcement authorities, border management authorities and financial institutions, insofar as those AI systems fall under Article 74(6); and

(iv) AI systems referred to in point 8 of Annex III as regards the administration of justice;

(b) AI systems that constitute or that are integrated into a very large online platform or very large online search engine designated in accordance with Regulation (EU) 2022/2065.

The exclusive competence referred to in the first subparagraph shall apply to the providers of those systems. It shall apply to the deployers of those systems only when they are also the provider or form part of the same undertaking as the provider.

▼**M1**

1a. By way of derogation from Article 73, providers of high-risk AI systems subject to the competence of the AI Office pursuant to paragraph 1 of this Article shall report any serious incidents to the AI Office. Article 73 (2) to (9), shall apply *mutatis mutandis*. The AI Office shall promptly transmit the relevant information to the market surveillance authority of the Member State in the territory of which the provider or its legal representative is situated.

1b. The authorities involved in the application of this Regulation shall cooperate actively with the AI Office and provide the AI Office the necessary assistance for the exercise of its powers, including, where necessary, in connection with inspections or other enforcement measures carried out in the territory of a Member State. To that end, those authorities shall enjoy the powers provided for pursuant to this Regulation and Regulation (EU) 2019/1020, and where relevant and limited to what is necessary to fulfil their tasks under this paragraph, in accordance with the applicable national procedures.

1c. When taking investigatory or enforcement action in the territory of a Member State that involves access to a public authority's data or AI system, the AI Office shall be assisted by the relevant market surveillance authority.

1d. Before taking a decision that would have the effect of prohibiting or restricting the AI system being made available or put into service on a national market, or a decision to withdraw or recall the AI system from such market, the AI Office shall, without undue delay, notify the market surveillance authority competent for that market of its intention to take such a decision. The AI Office shall consult the authorities involved in the application of this Regulation, where appropriate, on any matter relating to the application and enforcement of this Regulation.

1e. The AI Office shall be responsible for conformity assessments and tests of AI systems referred to in paragraph 1 of this Article that are classified as high-risk and subject to a third-party conformity assessment pursuant to Article 43 before such AI systems are placed on the market or put into service. Those tests and assessments shall verify that the systems comply with the relevant requirements of this Regulation and may be placed on the market or put into service in the Union in accordance with this Regulation. The Commission shall entrust the performance of those tests or assessments to notified bodies designated in accordance with this Regulation, in which case the notified body shall act on behalf of the Commission. If a notified body to which the Commission has delegated tasks under this paragraph does not perform those tasks adequately, the Commission may withdraw the delegation with immediate effect.

The fees for testing and assessment activities shall be levied on the provider of a high-risk AI system who has applied for a third-party conformity assessment to the Commission. The provider shall pay the costs related to the services entrusted by the Commission to the notified bodies in accordance with this Article directly to the notified body.

▼B

2. Where the relevant market surveillance authorities have sufficient reason to consider general-purpose AI systems that can be used directly by deployers for at least one purpose that is classified as high-risk pursuant to this Regulation to be non-compliant with the requirements laid down in this Regulation, they shall cooperate with the AI Office to carry out compliance evaluations, and shall inform the Board and other market surveillance authorities accordingly.

▼M1

2a. Where a market surveillance authority has well-founded and sufficient reasons to suspect that a provider or a deployer of an AI system referred to in paragraph 1 of this Article has infringed this Regulation, it may request, through the relevant single point of contact designated in accordance with Article 70(2), the AI Office to assess the matter in order to take the necessary supervisory and enforcement measures to ensure prompt compliance with this Regulation. Such a request shall be duly reasoned and shall include at least:

(a) the name of the provider or the deployer concerned;

(b) a description of the relevant facts, the provisions of this Regulation that have allegedly been infringed, and any well-founded and sufficient reasons for suspecting an infringement, including, where applicable, the description of the negative effects of the alleged infringement;

(c) the market surveillance authority making the request.

The AI Office shall take utmost account of the request and the market surveillance authority shall cooperate actively and provide the AI Office the necessary assistance for the exercise of its powers in accordance with paragraph 1a.

The AI Office shall, without undue delay and in any event no later than four months following receipt of the request, inform the single point of contact of its intention to exercise its powers in accordance with Article 75a or of its reasons for not exercising its powers. If the AI Office decides to exercise its powers in accordance with Article 75a, it shall periodically inform that single point of contact about major developments in the proceedings and the outcome of such proceedings, without disclosing any confidential information.

▼B

3. Where a market surveillance authority is unable to conclude its investigation of the high-risk AI system because of its inability to access certain information related to the general-purpose AI model despite having made all appropriate efforts to obtain that information, it may submit a reasoned request to the AI Office, by which access to that information shall be enforced. In that case, the AI Office shall supply to the applicant authority without delay, and in any event within 30 days, any information that the AI Office considers to be relevant in order to establish whether a high-risk AI system is non-compliant. Market surveillance authorities shall safeguard the confidentiality of the information that they obtain in accordance with Article 78 of this Regulation. The procedure provided for in Chapter VI of Regulation (EU) 2019/1020 shall apply *mutatis mutandis*.

▼M1

Article 75a

Supervisory and enforcement powers of the AI Office

1. When exercising its tasks of supervision and enforcement laid down in Article 75(1) of this Regulation, the AI Office shall have all the powers of a market surveillance authority provided for in this Section and in Article 14(4) and Article 16(3) of Regulation (EU) 2019/1020. The AI Office shall be authorised to fully reclaim from the relevant operator the totality of the costs of its supervision and enforcement activities with respect to instances of non-compliance, including costs for human and technical resources, in accordance with Article 15 of Regulation (EU) 2019/1020. Article 17 of Regulation (EU) 2019/1020 shall apply *mutatis mutandis*.

2. Where the AI Office has reasonable grounds to suspect non-compliance with this Regulation by a provider or a deployer of an AI system referred to in Article 75(1) of this Regulation, it may adopt a decision to start an investigation into that non-compliance in accordance with Article 14(4), point (f) of Regulation (EU) 2019/1020. Upon starting such an investigation, the AI Office shall notify the operator of the AI system concerned. The AI Office may exercise the powers referred to in paragraph 1 of this Article on its own initiative or following a complaint received pursuant to Article 85 of this Regulation, even before starting an investigation pursuant to Article 14(4), point (f) of Regulation (EU) 2019/1020.

Where a market surveillance authority has reason to suspect non-compliance with this Regulation by a provider or a deployer of an AI system referred to in Article 75(1), it may send a request to the AI Office to assess the matter.

3. The AI Office may exercise the powers listed in Article 14(4), points (a), (b) and (c) of Regulation (EU) 2019/1020 and Article 74(12) and (13) of this Regulation by simple request or by decision.

When requesting information, the AI Office shall state the legal basis and the purpose of the request, specify what information is required, and set the period within which the information is to be provided. Where the request is a simple request, the AI Office shall additionally indicate that although there is no obligation to provide the information requested, in the case of a voluntary reply, the information must be correct and not misleading, and indicate the potential fines provided for in Article 99(5) for supplying incorrect or misleading information. Where the request is made by decision, the AI Office shall additionally indicate the fines provided for in Article 99(5) for supplying incorrect, incomplete or misleading information and indicate the right to have the decision reviewed by the Court of Justice of the European Union. The AI Office shall send a copy of the request to the market surveillance authority of the Member State in the territory of which the operator or its legal representative is situated.

▼M1

4. In order to carry out the tasks assigned to it under this Section, the AI Office may conduct all necessary remote or on-site inspections pursuant to the powers laid down in Article 14(4), points (d) and (e) of Regulation (EU) 2019/1020 and Article 74(5) of this Regulation. When conducting an inspection, the AI Office shall inform the provider concerned of the subject matter and purpose of the investigation, the relevant fines referred to in Article 99(5) of this Regulation, and the right to have the decision reviewed by the Court of Justice of the European Union. Prior to conducting an inspection, the AI Office shall inform the market surveillance authority of the Member State in the territory of which the operator or its legal representative is situated.

During such an inspection, the officials of the AI Office shall be empowered to:

(a) enter any of the business premises, land or property located in the Union of the operator concerned;

(b) examine the books, data and other material relevant to the execution of their tasks, irrespective of the medium on which they are stored;

(c) take or obtain in any form copies of or extracts from books, data and other records;

(d) ask any of the persons subject to the inspection, or their representatives, or staff, for oral or written explanations on factors or documents relating to the subject matter and purpose of the inspection, and to record the answers;

(e) seal any business premises and books or records for the duration of, and to the extent necessary for, the inspection.

Where the AI Office finds that a natural or legal person opposes or obstructs an inspection, the national competent authority of the Member State concerned shall afford it the necessary assistance, requesting, where appropriate, the assistance of the police or an equivalent enforcement authority, to enable it to conduct its on-site inspection.

Where an on-site inspection of business premises, land or property requires authorisation by a judicial authority in accordance with national law, the AI Office shall apply for such an authorisation. The AI Office may also apply for such authorisation as a precautionary measure. Where such an authorisation is applied for, the national judicial authority shall promptly verify that the coercive measures envisaged are neither arbitrary nor excessive having regard to the subject matter of the investigation or inspection and the documents provided by the AI Office with the decision. In its verification of the proportionality of coercive measures, the national judicial authority may ask the AI Office for detailed explanations, in particular relating to the grounds the AI Office has for suspecting that an infringement of this Regulation has taken place and the seriousness of the suspected infringement and, where relevant, the nature of the involvement of the person subject to the coercive measures. The national judicial authority shall not review the necessity of the investigation or inspection nor demand information from the case file of the AI Office. In accordance with the Treaties, the legality of the decision of the AI Office is subject to review only by the Court of Justice of the European Union.

▼M1

5. At the request of the AI Office, the competent market surveillance authority of a Member State may in its own territory carry out any investigation, inspection or other fact-finding measure on behalf and for the account of the AI Office in order to establish whether there has been an infringement of this Regulation. The officials of the competent authorities of the Member States who are responsible for conducting such investigations, inspections, or fact-finding measures, as well as those authorised or appointed by them, shall exercise their powers in accordance with their national law.

6. In addition to the powers set out in paragraph 1 of this Article, the AI Office, in the exercise of its competences referred to in Article 75(1), may:

(a) order operators to provide access to, and explanations relating to, their AI systems;

(b) impose an obligation on an operator to retain all data and documents deemed to be necessary to assess the implementation of and compliance with the obligations under this Regulation.

7. To assist it in monitoring the effective implementation and compliance with the relevant provisions of this Regulation and to provide it with specific expertise or knowledge in the exercise of its competences under Article 75(1), the AI Office may appoint independent external experts and auditors, as well as experts, investigative teams and auditors from the Member State's competent authorities with the agreement of the authority concerned. Information obtained as a result of such monitoring actions shall be shared with the relevant competent authorities of the Member States.

8. Information collected pursuant to this Article shall be used only for the purpose of this Regulation.

Article 75b

Commitments

If, during proceedings under Article 75a(2), the operator concerned offers commitments to ensure compliance with the relevant provisions of this Regulation, the AI Office may, by decision, make those commitments binding on the operator concerned and declare that there are no further grounds for action. The AI Office may, upon request or on its own initiative, reopen the proceedings where:

(a) there has been a material change in any of the facts on which the decision was based;

(b) the operator acts contrary to its commitments; or

(c) the decision was based on incomplete, incorrect or misleading information provided by the operator concerned.

Where the AI Office considers that the commitments offered by the operator concerned are unable to ensure effective compliance with the relevant provisions of this Regulation, it shall reject those commitments in a reasoned decision when concluding the proceedings.

▼M1

Article 75c

Non-compliance, fines and periodic penalty payments

1. Where the AI Office finds that an operator falling within the scope of Article 75(1) does not comply with the relevant provisions of this Regulation or with commitments made binding pursuant to Article 75b, it shall adopt a decision establishing such non-compliance.

2. Before adopting a decision pursuant to paragraph 1, the AI Office shall communicate its preliminary findings to the operator concerned. In the preliminary findings, the AI Office shall explain the measures that it is considering taking, or that it considers that the operator concerned should take, in order to effectively address the preliminary findings.

3. In the decision pursuant to paragraph 1 of this Article, the AI Office shall, where relevant, order the operator concerned to take the necessary measures to ensure compliance with the relevant provisions of this Regulation within a reasonable period specified therein and to provide information on the measures that that operator intends to take to comply with the decision. The operator concerned shall provide the AI Office with a description of the measures it has taken to ensure compliance with the decision upon their implementation. Prior to requesting any measure, the AI Office may engage in a structured dialogue with the operator of the AI system in question. During this dialogue, the operator may propose commitments in accordance with Article 75b.

4. A decision adopted pursuant to paragraph 1 of this Article may be accompanied by the imposition of penalties in accordance with Article 99(3) to (7), which provisions shall apply *mutatis mutandis* to the AI Office in the execution of its supervision and enforcement tasks referred to in Article 75(1).

In particular, the following shall be subject to administrative fines as referred to in Article 99(4):

(a) infringement of any applicable provision of this Regulation, including those not listed in Article 99(4);

(b) failure to comply with decisions or measures adopted pursuant to the powers listed in Article 14(4) or Article 16(3) of Regulation (EU) 2019/1020, as well as those specified in Article 75a of this Regulation;

(c) failure to comply with a commitment made binding by a decision pursuant to Article 75b.

The supply of incorrect, incomplete or misleading information to the AI Office in reply to a request shall be subject to administrative fines as referred to in Article 99(5).

5. The AI Office may adopt a decision imposing periodic penalty payments to compel the operators subject to its competence pursuant to Article 75(1) to the following:

(a) to submit to an investigation;

(b) to comply with an information request ordered by a decision adopted under Article 75a(3);

▼M1

(c) to submit to an inspection ordered by a decision pursuant to Article 75a(4);

(d) to provide correct or complete answers or explanations in the context of an inspection ordered by a decision pursuant to Article 75a(4);

(e) to comply with corrective actions ordered pursuant to the power listed in Article 16 of Regulation (EU) 2019/1020;

(f) to comply with commitments made legally binding by a decision pursuant to Article 75b; or

(g) to comply with a decision pursuant to the paragraph (1) of this Article.

Those penalty payments shall be effective and proportionate, and, where applicable, shall not exceed 5 % of the average daily income or worldwide annual turnover in the preceding financial year per day, calculated from the date appointed by the decision.

6. The Court of Justice of the European Union shall have unlimited jurisdiction to review decisions of the AI Office fixing a fine or periodic penalty payment pursuant to this Article. It may cancel, reduce or increase the fine or periodic penalty payment imposed.

7. Funds collected through the imposition of fines or periodic penalty payments pursuant to this Article shall contribute to the general budget of the Union.

8. The powers conferred on the AI Office by this Article shall be subject to a limitation period of five years. The limitation period shall begin to run on the day on which the infringement is committed. However, in the case of continuing or repeated infringements, the limitation period shall begin to run on the day on which the infringement ceases.

The power of the AI Office to enforce decisions taken pursuant to this Article shall be subject to a limitation period of five years. The limitation period shall begin to run on the day on which the decision becomes final.

The implementing act referred to in Article 75d(3) shall specify the first and second subparagraphs of this paragraph, including the circumstances in which the limitation periods shall be interrupted.

9. Where the AI Office determines that there are no grounds to adopt a decision of non-compliance, it shall close the proceeding by a decision. That decision shall apply with immediate effect.

Article 75d

Safeguards and further specification

1. Article 18 of Regulation (EU) 2019/1020 shall apply *mutatis mutandis* to operators subject to the AI Office's competence pursuant to Article 75(1) of this Regulation, without prejudice to more specific procedural rights provided for in this Regulation.

▼M1

2. The rights of defence and of access to the file of operators falling within the scope of Article 75(1) shall be fully respected in proceedings. In view of the possible adoption of decisions on the basis of Article 75c(1), those operators shall be entitled to have access to the AI Office file under the terms of a negotiated disclosure, subject to the legitimate interest of the operator or other person concerned in the protection of their business secrets. The AI Office shall have the power to adopt decisions setting out such terms of disclosure in the case of disagreement between the parties. The right of access to the file shall not extend to confidential information and internal documents of the AI Office, the Board, competent market surveillance authorities or other public authorities of the Member States. In particular, the right of access shall not extend to correspondence between the AI Office and those authorities. Nothing in this paragraph shall prevent the AI Office from disclosing and using information necessary to prove an infringement.

3. The Commission may adopt implementing acts concerning the practical arrangements for access to the file and the negotiated disclosure of information provided for in paragraph 2.

4. The AI Office shall publish the decisions it adopts pursuant to Articles 75b and 75c. Such publication shall state the names of the parties and the main content of the decision, including any penalties imposed. The publication shall have regard to the rights and legitimate interests of any person concerned in the protection of their confidential information.

▼B

Article 76

Supervision of testing in real world conditions by market surveillance authorities

1. Market surveillance authorities shall have competences and powers to ensure that testing in real world conditions is in accordance with this Regulation.

▼M1

Where testing in real world conditions is based on Article 60a, any reference to a market surveillance authority in this Article shall be construed as a reference to the national competent authority or appropriate authority under the Union harmonisation legislation listed in Section B of Annex I, and references to Article 60 shall be construed as references to Article 60a, as appropriate.

▼B

2. Where testing in real world conditions is conducted for AI systems that are supervised within an AI regulatory sandbox under Article 58, the market surveillance authorities shall verify the compliance with Article 60 as part of their supervisory role for the AI regulatory sandbox. Those authorities may, as appropriate, allow the testing in real world conditions to be conducted by the provider or prospective provider, in derogation from the conditions set out in Article 60(4), points (f) and (g).

3. Where a market surveillance authority has been informed by the prospective provider, the provider or any third party of a serious incident or has other grounds for considering that the conditions set out in Articles 60 and 61 are not met, it may take either of the following decisions on its territory, as appropriate:

▼B

(a) to suspend or terminate the testing in real world conditions;

(b) to require the provider or prospective provider and the deployer or prospective deployer to modify any aspect of the testing in real world conditions.

4. Where a market surveillance authority has taken a decision referred to in paragraph 3 of this Article, or has issued an objection within the meaning of Article 60(4), point (b), the decision or the objection shall indicate the grounds therefor and how the provider or prospective provider can challenge the decision or objection.

5. Where applicable, where a market surveillance authority has taken a decision referred to in paragraph 3, it shall communicate the grounds therefor to the market surveillance authorities of other Member States in which the AI system has been tested in accordance with the testing plan.

Article 77

▼M1

Powers of authorities protecting fundamental rights and cooperation with market surveillance authorities

1. National public authorities or bodies which supervise or enforce the respect of obligations under Union law protecting fundamental rights, including the right to non-discrimination, shall have the power to request and access any information or documentation created or maintained from the relevant market surveillance authority pursuant to this Regulation in accessible language and machine-readable format by electronic means where access to that information or documentation is necessary for effectively fulfilling their mandates within the limits of their jurisdiction. This Article is without prejudice to the competences, tasks, powers and independence of the relevant national public authorities or bodies under their mandates.

1a. Subject to the conditions specified in this Article, the market surveillance authority shall grant the relevant public authority or body referred to in paragraph 1 access to such information or documentation, including by requesting such information or documentation from the provider or the deployer, where necessary and without undue delay.

1b. Market surveillance authorities and public authorities or bodies referred to in paragraph 1 shall cooperate closely and provide each other with the mutual assistance necessary to fulfil their respective mandates, with a view to ensuring the coherent application of this Regulation and Union law protecting fundamental rights and streamlining procedures, while respecting their respective competences, tasks, powers and independence. This shall include, in particular, exchange of information where necessary for the effective supervision or enforcement of this Regulation and the respective other Union legislation.

▼B

2. By 2 November 2024, each Member State shall identify the public authorities or bodies referred to in paragraph 1 and make a list of them publicly available. Member States shall notify the list to the Commission and to the other Member States, and shall keep the list up to date.

▼B

3. Where the documentation referred to in paragraph 1 is insufficient to ascertain whether an infringement of obligations under Union law protecting fundamental rights has occurred, the public authority or body referred to in paragraph 1 may make a reasoned request to the market surveillance authority, to organise testing of the high-risk AI system through technical means. The market surveillance authority shall organise the testing with the close involvement of the requesting public authority or body within a reasonable time following the request.

4. Any information or documentation obtained by the national public authorities or bodies referred to in paragraph 1 of this Article pursuant to this Article shall be treated in accordance with the confidentiality obligations set out in Article 78.

Article 78

Confidentiality

1. The Commission, market surveillance authorities and notified bodies and any other natural or legal person involved in the application of this Regulation shall, in accordance with Union or national law, respect the confidentiality of information and data obtained in carrying out their tasks and activities in such a manner as to protect, in particular:

(a) the intellectual property rights and confidential business information or trade secrets of a natural or legal person, including source code, except in the cases referred to in Article 5 of Directive (EU) 2016/943 of the European Parliament and of the Council ([1]);

(b) the effective implementation of this Regulation, in particular for the purposes of inspections, investigations or audits;

(c) public and national security interests;

(d) the conduct of criminal or administrative proceedings;

(e) information classified pursuant to Union or national law.

2. The authorities involved in the application of this Regulation pursuant to paragraph 1 shall request only data that is strictly necessary for the assessment of the risk posed by AI systems and for the exercise of their powers in accordance with this Regulation and with Regulation (EU) 2019/1020. They shall put in place adequate and effective cybersecurity measures to protect the security and confidentiality of the information and data obtained, and shall delete the data collected as soon as it is no longer needed for the purpose for which it was obtained, in accordance with applicable Union or national law.

([1]) Directive (EU) 2016/943 of the European Parliament and of the Council of 8 June 2016 on the protection of undisclosed know-how and business information (trade secrets) against their unlawful acquisition, use and disclosure (OJ L 157, 15.6.2016, p. 1).

▼B

3. Without prejudice to paragraphs 1 and 2, information exchanged on a confidential basis between the national competent authorities or between national competent authorities and the Commission shall not be disclosed without prior consultation of the originating national competent authority and the deployer when high-risk AI systems referred to in point 1, 6 or 7 of Annex III are used by law enforcement, border control, immigration or asylum authorities and when such disclosure would jeopardise public and national security interests. This exchange of information shall not cover sensitive operational data in relation to the activities of law enforcement, border control, immigration or asylum authorities.

When the law enforcement, immigration or asylum authorities are providers of high-risk AI systems referred to in point 1, 6 or 7 of Annex III, the technical documentation referred to in Annex IV shall remain within the premises of those authorities. Those authorities shall ensure that the market surveillance authorities referred to in Article 74(8) and (9), as applicable, can, upon request, immediately access the documentation or obtain a copy thereof. Only staff of the market surveillance authority holding the appropriate level of security clearance shall be allowed to access that documentation or any copy thereof.

4. Paragraphs 1, 2 and 3 shall not affect the rights or obligations of the Commission, Member States and their relevant authorities, as well as those of notified bodies, with regard to the exchange of information and the dissemination of warnings, including in the context of cross-border cooperation, nor shall they affect the obligations of the parties concerned to provide information under criminal law of the Member States.

5. The Commission and Member States may exchange, where necessary and in accordance with relevant provisions of international and trade agreements, confidential information with regulatory authorities of third countries with which they have concluded bilateral or multilateral confidentiality arrangements guaranteeing an adequate level of confidentiality.

Article 79

Procedure at national level for dealing with AI systems presenting a risk

1. AI systems presenting a risk shall be understood as a ‘product presenting a risk’ as defined in Article 3, point 19 of Regulation (EU) 2019/1020, in so far as they present risks to the health or safety, or to fundamental rights, of persons.

2. Where the market surveillance authority of a Member State has sufficient reason to consider an AI system to present a risk as referred to in paragraph 1 of this Article, it shall carry out an evaluation of the AI system concerned in respect of its compliance with all the requirements and obligations laid down in this Regulation. Particular attention shall be given to AI systems presenting a risk to vulnerable groups. Where risks to fundamental rights are identified, the market surveillance authority shall also inform and fully cooperate with the relevant national public authorities or bodies referred to in Article 77(1). The relevant operators shall cooperate as necessary with the market surveillance authority and with the other national public authorities or bodies referred to in Article 77(1).

▼B

Where, in the course of that evaluation, the market surveillance authority or, where applicable the market surveillance authority in co-operation with the national public authority referred to in Article 77(1), finds that the AI system does not comply with the requirements and obligations laid down in this Regulation, it shall without undue delay require the relevant operator to take all appropriate corrective actions to bring the AI system into compliance, to withdraw the AI system from the market, or to recall it within a period the market surveillance authority may prescribe, and in any event within the shorter of 15 working days, or as provided for in the relevant Union harmonisation legislation.

The market surveillance authority shall inform the relevant notified body accordingly. Article 18 of Regulation (EU) 2019/1020 shall apply to the measures referred to in the second subparagraph of this paragraph.

3. Where the market surveillance authority considers that the non-compliance is not restricted to its national territory, it shall inform the Commission and the other Member States without undue delay of the results of the evaluation and of the actions which it has required the operator to take.

4. The operator shall ensure that all appropriate corrective action is taken in respect of all the AI systems concerned that it has made available on the Union market.

5. Where the operator of an AI system does not take adequate corrective action within the period referred to in paragraph 2, the market surveillance authority shall take all appropriate provisional measures to prohibit or restrict the AI system's being made available on its national market or put into service, to withdraw the product or the standalone AI system from that market or to recall it. That authority shall without undue delay notify the Commission and the other Member States of those measures.

6. The notification referred to in paragraph 5 shall include all available details, in particular the information necessary for the identification of the non-compliant AI system, the origin of the AI system and the supply chain, the nature of the non-compliance alleged and the risk involved, the nature and duration of the national measures taken and the arguments put forward by the relevant operator. In particular, the market surveillance authorities shall indicate whether the non-compliance is due to one or more of the following:

(a) non-compliance with the prohibition of the AI practices referred to in Article 5;

(b) a failure of a high-risk AI system to meet requirements set out in Chapter III, Section 2;

(c) shortcomings in the harmonised standards or common specifications referred to in Articles 40 and 41 conferring a presumption of conformity;

(d) non-compliance with Article 50.

▼B

7. The market surveillance authorities other than the market surveillance authority of the Member State initiating the procedure shall, without undue delay, inform the Commission and the other Member States of any measures adopted and of any additional information at their disposal relating to the non-compliance of the AI system concerned, and, in the event of disagreement with the notified national measure, of their objections.

8. Where, within three months of receipt of the notification referred to in paragraph 5 of this Article, no objection has been raised by either a market surveillance authority of a Member State or by the Commission in respect of a provisional measure taken by a market surveillance authority of another Member State, that measure shall be deemed justified. This shall be without prejudice to the procedural rights of the concerned operator in accordance with Article 18 of Regulation (EU) 2019/1020. The three-month period referred to in this paragraph shall be reduced to 30 days in the event of non-compliance with the prohibition of the AI practices referred to in Article 5 of this Regulation.

9. The market surveillance authorities shall ensure that appropriate restrictive measures are taken in respect of the product or the AI system concerned, such as withdrawal of the product or the AI system from their market, without undue delay.

Article 80

Procedure for dealing with AI systems classified by the provider as non-high-risk in application of Annex III

1. Where a market surveillance authority has sufficient reason to consider that an AI system classified by the provider as non-high-risk pursuant to Article 6(3) is indeed high-risk, the market surveillance authority shall carry out an evaluation of the AI system concerned in respect of its classification as a high-risk AI system based on the conditions set out in Article 6(3) and the Commission guidelines.

2. Where, in the course of that evaluation, the market surveillance authority finds that the AI system concerned is high-risk, it shall without undue delay require the relevant provider to take all necessary actions to bring the AI system into compliance with the requirements and obligations laid down in this Regulation, as well as take appropriate corrective action within a period the market surveillance authority may prescribe.

3. Where the market surveillance authority considers that the use of the AI system concerned is not restricted to its national territory, it shall inform the Commission and the other Member States without undue delay of the results of the evaluation and of the actions which it has required the provider to take.

4. The provider shall ensure that all necessary action is taken to bring the AI system into compliance with the requirements and obligations laid down in this Regulation. Where the provider of an AI system concerned does not bring the AI system into compliance with those requirements and obligations within the period referred to in paragraph 2 of this Article, the provider shall be subject to fines in accordance with Article 99.

▼B

5. The provider shall ensure that all appropriate corrective action is taken in respect of all the AI systems concerned that it has made available on the Union market.

6. Where the provider of the AI system concerned does not take adequate corrective action within the period referred to in paragraph 2 of this Article, Article 79(5) to (9) shall apply.

7. Where, in the course of the evaluation pursuant to paragraph 1 of this Article, the market surveillance authority establishes that the AI system was misclassified by the provider as non-high-risk in order to circumvent the application of requirements in Chapter III, Section 2, the provider shall be subject to fines in accordance with Article 99.

8. In exercising their power to monitor the application of this Article, and in accordance with Article 11 of Regulation (EU) 2019/1020, market surveillance authorities may perform appropriate checks, taking into account in particular information stored in the EU database referred to in Article 71 of this Regulation.

Article 81

Union safeguard procedure

1. Where, within three months of receipt of the notification referred to in Article 79(5), or within 30 days in the case of non-compliance with the prohibition of the AI practices referred to in Article 5, objections are raised by the market surveillance authority of a Member State to a measure taken by another market surveillance authority, or where the Commission considers the measure to be contrary to Union law, the Commission shall without undue delay enter into consultation with the market surveillance authority of the relevant Member State and the operator or operators, and shall evaluate the national measure. On the basis of the results of that evaluation, the Commission shall, within six months, or within 60 days in the case of non-compliance with the prohibition of the AI practices referred to in Article 5, starting from the notification referred to in Article 79(5), decide whether the national measure is justified and shall notify its decision to the market surveillance authority of the Member State concerned. The Commission shall also inform all other market surveillance authorities of its decision.

2. Where the Commission considers the measure taken by the relevant Member State to be justified, all Member States shall ensure that they take appropriate restrictive measures in respect of the AI system concerned, such as requiring the withdrawal of the AI system from their market without undue delay, and shall inform the Commission accordingly. Where the Commission considers the national measure to be unjustified, the Member State concerned shall withdraw the measure and shall inform the Commission accordingly.

3. Where the national measure is considered justified and the non-compliance of the AI system is attributed to shortcomings in the harmonised standards or common specifications referred to in Articles 40 and 41 of this Regulation, the Commission shall apply the procedure provided for in Article 11 of Regulation (EU) No 1025/2012.

▼B

Article 82

Compliant AI systems which present a risk

1. Where, having performed an evaluation under Article 79, after consulting the relevant national public authority referred to in Article 77(1), the market surveillance authority of a Member State finds that although a high-risk AI system complies with this Regulation, it nevertheless presents a risk to the health or safety of persons, to fundamental rights, or to other aspects of public interest protection, it shall require the relevant operator to take all appropriate measures to ensure that the AI system concerned, when placed on the market or put into service, no longer presents that risk without undue delay, within a period it may prescribe.

2. The provider or other relevant operator shall ensure that corrective action is taken in respect of all the AI systems concerned that it has made available on the Union market within the timeline prescribed by the market surveillance authority of the Member State referred to in paragraph 1.

3. The Member States shall immediately inform the Commission and the other Member States of a finding under paragraph 1. That information shall include all available details, in particular the data necessary for the identification of the AI system concerned, the origin and the supply chain of the AI system, the nature of the risk involved and the nature and duration of the national measures taken.

4. The Commission shall without undue delay enter into consultation with the Member States concerned and the relevant operators, and shall evaluate the national measures taken. On the basis of the results of that evaluation, the Commission shall decide whether the measure is justified and, where necessary, propose other appropriate measures.

5. The Commission shall immediately communicate its decision to the Member States concerned and to the relevant operators. It shall also inform the other Member States.

Article 83

Formal non-compliance

1. Where the market surveillance authority of a Member State makes one of the following findings, it shall require the relevant provider to put an end to the non-compliance concerned, within a period it may prescribe:

(a) the CE marking has been affixed in violation of Article 48;

(b) the CE marking has not been affixed;

(c) the EU declaration of conformity referred to in Article 47 has not been drawn up;

(d) the EU declaration of conformity referred to in Article 47 has not been drawn up correctly;

(e) the registration in the EU database referred to in Article 71 has not been carried out;

(f) where applicable, no authorised representative has been appointed;

(g) technical documentation is not available.

▼B

2. Where the non-compliance referred to in paragraph 1 persists, the market surveillance authority of the Member State concerned shall take appropriate and proportionate measures to restrict or prohibit the high-risk AI system being made available on the market or to ensure that it is recalled or withdrawn from the market without delay.

Article 84

Union AI testing support structures

1. The Commission shall designate one or more Union AI testing support structures to perform the tasks listed under Article 21(6) of Regulation (EU) 2019/1020 in the area of AI.

2. Without prejudice to the tasks referred to in paragraph 1, Union AI testing support structures shall also provide independent technical or scientific advice at the request of the Board, the Commission, or of market surveillance authorities.

SECTION 4

Remedies

Article 85

Right to lodge a complaint with a market surveillance authority

Without prejudice to other administrative or judicial remedies, any natural or legal person having grounds to consider that there has been an infringement of the provisions of this Regulation may submit complaints to the relevant market surveillance authority.

In accordance with Regulation (EU) 2019/1020, such complaints shall be taken into account for the purpose of conducting market surveillance activities, and shall be handled in line with the dedicated procedures established therefor by the market surveillance authorities.

Article 86

Right to explanation of individual decision-making

1. Any affected person subject to a decision which is taken by the deployer on the basis of the output from a high-risk AI system listed in Annex III, with the exception of systems listed under point 2 thereof, and which produces legal effects or similarly significantly affects that person in a way that they consider to have an adverse impact on their health, safety or fundamental rights shall have the right to obtain from the deployer clear and meaningful explanations of the role of the AI system in the decision-making procedure and the main elements of the decision taken.

2. Paragraph 1 shall not apply to the use of AI systems for which exceptions from, or restrictions to, the obligation under that paragraph follow from Union or national law in compliance with Union law.

3. This Article shall apply only to the extent that the right referred to in paragraph 1 is not otherwise provided for under Union law.

▼B

Article 87

Reporting of infringements and protection of reporting persons

Directive (EU) 2019/1937 shall apply to the reporting of infringements of this Regulation and the protection of persons reporting such infringements.

SECTION 5

Supervision, investigation, enforcement and monitoring in respect of providers of general-purpose AI models

Article 88

Enforcement of the obligations of providers of general-purpose AI models

1. The Commission shall have exclusive powers to supervise and enforce Chapter V, taking into account the procedural guarantees under Article 94. The Commission shall entrust the implementation of these tasks to the AI Office, without prejudice to the powers of organisation of the Commission and the division of competences between Member States and the Union based on the Treaties.

2. Without prejudice to Article 75(3), market surveillance authorities may request the Commission to exercise the powers laid down in this Section, where that is necessary and proportionate to assist with the fulfilment of their tasks under this Regulation.

Article 89

Monitoring actions

1. For the purpose of carrying out the tasks assigned to it under this Section, the AI Office may take the necessary actions to monitor the effective implementation and compliance with this Regulation by providers of general-purpose AI models, including their adherence to approved codes of practice.

2. Downstream providers shall have the right to lodge a complaint alleging an infringement of this Regulation. A complaint shall be duly reasoned and indicate at least:

(a) the point of contact of the provider of the general-purpose AI model concerned;

(b) a description of the relevant facts, the provisions of this Regulation concerned, and the reason why the downstream provider considers that the provider of the general-purpose AI model concerned infringed this Regulation;

(c) any other information that the downstream provider that sent the request considers relevant, including, where appropriate, information gathered on its own initiative.

▼B

Article 90

Alerts of systemic risks by the scientific panel

1. The scientific panel may provide a qualified alert to the AI Office where it has reason to suspect that:

(a) a general-purpose AI model poses concrete identifiable risk at Union level; or

(b) a general-purpose AI model meets the conditions referred to in Article 51.

2. Upon such qualified alert, the Commission, through the AI Office and after having informed the Board, may exercise the powers laid down in this Section for the purpose of assessing the matter. The AI Office shall inform the Board of any measure according to Articles 91 to 94.

3. A qualified alert shall be duly reasoned and indicate at least:

(a) the point of contact of the provider of the general-purpose AI model with systemic risk concerned;

(b) a description of the relevant facts and the reasons for the alert by the scientific panel;

(c) any other information that the scientific panel considers to be relevant, including, where appropriate, information gathered on its own initiative.

Article 91

Power to request documentation and information

1. The Commission may request the provider of the general-purpose AI model concerned to provide the documentation drawn up by the provider in accordance with Articles 53 and 55, or any additional information that is necessary for the purpose of assessing compliance of the provider with this Regulation.

2. Before sending the request for information, the AI Office may initiate a structured dialogue with the provider of the general-purpose AI model.

3. Upon a duly substantiated request from the scientific panel, the Commission may issue a request for information to a provider of a general-purpose AI model, where the access to information is necessary and proportionate for the fulfilment of the tasks of the scientific panel under Article 68(2).

4. The request for information shall state the legal basis and the purpose of the request, specify what information is required, set a period within which the information is to be provided, and indicate the fines provided for in Article 101 for supplying incorrect, incomplete or misleading information.

▼B

5. The provider of the general-purpose AI model concerned, or its representative shall supply the information requested. In the case of legal persons, companies or firms, or where the provider has no legal personality, the persons authorised to represent them by law or by their statutes, shall supply the information requested on behalf of the provider of the general-purpose AI model concerned. Lawyers duly authorised to act may supply information on behalf of their clients. The clients shall nevertheless remain fully responsible if the information supplied is incomplete, incorrect or misleading.

Article 92

Power to conduct evaluations

1. The AI Office, after consulting the Board, may conduct evaluations of the general-purpose AI model concerned:

(a) to assess compliance of the provider with obligations under this Regulation, where the information gathered pursuant to Article 91 is insufficient; or

(b) to investigate systemic risks at Union level of general-purpose AI models with systemic risk, in particular following a qualified alert from the scientific panel in accordance with Article 90(1), point (a).

2. The Commission may decide to appoint independent experts to carry out evaluations on its behalf, including from the scientific panel established pursuant to Article 68. Independent experts appointed for this task shall meet the criteria outlined in Article 68(2).

3. For the purposes of paragraph 1, the Commission may request access to the general-purpose AI model concerned through APIs or further appropriate technical means and tools, including source code.

4. The request for access shall state the legal basis, the purpose and reasons of the request and set the period within which the access is to be provided, and the fines provided for in Article 101 for failure to provide access.

5. The providers of the general-purpose AI model concerned or its representative shall supply the information requested. In the case of legal persons, companies or firms, or where the provider has no legal personality, the persons authorised to represent them by law or by their statutes, shall provide the access requested on behalf of the provider of the general-purpose AI model concerned.

6. The Commission shall adopt implementing acts setting out the detailed arrangements and the conditions for the evaluations, including the detailed arrangements for involving independent experts, and the procedure for the selection thereof. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 98(2).

▼B

7. Prior to requesting access to the general-purpose AI model concerned, the AI Office may initiate a structured dialogue with the provider of the general-purpose AI model to gather more information on the internal testing of the model, internal safeguards for preventing systemic risks, and other internal procedures and measures the provider has taken to mitigate such risks.

Article 93

Power to request measures

1. Where necessary and appropriate, the Commission may request providers to:

(a) take appropriate measures to comply with the obligations set out in Articles 53 and 54;

(b) implement mitigation measures, where the evaluation carried out in accordance with Article 92 has given rise to serious and substantiated concern of a systemic risk at Union level;

(c) restrict the making available on the market, withdraw or recall the model.

2. Before a measure is requested, the AI Office may initiate a structured dialogue with the provider of the general-purpose AI model.

3. If, during the structured dialogue referred to in paragraph 2, the provider of the general-purpose AI model with systemic risk offers commitments to implement mitigation measures to address a systemic risk at Union level, the Commission may, by decision, make those commitments binding and declare that there are no further grounds for action.

Article 94

Procedural rights of economic operators of the general-purpose AI model

Article 18 of Regulation (EU) 2019/1020 shall apply *mutatis mutandis* to the providers of the general-purpose AI model, without prejudice to more specific procedural rights provided for in this Regulation.

CHAPTER X

CODES OF CONDUCT AND GUIDELINES

Article 95

Codes of conduct for voluntary application of specific requirements

1. The AI Office and the Member States shall encourage and facilitate the drawing up of codes of conduct, including related governance mechanisms, intended to foster the voluntary application to AI systems, other than high-risk AI systems, of some or all of the requirements set out in Chapter III, Section 2 taking into account the available technical solutions and industry best practices allowing for the application of such requirements.

▼B

2. The AI Office and the Member States shall facilitate the drawing up of codes of conduct concerning the voluntary application, including by deployers, of specific requirements to all AI systems, on the basis of clear objectives and key performance indicators to measure the achievement of those objectives, including elements such as, but not limited to:

(a) applicable elements provided for in Union ethical guidelines for trustworthy AI;

(b) assessing and minimising the impact of AI systems on environmental sustainability, including as regards energy-efficient programming and techniques for the efficient design, training and use of AI;

(c) promoting AI literacy, in particular that of persons dealing with the development, operation and use of AI;

(d) facilitating an inclusive and diverse design of AI systems, including through the establishment of inclusive and diverse development teams and the promotion of stakeholders' participation in that process;

(e) assessing and preventing the negative impact of AI systems on vulnerable persons or groups of vulnerable persons, including as regards accessibility for persons with a disability, as well as on gender equality.

3. Codes of conduct may be drawn up by individual providers or deployers of AI systems or by organisations representing them or by both, including with the involvement of any interested stakeholders and their representative organisations, including civil society organisations and academia. Codes of conduct may cover one or more AI systems taking into account the similarity of the intended purpose of the relevant systems.

▼M1

4. The AI Office and the Member States shall take into account the specific interests and needs of SMEs, including start-ups, and SMCs, when encouraging and facilitating the drawing up of codes of conduct.

▼B

Article 96

Guidelines from the Commission on the implementation of this Regulation

1. The Commission shall develop guidelines on the practical implementation of this Regulation, and in particular on:

▼M1

(a) the application of the requirements and obligations referred to in Articles 8 to 15 and in Articles 25 and 26;

▼B

(b) the prohibited practices referred to in Article 5;

(c) the practical implementation of the provisions related to substantial modification;

▼B

(d) the practical implementation of transparency obligations laid down in Article 50;

(e) detailed information on the relationship of this Regulation with the Union harmonisation legislation listed in Annex I, as well as with other relevant Union law, including as regards consistency in their enforcement;

(f) the application of the definition of an AI system as set out in Article 3, point (1);

▼M1

(g) the practical implementation of Article 8(2), Article 9(10) and Article 17(3) in accordance with the principle of complementarity and proportionality, with a view to ensuring consistency, avoiding duplication and minimising additional burdens when complying with the requirements of this Regulation and the requirements of the Union harmonisation legislation listed in Section A of Annex I; such guidelines shall be published by 1 August 2027.

When issuing such guidelines, the Commission shall involve the Board and pay particular attention to the needs of SMEs, including start-ups, and SMCs, of local public authorities and of the sectors most likely to be affected by this Regulation.

▼B

The guidelines referred to in the first subparagraph of this paragraph shall take due account of the generally acknowledged state of the art on AI, as well as of relevant harmonised standards and common specifications that are referred to in Articles 40 and 41, or of those harmonised standards or technical specifications that are set out pursuant to Union harmonisation law.

2. At the request of the Member States or the AI Office, or on its own initiative, the Commission shall update guidelines previously adopted when deemed necessary.

CHAPTER XI

DELEGATION OF POWER AND COMMITTEE PROCEDURE

Article 97

Exercise of the delegation

1. The power to adopt delegated acts is conferred on the Commission subject to the conditions laid down in this Article.

▼M1

2. The power to adopt delegated acts referred to in Article 6(6) and (7), Article 7(1) and (3), Article 11(3), Article 43(5) and (6), Article 47(5), Article 51(3), Article 52(4) and Article 53(5) and (6) shall be conferred on the Commission for a period of five years from 1 August 2024. The power to adopt delegated acts referred to in Article 2(13) and Article 30(2) shall be conferred on the Commission for a period of five years from 27 July 2026. The Commission shall draw up a report in respect of the delegation of power not later than nine months before the end of the five-year period. The delegation of power shall be tacitly extended for periods of an identical duration, unless the European Parliament or the Council opposes such extension no later than three months before the end of each period.

▼M1

3. The delegation of power referred to in Article 2(13), Article 6(6) and (7), Article 7(1) and (3), Article 11(3), Article 30(2), Article 43(5) and (6), Article 47(5), Article 51(3), Article 52(4) and Article 53(5) and (6) may be revoked at any time by the European Parliament or by the Council. A decision of revocation shall put an end to the delegation of power specified in that decision. It shall take effect the day following that of its publication in the *Official Journal of the European Union* or at a later date specified therein. It shall not affect the validity of any delegated acts already in force.

▼B

4. Before adopting a delegated act, the Commission shall consult experts designated by each Member State in accordance with the principles laid down in the Interinstitutional Agreement of 13 April 2016 on Better Law-Making.

5. As soon as it adopts a delegated act, the Commission shall notify it simultaneously to the European Parliament and to the Council.

▼M1

6. Any delegated act adopted pursuant to Article 2(13), Article 6(6) or (7), Article 7(1) or (3), Article 11(3), Article 30(2), Article 43(5) or (6), Article 47(5), Article 51(3), Article 52(4) or Article 53(5) or (6) shall enter into force only if no objection has been expressed by either the European Parliament or the Council within a period of three months of notification of that act to the European Parliament and the Council or if, before the expiry of that period, the European Parliament and the Council have both informed the Commission that they will not object. That period shall be extended by three months at the initiative of the European Parliament or of the Council.

▼B

Article 98

Committee procedure

1. The Commission shall be assisted by a committee. That committee shall be a committee within the meaning of Regulation (EU) No 182/2011.

2. Where reference is made to this paragraph, Article 5 of Regulation (EU) No 182/2011 shall apply.

CHAPTER XII

PENALTIES

Article 99

Penalties

▼M1

1. In accordance with the terms and conditions laid down in this Regulation, Member States shall lay down the rules on penalties and other enforcement measures, which may also include administrative fines, warnings and non-monetary measures, applicable to any infringement of this Regulation by operators, and shall take all measures necessary to ensure that they are properly and effectively implemented, thereby taking into account the guidelines issued by the Commission pursuant to Article 96. The penalties provided for shall be effective, proportionate and dissuasive. The Member States shall take into account the interests of SMEs, including start-ups, and SMCs, and their economic viability when imposing penalties.

▼B

2. The Member States shall, without delay and at the latest by the date of entry into application, notify the Commission of the rules on penalties and of other enforcement measures referred to in paragraph 1, and shall notify it, without delay, of any subsequent amendment to them.

3. Non-compliance with the prohibition of the AI practices referred to in Article 5 shall be subject to administrative fines of up to EUR 35 000 000 or, if the offender is an undertaking, up to 7 % of its total worldwide annual turnover for the preceding financial year, whichever is higher.

4. Non-compliance with any of the following provisions related to operators or notified bodies, other than those laid down in Articles 5, shall be subject to administrative fines of up to EUR 15 000 000 or, if the offender is an undertaking, up to 3 % of its total worldwide annual turnover for the preceding financial year, whichever is higher:

(a) obligations of providers pursuant to Article 16;

(b) obligations of authorised representatives pursuant to Article 22;

(c) obligations of importers pursuant to Article 23;

(d) obligations of distributors pursuant to Article 24;

▼M1

(da) obligations of providers and operators pursuant to Article 25(2) and (4);

▼B

(e) obligations of deployers pursuant to Article 26;

(f) requirements and obligations of notified bodies pursuant to Article 31, Article 33(1), (3) and (4) or Article 34;

(g) transparency obligations for providers and deployers pursuant to Article 50.

5. The supply of incorrect, incomplete or misleading information to notified bodies or national competent authorities in reply to a request shall be subject to administrative fines of up to EUR 7 500 000 or, if the offender is an undertaking, up to 1 % of its total worldwide annual turnover for the preceding financial year, whichever is higher.

6. In the case of SMEs, including start-ups, each fine referred to in this Article shall be up to the percentages or amount referred to in paragraphs 3, 4 and 5, whichever thereof is lower.

▼M1

6a. In the case of SMCs, each fine referred to in paragraphs 4 and 5 shall be up to the percentages or amount referred therein, whichever is lower.

▼B

7. When deciding whether to impose an administrative fine and when deciding on the amount of the administrative fine in each individual case, all relevant circumstances of the specific situation shall be taken into account and, as appropriate, regard shall be given to the following:

(a) the nature, gravity and duration of the infringement and of its consequences, taking into account the purpose of the AI system, as well as, where appropriate, the number of affected persons and the level of damage suffered by them;

(b) whether administrative fines have already been applied by other market surveillance authorities to the same operator for the same infringement;

(c) whether administrative fines have already been applied by other authorities to the same operator for infringements of other Union or national law, when such infringements result from the same activity or omission constituting a relevant infringement of this Regulation;

(d) the size, the annual turnover and market share of the operator committing the infringement;

(e) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits gained, or losses avoided, directly or indirectly, from the infringement;

(f) the degree of cooperation with the national competent authorities, in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

(g) the degree of responsibility of the operator taking into account the technical and organisational measures implemented by it;

(h) the manner in which the infringement became known to the national competent authorities, in particular whether, and if so to what extent, the operator notified the infringement;

(i) the intentional or negligent character of the infringement;

(j) any action taken by the operator to mitigate the harm suffered by the affected persons.

8. Each Member State shall lay down rules on to what extent administrative fines may be imposed on public authorities and bodies established in that Member State.

9. Depending on the legal system of the Member States, the rules on administrative fines may be applied in such a manner that the fines are imposed by competent national courts or by other bodies, as applicable in those Member States. The application of such rules in those Member States shall have an equivalent effect.

▼B

10. The exercise of powers under this Article shall be subject to appropriate procedural safeguards in accordance with Union and national law, including effective judicial remedies and due process.

11. Member States shall, on an annual basis, report to the Commission about the administrative fines they have issued during that year, in accordance with this Article, and about any related litigation or judicial proceedings.

Article 100

Administrative fines on Union institutions, bodies, offices and agencies

1. The European Data Protection Supervisor may impose administrative fines on Union institutions, bodies, offices and agencies falling within the scope of this Regulation. When deciding whether to impose an administrative fine and when deciding on the amount of the administrative fine in each individual case, all relevant circumstances of the specific situation shall be taken into account and due regard shall be given to the following:

(a) the nature, gravity and duration of the infringement and of its consequences, taking into account the purpose of the AI system concerned, as well as, where appropriate, the number of affected persons and the level of damage suffered by them;

(b) the degree of responsibility of the Union institution, body, office or agency, taking into account technical and organisational measures implemented by them;

(c) any action taken by the Union institution, body, office or agency to mitigate the damage suffered by affected persons;

(d) the degree of cooperation with the European Data Protection Supervisor in order to remedy the infringement and mitigate the possible adverse effects of the infringement, including compliance with any of the measures previously ordered by the European Data Protection Supervisor against the Union institution, body, office or agency concerned with regard to the same subject matter;

(e) any similar previous infringements by the Union institution, body, office or agency;

(f) the manner in which the infringement became known to the European Data Protection Supervisor, in particular whether, and if so to what extent, the Union institution, body, office or agency notified the infringement;

(g) the annual budget of the Union institution, body, office or agency.

2. Non-compliance with the prohibition of the AI practices referred to in Article 5 shall be subject to administrative fines of up to EUR 1 500 000.

▼B

3. The non-compliance of the AI system with any requirements or obligations under this Regulation, other than those laid down in Article 5, shall be subject to administrative fines of up to EUR 750 000.

4. Before taking decisions pursuant to this Article, the European Data Protection Supervisor shall give the Union institution, body, office or agency which is the subject of the proceedings conducted by the European Data Protection Supervisor the opportunity of being heard on the matter regarding the possible infringement. The European Data Protection Supervisor shall base his or her decisions only on elements and circumstances on which the parties concerned have been able to comment. Complainants, if any, shall be associated closely with the proceedings.

5. The rights of defence of the parties concerned shall be fully respected in the proceedings. They shall be entitled to have access to the European Data Protection Supervisor's file, subject to the legitimate interest of individuals or undertakings in the protection of their personal data or business secrets.

6. Funds collected by imposition of fines in this Article shall contribute to the general budget of the Union. The fines shall not affect the effective operation of the Union institution, body, office or agency fined.

7. The European Data Protection Supervisor shall, on an annual basis, notify the Commission of the administrative fines it has imposed pursuant to this Article and of any litigation or judicial proceedings it has initiated.

Article 101

Fines for providers of general-purpose AI models

1. The Commission may impose on providers of general-purpose AI models fines not exceeding 3 % of their annual total worldwide turnover in the preceding financial year or EUR 15 000 000, whichever is higher., when the Commission finds that the provider intentionally or negligently:

(a) infringed the relevant provisions of this Regulation;

(b) failed to comply with a request for a document or for information pursuant to Article 91, or supplied incorrect, incomplete or misleading information;

(c) failed to comply with a measure requested under Article 93;

(d) failed to make available to the Commission access to the general-purpose AI model or general-purpose AI model with systemic risk with a view to conducting an evaluation pursuant to Article 92.

▼B

In fixing the amount of the fine or periodic penalty payment, regard shall be had to the nature, gravity and duration of the infringement, taking due account of the principles of proportionality and appropriateness. The Commission shall also into account commitments made in accordance with Article 93(3) or made in relevant codes of practice in accordance with Article 56.

2. Before adopting the decision pursuant to paragraph 1, the Commission shall communicate its preliminary findings to the provider of the general-purpose AI model and give it an opportunity to be heard.

3. Fines imposed in accordance with this Article shall be effective, proportionate and dissuasive.

4. Information on fines imposed under this Article shall also be communicated to the Board as appropriate.

5. The Court of Justice of the European Union shall have unlimited jurisdiction to review decisions of the Commission fixing a fine under this Article. It may cancel, reduce or increase the fine imposed.

6. The Commission shall adopt implementing acts containing detailed arrangements and procedural safeguards for proceedings in view of the possible adoption of decisions pursuant to paragraph 1 of this Article. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 98(2).

CHAPTER XIII

FINAL PROVISIONS

Article 102

Amendment to Regulation (EC) No 300/2008

In Article 4(3) of Regulation (EC) No 300/2008, the following subparagraph is added:

‘When adopting detailed measures related to technical specifications and procedures for approval and use of security equipment concerning Artificial Intelligence systems within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’.

Article 103

Amendment to Regulation (EU) No 167/2013

In Article 17(5) of Regulation (EU) No 167/2013, the following subparagraph is added:

▼B

‘When adopting delegated acts pursuant to the first subparagraph concerning artificial intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’.

Article 104

Amendment to Regulation (EU) No 168/2013

In Article 22(5) of Regulation (EU) No 168/2013, the following subparagraph is added:

‘When adopting delegated acts pursuant to the first subparagraph concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’.

Article 105

Amendment to Directive 2014/90/EU

In Article 8 of Directive 2014/90/EU, the following paragraph is added:

‘5. For Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), when carrying out its activities pursuant to paragraph 1 and when adopting technical specifications and testing standards in accordance with paragraphs 2 and 3, the Commission shall take into account the requirements set out in Chapter III, Section 2, of that Regulation.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’.

▼B

Article 106

Amendment to Directive (EU) 2016/797

In Article 5 of Directive (EU) 2016/797, the following paragraph is added:

‘12. When adopting delegated acts pursuant to paragraph 1 and implementing acts pursuant to paragraph 11 concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’.

Article 107

Amendment to Regulation (EU) 2018/858

In Article 5 of Regulation (EU) 2018/858 the following paragraph is added:

‘4. When adopting delegated acts pursuant to paragraph 3 concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’.

Article 108

Amendments to Regulation (EU) 2018/1139

Regulation (EU) 2018/1139 is amended as follows:

(1) in Article 17, the following paragraph is added:

‘3. Without prejudice to paragraph 2, when adopting implementing acts pursuant to paragraph 1 concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’;

▼B

(2) in Article 19, the following paragraph is added:

‘4. When adopting delegated acts pursuant to paragraphs 1 and 2 concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’;

(3) in Article 43, the following paragraph is added:

‘4. When adopting implementing acts pursuant to paragraph 1 concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’;

(4) in Article 47, the following paragraph is added:

‘3. When adopting delegated acts pursuant to paragraphs 1 and 2 concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’;

(5) in Article 57, the following subparagraph is added:

‘When adopting those implementing acts concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’;

(6) in Article 58, the following paragraph is added:

‘3. When adopting delegated acts pursuant to paragraphs 1 and 2 concerning Artificial Intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’.

Article 109

Amendment to Regulation (EU) 2019/2144

In Article 11 of Regulation (EU) 2019/2144, the following paragraph is added:

‘3. When adopting the implementing acts pursuant to paragraph 2, concerning artificial intelligence systems which are safety components within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’.

▼B

Article 110

Amendment to Directive (EU) 2020/1828

In Annex I to Directive (EU) 2020/1828 of the European Parliament and of the Council ([2]), the following point is added:

‘(68) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).’.

Article 111

AI systems already placed on the market or put into service and general-purpose AI models already placed on the marked

1. Without prejudice to the application of Article 5 as referred to in Article 113(3), point (a), AI systems which are components of the large-scale IT systems established by the legal acts listed in Annex X that have been placed on the market or put into service before 2 August 2027 shall be brought into compliance with this Regulation by 31 December 2030.

The requirements laid down in this Regulation shall be taken into account in the evaluation of each large-scale IT system established by the legal acts listed in Annex X to be undertaken as provided for in those legal acts and where those legal acts are replaced or amended.

▼M1

2. Without prejudice to the application of Article 5 as referred to in Article 113, third paragraph, point (a), this Regulation shall apply to operators of high-risk AI systems, other than the systems referred to in paragraph 1 of this Article, that have been placed on the market or put into service before the date of application of Chapter III referred to in Article 113, only if, as from that date, those systems are subject to significant changes in their designs. In any case, the providers and deployers of high-risk AI systems intended to be used by public authorities shall take the necessary steps to comply with the requirements and obligations laid down in this Regulation by 2 August 2030.

▼B

3. Providers of general-purpose AI models that have been placed on the market before 2 August 2025 shall take the necessary steps in order to comply with the obligations laid down in this Regulation by 2 August 2027.

▼M1

4. Providers of AI systems, including general-purpose AI systems, generating synthetic audio, image, video or text content, that have been placed on the market before 2 August 2026 shall take the necessary steps in order to comply with Article 50(2) by 2 December 2026.

([2]) Directive (EU) 2020/1828 of the European Parliament and of the Council of 25 November 2020 on representative actions for the protection of the collective interests of consumers and repealing Directive 2009/22/EC (OJ L 409, 4.12.2020, p. 1).

▼B

Article 112

Evaluation and review

1. The Commission shall assess the need for amendment of the list set out in Annex III and of the list of prohibited AI practices laid down in Article 5, once a year following the entry into force of this Regulation, and until the end of the period of the delegation of power laid down in Article 97. The Commission shall submit the findings of that assessment to the European Parliament and the Council.

2. By 2 August 2028 and every four years thereafter, the Commission shall evaluate and report to the European Parliament and to the Council on the following:

(a) the need for amendments extending existing area headings or adding new area headings in Annex III;

(b) amendments to the list of AI systems requiring additional transparency measures in Article 50;

(c) amendments enhancing the effectiveness of the supervision and governance system.

3. By 2 August 2029 and every four years thereafter, the Commission shall submit a report on the evaluation and review of this Regulation to the European Parliament and to the Council. The report shall include an assessment with regard to the structure of enforcement and the possible need for a Union agency to resolve any identified shortcomings. On the basis of the findings, that report shall, where appropriate, be accompanied by a proposal for amendment of this Regulation. The reports shall be made public.

4. The reports referred to in paragraph 2 shall pay specific attention to the following:

(a) the status of the financial, technical and human resources of the national competent authorities in order to effectively perform the tasks assigned to them under this Regulation;

(b) the state of penalties, in particular administrative fines as referred to in Article 99(1), applied by Member States for infringements of this Regulation;

(c) adopted harmonised standards and common specifications developed to support this Regulation;

(d) the number of undertakings that enter the market after the entry into application of this Regulation, and how many of them are SMEs.

5. By 2 August 2028, the Commission shall evaluate the functioning of the AI Office, whether the AI Office has been given sufficient powers and competences to fulfil its tasks, and whether it would be relevant and needed for the proper implementation and enforcement of this Regulation to upgrade the AI Office and its enforcement competences and to increase its resources. The Commission shall submit a report on its evaluation to the European Parliament and to the Council.

▼B

6. By 2 August 2028 and every four years thereafter, the Commission shall submit a report on the review of the progress on the development of standardisation deliverables on the energy-efficient development of general-purpose AI models, and asses the need for further measures or actions, including binding measures or actions. The report shall be submitted to the European Parliament and to the Council, and it shall be made public.

7. By 2 August 2028 and every three years thereafter, the Commission shall evaluate the impact and effectiveness of voluntary codes of conduct to foster the application of the requirements set out in Chapter III, Section 2 for AI systems other than high-risk AI systems and possibly other additional requirements for AI systems other than high-risk AI systems, including as regards environmental sustainability.

8. For the purposes of paragraphs 1 to 7, the Board, the Member States and national competent authorities shall provide the Commission with information upon its request and without undue delay.

9. In carrying out the evaluations and reviews referred to in paragraphs 1 to 7, the Commission shall take into account the positions and findings of the Board, of the European Parliament, of the Council, and of other relevant bodies or sources.

10. The Commission shall, if necessary, submit appropriate proposals to amend this Regulation, in particular taking into account developments in technology, the effect of AI systems on health and safety, and on fundamental rights, and in light of the state of progress in the information society.

11. To guide the evaluations and reviews referred to in paragraphs 1 to 7 of this Article, the AI Office shall undertake to develop an objective and participative methodology for the evaluation of risk levels based on the criteria outlined in the relevant Articles and the inclusion of new systems in:

(a) the list set out in Annex III, including the extension of existing area headings or the addition of new area headings in that Annex;

(b) the list of prohibited practices set out in Article 5; and

(c) the list of AI systems requiring additional transparency measures pursuant to Article 50.

12. Any amendment to this Regulation pursuant to paragraph 10, or relevant delegated or implementing acts, which concerns sectoral Union harmonisation legislation listed in Section B of Annex I shall take into account the regulatory specificities of each sector, and the existing governance, conformity assessment and enforcement mechanisms and authorities established therein.

▼B

13. By 2 August 2031, the Commission shall carry out an assessment of the enforcement of this Regulation and shall report on it to the European Parliament, the Council and the European Economic and Social Committee, taking into account the first years of application of this Regulation. On the basis of the findings, that report shall, where appropriate, be accompanied by a proposal for amendment of this Regulation with regard to the structure of enforcement and the need for a Union agency to resolve any identified shortcomings.

Article 113

Entry into force and application

This Regulation shall enter into force on the twentieth day following that of its publication in the *Official Journal of the European Union*.

It shall apply from 2 August 2026.

However:

▼M1

(a) Chapters I and II shall apply from 2 February 2025, with the exception of Article 5(1), first subparagraph, points (ba) and (bb), and Article 5(1a) and (1b) which shall apply from 2 December 2026;

▼B

(b) Chapter III Section 4, Chapter V, Chapter VII and Chapter XII and Article 78 shall apply from 2 August 2025, with the exception of Article 101;

▼M1

(c) Chapter III, Sections 1, 2, and 3, with the exception of Article 6(5), shall apply from:

(i) 2 December 2027 as regards AI systems classified as high-risk pursuant to Article 6(2) and Annex III; and

(ii) 2 August 2028 as regards AI systems classified as high-risk pursuant to Article 6(1) and Annex I;

(d) Articles 102 to 110 shall apply from 27 July 2026.

▼B

This Regulation shall be binding in its entirety and directly applicable in all Member States.

▼B

ANNEX I

List of Union harmonisation legislation

Section A. List of Union harmonisation legislation based on the New Legislative Framework

▼M1

_____

▼B

2. Directive 2009/48/EC of the European Parliament and of the Council of 18 June 2009 on the safety of toys (OJ L 170, 30.6.2009, p. 1);

3. Directive 2013/53/EU of the European Parliament and of the Council of 20 November 2013 on recreational craft and personal watercraft and repealing Directive 94/25/EC (OJ L 354, 28.12.2013, p. 90);

4. Directive 2014/33/EU of the European Parliament and of the Council of 26 February 2014 on the harmonisation of the laws of the Member States relating to lifts and safety components for lifts (OJ L 96, 29.3.2014, p. 251);

5. Directive 2014/34/EU of the European Parliament and of the Council of 26 February 2014 on the harmonisation of the laws of the Member States relating to equipment and protective systems intended for use in potentially explosive atmospheres (OJ L 96, 29.3.2014, p. 309);

6. Directive 2014/53/EU of the European Parliament and of the Council of 16 April 2014 on the harmonisation of the laws of the Member States relating to the making available on the market of radio equipment and repealing Directive 1999/5/EC (OJ L 153, 22.5.2014, p. 62);

7. Directive 2014/68/EU of the European Parliament and of the Council of 15 May 2014 on the harmonisation of the laws of the Member States relating to the making available on the market of pressure equipment (OJ L 189, 27.6.2014, p. 164);

8. Regulation (EU) 2016/424 of the European Parliament and of the Council of 9 March 2016 on cableway installations and repealing Directive 2000/9/EC (OJ L 81, 31.3.2016, p. 1);

9. Regulation (EU) 2016/425 of the European Parliament and of the Council of 9 March 2016 on personal protective equipment and repealing Council Directive 89/686/EEC (OJ L 81, 31.3.2016, p. 51);

10. Regulation (EU) 2016/426 of the European Parliament and of the Council of 9 March 2016 on appliances burning gaseous fuels and repealing Directive 2009/142/EC (OJ L 81, 31.3.2016, p. 99);

11. Regulation (EU) 2017/745 of the European Parliament and of the Council of 5 April 2017 on medical devices, amending Directive 2001/83/EC, Regulation (EC) No 178/2002 and Regulation (EC) No 1223/2009 and repealing Council Directives 90/385/EEC and 93/42/EEC (OJ L 117, 5.5.2017, p. 1);

12. Regulation (EU) 2017/746 of the European Parliament and of the Council of 5 April 2017 on *in vitro* diagnostic medical devices and repealing Directive 98/79/EC and Commission Decision 2010/227/EU (OJ L 117, 5.5.2017, p. 176).

Section B. List of other Union harmonisation legislation

13. Regulation (EC) No 300/2008 of the European Parliament and of the Council of 11 March 2008 on common rules in the field of civil aviation security and repealing Regulation (EC) No 2320/2002 (OJ L 97, 9.4.2008, p. 72);

▼B

14. Regulation (EU) No 168/2013 of the European Parliament and of the Council of 15 January 2013 on the approval and market surveillance of two- or three-wheel vehicles and quadricycles (OJ L 60, 2.3.2013, p. 52);

15. Regulation (EU) No 167/2013 of the European Parliament and of the Council of 5 February 2013 on the approval and market surveillance of agricultural and forestry vehicles (OJ L 60, 2.3.2013, p. 1);

16. Directive 2014/90/EU of the European Parliament and of the Council of 23 July 2014 on marine equipment and repealing Council Directive 96/98/EC (OJ L 257, 28.8.2014, p. 146);

17. Directive (EU) 2016/797 of the European Parliament and of the Council of 11 May 2016 on the interoperability of the rail system within the European Union (OJ L 138, 26.5.2016, p. 44);

18. Regulation (EU) 2018/858 of the European Parliament and of the Council of 30 May 2018 on the approval and market surveillance of motor vehicles and their trailers, and of systems, components and separate technical units intended for such vehicles, amending Regulations (EC) No 715/2007 and (EC) No 595/2009 and repealing Directive 2007/46/EC (OJ L 151, 14.6.2018, p. 1);

19. Regulation (EU) 2019/2144 of the European Parliament and of the Council of 27 November 2019 on type-approval requirements for motor vehicles and their trailers, and systems, components and separate technical units intended for such vehicles, as regards their general safety and the protection of vehicle occupants and vulnerable road users, amending Regulation (EU) 2018/858 of the European Parliament and of the Council and repealing Regulations (EC) No 78/2009, (EC) No 79/2009 and (EC) No 661/2009 of the European Parliament and of the Council and Commission Regulations (EC) No 631/2009, (EU) No 406/2010, (EU) No 672/2010, (EU) No 1003/2010, (EU) No 1005/2010, (EU) No 1008/2010, (EU) No 1009/2010, (EU) No 19/2011, (EU) No 109/2011, (EU) No 458/2011, (EU) No 65/2012, (EU) No 130/2012, (EU) No 347/2012, (EU) No 351/2012, (EU) No 1230/2012 and (EU) 2015/166 (OJ L 325, 16.12.2019, p. 1);

20. Regulation (EU) 2018/1139 of the European Parliament and of the Council of 4 July 2018 on common rules in the field of civil aviation and establishing a European Union Aviation Safety Agency, and amending Regulations (EC) No 2111/2005, (EC) No 1008/2008, (EU) No 996/2010, (EU) No 376/2014 and Directives 2014/30/EU and 2014/53/EU of the European Parliament and of the Council, and repealing Regulations (EC) No 552/2004 and (EC) No 216/2008 of the European Parliament and of the Council and Council Regulation (EEC) No 3922/91 (OJ L 212, 22.8.2018, p. 1), in so far as the design, production and placing on the market of aircrafts referred to in Article 2(1), points (a) and (b) thereof, where it concerns unmanned aircraft and their engines, propellers, parts and equipment to control them remotely, are concerned;

▼M1

21. Regulation (EU) 2023/1230 of the European Parliament and of the Council of 14 June 2023 on machinery and repealing Directive 2006/42/EC of the European Parliament and of the Council and Council Directive 73/361/EEC (OJ L 165, 29.6.2023, p. 1, ELI: http://data.europa.eu/eli/reg/2023/1230/oj).

▼B

ANNEX II

List of criminal offences referred to in Article 5(1), first subparagraph, point (h)(iii)

Criminal offences referred to in Article 5(1), first subparagraph, point (h)(iii):

— terrorism,

— trafficking in human beings,

— sexual exploitation of children, and child pornography,

— illicit trafficking in narcotic drugs or psychotropic substances,

— illicit trafficking in weapons, munitions or explosives,

— murder, grievous bodily injury,

— illicit trade in human organs or tissue,

— illicit trafficking in nuclear or radioactive materials,

— kidnapping, illegal restraint or hostage-taking,

— crimes within the jurisdiction of the International Criminal Court,

— unlawful seizure of aircraft or ships,

— rape,

— environmental crime,

— organised or armed robbery,

— sabotage,

— participation in a criminal organisation involved in one or more of the offences listed above.

▼B

ANNEX III

High-risk AI systems referred to in Article 6(2)

High-risk AI systems pursuant to Article 6(2) are the AI systems listed in any of the following areas:

1. Biometrics, in so far as their use is permitted under relevant Union or national law:

   (a) remote biometric identification systems.

   This shall not include AI systems intended to be used for biometric verification the sole purpose of which is to confirm that a specific natural person is the person he or she claims to be;

   (b) AI systems intended to be used for biometric categorisation, according to sensitive or protected attributes or characteristics based on the inference of those attributes or characteristics;

   (c) AI systems intended to be used for emotion recognition.

2. Critical infrastructure: AI systems intended to be used as safety components in the management and operation of critical digital infrastructure, road traffic, or in the supply of water, gas, heating or electricity.

3. Education and vocational training:

   (a) AI systems intended to be used to determine access or admission or to assign natural persons to educational and vocational training institutions at all levels;

   (b) AI systems intended to be used to evaluate learning outcomes, including when those outcomes are used to steer the learning process of natural persons in educational and vocational training institutions at all levels;

   (c) AI systems intended to be used for the purpose of assessing the appropriate level of education that an individual will receive or will be able to access, in the context of or within educational and vocational training institutions at all levels;

   (d) AI systems intended to be used for monitoring and detecting prohibited behaviour of students during tests in the context of or within educational and vocational training institutions at all levels.

4. Employment, workers' management and access to self-employment:

   (a) AI systems intended to be used for the recruitment or selection of natural persons, in particular to place targeted job advertisements, to analyse and filter job applications, and to evaluate candidates;

   (b) AI systems intended to be used to make decisions affecting terms of work-related relationships, the promotion or termination of work-related contractual relationships, to allocate tasks based on individual behaviour or personal traits or characteristics or to monitor and evaluate the performance and behaviour of persons in such relationships.

5. Access to and enjoyment of essential private services and essential public services and benefits:

▼B

(a) AI systems intended to be used by public authorities or on behalf of public authorities to evaluate the eligibility of natural persons for essential public assistance benefits and services, including healthcare services, as well as to grant, reduce, revoke, or reclaim such benefits and services;

(b) AI systems intended to be used to evaluate the creditworthiness of natural persons or establish their credit score, with the exception of AI systems used for the purpose of detecting financial fraud;

(c) AI systems intended to be used for risk assessment and pricing in relation to natural persons in the case of life and health insurance;

(d) AI systems intended to evaluate and classify emergency calls by natural persons or to be used to dispatch, or to establish priority in the dispatching of, emergency first response services, including by police, firefighters and medical aid, as well as of emergency healthcare patient triage systems.

6. Law enforcement, in so far as their use is permitted under relevant Union or national law:

(a) AI systems intended to be used by or on behalf of law enforcement authorities, or by Union institutions, bodies, offices or agencies in support of law enforcement authorities or on their behalf to assess the risk of a natural person becoming the victim of criminal offences;

(b) AI systems intended to be used by or on behalf of law enforcement authorities or by Union institutions, bodies, offices or agencies in support of law enforcement authorities as polygraphs or similar tools;

(c) AI systems intended to be used by or on behalf of law enforcement authorities, or by Union institutions, bodies, offices or agencies, in support of law enforcement authorities to evaluate the reliability of evidence in the course of the investigation or prosecution of criminal offences;

(d) AI systems intended to be used by law enforcement authorities or on their behalf or by Union institutions, bodies, offices or agencies in support of law enforcement authorities for assessing the risk of a natural person offending or re-offending not solely on the basis of the profiling of natural persons as referred to in Article 3(4) of Directive (EU) 2016/680, or to assess personality traits and characteristics or past criminal behaviour of natural persons or groups;

(e) AI systems intended to be used by or on behalf of law enforcement authorities or by Union institutions, bodies, offices or agencies in support of law enforcement authorities for the profiling of natural persons as referred to in Article 3(4) of Directive (EU) 2016/680 in the course of the detection, investigation or prosecution of criminal offences.

7. Migration, asylum and border control management, in so far as their use is permitted under relevant Union or national law:

(a) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies as polygraphs or similar tools;

▼B

(b) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies to assess a risk, including a security risk, a risk of irregular migration, or a health risk, posed by a natural person who intends to enter or who has entered into the territory of a Member State;

(c) AI systems intended to be used by or on behalf of competent public authorities or by Union institutions, bodies, offices or agencies to assist competent public authorities for the examination of applications for asylum, visa or residence permits and for associated complaints with regard to the eligibility of the natural persons applying for a status, including related assessments of the reliability of evidence;

(d) AI systems intended to be used by or on behalf of competent public authorities, or by Union institutions, bodies, offices or agencies, in the context of migration, asylum or border control management, for the purpose of detecting, recognising or identifying natural persons, with the exception of the verification of travel documents.

8. Administration of justice and democratic processes:

(a) AI systems intended to be used by a judicial authority or on their behalf to assist a judicial authority in researching and interpreting facts and the law and in applying the law to a concrete set of facts, or to be used in a similar way in alternative dispute resolution;

(b) AI systems intended to be used for influencing the outcome of an election or referendum or the voting behaviour of natural persons in the exercise of their vote in elections or referenda. This does not include AI systems to the output of which natural persons are not directly exposed, such as tools used to organise, optimise or structure political campaigns from an administrative or logistical point of view.

▼B

ANNEX IV

Technical documentation referred to in Article 11(1)

The technical documentation referred to in Article 11(1) shall contain at least the following information, as applicable to the relevant AI system:

1. A general description of the AI system including:

   (a) its intended purpose, the name of the provider and the version of the system reflecting its relation to previous versions;

   (b) how the AI system interacts with, or can be used to interact with, hardware or software, including with other AI systems, that are not part of the AI system itself, where applicable;

   (c) the versions of relevant software or firmware, and any requirements related to version updates;

   (d) the description of all the forms in which the AI system is placed on the market or put into service, such as software packages embedded into hardware, downloads, or APIs;

   (e) the description of the hardware on which the AI system is intended to run;

   (f) where the AI system is a component of products, photographs or illustrations showing external features, the marking and internal layout of those products;

   (g) a basic description of the user-interface provided to the deployer;

   (h) instructions for use for the deployer, and a basic description of the user-interface provided to the deployer, where applicable;

2. A detailed description of the elements of the AI system and of the process for its development, including:

   (a) the methods and steps performed for the development of the AI system, including, where relevant, recourse to pre-trained systems or tools provided by third parties and how those were used, integrated or modified by the provider;

   (b) the design specifications of the system, namely the general logic of the AI system and of the algorithms; the key design choices including the rationale and assumptions made, including with regard to persons or groups of persons in respect of who, the system is intended to be used; the main classification choices; what the system is designed to optimise for, and the relevance of the different parameters; the description of the expected output and output quality of the system; the decisions about any possible trade-off made regarding the technical solutions adopted to comply with the requirements set out in Chapter III, Section 2;

   (c) the description of the system architecture explaining how software components build on or feed into each other and integrate into the overall processing; the computational resources used to develop, train, test and validate the AI system;

▼B

(d) where relevant, the data requirements in terms of datasheets describing the training methodologies and techniques and the training data sets used, including a general description of these data sets, information about their provenance, scope and main characteristics; how the data was obtained and selected; labelling procedures (e.g. for supervised learning), data cleaning methodologies (e.g. outliers detection);

(e) assessment of the human oversight measures needed in accordance with Article 14, including an assessment of the technical measures needed to facilitate the interpretation of the outputs of AI systems by the deployers, in accordance with Article 13(3), point (d);

(f) where applicable, a detailed description of pre-determined changes to the AI system and its performance, together with all the relevant information related to the technical solutions adopted to ensure continuous compliance of the AI system with the relevant requirements set out in Chapter III, Section 2;

(g) the validation and testing procedures used, including information about the validation and testing data used and their main characteristics; metrics used to measure accuracy, robustness and compliance with other relevant requirements set out in Chapter III, Section 2, as well as potentially discriminatory impacts; test logs and all test reports dated and signed by the responsible persons, including with regard to pre-determined changes as referred to under point (f);

(h) cybersecurity measures put in place;

3. Detailed information about the monitoring, functioning and control of the AI system, in particular with regard to: its capabilities and limitations in performance, including the degrees of accuracy for specific persons or groups of persons on which the system is intended to be used and the overall expected level of accuracy in relation to its intended purpose; the foreseeable unintended outcomes and sources of risks to health and safety, fundamental rights and discrimination in view of the intended purpose of the AI system; the human oversight measures needed in accordance with Article 14, including the technical measures put in place to facilitate the interpretation of the outputs of AI systems by the deployers; specifications on input data, as appropriate;

4. A description of the appropriateness of the performance metrics for the specific AI system;

5. A detailed description of the risk management system in accordance with Article 9;

6. A description of relevant changes made by the provider to the system through its lifecycle;

7. A list of the harmonised standards applied in full or in part the references of which have been published in the *Official Journal of the European Union*; where no such harmonised standards have been applied, a detailed description of the solutions adopted to meet the requirements set out in Chapter III, Section 2, including a list of other relevant standards and technical specifications applied;

8. A copy of the EU declaration of conformity referred to in Article 47;

9. A detailed description of the system in place to evaluate the AI system performance in the post-market phase in accordance with Article 72, including the post-market monitoring plan referred to in Article 72(3).

▼B

ANNEX V

EU declaration of conformity

The EU declaration of conformity referred to in Article 47, shall contain all of the following information:

1. AI system name and type and any additional unambiguous reference allowing the identification and traceability of the AI system;

2. The name and address of the provider or, where applicable, of their authorised representative;

3. A statement that the EU declaration of conformity referred to in Article 47 is issued under the sole responsibility of the provider;

4. A statement that the AI system is in conformity with this Regulation and, if applicable, with any other relevant Union law that provides for the issuing of the EU declaration of conformity referred to in Article 47;

5. Where an AI system involves the processing of personal data, a statement that that AI system complies with Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680;

6. References to any relevant harmonised standards used or any other common specification in relation to which conformity is declared;

7. Where applicable, the name and identification number of the notified body, a description of the conformity assessment procedure performed, and identification of the certificate issued;

8. The place and date of issue of the declaration, the name and function of the person who signed it, as well as an indication for, or on behalf of whom, that person signed, a signature.

▼B

ANNEX VI

Conformity assessment procedure based on internal control

1. The conformity assessment procedure based on internal control is the conformity assessment procedure based on points 2, 3 and 4.

2. The provider verifies that the established quality management system is in compliance with the requirements of Article 17.

3. The provider examines the information contained in the technical documentation in order to assess the compliance of the AI system with the relevant essential requirements set out in Chapter III, Section 2.

4. The provider also verifies that the design and development process of the AI system and its post-market monitoring as referred to in Article 72 is consistent with the technical documentation.

▼B

ANNEX VII

Conformity based on an assessment of the quality management system and an assessment of the technical documentation

1. Introduction

Conformity based on an assessment of the quality management system and an assessment of the technical documentation is the conformity assessment procedure based on points 2 to 5.

2. Overview

The approved quality management system for the design, development and testing of AI systems pursuant to Article 17 shall be examined in accordance with point 3 and shall be subject to surveillance as specified in point 5. The technical documentation of the AI system shall be examined in accordance with point 4.

3. Quality management system

3.1. The application of the provider shall include:

(a) the name and address of the provider and, if the application is lodged by an authorised representative, also their name and address;

(b) the list of AI systems covered under the same quality management system;

(c) the technical documentation for each AI system covered under the same quality management system;

(d) the documentation concerning the quality management system which shall cover all the aspects listed under Article 17;

(e) a description of the procedures in place to ensure that the quality management system remains adequate and effective;

(f) a written declaration that the same application has not been lodged with any other notified body.

3.2. The quality management system shall be assessed by the notified body, which shall determine whether it satisfies the requirements referred to in Article 17.

The decision shall be notified to the provider or its authorised representative.

The notification shall contain the conclusions of the assessment of the quality management system and the reasoned assessment decision.

3.3. The quality management system as approved shall continue to be implemented and maintained by the provider so that it remains adequate and efficient.

3.4. Any intended change to the approved quality management system or the list of AI systems covered by the latter shall be brought to the attention of the notified body by the provider.

The proposed changes shall be examined by the notified body, which shall decide whether the modified quality management system continues to satisfy the requirements referred to in point 3.2 or whether a reassessment is necessary.

The notified body shall notify the provider of its decision. The notification shall contain the conclusions of the examination of the changes and the reasoned assessment decision.

▼B

4. Control of the technical documentation.

4.1. In addition to the application referred to in point 3, an application with a notified body of their choice shall be lodged by the provider for the assessment of the technical documentation relating to the AI system which the provider intends to place on the market or put into service and which is covered by the quality management system referred to under point 3.

4.2. The application shall include:

(a) the name and address of the provider;

(b) a written declaration that the same application has not been lodged with any other notified body;

(c) the technical documentation referred to in Annex IV.

4.3. The technical documentation shall be examined by the notified body. Where relevant, and limited to what is necessary to fulfil its tasks, the notified body shall be granted full access to the training, validation, and testing data sets used, including, where appropriate and subject to security safeguards, through API or other relevant technical means and tools enabling remote access.

4.4. In examining the technical documentation, the notified body may require that the provider supply further evidence or carry out further tests so as to enable a proper assessment of the conformity of the AI system with the requirements set out in Chapter III, Section 2. Where the notified body is not satisfied with the tests carried out by the provider, the notified body shall itself directly carry out adequate tests, as appropriate.

4.5. Where necessary to assess the conformity of the high-risk AI system with the requirements set out in Chapter III, Section 2, after all other reasonable means to verify conformity have been exhausted and have proven to be insufficient, and upon a reasoned request, the notified body shall also be granted access to the training and trained models of the AI system, including its relevant parameters. Such access shall be subject to existing Union law on the protection of intellectual property and trade secrets.

4.6. The decision of the notified body shall be notified to the provider or its authorised representative. The notification shall contain the conclusions of the assessment of the technical documentation and the reasoned assessment decision.

Where the AI system is in conformity with the requirements set out in Chapter III, Section 2, the notified body shall issue a Union technical documentation assessment certificate. The certificate shall indicate the name and address of the provider, the conclusions of the examination, the conditions (if any) for its validity and the data necessary for the identification of the AI system.

The certificate and its annexes shall contain all relevant information to allow the conformity of the AI system to be evaluated, and to allow for control of the AI system while in use, where applicable.

Where the AI system is not in conformity with the requirements set out in Chapter III, Section 2, the notified body shall refuse to issue a Union technical documentation assessment certificate and shall inform the applicant accordingly, giving detailed reasons for its refusal.

▼B

Where the AI system does not meet the requirement relating to the data used to train it, re-training of the AI system will be needed prior to the application for a new conformity assessment. In this case, the reasoned assessment decision of the notified body refusing to issue the Union technical documentation assessment certificate shall contain specific considerations on the quality data used to train the AI system, in particular on the reasons for non-compliance.

4.7. Any change to the AI system that could affect the compliance of the AI system with the requirements or its intended purpose shall be assessed by the notified body which issued the Union technical documentation assessment certificate. The provider shall inform such notified body of its intention to introduce any of the abovementioned changes, or if it otherwise becomes aware of the occurrence of such changes. The intended changes shall be assessed by the notified body, which shall decide whether those changes require a new conformity assessment in accordance with Article 43(4) or whether they could be addressed by means of a supplement to the Union technical documentation assessment certificate. In the latter case, the notified body shall assess the changes, notify the provider of its decision and, where the changes are approved, issue to the provider a supplement to the Union technical documentation assessment certificate.

5. Surveillance of the approved quality management system.

5.1. The purpose of the surveillance carried out by the notified body referred to in Point 3 is to make sure that the provider duly complies with the terms and conditions of the approved quality management system.

5.2. For assessment purposes, the provider shall allow the notified body to access the premises where the design, development, testing of the AI systems is taking place. The provider shall further share with the notified body all necessary information.

5.3. The notified body shall carry out periodic audits to make sure that the provider maintains and applies the quality management system and shall provide the provider with an audit report. In the context of those audits, the notified body may carry out additional tests of the AI systems for which a Union technical documentation assessment certificate was issued.

▼B

ANNEX VIII

Information to be submitted upon the registration of high-risk AI systems in accordance with Article 49

Section A — Information to be submitted by providers of high-risk AI systems in accordance with Article 49(1)

The following information shall be provided and thereafter kept up to date with regard to high-risk AI systems to be registered in accordance with Article 49(1):

1. The name, address and contact details of the provider;

2. Where submission of information is carried out by another person on behalf of the provider, the name, address and contact details of that person;

3. The name, address and contact details of the authorised representative, where applicable;

4. The AI system trade name and any additional unambiguous reference allowing the identification and traceability of the AI system;

5. A description of the intended purpose of the AI system and of the components and functions supported through this AI system;

6. A basic and concise description of the information used by the system (data, inputs) and its operating logic;

7. The status of the AI system (on the market, or in service; no longer placed on the market/in service, recalled);

8. The type, number and expiry date of the certificate issued by the notified body and the name or identification number of that notified body, where applicable;

9. A scanned copy of the certificate referred to in point 8, where applicable;

10. Any Member States in which the AI system has been placed on the market, put into service or made available in the Union;

11. A copy of the EU declaration of conformity referred to in Article 47;

12. Electronic instructions for use; this information shall not be provided for high-risk AI systems in the areas of law enforcement or migration, asylum and border control management referred to in Annex III, points 1, 6 and 7;

13. A URL for additional information (optional).

Section B — Information to be submitted by providers of high-risk AI systems in accordance with Article 49(2)

The following information shall be provided and thereafter kept up to date with regard to AI systems to be registered in accordance with Article 49(2):

1. The name, address and contact details of the provider;

2. Where submission of information is carried out by another person on behalf of the provider, the name, address and contact details of that person;

3. The name, address and contact details of the authorised representative, where applicable;

4. The AI system trade name and any additional unambiguous reference allowing the identification and traceability of the AI system;

▼B

5. A description of the intended purpose of the AI system;

6. The condition or conditions under Article 6(3)based on which the AI system is considered to be not-high-risk;

▼M1

_____

▼B

8. The status of the AI system (on the market, or in service; no longer placed on the market/in service, recalled).

▼M1

_____

▼B

Section C — Information to be submitted by deployers of high-risk AI systems in accordance with Article 49(3)

The following information shall be provided and thereafter kept up to date with regard to high-risk AI systems to be registered in accordance with Article 49(3):

1. The name, address and contact details of the deployer;

2. The name, address and contact details of the person submitting information on behalf of the deployer;

3. The URL of the entry of the AI system in the EU database by its provider;

4. A summary of the findings of the fundamental rights impact assessment conducted in accordance with Article 27;

5. A summary of the data protection impact assessment carried out in accordance with Article 35 of Regulation (EU) 2016/679 or Article 27 of Directive (EU) 2016/680 as specified in Article 26(8) of this Regulation, where applicable.

▼B

ANNEX IX

Information to be submitted upon the registration of high-risk AI systems listed in Annex III in relation to testing in real world conditions in accordance with Article 60

The following information shall be provided and thereafter kept up to date with regard to testing in real world conditions to be registered in accordance with Article 60:

1. A Union-wide unique single identification number of the testing in real world conditions;

2. The name and contact details of the provider or prospective provider and of the deployers involved in the testing in real world conditions;

3. A brief description of the AI system, its intended purpose, and other information necessary for the identification of the system;

4. A summary of the main characteristics of the plan for testing in real world conditions;

5. Information on the suspension or termination of the testing in real world conditions.

▼B

ANNEX X

Union legislative acts on large-scale IT systems in the area of Freedom, Security and Justice

1. Schengen Information System

   (a) Regulation (EU) 2018/1860 of the European Parliament and of the Council of 28 November 2018 on the use of the Schengen Information System for the return of illegally staying third-country nationals (OJ L 312, 7.12.2018, p. 1).

   (b) Regulation (EU) 2018/1861 of the European Parliament and of the Council of 28 November 2018 on the establishment, operation and use of the Schengen Information System (SIS) in the field of border checks, and amending the Convention implementing the Schengen Agreement, and amending and repealing Regulation (EC) No 1987/2006 (OJ L 312, 7.12.2018, p. 14).

   (c) Regulation (EU) 2018/1862 of the European Parliament and of the Council of 28 November 2018 on the establishment, operation and use of the Schengen Information System (SIS) in the field of police cooperation and judicial cooperation in criminal matters, amending and repealing Council Decision 2007/533/JHA, and repealing Regulation (EC) No 1986/2006 of the European Parliament and of the Council and Commission Decision 2010/261/EU (OJ L 312, 7.12.2018, p. 56).

2. Visa Information System

   (a) Regulation (EU) 2021/1133 of the European Parliament and of the Council of 7 July 2021 amending Regulations (EU) No 603/2013, (EU) 2016/794, (EU) 2018/1862, (EU) 2019/816 and (EU) 2019/818 as regards the establishment of the conditions for accessing other EU information systems for the purposes of the Visa Information System (OJ L 248, 13.7.2021, p. 1).

   (b) Regulation (EU) 2021/1134 of the European Parliament and of the Council of 7 July 2021 amending Regulations (EC) No 767/2008, (EC) No 810/2009, (EU) 2016/399, (EU) 2017/2226, (EU) 2018/1240, (EU) 2018/1860, (EU) 2018/1861, (EU) 2019/817 and (EU) 2019/1896 of the European Parliament and of the Council and repealing Council Decisions 2004/512/EC and 2008/633/JHA, for the purpose of reforming the Visa Information System (OJ L 248, 13.7.2021, p. 11).

3. Eurodac

   Regulation (EU) 2024/1358 of the European Parliament and of the Council of 14 May 2024 on the establishment of 'Eurodac' for the comparison of biometric data in order to effectively apply Regulations (EU) 2024/1315 and (EU) 2024/1350 of the European Parliament and of the Council and Council Directive 2001/55/EC and to identify illegally staying third-country nationals and stateless persons and on requests for the comparison with Eurodac data by Member States' law enforcement authorities and Europol for law enforcement purposes, amending Regulations (EU) 2018/1240 and (EU) 2019/818 of the European Parliament and of the Council and repealing Regulation (EU) No 603/2013 of the European Parliament and of the Council (OJ L, 2024/1358, 22.5.2024, ELI: http://data.europa.eu/eli/reg/2024/1358/oj).

4. Entry/Exit System

   Regulation (EU) 2017/2226 of the European Parliament and of the Council of 30 November 2017 establishing an Entry/Exit System (EES) to register entry and exit data and refusal of entry data of third-country nationals crossing the external borders of the Member States and determining the conditions for access to the EES for law enforcement purposes, and amending the Convention implementing the Schengen Agreement and Regulations (EC) No 767/2008 and (EU) No 1077/2011 (OJ L 327, 9.12.2017, p. 20).

▼B

5. European Travel Information and Authorisation System

   (a) Regulation (EU) 2018/1240 of the European Parliament and of the Council of 12 September 2018 establishing a European Travel Information and Authorisation System (ETIAS) and amending Regulations (EU) No 1077/2011, (EU) No 515/2014, (EU) 2016/399, (EU) 2016/1624 and (EU) 2017/2226 (OJ L 236, 19.9.2018, p. 1).

   (b) Regulation (EU) 2018/1241 of the European Parliament and of the Council of 12 September 2018 amending Regulation (EU) 2016/794 for the purpose of establishing a European Travel Information and Authorisation System (ETIAS) (OJ L 236, 19.9.2018, p. 72).

6. European Criminal Records Information System on third-country nationals and stateless persons

   Regulation (EU) 2019/816 of the European Parliament and of the Council of 17 April 2019 establishing a centralised system for the identification of Member States holding conviction information on third-country nationals and stateless persons (ECRIS-TCN) to supplement the European Criminal Records Information System and amending Regulation (EU) 2018/1726 (OJ L 135, 22.5.2019, p. 1).

7. Interoperability

   (a) Regulation (EU) 2019/817 of the European Parliament and of the Council of 20 May 2019 on establishing a framework for interoperability between EU information systems in the field of borders and visa and amending Regulations (EC) No 767/2008, (EU) 2016/399, (EU) 2017/2226, (EU) 2018/1240, (EU) 2018/1726 and (EU) 2018/1861 of the European Parliament and of the Council and Council Decisions 2004/512/EC and 2008/633/JHA (OJ L 135, 22.5.2019, p. 27).

   (b) Regulation (EU) 2019/818 of the European Parliament and of the Council of 20 May 2019 on establishing a framework for interoperability between EU information systems in the field of police and judicial cooperation, asylum and migration and amending Regulations (EU) 2018/1726, (EU) 2018/1862 and (EU) 2019/816 (OJ L 135, 22.5.2019, p. 85).

▼B

ANNEX XI

Technical documentation referred to in Article 53(1), point (a) — technical documentation for providers of general-purpose AI models

Section 1

Information to be provided by all providers of general-purpose AI models

The technical documentation referred to in Article 53(1), point (a) shall contain at least the following information as appropriate to the size and risk profile of the model:

1. A general description of the general-purpose AI model including:

   (a) the tasks that the model is intended to perform and the type and nature of AI systems in which it can be integrated;

   (b) the acceptable use policies applicable;

   (c) the date of release and methods of distribution;

   (d) the architecture and number of parameters;

   (e) the modality (e.g. text, image) and format of inputs and outputs;

   (f) the licence.

2. A detailed description of the elements of the model referred to in point 1, and relevant information of the process for the development, including the following elements:

   (a) the technical means (e.g. instructions of use, infrastructure, tools) required for the general-purpose AI model to be integrated in AI systems;

   (b) the design specifications of the model and training process, including training methodologies and techniques, the key design choices including the rationale and assumptions made; what the model is designed to optimise for and the relevance of the different parameters, as applicable;

   (c) information on the data used for training, testing and validation, where applicable, including the type and provenance of data and curation methodologies (e.g. cleaning, filtering, etc.), the number of data points, their scope and main characteristics; how the data was obtained and selected as well as all other measures to detect the unsuitability of data sources and methods to detect identifiable biases, where applicable;

   (d) the computational resources used to train the model (e.g. number of floating point operations), training time, and other relevant details related to the training;

   (e) known or estimated energy consumption of the model.

   With regard to point (e), where the energy consumption of the model is unknown, the energy consumption may be based on information about computational resources used.

Section 2

Additional information to be provided by providers of general-purpose AI models with systemic risk

1. A detailed description of the evaluation strategies, including evaluation results, on the basis of available public evaluation protocols and tools or otherwise of other evaluation methodologies. Evaluation strategies shall include evaluation criteria, metrics and the methodology on the identification of limitations.

▼B

2. Where applicable, a detailed description of the measures put in place for the purpose of conducting internal and/or external adversarial testing (e.g. red teaming), model adaptations, including alignment and fine-tuning.

3. Where applicable, a detailed description of the system architecture explaining how software components build or feed into each other and integrate into the overall processing.

▼B

ANNEX XII

Transparency information referred to in Article 53(1), point (b) — technical documentation for providers of general-purpose AI models to downstream providers that integrate the model into their AI system

The information referred to in Article 53(1), point (b) shall contain at least the following:

1. A general description of the general-purpose AI model including:

   (a) the tasks that the model is intended to perform and the type and nature of AI systems into which it can be integrated;

   (b) the acceptable use policies applicable;

   (c) the date of release and methods of distribution;

   (d) how the model interacts, or can be used to interact, with hardware or software that is not part of the model itself, where applicable;

   (e) the versions of relevant software related to the use of the general-purpose AI model, where applicable;

   (f) the architecture and number of parameters;

   (g) the modality (e.g. text, image) and format of inputs and outputs;

   (h) the licence for the model.

2. A description of the elements of the model and of the process for its development, including:

   (a) the technical means (e.g. instructions for use, infrastructure, tools) required for the general-purpose AI model to be integrated into AI systems;

   (b) the modality (e.g. text, image, etc.) and format of the inputs and outputs and their maximum size (e.g. context window length, etc.);

   (c) information on the data used for training, testing and validation, where applicable, including the type and provenance of data and curation methodologies.

▼B

ANNEX XIII

Criteria for the designation of general-purpose AI models with systemic risk referred to in Article 51

For the purpose of determining that a general-purpose AI model has capabilities or an impact equivalent to those set out in Article 51(1), point (a), the Commission shall take into account the following criteria:

(a) the number of parameters of the model;

(b) the quality or size of the data set, for example measured through tokens;

(c) the amount of computation used for training the model, measured in floating point operations or indicated by a combination of other variables such as estimated cost of training, estimated time required for the training, or estimated energy consumption for the training;

(d) the input and output modalities of the model, such as text to text (large language models), text to image, multi-modality, and the state of the art thresholds for determining high-impact capabilities for each modality, and the specific type of inputs and outputs (e.g. biological sequences);

(e) the benchmarks and evaluations of capabilities of the model, including considering the number of tasks without additional training, adaptability to learn new, distinct tasks, its level of autonomy and scalability, the tools it has access to;

(f) whether it has a high impact on the internal market due to its reach, which shall be presumed when it has been made available to at least 10 000 registered business users established in the Union;

(g) the number of registered end-users.

▼M1

ANNEX XIV

The list of codes, categories and corresponding types of AI systems for the purpose of the notification procedure referred to in Article 30 specifying the scope of the designation as notified bodies

1. Introduction

Conformity assessment of high-risk AI systems pursuant to this Regulation may require the involvement of conformity assessment bodies. Only conformity assessment bodies that have been designated in accordance with this Regulation may carry out conformity assessments and only for the activities related to the types of AI systems concerned. The list of codes, categories, and corresponding types of AI systems sets the scope of the designation of conformity assessment bodies notified under Article 30.

2. List of Codes, categories, and corresponding AI systems

a. AI systems subject to Annex I

AIA Code	
AIP 0102	AI systems subject to point 2 of Section A of Annex I
AIP 0103	AI systems subject to point 3 of Section A of Annex I
AIP 0104	AI systems subject to point 4 of Section A of Annex I
AIP 0105	AI systems subject to point 5 of Section A of Annex I
AIP 0106	AI systems subject to point 6 of Section A of Annex I
AIP 0107	AI systems subject to point 7 of Section A of Annex I
AIP 0108	AI systems subject to point 8 of Section A of Annex I
AIP 0109	AI systems subject to point 9 of Section A of Annex I
AIP 0110	AI systems subject to point 10 of Section A of Annex I
AIP 0111	AI systems subject to point 11 of Section A of Annex I
AIP 0112	AI systems subject to point 12 of Section A of Annex I

b. AI systems subject to point 1 of Annex III

AIA Code	
AIB 0201	Remote biometric identification systems
AIB 0202	Biometric categorisation AI systems
AIB 0203	Emotion recognition AI systems

3. AI technology-specific codes

a. Symbolic AI and expert systems

AIA Code	
AIH 0101	AI systems based on symbolic AI, expert and knowledge-based systems, and AI systems based on search and optimisation

▼M1

b. Machine learning, excluding generative AI and general-purpose AI systems

AIA Code	
AIH 0201	AI systems that process structured data
AIH 0202	AI systems that process signal and audio data
AIH 0203	AI systems that process text data
AIH 0204	AI systems that process image and video
AIH 0205	AI systems that learn from their environment, excluding AI systems covered under AIH 0401

c. AI systems based on general-purpose AI models or generative AI

AIA Code	
AIH 0301	generative AI systems, including AI systems based on general-purpose AI models

d. Emerging AI technologies

AIA Code	
AIH 0401	AI systems based on other emerging AI technologies not covered by other codes, including Agentic AI

4. Application for designation

Conformity assessment bodies shall use the lists of codes, categories and corresponding types of AI systems set out in this Annex when specifying the types of AI systems in the application for designation referred to in Article 29.

Official Journal
of the European Union

EN
L series

2026/1744

24.7.2026

REGULATION (EU) 2026/1744 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 8 July 2026

amending Regulations (EU) 2024/1689, (EU) 2018/1139 and (EU) 2023/1230 as regards the simplification of the implementation of harmonised rules on artificial intelligence (Digital Omnibus on AI)

(Text with EEA relevance)

THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION,

Having regard to the Treaty on the Functioning of the European Union, and in particular Article 114 thereof,

Having regard to the proposal from the European Commission,

After transmission of the draft legislative act to the national parliaments,

Having regard to the opinion of the European Central Bank [1],

Having regard to the opinion of the European Economic and Social Committee [2],

Having regard to the opinion of the Committee of the Regions [3],

Acting in accordance with the ordinary legislative procedure [4],

Whereas:

(1) Regulation (EU) 2024/1689 of the European Parliament and of the Council [5] lays down harmonised rules on artificial intelligence (AI) and aims to improve the functioning of the internal market, to promote the uptake of human-centric and trustworthy AI, while ensuring a high level of protection of health, safety and fundamental rights and supporting innovation. Regulation (EU) 2024/1689 entered into force on 1 August 2024. The entry into application of its provisions is staggered, with all rules entering into application by 2 August 2027.

(2) The experience gathered from the implementation of the parts of Regulation (EU) 2024/1689 that already apply can inform the implementation of those parts that are yet to apply. In this context, the delayed preparation of standards, which provide technical solutions for providers of high-risk AI systems to ensure compliance with their obligations under that Regulation, and the delayed establishment of the governance and the conformity assessment frameworks at national level has resulted in a compliance burden that is heavier than expected. In addition, consultations of stakeholders have revealed the need for additional measures to facilitate and provide clarification on implementation and compliance, without reducing the level of protection for health, safety and fundamental rights from AI-related risks that the provisions of Regulation (EU) 2024/1689 seek to achieve.

---

(1) OJ C, C/2026/2285, 15.4.2026, ELI: http://data.europa.eu/eli/C/2026/2285/oj.
(2) Opinion of 18 March 2026 (not yet published in the Official Journal).
(3) Opinion of 7 May 2026 (not yet published in the Official Journal).
(4) Position of the European Parliament of 16 June 2026 (not yet published in the Official Journal) and decision of the Council of 29 June 2026.
(5) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).

(3) Targeted amendments to Regulation (EU) 2024/1689 are necessary to address certain implementation challenges, with a view to the effective, simple and uniform application of the relevant rules.

(4) In order to enable AI innovation in the private and public sectors, it is important that the Commission and Member States' competent authorities ensure that the supervision, enforcement and monitoring of sectoral and national laws do not create overlaps, inconsistent interpretations or divergent enforcement.

(5) Regulation (EU) 2024/1689 lays down horizontal rules for AI systems to ensure a consistent and high level of protection of public interests as regards health safety and fundamental rights. For high-risk AI systems referred to in Article 6(1), that Regulation applies in conjunction with the Union harmonisation legislation listed in Section A of Annex I. In certain cases, it is possible for such Union harmonisation legislation to lay down requirements that achieve the same or a higher level of protection of relevant public interests as achieved by the specific requirements or obligations laid down in Regulation (EU) 2024/1689. In that case, it should be possible to limit the application of specific requirements or obligations laid down in Regulation (EU) 2024/1689 in order to facilitate compliance, minimise administrative burden and duplications, while preserving the level of protection ensured by that Regulation. Such limitation should be possible where, and to the extent that, the Union harmonisation legislation listed in Section A of Annex I lays down requirements providing for an equivalent level of protection of health, safety or fundamental rights as the requirement or obligation concerned. The Commission should be empowered to adopt delegated acts to supplement that Regulation by identifying such cases and specifying the products concerned, the requirements or obligations that may be limited, and the conditions and scope of any limitation, ensuring that the level of protection provided by Regulation (EU) 2024/1689 is not reduced.

(6) Most Union companies are small and medium-sized enterprises, the majority of which are micro and small enterprises. Enterprises outgrowing the micro, small and medium-sized enterprises (SMEs) definition, namely the 'small mid-cap enterprises' (SMCs), play a vital role in the Union's economy. Compared to SMEs, SMCs tend to demonstrate a faster pace of growth, and a higher level of innovation and digitisation. Nevertheless, they face challenges similar to SMEs in relation to administrative burden, leading to a need for proportionality in the implementation of Regulation (EU) 2024/1689 and for targeted support. To enable the smooth transition of enterprises from SMEs to SMCs, it is important to address in a coherent manner the effect that Regulation may have on their activity once those enterprises become SMCs and are faced with rules that apply to large enterprises. Regulation (EU) 2024/1689 provides for several measures for small-scale operators, which should be extended to SMCs where appropriate while safeguarding the overarching objectives and level of protection afforded under Regulation (EU) 2024/1689. In order to clarify the treatment of SMEs and SMCs in Regulation (EU) 2024/1689, it is necessary to introduce definitions for SMEs and SMCs, which should correspond to the definition set out in the Annex to Commission Recommendation 2003/361/EC ([6]) and Annex to Commission Recommendation (EU) 2025/1099 ([7]), respectively.

([6]) Commission Recommendation 2003/361/EC of 6 May 2003 concerning the definition of micro, small and medium-sized enterprises (OJ L 124, 20.5.2003, p. 36, ELI: http://data.europa.eu/eli/reco/2003/361/oj).

([7]) Commission Recommendation (EU) 2025/1099 of 21 May 2025 on the definition of small mid-cap enterprises (OJ L, 2025/1099, 28.5.2025, ELI: http://data.europa.eu/eli/reco/2025/1099/oj).

(7) The notion of a 'safety component' is crucial for the classification of certain AI systems as high-risk according to Regulation (EU) 2024/1689. Thus, the notion should be targeted to include only the AI systems which could have an adverse impact on the health and safety of persons or property, in line with the risk-based approach of that Regulation. The definition set out in Article 3, point (14) of Regulation (EU) 2024/1689 does not provide the necessary clarity to allow providers of AI systems to determine whether an AI system qualifies as a safety component and, as a result, risks extending the high-risk classification of AI systems beyond what is justified by the risk-based approach of that Regulation. It is therefore necessary to amend that definition. First, it is necessary to provide clarity on the concept of a 'safety function'. The safety function should be an intended purpose of the system, which is determined by the provider of the system. An AI system fulfils a safety function where its intended purpose, as determined by the provider, is to prevent or mitigate risks to the health and safety of persons or property. In particular, this does not include AI systems which are intended to solely fulfil functions related to user assistance, performance optimisation, service efficiency, automation, convenience, or non-safety related aspects for quality control operations. The mere fact that an AI system is integrated into or operates within a product that is subject to Union harmonisation legislation does not, in itself, mean that it fulfils a safety function.

(8) Article 4 of Regulation (EU) 2024/1689 currently imposes an obligation on all providers and deployers of AI systems to ensure AI literacy of their staff. Development of AI literacy starting from education and training and continuing in a lifelong learning manner is crucial to equip providers, deployers and other affected persons with the necessary skills to make informed decisions regarding the deployment of AI systems. However, experience shared by stakeholders reveals that a solution imposing stringent obligations to ensure a sufficient level of AI literacy would not be suitable for all types of providers and deployers in relation to the promotion of AI literacy. Moreover, data indicates that imposing such obligations creates an additional compliance burden, particularly for smaller enterprises, whereas AI literacy should be a strategic priority, regardless of regulatory obligations and potential sanctions. In light of that information, Article 4 of Regulation (EU) 2024/1689 should be amended to require providers and deployers to take measures to support the development of AI literacy of their staff and of other persons dealing with the operation and use of AI systems on their behalf. The Commission and Member States should support and facilitate the efforts of providers and deployers of AI systems, including through offering training opportunities, providing informational resources, and allowing exchange of good practices and other initiatives. When complying with this obligation, the Commission and the Member States could take into account the European competence frameworks, for example the Digital Competence Framework for Citizens (DigComp) and the AI Literacy Framework for Primary and Secondary Education. The European Artificial Intelligence Board (the Board) should support the Commission and Member States by adopting recommendations setting out common objectives to be achieved in order to meet their obligation and ensure regular exchange between the Commission and Member States on the topic, while the Apply AI Alliance should allow discussion with the wider community.

(9) Bias detection and correction constitute a substantial public interest because they protect natural persons from the adverse effects of biases, including discrimination. For that reason, Regulation (EU) 2024/1689 provides a legal basis authorising providers of high-risk AI systems to process special categories of personal data in certain exceptional cases and subject to strict safeguards. This legal basis is linked to the obligation on those providers to establish practices concerning the detection, prevention and correction of biases likely to affect the health and safety of persons, have a negative impact on fundamental rights or lead to discrimination prohibited under Union law. Nevertheless, biases likely to have those effects could also result from the actions of the deployers of high-risk AI systems. Furthermore, such biases could also arise in the case of other AI systems or models. For example, biases in eligibility or risk-scoring tools used to assess applications for various types of public permits or licences can restrict

rights or effectively prevent certain groups from accessing public services. Accordingly, a substantial public interest exists to allow, exceptionally and where strictly necessary, the processing of special categories of personal data for the purposes of bias detection and correction to providers and deployers of other AI systems and models and deployers of high-risk AI systems. It is therefore necessary to extend the legal basis, established pursuant to Regulation (EU) 2024/1689, to those providers and deployers. That legal basis should be subject to the same limitations, conditions and safeguards that apply in accordance with the existing Article 10(5) of that Regulation, thereby ensuring compliance with Article 9(2), point (g) of Regulation (EU) 2016/679 of the European Parliament and of the Council ([8]), Article 10(2), point (g) of Regulation (EU) 2018/1725 of the European Parliament and of the Council ([9]) and Article 10, point (a) of Directive (EU) 2016/680 of the European Parliament and of the Council ([10]). Furthermore, to enable providers of high-risk AI systems to lawfully undertake bias detection and correction activities in preparation for compliance with the requirements for high-risk AI systems, including Article 10(2), points (f) and (g), of Regulation (EU) 2024/1689, the legal basis established by Article 4a of Regulation (EU) 2024/1689 should apply from the date of entry into application of that Regulation.

(10) Article 5 of Regulation (EU) 2024/1689 prohibits certain practices of AI systems that are particularly harmful and abusive, contradict certain Union values and violate certain fundamental rights. Article 5 is to be kept under review, as laid down in Article 112(1) of that Regulation. In light of technological and societal developments since the adoption of that Regulation, including the deployment and widespread use of AI systems generating non-consensual intimate images, videos, audio and similar material ('non-consensual intimate material') and child sexual abuse material, it is necessary to amend Article 5 of that Regulation.

(11) Non-consensual intimate material constitutes sexual violence and abuse against individuals, in particular women. AI systems that generate or manipulate such material pose a severe risk to health safety and fundamental rights, including victims' human dignity, personal autonomy, integrity and private life, with potentially serious lasting psychological and other harms, and enable abuse at scale. The proliferation of such technologies, often described as 'nudification' applications, has created an urgent need for an explicit regulatory prohibition. Child sexual abuse material, including wholly or partially synthetic material, constitutes a grave threat to the safety and fundamental rights of children. AI systems generating or manipulating such material pose a grave risk to human dignity and the rights of the child, and risk normalising, amplifying and perpetuating sexual violence against children. Accordingly, an amendment to Article 5 of Regulation (EU) 2024/1689 is necessary both to protect women, children, other individuals and society from seriously harmful practices, thereby pursuing the objectives of that Regulation, and to bring clarity to providers and deployers as to the scope of their obligations, thereby addressing implementation challenges.

([8]) Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ L 119, 4.5.2016, p. 1, ELI: http://data.europa.eu/eli/reg/2016/679/oj)

([9]) Regulation (EU) 2018/1725 of the European Parliament and of the Council of 23 October 2018 on the protection of natural persons with regard to the processing of personal data by the Union institutions, bodies, offices and agencies and on the free movement of such data, and repealing Regulation (EC) No 45/2001 and Decision No 1247/2002/EC (OJ L 295, 21.11.2018, p. 39, ELI: http://data.europa.eu/eli/reg/2018/1725/oj).

([10]) Directive (EU) 2016/680 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, and on the free movement of such data, and repealing Council Framework Decision 2008/977/JHA (OJ L 119, 4.5.2016, p. 89, ELI: http://data.europa.eu/eli/dir/2016/680/oj).

(12) It is necessary to define clearly the scope of the prohibition, including in particular the extent of providers' and deployers' obligations. This prohibition should not prevent providers from developing the technical capabilities of AI systems to generate or manipulate images, videos, audio or similar material. As concerns providers, the prohibition should be limited to the placing on the market or the putting into service of AI systems that generate or manipulate non-consensual intimate material or child sexual abuse material in two cases. First, it should cover systems intended to generate or manipulate such material. Second, it should cover systems where such generation or manipulation is a reasonably foreseeable and reproducible outcome and there are no reasonable and adequate technical safety measures and other safeguards in place, taking into account reasonably foreseeable misuse, to reliably prevent, and where necessary correct, that outcome and correct observed or reported misuse, including circumvention of such measures. Technical measures and other safeguards to prevent the generation of such material could include data cleaning, refusal training, safe prompt design and output controls, runtime prompt guardrails, content classification and filtering mechanisms, usage restrictions, abuse detection mechanisms, and notice and action mechanisms. Such preventive measures should be reasonable for the specific AI system, and are considered adequate if they align with the state-of-the-art measures and demonstrably prevent or sufficiently reduce in each specific case the likelihood of generating or manipulating such material, taking into account known and reasonably foreseeable misuse, including reasonably foreseeable circumvention of the preventive measures without significant technical modification. For providers retaining effective control over AI systems, for instance through a platform or a web interface, that could include following and reporting methods for misuse cases in full compliance with Union privacy and data protection law. In cases of observed or reported circumvention of the preventive measures or other safeguards, adequate corrective measures should be taken provided that such measures are reasonable, taking into account the specific AI system, including its release and distribution strategy (such as open-source releases). As concerns deployers, the use of an AI system should be prohibited only where the deployer uses an AI system for the purpose of generating or manipulating non-consensual intimate material or child sexual abuse material. This includes cases where a deployer uses or misuses AI systems placed on the market or put into service that lack reasonable and adequate preventive measures or where a deployer circumvents the preventive measures or uses for such purposes lawful AI systems not intended to generate or manipulate such material. The prohibition on use therefore does not cover the use of an AI system for lawful purposes, such as the generation or manipulation of material other than non-consensual intimate material or child sexual abuse material, even in cases where the AI system lacks reasonable and adequate safeguards that should have been put in place by the provider, nor does it cover accidental generation or manipulation of such content. Concerning the prohibition regarding non-consensual intimate material, where an AI system is intended for generation or manipulation of material falling under this prohibition, measures and other safeguards should include appropriate means for the distribution of the AI system aimed at enabling the reliable collection and demonstration of consent of the depicted person to such generation or manipulation, in compliance with Regulation (EU) 2016/679. The prohibition regarding non-consensual intimate material should be limited to realistic depictions of intimate parts, notably the genitals, pubic area, anus, exposed buttocks or exposed female breasts, nipples or areolae, or of sexually explicit activity. This 'realism' refers to the depiction of the person's face, voice or their body in a credible real-life manner, regardless of the realism of the context of that depiction or whether it fully corresponds to the actual voice or appearance of the depicted person. Conversely, it excludes cartoonish or physically impossible depictions of a person's body. The prohibition of non-consensual intimate material does not affect the generation or manipulation of other forms of nude material, such as material that does not depict identifiable natural persons, realistic partially nude depictions where intimate parts are not revealed and sexually explicit activities are not depicted, or non-realistic artistic nude works that do not realistically depict identifiable natural persons engaged in sexually explicit activity or depict their intimate parts. It also does not cover generative AI applications where intimate parts are not exposed or, if exposed, this is subject to the freely given, specific, informed, unambiguous and explicit consent of the depicted person (for example, try-on applications and medical applications, such as medical anatomical simulations and mammograms); this prohibition does not preclude the exceptional use of AI systems generating or manipulating nude depictions of the intimate parts of an identifiable person, in accordance with fundamental rights law, including data protection law, and applicable medical law, for the purpose of medical diagnosis and treatment by medical professionals where the person concerned is incapable of consent (for instance in an emergency situation). Finally, the prohibition on 'manipulating' non-consensual intimate material excludes cases where pre-existing intimate material is manipulated in a way that does not increase the exposure of any depicted intimate parts or alter the nature of any depicted sexually explicit activities, for instance the mere enhancement of an existing image depicting intimate parts or video depicting sexually explicit activities, such as changing the background, adding a text heading or enhancing the contrast or the brightness. Conversely, any manipulation of material, including material that already depicts intimate parts or sexually explicit activity, that increases the level of exposure of any depicted intimate parts or alters the nature of any depicted sexually explicit activities, falls under the scope of this prohibition.

(13) The prohibition on child sexual abuse material should not prevent the placing on the market, putting into service or use of an AI system where a 'without right' defence applies under national law, as referred to in Article 5(1) of Directive 2011/93/EU of the European Parliament and of the Council ([11]). This includes activities carried out under domestic legal powers, such as the legitimate generation, or manipulation of child sexual abuse material by the authorities in order to conduct criminal proceedings or to prevent, detect or investigate crime, as well as the legitimate use of the AI system in the context of red-teaming and evaluation activities for the purpose of assessing the system's compliance with the prohibition laid down in this Regulation.

(14) These prohibitions constitute justified interferences with the freedom of expression and information and the freedom to conduct a business. They pursue objectives of general interest and protect the rights and freedoms of others, including those set out in Article 1, Article 3(1) and Articles 4, 7, 8, 21, 23 and 24 of the Charter of Fundamental Rights of the European Union (the Charter). They are closely tailored. In the case of intimate material, they are limited to realistic depictions of identifiable natural persons and to cases where the AI system is used to increase the level of nudity or explicitness; and exclude generation or manipulation with the person's consent. Moreover, they are limited to requiring providers to implement 'reasonable and adequate' measures and safeguards in the case of systems not intended to generate or manipulate the prohibited material. They are also aligned with existing Union law, including Directive 2011/93/EU and Directive (EU) 2024/1385 of the European Parliament and of the Council ([12]). The interferences respect the essence of Articles 11 and 16 of the Charter, are prescribed by law, and are proportionate.

(15) The conduct covered by these prohibitions may also violate other law, including criminal law. The prohibitions do not preclude prosecution under such law. However, insofar as an infringement of the prohibitions may result in the imposition of penalties of a criminal nature, which may be laid down pursuant to Article 99(1) of Regulation (EU) 2024/1689, and to the extent that the same conduct is sanctioned under criminal law, including criminal law falling within the scope of Directives 2011/93/EU and (EU) 2024/1385, Member States are required to ensure respect for the *ne bis in idem* principle in accordance with the Charter.

(16) The prohibitions are without prejudice to remedies available under national laws for individuals to protect their fundamental rights, including rights to their image, privacy and human dignity.

(17) In order to ensure consistency, avoid duplication and minimise administrative burdens in relation to the procedure for the designation of notified bodies pursuant to Regulation (EU) 2024/1689, while maintaining the same level of scrutiny, a single application and a unified assessment procedure should be available for new conformity assessment bodies and notified bodies which are designated pursuant to the Union harmonisation legislation listed in Section A of Annex I to Regulation (EU) 2024/1689, such as Regulations (EU) 2017/745 ([13]) and (EU) 2017/746 ([14]) of the European Parliament and of the Council, where such an application and procedure is established pursuant to that Union harmonisation legislation. The single application and unified assessment procedure aims to facilitate, support and expedite the designation procedure in accordance with Regulation (EU) 2024/1689, while ensuring compliance with the requirements applicable to notified bodies in accordance with that Regulation and the Union harmonisation legislation listed in Section A of Annex I thereto. The unified assessment procedure should be carried out with respect to the tasks and responsibilities of the authorities involved. Moreover, it should be clarified that a conformity assessment body that is designated pursuant to more than one piece of Union harmonisation legislation listed in Section A of Annex I should have to apply only once to be designated pursuant to this Regulation.

([11]) Directive 2011/93/EU of the European Parliament and of the Council of 13 December 2011 on combating the sexual abuse and sexual exploitation of children and child pornography, and replacing Council Framework Decision 2004/68/JHA (OJ L 335, 17.12.2011, p. 1, ELI: http://data.europa.eu/eli/dir/2011/93/oj).

([12]) Directive (EU) 2024/1385 of the European Parliament and of the Council of 14 May 2024 on combating violence against women and domestic violence (OJ L, 2024/1385, 24.5.2024, ELI: http://data.europa.eu/eli/dir/2024/1385/oj).

([13]) Regulation (EU) 2017/745 of the European Parliament and of the Council of 5 April 2017 on medical devices, amending Directive 2001/83/EC, Regulation (EC) No 178/2002 and Regulation (EC) No 1223/2009 and repealing Council Directives 90/385/EEC and 93/42/EEC (OJ L 117, 5.5.2017, p. 1, ELI: http://data.europa.eu/eli/reg/2017/745/oj).

([14]) Regulation (EU) 2017/746 of the European Parliament and of the Council of 5 April 2017 on *in vitro* diagnostic medical devices and repealing Directive 98/79/EC and Commission Decision 2010/227/EU (OJ L 117, 5.5.2017, p. 176, ELI: http://data.europa.eu/eli/reg/2017/746/oj).

(18) With a view to ensuring the smooth application and consistency of Regulation (EU) 2024/1689, amendments should be made to it. A technical correction to Article 43(3), first subparagraph, of Regulation (EU) 2024/1689 should be made to align the conformity assessment requirements with the requirements of providers of high-risk AI systems in Article 16 of that Regulation. Moreover, it should be clarified that where a provider of a high-risk AI system is subject to the conformity assessment procedure under Union harmonisation legislation listed in Section A of Annex I to Regulation (EU) 2024/1689, and the conformity assessment extends to the compliance of the quality management system of that Regulation and of such Union harmonisation legislation, the provider should be able to include aspects related to quality management systems pursuant to that Regulation as part of the quality management systems pursuant to such Union harmonisation legislation, in accordance with Article 17(3) of Regulation (EU) 2024/1689. Article 43(3), second subparagraph, of that Regulation should be amended to clarify that notified bodies which have been notified pursuant to the Union harmonisation legislation listed in Section A of Annex I to Regulation (EU) 2024/1689 and which aim to assess high-risk AI systems covered by the Union harmonisation legislation listed in Section A of Annex I to that Regulation, should have the power to assess the conformity of high-risk AI systems under certain conditions for 18 months from 27 July 2026. This amendment is without prejudice to Article 28 of Regulation (EU) 2024/1689, thus conformity assessment bodies that wish to be designated and notified pursuant to that Regulation can submit an application at any time during and after these 18 months. Moreover, Regulation (EU) 2024/1689 should be amended to clarify that where a high-risk AI system is both covered by the Union harmonisation legislation listed in Section A of Annex I to Regulation (EU) 2024/1689 and falls within one of the use-cases listed in Annex III to that Regulation, the provider should follow the relevant conformity assessment procedure as required under that relevant harmonisation legislation.

(19) Regulation (EU) 2024/1689 and Regulation (EU) 2024/2847 of the European Parliament and of the Council [15] complement each other so that the safety and cybersecurity of products with digital elements is ensured. Article 12 of Regulation (EU) 2024/2847 states that where high-risk AI systems and processes put in place by manufacturers fulfil the essential cybersecurity requirements set out in Regulation (EU) 2024/2847, they should be deemed to comply with the cybersecurity requirements set out in Article 15 of Regulation (EU) 2024/1689 in so far as those requirements are covered by the EU declaration of conformity or parts thereof issued pursuant to Regulation (EU) 2024/2847. In order to improve the visibility of the interplay of Regulation (EU) 2024/1689 and Regulation (EU) 2024/2847, the rule of Article 12 of Regulation (EU) 2024/2847 should also be reflected in Regulation (EU) 2024/1689. The interplay between the two instruments should not be affected.

(20) In accordance with Article 6(1) of Regulation (EU) 2024/1689, AI systems are classified as high-risk where an AI system that is a component of a product covered by Union harmonisation legislation listed in Section A of Annex I to that Regulation is a safety component and that product requires a third-party conformity assessment. The requirement that such product must require a third-party conformity assessment, however, does not affect the choice of the manufacturer regarding the conformity assessment procedure for such product. Where Union harmonisation legislation listed in Section A of Annex I allows to choose a conformity assessment procedure based on harmonised standards amongst conformity assessment procedures, this possibility remains applicable also to products in which a high-risk AI system is embedded. Article 6(1) of Regulation (EU) 2024/1689 should not be understood to require products in which a high-risk AI system is embedded to automatically undergo a third-party conformity assessment involving a notified body. Where this possibility is provided for in Union harmonisation legislation, the provider of the product in which the high-risk AI system is embedded could continue to rely on harmonised standards to comply with the requirements of the Union harmonisation legislation and Regulation (EU) 2024/1689 as a conformity assessment procedure.

[15] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act) (OJ L, 2024/2847, 20.11.2024, ELI: http://data.europa.eu/eli/reg/2024/2847/oj).

(21) In order to enhance competitiveness and innovation, it is essential to support economic operators that are required to comply simultaneously with the requirements or obligations set out in Chapter III, Sections 2 and 3 of Regulation (EU) 2024/1689, and with the relevant requirements and obligations laid down in the Union harmonisation legislation listed in Annex I to that Regulation. To support and simplify the regulatory compliance pathways of such economic operators, the Commission should request that, without undue delay, the European standardisation organisations develop standardisation deliverables, including, where appropriate, harmonised standards. Those standardisation deliverables should be based on the harmonised standards published in the *Official Journal of the European Union* that give the presumption of conformity with the requirements or obligations of Regulation (EU) 2024/1689, as well as any relevant harmonised standards published in the *Official Journal of the European Union* that give the presumption of conformity with the relevant requirements or obligations set out in the Union harmonisation legislation listed in Annex I to that Regulation. Such standardisation deliverables should help reduce legal uncertainty, avoid unnecessary duplication of conformity assessment activities, testing, documentation and reporting obligations, and lower compliance costs, in particular for small and medium-sized enterprises and start-ups. Timely development of such deliverables is essential in order to provide economic operators with practical and reliable technical solutions, strengthen legal certainty and facilitate the placing on the market, putting into service and use of AI systems in accordance with this Regulation and the Union harmonisation legislation listed in Annex I to that Regulation.

(22) To streamline compliance and reduce associated costs, the registration of AI systems referred to in Article 6(3) of Regulation (EU) 2024/1689 in the EU database pursuant to Article 49(2) of that Regulation should be simplified by streamlining the content required under Annex VIII to that Regulation. While it remains crucial for effective market surveillance and public accountability that such AI systems are registered in the EU database, the registration requirements should be simplified and made more proportionate. This simplification would strike a better balance without undermining the protection laid down by Regulation (EU) 2024/1689. Such AI systems are not considered to be high risk under certain conditions where they do not pose a significant risk of harm to the health, safety or fundamental rights of persons. Furthermore, a provider applying Article 6(3) of Regulation (EU) 2024/1689 remains obligated to document its assessment before that AI system is placed on the market or put into service. National competent authorities should be able to request that assessment.

(23) Articles 57, 58 and 60 of Regulation (EU) 2024/1689 should be amended to strengthen further cooperation at Union level of AI regulatory sandboxes, foster clarity and consistency in the governance of AI regulatory sandboxes, and to extend the scope of real-world testing outside AI regulatory sandboxes to high-risk AI systems covered by the Union harmonisation legislation listed in Annex I to that Regulation. In particular, to allow procedural simplification, where applicable, in the projects supervised in the AI regulatory sandboxes that also include real-world testing, the real-world testing plan should be integrated into the sandbox plan agreed by the providers or prospective providers and the competent authority.

(24) In addition, it is appropriate to provide for the possibility of the European Artificial Intelligence Office (AI Office) to establish an AI regulatory sandbox at Union level for AI systems that are covered by Article 75(1) of Regulation (EU) 2024/1689. To ensure coherence, legal certainty and an efficient allocation of supervisory responsibilities between Union and national levels, the scope of the Union-level AI regulatory sandbox should be clearly defined in order to avoid any overlap with national AI regulatory sandboxes established pursuant to that Regulation. In order to foster innovation and facilitate the uptake of AI, SMEs, including startups, and SMCs should be provided with priority access to the AI regulatory sandboxes established by the AI Office.

(25) Moreover, the provisions on the cooperation between relevant competent authorities for the operation of an AI regulatory sandbox should be clarified in order to ensure their effective functioning. For that reason, the empowerment of the Commission to adopt implementing acts specifying the detailed arrangements for the establishment, development, implementation, operation and supervision of the AI regulatory sandboxes should be extended to also cover governance aspects of such sandboxes. In addition, where AI regulatory sandboxes involve innovative AI systems that process personal data or otherwise fall under the supervisory remit of other national authorities or competent authorities providing or supporting access to data, the relevant competent supervisory authorities should be associated with the operation of the AI regulatory sandbox and involved in the supervision of those aspects to the extent of their respective tasks and powers.

(26) To foster innovation, it is also appropriate to extend the scope of real-world testing outside AI regulatory sandboxes in Article 60 of Regulation (EU) 2024/1689, currently applicable to high-risk AI systems listed in Annex III to that Regulation, and allow providers and prospective providers of high-risk AI systems covered by the Union harmonisation legislation listed in Annex I to that Regulation to also test such systems in real-world conditions, subject to sufficient safeguards. This is without prejudice to other Union or national law on the testing in real-world conditions of high-risk AI systems related to products covered by that Union harmonisation legislation.

(27) It is also appropriate to ensure that real-world testing of high-risk AI systems covered by the Union harmonisation legislation listed in Section B of Annex I to Regulation (EU) 2024/1689 is possible. Those systems are subject to the requirements and procedures of the relevant sectoral legislation and are, for most purposes, not directly subject to that Regulation. Those sectoral acts will, in due course, incorporate requirements corresponding to the requirements set out in Articles 8 to 15 of that Regulation. Therefore, it is appropriate to ensure that Member States can allow real-world testing of these AI systems with a view to assessing and verifying the conformity of those systems with the requirements set out in Articles 8 to 15 of that Regulation. If Member States decide to allow such testing, that Regulation should require them to adopt frameworks setting out the detailed requirements for such testing. That Regulation should provide for essential elements to be contained in such frameworks. When designing such frameworks, Member States should ensure a high level of protection of health safety and fundamental rights of natural persons. Before implementing the framework, Member States should notify it to the Commission. The real-world testing should comply with the relevant Union harmonisation legislation listed in Section B of Annex I to Regulation (EU) 2024/1689, including any applicable provisions regarding testing. However, this should not affect the application of the new article regarding real-world testing.

(28) Article 63 of Regulation (EU) 2024/1689 offers microenterprises who are providers of high-risk AI systems the possibility to benefit from a simplified way to comply with the obligation to establish a quality management system. With a view to facilitating compliance for more innovators, that possibility should be extended to all SMEs, including start-ups.

(29) In light of the important role of the AI Office for the effective and coordinated governance of Regulation (EU) 2024/1689, as further reinforced by this Regulation, and without prejudice to the next Multiannual Financial Framework and to the budgetary procedure, the Commission should allocate adequate human, financial and technical resources to the AI Office to ensure that it can effectively, and within reasonable timeframes, perform its tasks in relation to the enforcement of Regulation (EU) 2024/1689, including the allocation of a sufficient number of permanent personnel with in-depth competences and technical expertise.

(30) Article 69 of Regulation (EU) 2024/1689 should be amended to simplify the fee structure of the scientific panel. If Member States call upon the panel's expertise, the fees they may be required to pay to the experts should be equivalent to the remuneration the Commission is obliged to pay in similar circumstances.

(31) In order to strengthen the governance system for AI systems, it is necessary to clarify the role of the AI Office in monitoring and supervising the compliance of such AI systems with Regulation (EU) 2024/1689. The Commission has exclusive competence as regards general-purpose AI models under Article 88 of that Regulation. To increase coherence, clarity and effectiveness, and in light of the reach and impacts of AI systems linked to those competences, the scope of the AI Office's exclusive competence to supervise systems should be refined. In particular, the AI Office should have exclusive competence over AI systems built on general-purpose AI models, not only where both the system and the model are developed by the same provider, but also where they are developed by providers that form part of the same undertaking. However, in certain cases, in particular where there is specific sectoral supervision, responsibility should remain with the relevant national competent authority. Accordingly, certain exceptions should be laid down. The personal scope of this exclusive competence should extend to the providers of those AI systems and to their deployers within the same undertaking. Other deployers should remain subject to national supervision and enforcement. Moreover, this does not include AI systems placed on the market, put into service or used by Union institutions, bodies, offices or agencies, which are under the supervision of the European Data Protection Supervisor pursuant to Article 74(9) of Regulation (EU) 2024/1689.

(32) Additionally, considering the existing supervisory and enforcement system under Regulation (EU) 2022/2065 of the European Parliament and of the Council ([16]), it is appropriate to grant the Commission the powers of a competent market surveillance authority pursuant to Regulation (EU) 2024/1689 where an AI system qualifies as a very large online platform or a very large online search engine in accordance with Regulation (EU) 2022/2065, or where it is embedded in such a platform or search engine. This should contribute to ensuring that the exercise of the Commission's supervision and enforcement powers pursuant to Regulation (EU) 2024/1689 and Regulation (EU) 2022/2065, as well as those applicable to general-purpose AI models integrated into such platforms or search engines, is carried out in a coherent and effective manner. This is also appropriate in light of the importance of such platforms and search engines, in view of their reach, impact and potential to cause complex and large societal harms. The personal scope of this exclusive competence should extend to the providers of those AI systems and to their deployers within the same undertaking. In the case of AI systems embedded in or qualifying as a very large online platform or search engine, the first point of entry for the assessment of the AI systems are the risk assessment, mitigating measures and audit obligations prescribed by Articles 34, 35 and 37 of Regulation (EU) 2022/2065, without prejudice to the AI Office's powers to investigate and enforce *ex post* non-compliance with the rules of Regulation (EU) 2024/1689. In the context of the analysis of this risk assessment, mitigating measures and audits, the Commission services responsible for the enforcement of Regulation (EU) 2022/2065 may seek the opinion of the AI Office on the outcome of a potential earlier or parallel risk assessment carried out in accordance with Regulation (EU) 2024/1689 and the applicability of prohibitions pursuant to Regulation (EU) 2024/1689. In addition, the AI Office and the competent national authorities should, in accordance with Regulation (EU) 2024/1689, coordinate their enforcement efforts with the authorities competent for the supervision and enforcement of Regulation (EU) 2022/2065, including the Commission, in order to ensure that the principles of loyal cooperation, proportionality and *ne bis in idem* are respected, while information obtained pursuant to one Regulation is to be used for the purposes of supervision and enforcement of the other only provided the undertaking agrees. In particular, those authorities should exchange views regularly and take into account, in their respective areas of competence, any fines and penalties imposed on the same provider for the same conduct through a final decision in proceedings relating to an infringement of other Union or national rules, so as to ensure that the overall fines and penalties imposed are proportionate and correspond to the seriousness of the infringements committed.

([16]) Regulation (EU) 2022/2065 of the European Parliament and of the Council of 19 October 2022 on a Single Market For Digital Services and amending Directive 2000/31/EC (Digital Services Act) (OJ L 277, 27.10.2022, p. 1, ELI: http://data.europa.eu/eli/reg/2022/2065/oj).

(33) When supervising and enforcing obligations in relation to AI systems under its competence, the AI Office has the same role and responsibility as a market surveillance authority pursuant to Regulation (EU) 2024/1689. Consequently, it is necessary for the AI Office to have all of the powers and responsibilities that market surveillance authorities have pursuant to that Regulation and Regulation (EU) 2019/1020 of the European Parliament and of the Council ([17]) ('the general powers'). These should ensure the appropriate and effective enforcement of the requirements and obligations set out in Regulation (EU) 2024/1689. However, it is necessary to specify, complement, and frame certain essential elements and other aspects of the general powers, as well as their safeguards ('the specifying provisions'). In particular, it is necessary to lay down provisions governing the relationship between the AI Office and national authorities; provisions specifying, complementing, and constraining the powers to request information and conduct on-site inspections; provisions governing investigations, including the possibility to make commitments binding; and provisions specifying and constraining power to find non-compliance, impose fines and impose periodic penalties. Where a type of general power has been so specified, the AI Office may not circumvent the conditions and limits of those powers by relying on a related general power. Conversely, types of general power that are not specified and framed in respect of the AI Office, such as the power to adopt measures referred to in Article 16(3) of Regulation (EU) 2019/1020, may be relied on by the AI Office. As necessary for the proper implementation of Regulation (EU) 2024/1689, the Commission should be able to adopt implementing acts further defining the rules and the procedures concerning the application of limitation periods and, the access to the file and the negotiated disclosure of information. In exercising all of these powers, the AI Office must comply with the Charter. Additionally, the AI Office is subject to the safeguards and protection for fundamental rights laid down in the specifying provisions.

(34) In addition to those procedural and fundamental rights safeguards the procedural rights provided for in Article 18 of Regulation (EU) 2019/1020 should apply *mutatis mutandis* to providers of AI systems, without prejudice to more specific procedural rights provided for in Regulation (EU) 2024/1689. When national market surveillance authorities, through the single point of contact, request that the AI Office takes supervisory and enforcement measures with regards to AI systems under its exclusive supervision, the AI Office should no later than four months following the receipt of that request, inform the single point of contact of its intention to exercise its supervisory and enforcement powers or of its reasons for not exercising its powers. If the AI Office decides to exercise its supervisory and enforcement powers, it should also inform the single point of contact about the final outcome of such proceedings and of intermediate developments that the AI Office considers as having a major impact in the investigation, including the decision to open proceedings, to impose a fine, and to withdraw or recall the AI system from the market.

(35) To enable access to the Union market for AI systems which are under the supervision of the AI Office pursuant to Article 75 of Regulation (EU) 2024/1689 and subject to a third party conformity assessment, the Commission should be responsible for the pre-market conformity assessments of those systems.

(36) Article 77 and related provisions of Regulation (EU) 2024/1689 constitute an important governance mechanism, as they aim to enable authorities or bodies responsible for enforcing or supervising Union law intended to protect fundamental rights to fulfil their mandate under specific conditions and to foster cooperation with market surveillance authorities responsible for the supervision and enforcement of that Regulation. It is necessary to clarify the scope of such cooperation, as well as to clarify which public authorities or bodies benefit from it. With a view to reinforcing cooperation, it should be clarified that requests to access information and documentation should be made to the competent market surveillance authority, which should respond to such requests without undue delay, and that the authorities or bodies involved should have a mutual obligation to cooperate. It should be clarified that these provisions are without prejudice to the competences, tasks, powers and independence of the relevant national public authorities or bodies under their mandates. In particular, those provisions do not limit any powers that those authorities and bodies have to request information pursuant to other Union or national law. Accordingly, those authorities and bodies retain any power they have to directly request information from operators pursuant to their mandate or Union or national law.

([17]) Regulation (EU) 2019/1020 of the European Parliament and of the Council of 20 June 2019 on market surveillance and compliance of products and amending Directive 2004/42/EC and Regulations (EC) No 765/2008 and (EU) No 305/2011 (OJ L 169, 25.6.2019, p. 1, ELI: http://data.europa.eu/eli/reg/2019/1020/oj).

(37) The requirements for high-risk AI systems laid down in Regulation (EU) 2024/1689 address specific risks inherent to AI systems, including bias, unpredictable model behaviour, poor robustness or accuracy, vulnerabilities to attacks by third parties, and a lack of transparency of the AI system. By addressing AI-specific risks, that Regulation complements the requirements laid down in Union harmonisation legislation listed in Annex I to that Regulation, without duplicating them. Regulation (EU) 2024/1689 provides mechanisms for economic operators to minimise the compliance burden. In particular, Article 8(2) on the interplay with the sectoral legislation, Article 9(10) on risk management and Article 17(3) on quality management, allow economic operators to integrate, when necessary and appropriate, an assessment of AI-specific risks into existing risk and quality management systems. Article 40 of Regulation (EU) 2024/1689 further requires the Commission to specify that harmonised standards developed pursuant to that Regulation are to be consistent with standards developed pursuant to the Union harmonisation legislation listed in Annex I to that Regulation. The Commission should provide guidelines to assist economic operators of high-risk AI systems covered in Annex I to Regulation (EU) 2024/1689 in complying with that Regulation, including by providing guidance on the application of Article 8(2), Article 9(10) and Article 17(3) of that Regulation as mechanisms to minimise the compliance burden, in line with principles of complementarity and proportionality. Those guidelines should be published, at the latest, by 1 August 2027.

(38) To allow sufficient time for providers of generative AI systems subject to the marking obligations laid down in Article 50(2) of Regulation (EU) 2024/1689 to adapt their practices within a reasonable time without disrupting the market, it is appropriate to introduce a transitional period of four months for providers who have already placed their systems on the market before the 2 August 2026.

(39) To provide sufficient time for providers of high-risk AI systems and to clarify rules applicable to the AI systems already placed on the market or put into service before the relevant provisions of Regulation (EU) 2024/1689 apply, it is appropriate to clarify the scope of the grace period provided in Article 111(2) of that Regulation. For the purpose of that Article 111(2), the grace period should apply where the type and model of AI system has already been placed on the market. This means that if at least one individual unit of the high-risk AI system has been lawfully placed on the market or put into service before the date specified in Article 111(2), other individual units of the same type and model of high-risk AI system are subject to the grace period provided in that Article 111(2) and thus may continue to be placed on the market, made available or put into service on the Union market without any additional obligations, requirements or the need for additional certification, as long as the design of that high-risk AI system remains unchanged. For the purposes of the application of the grace period provided in Article 111(2), the decisive factor is the date on which the first unit of that type and model of high-risk AI system was placed on the market or put into service on the Union market for the first time. Any significant change to the design of that AI system after the date specified in Article 111(2) should trigger the obligation of the provider to fully comply with all relevant provisions of that Regulation applicable to high-risk AI systems, including the conformity assessment requirements.

(40) Article 113 of Regulation (EU) 2024/1689 establishes the dates of entry into force and application of that Regulation, in particular that the general date of application is 2 August 2026. For the obligations related to high-risk AI systems laid down in Sections 1, 2 and 3 of Chapter III of Regulation (EU) 2024/1689, the delayed availability of standards, common specifications, and alternative guidance and the delayed establishment of national competent authorities lead to challenges that jeopardise the effective entry into application of those obligations and that risk a significant increase in implementation costs in a way that does not justify maintaining their initial date of application, namely 2 August 2026. Therefore, it is appropriate that the date of application of Sections 1, 2 and 3 of Chapter III is set to 2 December 2027 for AI systems classified as high-risk pursuant to Article 6(2) and Annex III, and to 2 August 2028 for AI systems classified as high-risk pursuant to Article 6(1) and Annex I. The distinction between the entry into application of the rules as regards AI systems classified as high-risk pursuant to Article 6(2) and Annex III and Article 6(1) and Annex I to that Regulation is consistent with the difference between the initial dates of application envisaged in Regulation (EU) 2024/1689 and aims to provide the necessary time for adaptation and implementation of the corresponding obligations. The timely availability of support instruments, including guidance, relevant standards, common specifications and codes of practice is important in order to facilitate compliance and reduce the risk of divergent interpretation and uneven application of the rules across Member States. In order to ensure legal certainty and to avoid further delays in the application of Regulation (EU) 2024/1689, the Commission should ensure that measures in support of compliance with regard to Chapter III, Sections 1, 2, and 3 of that Regulation are in place in due time to ensure timely and effective implementation of the necessary provisions.

(41) In light of the objective to reduce implementation challenges for citizens, businesses and public administrations, it is essential that harmonised conditions for the implementation of certain rules are adopted only where strictly necessary. For that purpose, it is appropriate to remove certain empowerments bestowed on the Commission to adopt such harmonised conditions by means of implementing acts in cases where that is not the case. Article 50(7), Article 56(6), and Article 72(3) of Regulation (EU) 2024/1689 should therefore be amended to remove the empowerments conferred on the Commission to adopt implementing acts. Given that the codes of practice referred to in Article 50(7) and Article 56(6) have limited legal effect, and in particular do not grant a presumption of conformity, it is not strictly necessary for these codes to be approved by an implementing act. Providers should be able to rely, pursuant to Article 53(4) and Article 54(2) of Regulation (EU) 2024/1689, on codes of practice assessed as adequate pursuant to Article 56(6) thereof. The removal of the empowerment to adopt a harmonised template for a post-market monitoring plan in Article 72(3) of Regulation (EU) 2024/1689 has the additional benefit of offering more flexibility for providers of high-risk AI systems to put in place a system for post-market monitoring that is tailored to their organisation. At the same time, recognising the need to offer clarity regarding how providers of high-risk AI systems are required to comply with their obligation set out in Article 72(1) of Regulation (EU) 2024/1689, the Commission should be required to publish guidance, including a voluntary template, on the post-market monitoring plan by 2 September 2027.

(42) The use of artificial intelligence in machinery can help foster innovation and improve the efficiency of those machines. The application of Regulation (EU) 2023/1230 of the European Parliament and of the Council ([18]) and Regulation (EU) 2024/1689 might lead to overlaps. At the same time, it is important to ensure a level of protection with regard to risks related to the use of artificial intelligence in machinery that is consistent with the level of protection provided in Regulation (EU) 2024/1689 with regard to high-risk AI systems. Given the specific nature of machinery and the machinery sector, and in order to address the need to simplify the regulatory framework for AI-enabled machinery, it is appropriate to move to a sectoral approach by moving Regulation (EU) 2023/1230 from Section A to Section B of Annex I to Regulation (EU) 2024/1689. Accordingly, first, the application of Regulation (EU) 2024/1689 to those machines should be limited to the provisions referred to in Article 2(2) of that Regulation. The reference to Directive 2006/42/EC should be moved from Section A to Section B of Annex I to Regulation (EU) 2024/1689 and updated so as to refer to Regulation (EU) 2023/1230. Second, it is crucial to ensure that Regulation (EU) 2023/1230 incorporates essential health and safety requirements for high-risk AI systems classified pursuant to Article 6(1) of Regulation (EU) 2024/1689 and used as a safety component in machinery or high-risk AI systems constituting machinery that ensure a level of protection consistent with Regulation (EU) 2024/1689. To that end, the Commission should be required to adopt delegated acts amending Annex III to Regulation (EU) 2023/1230 in order to reflect the relevant requirements set out in Chapter III, Section 2, and Articles 17, 19, 72 and 73 of Regulation (EU) 2024/1689. To avoid a legal gap and ensure alignment with the entry into application of the relevant high-risk AI system rules set out in Regulation (EU) 2024/1689, those delegated acts should apply by 2 August 2028. For the same reasons, manufacturers should be free to rely on harmonised standards or common specifications referenced or adopted pursuant to Regulation (EU) 2024/1689 that cover the relevant essential requirements for the presumption of conformity within the meaning of Article 20 of Regulation (EU) 2023/1230 until harmonised standards or common specifications regarding AI are referenced or adopted pursuant to Regulation (EU) 2023/1230.

(43) Conformity assessments of high-risk AI systems pursuant to Regulation (EU) 2024/1689 can require the involvement of conformity assessment bodies. Only conformity assessment bodies that have been designated pursuant to that Regulation are able to carry out conformity assessments, and only for the activities related to the categories and types of AI systems concerned. To enable the specification of the scope of the designation of conformity assessment bodies notified pursuant to Article 30 of Regulation (EU) 2024/1689, it is necessary to draw up a list of codes, categories, and corresponding types of AI systems. The list of codes should take into account whether the AI system is a component of a product or itself a product covered by the Union harmonisation legislation listed in Annex I to Regulation (EU) 2024/1689 (referred to as 'AIP codes', for AI systems covered by product legislation), or a system listed in Annex III to that Regulation, which currently concerns only biometric AI

([18]) Regulation (EU) 2023/1230 of the European Parliament and of the Council of 14 June 2023 on machinery and repealing Directive 2006/42/EC of the European Parliament and of the Council and Council Directive 73/361/EEC (OJ L 165, 29.6.2023, p. 1, ELI: http://data.europa.eu/eli/reg/2023/1230/oj).

systems referred to in point (1) of Annex III (referred to as 'AIB codes', for biometric AI systems). Both AIP codes and AIB codes are vertical codes. The AIP codes are reference codes that provide a link to the Union harmonisation legislation listed in Section A of Annex I to Regulation (EU) 2024/1689. The AIB codes are new codes specific to Regulation (EU) 2024/1689 that identify biometric AI systems referred to in point (1) of Annex III to that Regulation. The list of codes should also take into account specific types and underlying technologies of AI systems (referred to as 'AIH codes', for horizontal AI system codes). The AIH codes are new AI technology-specific codes and can be applied in conjunction with AIP or AIB vertical codes. The AIH codes cover the underlying types and technologies of AI systems. The list of codes, comprising three categories, should provide for a multi-dimensional typology of AI systems which ensures that conformity assessment bodies designated as notified bodies are fully competent in regard to the AI systems they are required to assess.

(44) Regulation (EU) 2018/1139 of the European Parliament and the Council ([19]) lays down common rules in the field of civil aviation. Article 108 of Regulation (EU) 2024/1689 amends Regulation (EU) 2018/1139 to ensure that the Commission, when adopting any relevant delegated or implementing acts pursuant to Regulation (EU) 2018/1139, takes into account, on the basis of the technical and regulatory specificities of the civil aviation sector, and without interfering with existing governance, conformity assessment and enforcement mechanisms and authorities established therein, the mandatory requirements for high-risk AI systems laid down in Regulation (EU) 2024/1689. A technical correction to amend additional Articles of Regulation (EU) 2018/1139 is necessary to ensure that the mandatory requirements for high-risk AI systems laid down in Regulation (EU) 2024/1689 are fully covered when adopting relevant delegated or implementing acts pursuant to Regulation (EU) 2018/1139.

(45) In order to amend certain non-essential elements of Regulations (EU) 2024/1689 and (EU) 2023/1230, the power to adopt acts in accordance with Article 290 of the Treaty on the Functioning of the European Union should be delegated to the Commission in respect of:

— limiting the application of specific requirements or obligations laid down in Regulation (EU) 2024/1689 where Union harmonisation legislation listed in Section A of Annex I of that Regulation lays down requirements providing for an equivalent level of protection,

— amending the list of codes, categories, and corresponding types of AI systems in Annex XIV of Regulation (EU) 2024/1689, and

— amending Annex III of Regulation (EU) 2023/1230 to reflect the relevant requirements of Regulation (EU) 2024/1689.

It is of particular importance that the Commission carry out appropriate consultations during its preparatory work, including at expert level, and that those consultations be conducted in accordance with the principles laid down in the Interinstitutional Agreement of 13 April 2016 on Better Law-Making ([20]). In particular, to ensure equal participation in the preparation of delegated acts, the European Parliament and the Council receive all documents at the same time as Member States' experts, and their experts systematically have access to meetings of Commission expert groups dealing with the preparation of delegated acts.

([19]) Regulation (EU) 2018/1139 of the European Parliament and of the Council of 4 July 2018 on common rules in the field of civil aviation and establishing a European Union Aviation Safety Agency, and amending Regulations (EC) No 2111/2005, (EC) No 1008/2008, (EU) No 996/2010, (EU) No 376/2014 and Directives 2014/30/EU and 2014/53/EU of the European Parliament and of the Council, and repealing Regulations (EC) No 552/2004 and (EC) No 216/2008 of the European Parliament and of the Council and Council Regulation (EEC) No 3922/91(OJ L 212, 22.8.2018, p. 1, ELI: http://data.europa.eu/eli/reg/2018/1139/oj).

([20]) OJ L 123, 12.5.2016, p. 1, ELI: http://data.europa.eu/eli/agree_interinstit/2016/512/oj.

(46) In order to ensure legal certainty without delay, with a view to the imminent general application of Regulation (EU) 2024/1689, this Regulation should enter into force as a matter of urgency on the third day following that of its publication in the *Official Journal of the European Union*.

(47) The European Data Protection Supervisor and the European Data Protection Board were consulted in accordance with Article 42(1) and (2) of Regulation (EU) 2018/1725 and delivered their joint opinion on 20 January 2026,

HAVE ADOPTED THIS REGULATION:

Article 1

Amendments to Regulation (EU) 2024/1689

Regulation (EU) 2024/1689 is amended as follows:

(1) in Article 1(2), point (g) is replaced by the following:

'(g) measures to support innovation, with a particular focus on small mid-cap enterprises (SMCs) and small and medium-sized enterprises (SMEs), including start-ups.';

(2) Article 2 is amended as follows:

(a) paragraph 2 is replaced by the following:

'2. For AI systems classified as high-risk AI systems in accordance with Article 6(1) related to products covered by the Union harmonisation legislation listed in Section B of Annex I, only Article 6(1), Article 60a and Articles 102 to 112 shall apply. Articles 57, 58 and 59 shall apply only in so far as the requirements for high-risk AI systems under this Regulation have been integrated in that Union harmonisation legislation.';

(b) paragraph 7 is replaced by the following:

'7. Union law on the protection of personal data, privacy and the confidentiality of communications applies to personal data processed in connection with the rights and obligations laid down in this Regulation. Without prejudice to Articles 4a and 59 of this Regulation, this Regulation shall not affect Regulation (EU) 2016/679 or (EU) 2018/1725, or Directive 2002/58/EC or (EU) 2016/680.';

(3) in Article 2, the following paragraph is added:

‘13. For high-risk AI systems referred to in Article 6(1), the application of specific requirements or obligations laid down in Articles 9 to 15 and 17 to 25 may be limited, where and to the extent that:

(a) Union harmonisation legislation listed in Section A of Annex I lays down requirements or obligations providing an equivalent or higher level of protection of health, safety or fundamental rights as the requirement or obligation concerned; and

(b) such limitation does not reduce the overall level of protection provided for by this Regulation.

By 2 August 2027, the Commission shall adopt delegated acts in accordance with Article 97 in order to supplement this Regulation by specifying the high-risk AI systems concerned, the requirements or obligations that may be limited, the conditions under which such limitation applies, and the scope of the limitation.’;

(4) Article 3 is amended as follows:

(a) point (14) is amended as follows:

‘(14) “safety component” means a component of a product or of an AI system which fulfils a safety function for that product or AI system, or the failure or malfunctioning of which endangers the health and safety of persons or property; for the purposes of this definition, a component fulfils a safety function where its intended purpose is to prevent or mitigate risks to health and safety of persons or property;’;

(b) the following points are inserted:

‘(14a) “micro, small and medium-sized enterprise” or “SME” means a micro, small or medium-sized enterprise as defined in Article 2 of the Annex to Recommendation 2003/361/EC;

(14b) “small mid-cap enterprise” or “SMC” means a small mid-cap enterprise as defined in point (2) of the Annex to Recommendation (EU) 2025/1099;’;

(5) Article 4 is replaced by the following:

‘*Article 4*

AI literacy

1. Providers and deployers of AI systems shall take measures to support the development of AI literacy of their staff and other persons dealing with the operation and use of AI systems on their behalf, taking into account their technical knowledge, experience, education and training and the context the AI systems are to be used in, and considering the persons or groups of persons on whom the AI systems are to be used. This obligation does not require providers or deployers to guarantee any specific level of AI literacy of any individual.

2. The Commission and the Member States shall support and facilitate the efforts of providers and deployers of AI systems, in particular SMEs, in fulfilling their obligation under paragraph 1 of this Article. For that purpose, the Commission shall publish practical examples of how to comply with that obligation on the single information platform referred to in Article 62(3), point (b).

3. The Board shall adopt recommendations, taking into account European competence frameworks, to support the Commission and Member States in the promotion of AI literacy required under paragraph 1, including by setting out common objectives.’;

(6) the following Article is inserted:

'*Article 4a*

Processing of special categories of personal data for bias detection and correction

1. To the extent strictly necessary to ensure bias detection and correction in relation to high-risk AI systems in accordance with Article 10(2), points (f) and (g), of this Regulation, providers of such systems may exceptionally process special categories of personal data, subject to appropriate safeguards for the fundamental rights and freedoms of natural persons. In addition to the provisions set out in Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680, as applicable, all the following conditions shall be met in order for such processing to occur:

(a) the bias detection and correction cannot be effectively fulfilled by processing other data, including synthetic or anonymised data;

(b) the special categories of personal data are subject to technical limitations on the re-use of personal data, and state-of-the-art security and privacy-preserving measures, including pseudonymisation;

(c) the special categories of personal data are subject to measures to ensure that the personal data processed are secured and protected, subject to suitable safeguards, including strict controls and documentation of the access, to avoid misuse and to ensure that only authorised persons have access to those personal data with appropriate confidentiality obligations;

(d) the special categories of personal data are not transmitted, transferred or otherwise accessed by other parties;

(e) the special categories of personal data are deleted once the bias has been corrected or the personal data has reached the end of its retention period, whichever comes first; and

(f) the records of processing activities pursuant to Regulations (EU) 2016/679 and (EU) 2018/1725 and Directive (EU) 2016/680 include the reasons why the processing of special categories of personal data was strictly necessary to detect and correct biases, and why that objective could not be achieved by processing other data.

2. Providers and deployers of other AI systems and models and deployers of high-risk AI systems may exceptionally process special categories of personal data to the extent that:

(a) such processing is strictly necessary to ensure bias detection and correction in view of possible biases that are likely to affect the health and safety of persons, have a negative impact on fundamental rights or lead to discrimination prohibited pursuant to Union law, especially where data outputs influence inputs for future operations; and

(b) all of the conditions and safeguards set out in paragraph 1 are applied.

This paragraph does not create any obligation to conduct such bias detection and correction.';

(7) Article 5 is amended as follows:

(a) in paragraph 1, the first subparagraph, the following points are inserted:

‘(ba) the placing on the market, the putting into service or the use of an AI system that generates or manipulates realistic images, videos, audio or similar material of an identifiable natural person’s intimate parts, or of an identifiable natural person engaged in sexually explicit activities, without that person’s freely-given, specific, informed, unambiguous and explicit consent for that generation or manipulation;

(bb) the placing on the market, the putting into service or the use of an AI system that generates or manipulates material or performance within the meaning of Article 2, points (c) and (e), of Directive 2011/93/EU, except where a “without right” defence applies under national law;’;

(b) the following paragraphs are inserted:

‘1a. For the purposes of paragraph 1, first subparagraph, points (ba) and (bb):

(a) the placing on the market or putting into service of an AI system that generates or manipulates the material or performance referred to in paragraph 1, first subparagraph, point (ba) or (bb) is only prohibited where:

(i) that generation or manipulation is the intended purpose of the AI system; or

(ii) the system’s design, training, architecture, capabilities or user-facing functionalities make that generation or manipulation a reasonably foreseeable and reproducible outcome, without requiring significant technical modification, and the system does not have reasonable and adequate technical safety measures and other safeguards to reliably prevent that generation or manipulation, taking into account reasonably foreseeable misuse, and to correct observed or reported misuse;

(b) the use of an AI system that generates or manipulates the material or performance referred to in paragraph 1, first subparagraph, points (ba) and (bb) is only prohibited where the deployer uses the system for the purpose of generating or manipulating such material or performance.

1b. For the purposes of paragraph 1, first subparagraph, point (ba), an AI system that manipulates material in a way that does not increase the exposure of any depicted intimate parts or alter the nature of any depicted sexually explicit activities shall not constitute manipulation.’;

(8) in Article 6, the following paragraphs are inserted:

‘1a. For the purposes of this Regulation, including paragraph 1 of this Article, AI systems that are solely used for non-safety related aspects of user assistance, performance optimisation, service efficiency, automation or convenience or quality control shall not qualify as safety components.

1b. Notwithstanding paragraph 1a, AI systems the failure or malfunctioning of which would endanger health and safety shall qualify as safety components.

1c. A product that is required to undergo a third-party conformity assessment solely due to risks other than risks to health and safety, in particular risks relating to the distribution of radio spectrum or electromagnetic interference that do not affect health and safety, shall not be considered as fulfilling the condition in paragraph 1, point (b).’;

(9) Article 10 is amended as follows:

(a) paragraph 1 is replaced by the following:

'1. High-risk AI systems which make use of techniques involving the training of AI models with data shall be developed on the basis of training, validation and testing data sets that meet the quality criteria referred to in paragraphs 2, 3 and 4 of this Article and in Article 4a(1) whenever such data sets are used.';

(b) paragraph 5 is deleted;

(c) paragraph 6 is replaced by the following:

'6. For the development of high-risk AI systems not using techniques involving the training of AI models, paragraphs 2, 3 and 4 of this Article and Article 4a(1) shall apply only to the testing data sets.';

(10) in Article 11(1), the second subparagraph is replaced by the following:

'That technical documentation shall be drawn up in such a way as to demonstrate that the high-risk AI system complies with the requirements set out in this Section and to provide national competent authorities and notified bodies with the necessary information in a clear and comprehensive form to assess the compliance of the AI system with those requirements. It shall contain, at a minimum, the elements set out in Annex IV. SMEs, including start-ups, and SMCs, may provide the elements of the technical documentation specified in Annex IV in a simplified manner. To that end, the Commission shall establish a simplified technical documentation form targeted at the needs of SMEs, including start-ups, and SMCs. Where an SME, including a start-up, or an SMC, opts to provide the information required in Annex IV in a simplified manner, it shall use the form referred to in this paragraph. Notified bodies shall accept the form for the purposes of the conformity assessment.';

(11) in Article 17, paragraph 2 is replaced by the following:

'2. The implementation of the aspects referred to in paragraph 1 shall be proportionate to the size of the provider's organisation, in particular, if the provider is an SME, including a start-up, or an SMC. Providers shall, in any event, respect the degree of rigour and the level of protection required to ensure the compliance of their high-risk AI systems with this Regulation.';

(12) Article 25 is amended as follows:

(a) paragraph 2 is replaced by the following:

'2. Where the circumstances referred to in paragraph 1 occur, the provider that initially placed the AI system on the market or put it into service shall no longer be considered to be a provider of that specific AI system for the purposes of this Regulation.

That initial provider shall closely cooperate with new providers and shall make available the necessary information and provide the reasonably expected technical access and other assistance that are required for the fulfilment of the obligations set out in this Regulation, in particular with regard to compliance with the conformity assessment of high-risk AI systems.

In particular, the obligation laid down in the second subparagraph shall include, where relevant for the purposes specified therein, the following:

(a) making available of technical documentation sufficient to assess compliance with the requirements laid down in Article 16;

(b) informing the new providers about known limitations and failure modes; and

(c) providing the new providers with targeted technical access, including for testing and validation.

This paragraph shall not apply in cases where the initial provider has clearly specified that its AI system is not to be changed into a high-risk AI system and therefore does not fall under the obligation to cooperate with the new providers and hand over the documentation.';

(b) in paragraph 4, the first subparagraph is replaced by the following:

'4. The provider of a high-risk AI system and the third party that supplies an AI system, AI model, tools, services, components, or processes that are used or integrated in a high-risk AI system shall, by written agreement, specify the necessary information, capabilities, technical access and other assistance based on the generally acknowledged state of the art, in order to enable the provider of the high-risk AI system to fully comply with the obligations set out in this Regulation. This paragraph shall not apply to third parties making accessible to the public tools, services, processes, or components, other than general-purpose AI models, under a free and open-source licence.';

(13) Article 27 is amended as follows:

(a) paragraph 4 is replaced by the following:

'4. If any of the obligations laid down in this Article is already met through the data protection impact assessment conducted pursuant to Article 35 of Regulation (EU) 2016/679 or Article 27 of Directive (EU) 2016/680, the deployer may, when conducting the fundamental rights impact assessment referred to in paragraph 1 of this Article, include cross-references to the relevant sections of that data protection impact assessment or include relevant parts thereof in the fundamental rights impact assessment.';

(b) paragraph 5 is replaced by the following:

'5. The AI Office shall develop a template for a questionnaire, including through an automated tool, to facilitate deployers in complying with their obligations under this Article in a simplified manner. This template shall, where relevant, give deployers the possibility to include cross-references to the relevant sections of the data protection impact assessment or include relevant parts thereof in the fundamental rights impact assessment pursuant to paragraph 4.';

(14) in Article 28, the following paragraphs are added:

'8. Notifying authorities designated pursuant to this Regulation that are responsible for AI systems covered by the Union harmonisation legislation listed in Section A of Annex I shall ensure that the conformity assessment body that applies for designation both pursuant to this Regulation and the Union harmonisation legislation listed in Section A of Annex I is provided with the possibility to submit a single application and undergoes a unified assessment procedure to be designated pursuant to this Regulation and Union harmonisation legislation listed in Section A of Annex I, where the relevant Union harmonisation legislation provides for such single application and unified assessment procedure. To that end, notifying authorities designated pursuant to this Regulation and those designated pursuant to the Union harmonisation legislation listed in Section A of Annex I shall cooperate in their assessments.

The single application and the unified assessment procedure referred to in this paragraph shall also be made available to notified bodies already designated pursuant to the Union harmonisation legislation listed in Section A of Annex I, when those notified bodies apply for designation pursuant to this Regulation, provided that the relevant Union harmonisation legislation provides for such a procedure.

A conformity assessment body that is designated pursuant to more than one piece of Union harmonisation legislation listed in Section A of Annex I shall have to apply only once to be designated pursuant to this Regulation. A designation pursuant to this Regulation shall be applicable for all Union harmonisation legislation listed in Section A of Annex I for which the conformity assessment body is designated.

The single application and the unified assessment procedure shall avoid any unnecessary duplications, build on the existing procedures for designation in accordance with the Union harmonisation legislation listed in Section A of Annex I and ensure compliance with the requirements relating to notified bodies both in accordance with this Regulation and the relevant Union harmonisation legislation.

9. A notifying authority that has been designated pursuant to the Union harmonisation legislation listed in Section A of Annex I is also the notifying authority for the application of the single application and unified assessment procedure referred to in paragraph 8, unless the Member State designates another notifying authority for this Regulation.';

(15) in Article 29, paragraph 4 is replaced by the following:

'4. For notified bodies which are designated pursuant to any other Union harmonisation legislation, all documents and certificates linked to those designations may be used to support and expedite their designation procedure under this Regulation, as appropriate.

Notified bodies, which are designated pursuant to any of the Union harmonisation legislation listed in Section A of Annex I and which undergo the unified assessment procedure referred to in Article 28(8), shall submit the single application for assessment to the notifying authority designated pursuant to that Union harmonisation legislation.

The notified body shall update the documentation referred to in paragraphs 2 and 3 of this Article whenever relevant changes occur, in order to enable the authority responsible for notified bodies to monitor and verify continuous compliance with all the requirements laid down in Article 31.';

(16) in Article 30, paragraph 2 is replaced by the following:

'2. Notifying authorities shall notify the Commission and the other Member States, based on the list of codes, categories, and corresponding types of AI systems referred to in Annex XIV, and using the electronic notification tool developed and managed by the Commission, of each conformity assessment body referred to in paragraph 1.

The Commission is empowered to adopt delegated acts in accordance with Article 97 in order to amend Annex XIV, in light of technical progress, advances in knowledge or new scientific evidence by adding to the list of codes, categories, and corresponding types of AI systems a new code, a category or a type of AI system, withdrawing an existing code, category or a type of AI system from that list or moving a code or type of AI system from one category to another.';

(17) in Article 40(2), the following subparagraph is added:

'The Commission shall request, in accordance with Regulation (EU) No 1025/2012 of the European Parliament and of the Council (*) and without undue delay, the European standardisation organisations to develop standardisation deliverables, including, as appropriate, harmonised standards, to facilitate the joint compliance and presumption of conformity with the requirements or obligations set out in Chapter III, Sections 2 and 3 of this Regulation, and the relevant requirements and obligations laid down in the Union harmonisation legislation listed in Annex I to this Regulation.';

(*) Regulation (EU) No 1025/2012 of the European Parliament and of the Council of 25 October 2012 on European standardisation, amending Council Directives 89/686/EEC and 93/15/EEC and Directives 94/9/EC, 94/25/EC, 95/16/EC, 97/23/EC, 98/34/EC, 2004/22/EC, 2007/23/EC, 2009/23/EC and 2009/105/EC of the European Parliament and of the Council and repealing Council Decision 87/95/EEC and Decision No 1673/2006/EC of the European Parliament and of the Council (OJ L 316, 14.11.2012, p. 12, ELI: http://data.europa.eu/eli/reg/2012/1025/oj).

(18) in Article 42, the following paragraph is added:

‘3. Where high-risk AI systems fall within the scope of Regulation (EU) 2024/2847 and the conditions laid down in Article 12(1) of that Regulation are fulfilled, such systems shall be deemed to comply with the cybersecurity requirements set out in Article 15 of this Regulation.’;

(19) in Article 43, paragraph 3 is replaced by the following:

‘3. For high-risk AI systems covered by the Union harmonisation legislation listed in Section A of Annex I, the provider of the system shall follow the relevant conformity assessment procedure as required in accordance with the relevant Union harmonisation legislation. The requirements set out in Section 2 of this Chapter shall apply to those high-risk AI systems and shall be part of that assessment. Assessment of the quality management system set out in Article 17 shall also be undertaken, and points 3, 4.3, 4.4. and 4.5, the fifth paragraph of point 4.6 and point 5 of Annex VII shall apply.

For the purposes of that conformity assessment, notified bodies which have been notified under the Union harmonisation legislation listed in Section A of Annex I shall have the power to assess the conformity of high-risk AI systems with the requirements set out in Section 2 of this Chapter, provided that the compliance of those notified bodies with the requirements laid down in Article 31(4), (5), (10) and (11) has been assessed in the context of the notification procedure in accordance with the relevant Union harmonisation legislation, which is evidenced through the assessment as part of the existing notification. Without prejudice to Article 28, such notified bodies which have been notified under the Union harmonisation legislation in Section A of Annex I, shall apply for designation in accordance with Section 4 of this Chapter by 28 January 2028.

Where Union harmonisation legislation listed in Section A of Annex I provides the product manufacturer with an option to rely on a conformity assessment that does not involve a third-party, provided that that manufacturer has applied harmonised standards to ensure compliance with all the relevant requirements, that manufacturer may use that option only if it has also applied harmonised standards or, where applicable, common specifications referred to in Article 41, covering all requirements set out in Section 2 of this Chapter. The classification of a product as a high-risk AI system in accordance with Article 6(1) does not affect the choice of the conformity assessment procedure provided to the manufacturers of products covered by Union harmonisation legislation listed in Section A of Annex I, including, where applicable, an option to rely on harmonised standards. The manufacturers of such products are not required to choose a conformity assessment procedure involving third-party conformity assessment only because the product includes a high-risk AI system as a safety component, if this is not required by the Union harmonisation legislation listed in Section A of Annex I.

Where a high-risk AI system is both covered by the Union harmonisation legislation listed in Section A of Annex I and it falls within one of the categories listed in Annex III, the provider of that system shall follow the relevant conformity assessment procedure as required pursuant to the relevant Union harmonisation legislation listed in Section A of Annex I.’;

(20) in Article 50, paragraph 7 is replaced by the following:

‘7. The Commission shall encourage and facilitate the drawing up of codes of practice at Union level to facilitate the effective implementation of the obligations regarding the detection, marking and labelling of artificially generated or manipulated content. The Commission, taking utmost account of the opinion of the Board, shall assess whether adherence to those codes of practice is adequate to ensure compliance with the obligations laid down in paragraphs 2 and 4 of this Article, in accordance with the procedure laid down in Article 56(6). If it deems the code of practice to be inadequate, the Commission may adopt an implementing act specifying common rules for the implementation of those obligations in accordance with the examination procedure laid down in Article 98(2).’;

(21) in Article 56, paragraph 6 is replaced by the following:

‘6. The Commission and the Board shall regularly monitor and evaluate the achievement of the objectives of the codes of practice by the participants and their contribution to the proper application of this Regulation. The Commission, taking utmost account of the opinion of the Board, shall assess whether the codes of practice cover the obligations provided for in Articles 53 and 55, and shall regularly monitor and evaluate the achievement of their objectives. The Commission shall publish its assessment of the adequacy of the codes of practice.’;

(22) Article 57 is amended as follows:

(a) in paragraph 1, the first subparagraph is replaced by the following:

‘1. Member States shall ensure that their competent authorities establish at least one AI regulatory sandbox at national level, which shall be operational by 2 August 2027. That sandbox may also be established jointly with the competent authorities of other Member States. The Commission may provide technical support, advice and tools for the establishment and operation of AI regulatory sandboxes.’;

(b) paragraph 3 is replaced by the following:

‘3. The European Data Protection Supervisor may establish an AI regulatory sandbox for Union institutions, bodies, offices and agencies. For this purpose, references to national competent authorities in this Chapter shall be construed as references to the European Data Protection Supervisor.’;

(c) the following paragraph is inserted:

‘3a. The AI Office may establish an AI regulatory sandbox at Union level for AI systems covered by Article 75(1). For this purpose, references to national competent authorities in this Chapter shall be construed, where relevant, as references to the AI Office. That AI regulatory sandbox shall be implemented in close cooperation with relevant competent authorities, in particular where compliance with Union legislation other than this Regulation is supervised in the AI regulatory sandbox, and shall provide priority access to SMEs, including start-ups, and SMCs.

The establishment of a Union level AI regulatory sandbox by the AI Office shall be without prejudice to the competences of Member States to establish and supervise AI regulatory sandboxes for AI systems under their supervision.’;

(d) paragraph 5 is replaced by the following:

‘5. AI regulatory sandboxes established under this Article shall provide for a controlled environment that fosters innovation and facilitates the development, training, testing and validation of innovative AI systems for a limited time before their being placed on the market or put into service pursuant to a specific sandbox plan agreed between the providers or prospective providers and the competent authorities, ensuring that appropriate safeguards are in place. Such sandboxes may include testing in real world conditions supervised therein. Where applicable, the sandbox plan shall incorporate the real-world testing plan referred to in Articles 60 and 60a.’;

(e) in paragraph 9, point (e) is replaced by the following:

‘(e) facilitating and accelerating access to the Union market for AI systems, in particular when provided by SMEs, including start-ups, and SMCs.’;

(f) paragraph 10 is replaced by the following:

‘10. National competent authorities shall ensure that, to the extent the innovative AI systems involve the processing of personal data or otherwise fall under the supervisory remit of other national authorities or competent authorities providing or supporting access to data, the competent data protection authorities and those other national or competent authorities are associated with the operation of the AI regulatory sandbox and involved in the supervision of those aspects to the extent of their respective tasks and powers.’;

(g) paragraph 14 is replaced by the following:

‘14. National competent authorities, the European Data Protection Supervisor and the AI Office, shall, as appropriate and within their respective competences, coordinate their activities and cooperate within the framework of the Board. They may support the joint establishment and operation of AI regulatory sandboxes, including in different sectors, and exchange best practices on related matters.’;

(23) in Article 58(1), the first subparagraph is amended as follows:

(a) the introductory part is replaced by the following:

‘1. In order to avoid fragmentation across the Union, the Commission shall adopt implementing acts specifying the detailed arrangements for the establishment, development, implementation, operation, governance, and supervision of the AI regulatory sandboxes. Those implementing acts shall include common principles on the following issues:’;

(b) the following point is added:

‘(d) the detailed rules applicable to the governance of AI regulatory sandboxes covered pursuant to Article 57, including as regards the involvement of and supervision by the competent data protection authorities, where relevant, and the coordination and cooperation at national and Union level.’;

(24) Article 60 is amended as follows:

(a) in paragraph 1, the first subparagraph is replaced by the following:

‘1. Testing of high-risk AI systems in real world conditions outside AI regulatory sandboxes may be conducted by providers or prospective providers of high-risk AI systems listed in Annex III or covered by Union harmonisation legislation listed in Section A of Annex I, in accordance with this Article and the real-world testing plan referred to in this Article, without prejudice to the prohibitions under Article 5.’;

(b) paragraph 2 is replaced by the following:

‘2. Providers or prospective providers may conduct testing of high-risk AI systems referred to in Annex III or covered by Union harmonisation legislation listed in Section A of Annex I in real world conditions at any time before the placing on the market or the putting into service of the high-risk AI system on their own or in partnership with one or more deployers or prospective deployers.’;

(25) the following Article is inserted:

'*Article 60a*

Testing of high-risk AI systems covered by Union harmonisation legislation listed in Section B of Annex I in real-world conditions outside AI regulatory sandboxes

1. Member States may allow, in accordance with this Article, the testing of high-risk AI systems in real world conditions outside AI regulatory sandboxes by providers or prospective providers of AI enabled products covered by the Union harmonisation legislation listed in Section B of Annex I, with a view to assessing and verifying the conformity of those systems with the requirements laid down in Articles 8 to 15.

2. Member States that choose to allow testing as referred to in paragraph 1 shall, individually or jointly, adopt frameworks for real-world testing.

3. Each Member State shall notify the Commission of any real-world testing framework it adopts before implementing it. This shall not affect the competences of the Commission under the Union harmonisation legislation listed in Section B of Annex I.

4. Member States that have adopted real-world testing frameworks shall ensure that the relevant national competent authorities, relevant authorities and public authorities responsible for the management and operation of infrastructure and products covered by Union harmonisation legislation listed in Section B of Annex I cooperate closely with each other in good faith and remove any practical obstacles, including on procedural rules providing access to physical public infrastructure, where this is necessary, to successfully implement those real-world testing frameworks and test AI-enabled products covered by Union harmonisation legislation listed in Section B of Annex I.

5. The frameworks for real-world testing shall lay down the requirements under which testing in real-world conditions shall occur. Those frameworks shall:

(a) include the provision of a mandatory real-world testing plan to be agreed between the provider or prospective provider and the national competent authority or relevant authority in accordance with the Union harmonisation legislation listed in Section B of Annex I;

(b) ensure compliance with the requirements laid down in Article 60(2), (3), (4)(d)-(j) and (5)-(9), where any reference to market surveillance authorities in those provisions shall be read as a reference to the national competent authority or relevant authority, as appropriate in accordance with the Union harmonisation legislation listed in Section B of Annex I;

(c) include effective governance and accountability arrangements;

(d) ensure a high level of protection of health safety and fundamental rights.

6. The real-world testing shall comply with the applicable provisions laid down in the Union harmonisation legislation listed in Section B of Annex I. Any requirements laid down in those provisions shall not affect the application of this Article to the extent necessary to enable the testing referred to in paragraph 1.';

(26) in Article 63, paragraph 1 is replaced by the following:

‘1. SMEs, including start-ups, may comply with certain elements of the quality management system required by Article 17 in a simplified manner, provided that they do not have partner enterprises or linked enterprises within the meaning of Recommendation 2003/361/EC. For that purpose, the Commission shall develop guidelines on the elements of the quality management system which may be complied with in a simplified manner considering the needs of SMEs, without affecting the level of protection or the need for compliance with the requirements in respect of high-risk AI systems.’;

(27) in Article 64, the following paragraph is added:

‘3. Without prejudice to the budgetary procedure, the AI Office shall be allocated adequate resources to effectively perform its duties and exercise its powers in relation to the enforcement of this Regulation.’;

(28) in Article 69, paragraph 2 is replaced by the following:

‘2. The Member States may be required to pay fees for the advice and support provided by the experts at a rate equivalent to the remuneration fees applicable to the Commission pursuant to the implementing act referred to in Article 68(1).’;

(29) in Article 70, paragraph 8 is replaced by the following:

‘8. National competent authorities may provide guidance and advice on the implementation of this Regulation, in particular to SMEs, including start-ups, and SMCs, taking into account the guidance and advice of the Board and the Commission, as appropriate. Whenever national competent authorities intend to provide guidance and advice with regard to an AI system in areas covered by other Union law, the national competent authorities under that Union law shall be consulted, as appropriate.’;

(30) in Article 72, paragraph 3 is replaced by the following:

‘3. The post-market monitoring system shall be based on a post-market monitoring plan. The post-market monitoring plan shall be part of the technical documentation referred to in Annex IV. The Commission, taking utmost account of the opinion of the Board, shall adopt guidance, including a template, on the post-market monitoring plan by 2 September 2027.’;

(31) Article 75 is amended as follows:

(a) the heading is replaced by the following:

‘Market surveillance and control of AI systems and mutual assistance’;

(b) paragraph 1 is replaced by the following:

‘1. The AI Office shall be exclusively competent for the supervision and enforcement of the obligations under this Regulation in relation to the following AI systems:

(a) AI systems based on general-purpose AI models where the model and the system are developed by the same provider, or by providers forming part of the same undertaking as that provider, with the exception of:

(i) AI systems related to products covered by the Union harmonisation legislation listed in Annex I;

(ii) AI systems referred to in point 2 of Annex III;

(iii) AI systems provided by law enforcement authorities, border management authorities and financial institutions, insofar as those AI systems fall under Article 74(6); and

(iv) AI systems referred to in point 8 of Annex III as regards the administration of justice;

(b) AI systems that constitute or that are integrated into a very large online platform or very large online search engine designated in accordance with Regulation (EU) 2022/2065.

The exclusive competence referred to in the first subparagraph shall apply to the providers of those systems. It shall apply to the deployers of those systems only when they are also the provider or form part of the same undertaking as the provider.';

(c) the following paragraphs are inserted:

'1a. By way of derogation from Article 73, providers of high-risk AI systems subject to the competence of the AI Office pursuant to paragraph 1 of this Article shall report any serious incidents to the AI Office. Article 73 (2) to (9), shall apply *mutatis mutandis*. The AI Office shall promptly transmit the relevant information to the market surveillance authority of the Member State in the territory of which the provider or its legal representative is situated.

1b. The authorities involved in the application of this Regulation shall cooperate actively with the AI Office and provide the AI Office the necessary assistance for the exercise of its powers, including, where necessary, in connection with inspections or other enforcement measures carried out in the territory of a Member State. To that end, those authorities shall enjoy the powers provided for pursuant to this Regulation and Regulation (EU) 2019/1020, and where relevant and limited to what is necessary to fulfil their tasks under this paragraph, in accordance with the applicable national procedures.

1c. When taking investigatory or enforcement action in the territory of a Member State that involves access to a public authority's data or AI system, the AI Office shall be assisted by the relevant market surveillance authority.

1d. Before taking a decision that would have the effect of prohibiting or restricting the AI system being made available or put into service on a national market, or a decision to withdraw or recall the AI system from such market, the AI Office shall, without undue delay, notify the market surveillance authority competent for that market of its intention to take such a decision. The AI Office shall consult the authorities involved in the application of this Regulation, where appropriate, on any matter relating to the application and enforcement of this Regulation.

1e. The AI Office shall be responsible for conformity assessments and tests of AI systems referred to in paragraph 1 of this Article that are classified as high-risk and subject to a third-party conformity assessment pursuant to Article 43 before such AI systems are placed on the market or put into service. Those tests and assessments shall verify that the systems comply with the relevant requirements of this Regulation and may be placed on the market or put into service in the Union in accordance with this Regulation. The Commission shall entrust the performance of those tests or assessments to notified bodies designated in accordance with this Regulation, in which case the notified body shall act on behalf of the Commission. If a notified body to which the Commission has delegated tasks under this paragraph does not perform those tasks adequately, the Commission may withdraw the delegation with immediate effect.

The fees for testing and assessment activities shall be levied on the provider of a high-risk AI system who has applied for a third-party conformity assessment to the Commission. The provider shall pay the costs related to the services entrusted by the Commission to the notified bodies in accordance with this Article directly to the notified body.';

(d) the following paragraph is inserted:

'2a. Where a market surveillance authority has well-founded and sufficient reasons to suspect that a provider or a deployer of an AI system referred to in paragraph 1 of this Article has infringed this Regulation, it may request, through the relevant single point of contact designated in accordance with Article 70(2), the AI Office to assess the matter in order to take the necessary supervisory and enforcement measures to ensure prompt compliance with this Regulation. Such a request shall be duly reasoned and shall include at least:

(a) the name of the provider or the deployer concerned;

(b) a description of the relevant facts, the provisions of this Regulation that have allegedly been infringed, and any well-founded and sufficient reasons for suspecting an infringement, including, where applicable, the description of the negative effects of the alleged infringement;

(c) the market surveillance authority making the request.

The AI Office shall take utmost account of the request and the market surveillance authority shall cooperate actively and provide the AI Office the necessary assistance for the exercise of its powers in accordance with paragraph 1a.

The AI Office shall, without undue delay and in any event no later than four months following receipt of the request, inform the single point of contact of its intention to exercise its powers in accordance with Article 75a or of its reasons for not exercising its powers. If the AI Office decides to exercise its powers in accordance with Article 75a, it shall periodically inform that single point of contact about major developments in the proceedings and the outcome of such proceedings, without disclosing any confidential information.';

(32) the following articles are inserted:

'*Article 75a*

Supervisory and enforcement powers of the AI Office

1. When exercising its tasks of supervision and enforcement laid down in Article 75(1) of this Regulation, the AI Office shall have all the powers of a market surveillance authority provided for in this Section and in Article 14(4) and Article 16(3) of Regulation (EU) 2019/1020. The AI Office shall be authorised to fully reclaim from the relevant operator the totality of the costs of its supervision and enforcement activities with respect to instances of non-compliance, including costs for human and technical resources, in accordance with Article 15 of Regulation (EU) 2019/1020. Article 17 of Regulation (EU) 2019/1020 shall apply *mutatis mutandis*.

2. Where the AI Office has reasonable grounds to suspect non-compliance with this Regulation by a provider or a deployer of an AI system referred to in Article 75(1) of this Regulation, it may adopt a decision to start an investigation into that non-compliance in accordance with Article 14(4), point (f) of Regulation (EU) 2019/1020. Upon starting such an investigation, the AI Office shall notify the operator of the AI system concerned. The AI Office may exercise the powers referred to in paragraph 1 of this Article on its own initiative or following a complaint received pursuant to Article 85 of this Regulation, even before starting an investigation pursuant to Article 14(4), point (f) of Regulation (EU) 2019/1020.

Where a market surveillance authority has reason to suspect non-compliance with this Regulation by a provider or a deployer of an AI system referred to in Article 75(1), it may send a request to the AI Office to assess the matter.

3. The AI Office may exercise the powers listed in Article 14(4), points (a), (b) and (c) of Regulation (EU) 2019/1020 and Article 74(12) and (13) of this Regulation by simple request or by decision.

When requesting information, the AI Office shall state the legal basis and the purpose of the request, specify what information is required, and set the period within which the information is to be provided. Where the request is a simple request, the AI Office shall additionally indicate that although there is no obligation to provide the information requested, in the case of a voluntary reply, the information must be correct and not misleading, and indicate the potential fines provided for in Article 99(5) for supplying incorrect or misleading information. Where the request is made by decision, the AI Office shall additionally indicate the fines provided for in Article 99(5) for supplying incorrect, incomplete or misleading information and indicate the right to have the decision reviewed by the Court of Justice of the European Union. The AI Office shall send a copy of the request to the market surveillance authority of the Member State in the territory of which the operator or its legal representative is situated.

4. In order to carry out the tasks assigned to it under this Section, the AI Office may conduct all necessary remote or on-site inspections pursuant to the powers laid down in Article 14(4), points (d) and (e) of Regulation (EU) 2019/1020 and Article 74(5) of this Regulation. When conducting an inspection, the AI Office shall inform the provider concerned of the subject matter and purpose of the investigation, the relevant fines referred to in Article 99(5) of this Regulation, and the right to have the decision reviewed by the Court of Justice of the European Union. Prior to conducting an inspection, the AI Office shall inform the market surveillance authority of the Member State in the territory of which the operator or its legal representative is situated.

During such an inspection, the officials of the AI Office shall be empowered to:

(a) enter any of the business premises, land or property located in the Union of the operator concerned;

(b) examine the books, data and other material relevant to the execution of their tasks, irrespective of the medium on which they are stored;

(c) take or obtain in any form copies of or extracts from books, data and other records;

(d) ask any of the persons subject to the inspection, or their representatives, or staff, for oral or written explanations on factors or documents relating to the subject matter and purpose of the inspection, and to record the answers;

(e) seal any business premises and books or records for the duration of, and to the extent necessary for, the inspection.

Where the AI Office finds that a natural or legal person opposes or obstructs an inspection, the national competent authority of the Member State concerned shall afford it the necessary assistance, requesting, where appropriate, the assistance of the police or an equivalent enforcement authority, to enable it to conduct its on-site inspection.

Where an on-site inspection of business premises, land or property requires authorisation by a judicial authority in accordance with national law, the AI Office shall apply for such an authorisation. The AI Office may also apply for such authorisation as a precautionary measure. Where such an authorisation is applied for, the national judicial authority shall promptly verify that the coercive measures envisaged are neither arbitrary nor excessive having regard to the subject matter of the investigation or inspection and the documents provided by the AI Office with the decision. In its verification of the proportionality of coercive measures, the national judicial authority may ask the AI Office for detailed explanations, in particular relating to the grounds the AI Office has for suspecting that an infringement of this Regulation has taken place and the seriousness of the suspected infringement and, where relevant, the nature of the involvement of the person subject to the coercive measures. The national judicial authority shall not review the necessity of the investigation or inspection nor demand information from the case file of the AI Office. In accordance with the Treaties, the legality of the decision of the AI Office is subject to review only by the Court of Justice of the European Union.

5. At the request of the AI Office, the competent market surveillance authority of a Member State may in its own territory carry out any investigation, inspection or other fact-finding measure on behalf and for the account of the AI Office in order to establish whether there has been an infringement of this Regulation. The officials of the competent authorities of the Member States who are responsible for conducting such investigations, inspections, or fact-finding measures, as well as those authorised or appointed by them, shall exercise their powers in accordance with their national law.

6. In addition to the powers set out in paragraph 1 of this Article, the AI Office, in the exercise of its competences referred to in Article 75(1), may:

(a) order operators to provide access to, and explanations relating to, their AI systems;

(b) impose an obligation on an operator to retain all data and documents deemed to be necessary to assess the implementation of and compliance with the obligations under this Regulation.

7. To assist it in monitoring the effective implementation and compliance with the relevant provisions of this Regulation and to provide it with specific expertise or knowledge in the exercise of its competences under Article 75(1), the AI Office may appoint independent external experts and auditors, as well as experts, investigative teams and auditors from the Member State's competent authorities with the agreement of the authority concerned. Information obtained as a result of such monitoring actions shall be shared with the relevant competent authorities of the Member States.

8. Information collected pursuant to this Article shall be used only for the purpose of this Regulation.

Article 75b

Commitments

If, during proceedings under Article 75a(2), the operator concerned offers commitments to ensure compliance with the relevant provisions of this Regulation, the AI Office may, by decision, make those commitments binding on the operator concerned and declare that there are no further grounds for action. The AI Office may, upon request or on its own initiative, reopen the proceedings where:

(a) there has been a material change in any of the facts on which the decision was based;

(b) the operator acts contrary to its commitments; or

(c) the decision was based on incomplete, incorrect or misleading information provided by the operator concerned.

Where the AI Office considers that the commitments offered by the operator concerned are unable to ensure effective compliance with the relevant provisions of this Regulation, it shall reject those commitments in a reasoned decision when concluding the proceedings.

Article 75c

Non-compliance, fines and periodic penalty payments

1. Where the AI Office finds that an operator falling within the scope of Article 75(1) does not comply with the relevant provisions of this Regulation or with commitments made binding pursuant to Article 75b, it shall adopt a decision establishing such non-compliance.

2. Before adopting a decision pursuant to paragraph 1, the AI Office shall communicate its preliminary findings to the operator concerned. In the preliminary findings, the AI Office shall explain the measures that it is considering taking, or that it considers that the operator concerned should take, in order to effectively address the preliminary findings.

3. In the decision pursuant to paragraph 1 of this Article, the AI Office shall, where relevant, order the operator concerned to take the necessary measures to ensure compliance with the relevant provisions of this Regulation within a reasonable period specified therein and to provide information on the measures that that operator intends to take to comply with the decision. The operator concerned shall provide the AI Office with a description of the measures it has taken to ensure compliance with the decision upon their implementation. Prior to requesting any measure, the AI Office may engage in a structured dialogue with the operator of the AI system in question. During this dialogue, the operator may propose commitments in accordance with Article 75b.

4. A decision adopted pursuant to paragraph 1 of this Article may be accompanied by the imposition of penalties in accordance with Article 99(3) to (7), which provisions shall apply *mutatis mutandis* to the AI Office in the execution of its supervision and enforcement tasks referred to in Article 75(1).

In particular, the following shall be subject to administrative fines as referred to in Article 99(4):

(a) infringement of any applicable provision of this Regulation, including those not listed in Article 99(4);

(b) failure to comply with decisions or measures adopted pursuant to the powers listed in Article 14(4) or Article 16(3) of Regulation (EU) 2019/1020, as well as those specified in Article 75a of this Regulation;

(c) failure to comply with a commitment made binding by a decision pursuant to Article 75b.

The supply of incorrect, incomplete or misleading information to the AI Office in reply to a request shall be subject to administrative fines as referred to in Article 99(5).

5. The AI Office may adopt a decision imposing periodic penalty payments to compel the operators subject to its competence pursuant to Article 75(1) to the following:

(a) to submit to an investigation;

(b) to comply with an information request ordered by a decision adopted under Article 75a(3);

(c) to submit to an inspection ordered by a decision pursuant to Article 75a(4);

(d) to provide correct or complete answers or explanations in the context of an inspection ordered by a decision pursuant to Article 75a(4);

(e) to comply with corrective actions ordered pursuant to the power listed in Article 16 of Regulation (EU) 2019/1020;

(f) to comply with commitments made legally binding by a decision pursuant to Article 75b; or

(g) to comply with a decision pursuant to the paragraph (1) of this Article.

Those penalty payments shall be effective and proportionate, and, where applicable, shall not exceed 5 % of the average daily income or worldwide annual turnover in the preceding financial year per day, calculated from the date appointed by the decision.

6. The Court of Justice of the European Union shall have unlimited jurisdiction to review decisions of the AI Office fixing a fine or periodic penalty payment pursuant to this Article. It may cancel, reduce or increase the fine or periodic penalty payment imposed.

7. Funds collected through the imposition of fines or periodic penalty payments pursuant to this Article shall contribute to the general budget of the Union.

8. The powers conferred on the AI Office by this Article shall be subject to a limitation period of five years. The limitation period shall begin to run on the day on which the infringement is committed. However, in the case of continuing or repeated infringements, the limitation period shall begin to run on the day on which the infringement ceases.

The power of the AI Office to enforce decisions taken pursuant to this Article shall be subject to a limitation period of five years. The limitation period shall begin to run on the day on which the decision becomes final.

The implementing act referred to in Article 75d(3) shall specify the first and second subparagraphs of this paragraph, including the circumstances in which the limitation periods shall be interrupted.

9. Where the AI Office determines that there are no grounds to adopt a decision of non-compliance, it shall close the proceeding by a decision. That decision shall apply with immediate effect.

Article 75d

Safeguards and further specification

1. Article 18 of Regulation (EU) 2019/1020 shall apply *mutatis mutandis* to operators subject to the AI Office's competence pursuant to Article 75(1) of this Regulation, without prejudice to more specific procedural rights provided for in this Regulation.

2. The rights of defence and of access to the file of operators falling within the scope of Article 75(1) shall be fully respected in proceedings. In view of the possible adoption of decisions on the basis of Article 75c(1), those operators shall be entitled to have access to the AI Office file under the terms of a negotiated disclosure, subject to the legitimate interest of the operator or other person concerned in the protection of their business secrets. The AI Office shall have the power to adopt decisions setting out such terms of disclosure in the case of disagreement between the parties. The right of access to the file shall not extend to confidential information and internal documents of the AI Office, the Board, competent market surveillance authorities or other public authorities of the Member States. In particular, the right of access shall not extend to correspondence between the AI Office and those authorities. Nothing in this paragraph shall prevent the AI Office from disclosing and using information necessary to prove an infringement.

3. The Commission may adopt implementing acts concerning the practical arrangements for access to the file and the negotiated disclosure of information provided for in paragraph 2.

4. The AI Office shall publish the decisions it adopts pursuant to Articles 75b and 75c. Such publication shall state the names of the parties and the main content of the decision, including any penalties imposed. The publication shall have regard to the rights and legitimate interests of any person concerned in the protection of their confidential information.';

(33) in Article 76(1), the following subparagraph is added:

'Where testing in real world conditions is based on Article 60a, any reference to a market surveillance authority in this Article shall be construed as a reference to the national competent authority or appropriate authority under the Union harmonisation legislation listed in Section B of Annex I, and references to Article 60 shall be construed as references to Article 60a, as appropriate.';

(34) Article 77 is amended as follows:

(a) the heading is replaced by the following:

'Powers of authorities protecting fundamental rights and cooperation with market surveillance authorities';

(b) paragraph 1 is replaced by the following:

'1. National public authorities or bodies which supervise or enforce the respect of obligations under Union law protecting fundamental rights, including the right to non-discrimination, shall have the power to request and access any information or documentation created or maintained from the relevant market surveillance authority pursuant to this Regulation in accessible language and machine-readable format by electronic means where access to that information or documentation is necessary for effectively fulfilling their mandates within the limits of their jurisdiction. This Article is without prejudice to the competences, tasks, powers and independence of the relevant national public authorities or bodies under their mandates.';

(c) the following paragraphs are inserted:

'1a. Subject to the conditions specified in this Article, the market surveillance authority shall grant the relevant public authority or body referred to in paragraph 1 access to such information or documentation, including by requesting such information or documentation from the provider or the deployer, where necessary and without undue delay.

1b. Market surveillance authorities and public authorities or bodies referred to in paragraph 1 shall cooperate closely and provide each other with the mutual assistance necessary to fulfil their respective mandates, with a view to ensuring the coherent application of this Regulation and Union law protecting fundamental rights and streamlining procedures, while respecting their respective competences, tasks, powers and independence. This shall include, in particular, exchange of information where necessary for the effective supervision or enforcement of this Regulation and the respective other Union legislation.';

(35) in Article 95, paragraph 4 is replaced by the following:

'4. The AI Office and the Member States shall take into account the specific interests and needs of SMEs, including start-ups, and SMCs, when encouraging and facilitating the drawing up of codes of conduct.';

(36) in Article 96, paragraph 1 is amended as follows:

(a) in the first subparagraph, point (a) is replaced by the following:

'(a) the application of the requirements and obligations referred to in Articles 8 to 15 and in Articles 25 and 26;';

(b) in the first subparagraph, the following point is added:

'(g) the practical implementation of Article 8(2), Article 9(10) and Article 17(3) in accordance with the principle of complementarity and proportionality, with a view to ensuring consistency, avoiding duplication and minimising additional burdens when complying with the requirements of this Regulation and the requirements of the Union harmonisation legislation listed in Section A of Annex I; such guidelines shall be published by 1 August 2027.';

(c) the second subparagraph is replaced by the following:

'When issuing such guidelines, the Commission shall involve the Board and pay particular attention to the needs of SMEs, including start-ups, and SMCs, of local public authorities and of the sectors most likely to be affected by this Regulation.';

(37) Article 97 is amended as follows:

(a) paragraphs 2 and 3 are replaced by the following:

'2. The power to adopt delegated acts referred to in Article 6(6) and (7), Article 7(1) and (3), Article 11(3), Article 43(5) and (6), Article 47(5), Article 51(3), Article 52(4) and Article 53(5) and (6) shall be conferred on the Commission for a period of five years from 1 August 2024. The power to adopt delegated acts referred to in Article 2(13) and Article 30(2) shall be conferred on the Commission for a period of five years from 27 July 2026. The Commission shall draw up a report in respect of the delegation of power not later than nine months before the end of the five-year period. The delegation of power shall be tacitly extended for periods of an identical duration, unless the European Parliament or the Council opposes such extension no later than three months before the end of each period.

3. The delegation of power referred to in Article 2(13), Article 6(6) and (7), Article 7(1) and (3), Article 11(3), Article 30(2), Article 43(5) and (6), Article 47(5), Article 51(3), Article 52(4) and Article 53(5) and (6) may be revoked at any time by the European Parliament or by the Council. A decision of revocation shall put an end to the delegation of power specified in that decision. It shall take effect the day following that of its publication in the *Official Journal of the European Union* or at a later date specified therein. It shall not affect the validity of any delegated acts already in force.';

(b) paragraph 6 is replaced by the following:

'6. Any delegated act adopted pursuant to Article 2(13), Article 6(6) or (7), Article 7(1) or (3), Article 11(3), Article 30(2), Article 43(5) or (6), Article 47(5), Article 51(3), Article 52(4) or Article 53(5) or (6) shall enter into force only if no objection has been expressed by either the European Parliament or the Council within a period of three months of notification of that act to the European Parliament and the Council or if, before the expiry of that period, the European Parliament and the Council have both informed the Commission that they will not object. That period shall be extended by three months at the initiative of the European Parliament or of the Council.';

(38) Article 99 is amended as follows:

(a) paragraph 1 is replaced by the following:

‘1. In accordance with the terms and conditions laid down in this Regulation, Member States shall lay down the rules on penalties and other enforcement measures, which may also include administrative fines, warnings and non-monetary measures, applicable to any infringement of this Regulation by operators, and shall take all measures necessary to ensure that they are properly and effectively implemented, thereby taking into account the guidelines issued by the Commission pursuant to Article 96. The penalties provided for shall be effective, proportionate and dissuasive. The Member States shall take into account the interests of SMEs, including start-ups, and SMCs, and their economic viability when imposing penalties.’;

(b) in paragraph 4, the following point is inserted:

‘(da) obligations of providers and operators pursuant to Article 25(2) and (4)’;

(c) the following paragraph is inserted:

‘6a. In the case of SMCs, each fine referred to in paragraphs 4 and 5 shall be up to the percentages or amount referred therein, whichever is lower.’;

(39) Article 111 is amended as follows:

(a) paragraph 2 is replaced by the following:

‘2. Without prejudice to the application of Article 5 as referred to in Article 113, third paragraph, point (a), this Regulation shall apply to operators of high-risk AI systems, other than the systems referred to in paragraph 1 of this Article, that have been placed on the market or put into service before the date of application of Chapter III referred to in Article 113, only if, as from that date, those systems are subject to significant changes in their designs. In any case, the providers and deployers of high-risk AI systems intended to be used by public authorities shall take the necessary steps to comply with the requirements and obligations laid down in this Regulation by 2 August 2030.’;

(b) the following paragraph is added:

‘4. Providers of AI systems, including general-purpose AI systems, generating synthetic audio, image, video or text content, that have been placed on the market before 2 August 2026 shall take the necessary steps in order to comply with Article 50(2) by 2 December 2026.’;

(40) in Article 113, the third paragraph is amended as follows:

(a) point (a) is replaced by the following:

‘(a) Chapters I and II shall apply from 2 February 2025, with the exception of Article 5(1), first subparagraph, points (ba) and (bb), and Article 5(1a) and (1b) which shall apply from 2 December 2026;’;

(b) point (c) is replaced by the following:

‘(c) Chapter III, Sections 1, 2, and 3, with the exception of Article 6(5), shall apply from:

(i) 2 December 2027 as regards AI systems classified as high-risk pursuant to Article 6(2) and Annex III; and

(ii) 2 August 2028 as regards AI systems classified as high-risk pursuant to Article 6(1) and Annex I;’;

(c) the following point is added:

‘(d) Articles 102 to 110 shall apply from 27 July 2026.’;

(41) Annex I is amended as follows:

(a) in Section A, point 1 is deleted;

(b) in Section B, the following point is added:

'21. Regulation (EU) 2023/1230 of the European Parliament and of the Council of 14 June 2023 on machinery and repealing Directive 2006/42/EC of the European Parliament and of the Council and Council Directive 73/361/EEC (OJ L 165, 29.6.2023, p. 1, ELI: http://data.europa.eu/eli/reg/2023/1230/oj).';

(42) in Annex VIII, section B, points 7 and 9 are deleted;

(43) the following Annex is added:

'Annex XIV

The list of codes, categories and corresponding types of AI systems for the purpose of the notification procedure referred to in Article 30 specifying the scope of the designation as notified bodies

1. Introduction

Conformity assessment of high-risk AI systems pursuant to this Regulation may require the involvement of conformity assessment bodies. Only conformity assessment bodies that have been designated in accordance with this Regulation may carry out conformity assessments and only for the activities related to the types of AI systems concerned. The list of codes, categories, and corresponding types of AI systems sets the scope of the designation of conformity assessment bodies notified under Article 30.

2. List of Codes, categories, and corresponding AI systems

a. AI systems subject to Annex I

AIA Code	
AIP 0102	AI systems subject to point 2 of Section A of Annex I
AIP 0103	AI systems subject to point 3 of Section A of Annex I
AIP 0104	AI systems subject to point 4 of Section A of Annex I
AIP 0105	AI systems subject to point 5 of Section A of Annex I
AIP 0106	AI systems subject to point 6 of Section A of Annex I
AIP 0107	AI systems subject to point 7 of Section A of Annex I
AIP 0108	AI systems subject to point 8 of Section A of Annex I

AIA Code	
AIP 0109	AI systems subject to point 9 of Section A of Annex I
AIP 0110	AI systems subject to point 10 of Section A of Annex I
AIP 0111	AI systems subject to point 11 of Section A of Annex I
AIP 0112	AI systems subject to point 12 of Section A of Annex I

b. AI systems subject to point 1 of Annex III

AIA Code	
AIB 0201	Remote biometric identification systems
AIB 0202	Biometric categorisation AI systems
AIB 0203	Emotion recognition AI systems

3. AI technology-specific codes

a. Symbolic AI and expert systems

AIA Code	
AIH 0101	AI systems based on symbolic AI, expert and knowledge-based systems, and AI systems based on search and optimisation

b. Machine learning, excluding generative AI and general-purpose AI systems

AIA Code	
AIH 0201	AI systems that process structured data
AIH 0202	AI systems that process signal and audio data
AIH 0203	AI systems that process text data
AIH 0204	AI systems that process image and video
AIH 0205	AI systems that learn from their environment, excluding AI systems covered under AIH 0401

c. AI systems based on general-purpose AI models or generative AI

AIA Code	
AIH 0301	generative AI systems, including AI systems based on general-purpose AI models

d. Emerging AI technologies

AIA Code	
AIH 0401	AI systems based on other emerging AI technologies not covered by other codes, including Agentic AI

4. Application for designation

Conformity assessment bodies shall use the lists of codes, categories and corresponding types of AI systems set out in this Annex when specifying the types of AI systems in the application for designation referred to in Article 29.'.

Article 2

Amendments to Regulation (EU) 2018/1139

Regulation (EU) 2018/1139 is amended as follows:

(1) in Article 27, the following paragraph is added:

'3. Without prejudice to paragraph 2, when adopting implementing acts pursuant to paragraph 1 concerning Artificial Intelligence (AI) systems which are safety components within the meaning of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*), the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).';

(2) in Article 31, the following paragraph is added:

'3. Without prejudice to paragraph 2, when adopting implementing acts pursuant to paragraph 1 concerning AI systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.';

(3) in Article 32, the following paragraph is added:

‘3. When adopting delegated acts pursuant to paragraph 1 concerning AI systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’;

(4) in Article 36, the following paragraph is added:

‘3. Without prejudice to paragraph 2, when adopting implementing acts pursuant to paragraph 1 concerning AI systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’;

(5) in Article 39 the following paragraph is added:

‘3. When adopting delegated acts pursuant to paragraph 1 concerning AI systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’;

(6) in Article 50, the following paragraph is added:

‘3. Without prejudice to paragraph 2, when adopting implementing acts pursuant to paragraph 1 concerning AI systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’;

(7) in Article 53, the following paragraph is added:

‘3. Without prejudice to paragraph 2, when adopting implementing acts pursuant to paragraph 1 concerning AI systems which are safety components within the meaning of Regulation (EU) 2024/1689, the requirements set out in Chapter III, Section 2, of that Regulation shall be taken into account.’

Article 3

Amendments to Regulation (EU) 2023/1230

Regulation (EU) 2023/1230 is amended as follows:

(1) in Article 8, the following paragraphs are added:

‘The Commission shall adopt delegated acts in accordance with Article 47 of this Regulation to amend Annex III to this Regulation by adding health and safety requirements in respect of Artificial Intelligence (AI) systems that are classified as high-risk pursuant to Article 6(1) of Regulation (EU) 2024/1689 of the European Parliament and of the Council (*) due to the fact that they are a safety component in a product covered by this Regulation, or they are themselves a product covered by this Regulation. Those requirements shall ensure that the relevant requirements set out in Chapter III, Section 2, and Articles 17, 19, 72 and 73 of Regulation (EU) 2024/1689 are reflected.

When adopting the delegated acts referred to in the third paragraph, the Commission shall take into account the objectives of Regulation (EU) 2024/1689 and ensure a level of protection consistent with that Regulation. Those delegated acts shall apply by 2 August 2028.

(*) Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence and amending Regulations (EC) No 300/2008, (EU) No 167/2013, (EU) No 168/2013, (EU) 2018/858, (EU) 2018/1139 and (EU) 2019/2144 and Directives 2014/90/EU, (EU) 2016/797 and (EU) 2020/1828 (Artificial Intelligence Act) (OJ L, 2024/1689, 12.7.2024, ELI: http://data.europa.eu/eli/reg/2024/1689/oj).';

(2) in Article 20, the following paragraph is added:

'10. Until harmonised standards or common specifications are referenced or adopted pursuant to this Article as regards high-risk AI systems, high-risk AI systems within the scope of this Regulation which comply with the relevant harmonised standards referenced, or common specifications adopted pursuant to Articles 40 and, respectively, 41 of Regulation (EU) 2024/1689 shall be presumed to be in conformity with the essential health and safety requirements set out in Annex III to this Regulation as regards high-risk AI systems.';

(3) Article 47 is amended as follows:

(a) paragraphs 2 and 3 are replaced by the following:

'2. The power to adopt delegated acts referred to in Article 6(2) and (11) and Article 7(2), shall be conferred on the Commission for a period of five years from 19 July 2023. The power to adopt delegated acts referred to in Article 8, third paragraph, shall be conferred on the Commission for a period of five years from 27 July 2026. The Commission shall draw up a report in respect of the delegation of power not later than nine months before the end of the five-year period. The delegation of power shall be tacitly extended for periods of an identical duration, unless the European Parliament or the Council opposes such extension no later than three months before the end of each period.

3. The delegation of power referred to in Article 6(2) and (11), Article 7(2) and Article 8, third paragraph, may be revoked at any time by the European Parliament or by the Council. A decision to revoke shall put an end to the delegation of the power specified in that decision. It shall take effect the day following the publication of the decision in the *Official Journal of the European Union* or at a later date specified therein. It shall not affect the validity of any delegated acts already in force.';

(b) paragraph 6 is replaced by the following:

'6. A delegated act adopted pursuant to Article 6(2) and (11), Article 7(2) or Article 8, third paragraph, shall enter into force only if no objection has been expressed either by the European Parliament or by the Council within a period of two months of notification of that act to the European Parliament and the Council or if, before the expiry of that period, the European Parliament and the Council have both informed the Commission that they will not object. That period shall be extended by two months at the initiative of the European Parliament or of the Council.'.

Article 4

Entry into force and application

This Regulation shall enter into force on the third day following that of its publication in the *Official Journal of the European Union*.

This Regulation shall be binding in its entirety and directly applicable in all Member States.

Done at Strasbourg, 8 July 2026.

For the European Parliament	*For the Council*
The President	*The President*
R. METSOLA	T. BYRNE

I

(Legislative acts)

REGULATIONS

REGULATION (EU) 2016/679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 27 April 2016

on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

(Text with EEA relevance)

THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION,

Having regard to the Treaty on the Functioning of the European Union, and in particular Article 16 thereof,

Having regard to the proposal from the European Commission,

After transmission of the draft legislative act to the national parliaments,

Having regard to the opinion of the European Economic and Social Committee ([1]),

Having regard to the opinion of the Committee of the Regions ([2]),

Acting in accordance with the ordinary legislative procedure ([3]),

Whereas:

(1) The protection of natural persons in relation to the processing of personal data is a fundamental right. Article 8(1) of the Charter of Fundamental Rights of the European Union (the 'Charter') and Article 16(1) of the Treaty on the Functioning of the European Union (TFEU) provide that everyone has the right to the protection of personal data concerning him or her.

(2) The principles of, and rules on the protection of natural persons with regard to the processing of their personal data should, whatever their nationality or residence, respect their fundamental rights and freedoms, in particular their right to the protection of personal data. This Regulation is intended to contribute to the accomplishment of an area of freedom, security and justice and of an economic union, to economic and social progress, to the strengthening and the convergence of the economies within the internal market, and to the well-being of natural persons.

(3) Directive 95/46/EC of the European Parliament and of the Council ([4]) seeks to harmonise the protection of fundamental rights and freedoms of natural persons in respect of processing activities and to ensure the free flow of personal data between Member States.

([1]) OJ C 229, 31.7.2012, p. 90.
([2]) OJ C 391, 18.12.2012, p. 127.
([3]) Position of the European Parliament of 12 March 2014 (not yet published in the Official Journal) and position of the Council at first reading of 8 April 2016 (not yet published in the Official Journal). Position of the European Parliament of 14 April 2016.
([4]) Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data (OJ L 281, 23.11.1995, p. 31).

(4) The processing of personal data should be designed to serve mankind. The right to the protection of personal data is not an absolute right; it must be considered in relation to its function in society and be balanced against other fundamental rights, in accordance with the principle of proportionality. This Regulation respects all fundamental rights and observes the freedoms and principles recognised in the Charter as enshrined in the Treaties, in particular the respect for private and family life, home and communications, the protection of personal data, freedom of thought, conscience and religion, freedom of expression and information, freedom to conduct a business, the right to an effective remedy and to a fair trial, and cultural, religious and linguistic diversity.

(5) The economic and social integration resulting from the functioning of the internal market has led to a substantial increase in cross-border flows of personal data. The exchange of personal data between public and private actors, including natural persons, associations and undertakings across the Union has increased. National authorities in the Member States are being called upon by Union law to cooperate and exchange personal data so as to be able to perform their duties or carry out tasks on behalf of an authority in another Member State.

(6) Rapid technological developments and globalisation have brought new challenges for the protection of personal data. The scale of the collection and sharing of personal data has increased significantly. Technology allows both private companies and public authorities to make use of personal data on an unprecedented scale in order to pursue their activities. Natural persons increasingly make personal information available publicly and globally. Technology has transformed both the economy and social life, and should further facilitate the free flow of personal data within the Union and the transfer to third countries and international organisations, while ensuring a high level of the protection of personal data.

(7) Those developments require a strong and more coherent data protection framework in the Union, backed by strong enforcement, given the importance of creating the trust that will allow the digital economy to develop across the internal market. Natural persons should have control of their own personal data. Legal and practical certainty for natural persons, economic operators and public authorities should be enhanced.

(8) Where this Regulation provides for specifications or restrictions of its rules by Member State law, Member States may, as far as necessary for coherence and for making the national provisions comprehensible to the persons to whom they apply, incorporate elements of this Regulation into their national law.

(9) The objectives and principles of Directive 95/46/EC remain sound, but it has not prevented fragmentation in the implementation of data protection across the Union, legal uncertainty or a widespread public perception that there are significant risks to the protection of natural persons, in particular with regard to online activity. Differences in the level of protection of the rights and freedoms of natural persons, in particular the right to the protection of personal data, with regard to the processing of personal data in the Member States may prevent the free flow of personal data throughout the Union. Those differences may therefore constitute an obstacle to the pursuit of economic activities at the level of the Union, distort competition and impede authorities in the discharge of their responsibilities under Union law. Such a difference in levels of protection is due to the existence of differences in the implementation and application of Directive 95/46/EC.

(10) In order to ensure a consistent and high level of protection of natural persons and to remove the obstacles to flows of personal data within the Union, the level of protection of the rights and freedoms of natural persons with regard to the processing of such data should be equivalent in all Member States. Consistent and homogenous application of the rules for the protection of the fundamental rights and freedoms of natural persons with regard to the processing of personal data should be ensured throughout the Union. Regarding the processing of personal data for compliance with a legal obligation, for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller, Member States should be allowed to maintain or introduce national provisions to further specify the application of the rules of this Regulation. In conjunction with the general and horizontal law on data protection implementing Directive 95/46/EC, Member States have several sector-specific laws in areas that need more specific provisions. This Regulation also provides a margin of manoeuvre for Member States to specify its rules, including for the processing of special categories of personal data ('sensitive data'). To that extent, this Regulation does not exclude Member State law that sets out the circumstances for specific processing situations, including determining more precisely the conditions under which the processing of personal data is lawful.

(11) Effective protection of personal data throughout the Union requires the strengthening and setting out in detail of the rights of data subjects and the obligations of those who process and determine the processing of personal data, as well as equivalent powers for monitoring and ensuring compliance with the rules for the protection of personal data and equivalent sanctions for infringements in the Member States.

(12) Article 16(2) TFEU mandates the European Parliament and the Council to lay down the rules relating to the protection of natural persons with regard to the processing of personal data and the rules relating to the free movement of personal data.

(13) In order to ensure a consistent level of protection for natural persons throughout the Union and to prevent divergences hampering the free movement of personal data within the internal market, a Regulation is necessary to provide legal certainty and transparency for economic operators, including micro, small and medium-sized enterprises, and to provide natural persons in all Member States with the same level of legally enforceable rights and obligations and responsibilities for controllers and processors, to ensure consistent monitoring of the processing of personal data, and equivalent sanctions in all Member States as well as effective cooperation between the supervisory authorities of different Member States. The proper functioning of the internal market requires that the free movement of personal data within the Union is not restricted or prohibited for reasons connected with the protection of natural persons with regard to the processing of personal data. To take account of the specific situation of micro, small and medium-sized enterprises, this Regulation includes a derogation for organisations with fewer than 250 employees with regard to record-keeping. In addition, the Union institutions and bodies, and Member States and their supervisory authorities, are encouraged to take account of the specific needs of micro, small and medium-sized enterprises in the application of this Regulation. The notion of micro, small and medium-sized enterprises should draw from Article 2 of the Annex to Commission Recommendation 2003/361/EC ([1]).

(14) The protection afforded by this Regulation should apply to natural persons, whatever their nationality or place of residence, in relation to the processing of their personal data. This Regulation does not cover the processing of personal data which concerns legal persons and in particular undertakings established as legal persons, including the name and the form of the legal person and the contact details of the legal person.

(15) In order to prevent creating a serious risk of circumvention, the protection of natural persons should be technologically neutral and should not depend on the techniques used. The protection of natural persons should apply to the processing of personal data by automated means, as well as to manual processing, if the personal data are contained or are intended to be contained in a filing system. Files or sets of files, as well as their cover pages, which are not structured according to specific criteria should not fall within the scope of this Regulation.

(16) This Regulation does not apply to issues of protection of fundamental rights and freedoms or the free flow of personal data related to activities which fall outside the scope of Union law, such as activities concerning national security. This Regulation does not apply to the processing of personal data by the Member States when carrying out activities in relation to the common foreign and security policy of the Union.

(17) Regulation (EC) No 45/2001 of the European Parliament and of the Council ([2]) applies to the processing of personal data by the Union institutions, bodies, offices and agencies. Regulation (EC) No 45/2001 and other Union legal acts applicable to such processing of personal data should be adapted to the principles and rules established in this Regulation and applied in the light of this Regulation. In order to provide a strong and coherent data protection framework in the Union, the necessary adaptations of Regulation (EC) No 45/2001 should follow after the adoption of this Regulation, in order to allow application at the same time as this Regulation.

(18) This Regulation does not apply to the processing of personal data by a natural person in the course of a purely personal or household activity and thus with no connection to a professional or commercial activity. Personal or

([1]) Commission Recommendation of 6 May 2003 concerning the definition of micro, small and medium-sized enterprises (C(2003) 1422) (OJ L 124, 20.5.2003, p. 36).

([2]) Regulation (EC) No 45/2001 of the European Parliament and of the Council of 18 December 2000 on the protection of individuals with regard to the processing of personal data by the Community institutions and bodies and on the free movement of such data (OJ L 8, 12.1.2001, p. 1).

household activities could include correspondence and the holding of addresses, or social networking and online activity undertaken within the context of such activities. However, this Regulation applies to controllers or processors which provide the means for processing personal data for such personal or household activities.

(19) The protection of natural persons with regard to the processing of personal data by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security and the free movement of such data, is the subject of a specific Union legal act. This Regulation should not, therefore, apply to processing activities for those purposes. However, personal data processed by public authorities under this Regulation should, when used for those purposes, be governed by a more specific Union legal act, namely Directive (EU) 2016/680 of the European Parliament and of the Council ([1]). Member States may entrust competent authorities within the meaning of Directive (EU) 2016/680 with tasks which are not necessarily carried out for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and prevention of threats to public security, so that the processing of personal data for those other purposes, in so far as it is within the scope of Union law, falls within the scope of this Regulation.

With regard to the processing of personal data by those competent authorities for purposes falling within scope of this Regulation, Member States should be able to maintain or introduce more specific provisions to adapt the application of the rules of this Regulation. Such provisions may determine more precisely specific requirements for the processing of personal data by those competent authorities for those other purposes, taking into account the constitutional, organisational and administrative structure of the respective Member State. When the processing of personal data by private bodies falls within the scope of this Regulation, this Regulation should provide for the possibility for Member States under specific conditions to restrict by law certain obligations and rights when such a restriction constitutes a necessary and proportionate measure in a democratic society to safeguard specific important interests including public security and the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security. This is relevant for instance in the framework of anti-money laundering or the activities of forensic laboratories.

(20) While this Regulation applies, inter alia, to the activities of courts and other judicial authorities, Union or Member State law could specify the processing operations and processing procedures in relation to the processing of personal data by courts and other judicial authorities. The competence of the supervisory authorities should not cover the processing of personal data when courts are acting in their judicial capacity, in order to safeguard the independence of the judiciary in the performance of its judicial tasks, including decision-making. It should be possible to entrust supervision of such data processing operations to specific bodies within the judicial system of the Member State, which should, in particular ensure compliance with the rules of this Regulation, enhance awareness among members of the judiciary of their obligations under this Regulation and handle complaints in relation to such data processing operations.

(21) This Regulation is without prejudice to the application of Directive 2000/31/EC of the European Parliament and of the Council ([2]), in particular of the liability rules of intermediary service providers in Articles 12 to 15 of that Directive. That Directive seeks to contribute to the proper functioning of the internal market by ensuring the free movement of information society services between Member States.

(22) Any processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union should be carried out in accordance with this Regulation, regardless of whether the processing itself takes place within the Union. Establishment implies the effective and real exercise of activity through stable arrangements. The legal form of such arrangements, whether through a branch or a subsidiary with a legal personality, is not the determining factor in that respect.

([1]) Directive (EU) 2016/680 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data by competent authorities for the purposes of prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, and the free movement of such data and repealing Council Framework Decision 2008/977/JHA (see page 89 of this Official Journal).

([2]) Directive 2000/31/EC of the European Parliament and of the Council of 8 June 2000 on certain legal aspects of information society services, in particular electronic commerce, in the Internal Market ('Directive on electronic commerce') (OJ L 178, 17.7.2000, p. 1).

(23) In order to ensure that natural persons are not deprived of the protection to which they are entitled under this Regulation, the processing of personal data of data subjects who are in the Union by a controller or a processor not established in the Union should be subject to this Regulation where the processing activities are related to offering goods or services to such data subjects irrespective of whether connected to a payment. In order to determine whether such a controller or processor is offering goods or services to data subjects who are in the Union, it should be ascertained whether it is apparent that the controller or processor envisages offering services to data subjects in one or more Member States in the Union. Whereas the mere accessibility of the controller's, processor's or an intermediary's website in the Union, of an email address or of other contact details, or the use of a language generally used in the third country where the controller is established, is insufficient to ascertain such intention, factors such as the use of a language or a currency generally used in one or more Member States with the possibility of ordering goods and services in that other language, or the mentioning of customers or users who are in the Union, may make it apparent that the controller envisages offering goods or services to data subjects in the Union.

(24) The processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union should also be subject to this Regulation when it is related to the monitoring of the behaviour of such data subjects in so far as their behaviour takes place within the Union. In order to determine whether a processing activity can be considered to monitor the behaviour of data subjects, it should be ascertained whether natural persons are tracked on the internet including potential subsequent use of personal data processing techniques which consist of profiling a natural person, particularly in order to take decisions concerning her or him or for analysing or predicting her or his personal preferences, behaviours and attitudes.

(25) Where Member State law applies by virtue of public international law, this Regulation should also apply to a controller not established in the Union, such as in a Member State's diplomatic mission or consular post.

(26) The principles of data protection should apply to any information concerning an identified or identifiable natural person. Personal data which have undergone pseudonymisation, which could be attributed to a natural person by the use of additional information should be considered to be information on an identifiable natural person. To determine whether a natural person is identifiable, account should be taken of all the means reasonably likely to be used, such as singling out, either by the controller or by another person to identify the natural person directly or indirectly. To ascertain whether means are reasonably likely to be used to identify the natural person, account should be taken of all objective factors, such as the costs of and the amount of time required for identification, taking into consideration the available technology at the time of the processing and technological developments. The principles of data protection should therefore not apply to anonymous information, namely information which does not relate to an identified or identifiable natural person or to personal data rendered anonymous in such a manner that the data subject is not or no longer identifiable. This Regulation does not therefore concern the processing of such anonymous information, including for statistical or research purposes.

(27) This Regulation does not apply to the personal data of deceased persons. Member States may provide for rules regarding the processing of personal data of deceased persons.

(28) The application of pseudonymisation to personal data can reduce the risks to the data subjects concerned and help controllers and processors to meet their data-protection obligations. The explicit introduction of 'pseudonymisation' in this Regulation is not intended to preclude any other measures of data protection.

(29) In order to create incentives to apply pseudonymisation when processing personal data, measures of pseudonymisation should, whilst allowing general analysis, be possible within the same controller when that controller has taken technical and organisational measures necessary to ensure, for the processing concerned, that this Regulation is implemented, and that additional information for attributing the personal data to a specific data subject is kept separately. The controller processing the personal data should indicate the authorised persons within the same controller.

(30) Natural persons may be associated with online identifiers provided by their devices, applications, tools and protocols, such as internet protocol addresses, cookie identifiers or other identifiers such as radio frequency identification tags. This may leave traces which, in particular when combined with unique identifiers and other information received by the servers, may be used to create profiles of the natural persons and identify them.

(31) Public authorities to which personal data are disclosed in accordance with a legal obligation for the exercise of their official mission, such as tax and customs authorities, financial investigation units, independent administrative authorities, or financial market authorities responsible for the regulation and supervision of securities markets should not be regarded as recipients if they receive personal data which are necessary to carry out a particular inquiry in the general interest, in accordance with Union or Member State law. The requests for disclosure sent by the public authorities should always be in writing, reasoned and occasional and should not concern the entirety of a filing system or lead to the interconnection of filing systems. The processing of personal data by those public authorities should comply with the applicable data-protection rules according to the purposes of the processing.

(32) Consent should be given by a clear affirmative act establishing a freely given, specific, informed and unambiguous indication of the data subject's agreement to the processing of personal data relating to him or her, such as by a written statement, including by electronic means, or an oral statement. This could include ticking a box when visiting an internet website, choosing technical settings for information society services or another statement or conduct which clearly indicates in this context the data subject's acceptance of the proposed processing of his or her personal data. Silence, pre-ticked boxes or inactivity should not therefore constitute consent. Consent should cover all processing activities carried out for the same purpose or purposes. When the processing has multiple purposes, consent should be given for all of them. If the data subject's consent is to be given following a request by electronic means, the request must be clear, concise and not unnecessarily disruptive to the use of the service for which it is provided.

(33) It is often not possible to fully identify the purpose of personal data processing for scientific research purposes at the time of data collection. Therefore, data subjects should be allowed to give their consent to certain areas of scientific research when in keeping with recognised ethical standards for scientific research. Data subjects should have the opportunity to give their consent only to certain areas of research or parts of research projects to the extent allowed by the intended purpose.

(34) Genetic data should be defined as personal data relating to the inherited or acquired genetic characteristics of a natural person which result from the analysis of a biological sample from the natural person in question, in particular chromosomal, deoxyribonucleic acid (DNA) or ribonucleic acid (RNA) analysis, or from the analysis of another element enabling equivalent information to be obtained.

(35) Personal data concerning health should include all data pertaining to the health status of a data subject which reveal information relating to the past, current or future physical or mental health status of the data subject. This includes information about the natural person collected in the course of the registration for, or the provision of, health care services as referred to in Directive 2011/24/EU of the European Parliament and of the Council ([1]) to that natural person; a number, symbol or particular assigned to a natural person to uniquely identify the natural person for health purposes; information derived from the testing or examination of a body part or bodily substance, including from genetic data and biological samples; and any information on, for example, a disease, disability, disease risk, medical history, clinical treatment or the physiological or biomedical state of the data subject independent of its source, for example from a physician or other health professional, a hospital, a medical device or an in vitro diagnostic test.

(36) The main establishment of a controller in the Union should be the place of its central administration in the Union, unless the decisions on the purposes and means of the processing of personal data are taken in another establishment of the controller in the Union, in which case that other establishment should be considered to be

([1]) Directive 2011/24/EU of the European Parliament and of the Council of 9 March 2011 on the application of patients' rights in cross-border healthcare (OJ L 88, 4.4.2011, p. 45).

the main establishment. The main establishment of a controller in the Union should be determined according to objective criteria and should imply the effective and real exercise of management activities determining the main decisions as to the purposes and means of processing through stable arrangements. That criterion should not depend on whether the processing of personal data is carried out at that location. The presence and use of technical means and technologies for processing personal data or processing activities do not, in themselves, constitute a main establishment and are therefore not determining criteria for a main establishment. The main establishment of the processor should be the place of its central administration in the Union or, if it has no central administration in the Union, the place where the main processing activities take place in the Union. In cases involving both the controller and the processor, the competent lead supervisory authority should remain the supervisory authority of the Member State where the controller has its main establishment, but the supervisory authority of the processor should be considered to be a supervisory authority concerned and that supervisory authority should participate in the cooperation procedure provided for by this Regulation. In any case, the supervisory authorities of the Member State or Member States where the processor has one or more establishments should not be considered to be supervisory authorities concerned where the draft decision concerns only the controller. Where the processing is carried out by a group of undertakings, the main establishment of the controlling undertaking should be considered to be the main establishment of the group of undertakings, except where the purposes and means of processing are determined by another undertaking.

(37) A group of undertakings should cover a controlling undertaking and its controlled undertakings, whereby the controlling undertaking should be the undertaking which can exert a dominant influence over the other undertakings by virtue, for example, of ownership, financial participation or the rules which govern it or the power to have personal data protection rules implemented. An undertaking which controls the processing of personal data in undertakings affiliated to it should be regarded, together with those undertakings, as a group of undertakings.

(38) Children merit specific protection with regard to their personal data, as they may be less aware of the risks, consequences and safeguards concerned and their rights in relation to the processing of personal data. Such specific protection should, in particular, apply to the use of personal data of children for the purposes of marketing or creating personality or user profiles and the collection of personal data with regard to children when using services offered directly to a child. The consent of the holder of parental responsibility should not be necessary in the context of preventive or counselling services offered directly to a child.

(39) Any processing of personal data should be lawful and fair. It should be transparent to natural persons that personal data concerning them are collected, used, consulted or otherwise processed and to what extent the personal data are or will be processed. The principle of transparency requires that any information and communication relating to the processing of those personal data be easily accessible and easy to understand, and that clear and plain language be used. That principle concerns, in particular, information to the data subjects on the identity of the controller and the purposes of the processing and further information to ensure fair and transparent processing in respect of the natural persons concerned and their right to obtain confirmation and communication of personal data concerning them which are being processed. Natural persons should be made aware of risks, rules, safeguards and rights in relation to the processing of personal data and how to exercise their rights in relation to such processing. In particular, the specific purposes for which personal data are processed should be explicit and legitimate and determined at the time of the collection of the personal data. The personal data should be adequate, relevant and limited to what is necessary for the purposes for which they are processed. This requires, in particular, ensuring that the period for which the personal data are stored is limited to a strict minimum. Personal data should be processed only if the purpose of the processing could not reasonably be fulfilled by other means. In order to ensure that the personal data are not kept longer than necessary, time limits should be established by the controller for erasure or for a periodic review. Every reasonable step should be taken to ensure that personal data which are inaccurate are rectified or deleted. Personal data should be processed in a manner that ensures appropriate security and confidentiality of the personal data, including for preventing unauthorised access to or use of personal data and the equipment used for the processing.

(40) In order for processing to be lawful, personal data should be processed on the basis of the consent of the data subject concerned or some other legitimate basis, laid down by law, either in this Regulation or in other Union or

Member State law as referred to in this Regulation, including the necessity for compliance with the legal obligation to which the controller is subject or the necessity for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract.

(41) Where this Regulation refers to a legal basis or a legislative measure, this does not necessarily require a legislative act adopted by a parliament, without prejudice to requirements pursuant to the constitutional order of the Member State concerned. However, such a legal basis or legislative measure should be clear and precise and its application should be foreseeable to persons subject to it, in accordance with the case-law of the Court of Justice of the European Union (the 'Court of Justice') and the European Court of Human Rights.

(42) Where processing is based on the data subject's consent, the controller should be able to demonstrate that the data subject has given consent to the processing operation. In particular in the context of a written declaration on another matter, safeguards should ensure that the data subject is aware of the fact that and the extent to which consent is given. In accordance with Council Directive 93/13/EEC ([1]) a declaration of consent pre-formulated by the controller should be provided in an intelligible and easily accessible form, using clear and plain language and it should not contain unfair terms. For consent to be informed, the data subject should be aware at least of the identity of the controller and the purposes of the processing for which the personal data are intended. Consent should not be regarded as freely given if the data subject has no genuine or free choice or is unable to refuse or withdraw consent without detriment.

(43) In order to ensure that consent is freely given, consent should not provide a valid legal ground for the processing of personal data in a specific case where there is a clear imbalance between the data subject and the controller, in particular where the controller is a public authority and it is therefore unlikely that consent was freely given in all the circumstances of that specific situation. Consent is presumed not to be freely given if it does not allow separate consent to be given to different personal data processing operations despite it being appropriate in the individual case, or if the performance of a contract, including the provision of a service, is dependent on the consent despite such consent not being necessary for such performance.

(44) Processing should be lawful where it is necessary in the context of a contract or the intention to enter into a contract.

(45) Where processing is carried out in accordance with a legal obligation to which the controller is subject or where processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority, the processing should have a basis in Union or Member State law. This Regulation does not require a specific law for each individual processing. A law as a basis for several processing operations based on a legal obligation to which the controller is subject or where processing is necessary for the performance of a task carried out in the public interest or in the exercise of an official authority may be sufficient. It should also be for Union or Member State law to determine the purpose of processing. Furthermore, that law could specify the general conditions of this Regulation governing the lawfulness of personal data processing, establish specifications for determining the controller, the type of personal data which are subject to the processing, the data subjects concerned, the entities to which the personal data may be disclosed, the purpose limitations, the storage period and other measures to ensure lawful and fair processing. It should also be for Union or Member State law to determine whether the controller performing a task carried out in the public interest or in the exercise of official authority should be a public authority or another natural or legal person governed by public law, or, where it is in the public interest to do so, including for health purposes such as public health and social protection and the management of health care services, by private law, such as a professional association.

(46) The processing of personal data should also be regarded to be lawful where it is necessary to protect an interest which is essential for the life of the data subject or that of another natural person. Processing of personal data

([1]) Council Directive 93/13/EEC of 5 April 1993 on unfair terms in consumer contracts (OJ L 95, 21.4.1993, p. 29).

based on the vital interest of another natural person should in principle take place only where the processing cannot be manifestly based on another legal basis. Some types of processing may serve both important grounds of public interest and the vital interests of the data subject as for instance when processing is necessary for humanitarian purposes, including for monitoring epidemics and their spread or in situations of humanitarian emergencies, in particular in situations of natural and man-made disasters.

(47) The legitimate interests of a controller, including those of a controller to which the personal data may be disclosed, or of a third party, may provide a legal basis for processing, provided that the interests or the fundamental rights and freedoms of the data subject are not overriding, taking into consideration the reasonable expectations of data subjects based on their relationship with the controller. Such legitimate interest could exist for example where there is a relevant and appropriate relationship between the data subject and the controller in situations such as where the data subject is a client or in the service of the controller. At any rate the existence of a legitimate interest would need careful assessment including whether a data subject can reasonably expect at the time and in the context of the collection of the personal data that processing for that purpose may take place. The interests and fundamental rights of the data subject could in particular override the interest of the data controller where personal data are processed in circumstances where data subjects do not reasonably expect further processing. Given that it is for the legislator to provide by law for the legal basis for public authorities to process personal data, that legal basis should not apply to the processing by public authorities in the performance of their tasks. The processing of personal data strictly necessary for the purposes of preventing fraud also constitutes a legitimate interest of the data controller concerned. The processing of personal data for direct marketing purposes may be regarded as carried out for a legitimate interest.

(48) Controllers that are part of a group of undertakings or institutions affiliated to a central body may have a legitimate interest in transmitting personal data within the group of undertakings for internal administrative purposes, including the processing of clients' or employees' personal data. The general principles for the transfer of personal data, within a group of undertakings, to an undertaking located in a third country remain unaffected.

(49) The processing of personal data to the extent strictly necessary and proportionate for the purposes of ensuring network and information security, i.e. the ability of a network or an information system to resist, at a given level of confidence, accidental events or unlawful or malicious actions that compromise the availability, authenticity, integrity and confidentiality of stored or transmitted personal data, and the security of the related services offered by, or accessible via, those networks and systems, by public authorities, by computer emergency response teams (CERTs), computer security incident response teams (CSIRTs), by providers of electronic communications networks and services and by providers of security technologies and services, constitutes a legitimate interest of the data controller concerned. This could, for example, include preventing unauthorised access to electronic communications networks and malicious code distribution and stopping 'denial of service' attacks and damage to computer and electronic communication systems.

(50) The processing of personal data for purposes other than those for which the personal data were initially collected should be allowed only where the processing is compatible with the purposes for which the personal data were initially collected. In such a case, no legal basis separate from that which allowed the collection of the personal data is required. If the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller, Union or Member State law may determine and specify the tasks and purposes for which the further processing should be regarded as compatible and lawful. Further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes should be considered to be compatible lawful processing operations. The legal basis provided by Union or Member State law for the processing of personal data may also provide a legal basis for further processing. In order to ascertain whether a purpose of further processing is compatible with the purpose for which the personal data are initially collected, the controller, after having met all the requirements for the lawfulness of the original processing, should take into account, inter alia: any link between those purposes and the purposes of the intended further processing; the context in which the personal data have been collected, in particular the reasonable expectations of data subjects based on their relationship with the controller as to their

further use; the nature of the personal data; the consequences of the intended further processing for data subjects; and the existence of appropriate safeguards in both the original and intended further processing operations.

Where the data subject has given consent or the processing is based on Union or Member State law which constitutes a necessary and proportionate measure in a democratic society to safeguard, in particular, important objectives of general public interest, the controller should be allowed to further process the personal data irrespective of the compatibility of the purposes. In any case, the application of the principles set out in this Regulation and in particular the information of the data subject on those other purposes and on his or her rights including the right to object, should be ensured. Indicating possible criminal acts or threats to public security by the controller and transmitting the relevant personal data in individual cases or in several cases relating to the same criminal act or threats to public security to a competent authority should be regarded as being in the legitimate interest pursued by the controller. However, such transmission in the legitimate interest of the controller or further processing of personal data should be prohibited if the processing is not compatible with a legal, professional or other binding obligation of secrecy.

(51) Personal data which are, by their nature, particularly sensitive in relation to fundamental rights and freedoms merit specific protection as the context of their processing could create significant risks to the fundamental rights and freedoms. Those personal data should include personal data revealing racial or ethnic origin, whereby the use of the term 'racial origin' in this Regulation does not imply an acceptance by the Union of theories which attempt to determine the existence of separate human races. The processing of photographs should not systematically be considered to be processing of special categories of personal data as they are covered by the definition of biometric data only when processed through a specific technical means allowing the unique identification or authentication of a natural person. Such personal data should not be processed, unless processing is allowed in specific cases set out in this Regulation, taking into account that Member States law may lay down specific provisions on data protection in order to adapt the application of the rules of this Regulation for compliance with a legal obligation or for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller. In addition to the specific requirements for such processing, the general principles and other rules of this Regulation should apply, in particular as regards the conditions for lawful processing. Derogations from the general prohibition for processing such special categories of personal data should be explicitly provided, inter alia, where the data subject gives his or her explicit consent or in respect of specific needs in particular where the processing is carried out in the course of legitimate activities by certain associations or foundations the purpose of which is to permit the exercise of fundamental freedoms.

(52) Derogating from the prohibition on processing special categories of personal data should also be allowed when provided for in Union or Member State law and subject to suitable safeguards, so as to protect personal data and other fundamental rights, where it is in the public interest to do so, in particular processing personal data in the field of employment law, social protection law including pensions and for health security, monitoring and alert purposes, the prevention or control of communicable diseases and other serious threats to health. Such a derogation may be made for health purposes, including public health and the management of health-care services, especially in order to ensure the quality and cost-effectiveness of the procedures used for settling claims for benefits and services in the health insurance system, or for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes. A derogation should also allow the processing of such personal data where necessary for the establishment, exercise or defence of legal claims, whether in court proceedings or in an administrative or out-of-court procedure.

(53) Special categories of personal data which merit higher protection should be processed for health-related purposes only where necessary to achieve those purposes for the benefit of natural persons and society as a whole, in particular in the context of the management of health or social care services and systems, including processing by the management and central national health authorities of such data for the purpose of quality control, management information and the general national and local supervision of the health or social care system, and ensuring continuity of health or social care and cross-border healthcare or health security, monitoring and alert purposes, or for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes, based on Union or Member State law which has to meet an objective of public interest, as well as for studies conducted in the public interest in the area of public health. Therefore, this Regulation should provide for harmonised conditions for the processing of special categories of personal data concerning health, in respect of specific needs, in particular where the processing of such data is carried out for certain health-related purposes

by persons subject to a legal obligation of professional secrecy. Union or Member State law should provide for specific and suitable measures so as to protect the fundamental rights and the personal data of natural persons. Member States should be allowed to maintain or introduce further conditions, including limitations, with regard to the processing of genetic data, biometric data or data concerning health. However, this should not hamper the free flow of personal data within the Union when those conditions apply to cross-border processing of such data.

(54) The processing of special categories of personal data may be necessary for reasons of public interest in the areas of public health without consent of the data subject. Such processing should be subject to suitable and specific measures so as to protect the rights and freedoms of natural persons. In that context, 'public health' should be interpreted as defined in Regulation (EC) No 1338/2008 of the European Parliament and of the Council ([1]), namely all elements related to health, namely health status, including morbidity and disability, the determinants having an effect on that health status, health care needs, resources allocated to health care, the provision of, and universal access to, health care as well as health care expenditure and financing, and the causes of mortality. Such processing of data concerning health for reasons of public interest should not result in personal data being processed for other purposes by third parties such as employers or insurance and banking companies.

(55) Moreover, the processing of personal data by official authorities for the purpose of achieving the aims, laid down by constitutional law or by international public law, of officially recognised religious associations, is carried out on grounds of public interest.

(56) Where in the course of electoral activities, the operation of the democratic system in a Member State requires that political parties compile personal data on people's political opinions, the processing of such data may be permitted for reasons of public interest, provided that appropriate safeguards are established.

(57) If the personal data processed by a controller do not permit the controller to identify a natural person, the data controller should not be obliged to acquire additional information in order to identify the data subject for the sole purpose of complying with any provision of this Regulation. However, the controller should not refuse to take additional information provided by the data subject in order to support the exercise of his or her rights. Identification should include the digital identification of a data subject, for example through authentication mechanism such as the same credentials, used by the data subject to log-in to the on-line service offered by the data controller.

(58) The principle of transparency requires that any information addressed to the public or to the data subject be concise, easily accessible and easy to understand, and that clear and plain language and, additionally, where appropriate, visualisation be used. Such information could be provided in electronic form, for example, when addressed to the public, through a website. This is of particular relevance in situations where the proliferation of actors and the technological complexity of practice make it difficult for the data subject to know and understand whether, by whom and for what purpose personal data relating to him or her are being collected, such as in the case of online advertising. Given that children merit specific protection, any information and communication, where processing is addressed to a child, should be in such a clear and plain language that the child can easily understand.

(59) Modalities should be provided for facilitating the exercise of the data subject's rights under this Regulation, including mechanisms to request and, if applicable, obtain, free of charge, in particular, access to and rectification or erasure of personal data and the exercise of the right to object. The controller should also provide means for requests to be made electronically, especially where personal data are processed by electronic means. The controller should be obliged to respond to requests from the data subject without undue delay and at the latest within one month and to give reasons where the controller does not intend to comply with any such requests.

([1]) Regulation (EC) No 1338/2008 of the European Parliament and of the Council of 16 December 2008 on Community statistics on public health and health and safety at work (OJ L 354, 31.12.2008, p. 70).

(60) The principles of fair and transparent processing require that the data subject be informed of the existence of the processing operation and its purposes. The controller should provide the data subject with any further information necessary to ensure fair and transparent processing taking into account the specific circumstances and context in which the personal data are processed. Furthermore, the data subject should be informed of the existence of profiling and the consequences of such profiling. Where the personal data are collected from the data subject, the data subject should also be informed whether he or she is obliged to provide the personal data and of the consequences, where he or she does not provide such data. That information may be provided in combination with standardised icons in order to give in an easily visible, intelligible and clearly legible manner, a meaningful overview of the intended processing. Where the icons are presented electronically, they should be machine-readable.

(61) The information in relation to the processing of personal data relating to the data subject should be given to him or her at the time of collection from the data subject, or, where the personal data are obtained from another source, within a reasonable period, depending on the circumstances of the case. Where personal data can be legitimately disclosed to another recipient, the data subject should be informed when the personal data are first disclosed to the recipient. Where the controller intends to process the personal data for a purpose other than that for which they were collected, the controller should provide the data subject prior to that further processing with information on that other purpose and other necessary information. Where the origin of the personal data cannot be provided to the data subject because various sources have been used, general information should be provided.

(62) However, it is not necessary to impose the obligation to provide information where the data subject already possesses the information, where the recording or disclosure of the personal data is expressly laid down by law or where the provision of information to the data subject proves to be impossible or would involve a disproportionate effort. The latter could in particular be the case where processing is carried out for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes. In that regard, the number of data subjects, the age of the data and any appropriate safeguards adopted should be taken into consideration.

(63) A data subject should have the right of access to personal data which have been collected concerning him or her, and to exercise that right easily and at reasonable intervals, in order to be aware of, and verify, the lawfulness of the processing. This includes the right for data subjects to have access to data concerning their health, for example the data in their medical records containing information such as diagnoses, examination results, assessments by treating physicians and any treatment or interventions provided. Every data subject should therefore have the right to know and obtain communication in particular with regard to the purposes for which the personal data are processed, where possible the period for which the personal data are processed, the recipients of the personal data, the logic involved in any automatic personal data processing and, at least when based on profiling, the consequences of such processing. Where possible, the controller should be able to provide remote access to a secure system which would provide the data subject with direct access to his or her personal data. That right should not adversely affect the rights or freedoms of others, including trade secrets or intellectual property and in particular the copyright protecting the software. However, the result of those considerations should not be a refusal to provide all information to the data subject. Where the controller processes a large quantity of information concerning the data subject, the controller should be able to request that, before the information is delivered, the data subject specify the information or processing activities to which the request relates.

(64) The controller should use all reasonable measures to verify the identity of a data subject who requests access, in particular in the context of online services and online identifiers. A controller should not retain personal data for the sole purpose of being able to react to potential requests.

(65) A data subject should have the right to have personal data concerning him or her rectified and a 'right to be forgotten' where the retention of such data infringes this Regulation or Union or Member State law to which the controller is subject. In particular, a data subject should have the right to have his or her personal data erased and no longer processed where the personal data are no longer necessary in relation to the purposes for which they are collected or otherwise processed, where a data subject has withdrawn his or her consent or objects to the processing of personal data concerning him or her, or where the processing of his or her personal data does not otherwise comply with this Regulation. That right is relevant in particular where the data subject has given

his or her consent as a child and is not fully aware of the risks involved by the processing, and later wants to remove such personal data, especially on the internet. The data subject should be able to exercise that right notwithstanding the fact that he or she is no longer a child. However, the further retention of the personal data should be lawful where it is necessary, for exercising the right of freedom of expression and information, for compliance with a legal obligation, for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller, on the grounds of public interest in the area of public health, for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes, or for the establishment, exercise or defence of legal claims.

(66) To strengthen the right to be forgotten in the online environment, the right to erasure should also be extended in such a way that a controller who has made the personal data public should be obliged to inform the controllers which are processing such personal data to erase any links to, or copies or replications of those personal data. In doing so, that controller should take reasonable steps, taking into account available technology and the means available to the controller, including technical measures, to inform the controllers which are processing the personal data of the data subject's request.

(67) Methods by which to restrict the processing of personal data could include, inter alia, temporarily moving the selected data to another processing system, making the selected personal data unavailable to users, or temporarily removing published data from a website. In automated filing systems, the restriction of processing should in principle be ensured by technical means in such a manner that the personal data are not subject to further processing operations and cannot be changed. The fact that the processing of personal data is restricted should be clearly indicated in the system.

(68) To further strengthen the control over his or her own data, where the processing of personal data is carried out by automated means, the data subject should also be allowed to receive personal data concerning him or her which he or she has provided to a controller in a structured, commonly used, machine-readable and interoperable format, and to transmit it to another controller. Data controllers should be encouraged to develop interoperable formats that enable data portability. That right should apply where the data subject provided the personal data on the basis of his or her consent or the processing is necessary for the performance of a contract. It should not apply where processing is based on a legal ground other than consent or contract. By its very nature, that right should not be exercised against controllers processing personal data in the exercise of their public duties. It should therefore not apply where the processing of the personal data is necessary for compliance with a legal obligation to which the controller is subject or for the performance of a task carried out in the public interest or in the exercise of an official authority vested in the controller. The data subject's right to transmit or receive personal data concerning him or her should not create an obligation for the controllers to adopt or maintain processing systems which are technically compatible. Where, in a certain set of personal data, more than one data subject is concerned, the right to receive the personal data should be without prejudice to the rights and freedoms of other data subjects in accordance with this Regulation. Furthermore, that right should not prejudice the right of the data subject to obtain the erasure of personal data and the limitations of that right as set out in this Regulation and should, in particular, not imply the erasure of personal data concerning the data subject which have been provided by him or her for the performance of a contract to the extent that and for as long as the personal data are necessary for the performance of that contract. Where technically feasible, the data subject should have the right to have the personal data transmitted directly from one controller to another.

(69) Where personal data might lawfully be processed because processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller, or on grounds of the legitimate interests of a controller or a third party, a data subject should, nevertheless, be entitled to object to the processing of any personal data relating to his or her particular situation. It should be for the controller to demonstrate that its compelling legitimate interest overrides the interests or the fundamental rights and freedoms of the data subject.

(70) Where personal data are processed for the purposes of direct marketing, the data subject should have the right to object to such processing, including profiling to the extent that it is related to such direct marketing, whether with regard to initial or further processing, at any time and free of charge. That right should be explicitly brought to the attention of the data subject and presented clearly and separately from any other information.

(71) The data subject should have the right not to be subject to a decision, which may include a measure, evaluating personal aspects relating to him or her which is based solely on automated processing and which produces legal effects concerning him or her or similarly significantly affects him or her, such as automatic refusal of an online credit application or e-recruiting practices without any human intervention. Such processing includes 'profiling' that consists of any form of automated processing of personal data evaluating the personal aspects relating to a natural person, in particular to analyse or predict aspects concerning the data subject's performance at work, economic situation, health, personal preferences or interests, reliability or behaviour, location or movements, where it produces legal effects concerning him or her or similarly significantly affects him or her. However, decision-making based on such processing, including profiling, should be allowed where expressly authorised by Union or Member State law to which the controller is subject, including for fraud and tax-evasion monitoring and prevention purposes conducted in accordance with the regulations, standards and recommendations of Union institutions or national oversight bodies and to ensure the security and reliability of a service provided by the controller, or necessary for the entering or performance of a contract between the data subject and a controller, or when the data subject has given his or her explicit consent. In any case, such processing should be subject to suitable safeguards, which should include specific information to the data subject and the right to obtain human intervention, to express his or her point of view, to obtain an explanation of the decision reached after such assessment and to challenge the decision. Such measure should not concern a child.

In order to ensure fair and transparent processing in respect of the data subject, taking into account the specific circumstances and context in which the personal data are processed, the controller should use appropriate mathematical or statistical procedures for the profiling, implement technical and organisational measures appropriate to ensure, in particular, that factors which result in inaccuracies in personal data are corrected and the risk of errors is minimised, secure personal data in a manner that takes account of the potential risks involved for the interests and rights of the data subject and that prevents, inter alia, discriminatory effects on natural persons on the basis of racial or ethnic origin, political opinion, religion or beliefs, trade union membership, genetic or health status or sexual orientation, or that result in measures having such an effect. Automated decision-making and profiling based on special categories of personal data should be allowed only under specific conditions.

(72) Profiling is subject to the rules of this Regulation governing the processing of personal data, such as the legal grounds for processing or data protection principles. The European Data Protection Board established by this Regulation (the 'Board') should be able to issue guidance in that context.

(73) Restrictions concerning specific principles and the rights of information, access to and rectification or erasure of personal data, the right to data portability, the right to object, decisions based on profiling, as well as the communication of a personal data breach to a data subject and certain related obligations of the controllers may be imposed by Union or Member State law, as far as necessary and proportionate in a democratic society to safeguard public security, including the protection of human life especially in response to natural or manmade disasters, the prevention, investigation and prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security, or of breaches of ethics for regulated professions, other important objectives of general public interest of the Union or of a Member State, in particular an important economic or financial interest of the Union or of a Member State, the keeping of public registers kept for reasons of general public interest, further processing of archived personal data to provide specific information related to the political behaviour under former totalitarian state regimes or the protection of the data subject or the rights and freedoms of others, including social protection, public health and humanitarian purposes. Those restrictions should be in accordance with the requirements set out in the Charter and in the European Convention for the Protection of Human Rights and Fundamental Freedoms.

(74) The responsibility and liability of the controller for any processing of personal data carried out by the controller or on the controller's behalf should be established. In particular, the controller should be obliged to implement appropriate and effective measures and be able to demonstrate the compliance of processing activities with this Regulation, including the effectiveness of the measures. Those measures should take into account the nature, scope, context and purposes of the processing and the risk to the rights and freedoms of natural persons.

(75) The risk to the rights and freedoms of natural persons, of varying likelihood and severity, may result from personal data processing which could lead to physical, material or non-material damage, in particular: where the processing may give rise to discrimination, identity theft or fraud, financial loss, damage to the reputation, loss of confidentiality of personal data protected by professional secrecy, unauthorised reversal of pseudonymisation, or any other significant economic or social disadvantage; where data subjects might be deprived of their rights and freedoms or prevented from exercising control over their personal data; where personal data are processed which reveal racial or ethnic origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health or data concerning sex life or criminal convictions and offences or related security measures; where personal aspects are evaluated, in particular analysing or predicting aspects concerning performance at work, economic situation, health, personal preferences or interests, reliability or behaviour, location or movements, in order to create or use personal profiles; where personal data of vulnerable natural persons, in particular of children, are processed; or where processing involves a large amount of personal data and affects a large number of data subjects.

(76) The likelihood and severity of the risk to the rights and freedoms of the data subject should be determined by reference to the nature, scope, context and purposes of the processing. Risk should be evaluated on the basis of an objective assessment, by which it is established whether data processing operations involve a risk or a high risk.

(77) Guidance on the implementation of appropriate measures and on the demonstration of compliance by the controller or the processor, especially as regards the identification of the risk related to the processing, their assessment in terms of origin, nature, likelihood and severity, and the identification of best practices to mitigate the risk, could be provided in particular by means of approved codes of conduct, approved certifications, guidelines provided by the Board or indications provided by a data protection officer. The Board may also issue guidelines on processing operations that are considered to be unlikely to result in a high risk to the rights and freedoms of natural persons and indicate what measures may be sufficient in such cases to address such risk.

(78) The protection of the rights and freedoms of natural persons with regard to the processing of personal data require that appropriate technical and organisational measures be taken to ensure that the requirements of this Regulation are met. In order to be able to demonstrate compliance with this Regulation, the controller should adopt internal policies and implement measures which meet in particular the principles of data protection by design and data protection by default. Such measures could consist, inter alia, of minimising the processing of personal data, pseudonymising personal data as soon as possible, transparency with regard to the functions and processing of personal data, enabling the data subject to monitor the data processing, enabling the controller to create and improve security features. When developing, designing, selecting and using applications, services and products that are based on the processing of personal data or process personal data to fulfil their task, producers of the products, services and applications should be encouraged to take into account the right to data protection when developing and designing such products, services and applications and, with due regard to the state of the art, to make sure that controllers and processors are able to fulfil their data protection obligations. The principles of data protection by design and by default should also be taken into consideration in the context of public tenders.

(79) The protection of the rights and freedoms of data subjects as well as the responsibility and liability of controllers and processors, also in relation to the monitoring by and measures of supervisory authorities, requires a clear allocation of the responsibilities under this Regulation, including where a controller determines the purposes and means of the processing jointly with other controllers or where a processing operation is carried out on behalf of a controller.

(80) Where a controller or a processor not established in the Union is processing personal data of data subjects who are in the Union whose processing activities are related to the offering of goods or services, irrespective of whether a payment of the data subject is required, to such data subjects in the Union, or to the monitoring of their behaviour as far as their behaviour takes place within the Union, the controller or the processor should designate a representative, unless the processing is occasional, does not include processing, on a large scale, of special categories of personal data or the processing of personal data relating to criminal convictions and offences, and is unlikely to result in a risk to the rights and freedoms of natural persons, taking into account the

nature, context, scope and purposes of the processing or if the controller is a public authority or body. The representative should act on behalf of the controller or the processor and may be addressed by any supervisory authority. The representative should be explicitly designated by a written mandate of the controller or of the processor to act on its behalf with regard to its obligations under this Regulation. The designation of such a representative does not affect the responsibility or liability of the controller or of the processor under this Regulation. Such a representative should perform its tasks according to the mandate received from the controller or processor, including cooperating with the competent supervisory authorities with regard to any action taken to ensure compliance with this Regulation. The designated representative should be subject to enforcement proceedings in the event of non-compliance by the controller or processor.

(81) To ensure compliance with the requirements of this Regulation in respect of the processing to be carried out by the processor on behalf of the controller, when entrusting a processor with processing activities, the controller should use only processors providing sufficient guarantees, in particular in terms of expert knowledge, reliability and resources, to implement technical and organisational measures which will meet the requirements of this Regulation, including for the security of processing. The adherence of the processor to an approved code of conduct or an approved certification mechanism may be used as an element to demonstrate compliance with the obligations of the controller. The carrying-out of processing by a processor should be governed by a contract or other legal act under Union or Member State law, binding the processor to the controller, setting out the subject-matter and duration of the processing, the nature and purposes of the processing, the type of personal data and categories of data subjects, taking into account the specific tasks and responsibilities of the processor in the context of the processing to be carried out and the risk to the rights and freedoms of the data subject. The controller and processor may choose to use an individual contract or standard contractual clauses which are adopted either directly by the Commission or by a supervisory authority in accordance with the consistency mechanism and then adopted by the Commission. After the completion of the processing on behalf of the controller, the processor should, at the choice of the controller, return or delete the personal data, unless there is a requirement to store the personal data under Union or Member State law to which the processor is subject.

(82) In order to demonstrate compliance with this Regulation, the controller or processor should maintain records of processing activities under its responsibility. Each controller and processor should be obliged to cooperate with the supervisory authority and make those records, on request, available to it, so that it might serve for monitoring those processing operations.

(83) In order to maintain security and to prevent processing in infringement of this Regulation, the controller or processor should evaluate the risks inherent in the processing and implement measures to mitigate those risks, such as encryption. Those measures should ensure an appropriate level of security, including confidentiality, taking into account the state of the art and the costs of implementation in relation to the risks and the nature of the personal data to be protected. In assessing data security risk, consideration should be given to the risks that are presented by personal data processing, such as accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed which may in particular lead to physical, material or non-material damage.

(84) In order to enhance compliance with this Regulation where processing operations are likely to result in a high risk to the rights and freedoms of natural persons, the controller should be responsible for the carrying-out of a data protection impact assessment to evaluate, in particular, the origin, nature, particularity and severity of that risk. The outcome of the assessment should be taken into account when determining the appropriate measures to be taken in order to demonstrate that the processing of personal data complies with this Regulation. Where a data-protection impact assessment indicates that processing operations involve a high risk which the controller cannot mitigate by appropriate measures in terms of available technology and costs of implementation, a consultation of the supervisory authority should take place prior to the processing.

(85) A personal data breach may, if not addressed in an appropriate and timely manner, result in physical, material or non-material damage to natural persons such as loss of control over their personal data or limitation of their rights, discrimination, identity theft or fraud, financial loss, unauthorised reversal of pseudonymisation, damage to reputation, loss of confidentiality of personal data protected by professional secrecy or any other significant economic or social disadvantage to the natural person concerned. Therefore, as soon as the controller becomes

aware that a personal data breach has occurred, the controller should notify the personal data breach to the supervisory authority without undue delay and, where feasible, not later than 72 hours after having become aware of it, unless the controller is able to demonstrate, in accordance with the accountability principle, that the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. Where such notification cannot be achieved within 72 hours, the reasons for the delay should accompany the notification and information may be provided in phases without undue further delay.

(86) The controller should communicate to the data subject a personal data breach, without undue delay, where that personal data breach is likely to result in a high risk to the rights and freedoms of the natural person in order to allow him or her to take the necessary precautions. The communication should describe the nature of the personal data breach as well as recommendations for the natural person concerned to mitigate potential adverse effects. Such communications to data subjects should be made as soon as reasonably feasible and in close cooperation with the supervisory authority, respecting guidance provided by it or by other relevant authorities such as law-enforcement authorities. For example, the need to mitigate an immediate risk of damage would call for prompt communication with data subjects whereas the need to implement appropriate measures against continuing or similar personal data breaches may justify more time for communication.

(87) It should be ascertained whether all appropriate technological protection and organisational measures have been implemented to establish immediately whether a personal data breach has taken place and to inform promptly the supervisory authority and the data subject. The fact that the notification was made without undue delay should be established taking into account in particular the nature and gravity of the personal data breach and its consequences and adverse effects for the data subject. Such notification may result in an intervention of the supervisory authority in accordance with its tasks and powers laid down in this Regulation.

(88) In setting detailed rules concerning the format and procedures applicable to the notification of personal data breaches, due consideration should be given to the circumstances of that breach, including whether or not personal data had been protected by appropriate technical protection measures, effectively limiting the likelihood of identity fraud or other forms of misuse. Moreover, such rules and procedures should take into account the legitimate interests of law-enforcement authorities where early disclosure could unnecessarily hamper the investigation of the circumstances of a personal data breach.

(89) Directive 95/46/EC provided for a general obligation to notify the processing of personal data to the supervisory authorities. While that obligation produces administrative and financial burdens, it did not in all cases contribute to improving the protection of personal data. Such indiscriminate general notification obligations should therefore be abolished, and replaced by effective procedures and mechanisms which focus instead on those types of processing operations which are likely to result in a high risk to the rights and freedoms of natural persons by virtue of their nature, scope, context and purposes. Such types of processing operations may be those which in, particular, involve using new technologies, or are of a new kind and where no data protection impact assessment has been carried out before by the controller, or where they become necessary in the light of the time that has elapsed since the initial processing.

(90) In such cases, a data protection impact assessment should be carried out by the controller prior to the processing in order to assess the particular likelihood and severity of the high risk, taking into account the nature, scope, context and purposes of the processing and the sources of the risk. That impact assessment should include, in particular, the measures, safeguards and mechanisms envisaged for mitigating that risk, ensuring the protection of personal data and demonstrating compliance with this Regulation.

(91) This should in particular apply to large-scale processing operations which aim to process a considerable amount of personal data at regional, national or supranational level and which could affect a large number of data subjects and which are likely to result in a high risk, for example, on account of their sensitivity, where in accordance with the achieved state of technological knowledge a new technology is used on a large scale as well as to other processing operations which result in a high risk to the rights and freedoms of data subjects, in particular where those operations render it more difficult for data subjects to exercise their rights. A data

protection impact assessment should also be made where personal data are processed for taking decisions regarding specific natural persons following any systematic and extensive evaluation of personal aspects relating to natural persons based on profiling those data or following the processing of special categories of personal data, biometric data, or data on criminal convictions and offences or related security measures. A data protection impact assessment is equally required for monitoring publicly accessible areas on a large scale, especially when using optic-electronic devices or for any other operations where the competent supervisory authority considers that the processing is likely to result in a high risk to the rights and freedoms of data subjects, in particular because they prevent data subjects from exercising a right or using a service or a contract, or because they are carried out systematically on a large scale. The processing of personal data should not be considered to be on a large scale if the processing concerns personal data from patients or clients by an individual physician, other health care professional or lawyer. In such cases, a data protection impact assessment should not be mandatory.

(92) There are circumstances under which it may be reasonable and economical for the subject of a data protection impact assessment to be broader than a single project, for example where public authorities or bodies intend to establish a common application or processing platform or where several controllers plan to introduce a common application or processing environment across an industry sector or segment or for a widely used horizontal activity.

(93) In the context of the adoption of the Member State law on which the performance of the tasks of the public authority or public body is based and which regulates the specific processing operation or set of operations in question, Member States may deem it necessary to carry out such assessment prior to the processing activities.

(94) Where a data protection impact assessment indicates that the processing would, in the absence of safeguards, security measures and mechanisms to mitigate the risk, result in a high risk to the rights and freedoms of natural persons and the controller is of the opinion that the risk cannot be mitigated by reasonable means in terms of available technologies and costs of implementation, the supervisory authority should be consulted prior to the start of processing activities. Such high risk is likely to result from certain types of processing and the extent and frequency of processing, which may result also in a realisation of damage or interference with the rights and freedoms of the natural person. The supervisory authority should respond to the request for consultation within a specified period. However, the absence of a reaction of the supervisory authority within that period should be without prejudice to any intervention of the supervisory authority in accordance with its tasks and powers laid down in this Regulation, including the power to prohibit processing operations. As part of that consultation process, the outcome of a data protection impact assessment carried out with regard to the processing at issue may be submitted to the supervisory authority, in particular the measures envisaged to mitigate the risk to the rights and freedoms of natural persons.

(95) The processor should assist the controller, where necessary and upon request, in ensuring compliance with the obligations deriving from the carrying out of data protection impact assessments and from prior consultation of the supervisory authority.

(96) A consultation of the supervisory authority should also take place in the course of the preparation of a legislative or regulatory measure which provides for the processing of personal data, in order to ensure compliance of the intended processing with this Regulation and in particular to mitigate the risk involved for the data subject.

(97) Where the processing is carried out by a public authority, except for courts or independent judicial authorities when acting in their judicial capacity, where, in the private sector, processing is carried out by a controller whose core activities consist of processing operations that require regular and systematic monitoring of the data subjects on a large scale, or where the core activities of the controller or the processor consist of processing on a large scale of special categories of personal data and data relating to criminal convictions and offences, a person with expert knowledge of data protection law and practices should assist the controller or processor to monitor internal compliance with this Regulation. In the private sector, the core activities of a controller relate to its primary activities and do not relate to the processing of personal data as ancillary activities. The necessary level of expert knowledge should be determined in particular according to the data processing operations carried out

and the protection required for the personal data processed by the controller or the processor. Such data protection officers, whether or not they are an employee of the controller, should be in a position to perform their duties and tasks in an independent manner.

(98) Associations or other bodies representing categories of controllers or processors should be encouraged to draw up codes of conduct, within the limits of this Regulation, so as to facilitate the effective application of this Regulation, taking account of the specific characteristics of the processing carried out in certain sectors and the specific needs of micro, small and medium enterprises. In particular, such codes of conduct could calibrate the obligations of controllers and processors, taking into account the risk likely to result from the processing for the rights and freedoms of natural persons.

(99) When drawing up a code of conduct, or when amending or extending such a code, associations and other bodies representing categories of controllers or processors should consult relevant stakeholders, including data subjects where feasible, and have regard to submissions received and views expressed in response to such consultations.

(100) In order to enhance transparency and compliance with this Regulation, the establishment of certification mechanisms and data protection seals and marks should be encouraged, allowing data subjects to quickly assess the level of data protection of relevant products and services.

(101) Flows of personal data to and from countries outside the Union and international organisations are necessary for the expansion of international trade and international cooperation. The increase in such flows has raised new challenges and concerns with regard to the protection of personal data. However, when personal data are transferred from the Union to controllers, processors or other recipients in third countries or to international organisations, the level of protection of natural persons ensured in the Union by this Regulation should not be undermined, including in cases of onward transfers of personal data from the third country or international organisation to controllers, processors in the same or another third country or international organisation. In any event, transfers to third countries and international organisations may only be carried out in full compliance with this Regulation. A transfer could take place only if, subject to the other provisions of this Regulation, the conditions laid down in the provisions of this Regulation relating to the transfer of personal data to third countries or international organisations are complied with by the controller or processor.

(102) This Regulation is without prejudice to international agreements concluded between the Union and third countries regulating the transfer of personal data including appropriate safeguards for the data subjects. Member States may conclude international agreements which involve the transfer of personal data to third countries or international organisations, as far as such agreements do not affect this Regulation or any other provisions of Union law and include an appropriate level of protection for the fundamental rights of the data subjects.

(103) The Commission may decide with effect for the entire Union that a third country, a territory or specified sector within a third country, or an international organisation, offers an adequate level of data protection, thus providing legal certainty and uniformity throughout the Union as regards the third country or international organisation which is considered to provide such level of protection. In such cases, transfers of personal data to that third country or international organisation may take place without the need to obtain any further authorisation. The Commission may also decide, having given notice and a full statement setting out the reasons to the third country or international organisation, to revoke such a decision.

(104) In line with the fundamental values on which the Union is founded, in particular the protection of human rights, the Commission should, in its assessment of the third country, or of a territory or specified sector within a third country, take into account how a particular third country respects the rule of law, access to justice as well as international human rights norms and standards and its general and sectoral law, including legislation concerning public security, defence and national security as well as public order and criminal law. The adoption of an adequacy decision with regard to a territory or a specified sector in a third country should take into account clear and objective criteria, such as specific processing activities and the scope of applicable legal standards and legislation in force in the third country. The third country should offer guarantees ensuring an adequate level of

protection essentially equivalent to that ensured within the Union, in particular where personal data are processed in one or several specific sectors. In particular, the third country should ensure effective independent data protection supervision and should provide for cooperation mechanisms with the Member States' data protection authorities, and the data subjects should be provided with effective and enforceable rights and effective administrative and judicial redress.

(105) Apart from the international commitments the third country or international organisation has entered into, the Commission should take account of obligations arising from the third country's or international organisation's participation in multilateral or regional systems in particular in relation to the protection of personal data, as well as the implementation of such obligations. In particular, the third country's accession to the Council of Europe Convention of 28 January 1981 for the Protection of Individuals with regard to the Automatic Processing of Personal Data and its Additional Protocol should be taken into account. The Commission should consult the Board when assessing the level of protection in third countries or international organisations.

(106) The Commission should monitor the functioning of decisions on the level of protection in a third country, a territory or specified sector within a third country, or an international organisation, and monitor the functioning of decisions adopted on the basis of Article 25(6) or Article 26(4) of Directive 95/46/EC. In its adequacy decisions, the Commission should provide for a periodic review mechanism of their functioning. That periodic review should be conducted in consultation with the third country or international organisation in question and take into account all relevant developments in the third country or international organisation. For the purposes of monitoring and of carrying out the periodic reviews, the Commission should take into consideration the views and findings of the European Parliament and of the Council as well as of other relevant bodies and sources. The Commission should evaluate, within a reasonable time, the functioning of the latter decisions and report any relevant findings to the Committee within the meaning of Regulation (EU) No 182/2011 of the European Parliament and of the Council ([1]) as established under this Regulation, to the European Parliament and to the Council.

(107) The Commission may recognise that a third country, a territory or a specified sector within a third country, or an international organisation no longer ensures an adequate level of data protection. Consequently the transfer of personal data to that third country or international organisation should be prohibited, unless the requirements in this Regulation relating to transfers subject to appropriate safeguards, including binding corporate rules, and derogations for specific situations are fulfilled. In that case, provision should be made for consultations between the Commission and such third countries or international organisations. The Commission should, in a timely manner, inform the third country or international organisation of the reasons and enter into consultations with it in order to remedy the situation.

(108) In the absence of an adequacy decision, the controller or processor should take measures to compensate for the lack of data protection in a third country by way of appropriate safeguards for the data subject. Such appropriate safeguards may consist of making use of binding corporate rules, standard data protection clauses adopted by the Commission, standard data protection clauses adopted by a supervisory authority or contractual clauses authorised by a supervisory authority. Those safeguards should ensure compliance with data protection requirements and the rights of the data subjects appropriate to processing within the Union, including the availability of enforceable data subject rights and of effective legal remedies, including to obtain effective administrative or judicial redress and to claim compensation, in the Union or in a third country. They should relate in particular to compliance with the general principles relating to personal data processing, the principles of data protection by design and by default. Transfers may also be carried out by public authorities or bodies with public authorities or bodies in third countries or with international organisations with corresponding duties or functions, including on the basis of provisions to be inserted into administrative arrangements, such as a memorandum of understanding, providing for enforceable and effective rights for data subjects. Authorisation by the competent supervisory authority should be obtained when the safeguards are provided for in administrative arrangements that are not legally binding.

(109) The possibility for the controller or processor to use standard data-protection clauses adopted by the Commission or by a supervisory authority should prevent controllers or processors neither from including the

([1]) Regulation (EU) No 182/2011 of the European Parliament and of the Council of 16 February 2011 laying down the rules and general principles concerning mechanisms for control by Member States of the Commission's exercise of implementing powers (OJ L 55, 28.2.2011, p. 13).

standard data-protection clauses in a wider contract, such as a contract between the processor and another processor, nor from adding other clauses or additional safeguards provided that they do not contradict, directly or indirectly, the standard contractual clauses adopted by the Commission or by a supervisory authority or prejudice the fundamental rights or freedoms of the data subjects. Controllers and processors should be encouraged to provide additional safeguards via contractual commitments that supplement standard protection clauses.

(110) A group of undertakings, or a group of enterprises engaged in a joint economic activity, should be able to make use of approved binding corporate rules for its international transfers from the Union to organisations within the same group of undertakings, or group of enterprises engaged in a joint economic activity, provided that such corporate rules include all essential principles and enforceable rights to ensure appropriate safeguards for transfers or categories of transfers of personal data.

(111) Provisions should be made for the possibility for transfers in certain circumstances where the data subject has given his or her explicit consent, where the transfer is occasional and necessary in relation to a contract or a legal claim, regardless of whether in a judicial procedure or whether in an administrative or any out-of-court procedure, including procedures before regulatory bodies. Provision should also be made for the possibility for transfers where important grounds of public interest laid down by Union or Member State law so require or where the transfer is made from a register established by law and intended for consultation by the public or persons having a legitimate interest. In the latter case, such a transfer should not involve the entirety of the personal data or entire categories of the data contained in the register and, when the register is intended for consultation by persons having a legitimate interest, the transfer should be made only at the request of those persons or, if they are to be the recipients, taking into full account the interests and fundamental rights of the data subject.

(112) Those derogations should in particular apply to data transfers required and necessary for important reasons of public interest, for example in cases of international data exchange between competition authorities, tax or customs administrations, between financial supervisory authorities, between services competent for social security matters, or for public health, for example in the case of contact tracing for contagious diseases or in order to reduce and/or eliminate doping in sport. A transfer of personal data should also be regarded as lawful where it is necessary to protect an interest which is essential for the data subject's or another person's vital interests, including physical integrity or life, if the data subject is incapable of giving consent. In the absence of an adequacy decision, Union or Member State law may, for important reasons of public interest, expressly set limits to the transfer of specific categories of data to a third country or an international organisation. Member States should notify such provisions to the Commission. Any transfer to an international humanitarian organisation of personal data of a data subject who is physically or legally incapable of giving consent, with a view to accomplishing a task incumbent under the Geneva Conventions or to complying with international humanitarian law applicable in armed conflicts, could be considered to be necessary for an important reason of public interest or because it is in the vital interest of the data subject.

(113) Transfers which can be qualified as not repetitive and that only concern a limited number of data subjects, could also be possible for the purposes of the compelling legitimate interests pursued by the controller, when those interests are not overridden by the interests or rights and freedoms of the data subject and when the controller has assessed all the circumstances surrounding the data transfer. The controller should give particular consideration to the nature of the personal data, the purpose and duration of the proposed processing operation or operations, as well as the situation in the country of origin, the third country and the country of final destination, and should provide suitable safeguards to protect fundamental rights and freedoms of natural persons with regard to the processing of their personal data. Such transfers should be possible only in residual cases where none of the other grounds for transfer are applicable. For scientific or historical research purposes or statistical purposes, the legitimate expectations of society for an increase of knowledge should be taken into consideration. The controller should inform the supervisory authority and the data subject about the transfer.

(114) In any case, where the Commission has taken no decision on the adequate level of data protection in a third country, the controller or processor should make use of solutions that provide data subjects with enforceable and effective rights as regards the processing of their data in the Union once those data have been transferred so that that they will continue to benefit from fundamental rights and safeguards.

(115) Some third countries adopt laws, regulations and other legal acts which purport to directly regulate the processing activities of natural and legal persons under the jurisdiction of the Member States. This may include judgments of courts or tribunals or decisions of administrative authorities in third countries requiring a controller or processor to transfer or disclose personal data, and which are not based on an international agreement, such as a mutual legal assistance treaty, in force between the requesting third country and the Union or a Member State. The extraterritorial application of those laws, regulations and other legal acts may be in breach of international law and may impede the attainment of the protection of natural persons ensured in the Union by this Regulation. Transfers should only be allowed where the conditions of this Regulation for a transfer to third countries are met. This may be the case, inter alia, where disclosure is necessary for an important ground of public interest recognised in Union or Member State law to which the controller is subject.

(116) When personal data moves across borders outside the Union it may put at increased risk the ability of natural persons to exercise data protection rights in particular to protect themselves from the unlawful use or disclosure of that information. At the same time, supervisory authorities may find that they are unable to pursue complaints or conduct investigations relating to the activities outside their borders. Their efforts to work together in the cross-border context may also be hampered by insufficient preventative or remedial powers, inconsistent legal regimes, and practical obstacles like resource constraints. Therefore, there is a need to promote closer cooperation among data protection supervisory authorities to help them exchange information and carry out investigations with their international counterparts. For the purposes of developing international cooperation mechanisms to facilitate and provide international mutual assistance for the enforcement of legislation for the protection of personal data, the Commission and the supervisory authorities should exchange information and cooperate in activities related to the exercise of their powers with competent authorities in third countries, based on reciprocity and in accordance with this Regulation.

(117) The establishment of supervisory authorities in Member States, empowered to perform their tasks and exercise their powers with complete independence, is an essential component of the protection of natural persons with regard to the processing of their personal data. Member States should be able to establish more than one supervisory authority, to reflect their constitutional, organisational and administrative structure.

(118) The independence of supervisory authorities should not mean that the supervisory authorities cannot be subject to control or monitoring mechanisms regarding their financial expenditure or to judicial review.

(119) Where a Member State establishes several supervisory authorities, it should establish by law mechanisms for ensuring the effective participation of those supervisory authorities in the consistency mechanism. That Member State should in particular designate the supervisory authority which functions as a single contact point for the effective participation of those authorities in the mechanism, to ensure swift and smooth cooperation with other supervisory authorities, the Board and the Commission.

(120) Each supervisory authority should be provided with the financial and human resources, premises and infrastructure necessary for the effective performance of their tasks, including those related to mutual assistance and cooperation with other supervisory authorities throughout the Union. Each supervisory authority should have a separate, public annual budget, which may be part of the overall state or national budget.

(121) The general conditions for the member or members of the supervisory authority should be laid down by law in each Member State and should in particular provide that those members are to be appointed, by means of a transparent procedure, either by the parliament, government or the head of State of the Member State on the basis of a proposal from the government, a member of the government, the parliament or a chamber of the parliament, or by an independent body entrusted under Member State law. In order to ensure the independence of the supervisory authority, the member or members should act with integrity, refrain from any action that is incompatible with their duties and should not, during their term of office, engage in any incompatible occupation, whether gainful or not. The supervisory authority should have its own staff, chosen by the supervisory authority or an independent body established by Member State law, which should be subject to the exclusive direction of the member or members of the supervisory authority.

(122) Each supervisory authority should be competent on the territory of its own Member State to exercise the powers and to perform the tasks conferred on it in accordance with this Regulation. This should cover in particular the

processing in the context of the activities of an establishment of the controller or processor on the territory of its own Member State, the processing of personal data carried out by public authorities or private bodies acting in the public interest, processing affecting data subjects on its territory or processing carried out by a controller or processor not established in the Union when targeting data subjects residing on its territory. This should include handling complaints lodged by a data subject, conducting investigations on the application of this Regulation and promoting public awareness of the risks, rules, safeguards and rights in relation to the processing of personal data.

(123) The supervisory authorities should monitor the application of the provisions pursuant to this Regulation and contribute to its consistent application throughout the Union, in order to protect natural persons in relation to the processing of their personal data and to facilitate the free flow of personal data within the internal market. For that purpose, the supervisory authorities should cooperate with each other and with the Commission, without the need for any agreement between Member States on the provision of mutual assistance or on such cooperation.

(124) Where the processing of personal data takes place in the context of the activities of an establishment of a controller or a processor in the Union and the controller or processor is established in more than one Member State, or where processing taking place in the context of the activities of a single establishment of a controller or processor in the Union substantially affects or is likely to substantially affect data subjects in more than one Member State, the supervisory authority for the main establishment of the controller or processor or for the single establishment of the controller or processor should act as lead authority. It should cooperate with the other authorities concerned, because the controller or processor has an establishment on the territory of their Member State, because data subjects residing on their territory are substantially affected, or because a complaint has been lodged with them. Also where a data subject not residing in that Member State has lodged a complaint, the supervisory authority with which such complaint has been lodged should also be a supervisory authority concerned. Within its tasks to issue guidelines on any question covering the application of this Regulation, the Board should be able to issue guidelines in particular on the criteria to be taken into account in order to ascertain whether the processing in question substantially affects data subjects in more than one Member State and on what constitutes a relevant and reasoned objection.

(125) The lead authority should be competent to adopt binding decisions regarding measures applying the powers conferred on it in accordance with this Regulation. In its capacity as lead authority, the supervisory authority should closely involve and coordinate the supervisory authorities concerned in the decision-making process. Where the decision is to reject the complaint by the data subject in whole or in part, that decision should be adopted by the supervisory authority with which the complaint has been lodged.

(126) The decision should be agreed jointly by the lead supervisory authority and the supervisory authorities concerned and should be directed towards the main or single establishment of the controller or processor and be binding on the controller and processor. The controller or processor should take the necessary measures to ensure compliance with this Regulation and the implementation of the decision notified by the lead supervisory authority to the main establishment of the controller or processor as regards the processing activities in the Union.

(127) Each supervisory authority not acting as the lead supervisory authority should be competent to handle local cases where the controller or processor is established in more than one Member State, but the subject matter of the specific processing concerns only processing carried out in a single Member State and involves only data subjects in that single Member State, for example, where the subject matter concerns the processing of employees' personal data in the specific employment context of a Member State. In such cases, the supervisory authority should inform the lead supervisory authority without delay about the matter. After being informed, the lead supervisory authority should decide, whether it will handle the case pursuant to the provision on cooperation between the lead supervisory authority and other supervisory authorities concerned ('one-stop-shop mechanism'), or whether the supervisory authority which informed it should handle the case at local level. When deciding whether it will handle the case, the lead supervisory authority should take into account whether there is an establishment of the controller or processor in the Member State of the supervisory authority which informed it in order to ensure effective enforcement of a decision *vis-à-vis* the controller or processor. Where the lead supervisory authority decides to handle the case, the supervisory authority which informed it should have the

possibility to submit a draft for a decision, of which the lead supervisory authority should take utmost account when preparing its draft decision in that one-stop-shop mechanism.

(128) The rules on the lead supervisory authority and the one-stop-shop mechanism should not apply where the processing is carried out by public authorities or private bodies in the public interest. In such cases the only supervisory authority competent to exercise the powers conferred to it in accordance with this Regulation should be the supervisory authority of the Member State where the public authority or private body is established.

(129) In order to ensure consistent monitoring and enforcement of this Regulation throughout the Union, the supervisory authorities should have in each Member State the same tasks and effective powers, including powers of investigation, corrective powers and sanctions, and authorisation and advisory powers, in particular in cases of complaints from natural persons, and without prejudice to the powers of prosecutorial authorities under Member State law, to bring infringements of this Regulation to the attention of the judicial authorities and engage in legal proceedings. Such powers should also include the power to impose a temporary or definitive limitation, including a ban, on processing. Member States may specify other tasks related to the protection of personal data under this Regulation. The powers of supervisory authorities should be exercised in accordance with appropriate procedural safeguards set out in Union and Member State law, impartially, fairly and within a reasonable time. In particular each measure should be appropriate, necessary and proportionate in view of ensuring compliance with this Regulation, taking into account the circumstances of each individual case, respect the right of every person to be heard before any individual measure which would affect him or her adversely is taken and avoid superfluous costs and excessive inconveniences for the persons concerned. Investigatory powers as regards access to premises should be exercised in accordance with specific requirements in Member State procedural law, such as the requirement to obtain a prior judicial authorisation. Each legally binding measure of the supervisory authority should be in writing, be clear and unambiguous, indicate the supervisory authority which has issued the measure, the date of issue of the measure, bear the signature of the head, or a member of the supervisory authority authorised by him or her, give the reasons for the measure, and refer to the right of an effective remedy. This should not preclude additional requirements pursuant to Member State procedural law. The adoption of a legally binding decision implies that it may give rise to judicial review in the Member State of the supervisory authority that adopted the decision.

(130) Where the supervisory authority with which the complaint has been lodged is not the lead supervisory authority, the lead supervisory authority should closely cooperate with the supervisory authority with which the complaint has been lodged in accordance with the provisions on cooperation and consistency laid down in this Regulation. In such cases, the lead supervisory authority should, when taking measures intended to produce legal effects, including the imposition of administrative fines, take utmost account of the view of the supervisory authority with which the complaint has been lodged and which should remain competent to carry out any investigation on the territory of its own Member State in liaison with the competent supervisory authority.

(131) Where another supervisory authority should act as a lead supervisory authority for the processing activities of the controller or processor but the concrete subject matter of a complaint or the possible infringement concerns only processing activities of the controller or processor in the Member State where the complaint has been lodged or the possible infringement detected and the matter does not substantially affect or is not likely to substantially affect data subjects in other Member States, the supervisory authority receiving a complaint or detecting or being informed otherwise of situations that entail possible infringements of this Regulation should seek an amicable settlement with the controller and, if this proves unsuccessful, exercise its full range of powers. This should include: specific processing carried out in the territory of the Member State of the supervisory authority or with regard to data subjects on the territory of that Member State; processing that is carried out in the context of an offer of goods or services specifically aimed at data subjects in the territory of the Member State of the supervisory authority; or processing that has to be assessed taking into account relevant legal obligations under Member State law.

(132) Awareness-raising activities by supervisory authorities addressed to the public should include specific measures directed at controllers and processors, including micro, small and medium-sized enterprises, as well as natural persons in particular in the educational context.

(133) The supervisory authorities should assist each other in performing their tasks and provide mutual assistance, so as to ensure the consistent application and enforcement of this Regulation in the internal market. A supervisory authority requesting mutual assistance may adopt a provisional measure if it receives no response to a request for mutual assistance within one month of the receipt of that request by the other supervisory authority.

(134) Each supervisory authority should, where appropriate, participate in joint operations with other supervisory authorities. The requested supervisory authority should be obliged to respond to the request within a specified time period.

(135) In order to ensure the consistent application of this Regulation throughout the Union, a consistency mechanism for cooperation between the supervisory authorities should be established. That mechanism should in particular apply where a supervisory authority intends to adopt a measure intended to produce legal effects as regards processing operations which substantially affect a significant number of data subjects in several Member States. It should also apply where any supervisory authority concerned or the Commission requests that such matter should be handled in the consistency mechanism. That mechanism should be without prejudice to any measures that the Commission may take in the exercise of its powers under the Treaties.

(136) In applying the consistency mechanism, the Board should, within a determined period of time, issue an opinion, if a majority of its members so decides or if so requested by any supervisory authority concerned or the Commission. The Board should also be empowered to adopt legally binding decisions where there are disputes between supervisory authorities. For that purpose, it should issue, in principle by a two-thirds majority of its members, legally binding decisions in clearly specified cases where there are conflicting views among supervisory authorities, in particular in the cooperation mechanism between the lead supervisory authority and supervisory authorities concerned on the merits of the case, in particular whether there is an infringement of this Regulation.

(137) There may be an urgent need to act in order to protect the rights and freedoms of data subjects, in particular when the danger exists that the enforcement of a right of a data subject could be considerably impeded. A supervisory authority should therefore be able to adopt duly justified provisional measures on its territory with a specified period of validity which should not exceed three months.

(138) The application of such mechanism should be a condition for the lawfulness of a measure intended to produce legal effects by a supervisory authority in those cases where its application is mandatory. In other cases of cross-border relevance, the cooperation mechanism between the lead supervisory authority and supervisory authorities concerned should be applied and mutual assistance and joint operations might be carried out between the supervisory authorities concerned on a bilateral or multilateral basis without triggering the consistency mechanism.

(139) In order to promote the consistent application of this Regulation, the Board should be set up as an independent body of the Union. To fulfil its objectives, the Board should have legal personality. The Board should be represented by its Chair. It should replace the Working Party on the Protection of Individuals with Regard to the Processing of Personal Data established by Directive 95/46/EC. It should consist of the head of a supervisory authority of each Member State and the European Data Protection Supervisor or their respective representatives. The Commission should participate in the Board's activities without voting rights and the European Data Protection Supervisor should have specific voting rights. The Board should contribute to the consistent application of this Regulation throughout the Union, including by advising the Commission, in particular on the level of protection in third countries or international organisations, and promoting cooperation of the supervisory authorities throughout the Union. The Board should act independently when performing its tasks.

(140) The Board should be assisted by a secretariat provided by the European Data Protection Supervisor. The staff of the European Data Protection Supervisor involved in carrying out the tasks conferred on the Board by this Regulation should perform its tasks exclusively under the instructions of, and report to, the Chair of the Board.

(141) Every data subject should have the right to lodge a complaint with a single supervisory authority, in particular in the Member State of his or her habitual residence, and the right to an effective judicial remedy in accordance

with Article 47 of the Charter if the data subject considers that his or her rights under this Regulation are infringed or where the supervisory authority does not act on a complaint, partially or wholly rejects or dismisses a complaint or does not act where such action is necessary to protect the rights of the data subject. The investigation following a complaint should be carried out, subject to judicial review, to the extent that is appropriate in the specific case. The supervisory authority should inform the data subject of the progress and the outcome of the complaint within a reasonable period. If the case requires further investigation or coordination with another supervisory authority, intermediate information should be given to the data subject. In order to facilitate the submission of complaints, each supervisory authority should take measures such as providing a complaint submission form which can also be completed electronically, without excluding other means of communication.

(142) Where a data subject considers that his or her rights under this Regulation are infringed, he or she should have the right to mandate a not-for-profit body, organisation or association which is constituted in accordance with the law of a Member State, has statutory objectives which are in the public interest and is active in the field of the protection of personal data to lodge a complaint on his or her behalf with a supervisory authority, exercise the right to a judicial remedy on behalf of data subjects or, if provided for in Member State law, exercise the right to receive compensation on behalf of data subjects. A Member State may provide for such a body, organisation or association to have the right to lodge a complaint in that Member State, independently of a data subject's mandate, and the right to an effective judicial remedy where it has reasons to consider that the rights of a data subject have been infringed as a result of the processing of personal data which infringes this Regulation. That body, organisation or association may not be allowed to claim compensation on a data subject's behalf independently of the data subject's mandate.

(143) Any natural or legal person has the right to bring an action for annulment of decisions of the Board before the Court of Justice under the conditions provided for in Article 263 TFEU. As addressees of such decisions, the supervisory authorities concerned which wish to challenge them have to bring action within two months of being notified of them, in accordance with Article 263 TFEU. Where decisions of the Board are of direct and individual concern to a controller, processor or complainant, the latter may bring an action for annulment against those decisions within two months of their publication on the website of the Board, in accordance with Article 263 TFEU. Without prejudice to this right under Article 263 TFEU, each natural or legal person should have an effective judicial remedy before the competent national court against a decision of a supervisory authority which produces legal effects concerning that person. Such a decision concerns in particular the exercise of investigative, corrective and authorisation powers by the supervisory authority or the dismissal or rejection of complaints. However, the right to an effective judicial remedy does not encompass measures taken by supervisory authorities which are not legally binding, such as opinions issued by or advice provided by the supervisory authority. Proceedings against a supervisory authority should be brought before the courts of the Member State where the supervisory authority is established and should be conducted in accordance with that Member State's procedural law. Those courts should exercise full jurisdiction, which should include jurisdiction to examine all questions of fact and law relevant to the dispute before them.

Where a complaint has been rejected or dismissed by a supervisory authority, the complainant may bring proceedings before the courts in the same Member State. In the context of judicial remedies relating to the application of this Regulation, national courts which consider a decision on the question necessary to enable them to give judgment, may, or in the case provided for in Article 267 TFEU, must, request the Court of Justice to give a preliminary ruling on the interpretation of Union law, including this Regulation. Furthermore, where a decision of a supervisory authority implementing a decision of the Board is challenged before a national court and the validity of the decision of the Board is at issue, that national court does not have the power to declare the Board's decision invalid but must refer the question of validity to the Court of Justice in accordance with Article 267 TFEU as interpreted by the Court of Justice, where it considers the decision invalid. However, a national court may not refer a question on the validity of the decision of the Board at the request of a natural or legal person which had the opportunity to bring an action for annulment of that decision, in particular if it was directly and individually concerned by that decision, but had not done so within the period laid down in Article 263 TFEU.

(144) Where a court seized of proceedings against a decision by a supervisory authority has reason to believe that proceedings concerning the same processing, such as the same subject matter as regards processing by the same controller or processor, or the same cause of action, are brought before a competent court in another Member State, it should contact that court in order to confirm the existence of such related proceedings. If related proceedings are pending before a court in another Member State, any court other than the court first

seized may stay its proceedings or may, on request of one of the parties, decline jurisdiction in favour of the court first seized if that court has jurisdiction over the proceedings in question and its law permits the consolidation of such related proceedings. Proceedings are deemed to be related where they are so closely connected that it is expedient to hear and determine them together in order to avoid the risk of irreconcilable judgments resulting from separate proceedings.

(145) For proceedings against a controller or processor, the plaintiff should have the choice to bring the action before the courts of the Member States where the controller or processor has an establishment or where the data subject resides, unless the controller is a public authority of a Member State acting in the exercise of its public powers.

(146) The controller or processor should compensate any damage which a person may suffer as a result of processing that infringes this Regulation. The controller or processor should be exempt from liability if it proves that it is not in any way responsible for the damage. The concept of damage should be broadly interpreted in the light of the case-law of the Court of Justice in a manner which fully reflects the objectives of this Regulation. This is without prejudice to any claims for damage deriving from the violation of other rules in Union or Member State law. Processing that infringes this Regulation also includes processing that infringes delegated and implementing acts adopted in accordance with this Regulation and Member State law specifying rules of this Regulation. Data subjects should receive full and effective compensation for the damage they have suffered. Where controllers or processors are involved in the same processing, each controller or processor should be held liable for the entire damage. However, where they are joined to the same judicial proceedings, in accordance with Member State law, compensation may be apportioned according to the responsibility of each controller or processor for the damage caused by the processing, provided that full and effective compensation of the data subject who suffered the damage is ensured. Any controller or processor which has paid full compensation may subsequently institute recourse proceedings against other controllers or processors involved in the same processing.

(147) Where specific rules on jurisdiction are contained in this Regulation, in particular as regards proceedings seeking a judicial remedy including compensation, against a controller or processor, general jurisdiction rules such as those of Regulation (EU) No 1215/2012 of the European Parliament and of the Council [1] should not prejudice the application of such specific rules.

(148) In order to strengthen the enforcement of the rules of this Regulation, penalties including administrative fines should be imposed for any infringement of this Regulation, in addition to, or instead of appropriate measures imposed by the supervisory authority pursuant to this Regulation. In a case of a minor infringement or if the fine likely to be imposed would constitute a disproportionate burden to a natural person, a reprimand may be issued instead of a fine. Due regard should however be given to the nature, gravity and duration of the infringement, the intentional character of the infringement, actions taken to mitigate the damage suffered, degree of responsibility or any relevant previous infringements, the manner in which the infringement became known to the supervisory authority, compliance with measures ordered against the controller or processor, adherence to a code of conduct and any other aggravating or mitigating factor. The imposition of penalties including administrative fines should be subject to appropriate procedural safeguards in accordance with the general principles of Union law and the Charter, including effective judicial protection and due process.

(149) Member States should be able to lay down the rules on criminal penalties for infringements of this Regulation, including for infringements of national rules adopted pursuant to and within the limits of this Regulation. Those criminal penalties may also allow for the deprivation of the profits obtained through infringements of this Regulation. However, the imposition of criminal penalties for infringements of such national rules and of administrative penalties should not lead to a breach of the principle of *ne bis in idem*, as interpreted by the Court of Justice.

(150) In order to strengthen and harmonise administrative penalties for infringements of this Regulation, each supervisory authority should have the power to impose administrative fines. This Regulation should indicate

[1] Regulation (EU) No 1215/2012 of the European Parliament and of the Council of 12 December 2012 on jurisdiction and the recognition and enforcement of judgments in civil and commercial matters (OJ L 351, 20.12.2012, p. 1).

infringements and the upper limit and criteria for setting the related administrative fines, which should be determined by the competent supervisory authority in each individual case, taking into account all relevant circumstances of the specific situation, with due regard in particular to the nature, gravity and duration of the infringement and of its consequences and the measures taken to ensure compliance with the obligations under this Regulation and to prevent or mitigate the consequences of the infringement. Where administrative fines are imposed on an undertaking, an undertaking should be understood to be an undertaking in accordance with Articles 101 and 102 TFEU for those purposes. Where administrative fines are imposed on persons that are not an undertaking, the supervisory authority should take account of the general level of income in the Member State as well as the economic situation of the person in considering the appropriate amount of the fine. The consistency mechanism may also be used to promote a consistent application of administrative fines. It should be for the Member States to determine whether and to which extent public authorities should be subject to administrative fines. Imposing an administrative fine or giving a warning does not affect the application of other powers of the supervisory authorities or of other penalties under this Regulation.

(151) The legal systems of Denmark and Estonia do not allow for administrative fines as set out in this Regulation. The rules on administrative fines may be applied in such a manner that in Denmark the fine is imposed by competent national courts as a criminal penalty and in Estonia the fine is imposed by the supervisory authority in the framework of a misdemeanour procedure, provided that such an application of the rules in those Member States has an equivalent effect to administrative fines imposed by supervisory authorities. Therefore the competent national courts should take into account the recommendation by the supervisory authority initiating the fine. In any event, the fines imposed should be effective, proportionate and dissuasive.

(152) Where this Regulation does not harmonise administrative penalties or where necessary in other cases, for example in cases of serious infringements of this Regulation, Member States should implement a system which provides for effective, proportionate and dissuasive penalties. The nature of such penalties, criminal or administrative, should be determined by Member State law.

(153) Member States law should reconcile the rules governing freedom of expression and information, including journalistic, academic, artistic and or literary expression with the right to the protection of personal data pursuant to this Regulation. The processing of personal data solely for journalistic purposes, or for the purposes of academic, artistic or literary expression should be subject to derogations or exemptions from certain provisions of this Regulation if necessary to reconcile the right to the protection of personal data with the right to freedom of expression and information, as enshrined in Article 11 of the Charter. This should apply in particular to the processing of personal data in the audiovisual field and in news archives and press libraries. Therefore, Member States should adopt legislative measures which lay down the exemptions and derogations necessary for the purpose of balancing those fundamental rights. Member States should adopt such exemptions and derogations on general principles, the rights of the data subject, the controller and the processor, the transfer of personal data to third countries or international organisations, the independent supervisory authorities, cooperation and consistency, and specific data-processing situations. Where such exemptions or derogations differ from one Member State to another, the law of the Member State to which the controller is subject should apply. In order to take account of the importance of the right to freedom of expression in every democratic society, it is necessary to interpret notions relating to that freedom, such as journalism, broadly.

(154) This Regulation allows the principle of public access to official documents to be taken into account when applying this Regulation. Public access to official documents may be considered to be in the public interest. Personal data in documents held by a public authority or a public body should be able to be publicly disclosed by that authority or body if the disclosure is provided for by Union or Member State law to which the public authority or public body is subject. Such laws should reconcile public access to official documents and the reuse of public sector information with the right to the protection of personal data and may therefore provide for the necessary reconciliation with the right to the protection of personal data pursuant to this Regulation. The reference to public authorities and bodies should in that context include all authorities or other bodies covered by Member State law on public access to documents. Directive 2003/98/EC of the European Parliament and of the Council ([1]) leaves intact and in no way affects the level of protection of natural persons with regard to the

([1]) Directive 2003/98/EC of the European Parliament and of the Council of 17 November 2003 on the re-use of public sector information (OJ L 345, 31.12.2003, p. 90).

processing of personal data under the provisions of Union and Member State law, and in particular does not alter the obligations and rights set out in this Regulation. In particular, that Directive should not apply to documents to which access is excluded or restricted by virtue of the access regimes on the grounds of protection of personal data, and parts of documents accessible by virtue of those regimes which contain personal data the re-use of which has been provided for by law as being incompatible with the law concerning the protection of natural persons with regard to the processing of personal data.

(155) Member State law or collective agreements, including 'works agreements', may provide for specific rules on the processing of employees' personal data in the employment context, in particular for the conditions under which personal data in the employment context may be processed on the basis of the consent of the employee, the purposes of the recruitment, the performance of the contract of employment, including discharge of obligations laid down by law or by collective agreements, management, planning and organisation of work, equality and diversity in the workplace, health and safety at work, and for the purposes of the exercise and enjoyment, on an individual or collective basis, of rights and benefits related to employment, and for the purpose of the termination of the employment relationship.

(156) The processing of personal data for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes should be subject to appropriate safeguards for the rights and freedoms of the data subject pursuant to this Regulation. Those safeguards should ensure that technical and organisational measures are in place in order to ensure, in particular, the principle of data minimisation. The further processing of personal data for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes is to be carried out when the controller has assessed the feasibility to fulfil those purposes by processing data which do not permit or no longer permit the identification of data subjects, provided that appropriate safeguards exist (such as, for instance, pseudonymisation of the data). Member States should provide for appropriate safeguards for the processing of personal data for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes. Member States should be authorised to provide, under specific conditions and subject to appropriate safeguards for data subjects, specifications and derogations with regard to the information requirements and rights to rectification, to erasure, to be forgotten, to restriction of processing, to data portability, and to object when processing personal data for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes. The conditions and safeguards in question may entail specific procedures for data subjects to exercise those rights if this is appropriate in the light of the purposes sought by the specific processing along with technical and organisational measures aimed at minimising the processing of personal data in pursuance of the proportionality and necessity principles. The processing of personal data for scientific purposes should also comply with other relevant legislation such as on clinical trials.

(157) By coupling information from registries, researchers can obtain new knowledge of great value with regard to widespread medical conditions such as cardiovascular disease, cancer and depression. On the basis of registries, research results can be enhanced, as they draw on a larger population. Within social science, research on the basis of registries enables researchers to obtain essential knowledge about the long-term correlation of a number of social conditions such as unemployment and education with other life conditions. Research results obtained through registries provide solid, high-quality knowledge which can provide the basis for the formulation and implementation of knowledge-based policy, improve the quality of life for a number of people and improve the efficiency of social services. In order to facilitate scientific research, personal data can be processed for scientific research purposes, subject to appropriate conditions and safeguards set out in Union or Member State law.

(158) Where personal data are processed for archiving purposes, this Regulation should also apply to that processing, bearing in mind that this Regulation should not apply to deceased persons. Public authorities or public or private bodies that hold records of public interest should be services which, pursuant to Union or Member State law, have a legal obligation to acquire, preserve, appraise, arrange, describe, communicate, promote, disseminate and provide access to records of enduring value for general public interest. Member States should also be authorised to provide for the further processing of personal data for archiving purposes, for example with a view to providing specific information related to the political behaviour under former totalitarian state regimes, genocide, crimes against humanity, in particular the Holocaust, or war crimes.

(159) Where personal data are processed for scientific research purposes, this Regulation should also apply to that processing. For the purposes of this Regulation, the processing of personal data for scientific research purposes should be interpreted in a broad manner including for example technological development and demonstration, fundamental research, applied research and privately funded research. In addition, it should take into account the Union's objective under Article 179(1) TFEU of achieving a European Research Area. Scientific research purposes should also include studies conducted in the public interest in the area of public health. To meet the specificities of processing personal data for scientific research purposes, specific conditions should apply in particular as regards the publication or otherwise disclosure of personal data in the context of scientific research purposes. If the result of scientific research in particular in the health context gives reason for further measures in the interest of the data subject, the general rules of this Regulation should apply in view of those measures.

(160) Where personal data are processed for historical research purposes, this Regulation should also apply to that processing. This should also include historical research and research for genealogical purposes, bearing in mind that this Regulation should not apply to deceased persons.

(161) For the purpose of consenting to the participation in scientific research activities in clinical trials, the relevant provisions of Regulation (EU) No 536/2014 of the European Parliament and of the Council ([1]) should apply.

(162) Where personal data are processed for statistical purposes, this Regulation should apply to that processing. Union or Member State law should, within the limits of this Regulation, determine statistical content, control of access, specifications for the processing of personal data for statistical purposes and appropriate measures to safeguard the rights and freedoms of the data subject and for ensuring statistical confidentiality. Statistical purposes mean any operation of collection and the processing of personal data necessary for statistical surveys or for the production of statistical results. Those statistical results may further be used for different purposes, including a scientific research purpose. The statistical purpose implies that the result of processing for statistical purposes is not personal data, but aggregate data, and that this result or the personal data are not used in support of measures or decisions regarding any particular natural person.

(163) The confidential information which the Union and national statistical authorities collect for the production of official European and official national statistics should be protected. European statistics should be developed, produced and disseminated in accordance with the statistical principles as set out in Article 338(2) TFEU, while national statistics should also comply with Member State law. Regulation (EC) No 223/2009 of the European Parliament and of the Council ([2]) provides further specifications on statistical confidentiality for European statistics.

(164) As regards the powers of the supervisory authorities to obtain from the controller or processor access to personal data and access to their premises, Member States may adopt by law, within the limits of this Regulation, specific rules in order to safeguard the professional or other equivalent secrecy obligations, in so far as necessary to reconcile the right to the protection of personal data with an obligation of professional secrecy. This is without prejudice to existing Member State obligations to adopt rules on professional secrecy where required by Union law.

(165) This Regulation respects and does not prejudice the status under existing constitutional law of churches and religious associations or communities in the Member States, as recognised in Article 17 TFEU.

(166) In order to fulfil the objectives of this Regulation, namely to protect the fundamental rights and freedoms of natural persons and in particular their right to the protection of personal data and to ensure the free movement

([1]) Regulation (EU) No 536/2014 of the European Parliament and of the Council of 16 April 2014 on clinical trials on medicinal products for human use, and repealing Directive 2001/20/EC (OJ L 158, 27.5.2014, p. 1).

([2]) Regulation (EC) No 223/2009 of the European Parliament and of the Council of 11 March 2009 on European statistics and repealing Regulation (EC, Euratom) No 1101/2008 of the European Parliament and of the Council on the transmission of data subject to statistical confidentiality to the Statistical Office of the European Communities, Council Regulation (EC) No 322/97 on Community Statistics, and Council Decision 89/382/EEC, Euratom establishing a Committee on the Statistical Programmes of the European Communities (OJ L 87, 31.3.2009, p. 164).

of personal data within the Union, the power to adopt acts in accordance with Article 290 TFEU should be delegated to the Commission. In particular, delegated acts should be adopted in respect of criteria and requirements for certification mechanisms, information to be presented by standardised icons and procedures for providing such icons. It is of particular importance that the Commission carry out appropriate consultations during its preparatory work, including at expert level. The Commission, when preparing and drawing-up delegated acts, should ensure a simultaneous, timely and appropriate transmission of relevant documents to the European Parliament and to the Council.

(167) In order to ensure uniform conditions for the implementation of this Regulation, implementing powers should be conferred on the Commission when provided for by this Regulation. Those powers should be exercised in accordance with Regulation (EU) No 182/2011. In that context, the Commission should consider specific measures for micro, small and medium-sized enterprises.

(168) The examination procedure should be used for the adoption of implementing acts on standard contractual clauses between controllers and processors and between processors; codes of conduct; technical standards and mechanisms for certification; the adequate level of protection afforded by a third country, a territory or a specified sector within that third country, or an international organisation; standard protection clauses; formats and procedures for the exchange of information by electronic means between controllers, processors and supervisory authorities for binding corporate rules; mutual assistance; and arrangements for the exchange of information by electronic means between supervisory authorities, and between supervisory authorities and the Board.

(169) The Commission should adopt immediately applicable implementing acts where available evidence reveals that a third country, a territory or a specified sector within that third country, or an international organisation does not ensure an adequate level of protection, and imperative grounds of urgency so require.

(170) Since the objective of this Regulation, namely to ensure an equivalent level of protection of natural persons and the free flow of personal data throughout the Union, cannot be sufficiently achieved by the Member States and can rather, by reason of the scale or effects of the action, be better achieved at Union level, the Union may adopt measures, in accordance with the principle of subsidiarity as set out in Article 5 of the Treaty on European Union (TEU). In accordance with the principle of proportionality as set out in that Article, this Regulation does not go beyond what is necessary in order to achieve that objective.

(171) Directive 95/46/EC should be repealed by this Regulation. Processing already under way on the date of application of this Regulation should be brought into conformity with this Regulation within the period of two years after which this Regulation enters into force. Where processing is based on consent pursuant to Directive 95/46/EC, it is not necessary for the data subject to give his or her consent again if the manner in which the consent has been given is in line with the conditions of this Regulation, so as to allow the controller to continue such processing after the date of application of this Regulation. Commission decisions adopted and authorisations by supervisory authorities based on Directive 95/46/EC remain in force until amended, replaced or repealed.

(172) The European Data Protection Supervisor was consulted in accordance with Article 28(2) of Regulation (EC) No 45/2001 and delivered an opinion on 7 March 2012 ([1]).

(173) This Regulation should apply to all matters concerning the protection of fundamental rights and freedoms *vis-à-vis* the processing of personal data which are not subject to specific obligations with the same objective set out in Directive 2002/58/EC of the European Parliament and of the Council ([2]), including the obligations on the controller and the rights of natural persons. In order to clarify the relationship between this Regulation and Directive 2002/58/EC, that Directive should be amended accordingly. Once this Regulation is adopted, Directive 2002/58/EC should be reviewed in particular in order to ensure consistency with this Regulation,

([1]) OJ C 192, 30.6.2012, p. 7.
([2]) Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications) (OJ L 201, 31.7.2002, p. 37).

HAVE ADOPTED THIS REGULATION:

CHAPTER I

General provisions

Article 1

Subject-matter and objectives

1. This Regulation lays down rules relating to the protection of natural persons with regard to the processing of personal data and rules relating to the free movement of personal data.

2. This Regulation protects fundamental rights and freedoms of natural persons and in particular their right to the protection of personal data.

3. The free movement of personal data within the Union shall be neither restricted nor prohibited for reasons connected with the protection of natural persons with regard to the processing of personal data.

Article 2

Material scope

1. This Regulation applies to the processing of personal data wholly or partly by automated means and to the processing other than by automated means of personal data which form part of a filing system or are intended to form part of a filing system.

2. This Regulation does not apply to the processing of personal data:

(a) in the course of an activity which falls outside the scope of Union law;

(b) by the Member States when carrying out activities which fall within the scope of Chapter 2 of Title V of the TEU;

(c) by a natural person in the course of a purely personal or household activity;

(d) by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security.

3. For the processing of personal data by the Union institutions, bodies, offices and agencies, Regulation (EC) No 45/2001 applies. Regulation (EC) No 45/2001 and other Union legal acts applicable to such processing of personal data shall be adapted to the principles and rules of this Regulation in accordance with Article 98.

4. This Regulation shall be without prejudice to the application of Directive 2000/31/EC, in particular of the liability rules of intermediary service providers in Articles 12 to 15 of that Directive.

Article 3

Territorial scope

1. This Regulation applies to the processing of personal data in the context of the activities of an establishment of a controller or a processor in the Union, regardless of whether the processing takes place in the Union or not.

2. This Regulation applies to the processing of personal data of data subjects who are in the Union by a controller or processor not established in the Union, where the processing activities are related to:

(a) the offering of goods or services, irrespective of whether a payment of the data subject is required, to such data subjects in the Union; or

(b) the monitoring of their behaviour as far as their behaviour takes place within the Union.

3. This Regulation applies to the processing of personal data by a controller not established in the Union, but in a place where Member State law applies by virtue of public international law.

Article 4

Definitions

For the purposes of this Regulation:

(1) 'personal data' means any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person;

(2) 'processing' means any operation or set of operations which is performed on personal data or on sets of personal data, whether or not by automated means, such as collection, recording, organisation, structuring, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, alignment or combination, restriction, erasure or destruction;

(3) 'restriction of processing' means the marking of stored personal data with the aim of limiting their processing in the future;

(4) 'profiling' means any form of automated processing of personal data consisting of the use of personal data to evaluate certain personal aspects relating to a natural person, in particular to analyse or predict aspects concerning that natural person's performance at work, economic situation, health, personal preferences, interests, reliability, behaviour, location or movements;

(5) 'pseudonymisation' means the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person;

(6) 'filing system' means any structured set of personal data which are accessible according to specific criteria, whether centralised, decentralised or dispersed on a functional or geographical basis;

(7) 'controller' means the natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union or Member State law, the controller or the specific criteria for its nomination may be provided for by Union or Member State law;

(8) 'processor' means a natural or legal person, public authority, agency or other body which processes personal data on behalf of the controller;

(9) 'recipient' means a natural or legal person, public authority, agency or another body, to which the personal data are disclosed, whether a third party or not. However, public authorities which may receive personal data in the

framework of a particular inquiry in accordance with Union or Member State law shall not be regarded as recipients; the processing of those data by those public authorities shall be in compliance with the applicable data protection rules according to the purposes of the processing;

(10) 'third party' means a natural or legal person, public authority, agency or body other than the data subject, controller, processor and persons who, under the direct authority of the controller or processor, are authorised to process personal data;

(11) 'consent' of the data subject means any freely given, specific, informed and unambiguous indication of the data subject's wishes by which he or she, by a statement or by a clear affirmative action, signifies agreement to the processing of personal data relating to him or her;

(12) 'personal data breach' means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed;

(13) 'genetic data' means personal data relating to the inherited or acquired genetic characteristics of a natural person which give unique information about the physiology or the health of that natural person and which result, in particular, from an analysis of a biological sample from the natural person in question;

(14) 'biometric data' means personal data resulting from specific technical processing relating to the physical, physiological or behavioural characteristics of a natural person, which allow or confirm the unique identification of that natural person, such as facial images or dactyloscopic data;

(15) 'data concerning health' means personal data related to the physical or mental health of a natural person, including the provision of health care services, which reveal information about his or her health status;

(16) 'main establishment' means:

(a) as regards a controller with establishments in more than one Member State, the place of its central administration in the Union, unless the decisions on the purposes and means of the processing of personal data are taken in another establishment of the controller in the Union and the latter establishment has the power to have such decisions implemented, in which case the establishment having taken such decisions is to be considered to be the main establishment;

(b) as regards a processor with establishments in more than one Member State, the place of its central administration in the Union, or, if the processor has no central administration in the Union, the establishment of the processor in the Union where the main processing activities in the context of the activities of an establishment of the processor take place to the extent that the processor is subject to specific obligations under this Regulation;

(17) 'representative' means a natural or legal person established in the Union who, designated by the controller or processor in writing pursuant to Article 27, represents the controller or processor with regard to their respective obligations under this Regulation;

(18) 'enterprise' means a natural or legal person engaged in an economic activity, irrespective of its legal form, including partnerships or associations regularly engaged in an economic activity;

(19) 'group of undertakings' means a controlling undertaking and its controlled undertakings;

(20) 'binding corporate rules' means personal data protection policies which are adhered to by a controller or processor established on the territory of a Member State for transfers or a set of transfers of personal data to a controller or processor in one or more third countries within a group of undertakings, or group of enterprises engaged in a joint economic activity;

(21) 'supervisory authority' means an independent public authority which is established by a Member State pursuant to Article 51;

(22) 'supervisory authority concerned' means a supervisory authority which is concerned by the processing of personal data because:

(a) the controller or processor is established on the territory of the Member State of that supervisory authority;

(b) data subjects residing in the Member State of that supervisory authority are substantially affected or likely to be substantially affected by the processing; or

(c) a complaint has been lodged with that supervisory authority;

(23) 'cross-border processing' means either:

(a) processing of personal data which takes place in the context of the activities of establishments in more than one Member State of a controller or processor in the Union where the controller or processor is established in more than one Member State; or

(b) processing of personal data which takes place in the context of the activities of a single establishment of a controller or processor in the Union but which substantially affects or is likely to substantially affect data subjects in more than one Member State.

(24) 'relevant and reasoned objection' means an objection to a draft decision as to whether there is an infringement of this Regulation, or whether envisaged action in relation to the controller or processor complies with this Regulation, which clearly demonstrates the significance of the risks posed by the draft decision as regards the fundamental rights and freedoms of data subjects and, where applicable, the free flow of personal data within the Union;

(25) 'information society service' means a service as defined in point (b) of Article 1(1) of Directive (EU) 2015/1535 of the European Parliament and of the Council [1];

(26) 'international organisation' means an organisation and its subordinate bodies governed by public international law, or any other body which is set up by, or on the basis of, an agreement between two or more countries.

CHAPTER II

Principles

Article 5

Principles relating to processing of personal data

1. Personal data shall be:

(a) processed lawfully, fairly and in a transparent manner in relation to the data subject ('lawfulness, fairness and transparency');

(b) collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; further processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes shall, in accordance with Article 89(1), not be considered to be incompatible with the initial purposes ('purpose limitation');

(c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation');

(d) accurate and, where necessary, kept up to date; every reasonable step must be taken to ensure that personal data that are inaccurate, having regard to the purposes for which they are processed, are erased or rectified without delay ('accuracy');

[1] Directive (EU) 2015/1535 of the European Parliament and of the Council of 9 September 2015 laying down a procedure for the provision of information in the field of technical regulations and of rules on Information Society services (OJ L 241, 17.9.2015, p. 1).

(e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; personal data may be stored for longer periods insofar as the personal data will be processed solely for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) subject to implementation of the appropriate technical and organisational measures required by this Regulation in order to safeguard the rights and freedoms of the data subject ('storage limitation');

(f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality').

2. The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 ('accountability').

Article 6

Lawfulness of processing

1. Processing shall be lawful only if and to the extent that at least one of the following applies:

(a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes;

(b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;

(c) processing is necessary for compliance with a legal obligation to which the controller is subject;

(d) processing is necessary in order to protect the vital interests of the data subject or of another natural person;

(e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;

(f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.

Point (f) of the first subparagraph shall not apply to processing carried out by public authorities in the performance of their tasks.

2. Member States may maintain or introduce more specific provisions to adapt the application of the rules of this Regulation with regard to processing for compliance with points (c) and (e) of paragraph 1 by determining more precisely specific requirements for the processing and other measures to ensure lawful and fair processing including for other specific processing situations as provided for in Chapter IX.

3. The basis for the processing referred to in point (c) and (e) of paragraph 1 shall be laid down by:

(a) Union law; or

(b) Member State law to which the controller is subject.

The purpose of the processing shall be determined in that legal basis or, as regards the processing referred to in point (e) of paragraph 1, shall be necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller. That legal basis may contain specific provisions to adapt the application of rules of this Regulation, inter alia: the general conditions governing the lawfulness of processing by the controller; the types of data which are subject to the processing; the data subjects concerned; the entities to, and the purposes for which, the personal data may be disclosed; the purpose limitation; storage periods; and processing operations and processing procedures, including measures to ensure lawful and fair processing such as those for other specific

processing situations as provided for in Chapter IX. The Union or the Member State law shall meet an objective of public interest and be proportionate to the legitimate aim pursued.

4. Where the processing for a purpose other than that for which the personal data have been collected is not based on the data subject's consent or on a Union or Member State law which constitutes a necessary and proportionate measure in a democratic society to safeguard the objectives referred to in Article 23(1), the controller shall, in order to ascertain whether processing for another purpose is compatible with the purpose for which the personal data are initially collected, take into account, inter alia:

(a) any link between the purposes for which the personal data have been collected and the purposes of the intended further processing;

(b) the context in which the personal data have been collected, in particular regarding the relationship between data subjects and the controller;

(c) the nature of the personal data, in particular whether special categories of personal data are processed, pursuant to Article 9, or whether personal data related to criminal convictions and offences are processed, pursuant to Article 10;

(d) the possible consequences of the intended further processing for data subjects;

(e) the existence of appropriate safeguards, which may include encryption or pseudonymisation.

Article 7

Conditions for consent

1. Where processing is based on consent, the controller shall be able to demonstrate that the data subject has consented to processing of his or her personal data.

2. If the data subject's consent is given in the context of a written declaration which also concerns other matters, the request for consent shall be presented in a manner which is clearly distinguishable from the other matters, in an intelligible and easily accessible form, using clear and plain language. Any part of such a declaration which constitutes an infringement of this Regulation shall not be binding.

3. The data subject shall have the right to withdraw his or her consent at any time. The withdrawal of consent shall not affect the lawfulness of processing based on consent before its withdrawal. Prior to giving consent, the data subject shall be informed thereof. It shall be as easy to withdraw as to give consent.

4. When assessing whether consent is freely given, utmost account shall be taken of whether, *inter alia*, the performance of a contract, including the provision of a service, is conditional on consent to the processing of personal data that is not necessary for the performance of that contract.

Article 8

Conditions applicable to child's consent in relation to information society services

1. Where point (a) of Article 6(1) applies, in relation to the offer of information society services directly to a child, the processing of the personal data of a child shall be lawful where the child is at least 16 years old. Where the child is below the age of 16 years, such processing shall be lawful only if and to the extent that consent is given or authorised by the holder of parental responsibility over the child.

Member States may provide by law for a lower age for those purposes provided that such lower age is not below 13 years.

2. The controller shall make reasonable efforts to verify in such cases that consent is given or authorised by the holder of parental responsibility over the child, taking into consideration available technology.

3. Paragraph 1 shall not affect the general contract law of Member States such as the rules on the validity, formation or effect of a contract in relation to a child.

Article 9

Processing of special categories of personal data

1. Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person's sex life or sexual orientation shall be prohibited.

2. Paragraph 1 shall not apply if one of the following applies:

(a) the data subject has given explicit consent to the processing of those personal data for one or more specified purposes, except where Union or Member State law provide that the prohibition referred to in paragraph 1 may not be lifted by the data subject;

(b) processing is necessary for the purposes of carrying out the obligations and exercising specific rights of the controller or of the data subject in the field of employment and social security and social protection law in so far as it is authorised by Union or Member State law or a collective agreement pursuant to Member State law providing for appropriate safeguards for the fundamental rights and the interests of the data subject;

(c) processing is necessary to protect the vital interests of the data subject or of another natural person where the data subject is physically or legally incapable of giving consent;

(d) processing is carried out in the course of its legitimate activities with appropriate safeguards by a foundation, association or any other not-for-profit body with a political, philosophical, religious or trade union aim and on condition that the processing relates solely to the members or to former members of the body or to persons who have regular contact with it in connection with its purposes and that the personal data are not disclosed outside that body without the consent of the data subjects;

(e) processing relates to personal data which are manifestly made public by the data subject;

(f) processing is necessary for the establishment, exercise or defence of legal claims or whenever courts are acting in their judicial capacity;

(g) processing is necessary for reasons of substantial public interest, on the basis of Union or Member State law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject;

(h) processing is necessary for the purposes of preventive or occupational medicine, for the assessment of the working capacity of the employee, medical diagnosis, the provision of health or social care or treatment or the management of health or social care systems and services on the basis of Union or Member State law or pursuant to contract with a health professional and subject to the conditions and safeguards referred to in paragraph 3;

(i) processing is necessary for reasons of public interest in the area of public health, such as protecting against serious cross-border threats to health or ensuring high standards of quality and safety of health care and of medicinal products or medical devices, on the basis of Union or Member State law which provides for suitable and specific measures to safeguard the rights and freedoms of the data subject, in particular professional secrecy;

(j) processing is necessary for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) based on Union or Member State law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject.

3. Personal data referred to in paragraph 1 may be processed for the purposes referred to in point (h) of paragraph 2 when those data are processed by or under the responsibility of a professional subject to the obligation of professional secrecy under Union or Member State law or rules established by national competent bodies or by another person also subject to an obligation of secrecy under Union or Member State law or rules established by national competent bodies.

4. Member States may maintain or introduce further conditions, including limitations, with regard to the processing of genetic data, biometric data or data concerning health.

Article 10

Processing of personal data relating to criminal convictions and offences

Processing of personal data relating to criminal convictions and offences or related security measures based on Article 6(1) shall be carried out only under the control of official authority or when the processing is authorised by Union or Member State law providing for appropriate safeguards for the rights and freedoms of data subjects. Any comprehensive register of criminal convictions shall be kept only under the control of official authority.

Article 11

Processing which does not require identification

1. If the purposes for which a controller processes personal data do not or do no longer require the identification of a data subject by the controller, the controller shall not be obliged to maintain, acquire or process additional information in order to identify the data subject for the sole purpose of complying with this Regulation.

2. Where, in cases referred to in paragraph 1 of this Article, the controller is able to demonstrate that it is not in a position to identify the data subject, the controller shall inform the data subject accordingly, if possible. In such cases, Articles 15 to 20 shall not apply except where the data subject, for the purpose of exercising his or her rights under those articles, provides additional information enabling his or her identification.

CHAPTER III

Rights of the data subject

Section 1

Transparency and modalities

Article 12

Transparent information, communication and modalities for the exercise of the rights of the data subject

1. The controller shall take appropriate measures to provide any information referred to in Articles 13 and 14 and any communication under Articles 15 to 22 and 34 relating to processing to the data subject in a concise, transparent, intelligible and easily accessible form, using clear and plain language, in particular for any information addressed specifically to a child. The information shall be provided in writing, or by other means, including, where appropriate, by electronic means. When requested by the data subject, the information may be provided orally, provided that the identity of the data subject is proven by other means.

2. The controller shall facilitate the exercise of data subject rights under Articles 15 to 22. In the cases referred to in Article 11(2), the controller shall not refuse to act on the request of the data subject for exercising his or her rights under Articles 15 to 22, unless the controller demonstrates that it is not in a position to identify the data subject.

3. The controller shall provide information on action taken on a request under Articles 15 to 22 to the data subject without undue delay and in any event within one month of receipt of the request. That period may be extended by two further months where necessary, taking into account the complexity and number of the requests. The controller shall inform the data subject of any such extension within one month of receipt of the request, together with the reasons for the delay. Where the data subject makes the request by electronic form means, the information shall be provided by electronic means where possible, unless otherwise requested by the data subject.

4. If the controller does not take action on the request of the data subject, the controller shall inform the data subject without delay and at the latest within one month of receipt of the request of the reasons for not taking action and on the possibility of lodging a complaint with a supervisory authority and seeking a judicial remedy.

5. Information provided under Articles 13 and 14 and any communication and any actions taken under Articles 15 to 22 and 34 shall be provided free of charge. Where requests from a data subject are manifestly unfounded or excessive, in particular because of their repetitive character, the controller may either:

(a) charge a reasonable fee taking into account the administrative costs of providing the information or communication or taking the action requested; or

(b) refuse to act on the request.

The controller shall bear the burden of demonstrating the manifestly unfounded or excessive character of the request.

6. Without prejudice to Article 11, where the controller has reasonable doubts concerning the identity of the natural person making the request referred to in Articles 15 to 21, the controller may request the provision of additional information necessary to confirm the identity of the data subject.

7. The information to be provided to data subjects pursuant to Articles 13 and 14 may be provided in combination with standardised icons in order to give in an easily visible, intelligible and clearly legible manner a meaningful overview of the intended processing. Where the icons are presented electronically they shall be machine-readable.

8. The Commission shall be empowered to adopt delegated acts in accordance with Article 92 for the purpose of determining the information to be presented by the icons and the procedures for providing standardised icons.

Section 2

Information and access to personal data

Article 13

Information to be provided where personal data are collected from the data subject

1. Where personal data relating to a data subject are collected from the data subject, the controller shall, at the time when personal data are obtained, provide the data subject with all of the following information:

(a) the identity and the contact details of the controller and, where applicable, of the controller's representative;

(b) the contact details of the data protection officer, where applicable;

(c) the purposes of the processing for which the personal data are intended as well as the legal basis for the processing;

(d) where the processing is based on point (f) of Article 6(1), the legitimate interests pursued by the controller or by a third party;

(e) the recipients or categories of recipients of the personal data, if any;

(f) where applicable, the fact that the controller intends to transfer personal data to a third country or international organisation and the existence or absence of an adequacy decision by the Commission, or in the case of transfers referred to in Article 46 or 47, or the second subparagraph of Article 49(1), reference to the appropriate or suitable safeguards and the means by which to obtain a copy of them or where they have been made available.

2. In addition to the information referred to in paragraph 1, the controller shall, at the time when personal data are obtained, provide the data subject with the following further information necessary to ensure fair and transparent processing:

(a) the period for which the personal data will be stored, or if that is not possible, the criteria used to determine that period;

(b) the existence of the right to request from the controller access to and rectification or erasure of personal data or restriction of processing concerning the data subject or to object to processing as well as the right to data portability;

(c) where the processing is based on point (a) of Article 6(1) or point (a) of Article 9(2), the existence of the right to withdraw consent at any time, without affecting the lawfulness of processing based on consent before its withdrawal;

(d) the right to lodge a complaint with a supervisory authority;

(e) whether the provision of personal data is a statutory or contractual requirement, or a requirement necessary to enter into a contract, as well as whether the data subject is obliged to provide the personal data and of the possible consequences of failure to provide such data;

(f) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

3. Where the controller intends to further process the personal data for a purpose other than that for which the personal data were collected, the controller shall provide the data subject prior to that further processing with information on that other purpose and with any relevant further information as referred to in paragraph 2.

4. Paragraphs 1, 2 and 3 shall not apply where and insofar as the data subject already has the information.

Article 14

Information to be provided where personal data have not been obtained from the data subject

1. Where personal data have not been obtained from the data subject, the controller shall provide the data subject with the following information:

(a) the identity and the contact details of the controller and, where applicable, of the controller's representative;

(b) the contact details of the data protection officer, where applicable;

(c) the purposes of the processing for which the personal data are intended as well as the legal basis for the processing;

(d) the categories of personal data concerned;

(e) the recipients or categories of recipients of the personal data, if any;

(f) where applicable, that the controller intends to transfer personal data to a recipient in a third country or international organisation and the existence or absence of an adequacy decision by the Commission, or in the case of transfers referred to in Article 46 or 47, or the second subparagraph of Article 49(1), reference to the appropriate or suitable safeguards and the means to obtain a copy of them or where they have been made available.

2. In addition to the information referred to in paragraph 1, the controller shall provide the data subject with the following information necessary to ensure fair and transparent processing in respect of the data subject:

(a) the period for which the personal data will be stored, or if that is not possible, the criteria used to determine that period;

(b) where the processing is based on point (f) of Article 6(1), the legitimate interests pursued by the controller or by a third party;

(c) the existence of the right to request from the controller access to and rectification or erasure of personal data or restriction of processing concerning the data subject and to object to processing as well as the right to data portability;

(d) where processing is based on point (a) of Article 6(1) or point (a) of Article 9(2), the existence of the right to withdraw consent at any time, without affecting the lawfulness of processing based on consent before its withdrawal;

(e) the right to lodge a complaint with a supervisory authority;

(f) from which source the personal data originate, and if applicable, whether it came from publicly accessible sources;

(g) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

3. The controller shall provide the information referred to in paragraphs 1 and 2:

(a) within a reasonable period after obtaining the personal data, but at the latest within one month, having regard to the specific circumstances in which the personal data are processed;

(b) if the personal data are to be used for communication with the data subject, at the latest at the time of the first communication to that data subject; or

(c) if a disclosure to another recipient is envisaged, at the latest when the personal data are first disclosed.

4. Where the controller intends to further process the personal data for a purpose other than that for which the personal data were obtained, the controller shall provide the data subject prior to that further processing with information on that other purpose and with any relevant further information as referred to in paragraph 2.

5. Paragraphs 1 to 4 shall not apply where and insofar as:

(a) the data subject already has the information;

(b) the provision of such information proves impossible or would involve a disproportionate effort, in particular for processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes, subject to the conditions and safeguards referred to in Article 89(1) or in so far as the obligation referred to in paragraph 1 of this Article is likely to render impossible or seriously impair the achievement of the objectives of that processing. In such cases the controller shall take appropriate measures to protect the data subject's rights and freedoms and legitimate interests, including making the information publicly available;

(c) obtaining or disclosure is expressly laid down by Union or Member State law to which the controller is subject and which provides appropriate measures to protect the data subject's legitimate interests; or

(d) where the personal data must remain confidential subject to an obligation of professional secrecy regulated by Union or Member State law, including a statutory obligation of secrecy.

Article 15

Right of access by the data subject

1. The data subject shall have the right to obtain from the controller confirmation as to whether or not personal data concerning him or her are being processed, and, where that is the case, access to the personal data and the following information:

(a) the purposes of the processing;

(b) the categories of personal data concerned;

(c) the recipients or categories of recipient to whom the personal data have been or will be disclosed, in particular recipients in third countries or international organisations;

(d) where possible, the envisaged period for which the personal data will be stored, or, if not possible, the criteria used to determine that period;

(e) the existence of the right to request from the controller rectification or erasure of personal data or restriction of processing of personal data concerning the data subject or to object to such processing;

(f) the right to lodge a complaint with a supervisory authority;

(g) where the personal data are not collected from the data subject, any available information as to their source;

(h) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

2. Where personal data are transferred to a third country or to an international organisation, the data subject shall have the right to be informed of the appropriate safeguards pursuant to Article 46 relating to the transfer.

3. The controller shall provide a copy of the personal data undergoing processing. For any further copies requested by the data subject, the controller may charge a reasonable fee based on administrative costs. Where the data subject makes the request by electronic means, and unless otherwise requested by the data subject, the information shall be provided in a commonly used electronic form.

4. The right to obtain a copy referred to in paragraph 3 shall not adversely affect the rights and freedoms of others.

Section 3

Rectification and erasure

Article 16

Right to rectification

The data subject shall have the right to obtain from the controller without undue delay the rectification of inaccurate personal data concerning him or her. Taking into account the purposes of the processing, the data subject shall have the right to have incomplete personal data completed, including by means of providing a supplementary statement.

Article 17

Right to erasure ('right to be forgotten')

1. The data subject shall have the right to obtain from the controller the erasure of personal data concerning him or her without undue delay and the controller shall have the obligation to erase personal data without undue delay where one of the following grounds applies:

(a) the personal data are no longer necessary in relation to the purposes for which they were collected or otherwise processed;

(b) the data subject withdraws consent on which the processing is based according to point (a) of Article 6(1), or point (a) of Article 9(2), and where there is no other legal ground for the processing;

(c) the data subject objects to the processing pursuant to Article 21(1) and there are no overriding legitimate grounds for the processing, or the data subject objects to the processing pursuant to Article 21(2);

(d) the personal data have been unlawfully processed;

(e) the personal data have to be erased for compliance with a legal obligation in Union or Member State law to which the controller is subject;

(f) the personal data have been collected in relation to the offer of information society services referred to in Article 8(1).

2. Where the controller has made the personal data public and is obliged pursuant to paragraph 1 to erase the personal data, the controller, taking account of available technology and the cost of implementation, shall take reasonable steps, including technical measures, to inform controllers which are processing the personal data that the data subject has requested the erasure by such controllers of any links to, or copy or replication of, those personal data.

3. Paragraphs 1 and 2 shall not apply to the extent that processing is necessary:

(a) for exercising the right of freedom of expression and information;

(b) for compliance with a legal obligation which requires processing by Union or Member State law to which the controller is subject or for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;

(c) for reasons of public interest in the area of public health in accordance with points (h) and (i) of Article 9(2) as well as Article 9(3);

(d) for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes in accordance with Article 89(1) in so far as the right referred to in paragraph 1 is likely to render impossible or seriously impair the achievement of the objectives of that processing; or

(e) for the establishment, exercise or defence of legal claims.

Article 18

Right to restriction of processing

1. The data subject shall have the right to obtain from the controller restriction of processing where one of the following applies:

(a) the accuracy of the personal data is contested by the data subject, for a period enabling the controller to verify the accuracy of the personal data;

(b) the processing is unlawful and the data subject opposes the erasure of the personal data and requests the restriction of their use instead;

(c) the controller no longer needs the personal data for the purposes of the processing, but they are required by the data subject for the establishment, exercise or defence of legal claims;

(d) the data subject has objected to processing pursuant to Article 21(1) pending the verification whether the legitimate grounds of the controller override those of the data subject.

2. Where processing has been restricted under paragraph 1, such personal data shall, with the exception of storage, only be processed with the data subject's consent or for the establishment, exercise or defence of legal claims or for the protection of the rights of another natural or legal person or for reasons of important public interest of the Union or of a Member State.

3. A data subject who has obtained restriction of processing pursuant to paragraph 1 shall be informed by the controller before the restriction of processing is lifted.

Article 19

Notification obligation regarding rectification or erasure of personal data or restriction of processing

The controller shall communicate any rectification or erasure of personal data or restriction of processing carried out in accordance with Article 16, Article 17(1) and Article 18 to each recipient to whom the personal data have been disclosed, unless this proves impossible or involves disproportionate effort. The controller shall inform the data subject about those recipients if the data subject requests it.

Article 20

Right to data portability

1. The data subject shall have the right to receive the personal data concerning him or her, which he or she has provided to a controller, in a structured, commonly used and machine-readable format and have the right to transmit those data to another controller without hindrance from the controller to which the personal data have been provided, where:

(a) the processing is based on consent pursuant to point (a) of Article 6(1) or point (a) of Article 9(2) or on a contract pursuant to point (b) of Article 6(1); and

(b) the processing is carried out by automated means.

2. In exercising his or her right to data portability pursuant to paragraph 1, the data subject shall have the right to have the personal data transmitted directly from one controller to another, where technically feasible.

3. The exercise of the right referred to in paragraph 1 of this Article shall be without prejudice to Article 17. That right shall not apply to processing necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller.

4. The right referred to in paragraph 1 shall not adversely affect the rights and freedoms of others.

Section 4

Right to object and automated individual decision-making

Article 21

Right to object

1. The data subject shall have the right to object, on grounds relating to his or her particular situation, at any time to processing of personal data concerning him or her which is based on point (e) or (f) of Article 6(1), including profiling based on those provisions. The controller shall no longer process the personal data unless the controller demonstrates compelling legitimate grounds for the processing which override the interests, rights and freedoms of the data subject or for the establishment, exercise or defence of legal claims.

2. Where personal data are processed for direct marketing purposes, the data subject shall have the right to object at any time to processing of personal data concerning him or her for such marketing, which includes profiling to the extent that it is related to such direct marketing.

3. Where the data subject objects to processing for direct marketing purposes, the personal data shall no longer be processed for such purposes.

4. At the latest at the time of the first communication with the data subject, the right referred to in paragraphs 1 and 2 shall be explicitly brought to the attention of the data subject and shall be presented clearly and separately from any other information.

5. In the context of the use of information society services, and notwithstanding Directive 2002/58/EC, the data subject may exercise his or her right to object by automated means using technical specifications.

6. Where personal data are processed for scientific or historical research purposes or statistical purposes pursuant to Article 89(1), the data subject, on grounds relating to his or her particular situation, shall have the right to object to processing of personal data concerning him or her, unless the processing is necessary for the performance of a task carried out for reasons of public interest.

Article 22

Automated individual decision-making, including profiling

1. The data subject shall have the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning him or her or similarly significantly affects him or her.

2. Paragraph 1 shall not apply if the decision:

(a) is necessary for entering into, or performance of, a contract between the data subject and a data controller;

(b) is authorised by Union or Member State law to which the controller is subject and which also lays down suitable measures to safeguard the data subject's rights and freedoms and legitimate interests; or

(c) is based on the data subject's explicit consent.

3. In the cases referred to in points (a) and (c) of paragraph 2, the data controller shall implement suitable measures to safeguard the data subject's rights and freedoms and legitimate interests, at least the right to obtain human intervention on the part of the controller, to express his or her point of view and to contest the decision.

4. Decisions referred to in paragraph 2 shall not be based on special categories of personal data referred to in Article 9(1), unless point (a) or (g) of Article 9(2) applies and suitable measures to safeguard the data subject's rights and freedoms and legitimate interests are in place.

Section 5

Restrictions

Article 23

Restrictions

1. Union or Member State law to which the data controller or processor is subject may restrict by way of a legislative measure the scope of the obligations and rights provided for in Articles 12 to 22 and Article 34, as well as Article 5 in so far as its provisions correspond to the rights and obligations provided for in Articles 12 to 22, when such a restriction respects the essence of the fundamental rights and freedoms and is a necessary and proportionate measure in a democratic society to safeguard:

(a) national security;

(b) defence;

(c) public security;

(d) the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, including the safeguarding against and the prevention of threats to public security;

(e) other important objectives of general public interest of the Union or of a Member State, in particular an important economic or financial interest of the Union or of a Member State, including monetary, budgetary and taxation a matters, public health and social security;

(f) the protection of judicial independence and judicial proceedings;

(g) the prevention, investigation, detection and prosecution of breaches of ethics for regulated professions;

(h) a monitoring, inspection or regulatory function connected, even occasionally, to the exercise of official authority in the cases referred to in points (a) to (e) and (g);

(i) the protection of the data subject or the rights and freedoms of others;

(j) the enforcement of civil law claims.

2. In particular, any legislative measure referred to in paragraph 1 shall contain specific provisions at least, where relevant, as to:

(a) the purposes of the processing or categories of processing;

(b) the categories of personal data;

(c) the scope of the restrictions introduced;

(d) the safeguards to prevent abuse or unlawful access or transfer;

(e) the specification of the controller or categories of controllers;

(f) the storage periods and the applicable safeguards taking into account the nature, scope and purposes of the processing or categories of processing;

(g) the risks to the rights and freedoms of data subjects; and

(h) the right of data subjects to be informed about the restriction, unless that may be prejudicial to the purpose of the restriction.

CHAPTER IV

Controller and processor

Section 1

General obligations

Article 24

Responsibility of the controller

1. Taking into account the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller shall implement appropriate technical and organisational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation. Those measures shall be reviewed and updated where necessary.

2. Where proportionate in relation to processing activities, the measures referred to in paragraph 1 shall include the implementation of appropriate data protection policies by the controller.

3. Adherence to approved codes of conduct as referred to in Article 40 or approved certification mechanisms as referred to in Article 42 may be used as an element by which to demonstrate compliance with the obligations of the controller.

Article 25

Data protection by design and by default

1. Taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for rights and freedoms of natural persons posed by the processing, the controller shall, both at the time of the determination of the means for processing and at the time of the processing itself, implement appropriate technical and organisational measures, such as pseudonymisation, which are designed to implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects.

2. The controller shall implement appropriate technical and organisational measures for ensuring that, by default, only personal data which are necessary for each specific purpose of the processing are processed. That obligation applies to the amount of personal data collected, the extent of their processing, the period of their storage and their accessibility. In particular, such measures shall ensure that by default personal data are not made accessible without the individual's intervention to an indefinite number of natural persons.

3. An approved certification mechanism pursuant to Article 42 may be used as an element to demonstrate compliance with the requirements set out in paragraphs 1 and 2 of this Article.

Article 26

Joint controllers

1. Where two or more controllers jointly determine the purposes and means of processing, they shall be joint controllers. They shall in a transparent manner determine their respective responsibilities for compliance with the obligations under this Regulation, in particular as regards the exercising of the rights of the data subject and their respective duties to provide the information referred to in Articles 13 and 14, by means of an arrangement between them unless, and in so far as, the respective responsibilities of the controllers are determined by Union or Member State law to which the controllers are subject. The arrangement may designate a contact point for data subjects.

2. The arrangement referred to in paragraph 1 shall duly reflect the respective roles and relationships of the joint controllers *vis-à-vis* the data subjects. The essence of the arrangement shall be made available to the data subject.

3. Irrespective of the terms of the arrangement referred to in paragraph 1, the data subject may exercise his or her rights under this Regulation in respect of and against each of the controllers.

Article 27

Representatives of controllers or processors not established in the Union

1. Where Article 3(2) applies, the controller or the processor shall designate in writing a representative in the Union.

2. The obligation laid down in paragraph 1 of this Article shall not apply to:

(a) processing which is occasional, does not include, on a large scale, processing of special categories of data as referred to in Article 9(1) or processing of personal data relating to criminal convictions and offences referred to in Article 10, and is unlikely to result in a risk to the rights and freedoms of natural persons, taking into account the nature, context, scope and purposes of the processing; or

(b) a public authority or body.

3. The representative shall be established in one of the Member States where the data subjects, whose personal data are processed in relation to the offering of goods or services to them, or whose behaviour is monitored, are.

4. The representative shall be mandated by the controller or processor to be addressed in addition to or instead of the controller or the processor by, in particular, supervisory authorities and data subjects, on all issues related to processing, for the purposes of ensuring compliance with this Regulation.

5. The designation of a representative by the controller or processor shall be without prejudice to legal actions which could be initiated against the controller or the processor themselves.

Article 28

Processor

1. Where processing is to be carried out on behalf of a controller, the controller shall use only processors providing sufficient guarantees to implement appropriate technical and organisational measures in such a manner that processing will meet the requirements of this Regulation and ensure the protection of the rights of the data subject.

2. The processor shall not engage another processor without prior specific or general written authorisation of the controller. In the case of general written authorisation, the processor shall inform the controller of any intended changes concerning the addition or replacement of other processors, thereby giving the controller the opportunity to object to such changes.

3. Processing by a processor shall be governed by a contract or other legal act under Union or Member State law, that is binding on the processor with regard to the controller and that sets out the subject-matter and duration of the processing, the nature and purpose of the processing, the type of personal data and categories of data subjects and the obligations and rights of the controller. That contract or other legal act shall stipulate, in particular, that the processor:

(a) processes the personal data only on documented instructions from the controller, including with regard to transfers of personal data to a third country or an international organisation, unless required to do so by Union or Member State law to which the processor is subject; in such a case, the processor shall inform the controller of that legal requirement before processing, unless that law prohibits such information on important grounds of public interest;

(b) ensures that persons authorised to process the personal data have committed themselves to confidentiality or are under an appropriate statutory obligation of confidentiality;

(c) takes all measures required pursuant to Article 32;

(d) respects the conditions referred to in paragraphs 2 and 4 for engaging another processor;

(e) taking into account the nature of the processing, assists the controller by appropriate technical and organisational measures, insofar as this is possible, for the fulfilment of the controller's obligation to respond to requests for exercising the data subject's rights laid down in Chapter III;

(f) assists the controller in ensuring compliance with the obligations pursuant to Articles 32 to 36 taking into account the nature of processing and the information available to the processor;

(g) at the choice of the controller, deletes or returns all the personal data to the controller after the end of the provision of services relating to processing, and deletes existing copies unless Union or Member State law requires storage of the personal data;

(h) makes available to the controller all information necessary to demonstrate compliance with the obligations laid down in this Article and allow for and contribute to audits, including inspections, conducted by the controller or another auditor mandated by the controller.

With regard to point (h) of the first subparagraph, the processor shall immediately inform the controller if, in its opinion, an instruction infringes this Regulation or other Union or Member State data protection provisions.

4. Where a processor engages another processor for carrying out specific processing activities on behalf of the controller, the same data protection obligations as set out in the contract or other legal act between the controller and the processor as referred to in paragraph 3 shall be imposed on that other processor by way of a contract or other legal act under Union or Member State law, in particular providing sufficient guarantees to implement appropriate technical and organisational measures in such a manner that the processing will meet the requirements of this Regulation. Where that other processor fails to fulfil its data protection obligations, the initial processor shall remain fully liable to the controller for the performance of that other processor's obligations.

5. Adherence of a processor to an approved code of conduct as referred to in Article 40 or an approved certification mechanism as referred to in Article 42 may be used as an element by which to demonstrate sufficient guarantees as referred to in paragraphs 1 and 4 of this Article.

6. Without prejudice to an individual contract between the controller and the processor, the contract or the other legal act referred to in paragraphs 3 and 4 of this Article may be based, in whole or in part, on standard contractual clauses referred to in paragraphs 7 and 8 of this Article, including when they are part of a certification granted to the controller or processor pursuant to Articles 42 and 43.

7. The Commission may lay down standard contractual clauses for the matters referred to in paragraph 3 and 4 of this Article and in accordance with the examination procedure referred to in Article 93(2).

8. A supervisory authority may adopt standard contractual clauses for the matters referred to in paragraph 3 and 4 of this Article and in accordance with the consistency mechanism referred to in Article 63.

9. The contract or the other legal act referred to in paragraphs 3 and 4 shall be in writing, including in electronic form.

10. Without prejudice to Articles 82, 83 and 84, if a processor infringes this Regulation by determining the purposes and means of processing, the processor shall be considered to be a controller in respect of that processing.

Article 29

Processing under the authority of the controller or processor

The processor and any person acting under the authority of the controller or of the processor, who has access to personal data, shall not process those data except on instructions from the controller, unless required to do so by Union or Member State law.

Article 30

Records of processing activities

1. Each controller and, where applicable, the controller's representative, shall maintain a record of processing activities under its responsibility. That record shall contain all of the following information:

(a) the name and contact details of the controller and, where applicable, the joint controller, the controller's representative and the data protection officer;

(b) the purposes of the processing;

(c) a description of the categories of data subjects and of the categories of personal data;

(d) the categories of recipients to whom the personal data have been or will be disclosed including recipients in third countries or international organisations;

(e) where applicable, transfers of personal data to a third country or an international organisation, including the identification of that third country or international organisation and, in the case of transfers referred to in the second subparagraph of Article 49(1), the documentation of suitable safeguards;

(f) where possible, the envisaged time limits for erasure of the different categories of data;

(g) where possible, a general description of the technical and organisational security measures referred to in Article 32(1).

2. Each processor and, where applicable, the processor's representative shall maintain a record of all categories of processing activities carried out on behalf of a controller, containing:

(a) the name and contact details of the processor or processors and of each controller on behalf of which the processor is acting, and, where applicable, of the controller's or the processor's representative, and the data protection officer;

(b) the categories of processing carried out on behalf of each controller;

(c) where applicable, transfers of personal data to a third country or an international organisation, including the identification of that third country or international organisation and, in the case of transfers referred to in the second subparagraph of Article 49(1), the documentation of suitable safeguards;

(d) where possible, a general description of the technical and organisational security measures referred to in Article 32(1).

3. The records referred to in paragraphs 1 and 2 shall be in writing, including in electronic form.

4. The controller or the processor and, where applicable, the controller's or the processor's representative, shall make the record available to the supervisory authority on request.

5. The obligations referred to in paragraphs 1 and 2 shall not apply to an enterprise or an organisation employing fewer than 250 persons unless the processing it carries out is likely to result in a risk to the rights and freedoms of data subjects, the processing is not occasional, or the processing includes special categories of data as referred to in Article 9(1) or personal data relating to criminal convictions and offences referred to in Article 10.

Article 31

Cooperation with the supervisory authority

The controller and the processor and, where applicable, their representatives, shall cooperate, on request, with the supervisory authority in the performance of its tasks.

Section 2

Security of personal data

Article 32

Security of processing

1. Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as appropriate:

(a) the pseudonymisation and encryption of personal data;

(b) the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services;

(c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident;

(d) a process for regularly testing, assessing and evaluating the effectiveness of technical and organisational measures for ensuring the security of the processing.

2. In assessing the appropriate level of security account shall be taken in particular of the risks that are presented by processing, in particular from accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to personal data transmitted, stored or otherwise processed.

3. Adherence to an approved code of conduct as referred to in Article 40 or an approved certification mechanism as referred to in Article 42 may be used as an element by which to demonstrate compliance with the requirements set out in paragraph 1 of this Article.

4. The controller and processor shall take steps to ensure that any natural person acting under the authority of the controller or the processor who has access to personal data does not process them except on instructions from the controller, unless he or she is required to do so by Union or Member State law.

Article 33

Notification of a personal data breach to the supervisory authority

1. In the case of a personal data breach, the controller shall without undue delay and, where feasible, not later than 72 hours after having become aware of it, notify the personal data breach to the supervisory authority competent in accordance with Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. Where the notification to the supervisory authority is not made within 72 hours, it shall be accompanied by reasons for the delay.

2. The processor shall notify the controller without undue delay after becoming aware of a personal data breach.

3. The notification referred to in paragraph 1 shall at least:

(a) describe the nature of the personal data breach including where possible, the categories and approximate number of data subjects concerned and the categories and approximate number of personal data records concerned;

(b) communicate the name and contact details of the data protection officer or other contact point where more information can be obtained;

(c) describe the likely consequences of the personal data breach;

(d) describe the measures taken or proposed to be taken by the controller to address the personal data breach, including, where appropriate, measures to mitigate its possible adverse effects.

4. Where, and in so far as, it is not possible to provide the information at the same time, the information may be provided in phases without undue further delay.

5. The controller shall document any personal data breaches, comprising the facts relating to the personal data breach, its effects and the remedial action taken. That documentation shall enable the supervisory authority to verify compliance with this Article.

Article 34

Communication of a personal data breach to the data subject

1. When the personal data breach is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall communicate the personal data breach to the data subject without undue delay.

2. The communication to the data subject referred to in paragraph 1 of this Article shall describe in clear and plain language the nature of the personal data breach and contain at least the information and measures referred to in points (b), (c) and (d) of Article 33(3).

3. The communication to the data subject referred to in paragraph 1 shall not be required if any of the following conditions are met:

(a) the controller has implemented appropriate technical and organisational protection measures, and those measures were applied to the personal data affected by the personal data breach, in particular those that render the personal data unintelligible to any person who is not authorised to access it, such as encryption;

(b) the controller has taken subsequent measures which ensure that the high risk to the rights and freedoms of data subjects referred to in paragraph 1 is no longer likely to materialise;

(c) it would involve disproportionate effort. In such a case, there shall instead be a public communication or similar measure whereby the data subjects are informed in an equally effective manner.

4. If the controller has not already communicated the personal data breach to the data subject, the supervisory authority, having considered the likelihood of the personal data breach resulting in a high risk, may require it to do so or may decide that any of the conditions referred to in paragraph 3 are met.

Section 3

Data protection impact assessment and prior consultation

Article 35

Data protection impact assessment

1. Where a type of processing in particular using new technologies, and taking into account the nature, scope, context and purposes of the processing, is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall, prior to the processing, carry out an assessment of the impact of the envisaged processing operations on the protection of personal data. A single assessment may address a set of similar processing operations that present similar high risks.

2. The controller shall seek the advice of the data protection officer, where designated, when carrying out a data protection impact assessment.

3. A data protection impact assessment referred to in paragraph 1 shall in particular be required in the case of:

(a) a systematic and extensive evaluation of personal aspects relating to natural persons which is based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural person or similarly significantly affect the natural person;

(b) processing on a large scale of special categories of data referred to in Article 9(1), or of personal data relating to criminal convictions and offences referred to in Article 10; or

(c) a systematic monitoring of a publicly accessible area on a large scale.

4. The supervisory authority shall establish and make public a list of the kind of processing operations which are subject to the requirement for a data protection impact assessment pursuant to paragraph 1. The supervisory authority shall communicate those lists to the Board referred to in Article 68.

5. The supervisory authority may also establish and make public a list of the kind of processing operations for which no data protection impact assessment is required. The supervisory authority shall communicate those lists to the Board.

6. Prior to the adoption of the lists referred to in paragraphs 4 and 5, the competent supervisory authority shall apply the consistency mechanism referred to in Article 63 where such lists involve processing activities which are related to the offering of goods or services to data subjects or to the monitoring of their behaviour in several Member States, or may substantially affect the free movement of personal data within the Union.

7. The assessment shall contain at least:

(a) a systematic description of the envisaged processing operations and the purposes of the processing, including, where applicable, the legitimate interest pursued by the controller;

(b) an assessment of the necessity and proportionality of the processing operations in relation to the purposes;

(c) an assessment of the risks to the rights and freedoms of data subjects referred to in paragraph 1; and

(d) the measures envisaged to address the risks, including safeguards, security measures and mechanisms to ensure the protection of personal data and to demonstrate compliance with this Regulation taking into account the rights and legitimate interests of data subjects and other persons concerned.

8. Compliance with approved codes of conduct referred to in Article 40 by the relevant controllers or processors shall be taken into due account in assessing the impact of the processing operations performed by such controllers or processors, in particular for the purposes of a data protection impact assessment.

9. Where appropriate, the controller shall seek the views of data subjects or their representatives on the intended processing, without prejudice to the protection of commercial or public interests or the security of processing operations.

10. Where processing pursuant to point (c) or (e) of Article 6(1) has a legal basis in Union law or in the law of the Member State to which the controller is subject, that law regulates the specific processing operation or set of operations in question, and a data protection impact assessment has already been carried out as part of a general impact assessment in the context of the adoption of that legal basis, paragraphs 1 to 7 shall not apply unless Member States deem it to be necessary to carry out such an assessment prior to processing activities.

11. Where necessary, the controller shall carry out a review to assess if processing is performed in accordance with the data protection impact assessment at least when there is a change of the risk represented by processing operations.

Article 36

Prior consultation

1. The controller shall consult the supervisory authority prior to processing where a data protection impact assessment under Article 35 indicates that the processing would result in a high risk in the absence of measures taken by the controller to mitigate the risk.

2. Where the supervisory authority is of the opinion that the intended processing referred to in paragraph 1 would infringe this Regulation, in particular where the controller has insufficiently identified or mitigated the risk, the supervisory authority shall, within period of up to eight weeks of receipt of the request for consultation, provide written advice to the controller and, where applicable to the processor, and may use any of its powers referred to in Article 58. That period may be extended by six weeks, taking into account the complexity of the intended processing. The supervisory authority shall inform the controller and, where applicable, the processor, of any such extension within one month of receipt of the request for consultation together with the reasons for the delay. Those periods may be suspended until the supervisory authority has obtained information it has requested for the purposes of the consultation.

3. When consulting the supervisory authority pursuant to paragraph 1, the controller shall provide the supervisory authority with:

(a) where applicable, the respective responsibilities of the controller, joint controllers and processors involved in the processing, in particular for processing within a group of undertakings;

(b) the purposes and means of the intended processing;

(c) the measures and safeguards provided to protect the rights and freedoms of data subjects pursuant to this Regulation;

(d) where applicable, the contact details of the data protection officer;

(e) the data protection impact assessment provided for in Article 35; and

(f) any other information requested by the supervisory authority.

4. Member States shall consult the supervisory authority during the preparation of a proposal for a legislative measure to be adopted by a national parliament, or of a regulatory measure based on such a legislative measure, which relates to processing.

5. Notwithstanding paragraph 1, Member State law may require controllers to consult with, and obtain prior authorisation from, the supervisory authority in relation to processing by a controller for the performance of a task carried out by the controller in the public interest, including processing in relation to social protection and public health.

Section 4

Data protection officer

Article 37

Designation of the data protection officer

1. The controller and the processor shall designate a data protection officer in any case where:

(a) the processing is carried out by a public authority or body, except for courts acting in their judicial capacity;

(b) the core activities of the controller or the processor consist of processing operations which, by virtue of their nature, their scope and/or their purposes, require regular and systematic monitoring of data subjects on a large scale; or

(c) the core activities of the controller or the processor consist of processing on a large scale of special categories of data pursuant to Article 9 and personal data relating to criminal convictions and offences referred to in Article 10.

2. A group of undertakings may appoint a single data protection officer provided that a data protection officer is easily accessible from each establishment.

3. Where the controller or the processor is a public authority or body, a single data protection officer may be designated for several such authorities or bodies, taking account of their organisational structure and size.

4. In cases other than those referred to in paragraph 1, the controller or processor or associations and other bodies representing categories of controllers or processors may or, where required by Union or Member State law shall, designate a data protection officer. The data protection officer may act for such associations and other bodies representing controllers or processors.

5. The data protection officer shall be designated on the basis of professional qualities and, in particular, expert knowledge of data protection law and practices and the ability to fulfil the tasks referred to in Article 39.

6. The data protection officer may be a staff member of the controller or processor, or fulfil the tasks on the basis of a service contract.

7. The controller or the processor shall publish the contact details of the data protection officer and communicate them to the supervisory authority.

Article 38

Position of the data protection officer

1. The controller and the processor shall ensure that the data protection officer is involved, properly and in a timely manner, in all issues which relate to the protection of personal data.

2. The controller and processor shall support the data protection officer in performing the tasks referred to in Article 39 by providing resources necessary to carry out those tasks and access to personal data and processing operations, and to maintain his or her expert knowledge.

3. The controller and processor shall ensure that the data protection officer does not receive any instructions regarding the exercise of those tasks. He or she shall not be dismissed or penalised by the controller or the processor for performing his tasks. The data protection officer shall directly report to the highest management level of the controller or the processor.

4. Data subjects may contact the data protection officer with regard to all issues related to processing of their personal data and to the exercise of their rights under this Regulation.

5. The data protection officer shall be bound by secrecy or confidentiality concerning the performance of his or her tasks, in accordance with Union or Member State law.

6. The data protection officer may fulfil other tasks and duties. The controller or processor shall ensure that any such tasks and duties do not result in a conflict of interests.

Article 39

Tasks of the data protection officer

1. The data protection officer shall have at least the following tasks:

(a) to inform and advise the controller or the processor and the employees who carry out processing of their obligations pursuant to this Regulation and to other Union or Member State data protection provisions;

(b) to monitor compliance with this Regulation, with other Union or Member State data protection provisions and with the policies of the controller or processor in relation to the protection of personal data, including the assignment of responsibilities, awareness-raising and training of staff involved in processing operations, and the related audits;

(c) to provide advice where requested as regards the data protection impact assessment and monitor its performance pursuant to Article 35;

(d) to cooperate with the supervisory authority;

(e) to act as the contact point for the supervisory authority on issues relating to processing, including the prior consultation referred to in Article 36, and to consult, where appropriate, with regard to any other matter.

2. The data protection officer shall in the performance of his or her tasks have due regard to the risk associated with processing operations, taking into account the nature, scope, context and purposes of processing.

Section 5

Codes of conduct and certification

Article 40

Codes of conduct

1. The Member States, the supervisory authorities, the Board and the Commission shall encourage the drawing up of codes of conduct intended to contribute to the proper application of this Regulation, taking account of the specific features of the various processing sectors and the specific needs of micro, small and medium-sized enterprises.

2. Associations and other bodies representing categories of controllers or processors may prepare codes of conduct, or amend or extend such codes, for the purpose of specifying the application of this Regulation, such as with regard to:

(a) fair and transparent processing;

(b) the legitimate interests pursued by controllers in specific contexts;

(c) the collection of personal data;

(d) the pseudonymisation of personal data;

(e) the information provided to the public and to data subjects;

(f) the exercise of the rights of data subjects;

(g) the information provided to, and the protection of, children, and the manner in which the consent of the holders of parental responsibility over children is to be obtained;

(h) the measures and procedures referred to in Articles 24 and 25 and the measures to ensure security of processing referred to in Article 32;

(i) the notification of personal data breaches to supervisory authorities and the communication of such personal data breaches to data subjects;

(j) the transfer of personal data to third countries or international organisations; or

(k) out-of-court proceedings and other dispute resolution procedures for resolving disputes between controllers and data subjects with regard to processing, without prejudice to the rights of data subjects pursuant to Articles 77 and 79.

3. In addition to adherence by controllers or processors subject to this Regulation, codes of conduct approved pursuant to paragraph 5 of this Article and having general validity pursuant to paragraph 9 of this Article may also be adhered to by controllers or processors that are not subject to this Regulation pursuant to Article 3 in order to provide appropriate safeguards within the framework of personal data transfers to third countries or international organisations under the terms referred to in point (e) of Article 46(2). Such controllers or processors shall make binding and enforceable commitments, via contractual or other legally binding instruments, to apply those appropriate safeguards including with regard to the rights of data subjects.

4. A code of conduct referred to in paragraph 2 of this Article shall contain mechanisms which enable the body referred to in Article 41(1) to carry out the mandatory monitoring of compliance with its provisions by the controllers or processors which undertake to apply it, without prejudice to the tasks and powers of supervisory authorities competent pursuant to Article 55 or 56.

5. Associations and other bodies referred to in paragraph 2 of this Article which intend to prepare a code of conduct or to amend or extend an existing code shall submit the draft code, amendment or extension to the supervisory authority which is competent pursuant to Article 55. The supervisory authority shall provide an opinion on whether the draft code, amendment or extension complies with this Regulation and shall approve that draft code, amendment or extension if it finds that it provides sufficient appropriate safeguards.

6. Where the draft code, or amendment or extension is approved in accordance with paragraph 5, and where the code of conduct concerned does not relate to processing activities in several Member States, the supervisory authority shall register and publish the code.

7. Where a draft code of conduct relates to processing activities in several Member States, the supervisory authority which is competent pursuant to Article 55 shall, before approving the draft code, amendment or extension, submit it in the procedure referred to in Article 63 to the Board which shall provide an opinion on whether the draft code, amendment or extension complies with this Regulation or, in the situation referred to in paragraph 3 of this Article, provides appropriate safeguards.

8. Where the opinion referred to in paragraph 7 confirms that the draft code, amendment or extension complies with this Regulation, or, in the situation referred to in paragraph 3, provides appropriate safeguards, the Board shall submit its opinion to the Commission.

9. The Commission may, by way of implementing acts, decide that the approved code of conduct, amendment or extension submitted to it pursuant to paragraph 8 of this Article have general validity within the Union. Those implementing acts shall be adopted in accordance with the examination procedure set out in Article 93(2).

10. The Commission shall ensure appropriate publicity for the approved codes which have been decided as having general validity in accordance with paragraph 9.

11. The Board shall collate all approved codes of conduct, amendments and extensions in a register and shall make them publicly available by way of appropriate means.

Article 41

Monitoring of approved codes of conduct

1. Without prejudice to the tasks and powers of the competent supervisory authority under Articles 57 and 58, the monitoring of compliance with a code of conduct pursuant to Article 40 may be carried out by a body which has an appropriate level of expertise in relation to the subject-matter of the code and is accredited for that purpose by the competent supervisory authority.

2. A body as referred to in paragraph 1 may be accredited to monitor compliance with a code of conduct where that body has:

(a) demonstrated its independence and expertise in relation to the subject-matter of the code to the satisfaction of the competent supervisory authority;

(b) established procedures which allow it to assess the eligibility of controllers and processors concerned to apply the code, to monitor their compliance with its provisions and to periodically review its operation;

(c) established procedures and structures to handle complaints about infringements of the code or the manner in which the code has been, or is being, implemented by a controller or processor, and to make those procedures and structures transparent to data subjects and the public; and

(d) demonstrated to the satisfaction of the competent supervisory authority that its tasks and duties do not result in a conflict of interests.

3. The competent supervisory authority shall submit the draft criteria for accreditation of a body as referred to in paragraph 1 of this Article to the Board pursuant to the consistency mechanism referred to in Article 63.

4. Without prejudice to the tasks and powers of the competent supervisory authority and the provisions of Chapter VIII, a body as referred to in paragraph 1 of this Article shall, subject to appropriate safeguards, take appropriate action in cases of infringement of the code by a controller or processor, including suspension or exclusion of the controller or processor concerned from the code. It shall inform the competent supervisory authority of such actions and the reasons for taking them.

5. The competent supervisory authority shall revoke the accreditation of a body as referred to in paragraph 1 if the conditions for accreditation are not, or are no longer, met or where actions taken by the body infringe this Regulation.

6. This Article shall not apply to processing carried out by public authorities and bodies.

Article 42

Certification

1. The Member States, the supervisory authorities, the Board and the Commission shall encourage, in particular at Union level, the establishment of data protection certification mechanisms and of data protection seals and marks, for the purpose of demonstrating compliance with this Regulation of processing operations by controllers and processors. The specific needs of micro, small and medium-sized enterprises shall be taken into account.

2. In addition to adherence by controllers or processors subject to this Regulation, data protection certification mechanisms, seals or marks approved pursuant to paragraph 5 of this Article may be established for the purpose of demonstrating the existence of appropriate safeguards provided by controllers or processors that are not subject to this Regulation pursuant to Article 3 within the framework of personal data transfers to third countries or international organisations under the terms referred to in point (f) of Article 46(2). Such controllers or processors shall make binding and enforceable commitments, via contractual or other legally binding instruments, to apply those appropriate safeguards, including with regard to the rights of data subjects.

3. The certification shall be voluntary and available via a process that is transparent.

4. A certification pursuant to this Article does not reduce the responsibility of the controller or the processor for compliance with this Regulation and is without prejudice to the tasks and powers of the supervisory authorities which are competent pursuant to Article 55 or 56.

5. A certification pursuant to this Article shall be issued by the certification bodies referred to in Article 43 or by the competent supervisory authority, on the basis of criteria approved by that competent supervisory authority pursuant to Article 58(3) or by the Board pursuant to Article 63. Where the criteria are approved by the Board, this may result in a common certification, the European Data Protection Seal.

6. The controller or processor which submits its processing to the certification mechanism shall provide the certification body referred to in Article 43, or where applicable, the competent supervisory authority, with all information and access to its processing activities which are necessary to conduct the certification procedure.

7. Certification shall be issued to a controller or processor for a maximum period of three years and may be renewed, under the same conditions, provided that the relevant requirements continue to be met. Certification shall be withdrawn, as applicable, by the certification bodies referred to in Article 43 or by the competent supervisory authority where the requirements for the certification are not or are no longer met.

8. The Board shall collate all certification mechanisms and data protection seals and marks in a register and shall make them publicly available by any appropriate means.

Article 43

Certification bodies

1. Without prejudice to the tasks and powers of the competent supervisory authority under Articles 57 and 58, certification bodies which have an appropriate level of expertise in relation to data protection shall, after informing the supervisory authority in order to allow it to exercise its powers pursuant to point (h) of Article 58(2) where necessary, issue and renew certification. Member States shall ensure that those certification bodies are accredited by one or both of the following:

(a) the supervisory authority which is competent pursuant to Article 55 or 56;

(b) the national accreditation body named in accordance with Regulation (EC) No 765/2008 of the European Parliament and of the Council [1] in accordance with EN-ISO/IEC 17065/2012 and with the additional requirements established by the supervisory authority which is competent pursuant to Article 55 or 56.

2. Certification bodies referred to in paragraph 1 shall be accredited in accordance with that paragraph only where they have:

(a) demonstrated their independence and expertise in relation to the subject-matter of the certification to the satisfaction of the competent supervisory authority;

[1] Regulation (EC) No 765/2008 of the European Parliament and of the Council of 9 July 2008 setting out the requirements for accreditation and market surveillance relating to the marketing of products and repealing Regulation (EEC) No 339/93 (OJ L 218, 13.8.2008, p. 30).

(b) undertaken to respect the criteria referred to in Article 42(5) and approved by the supervisory authority which is competent pursuant to Article 55 or 56 or by the Board pursuant to Article 63;

(c) established procedures for the issuing, periodic review and withdrawal of data protection certification, seals and marks;

(d) established procedures and structures to handle complaints about infringements of the certification or the manner in which the certification has been, or is being, implemented by the controller or processor, and to make those procedures and structures transparent to data subjects and the public; and

(e) demonstrated, to the satisfaction of the competent supervisory authority, that their tasks and duties do not result in a conflict of interests.

3. The accreditation of certification bodies as referred to in paragraphs 1 and 2 of this Article shall take place on the basis of criteria approved by the supervisory authority which is competent pursuant to Article 55 or 56 or by the Board pursuant to Article 63. In the case of accreditation pursuant to point (b) of paragraph 1 of this Article, those requirements shall complement those envisaged in Regulation (EC) No 765/2008 and the technical rules that describe the methods and procedures of the certification bodies.

4. The certification bodies referred to in paragraph 1 shall be responsible for the proper assessment leading to the certification or the withdrawal of such certification without prejudice to the responsibility of the controller or processor for compliance with this Regulation. The accreditation shall be issued for a maximum period of five years and may be renewed on the same conditions provided that the certification body meets the requirements set out in this Article.

5. The certification bodies referred to in paragraph 1 shall provide the competent supervisory authorities with the reasons for granting or withdrawing the requested certification.

6. The requirements referred to in paragraph 3 of this Article and the criteria referred to in Article 42(5) shall be made public by the supervisory authority in an easily accessible form. The supervisory authorities shall also transmit those requirements and criteria to the Board. The Board shall collate all certification mechanisms and data protection seals in a register and shall make them publicly available by any appropriate means.

7. Without prejudice to Chapter VIII, the competent supervisory authority or the national accreditation body shall revoke an accreditation of a certification body pursuant to paragraph 1 of this Article where the conditions for the accreditation are not, or are no longer, met or where actions taken by a certification body infringe this Regulation.

8. The Commission shall be empowered to adopt delegated acts in accordance with Article 92 for the purpose of specifying the requirements to be taken into account for the data protection certification mechanisms referred to in Article 42(1).

9. The Commission may adopt implementing acts laying down technical standards for certification mechanisms and data protection seals and marks, and mechanisms to promote and recognise those certification mechanisms, seals and marks. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 93(2).

CHAPTER V

Transfers of personal data to third countries or international organisations

Article 44

General principle for transfers

Any transfer of personal data which are undergoing processing or are intended for processing after transfer to a third country or to an international organisation shall take place only if, subject to the other provisions of this Regulation, the conditions laid down in this Chapter are complied with by the controller and processor, including for onward transfers of personal data from the third country or an international organisation to another third country or to another international organisation. All provisions in this Chapter shall be applied in order to ensure that the level of protection of natural persons guaranteed by this Regulation is not undermined.

Article 45

Transfers on the basis of an adequacy decision

1. A transfer of personal data to a third country or an international organisation may take place where the Commission has decided that the third country, a territory or one or more specified sectors within that third country, or the international organisation in question ensures an adequate level of protection. Such a transfer shall not require any specific authorisation.

2. When assessing the adequacy of the level of protection, the Commission shall, in particular, take account of the following elements:

(a) the rule of law, respect for human rights and fundamental freedoms, relevant legislation, both general and sectoral, including concerning public security, defence, national security and criminal law and the access of public authorities to personal data, as well as the implementation of such legislation, data protection rules, professional rules and security measures, including rules for the onward transfer of personal data to another third country or international organisation which are complied with in that country or international organisation, case-law, as well as effective and enforceable data subject rights and effective administrative and judicial redress for the data subjects whose personal data are being transferred;

(b) the existence and effective functioning of one or more independent supervisory authorities in the third country or to which an international organisation is subject, with responsibility for ensuring and enforcing compliance with the data protection rules, including adequate enforcement powers, for assisting and advising the data subjects in exercising their rights and for cooperation with the supervisory authorities of the Member States; and

(c) the international commitments the third country or international organisation concerned has entered into, or other obligations arising from legally binding conventions or instruments as well as from its participation in multilateral or regional systems, in particular in relation to the protection of personal data.

3. The Commission, after assessing the adequacy of the level of protection, may decide, by means of implementing act, that a third country, a territory or one or more specified sectors within a third country, or an international organisation ensures an adequate level of protection within the meaning of paragraph 2 of this Article. The implementing act shall provide for a mechanism for a periodic review, at least every four years, which shall take into account all relevant developments in the third country or international organisation. The implementing act shall specify its territorial and sectoral application and, where applicable, identify the supervisory authority or authorities referred to in point (b) of paragraph 2 of this Article. The implementing act shall be adopted in accordance with the examination procedure referred to in Article 93(2).

4. The Commission shall, on an ongoing basis, monitor developments in third countries and international organisations that could affect the functioning of decisions adopted pursuant to paragraph 3 of this Article and decisions adopted on the basis of Article 25(6) of Directive 95/46/EC.

5. The Commission shall, where available information reveals, in particular following the review referred to in paragraph 3 of this Article, that a third country, a territory or one or more specified sectors within a third country, or an international organisation no longer ensures an adequate level of protection within the meaning of paragraph 2 of this Article, to the extent necessary, repeal, amend or suspend the decision referred to in paragraph 3 of this Article by means of implementing acts without retro-active effect. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 93(2).

On duly justified imperative grounds of urgency, the Commission shall adopt immediately applicable implementing acts in accordance with the procedure referred to in Article 93(3).

6. The Commission shall enter into consultations with the third country or international organisation with a view to remedying the situation giving rise to the decision made pursuant to paragraph 5.

7. A decision pursuant to paragraph 5 of this Article is without prejudice to transfers of personal data to the third country, a territory or one or more specified sectors within that third country, or the international organisation in question pursuant to Articles 46 to 49.

8. The Commission shall publish in the *Official Journal of the European Union* and on its website a list of the third countries, territories and specified sectors within a third country and international organisations for which it has decided that an adequate level of protection is or is no longer ensured.

9. Decisions adopted by the Commission on the basis of Article 25(6) of Directive 95/46/EC shall remain in force until amended, replaced or repealed by a Commission Decision adopted in accordance with paragraph 3 or 5 of this Article.

Article 46

Transfers subject to appropriate safeguards

1. In the absence of a decision pursuant to Article 45(3), a controller or processor may transfer personal data to a third country or an international organisation only if the controller or processor has provided appropriate safeguards, and on condition that enforceable data subject rights and effective legal remedies for data subjects are available.

2. The appropriate safeguards referred to in paragraph 1 may be provided for, without requiring any specific authorisation from a supervisory authority, by:

(a) a legally binding and enforceable instrument between public authorities or bodies;

(b) binding corporate rules in accordance with Article 47;

(c) standard data protection clauses adopted by the Commission in accordance with the examination procedure referred to in Article 93(2);

(d) standard data protection clauses adopted by a supervisory authority and approved by the Commission pursuant to the examination procedure referred to in Article 93(2);

(e) an approved code of conduct pursuant to Article 40 together with binding and enforceable commitments of the controller or processor in the third country to apply the appropriate safeguards, including as regards data subjects' rights; or

(f) an approved certification mechanism pursuant to Article 42 together with binding and enforceable commitments of the controller or processor in the third country to apply the appropriate safeguards, including as regards data subjects' rights.

3. Subject to the authorisation from the competent supervisory authority, the appropriate safeguards referred to in paragraph 1 may also be provided for, in particular, by:

(a) contractual clauses between the controller or processor and the controller, processor or the recipient of the personal data in the third country or international organisation; or

(b) provisions to be inserted into administrative arrangements between public authorities or bodies which include enforceable and effective data subject rights.

4. The supervisory authority shall apply the consistency mechanism referred to in Article 63 in the cases referred to in paragraph 3 of this Article.

5. Authorisations by a Member State or supervisory authority on the basis of Article 26(2) of Directive 95/46/EC shall remain valid until amended, replaced or repealed, if necessary, by that supervisory authority. Decisions adopted by the Commission on the basis of Article 26(4) of Directive 95/46/EC shall remain in force until amended, replaced or repealed, if necessary, by a Commission Decision adopted in accordance with paragraph 2 of this Article.

Article 47

Binding corporate rules

1. The competent supervisory authority shall approve binding corporate rules in accordance with the consistency mechanism set out in Article 63, provided that they:

(a) are legally binding and apply to and are enforced by every member concerned of the group of undertakings, or group of enterprises engaged in a joint economic activity, including their employees;

(b) expressly confer enforceable rights on data subjects with regard to the processing of their personal data; and

(c) fulfil the requirements laid down in paragraph 2.

2. The binding corporate rules referred to in paragraph 1 shall specify at least:

(a) the structure and contact details of the group of undertakings, or group of enterprises engaged in a joint economic activity and of each of its members;

(b) the data transfers or set of transfers, including the categories of personal data, the type of processing and its purposes, the type of data subjects affected and the identification of the third country or countries in question;

(c) their legally binding nature, both internally and externally;

(d) the application of the general data protection principles, in particular purpose limitation, data minimisation, limited storage periods, data quality, data protection by design and by default, legal basis for processing, processing of special categories of personal data, measures to ensure data security, and the requirements in respect of onward transfers to bodies not bound by the binding corporate rules;

(e) the rights of data subjects in regard to processing and the means to exercise those rights, including the right not to be subject to decisions based solely on automated processing, including profiling in accordance with Article 22, the right to lodge a complaint with the competent supervisory authority and before the competent courts of the Member States in accordance with Article 79, and to obtain redress and, where appropriate, compensation for a breach of the binding corporate rules;

(f) the acceptance by the controller or processor established on the territory of a Member State of liability for any breaches of the binding corporate rules by any member concerned not established in the Union; the controller or the processor shall be exempt from that liability, in whole or in part, only if it proves that that member is not responsible for the event giving rise to the damage;

(g) how the information on the binding corporate rules, in particular on the provisions referred to in points (d), (e) and (f) of this paragraph is provided to the data subjects in addition to Articles 13 and 14;

(h) the tasks of any data protection officer designated in accordance with Article 37 or any other person or entity in charge of the monitoring compliance with the binding corporate rules within the group of undertakings, or group of enterprises engaged in a joint economic activity, as well as monitoring training and complaint-handling;

(i) the complaint procedures;

(j) the mechanisms within the group of undertakings, or group of enterprises engaged in a joint economic activity for ensuring the verification of compliance with the binding corporate rules. Such mechanisms shall include data protection audits and methods for ensuring corrective actions to protect the rights of the data subject. Results of such verification should be communicated to the person or entity referred to in point (h) and to the board of the controlling undertaking of a group of undertakings, or of the group of enterprises engaged in a joint economic activity, and should be available upon request to the competent supervisory authority;

(k) the mechanisms for reporting and recording changes to the rules and reporting those changes to the supervisory authority;

(l) the cooperation mechanism with the supervisory authority to ensure compliance by any member of the group of undertakings, or group of enterprises engaged in a joint economic activity, in particular by making available to the supervisory authority the results of verifications of the measures referred to in point (j);

(m) the mechanisms for reporting to the competent supervisory authority any legal requirements to which a member of the group of undertakings, or group of enterprises engaged in a joint economic activity is subject in a third country which are likely to have a substantial adverse effect on the guarantees provided by the binding corporate rules; and

(n) the appropriate data protection training to personnel having permanent or regular access to personal data.

3. The Commission may specify the format and procedures for the exchange of information between controllers, processors and supervisory authorities for binding corporate rules within the meaning of this Article. Those implementing acts shall be adopted in accordance with the examination procedure set out in Article 93(2).

Article 48

Transfers or disclosures not authorised by Union law

Any judgment of a court or tribunal and any decision of an administrative authority of a third country requiring a controller or processor to transfer or disclose personal data may only be recognised or enforceable in any manner if based on an international agreement, such as a mutual legal assistance treaty, in force between the requesting third country and the Union or a Member State, without prejudice to other grounds for transfer pursuant to this Chapter.

Article 49

Derogations for specific situations

1. In the absence of an adequacy decision pursuant to Article 45(3), or of appropriate safeguards pursuant to Article 46, including binding corporate rules, a transfer or a set of transfers of personal data to a third country or an international organisation shall take place only on one of the following conditions:

(a) the data subject has explicitly consented to the proposed transfer, after having been informed of the possible risks of such transfers for the data subject due to the absence of an adequacy decision and appropriate safeguards;

(b) the transfer is necessary for the performance of a contract between the data subject and the controller or the implementation of pre-contractual measures taken at the data subject's request;

(c) the transfer is necessary for the conclusion or performance of a contract concluded in the interest of the data subject between the controller and another natural or legal person;

(d) the transfer is necessary for important reasons of public interest;

(e) the transfer is necessary for the establishment, exercise or defence of legal claims;

(f) the transfer is necessary in order to protect the vital interests of the data subject or of other persons, where the data subject is physically or legally incapable of giving consent;

(g) the transfer is made from a register which according to Union or Member State law is intended to provide information to the public and which is open to consultation either by the public in general or by any person who can demonstrate a legitimate interest, but only to the extent that the conditions laid down by Union or Member State law for consultation are fulfilled in the particular case.

Where a transfer could not be based on a provision in Article 45 or 46, including the provisions on binding corporate rules, and none of the derogations for a specific situation referred to in the first subparagraph of this paragraph is applicable, a transfer to a third country or an international organisation may take place only if the transfer is not repetitive, concerns only a limited number of data subjects, is necessary for the purposes of compelling legitimate interests pursued by the controller which are not overridden by the interests or rights and freedoms of the data subject, and the controller has assessed all the circumstances surrounding the data transfer and has on the basis of that assessment provided suitable safeguards with regard to the protection of personal data. The controller shall inform the supervisory authority of the transfer. The controller shall, in addition to providing the information referred to in Articles 13 and 14, inform the data subject of the transfer and on the compelling legitimate interests pursued.

2. A transfer pursuant to point (g) of the first subparagraph of paragraph 1 shall not involve the entirety of the personal data or entire categories of the personal data contained in the register. Where the register is intended for consultation by persons having a legitimate interest, the transfer shall be made only at the request of those persons or if they are to be the recipients.

3. Points (a), (b) and (c) of the first subparagraph of paragraph 1 and the second subparagraph thereof shall not apply to activities carried out by public authorities in the exercise of their public powers.

4. The public interest referred to in point (d) of the first subparagraph of paragraph 1 shall be recognised in Union law or in the law of the Member State to which the controller is subject.

5. In the absence of an adequacy decision, Union or Member State law may, for important reasons of public interest, expressly set limits to the transfer of specific categories of personal data to a third country or an international organisation. Member States shall notify such provisions to the Commission.

6. The controller or processor shall document the assessment as well as the suitable safeguards referred to in the second subparagraph of paragraph 1 of this Article in the records referred to in Article 30.

Article 50

International cooperation for the protection of personal data

In relation to third countries and international organisations, the Commission and supervisory authorities shall take appropriate steps to:

(a) develop international cooperation mechanisms to facilitate the effective enforcement of legislation for the protection of personal data;

(b) provide international mutual assistance in the enforcement of legislation for the protection of personal data, including through notification, complaint referral, investigative assistance and information exchange, subject to appropriate safeguards for the protection of personal data and other fundamental rights and freedoms;

(c) engage relevant stakeholders in discussion and activities aimed at furthering international cooperation in the enforcement of legislation for the protection of personal data;

(d) promote the exchange and documentation of personal data protection legislation and practice, including on jurisdictional conflicts with third countries.

CHAPTER VI

Independent supervisory authorities

Section 1

Independent status

Article 51

Supervisory authority

1. Each Member State shall provide for one or more independent public authorities to be responsible for monitoring the application of this Regulation, in order to protect the fundamental rights and freedoms of natural persons in relation to processing and to facilitate the free flow of personal data within the Union ('supervisory authority').

2. Each supervisory authority shall contribute to the consistent application of this Regulation throughout the Union. For that purpose, the supervisory authorities shall cooperate with each other and the Commission in accordance with Chapter VII.

3. Where more than one supervisory authority is established in a Member State, that Member State shall designate the supervisory authority which is to represent those authorities in the Board and shall set out the mechanism to ensure compliance by the other authorities with the rules relating to the consistency mechanism referred to in Article 63.

4. Each Member State shall notify to the Commission the provisions of its law which it adopts pursuant to this Chapter, by 25 May 2018 and, without delay, any subsequent amendment affecting them.

Article 52

Independence

1. Each supervisory authority shall act with complete independence in performing its tasks and exercising its powers in accordance with this Regulation.

2. The member or members of each supervisory authority shall, in the performance of their tasks and exercise of their powers in accordance with this Regulation, remain free from external influence, whether direct or indirect, and shall neither seek nor take instructions from anybody.

3. Member or members of each supervisory authority shall refrain from any action incompatible with their duties and shall not, during their term of office, engage in any incompatible occupation, whether gainful or not.

4. Each Member State shall ensure that each supervisory authority is provided with the human, technical and financial resources, premises and infrastructure necessary for the effective performance of its tasks and exercise of its powers, including those to be carried out in the context of mutual assistance, cooperation and participation in the Board.

5. Each Member State shall ensure that each supervisory authority chooses and has its own staff which shall be subject to the exclusive direction of the member or members of the supervisory authority concerned.

6. Each Member State shall ensure that each supervisory authority is subject to financial control which does not affect its independence and that it has separate, public annual budgets, which may be part of the overall state or national budget.

Article 53

General conditions for the members of the supervisory authority

1. Member States shall provide for each member of their supervisory authorities to be appointed by means of a transparent procedure by:

— their parliament;

— their government;

— their head of State; or

— an independent body entrusted with the appointment under Member State law.

2. Each member shall have the qualifications, experience and skills, in particular in the area of the protection of personal data, required to perform its duties and exercise its powers.

3. The duties of a member shall end in the event of the expiry of the term of office, resignation or compulsory retirement, in accordance with the law of the Member State concerned.

4. A member shall be dismissed only in cases of serious misconduct or if the member no longer fulfils the conditions required for the performance of the duties.

Article 54

Rules on the establishment of the supervisory authority

1. Each Member State shall provide by law for all of the following:

(a) the establishment of each supervisory authority;

(b) the qualifications and eligibility conditions required to be appointed as member of each supervisory authority;

(c) the rules and procedures for the appointment of the member or members of each supervisory authority;

(d) the duration of the term of the member or members of each supervisory authority of no less than four years, except for the first appointment after 24 May 2016, part of which may take place for a shorter period where that is necessary to protect the independence of the supervisory authority by means of a staggered appointment procedure;

(e) whether and, if so, for how many terms the member or members of each supervisory authority is eligible for reappointment;

(f) the conditions governing the obligations of the member or members and staff of each supervisory authority, prohibitions on actions, occupations and benefits incompatible therewith during and after the term of office and rules governing the cessation of employment.

2. The member or members and the staff of each supervisory authority shall, in accordance with Union or Member State law, be subject to a duty of professional secrecy both during and after their term of office, with regard to any confidential information which has come to their knowledge in the course of the performance of their tasks or exercise of their powers. During their term of office, that duty of professional secrecy shall in particular apply to reporting by natural persons of infringements of this Regulation.

Section 2

Competence, tasks and powers

Article 55

Competence

1. Each supervisory authority shall be competent for the performance of the tasks assigned to and the exercise of the powers conferred on it in accordance with this Regulation on the territory of its own Member State.

2. Where processing is carried out by public authorities or private bodies acting on the basis of point (c) or (e) of Article 6(1), the supervisory authority of the Member State concerned shall be competent. In such cases Article 56 does not apply.

3. Supervisory authorities shall not be competent to supervise processing operations of courts acting in their judicial capacity.

Article 56

Competence of the lead supervisory authority

1. Without prejudice to Article 55, the supervisory authority of the main establishment or of the single establishment of the controller or processor shall be competent to act as lead supervisory authority for the cross-border processing carried out by that controller or processor in accordance with the procedure provided in Article 60.

2. By derogation from paragraph 1, each supervisory authority shall be competent to handle a complaint lodged with it or a possible infringement of this Regulation, if the subject matter relates only to an establishment in its Member State or substantially affects data subjects only in its Member State.

3. In the cases referred to in paragraph 2 of this Article, the supervisory authority shall inform the lead supervisory authority without delay on that matter. Within a period of three weeks after being informed the lead supervisory authority shall decide whether or not it will handle the case in accordance with the procedure provided in Article 60, taking into account whether or not there is an establishment of the controller or processor in the Member State of which the supervisory authority informed it.

4. Where the lead supervisory authority decides to handle the case, the procedure provided in Article 60 shall apply. The supervisory authority which informed the lead supervisory authority may submit to the lead supervisory authority a draft for a decision. The lead supervisory authority shall take utmost account of that draft when preparing the draft decision referred to in Article 60(3).

5. Where the lead supervisory authority decides not to handle the case, the supervisory authority which informed the lead supervisory authority shall handle it according to Articles 61 and 62.

6. The lead supervisory authority shall be the sole interlocutor of the controller or processor for the cross-border processing carried out by that controller or processor.

Article 57

Tasks

1. Without prejudice to other tasks set out under this Regulation, each supervisory authority shall on its territory:

(a) monitor and enforce the application of this Regulation;

(b) promote public awareness and understanding of the risks, rules, safeguards and rights in relation to processing. Activities addressed specifically to children shall receive specific attention;

(c) advise, in accordance with Member State law, the national parliament, the government, and other institutions and bodies on legislative and administrative measures relating to the protection of natural persons' rights and freedoms with regard to processing;

(d) promote the awareness of controllers and processors of their obligations under this Regulation;

(e) upon request, provide information to any data subject concerning the exercise of their rights under this Regulation and, if appropriate, cooperate with the supervisory authorities in other Member States to that end;

(f) handle complaints lodged by a data subject, or by a body, organisation or association in accordance with Article 80, and investigate, to the extent appropriate, the subject matter of the complaint and inform the complainant of the progress and the outcome of the investigation within a reasonable period, in particular if further investigation or coordination with another supervisory authority is necessary;

(g) cooperate with, including sharing information and provide mutual assistance to, other supervisory authorities with a view to ensuring the consistency of application and enforcement of this Regulation;

(h) conduct investigations on the application of this Regulation, including on the basis of information received from another supervisory authority or other public authority;

(i) monitor relevant developments, insofar as they have an impact on the protection of personal data, in particular the development of information and communication technologies and commercial practices;

(j) adopt standard contractual clauses referred to in Article 28(8) and in point (d) of Article 46(2);

(k) establish and maintain a list in relation to the requirement for data protection impact assessment pursuant to Article 35(4);

(l) give advice on the processing operations referred to in Article 36(2);

(m) encourage the drawing up of codes of conduct pursuant to Article 40(1) and provide an opinion and approve such codes of conduct which provide sufficient safeguards, pursuant to Article 40(5);

(n) encourage the establishment of data protection certification mechanisms and of data protection seals and marks pursuant to Article 42(1), and approve the criteria of certification pursuant to Article 42(5);

(o) where applicable, carry out a periodic review of certifications issued in accordance with Article 42(7);

(p) draft and publish the criteria for accreditation of a body for monitoring codes of conduct pursuant to Article 41 and of a certification body pursuant to Article 43;

(q) conduct the accreditation of a body for monitoring codes of conduct pursuant to Article 41 and of a certification body pursuant to Article 43;

(r) authorise contractual clauses and provisions referred to in Article 46(3);

(s) approve binding corporate rules pursuant to Article 47;

(t) contribute to the activities of the Board;

(u) keep internal records of infringements of this Regulation and of measures taken in accordance with Article 58(2); and

(v) fulfil any other tasks related to the protection of personal data.

2. Each supervisory authority shall facilitate the submission of complaints referred to in point (f) of paragraph 1 by measures such as a complaint submission form which can also be completed electronically, without excluding other means of communication.

3. The performance of the tasks of each supervisory authority shall be free of charge for the data subject and, where applicable, for the data protection officer.

4. Where requests are manifestly unfounded or excessive, in particular because of their repetitive character, the supervisory authority may charge a reasonable fee based on administrative costs, or refuse to act on the request. The supervisory authority shall bear the burden of demonstrating the manifestly unfounded or excessive character of the request.

Article 58

Powers

1. Each supervisory authority shall have all of the following investigative powers:

(a) to order the controller and the processor, and, where applicable, the controller's or the processor's representative to provide any information it requires for the performance of its tasks;

(b) to carry out investigations in the form of data protection audits;

(c) to carry out a review on certifications issued pursuant to Article 42(7);

(d) to notify the controller or the processor of an alleged infringement of this Regulation;

(e) to obtain, from the controller and the processor, access to all personal data and to all information necessary for the performance of its tasks;

(f) to obtain access to any premises of the controller and the processor, including to any data processing equipment and means, in accordance with Union or Member State procedural law.

2. Each supervisory authority shall have all of the following corrective powers:

(a) to issue warnings to a controller or processor that intended processing operations are likely to infringe provisions of this Regulation;

(b) to issue reprimands to a controller or a processor where processing operations have infringed provisions of this Regulation;

(c) to order the controller or the processor to comply with the data subject's requests to exercise his or her rights pursuant to this Regulation;

(d) to order the controller or processor to bring processing operations into compliance with the provisions of this Regulation, where appropriate, in a specified manner and within a specified period;

(e) to order the controller to communicate a personal data breach to the data subject;

(f) to impose a temporary or definitive limitation including a ban on processing;

(g) to order the rectification or erasure of personal data or restriction of processing pursuant to Articles 16, 17 and 18 and the notification of such actions to recipients to whom the personal data have been disclosed pursuant to Article 17(2) and Article 19;

(h) to withdraw a certification or to order the certification body to withdraw a certification issued pursuant to Articles 42 and 43, or to order the certification body not to issue certification if the requirements for the certification are not or are no longer met;

(i) to impose an administrative fine pursuant to Article 83, in addition to, or instead of measures referred to in this paragraph, depending on the circumstances of each individual case;

(j) to order the suspension of data flows to a recipient in a third country or to an international organisation.

3. Each supervisory authority shall have all of the following authorisation and advisory powers:

(a) to advise the controller in accordance with the prior consultation procedure referred to in Article 36;

(b) to issue, on its own initiative or on request, opinions to the national parliament, the Member State government or, in accordance with Member State law, to other institutions and bodies as well as to the public on any issue related to the protection of personal data;

(c) to authorise processing referred to in Article 36(5), if the law of the Member State requires such prior authorisation;

(d) to issue an opinion and approve draft codes of conduct pursuant to Article 40(5);

(e) to accredit certification bodies pursuant to Article 43;

(f) to issue certifications and approve criteria of certification in accordance with Article 42(5);

(g) to adopt standard data protection clauses referred to in Article 28(8) and in point (d) of Article 46(2);

(h) to authorise contractual clauses referred to in point (a) of Article 46(3);

(i) to authorise administrative arrangements referred to in point (b) of Article 46(3);

(j) to approve binding corporate rules pursuant to Article 47.

4. The exercise of the powers conferred on the supervisory authority pursuant to this Article shall be subject to appropriate safeguards, including effective judicial remedy and due process, set out in Union and Member State law in accordance with the Charter.

5. Each Member State shall provide by law that its supervisory authority shall have the power to bring infringements of this Regulation to the attention of the judicial authorities and where appropriate, to commence or engage otherwise in legal proceedings, in order to enforce the provisions of this Regulation.

6. Each Member State may provide by law that its supervisory authority shall have additional powers to those referred to in paragraphs 1, 2 and 3. The exercise of those powers shall not impair the effective operation of Chapter VII.

Article 59

Activity reports

Each supervisory authority shall draw up an annual report on its activities, which may include a list of types of infringement notified and types of measures taken in accordance with Article 58(2). Those reports shall be transmitted to the national parliament, the government and other authorities as designated by Member State law. They shall be made available to the public, to the Commission and to the Board.

CHAPTER VII

Cooperation and consistency

Section 1

Cooperation

Article 60

Cooperation between the lead supervisory authority and the other supervisory authorities concerned

1. The lead supervisory authority shall cooperate with the other supervisory authorities concerned in accordance with this Article in an endeavour to reach consensus. The lead supervisory authority and the supervisory authorities concerned shall exchange all relevant information with each other.

2. The lead supervisory authority may request at any time other supervisory authorities concerned to provide mutual assistance pursuant to Article 61 and may conduct joint operations pursuant to Article 62, in particular for carrying out investigations or for monitoring the implementation of a measure concerning a controller or processor established in another Member State.

3. The lead supervisory authority shall, without delay, communicate the relevant information on the matter to the other supervisory authorities concerned. It shall without delay submit a draft decision to the other supervisory authorities concerned for their opinion and take due account of their views.

4. Where any of the other supervisory authorities concerned within a period of four weeks after having been consulted in accordance with paragraph 3 of this Article, expresses a relevant and reasoned objection to the draft decision, the lead supervisory authority shall, if it does not follow the relevant and reasoned objection or is of the opinion that the objection is not relevant or reasoned, submit the matter to the consistency mechanism referred to in Article 63.

5. Where the lead supervisory authority intends to follow the relevant and reasoned objection made, it shall submit to the other supervisory authorities concerned a revised draft decision for their opinion. That revised draft decision shall be subject to the procedure referred to in paragraph 4 within a period of two weeks.

6. Where none of the other supervisory authorities concerned has objected to the draft decision submitted by the lead supervisory authority within the period referred to in paragraphs 4 and 5, the lead supervisory authority and the supervisory authorities concerned shall be deemed to be in agreement with that draft decision and shall be bound by it.

7. The lead supervisory authority shall adopt and notify the decision to the main establishment or single establishment of the controller or processor, as the case may be and inform the other supervisory authorities concerned and the Board of the decision in question, including a summary of the relevant facts and grounds. The supervisory authority with which a complaint has been lodged shall inform the complainant on the decision.

8. By derogation from paragraph 7, where a complaint is dismissed or rejected, the supervisory authority with which the complaint was lodged shall adopt the decision and notify it to the complainant and shall inform the controller thereof.

9. Where the lead supervisory authority and the supervisory authorities concerned agree to dismiss or reject parts of a complaint and to act on other parts of that complaint, a separate decision shall be adopted for each of those parts of the matter. The lead supervisory authority shall adopt the decision for the part concerning actions in relation to the controller, shall notify it to the main establishment or single establishment of the controller or processor on the territory of its Member State and shall inform the complainant thereof, while the supervisory authority of the complainant shall adopt the decision for the part concerning dismissal or rejection of that complaint, and shall notify it to that complainant and shall inform the controller or processor thereof.

10. After being notified of the decision of the lead supervisory authority pursuant to paragraphs 7 and 9, the controller or processor shall take the necessary measures to ensure compliance with the decision as regards processing activities in the context of all its establishments in the Union. The controller or processor shall notify the measures taken for complying with the decision to the lead supervisory authority, which shall inform the other supervisory authorities concerned.

11. Where, in exceptional circumstances, a supervisory authority concerned has reasons to consider that there is an urgent need to act in order to protect the interests of data subjects, the urgency procedure referred to in Article 66 shall apply.

12. The lead supervisory authority and the other supervisory authorities concerned shall supply the information required under this Article to each other by electronic means, using a standardised format.

Article 61

Mutual assistance

1. Supervisory authorities shall provide each other with relevant information and mutual assistance in order to implement and apply this Regulation in a consistent manner, and shall put in place measures for effective cooperation with one another. Mutual assistance shall cover, in particular, information requests and supervisory measures, such as requests to carry out prior authorisations and consultations, inspections and investigations.

2. Each supervisory authority shall take all appropriate measures required to reply to a request of another supervisory authority without undue delay and no later than one month after receiving the request. Such measures may include, in particular, the transmission of relevant information on the conduct of an investigation.

3. Requests for assistance shall contain all the necessary information, including the purpose of and reasons for the request. Information exchanged shall be used only for the purpose for which it was requested.

4. The requested supervisory authority shall not refuse to comply with the request unless:

(a) it is not competent for the subject-matter of the request or for the measures it is requested to execute; or

(b) compliance with the request would infringe this Regulation or Union or Member State law to which the supervisory authority receiving the request is subject.

5. The requested supervisory authority shall inform the requesting supervisory authority of the results or, as the case may be, of the progress of the measures taken in order to respond to the request. The requested supervisory authority shall provide reasons for any refusal to comply with a request pursuant to paragraph 4.

6. Requested supervisory authorities shall, as a rule, supply the information requested by other supervisory authorities by electronic means, using a standardised format.

7. Requested supervisory authorities shall not charge a fee for any action taken by them pursuant to a request for mutual assistance. Supervisory authorities may agree on rules to indemnify each other for specific expenditure arising from the provision of mutual assistance in exceptional circumstances.

8. Where a supervisory authority does not provide the information referred to in paragraph 5 of this Article within one month of receiving the request of another supervisory authority, the requesting supervisory authority may adopt a provisional measure on the territory of its Member State in accordance with Article 55(1). In that case, the urgent need to act under Article 66(1) shall be presumed to be met and require an urgent binding decision from the Board pursuant to Article 66(2).

9. The Commission may, by means of implementing acts, specify the format and procedures for mutual assistance referred to in this Article and the arrangements for the exchange of information by electronic means between supervisory authorities, and between supervisory authorities and the Board, in particular the standardised format referred to in paragraph 6 of this Article. Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 93(2).

Article 62

Joint operations of supervisory authorities

1. The supervisory authorities shall, where appropriate, conduct joint operations including joint investigations and joint enforcement measures in which members or staff of the supervisory authorities of other Member States are involved.

2. Where the controller or processor has establishments in several Member States or where a significant number of data subjects in more than one Member State are likely to be substantially affected by processing operations, a supervisory authority of each of those Member States shall have the right to participate in joint operations. The supervisory authority which is competent pursuant to Article 56(1) or (4) shall invite the supervisory authority of each of those Member States to take part in the joint operations and shall respond without delay to the request of a supervisory authority to participate.

3. A supervisory authority may, in accordance with Member State law, and with the seconding supervisory authority's authorisation, confer powers, including investigative powers on the seconding supervisory authority's members or staff involved in joint operations or, in so far as the law of the Member State of the host supervisory authority permits, allow the seconding supervisory authority's members or staff to exercise their investigative powers in accordance with the law of the Member State of the seconding supervisory authority. Such investigative powers may be exercised only under the guidance and in the presence of members or staff of the host supervisory authority. The seconding supervisory authority's members or staff shall be subject to the Member State law of the host supervisory authority.

4. Where, in accordance with paragraph 1, staff of a seconding supervisory authority operate in another Member State, the Member State of the host supervisory authority shall assume responsibility for their actions, including liability, for any damage caused by them during their operations, in accordance with the law of the Member State in whose territory they are operating.

5. The Member State in whose territory the damage was caused shall make good such damage under the conditions applicable to damage caused by its own staff. The Member State of the seconding supervisory authority whose staff has caused damage to any person in the territory of another Member State shall reimburse that other Member State in full any sums it has paid to the persons entitled on their behalf.

6. Without prejudice to the exercise of its rights *vis-à-vis* third parties and with the exception of paragraph 5, each Member State shall refrain, in the case provided for in paragraph 1, from requesting reimbursement from another Member State in relation to damage referred to in paragraph 4.

7. Where a joint operation is intended and a supervisory authority does not, within one month, comply with the obligation laid down in the second sentence of paragraph 2 of this Article, the other supervisory authorities may adopt a provisional measure on the territory of its Member State in accordance with Article 55. In that case, the urgent need to act under Article 66(1) shall be presumed to be met and require an opinion or an urgent binding decision from the Board pursuant to Article 66(2).

Section 2

Consistency

Article 63

Consistency mechanism

In order to contribute to the consistent application of this Regulation throughout the Union, the supervisory authorities shall cooperate with each other and, where relevant, with the Commission, through the consistency mechanism as set out in this Section.

Article 64

Opinion of the Board

1. The Board shall issue an opinion where a competent supervisory authority intends to adopt any of the measures below. To that end, the competent supervisory authority shall communicate the draft decision to the Board, when it:

(a) aims to adopt a list of the processing operations subject to the requirement for a data protection impact assessment pursuant to Article 35(4);

(b) concerns a matter pursuant to Article 40(7) whether a draft code of conduct or an amendment or extension to a code of conduct complies with this Regulation;

(c) aims to approve the criteria for accreditation of a body pursuant to Article 41(3) or a certification body pursuant to Article 43(3);

(d) aims to determine standard data protection clauses referred to in point (d) of Article 46(2) and in Article 28(8);

(e) aims to authorise contractual clauses referred to in point (a) of Article 46(3); or

(f) aims to approve binding corporate rules within the meaning of Article 47.

2. Any supervisory authority, the Chair of the Board or the Commission may request that any matter of general application or producing effects in more than one Member State be examined by the Board with a view to obtaining an opinion, in particular where a competent supervisory authority does not comply with the obligations for mutual assistance in accordance with Article 61 or for joint operations in accordance with Article 62.

3. In the cases referred to in paragraphs 1 and 2, the Board shall issue an opinion on the matter submitted to it provided that it has not already issued an opinion on the same matter. That opinion shall be adopted within eight weeks by simple majority of the members of the Board. That period may be extended by a further six weeks, taking into account the complexity of the subject matter. Regarding the draft decision referred to in paragraph 1 circulated to the members of the Board in accordance with paragraph 5, a member which has not objected within a reasonable period indicated by the Chair, shall be deemed to be in agreement with the draft decision.

4. Supervisory authorities and the Commission shall, without undue delay, communicate by electronic means to the Board, using a standardised format any relevant information, including as the case may be a summary of the facts, the draft decision, the grounds which make the enactment of such measure necessary, and the views of other supervisory authorities concerned.

5. The Chair of the Board shall, without undue, delay inform by electronic means:

(a) the members of the Board and the Commission of any relevant information which has been communicated to it using a standardised format. The secretariat of the Board shall, where necessary, provide translations of relevant information; and

(b) the supervisory authority referred to, as the case may be, in paragraphs 1 and 2, and the Commission of the opinion and make it public.

6. The competent supervisory authority shall not adopt its draft decision referred to in paragraph 1 within the period referred to in paragraph 3.

7. The supervisory authority referred to in paragraph 1 shall take utmost account of the opinion of the Board and shall, within two weeks after receiving the opinion, communicate to the Chair of the Board by electronic means whether it will maintain or amend its draft decision and, if any, the amended draft decision, using a standardised format.

8. Where the supervisory authority concerned informs the Chair of the Board within the period referred to in paragraph 7 of this Article that it does not intend to follow the opinion of the Board, in whole or in part, providing the relevant grounds, Article 65(1) shall apply.

Article 65

Dispute resolution by the Board

1. In order to ensure the correct and consistent application of this Regulation in individual cases, the Board shall adopt a binding decision in the following cases:

(a) where, in a case referred to in Article 60(4), a supervisory authority concerned has raised a relevant and reasoned objection to a draft decision of the lead authority or the lead authority has rejected such an objection as being not relevant or reasoned. The binding decision shall concern all the matters which are the subject of the relevant and reasoned objection, in particular whether there is an infringement of this Regulation;

(b) where there are conflicting views on which of the supervisory authorities concerned is competent for the main establishment;

(c) where a competent supervisory authority does not request the opinion of the Board in the cases referred to in Article 64(1), or does not follow the opinion of the Board issued under Article 64. In that case, any supervisory authority concerned or the Commission may communicate the matter to the Board.

2. The decision referred to in paragraph 1 shall be adopted within one month from the referral of the subject-matter by a two-thirds majority of the members of the Board. That period may be extended by a further month on account of the complexity of the subject-matter. The decision referred to in paragraph 1 shall be reasoned and addressed to the lead supervisory authority and all the supervisory authorities concerned and binding on them.

3. Where the Board has been unable to adopt a decision within the periods referred to in paragraph 2, it shall adopt its decision within two weeks following the expiration of the second month referred to in paragraph 2 by a simple majority of the members of the Board. Where the members of the Board are split, the decision shall by adopted by the vote of its Chair.

4. The supervisory authorities concerned shall not adopt a decision on the subject matter submitted to the Board under paragraph 1 during the periods referred to in paragraphs 2 and 3.

5. The Chair of the Board shall notify, without undue delay, the decision referred to in paragraph 1 to the supervisory authorities concerned. It shall inform the Commission thereof. The decision shall be published on the website of the Board without delay after the supervisory authority has notified the final decision referred to in paragraph 6.

6. The lead supervisory authority or, as the case may be, the supervisory authority with which the complaint has been lodged shall adopt its final decision on the basis of the decision referred to in paragraph 1 of this Article, without undue delay and at the latest by one month after the Board has notified its decision. The lead supervisory authority or, as the case may be, the supervisory authority with which the complaint has been lodged, shall inform the Board of the date when its final decision is notified respectively to the controller or the processor and to the data subject. The final decision of the supervisory authorities concerned shall be adopted under the terms of Article 60(7), (8) and (9). The final decision shall refer to the decision referred to in paragraph 1 of this Article and shall specify that the decision referred to in that paragraph will be published on the website of the Board in accordance with paragraph 5 of this Article. The final decision shall attach the decision referred to in paragraph 1 of this Article.

Article 66

Urgency procedure

1. In exceptional circumstances, where a supervisory authority concerned considers that there is an urgent need to act in order to protect the rights and freedoms of data subjects, it may, by way of derogation from the consistency mechanism referred to in Articles 63, 64 and 65 or the procedure referred to in Article 60, immediately adopt provisional measures intended to produce legal effects on its own territory with a specified period of validity which shall not exceed three months. The supervisory authority shall, without delay, communicate those measures and the reasons for adopting them to the other supervisory authorities concerned, to the Board and to the Commission.

2. Where a supervisory authority has taken a measure pursuant to paragraph 1 and considers that final measures need urgently be adopted, it may request an urgent opinion or an urgent binding decision from the Board, giving reasons for requesting such opinion or decision.

3. Any supervisory authority may request an urgent opinion or an urgent binding decision, as the case may be, from the Board where a competent supervisory authority has not taken an appropriate measure in a situation where there is an urgent need to act, in order to protect the rights and freedoms of data subjects, giving reasons for requesting such opinion or decision, including for the urgent need to act.

4. By derogation from Article 64(3) and Article 65(2), an urgent opinion or an urgent binding decision referred to in paragraphs 2 and 3 of this Article shall be adopted within two weeks by simple majority of the members of the Board.

Article 67

Exchange of information

The Commission may adopt implementing acts of general scope in order to specify the arrangements for the exchange of information by electronic means between supervisory authorities, and between supervisory authorities and the Board, in particular the standardised format referred to in Article 64.

Those implementing acts shall be adopted in accordance with the examination procedure referred to in Article 93(2).

Section 3

European data protection board

Article 68

European Data Protection Board

1. The European Data Protection Board (the 'Board') is hereby established as a body of the Union and shall have legal personality.

2. The Board shall be represented by its Chair.

3. The Board shall be composed of the head of one supervisory authority of each Member State and of the European Data Protection Supervisor, or their respective representatives.

4. Where in a Member State more than one supervisory authority is responsible for monitoring the application of the provisions pursuant to this Regulation, a joint representative shall be appointed in accordance with that Member State's law.

5. The Commission shall have the right to participate in the activities and meetings of the Board without voting right. The Commission shall designate a representative. The Chair of the Board shall communicate to the Commission the activities of the Board.

6. In the cases referred to in Article 65, the European Data Protection Supervisor shall have voting rights only on decisions which concern principles and rules applicable to the Union institutions, bodies, offices and agencies which correspond in substance to those of this Regulation.

Article 69

Independence

1. The Board shall act independently when performing its tasks or exercising its powers pursuant to Articles 70 and 71.

2. Without prejudice to requests by the Commission referred to in point (b) of Article 70(1) and in Article 70(2), the Board shall, in the performance of its tasks or the exercise of its powers, neither seek nor take instructions from anybody.

Article 70

Tasks of the Board

1. The Board shall ensure the consistent application of this Regulation. To that end, the Board shall, on its own initiative or, where relevant, at the request of the Commission, in particular:

(a) monitor and ensure the correct application of this Regulation in the cases provided for in Articles 64 and 65 without prejudice to the tasks of national supervisory authorities;

(b) advise the Commission on any issue related to the protection of personal data in the Union, including on any proposed amendment of this Regulation;

(c) advise the Commission on the format and procedures for the exchange of information between controllers, processors and supervisory authorities for binding corporate rules;

(d) issue guidelines, recommendations, and best practices on procedures for erasing links, copies or replications of personal data from publicly available communication services as referred to in Article 17(2);

(e) examine, on its own initiative, on request of one of its members or on request of the Commission, any question covering the application of this Regulation and issue guidelines, recommendations and best practices in order to encourage consistent application of this Regulation;

(f) issue guidelines, recommendations and best practices in accordance with point (e) of this paragraph for further specifying the criteria and conditions for decisions based on profiling pursuant to Article 22(2);

(g) issue guidelines, recommendations and best practices in accordance with point (e) of this paragraph for establishing the personal data breaches and determining the undue delay referred to in Article 33(1) and (2) and for the particular circumstances in which a controller or a processor is required to notify the personal data breach;

(h) issue guidelines, recommendations and best practices in accordance with point (e) of this paragraph as to the circumstances in which a personal data breach is likely to result in a high risk to the rights and freedoms of the natural persons referred to in Article 34(1).

(i) issue guidelines, recommendations and best practices in accordance with point (e) of this paragraph for the purpose of further specifying the criteria and requirements for personal data transfers based on binding corporate rules adhered to by controllers and binding corporate rules adhered to by processors and on further necessary requirements to ensure the protection of personal data of the data subjects concerned referred to in Article 47;

(j) issue guidelines, recommendations and best practices in accordance with point (e) of this paragraph for the purpose of further specifying the criteria and requirements for the personal data transfers on the basis of Article 49(1);

(k) draw up guidelines for supervisory authorities concerning the application of measures referred to in Article 58(1), (2) and (3) and the setting of administrative fines pursuant to Article 83;

(l) review the practical application of the guidelines, recommendations and best practices referred to in points (e) and (f);

(m) issue guidelines, recommendations and best practices in accordance with point (e) of this paragraph for establishing common procedures for reporting by natural persons of infringements of this Regulation pursuant to Article 54(2);

(n) encourage the drawing-up of codes of conduct and the establishment of data protection certification mechanisms and data protection seals and marks pursuant to Articles 40 and 42;

(o) carry out the accreditation of certification bodies and its periodic review pursuant to Article 43 and maintain a public register of accredited bodies pursuant to Article 43(6) and of the accredited controllers or processors established in third countries pursuant to Article 42(7);

(p) specify the requirements referred to in Article 43(3) with a view to the accreditation of certification bodies under Article 42;

(q) provide the Commission with an opinion on the certification requirements referred to in Article 43(8);

(r) provide the Commission with an opinion on the icons referred to in Article 12(7);

(s) provide the Commission with an opinion for the assessment of the adequacy of the level of protection in a third country or international organisation, including for the assessment whether a third country, a territory or one or more specified sectors within that third country, or an international organisation no longer ensures an adequate level of protection. To that end, the Commission shall provide the Board with all necessary documentation, including correspondence with the government of the third country, with regard to that third country, territory or specified sector, or with the international organisation.

(t) issue opinions on draft decisions of supervisory authorities pursuant to the consistency mechanism referred to in Article 64(1), on matters submitted pursuant to Article 64(2) and to issue binding decisions pursuant to Article 65, including in cases referred to in Article 66;

(u) promote the cooperation and the effective bilateral and multilateral exchange of information and best practices between the supervisory authorities;

(v) promote common training programmes and facilitate personnel exchanges between the supervisory authorities and, where appropriate, with the supervisory authorities of third countries or with international organisations;

(w) promote the exchange of knowledge and documentation on data protection legislation and practice with data protection supervisory authorities worldwide.

(x) issue opinions on codes of conduct drawn up at Union level pursuant to Article 40(9); and

(y) maintain a publicly accessible electronic register of decisions taken by supervisory authorities and courts on issues handled in the consistency mechanism.

2. Where the Commission requests advice from the Board, it may indicate a time limit, taking into account the urgency of the matter.

3. The Board shall forward its opinions, guidelines, recommendations, and best practices to the Commission and to the committee referred to in Article 93 and make them public.

4. The Board shall, where appropriate, consult interested parties and give them the opportunity to comment within a reasonable period. The Board shall, without prejudice to Article 76, make the results of the consultation procedure publicly available.

Article 71

Reports

1. The Board shall draw up an annual report regarding the protection of natural persons with regard to processing in the Union and, where relevant, in third countries and international organisations. The report shall be made public and be transmitted to the European Parliament, to the Council and to the Commission.

2. The annual report shall include a review of the practical application of the guidelines, recommendations and best practices referred to in point (l) of Article 70(1) as well as of the binding decisions referred to in Article 65.

Article 72

Procedure

1. The Board shall take decisions by a simple majority of its members, unless otherwise provided for in this Regulation.

2. The Board shall adopt its own rules of procedure by a two-thirds majority of its members and organise its own operational arrangements.

Article 73

Chair

1. The Board shall elect a chair and two deputy chairs from amongst its members by simple majority.

2. The term of office of the Chair and of the deputy chairs shall be five years and be renewable once.

Article 74

Tasks of the Chair

1. The Chair shall have the following tasks:

(a) to convene the meetings of the Board and prepare its agenda;

(b) to notify decisions adopted by the Board pursuant to Article 65 to the lead supervisory authority and the supervisory authorities concerned;

(c) to ensure the timely performance of the tasks of the Board, in particular in relation to the consistency mechanism referred to in Article 63.

2. The Board shall lay down the allocation of tasks between the Chair and the deputy chairs in its rules of procedure.

Article 75

Secretariat

1. The Board shall have a secretariat, which shall be provided by the European Data Protection Supervisor.

2. The secretariat shall perform its tasks exclusively under the instructions of the Chair of the Board.

3. The staff of the European Data Protection Supervisor involved in carrying out the tasks conferred on the Board by this Regulation shall be subject to separate reporting lines from the staff involved in carrying out tasks conferred on the European Data Protection Supervisor.

4. Where appropriate, the Board and the European Data Protection Supervisor shall establish and publish a Memorandum of Understanding implementing this Article, determining the terms of their cooperation, and applicable to the staff of the European Data Protection Supervisor involved in carrying out the tasks conferred on the Board by this Regulation.

5. The secretariat shall provide analytical, administrative and logistical support to the Board.

6. The secretariat shall be responsible in particular for:

(a) the day-to-day business of the Board;

(b) communication between the members of the Board, its Chair and the Commission;

(c) communication with other institutions and the public;

(d) the use of electronic means for the internal and external communication;

(e) the translation of relevant information;

(f) the preparation and follow-up of the meetings of the Board;

(g) the preparation, drafting and publication of opinions, decisions on the settlement of disputes between supervisory authorities and other texts adopted by the Board.

Article 76

Confidentiality

1. The discussions of the Board shall be confidential where the Board deems it necessary, as provided for in its rules of procedure.

2. Access to documents submitted to members of the Board, experts and representatives of third parties shall be governed by Regulation (EC) No 1049/2001 of the European Parliament and of the Council ([1]).

CHAPTER VIII

Remedies, liability and penalties

Article 77

Right to lodge a complaint with a supervisory authority

1. Without prejudice to any other administrative or judicial remedy, every data subject shall have the right to lodge a complaint with a supervisory authority, in particular in the Member State of his or her habitual residence, place of work or place of the alleged infringement if the data subject considers that the processing of personal data relating to him or her infringes this Regulation.

2. The supervisory authority with which the complaint has been lodged shall inform the complainant on the progress and the outcome of the complaint including the possibility of a judicial remedy pursuant to Article 78.

Article 78

Right to an effective judicial remedy against a supervisory authority

1. Without prejudice to any other administrative or non-judicial remedy, each natural or legal person shall have the right to an effective judicial remedy against a legally binding decision of a supervisory authority concerning them.

2. Without prejudice to any other administrative or non-judicial remedy, each data subject shall have the right to a an effective judicial remedy where the supervisory authority which is competent pursuant to Articles 55 and 56 does not handle a complaint or does not inform the data subject within three months on the progress or outcome of the complaint lodged pursuant to Article 77.

3. Proceedings against a supervisory authority shall be brought before the courts of the Member State where the supervisory authority is established.

4. Where proceedings are brought against a decision of a supervisory authority which was preceded by an opinion or a decision of the Board in the consistency mechanism, the supervisory authority shall forward that opinion or decision to the court.

Article 79

Right to an effective judicial remedy against a controller or processor

1. Without prejudice to any available administrative or non-judicial remedy, including the right to lodge a complaint with a supervisory authority pursuant to Article 77, each data subject shall have the right to an effective judicial remedy where he or she considers that his or her rights under this Regulation have been infringed as a result of the processing of his or her personal data in non-compliance with this Regulation.

2. Proceedings against a controller or a processor shall be brought before the courts of the Member State where the controller or processor has an establishment. Alternatively, such proceedings may be brought before the courts of the Member State where the data subject has his or her habitual residence, unless the controller or processor is a public authority of a Member State acting in the exercise of its public powers.

([1]) Regulation (EC) No 1049/2001 of the European Parliament and of the Council of 30 May 2001 regarding public access to European Parliament, Council and Commission documents (OJ L 145, 31.5.2001, p. 43).

Article 80

Representation of data subjects

1. The data subject shall have the right to mandate a not-for-profit body, organisation or association which has been properly constituted in accordance with the law of a Member State, has statutory objectives which are in the public interest, and is active in the field of the protection of data subjects' rights and freedoms with regard to the protection of their personal data to lodge the complaint on his or her behalf, to exercise the rights referred to in Articles 77, 78 and 79 on his or her behalf, and to exercise the right to receive compensation referred to in Article 82 on his or her behalf where provided for by Member State law.

2. Member States may provide that any body, organisation or association referred to in paragraph 1 of this Article, independently of a data subject's mandate, has the right to lodge, in that Member State, a complaint with the supervisory authority which is competent pursuant to Article 77 and to exercise the rights referred to in Articles 78 and 79 if it considers that the rights of a data subject under this Regulation have been infringed as a result of the processing.

Article 81

Suspension of proceedings

1. Where a competent court of a Member State has information on proceedings, concerning the same subject matter as regards processing by the same controller or processor, that are pending in a court in another Member State, it shall contact that court in the other Member State to confirm the existence of such proceedings.

2. Where proceedings concerning the same subject matter as regards processing of the same controller or processor are pending in a court in another Member State, any competent court other than the court first seized may suspend its proceedings.

3. Where those proceedings are pending at first instance, any court other than the court first seized may also, on the application of one of the parties, decline jurisdiction if the court first seized has jurisdiction over the actions in question and its law permits the consolidation thereof.

Article 82

Right to compensation and liability

1. Any person who has suffered material or non-material damage as a result of an infringement of this Regulation shall have the right to receive compensation from the controller or processor for the damage suffered.

2. Any controller involved in processing shall be liable for the damage caused by processing which infringes this Regulation. A processor shall be liable for the damage caused by processing only where it has not complied with obligations of this Regulation specifically directed to processors or where it has acted outside or contrary to lawful instructions of the controller.

3. A controller or processor shall be exempt from liability under paragraph 2 if it proves that it is not in any way responsible for the event giving rise to the damage.

4. Where more than one controller or processor, or both a controller and a processor, are involved in the same processing and where they are, under paragraphs 2 and 3, responsible for any damage caused by processing, each controller or processor shall be held liable for the entire damage in order to ensure effective compensation of the data subject.

5. Where a controller or processor has, in accordance with paragraph 4, paid full compensation for the damage suffered, that controller or processor shall be entitled to claim back from the other controllers or processors involved in the same processing that part of the compensation corresponding to their part of responsibility for the damage, in accordance with the conditions set out in paragraph 2.

6. Court proceedings for exercising the right to receive compensation shall be brought before the courts competent under the law of the Member State referred to in Article 79(2).

Article 83

General conditions for imposing administrative fines

1. Each supervisory authority shall ensure that the imposition of administrative fines pursuant to this Article in respect of infringements of this Regulation referred to in paragraphs 4, 5 and 6 shall in each individual case be effective, proportionate and dissuasive.

2. Administrative fines shall, depending on the circumstances of each individual case, be imposed in addition to, or instead of, measures referred to in points (a) to (h) and (j) of Article 58(2). When deciding whether to impose an administrative fine and deciding on the amount of the administrative fine in each individual case due regard shall be given to the following:

(a) the nature, gravity and duration of the infringement taking into account the nature scope or purpose of the processing concerned as well as the number of data subjects affected and the level of damage suffered by them;

(b) the intentional or negligent character of the infringement;

(c) any action taken by the controller or processor to mitigate the damage suffered by data subjects;

(d) the degree of responsibility of the controller or processor taking into account technical and organisational measures implemented by them pursuant to Articles 25 and 32;

(e) any relevant previous infringements by the controller or processor;

(f) the degree of cooperation with the supervisory authority, in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

(g) the categories of personal data affected by the infringement;

(h) the manner in which the infringement became known to the supervisory authority, in particular whether, and if so to what extent, the controller or processor notified the infringement;

(i) where measures referred to in Article 58(2) have previously been ordered against the controller or processor concerned with regard to the same subject-matter, compliance with those measures;

(j) adherence to approved codes of conduct pursuant to Article 40 or approved certification mechanisms pursuant to Article 42; and

(k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as financial benefits gained, or losses avoided, directly or indirectly, from the infringement.

3. If a controller or processor intentionally or negligently, for the same or linked processing operations, infringes several provisions of this Regulation, the total amount of the administrative fine shall not exceed the amount specified for the gravest infringement.

4. Infringements of the following provisions shall, in accordance with paragraph 2, be subject to administrative fines up to 10 000 000 EUR, or in the case of an undertaking, up to 2 % of the total worldwide annual turnover of the preceding financial year, whichever is higher:

(a) the obligations of the controller and the processor pursuant to Articles 8, 11, 25 to 39 and 42 and 43;

(b) the obligations of the certification body pursuant to Articles 42 and 43;

(c) the obligations of the monitoring body pursuant to Article 41(4).

5. Infringements of the following provisions shall, in accordance with paragraph 2, be subject to administrative fines up to 20 000 000 EUR, or in the case of an undertaking, up to 4 % of the total worldwide annual turnover of the preceding financial year, whichever is higher:

(a) the basic principles for processing, including conditions for consent, pursuant to Articles 5, 6, 7 and 9;

(b) the data subjects' rights pursuant to Articles 12 to 22;

(c) the transfers of personal data to a recipient in a third country or an international organisation pursuant to Articles 44 to 49;

(d) any obligations pursuant to Member State law adopted under Chapter IX;

(e) non-compliance with an order or a temporary or definitive limitation on processing or the suspension of data flows by the supervisory authority pursuant to Article 58(2) or failure to provide access in violation of Article 58(1).

6. Non-compliance with an order by the supervisory authority as referred to in Article 58(2) shall, in accordance with paragraph 2 of this Article, be subject to administrative fines up to 20 000 000 EUR, or in the case of an undertaking, up to 4 % of the total worldwide annual turnover of the preceding financial year, whichever is higher.

7. Without prejudice to the corrective powers of supervisory authorities pursuant to Article 58(2), each Member State may lay down the rules on whether and to what extent administrative fines may be imposed on public authorities and bodies established in that Member State.

8. The exercise by the supervisory authority of its powers under this Article shall be subject to appropriate procedural safeguards in accordance with Union and Member State law, including effective judicial remedy and due process.

9. Where the legal system of the Member State does not provide for administrative fines, this Article may be applied in such a manner that the fine is initiated by the competent supervisory authority and imposed by competent national courts, while ensuring that those legal remedies are effective and have an equivalent effect to the administrative fines imposed by supervisory authorities. In any event, the fines imposed shall be effective, proportionate and dissuasive. Those Member States shall notify to the Commission the provisions of their laws which they adopt pursuant to this paragraph by 25 May 2018 and, without delay, any subsequent amendment law or amendment affecting them.

Article 84

Penalties

1. Member States shall lay down the rules on other penalties applicable to infringements of this Regulation in particular for infringements which are not subject to administrative fines pursuant to Article 83, and shall take all measures necessary to ensure that they are implemented. Such penalties shall be effective, proportionate and dissuasive.

2. Each Member State shall notify to the Commission the provisions of its law which it adopts pursuant to paragraph 1, by 25 May 2018 and, without delay, any subsequent amendment affecting them.

CHAPTER IX

Provisions relating to specific processing situations

Article 85

Processing and freedom of expression and information

1. Member States shall by law reconcile the right to the protection of personal data pursuant to this Regulation with the right to freedom of expression and information, including processing for journalistic purposes and the purposes of academic, artistic or literary expression.

2. For processing carried out for journalistic purposes or the purpose of academic artistic or literary expression, Member States shall provide for exemptions or derogations from Chapter II (principles), Chapter III (rights of the data subject), Chapter IV (controller and processor), Chapter V (transfer of personal data to third countries or international organisations), Chapter VI (independent supervisory authorities), Chapter VII (cooperation and consistency) and Chapter IX (specific data processing situations) if they are necessary to reconcile the right to the protection of personal data with the freedom of expression and information.

3. Each Member State shall notify to the Commission the provisions of its law which it has adopted pursuant to paragraph 2 and, without delay, any subsequent amendment law or amendment affecting them.

Article 86

Processing and public access to official documents

Personal data in official documents held by a public authority or a public body or a private body for the performance of a task carried out in the public interest may be disclosed by the authority or body in accordance with Union or Member State law to which the public authority or body is subject in order to reconcile public access to official documents with the right to the protection of personal data pursuant to this Regulation.

Article 87

Processing of the national identification number

Member States may further determine the specific conditions for the processing of a national identification number or any other identifier of general application. In that case the national identification number or any other identifier of general application shall be used only under appropriate safeguards for the rights and freedoms of the data subject pursuant to this Regulation.

Article 88

Processing in the context of employment

1. Member States may, by law or by collective agreements, provide for more specific rules to ensure the protection of the rights and freedoms in respect of the processing of employees' personal data in the employment context, in particular for the purposes of the recruitment, the performance of the contract of employment, including discharge of obligations laid down by law or by collective agreements, management, planning and organisation of work, equality and diversity in the workplace, health and safety at work, protection of employer's or customer's property and for the purposes of the exercise and enjoyment, on an individual or collective basis, of rights and benefits related to employment, and for the purpose of the termination of the employment relationship.

2. Those rules shall include suitable and specific measures to safeguard the data subject's human dignity, legitimate interests and fundamental rights, with particular regard to the transparency of processing, the transfer of personal data within a group of undertakings, or a group of enterprises engaged in a joint economic activity and monitoring systems at the work place.

3. Each Member State shall notify to the Commission those provisions of its law which it adopts pursuant to paragraph 1, by 25 May 2018 and, without delay, any subsequent amendment affecting them.

Article 89

Safeguards and derogations relating to processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes

1. Processing for archiving purposes in the public interest, scientific or historical research purposes or statistical purposes, shall be subject to appropriate safeguards, in accordance with this Regulation, for the rights and freedoms of the data subject. Those safeguards shall ensure that technical and organisational measures are in place in particular in

order to ensure respect for the principle of data minimisation. Those measures may include pseudonymisation provided that those purposes can be fulfilled in that manner. Where those purposes can be fulfilled by further processing which does not permit or no longer permits the identification of data subjects, those purposes shall be fulfilled in that manner.

2. Where personal data are processed for scientific or historical research purposes or statistical purposes, Union or Member State law may provide for derogations from the rights referred to in Articles 15, 16, 18 and 21 subject to the conditions and safeguards referred to in paragraph 1 of this Article in so far as such rights are likely to render impossible or seriously impair the achievement of the specific purposes, and such derogations are necessary for the fulfilment of those purposes.

3. Where personal data are processed for archiving purposes in the public interest, Union or Member State law may provide for derogations from the rights referred to in Articles 15, 16, 18, 19, 20 and 21 subject to the conditions and safeguards referred to in paragraph 1 of this Article in so far as such rights are likely to render impossible or seriously impair the achievement of the specific purposes, and such derogations are necessary for the fulfilment of those purposes.

4. Where processing referred to in paragraphs 2 and 3 serves at the same time another purpose, the derogations shall apply only to processing for the purposes referred to in those paragraphs.

Article 90

Obligations of secrecy

1. Member States may adopt specific rules to set out the powers of the supervisory authorities laid down in points (e) and (f) of Article 58(1) in relation to controllers or processors that are subject, under Union or Member State law or rules established by national competent bodies, to an obligation of professional secrecy or other equivalent obligations of secrecy where this is necessary and proportionate to reconcile the right of the protection of personal data with the obligation of secrecy. Those rules shall apply only with regard to personal data which the controller or processor has received as a result of or has obtained in an activity covered by that obligation of secrecy.

2. Each Member State shall notify to the Commission the rules adopted pursuant to paragraph 1, by 25 May 2018 and, without delay, any subsequent amendment affecting them.

Article 91

Existing data protection rules of churches and religious associations

1. Where in a Member State, churches and religious associations or communities apply, at the time of entry into force of this Regulation, comprehensive rules relating to the protection of natural persons with regard to processing, such rules may continue to apply, provided that they are brought into line with this Regulation.

2. Churches and religious associations which apply comprehensive rules in accordance with paragraph 1 of this Article shall be subject to the supervision of an independent supervisory authority, which may be specific, provided that it fulfils the conditions laid down in Chapter VI of this Regulation.

CHAPTER X

Delegated acts and implementing acts

Article 92

Exercise of the delegation

1. The power to adopt delegated acts is conferred on the Commission subject to the conditions laid down in this Article.

2. The delegation of power referred to in Article 12(8) and Article 43(8) shall be conferred on the Commission for an indeterminate period of time from 24 May 2016.

3. The delegation of power referred to in Article 12(8) and Article 43(8) may be revoked at any time by the European Parliament or by the Council. A decision of revocation shall put an end to the delegation of power specified in that decision. It shall take effect the day following that of its publication in the *Official Journal of the European Union* or at a later date specified therein. It shall not affect the validity of any delegated acts already in force.

4. As soon as it adopts a delegated act, the Commission shall notify it simultaneously to the European Parliament and to the Council.

5. A delegated act adopted pursuant to Article 12(8) and Article 43(8) shall enter into force only if no objection has been expressed by either the European Parliament or the Council within a period of three months of notification of that act to the European Parliament and the Council or if, before the expiry of that period, the European Parliament and the Council have both informed the Commission that they will not object. That period shall be extended by three months at the initiative of the European Parliament or of the Council.

Article 93

Committee procedure

1. The Commission shall be assisted by a committee. That committee shall be a committee within the meaning of Regulation (EU) No 182/2011.

2. Where reference is made to this paragraph, Article 5 of Regulation (EU) No 182/2011 shall apply.

3. Where reference is made to this paragraph, Article 8 of Regulation (EU) No 182/2011, in conjunction with Article 5 thereof, shall apply.

CHAPTER XI

Final provisions

Article 94

Repeal of Directive 95/46/EC

1. Directive 95/46/EC is repealed with effect from 25 May 2018.

2. References to the repealed Directive shall be construed as references to this Regulation. References to the Working Party on the Protection of Individuals with regard to the Processing of Personal Data established by Article 29 of Directive 95/46/EC shall be construed as references to the European Data Protection Board established by this Regulation.

Article 95

Relationship with Directive 2002/58/EC

This Regulation shall not impose additional obligations on natural or legal persons in relation to processing in connection with the provision of publicly available electronic communications services in public communication networks in the Union in relation to matters for which they are subject to specific obligations with the same objective set out in Directive 2002/58/EC.

Article 96

Relationship with previously concluded Agreements

International agreements involving the transfer of personal data to third countries or international organisations which were concluded by Member States prior to 24 May 2016, and which comply with Union law as applicable prior to that date, shall remain in force until amended, replaced or revoked.

Article 97

Commission reports

1. By 25 May 2020 and every four years thereafter, the Commission shall submit a report on the evaluation and review of this Regulation to the European Parliament and to the Council. The reports shall be made public.

2. In the context of the evaluations and reviews referred to in paragraph 1, the Commission shall examine, in particular, the application and functioning of:

(a) Chapter V on the transfer of personal data to third countries or international organisations with particular regard to decisions adopted pursuant to Article 45(3) of this Regulation and decisions adopted on the basis of Article 25(6) of Directive 95/46/EC;

(b) Chapter VII on cooperation and consistency.

3. For the purpose of paragraph 1, the Commission may request information from Member States and supervisory authorities.

4. In carrying out the evaluations and reviews referred to in paragraphs 1 and 2, the Commission shall take into account the positions and findings of the European Parliament, of the Council, and of other relevant bodies or sources.

5. The Commission shall, if necessary, submit appropriate proposals to amend this Regulation, in particular taking into account of developments in information technology and in the light of the state of progress in the information society.

Article 98

Review of other Union legal acts on data protection

The Commission shall, if appropriate, submit legislative proposals with a view to amending other Union legal acts on the protection of personal data, in order to ensure uniform and consistent protection of natural persons with regard to processing. This shall in particular concern the rules relating to the protection of natural persons with regard to processing by Union institutions, bodies, offices and agencies and on the free movement of such data.

Article 99

Entry into force and application

1. This Regulation shall enter into force on the twentieth day following that of its publication in the *Official Journal of the European Union*.

2. It shall apply from 25 May 2018.

This Regulation shall be binding in its entirety and directly applicable in all Member States.

Done at Brussels, 27 April 2016.

For the European Parliament	*For the Council*
The President	*The President*
M. SCHULZ	J.A. HENNIS-PLASSCHAERT

2023/2225

30.10.2023

DIRECTIVE (EU) 2023/2225 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 18 October 2023

on credit agreements for consumers and repealing Directive 2008/48/EC

THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION,

Having regard to the Treaty on the Functioning of the European Union, and in particular Article 114 thereof,

Having regard to the proposal from the European Commission,

After transmission of the draft legislative act to the national parliaments,

Having regard to the opinion of the European Economic and Social Committee ([1]),

Acting in accordance with the ordinary legislative procedure ([2]),

Whereas:

(1) Directive 2008/48/EC of the European Parliament and of the Council ([3]) lays down rules at Union level concerning credit agreements for consumers.

(2) In 2014, the Commission presented a report on the implementation of Directive 2008/48/EC. In 2020, the Commission presented a second report on the implementation of that Directive and a Commission Staff Working Document with the results of a regulatory fitness and performance evaluation of that Directive, which included broad consultation of relevant stakeholders.

(3) Those reports and consultations revealed that Directive 2008/48/EC has been partially effective in ensuring high standards of consumer protection and fostering the development of a single market for credit, and that such objectives are still relevant. The reasons why that Directive has been only partially effective stem both from the Directive itself, as for instance imprecise wording of particular articles, and from external factors, such as the developments linked to digitalisation, the practical application and enforcement in Member States as well as from the fact that certain aspects of the consumer credit market are not covered by that Directive.

(4) Digitalisation has contributed to market developments that were not foreseen at the time when Directive 2008/48/EC was adopted. In fact, the rapid technological developments registered since the adoption of that Directive have brought significant changes to the consumer credit market, both on the supply side and on the demand side, such as the emergence of new products and the evolution of consumer behaviour and preferences.

(5) The imprecise wording of certain provisions of Directive 2008/48/EC, allowing Member States to adopt diverging provisions going beyond those provided for in that Directive, resulted in a fragmented regulatory framework across the Union in a number of aspects of credit agreements for consumers.

(6) The de facto and de jure situation resulting from those national differences in some cases leads to distortions of competition among creditors in the Union and creates obstacles to the internal market. The situation restricts consumers' ability to benefit from a gradually increasing offer of cross-border credit, which is expected to grow further as a result of digitalisation. Those distortions and restrictions may in turn have consequences in terms of reduced demand for goods and services. The situation also leads to an inadequate and inconsistent level of protection for consumers across the Union.

([1]) OJ C 105, 4.3.2022, p. 92.
([2]) Position of the European Parliament of 12 September 2023 (not yet published in the Official Journal) and decision of the Council of 9 October 2023.
([3]) Directive 2008/48/EC of the European Parliament and of the Council of 23 April 2008 on credit agreements for consumers and repealing Council Directive 87/102/EEC (OJ L 133, 22.5.2008, p. 66).

(7) In recent years, credit offered to consumers has evolved and diversified considerably. New credit products have appeared, in particular in the online environment, and their use continues to develop. This has led to legal uncertainty with regard to the application of the Directive 2008/48/EC to such new products.

(8) This Directive complements the rules set out in Directive 2002/65/EC of the European Parliament and of the Council ([4]). In order to ensure legal certainty, it should be clarified that in the event of conflict between the provisions of this Directive and those of that Directive, the provisions of this Directive, as *lex specialis*, should apply.

(9) In accordance with Article 26 of the Treaty on the Functioning of the European Union (TFEU), the internal market comprises an area in which the free movement of goods, persons and services is ensured. The development of a more transparent and efficient legal framework for consumer credit should increase consumer trust and protection, and facilitate the development of cross-border activities.

(10) In order to improve the functioning of the internal market for consumer credits, it is necessary to provide for a harmonised Union framework in a number of core areas. In view of the developing market in consumer credit, in particular in the online environment, and the increasing mobility of Union citizens, forward-looking Union legislation which is able to adapt to future forms of credit and which allows Member States the appropriate degree of flexibility in their implementation will help to create a level playing field for businesses.

(11) Article 169(1) and Article 169(2), point (a), TFEU provide that the Union is to contribute to the attainment of a high level of consumer protection through measures adopted pursuant to Article 114 TFEU. Article 38 of the Charter of Fundamental Rights of the European Union ('the Charter') provides that Union policies are to ensure a high level of consumer protection.

(12) It is important that consumers benefit from a high level of protection. Thus, it should be possible for the free movement of credit offers to take place under optimum conditions for both those who offer credit and those who require it, with due regard to specific situations in the Member States.

(13) Full harmonisation is necessary in order to ensure that all consumers in the Union enjoy a high and equivalent level of protection of their interests and to create a well-functioning internal market. Member States should therefore not be allowed to maintain or introduce national provisions diverging from those laid down in this Directive, unless otherwise provided for in this Directive. However, such restriction should only apply where there are provisions harmonised in this Directive. Where no such harmonised provisions exist, Member States should remain free to maintain or introduce national legislation. Accordingly, Member States should have the possibility to maintain or introduce national provisions on joint and several liability of the supplier of goods or the provider of services and the creditor. Member States should also have the possibility to maintain or introduce national provisions on the cancellation of a contract for the sale of goods or supply of services where the consumer exercises his or her right of withdrawal from the credit agreement. In that respect, Member States, in the case of open-end credit agreements, should be allowed to fix a minimum period needing to elapse between the time when the creditor asks for reimbursement and the day on which the credit has to be reimbursed.

(14) The definitions set out in this Directive determine the scope of harmonisation. The obligation on Member States to transpose this Directive should therefore be limited to its scope as determined by those definitions. However, this Directive should be without prejudice to the application by Member States, in accordance with Union law, of the provisions of this Directive to areas not covered by its scope. A Member State could thereby maintain or introduce national legislation corresponding to this Directive or certain provisions of this Directive on credit agreements falling outside its scope, for instance on credit agreements upon the conclusion of which the consumer is requested to deposit an item as security in the creditor's safe-keeping and where the liability of the consumer is strictly limited to that deposited item, or on credit agreements involving a total amount of credit of more than EUR 100 000. Furthermore, Member States could also apply this Directive to linked credit which does not fall within the definition of a linked credit agreement set out in this Directive. Thus, the provisions of this Directive on linked credit agreements could be applied to credit agreements that serve only partially to finance a contract for the supply of goods or provision of a service.

([4]) Directive 2002/65/EC of the European Parliament and of the Council of 23 September 2002 concerning the distance marketing of consumer financial services and amending Council Directive 90/619/EEC and Directives 97/7/EC and 98/27/EC (OJ L 271, 9.10.2002, p. 16).

(15) A number of Member States have applied Directive 2008/48/EC to areas not covered by its scope to enhance the level of consumer protection, while other Member States have different national rules regulating those areas stemming from market specificities, thereby maintaining certain divergences between the national law of different Member States with regard to those types of credits. In fact, several of the credit agreements not falling within the scope of Directive 2008/48/EC can be detrimental for consumers, including short-term high-cost credit agreements whose amount is typically lower than the minimum threshold of EUR 200 set out in that Directive. In that context, and with the aim of ensuring a high level of consumer protection and of facilitating the cross-border consumer credit market, this Directive should cover some agreements that were excluded from the scope of Directive 2008/48/EC, such as credit agreements for consumers involving a total amount of credit of less than EUR 200. Likewise, other potentially detrimental products, because of the high costs they entail or high fees in the case of missed payments, should be covered by this Directive, to ensure increased transparency and better consumer protection, resulting in higher consumer confidence. To that extent, hiring or leasing agreements with an option to buy, credit agreements in the form of an overdraft facility and where the credit has to be repaid within one month, credit agreements where the credit is granted free of interest and without any other charges, and credit agreements under the terms of which the credit has to be repaid within three months and only insignificant charges are payable should not be excluded from the scope of this Directive. However, for some of those credit agreements that were excluded from the scope of Directive 2008/48/EC and should be covered under this Directive, namely credit agreements involving a total amount of credit of less than EUR 200, credit granted free of interest and without any other charges and with only limited charges payable by the consumer for late payments and credit to be repaid within three months with only insignificant charges, Member States should be able to exclude the application of a defined and limited number of provisions of this Directive related to advertisement, pre-contractual information and contractual information, in order to avoid an unnecessary burden for creditors, taking into account the market specificities and the particular characteristics of those credit agreements, such as their shorter duration, while ensuring a higher level of consumer protection.

(16) 'Buy now, pay later' schemes whereby the creditor grants credit to a consumer for the exclusive purpose of purchasing goods or services provided by a supplier, which are new digital financial tools that let consumers make purchases and pay them off over time, are often granted free of interest and without any other charges, and should therefore be included in the scope of this Directive.

(17) Certain deferred payments, where a supplier of goods or a provider of services gives the consumer time to pay for a good or service free of interest and without any other charges except for limited charges for late payments in accordance with national law, should be excluded from the scope of this Directive, provided that there is no third party, such as in 'buy now, pay later' schemes, offering credit for the good or service and that the payment is to be entirely executed in a limited time-frame of 50 days from the delivery of the good or provision of the service. In fact, such deferred payments are business practices commonly used to allow consumers to pay only after receipt of the goods or services, which are beneficial for consumers, for instance in the case of deferred payment of medical bills where hospitals give time to consumers to pay for medical expenses. That exclusion should be restricted for certain large online suppliers of goods or providers of services which have access to a large customer base, where a third party is neither offering nor purchasing credit and where payment is to be entirely executed within 14 days of the delivery of the goods or services, free of interest and without any other charges and with only limited charges payable by the consumer for late payments imposed in accordance with national law. Such large online suppliers, considering their financial capacities and their ability to drive consumers towards impulsive buying and potentially over-consumption, would otherwise be able to offer deferred payment in a very extensive way without any safeguard for consumers and to weaken fair competition with other suppliers of goods or providers of services. Such a restriction would always allow consumers to make payments in a convenient way within two weeks, while ensuring that, if large online suppliers of goods or providers of services want to provide credit on a large scale with a longer timeframe, they are subject to this Directive.

(18) As described in recital 17 of Regulation (EU) 2015/751 of the European Parliament and of the Council ([5]), deferred debit cards are credit cards commonly available on the market where the total amount of transactions is debited from the cardholder account at a pre-agreed specific date, usually once a month, without interest to be paid. Member States should be able to exempt from this Directive certain credit agreements in the form of deferred debit cards, as such credit agreements can help households to better adjust their budget to a monthly income, when the credit needs to be repaid within 40 days, is free of interest and without any other charges and with only limited charges linked to the provision of the payment service, and is provided by a credit institution or a payment institution. That exemption should be without prejudice to the application of relevant provisions on overdraft facilities or overrunning, which should apply in case the repayment exceeds the positive balance in the current account.

([5]) Regulation (EU) 2015/751 of the European Parliament and of the Council of 29 April 2015 on interchange fees for card-based payment transactions (OJ L 123, 19.5.2015, p. 1).

(19) Hiring and leasing agreements where an obligation or an option for the consumer to purchase the object of the agreement is not laid down either in the agreement itself or in any separate agreement, such as pure rental agreements, should not be included in the scope of this Directive, given that they do not involve any possible transfer of property by the end of the contract.

(20) Moreover, all credit agreements up to EUR 100 000 should be included in the scope of this Directive. The upper threshold of credit agreements set out in this Directive should be higher than the one set out in Directive 2008/48/EC in order to take into account the indexation for the effects of inflation since 2008 and for the coming years.

(21) In the case of credit agreements which provide for arrangements between the creditor and the consumer in respect of deferred payment or of repayment methods, where the consumer is already in default or is likely to default on the initial credit agreement, when such arrangements are likely to avert the possibility of legal proceedings concerning the default and their terms are not less favourable than those laid down in the initial credit agreement, Member States should be able to decide to apply only a limited number of provisions of this Directive, inter alia exempting creditors from the obligation to perform a creditworthiness assessment. This is not to prevent consumers in payment difficulty to get a new credit agreement that would help them to repay their initial credit more easily. Consumers would be considered likely to default for instance in situations where they lost their job.

(22) Since 2008, crowdfunding has developed as a form of finance available to consumers, typically for small expenses or investments. A provider of crowdfunding credit services operates a digital platform open to the public in order to match or facilitate the matching of prospective lenders, acting in the course of their trade, business or profession or not, with consumers that seek funding. Such funding could take the form of consumer credit. Where providers of crowdfunding credit services directly provide credit to consumers, the provisions of this Directive concerning creditors should apply to them. Where providers of crowdfunding credit services facilitate the granting of credit between creditors acting in the course of their trade, business or profession, and consumers, the obligations for creditors under this Directive should apply to those creditors. In such a situation, providers of crowdfunding credit services act as credit intermediaries, hence the obligations for credit intermediaries under this Directive should apply to them.

(23) In the case of specific types of credit agreements to which only some provisions of this Directive are applicable, Member States should remain free to regulate, in their national law, such types of credit agreements as regards other aspects not harmonised by this Directive.

(24) Agreements for the provision on a continuing basis of services or for the supply of goods of the same kind, where the consumer pays for them for the duration of their provision by means of instalments, may differ considerably, in terms of the interests of the contractual parties involved, and the modalities and performance of the transactions, from credit agreements covered by this Directive. Therefore, such agreements should not be regarded as credit agreements for the purposes of this Directive. Such agreements include, for example, an insurance contract where the insurance is paid for in monthly instalments.

(25) Credit agreements covering the granting of credit secured by immovable property and credit agreements the purpose of which is to finance the acquisition or retention of property rights in land or in an existing or projected building, including premises used for trade, business or a profession, should be excluded from the scope of this Directive as such agreements are regulated by Directive 2014/17/EU of the European Parliament and of the Council ([6]). However, credits the purpose of which is the renovation of a residential immovable property involving a total amount above EUR 100 000, and which are not secured either by a mortgage, or by another comparable security commonly used in a Member State on immovable property or by a right related to immovable property, should not be excluded from the scope of this Directive.

(26) This Directive should apply irrespective of whether the creditor is a legal person or a natural person. However, this Directive should not affect the right of Member States to limit the provision of credit for consumers to legal persons only or to certain legal persons.

([6]) Directive 2014/17/EU of the European Parliament and of the Council of 4 February 2014 on credit agreements for consumers relating to residential immovable property and amending Directives 2008/48/EC and 2013/36/EU and Regulation (EU) No 1093/2010 (OJ L 60, 28.2.2014, p. 34).

(27) Certain provisions of this Directive should apply to credit intermediaries, which are natural and legal persons who, in the course of their trade, business or profession, for remuneration, present or offer credit agreements to consumers, assist consumers by undertaking preparatory work in respect of credit agreements or conclude credit agreements with consumers on behalf of the creditor.

(28) Information to consumers, such as adequate explanations, pre-contractual information, general information and information on consultation of databases, should be provided free of charge. Special attention should be given to the needs of persons with disabilities.

(29) This Directive respects fundamental rights and observes the principles recognised in particular by the Charter. In particular, this Directive fully respects the rights to the protection of personal data, to property, to non-discrimination, to protection of family and professional life, and to consumer protection pursuant to the Charter.

(30) This Directive should be without prejudice to Regulation (EU) 2016/679 of the European Parliament and of the Council ([7]) which applies to any processing of personal data carried out by creditors and credit intermediaries falling within the scope of this Directive, and in particular without prejudice to principles relating to the processing of personal data set out in Article 5 of that Regulation, including data minimisation, accuracy and purpose limitation.

(31) Consumers who are legally resident in the Union should not be discriminated against on the ground of their nationality or place of residence, or on any ground as referred to in Article 21 of the Charter when requesting, concluding or holding a credit agreement within the Union. This is without prejudice to the possibility of offering different conditions of access to a credit where those different conditions are duly justified by objective criteria. Moreover, this should not be understood as creating an obligation for creditors or credit intermediaries to provide services in areas in which they do not conduct business.

(32) Consumers should be protected against unfair or misleading practices, in particular with respect to the information provided by the creditor or credit intermediary, in line with Directive 2005/29/EC of the European Parliament and of the Council ([8]). That Directive continues to apply to credit agreements and works as a 'safety net' ensuring that a high common level of consumer protection against unfair commercial practices can be maintained in all sectors, including by complementing other Union law.

(33) Specific provisions should be laid down on advertising of credit agreements and on certain items of standard information to be provided to consumers in order to enable them, in particular, to compare different offers. Such standard information should be given in a clear, concise and prominent way by means of a representative example. The total amount of the credit and the repayment duration chosen by the creditor for such a representative example should correspond as much as possible to the characteristics of the credit agreement that the creditor advertises. The standard information should be shown upfront and saliently, in a clear way and in an engaging format. It should be clearly legible and adapted to take into account the technical constraints of certain media such as mobile telephone screens. On digital channels, part of the standard information in the representative example could be provided by means of clicking, scrolling or swiping. However, before accessing credit offers, consumers should be presented with all standard information to be included in advertising concerning credit agreements even in the case of clicking, scrolling or swiping. The standard information should also be clearly demarcated from any additional information pertained to the credit agreement. Temporary promotional conditions, such as a 'teaser' rate with a lower borrowing rate for the initial months of the credit agreement, should be clearly identified as such. Consumers should be able to see all essential information at a glance, even when they watch it on the screen of a mobile telephone. The creditor's and, where applicable, credit intermediary's telephone number and email address should also be communicated to the consumer to enable him or her to contact the creditor or the credit intermediary quickly and efficiently.

([7]) Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ L 119, 4.5.2016, p. 1).

([8]) Directive 2005/29/EC of the European Parliament and of the Council of 11 May 2005 concerning unfair business-to-consumer commercial practices in the internal market and amending Council Directive 84/450/EEC, Directives 97/7/EC, 98/27/EC and 2002/65/EC of the European Parliament and of the Council and Regulation (EC) No 2006/2004 of the European Parliament and of the Council ('Unfair Commercial Practices Directive') (OJ L 149, 11.6.2005, p. 22).

A ceiling should be provided where it is not possible to indicate the total amount of credit as the total sums made available, in particular where a credit agreement gives the consumer freedom of drawdown with a limitation with regard to the amount. The ceiling should indicate the upper limit of credit which can be made available to the consumer. In specific and justified cases, in order to improve consumer understanding of information disclosed in advertising of credit agreements where the medium used does not allow that information to be visually displayed, such as in radio advertising, the amount of information disclosed should be reduced. In addition, Member States should remain free to regulate information requirements in their national law regarding advertising of credit agreements which does not contain information on the cost of credit. In order to reduce instances of mis-selling of credit to consumers who are not able to afford it and to promote sustainable lending, advertising of credit agreements should contain, in all cases, a clear and prominent warning to make consumers aware that borrowing money costs money. In order to ensure a higher level of consumer protection, certain advertisements, such as those encouraging consumers to seek credit by suggesting that credit would improve their financial situation or specifying that registered credit in databases have little or no influence on the assessment of a credit application, should be prohibited. Member States should also be allowed to prohibit advertisements that they deem to be risky for consumers, such as those that highlight the ease or speed with which credit can be obtained.

(34) A durable medium, including paper and interoperable, portable and machine-readable digital versions of documents, should allow information to be addressed personally to the consumer, it should enable the consumer to store information in a way that is accessible for future reference and for a period of time adequate for the purposes of the information, it should allow the unchanged reproduction of the information stored and it should ensure readability of the information so that the information can be read and referred to. Consumers should have the possibility to choose the type of durable medium on which to receive information at the pre-contractual stage and once the contract is concluded, and on which to notify their withdrawal. However, consumers should not be able to notify their withdrawal and to require creditors or, where applicable, credit intermediaries to provide information on types of durable medium that are not commonly used.

(35) Advertising tends to focus on one or more products in particular, while consumers should be able to make their decisions in full knowledge of the range of credit products on offer. In that respect, general information plays an important role in educating the consumer in relation to the broad range of products and services available and the key features thereof. Consumers should therefore be able at any time to access general information on credit products available. This should be without prejudice to the obligation to provide consumers with personalised pre-contractual information.

(36) In order to be able to make their decisions in full knowledge of the facts, consumers should receive adequate pre-contractual information, for careful consideration at their own leisure and convenience, in good time before and not at the same time as the conclusion of the credit agreement, including information on the conditions and cost of the credit and on their obligations, as well as adequate explanations thereof. This is to ensure that consumers have sufficient time to read and understand the pre-contractual information, compare offers and make an informed decision. Such a requirement should be without prejudice to Council Directive 93/13/EEC ([9]).

(37) Pre-contractual information should be provided through the Standard European Consumer Credit Information form set out in Annex I to this Directive. To help consumers understand and compare different offers, the key elements of the credit should be provided in a prominent way on the first page of that form, through which consumers should see all essential information at a glance, even on the screen of a mobile telephone. In case all of the key elements cannot be displayed in a prominent way on one page, they should be displayed in the first part of the Standard European Consumer Credit Information form on two pages at most. Information provided in that form should be clear, clearly legible and adapted to the technical constraints of certain media such as mobile telephone screens. It should be displayed in an adequate and suitable way on the different channels, to ensure that every consumer can access information on an equal basis and in line with Directive (EU) 2019/882 of the European Parliament and of the Council ([10]).

([9]) Council Directive 93/13/EEC of 5 April 1993 on unfair terms in consumer contracts (OJ L 95, 21.4.1993, p. 29).

([10]) Directive (EU) 2019/882 of the European Parliament and of the Council of 17 April 2019 on the accessibility requirements for products and services (OJ L 151, 7.6.2019, p. 70).

(38) To ensure the greatest possible transparency and comparability of offers, pre-contractual information should, in particular, include the annual percentage rate of charge applicable to the credit, determined in the same way throughout the Union. As the annual percentage rate of charge can at this stage be indicated only through an example, such example should be representative. Therefore, it should correspond, for instance, to the average duration and total amount of credit granted for the type of credit agreement under consideration and, if applicable, to the goods purchased. When determining the representative example, the frequency of certain types of credit agreement in a specific market should also be taken into account. As regards the borrowing rate, the frequency of instalments and the capitalisation of interest, creditors should use their usual method of calculation for the consumer credit concerned. In the event that pre-contractual information is provided less than one day before the consumer is bound by any credit agreement or offer, the creditor and, where applicable, the credit intermediary should remind the consumer, between one and seven days after the conclusion of the contract or, where applicable, the submission of the binding credit offer by the consumer, of the possibility to withdraw from the credit agreement.

(39) The total cost of the credit to the consumer should comprise all the costs, including interest, commissions, taxes, fees for credit intermediaries and any other fees which the consumer has to pay in connection with the credit agreement, except for notarial costs. Creditors' actual knowledge of the costs should be assessed objectively, taking into account the requirements of professionalism laid down in this Directive.

(40) Credit agreements in which a borrowing rate is periodically revised in line with changes occurring in a reference rate referred to in the credit agreement should not be regarded as credit agreements with a fixed borrowing rate.

(41) Member States should remain free to maintain or introduce national provisions prohibiting the creditor from requiring the consumer, in connection with the credit agreement, to open a bank account or conclude an agreement in respect of another ancillary service, or to pay the expenses or fees for such bank accounts or other ancillary services. In those Member States where such combined offers are allowed, consumers should be informed before the conclusion of the credit agreement about any ancillary services which are compulsory in order for the credit to be obtained in the first place or on the terms and conditions marketed. The costs payable in respect of those ancillary services, in particular insurance premiums, should be included in the total cost of the credit. Alternatively, if the amount of such costs cannot be determined in advance, consumers should receive adequate information about the existence of costs at the pre-contractual stage. Creditors should be presumed to have knowledge of the costs of the ancillary services which they offer to the consumers themselves or on behalf of a third party, unless the price thereof depends on the specific characteristics or the situation of the consumers.

(42) For specific types of credit agreements, however, it is appropriate, in order to ensure an adequate level of consumer protection without placing an excessive burden on creditors or, where applicable, credit intermediaries, to restrict the pre-contractual information requirements, taking into account the specific character of such types of credit agreements.

(43) Consumers should be given comprehensive information before they conclude a credit agreement, regardless of whether or not a credit intermediary is involved in the marketing of the credit. Therefore, in general, the pre-contractual information requirements should also apply to credit intermediaries. However, where suppliers of goods or providers of services act as credit intermediaries in an ancillary capacity, it is not appropriate to impose on them the legal obligation to provide the pre-contractual information in accordance with this Directive. Suppliers of goods or providers of services may be deemed, for example, to be acting as credit intermediaries in an ancillary capacity if their activity as credit intermediaries is not the main purpose of their trade, business or profession. In those cases, a sufficient level of consumer protection is still achieved since the creditor should be responsible for ensuring that the consumer receives the full pre-contractual information, either from the credit intermediary, where the creditor and the credit intermediary so agree, or in some other appropriate manner.

(44) Member States should have the possibility to regulate the potentially binding character of the information to be provided to the consumer prior to the conclusion of the credit agreement and the period of time during which the creditor is to be bound by it.

(45) Despite the pre-contractual information to be provided, the consumer may still need additional assistance in order to decide which credit agreement, within the range of products proposed, is the most appropriate for his or her needs and financial situation. Therefore, Member States should ensure that before the conclusion of a credit agreement creditors and, where applicable, credit intermediaries provide such assistance in relation to the credit products which they offer to the consumer, by providing adequate explanations about the relevant information free of charge, including in particular the essential characteristics of the products proposed to the consumer in a personalised manner so that the consumer can understand the effects which they may have on his or her economic situation including legal and financial consequences that may result from improper performance of contractual obligations. Creditors and, where applicable, credit intermediaries should adapt the way in which such explanations are given to the circumstances in which the credit is offered and the consumer's need for assistance, taking into account the consumer's knowledge and experience of credit and the nature of individual credit products. Such explanations should not in themselves constitute a personal recommendation. Member States should be able to require creditors and, where applicable, credit intermediaries, to document in what form and when such explanations were provided to the consumer.

(46) As highlighted in the Commission proposal for a Regulation laying down harmonised rules on artificial intelligence (Artificial Intelligence Act) published on 21 April 2021, artificial intelligence (AI) systems can be easily deployed in multiple sectors of the economy and society, including cross border, and can circulate throughout the Union. In this context, creditors and credit intermediaries, when personalising the price of their offers for specific consumers or specific categories of consumer on the basis of automated decision-making, should clearly inform consumers that the price presented to them is personalised on the basis of automated processing of personal data including inferred data, so that they can take into account the potential risks in their purchasing decision. Pursuant to Article 14(2), point (f) of Regulation (EU) 2016/679, creditors and credit intermediaries are also required to inform consumers who receive the offer about the sources of data used for the personalisation of the offer.

(47) It is important to prevent practices, such as tying of certain products, which may induce consumers to enter into credit agreements which are not in their best interest, without however restricting product bundling which can be beneficial to consumers. Member States should, however, continue monitoring retail financial services markets closely to ensure that bundling practices do not distort consumer choice or competition. As a general rule, tying practices should not be allowed unless the financial service or product offered together with the credit agreement could not be offered separately as it is a fully integrated part of the credit, for example in the case of an overdraft facility. While, taking into account proportionality considerations, a creditor should be able to require the consumer to have a relevant insurance policy in order to guarantee repayment of the credit or to insure the value of the security, the consumer should have the opportunity to choose his or her own insurance provider. This should not prejudice the credit conditions set by the creditor, provided that the insurance policy of that provider has an equivalent level of guarantee as the insurance policy proposed or offered by the creditor. Moreover, Member States should have the possibility to standardise, wholly or in part, the cover provided by insurance contracts in order to facilitate comparisons between different offers for consumers who wish to make such comparisons. In order for the consumer to have additional time to compare insurance offers before purchasing an insurance policy, Member States should require that the consumer is given at least three days to compare insurance offers related to the credit agreement, without the offer being changed, and the consumer is informed thereof. Consumers should be able to conclude an insurance policy prior to the expiry of that three-day period if they explicitly so request.

(48) Because of their medical history, many cancer survivors in long-term remission often experience an unfair treatment in accessing financial services. They often face prohibitively high premiums, although they have been cured for many years, even decades. For the purpose of giving consumers who survived cancer equal access to insurance related to credit agreements, Member States should require that the insurance policies are not based on personal data concerning consumers' diagnosis of oncological diseases after a relevant period of time following the end of the medical treatment of those consumers. Such period of time determined by the Member States should not exceed 15 years starting from the end of the medical treatment of the consumer.

(49) Credit agreements and ancillary services should be presented in a clear and transparent manner. It should not be possible to infer the consumer's agreement to conclude a credit agreement or to purchase ancillary services. Any such agreement by the consumer should be a clear affirmative act establishing a freely given, specific, informed and unambiguous indication of the consumer's approval. In this context, silence, inactivity or default option such as pre-ticked boxes should not be considered to constitute agreement by the consumer.

(50) Providing advice in the form of a personalised recommendation, that is to say advisory services, is an activity which may be combined with other aspects of granting or intermediating credit. Therefore, in order to be in a position to understand the nature of the services provided to them, consumers should be made aware of what constitutes such advisory services and of whether or not advisory services are being, or can be, provided. Given the importance which consumers attach to the use of the terms 'advice' and 'advisors', Member States should be allowed to prohibit the use of those terms, or of similar terms, where such advisory services are being provided to consumers by creditors or credit intermediaries. It is appropriate to ensure that Member States impose safeguards where advice is described as independent to ensure that the range of products considered and remuneration arrangements are commensurate with consumers' expectations of such advice. When providing advisory services, the creditors or the credit intermediaries should provide an indication of whether the recommendation will be based on only their own product range or on a wide range of products from across the market, so that the consumer can understand the basis on which the recommendation is made. Moreover, the creditor and the credit intermediary should provide an indication of the fee payable by the consumer for the advisory services or, where the amount cannot be established at the time of disclosure, the method used for its calculation. Advice should always be provided in the best interest of the consumer, by advisors informing themselves about the consumer's needs and circumstances and recommending credit agreements suitable to the consumer's needs, financial situation and personal circumstances, bearing in mind also the objective to minimise defaults and arrears. Moreover, a sufficiently large number of credit agreements in the advisor's product range should be taken into consideration when providing advice.

(51) Granting of credit that has not been solicited by the consumer may in some cases be associated with practices that are harmful to the consumer. In that regard, unsolicited granting of credit, including non-requested pre-approved credit cards sent to consumers, the unilateral introduction of a new overdraft facility or overrunning or the unilateral increase in the limit of a consumer's overdraft, overrunning or credit card, should be prohibited. The unsolicited granting of credit in the form of off-premises contracts as defined in Article 2, point 8 of Directive 2011/83/EU of the European Parliament and of the Council ([11]) should also be prohibited. The prohibition on unsolicited granting of credit should not prevent creditors and credit intermediaries from advertising or offering credit in the course of a commercial relationship in compliance with Union law on consumer protection and with national measures in compliance with Union law, including advertising and offering credit at the point of sale to finance the purchase of a good or a service.

(52) It is possible for Member States to offer consumers the possibility to pursue proportionate and effective remedies against creditors or credit intermediaries in the event of non-compliance with this Directive in accordance with national law. Those remedies could entail compensation for damages and a reduction in the total cost of the credit to the consumer or the termination of the credit agreement.

(53) Member States should take appropriate measures to promote responsible practices during all phases of the credit relationship, taking into account the specific features of their credit market. It should be possible for those measures to include, for instance, the provision of information to, and the education of, consumers, including warnings about the risks related to default on payment and to over-indebtedness. In an expanding credit market, in particular, it is important that creditors do not engage in irresponsible lending or give out credit without prior assessment of creditworthiness. Member States should carry out the necessary supervision to avoid such behaviour of creditors and should determine the necessary means to sanction such behaviour. Without prejudice to the provisions on credit risk of Directive 2013/36/EU of the European Parliament and of the Council ([12]), creditors should bear the responsibility of checking individually the creditworthiness of the consumer. To that end, creditors should be allowed to use information provided by the consumer not only during the preparation of the credit agreement in question, but also during a long-standing commercial relationship. Consumers should also act with prudence and respect their contractual obligations.

([11]) Directive 2011/83/EU of the European Parliament and of the Council of 25 October 2011 on consumer rights, amending Council Directive 93/13/EEC and Directive 1999/44/EC of the European Parliament and of the Council and repealing Council Directive 85/577/EEC and Directive 97/7/EC of the European Parliament and of the Council (OJ L 304, 22.11.2011, p. 64).

([12]) Directive 2013/36/EU of the European Parliament and of the Council of 26 June 2013 on access to the activity of credit institutions and the prudential supervision of credit institutions, amending Directive 2002/87/EC and repealing Directives 2006/48/EC and 2006/49/EC (OJ L 176, 27.6.2013, p. 338).

(54) It is essential that the consumer's ability and propensity to repay the credit is assessed and verified before a credit agreement is concluded. That assessment of creditworthiness should be proportionate and done in the interest of the consumer, to prevent irresponsible lending practices and over-indebtedness, and should take into consideration all necessary and relevant factors that could influence a consumer's ability to repay the credit. The repayment schedule should be tailored to the consumer's specific needs and repayment capacity. In cases where the credit application is submitted jointly by more than one consumer, the creditworthiness assessment could be performed on the basis of the joint repayment capacity. A positive assessment should be without prejudice to the freedom of contract of the creditor in relation to the granting of credit. Member States should be able to issue additional guidance on additional criteria and methods to assess a consumer's creditworthiness, for example by setting limits on loan-to-value or loan-to-income ratios.

(55) The assessment of creditworthiness should be based on information on the financial and economic situation. Such information should be necessary and proportionate to the nature, duration, value and risks of the credit for the consumer, in line with the data minimisation principle set out in Regulation (EU) 2016/679, and should be relevant, complete and accurate. That information should include at least the income and expenses of the consumer, including giving appropriate consideration to the consumer's current obligations, inter alia the living expenses of the consumer and the consumer's household, as well as the consumer's financial liabilities. That information should not include special categories of personal data referred to in Article 9(1) of Regulation (EU) 2016/679, such as health data including cancer data, nor information obtained from social networks. The European Banking Authority Guidelines of 29 May 2020 on loan origination and monitoring provide guidelines on what categories of data may be used for the processing of personal data for creditworthiness purposes, which include evidence of income or other sources of repayment, and information on financial assets and liabilities or on other financial commitments. Consumers should provide information about their financial and economic situation in order to facilitate the creditworthiness assessment. Credit should only be made available to the consumer where the result of the creditworthiness assessment indicates that the obligations resulting from the credit agreement are likely to be met in the manner required under that agreement. When assessing the consumer's ability to meet his or her obligations under the credit agreement, the creditor should take into account relevant factors and specific circumstances, for example, but not limited to, in the case of credit granted in accordance with this Directive to finance studies or to cover exceptional health care expenses, the existence of sufficient evidence that such credit will bring the consumer future incomes, or the existence of collateral or other forms of guarantees that the consumer could provide in order to secure the credit.

(56) The Commission proposal for a Regulation laying down harmonised rules on artificial intelligence (Artificial Intelligence Act) establishes that AI systems used to evaluate the credit score or creditworthiness of natural persons should be classified as high-risk AI systems, since they determine those persons' access to financial resources or essential services such as housing, electricity, and telecommunication services. In view of those high stakes, whenever the creditworthiness assessment involves automated processing, the consumer should have the right to obtain human intervention on the part of the creditor. Without prejudice to Regulation (EU) 2016/679, the consumer should have the right to obtain a meaningful, comprehensible explanation of the assessment made and of the functioning of the automated processing used, including the main variables, the logic and risks involved, as well as the right to express the consumer's point of view and to request a review of the assessment of the creditworthiness and a review of the decision on whether to grant credit. The consumer should have the right to be informed about those rights after having duly received information on the procedure to follow. The possibility to request a review of the initial assessment and of the decision should not necessarily lead to the granting of credit to the consumer.

(57) To assess the credit status of a consumer, the creditor should also consult credit databases. The legal and factual circumstances may require that such consultations vary in scope. To prevent any distortion of competition among creditors, those who are supervised and fully comply with Regulation (EU) 2016/679 should have access to private or public credit databases concerning consumers in a Member State where they are not established under non-discriminatory conditions compared with creditors established in that Member State. Member States should facilitate the cross-border access to private or public databases, in compliance with Regulation (EU) 2016/679. To enhance reciprocity, credit databases should as a minimum hold information on consumers' arrears in repayment of the credit, on the type of credit and on the identity of the creditor, in accordance with Union and national law. Creditors and credit intermediaries should not process special categories of data, such as health data, referred to in Article 9(1) of Regulation (EU) 2016/679, nor information obtained from social networks, since neither those categories of data nor such information should be used for the purpose of assessing consumer creditworthiness. Credit databases providers should have processes in place to ensure that information contained in their databases is

up-to-date and accurate. Where the credit application is rejected on the basis of a consultation of a database, creditors should inform consumers without undue delay and free of charge of the result of such consultation and of the details of the database consulted as well as the categories of data taken into account. Moreover, to ensure consumer awareness, Member States should ensure that consumers are informed about the registration of any credit repayment arrears in a database in a timely manner and within 30 days of the registration, for instance by sending them a warning via email asking them to access the database to view their own information regarding arrears in repayment of credit.

(58) This Directive should not regulate contract law issues related to the validity of credit agreements. Therefore, in that area, the Member States should be able to maintain or introduce national provisions which are in conformity with Union law. Member States should be able to regulate the legal regime governing the offer to conclude the credit agreement, in particular when the offer is to be given and the period during which such offer is to be binding on the creditor. If such an offer is made at the same time as the provision of the pre-contractual information provided for in this Directive, such offer should, like any additional information the creditor may wish to give to the consumer, be provided in a separate document. That separate document could be annexed to the Standard European Consumer Credit Information form.

(59) The credit agreement should contain all necessary information in a clear and concise manner to enable the consumer to know his or her rights and obligations under that agreement.

(60) Without prejudice to Directive 93/13/EEC, and to pre-contractual obligations under this Directive, and in order to ensure a high level of consumer protection, the consumer should be presented, in due time and prior to any modifications to the terms and conditions of the credit agreement, with a description of the proposed changes and, where applicable, of the need for the consumer's consent or an explanation of the changes introduced by operation of law; with the timescale for implementing those changes; and with the means for complaint available to the consumer as well as the time period for the consumer to lodge a complaint and the name and address of the competent authority where the complaint may be submitted. The modification of a credit agreement should not affect any consumer right, including information rights under this Directive. This should be without prejudice to Union law or national provisions regarding the admissibility, the conditions and the validity of contract modifications.

(61) In order to ensure full transparency, the consumer should be provided with information concerning the borrowing rate, both at the pre-contractual stage and when the credit agreement is concluded. During the contractual relationship, the consumer should, furthermore, be informed of changes to the variable borrowing rate and changes to the payments caused by those changes. This should be without prejudice to provisions of national law not related to consumer information which lay down conditions for, or prescribe the consequences of, changes, other than changes concerning payments, in borrowing rates and other economic conditions governing the credit, for instance rules providing that the creditor may change the borrowing rate only where there is a valid reason for such change or that the consumer may terminate the credit agreement should there be a change in the borrowing rate or in other specific economic conditions concerning the credit.

(62) Overdraft facilities and overrunning are increasingly common forms of consumer credit. Therefore, there is a need to regulate those financial products in order to increase the level of consumer protection and avoid over-indebtedness. There is a danger that consumers will not be able to pay if the creditors decide to request immediate refunds. Therefore, consumer rights in respect of overdraft facilities and overrunning should be laid down in this Directive.

(63) In the event of a significant overrun exceeding a period of one month, the creditor should present the consumer without delay with information on the overrun, including the amount involved, the borrowing rate and any applicable penalties, charges or interest on arrears. In the case of regular overrunning, the creditor should offer the consumer advisory services, where available, to help the consumer identify less expensive alternatives, and redirect the consumer towards debt advisory services.

(64) Consumers should have a right of withdrawal without penalty and with no obligation to provide justification. However, in order to increase legal certainty, the withdrawal period should in any event expire 12 months and 14 days after the conclusion of the credit agreement if the consumer has not received the contractual terms and conditions and information in accordance with this Directive. The withdrawal period should not expire if the consumer has not been informed about his or her right of withdrawal.

(65) Where a consumer withdraws from a credit agreement in connection with which the consumer has received goods, in particular from a purchase in instalments or from a hiring or leasing agreement providing for an obligation to purchase, this Directive should be without prejudice to any regulation by Member States of questions concerning the return of the goods or any related questions.

(66) In some cases, national law already provides that funds cannot be made available to the consumers before the expiry of a specific deadline. In those cases, consumers may wish to ensure that they receive the goods or services purchased early. Therefore, in the case of linked credit agreements, Member States should have the possibility to exceptionally provide that, if consumers explicitly wish early receipt of the purchased goods or services, the deadline for the exercise of the right of withdrawal could be reduced so that it is the same as the deadline before which funds cannot be made available.

(67) In the case of linked credit agreements, a relationship of interdependence exists between the purchase of goods or services and the credit agreement concluded for that purpose. Therefore, where the consumer exercises the right of withdrawal in respect of the purchase agreement, based on Union law, the consumer should no longer be bound by the linked credit agreement. This should not affect national law applicable to linked credit agreements in cases where a purchase agreement has been voided or where the consumer has exercised his or her right of withdrawal based on national law. Nor should this affect the rights of consumers granted by national law according to which no commitment may be entered into between a consumer and a supplier of goods or a provider of services, nor any payment made between those persons, as long as the consumer has not signed the credit agreement to finance the purchase of goods or services.

(68) The contracting parties should have the right to effect a standard termination of an open-end credit agreement. In addition, where agreed in the credit agreement, the creditor should have the right to suspend the consumer's right to draw down on an open-end credit agreement for objectively justified reasons. Such reasons may include, for instance, suspicion of an unauthorised or fraudulent use of the credit or a significantly increased risk of the consumer being unable to fulfil his or her obligation to repay the credit. This Directive should not affect national contract law regulating the rights of the contracting parties to terminate the credit agreement on the basis of a breach of contract.

(69) Under certain conditions, the consumer should be allowed to pursue remedies against the creditor in the event of problems related to the purchase agreement. However, Member States should determine to what extent and under what conditions the consumer is required to pursue those remedies against the supplier of goods or the provider of services, in particular by bringing an action against the supplier of goods or the provider of services, before being in a position to pursue them against the creditor. Consumers should not be deprived of their rights under national law attaching joint and several liability to the supplier of goods or the provider of services and to the creditor.

(70) The consumer should have the right to discharge his or her obligations before the date agreed in the credit agreement. As interpreted by the Court of Justice of the European Union in the Lexitor ruling ([13]), the right of the consumer to a reduction in the total cost of the credit to the consumer in the event of early repayment of the credit includes all the costs imposed on the consumer. The reduction in the total cost of the credit to the consumer should be proportionate to the remaining duration of the credit agreement and should also include costs which are not dependent on the duration of that credit agreement, including those which are fully exhausted at the time of granting the credit. However, taxes and fees applied by and directly paid to a third party and which are not dependent on the duration of the credit agreement should not be taken into consideration when calculating the reduction, as those costs are not imposed by the creditor and cannot therefore be unilaterally changed by the

([13]) Judgment of the Court of Justice of 11 September 2019, Lexitor, C-383/18, ECLI:EU:C:2019:702.

creditor. However, fees charged by a creditor to the benefit of a third party should be taken into consideration when calculating the reduction. In the case of early repayment, the creditor should be entitled to a fair and objectively justified compensation for the costs directly linked to the early repayment, taking into account also any savings thereby made by the creditor. However, in order to determine the method of calculating the compensation, it is important to comply with several principles. The calculation of the compensation due to the creditor should be transparent and comprehensible to consumers already at the pre-contractual stage and in any case during the performance of the credit agreement. In addition, the calculation method should be easy for creditors to apply, and supervisory control of the compensation by the competent authorities should be facilitated. Therefore, and due to the fact that consumer credit is, given its duration and volume, not financed by long-term funding mechanisms, the ceiling for the compensation should be fixed in terms of a flat-rate amount. This approach reflects the specific nature of consumer credits and should not prejudice the approach in respect of other products which are financed by long-term funding mechanisms, such as fixed-rate mortgage loans.

(71) Member States should have the right to provide that compensation for early repayment may be claimed by the creditor only on condition that the amount repaid over a 12-month period exceeds a threshold defined by Member States. When fixing that threshold, which should not exceed EUR 10 000, Member States should take into account the average amount of consumer credits in their market.

(72) In order to promote the establishment and functioning of the internal market and to ensure a high degree of protection for consumers throughout the Union, it is necessary to ensure the comparability of information relating to annual percentage rates of charge throughout the Union.

(73) The fixing of caps on borrowing rates, on annual percentage rates of charge or on the total cost of the credit to the consumer is a common practice in a number of Member States. Such capping system has proved beneficial in protecting consumers from excessively high borrowing rates, annual percentage rates of charge or total cost of credit to the consumer. In that respect, Member States should be able to maintain their current legal regime. In an effort to increase consumer protection without imposing unnecessary limits on Member States, adequate measures, such as caps or usury rates, should exist to effectively prevent abuse and to ensure that consumers are not charged with excessively high borrowing rates, annual percentage rates of charge or total cost of credit to the consumer.

(74) To ensure transparency, the Commission should make such measures introduced by Member States publicly available, in a concise and clear form.

(75) There are substantial differences in the laws of the various Member States with regard to the conduct of business in the granting of credit agreements. While recognising the diversity in the types of actor involved in credit intermediation, certain standards at Union level are essential in order to ensure a high level of professionalism and service.

(76) The applicable Union framework should give consumers the confidence that creditors and credit intermediaries take account of the interests of the consumer, including their possible vulnerability and difficulties in understanding the product, based on the information available to the creditor or the credit intermediary at the relevant time and on reasonable assumptions about risks to the consumer's situation over the term of the proposed credit agreement. A key aspect of ensuring such consumer confidence is the requirement to ensure a high degree of fairness, honesty and professionalism in the industry, which also includes responsible behaviour to avoid practices that have a negative impact on consumers, and appropriate management of conflicts of interest including those arising from remuneration, as well as to give advice in the best interests of the consumer.

(77) It is appropriate to ensure that the relevant staff of creditors and credit intermediaries possess an adequate level of knowledge and competence in order to achieve a high level of professionalism. It should, therefore, be required that creditors and credit intermediaries prove relevant knowledge and competence at the level of the company, based on the minimum knowledge and competence requirements. Member States should be free to introduce or maintain such requirements applicable to individual natural persons, and to adapt the minimum knowledge and competence

requirements to the different types of creditors and credit intermediaries, in particular when they act in an ancillary capacity. For the purpose of this Directive, staff directly engaged in activities under this Directive should include both front- and back-office staff, including management and, where appropriate, members of the board of creditors and credit intermediaries, who fulfil an important role in the credit agreement process. Persons fulfilling support functions which are unrelated to the credit agreement process, including human resources and information and communications technology personnel, should not be considered as staff under this Directive. Member States should put in place measures to support raising awareness of the requirements of this Directive in small and medium-sized enterprises that are creditors or credit intermediaries and facilitating their compliance, such as information campaigns, user guides and employee training schemes.

(78) In order to increase the ability of consumers to make informed decisions about borrowing and managing debt responsibly, Member States should promote measures to support the education of consumers in relation to responsible borrowing and debt management, in particular relating to credit agreements for consumers, as well as to general budget management. Such an obligation could be fulfilled taking into account the financial competence framework developed by the Union together with the Organisation for Economic Co-operation and Development. It is particularly important to provide guidance for consumers taking out, particularly by means of digital tools, consumer credit for the first time. In that regard, the Commission should identify examples of best practices to facilitate the further development of measures to enhance consumers' financial awareness. The Commission could publish such examples of best practices in coordination with similar reports drawn up in relation to other Union legislative acts. In creating and promoting those measures, Member States should consult relevant stakeholders, including consumer organisations. Such an obligation should not prevent Member States from providing for additional financial education.

(79) Given the significant consequences of the enforcement proceedings for creditors and consumers and potentially for financial stability, it is necessary for creditors to deal proactively with emerging credit risk at an early stage and to put in place necessary measures to ensure that they exercise, where appropriate, reasonable forbearance before enforcement proceedings are initiated. When deciding whether it is appropriate to exercise forbearance measures, or whether it is justified to offer them reiteratively, the creditor should take into account, among other elements, the individual circumstances of the consumer, such as the consumer's interests and rights, his or her ability to repay the credit and his or her reasonable needs for living expenses, and the creditor should limit the costs for the consumer in the event of default. In particular, when the consumer does not respond to the creditor's offer within a reasonable period of time, the creditor should not be required to offer forbearance measures reiteratively. Member States should not prevent the parties to a credit agreement from expressly agreeing that the transfer to the creditor of goods covered by a linked credit agreement or of proceeds from the sale of such goods is sufficient to repay the credit.

(80) When forbearance measures are deemed appropriate, they should include a modification of the terms and conditions of the initial credit agreement and could among others include a total or partial refinancing of a credit agreement. The modification of those terms and conditions could include, among others: extending the term of the credit agreement; changing the type of the credit agreement; deferring payment of all or part of the instalment repayment for a period; reducing the borrowing rate; offering a payment holiday; partial repayments; currency conversion; and partial forgiveness and debt consolidation. When forbearance measures are deemed appropriate, creditors should not be required to perform a creditworthiness assessment when modifying the terms and conditions of the credit agreement, unless the total amount payable by the consumer is significantly increased when modifying those terms and conditions. While the obligation to exercise forbearance measures should be without prejudice to procedures under national rules on enforcement proceedings, Member States should ensure that the forbearance measures provided for in this Directive are properly applied.

(81) Consumers facing difficulties in meeting their financial commitments stand to benefit from specialised help on managing their debts. Financial difficulties cover a wide variety of situations, for example among many others, having delayed the repayment of debt for more than 90 days. The objective of debt advisory services is to help consumers facing financial difficulties and guide them to repay, as far as possible, their outstanding debts, while maintaining a decent level of life and preserving their dignity. That personalised and independent assistance may include legal counselling, money and debt management as well as social and psychological assistance. The assistance should be provided by professional operators which are not creditors, credit intermediaries, providers of

crowdfunding credit services, credit purchasers or credit servicers, and are independent from them. Member States should ensure that debt advisory services provided by independent professional operators are made available, directly or indirectly and with only limited charges, to consumers. Those charges should in principle only cover operating expenses and not place an unnecessary burden on the consumers who experience or might experience difficulties in meeting their financial commitments. Where possible, consumers facing difficulties in repaying their debts are referred to debt advisory services before the enforcement proceedings are initiated. Debt advisory services should be easily accessible for consumers, taking into account for example consumers' place of residence and also their language. Member States remain free to maintain or introduce specific requirements for debt advisory services. Creditors have a role to play in preventing over-indebtedness through the early detection and support of consumers experiencing financial difficulties. For that reason, creditors should have processes and policies in place for the detection of such consumers to ensure they can effectively refer them to easily accessible debt advisory services.

(82) In order to ensure market transparency and stability, and pending further harmonisation, Member States should ensure that appropriate measures for the regulation or supervision of creditors are in place.

(83) Member States should ensure that creditors and credit intermediaries, including non-credit institutions, are subject to an adequate admission process including an authorisation process or entering the non-credit institution in a register, and supervision arrangements by a competent authority. The requirement of an adequate admission process and of registration should not apply to credit institutions as defined in Article 4(1), point (1), of Regulation (EU) No 575/2013 of the European Parliament and of the Council ([14]), which are already subject to an authorisation process under Directive 2013/36/EU, nor to payment institutions as defined in Article 4, point (4), of Directive (EU) 2015/2366 of the European Parliament and of the Council ([15]), for the services referred to in Annex I, point (4), of Directive (EU) 2015/2366, nor to electronic money institutions as defined in Article 2, point (1), of Directive 2009/110/EC of the European Parliament and of the Council ([16]), for the granting of credit referred to in Article 6(1), first subparagraph, point (b), of Directive 2009/110/EC. This should be without prejudice to national admission processes and registration or supervision arrangements imposed on payment institutions and electronic money institutions for the purpose of granting credit to consumers and imposed on credit institutions for the purpose of credit intermediary activities in compliance with Union law.

(84) Member States should be able to exempt from the requirements of admission and registration suppliers of goods or providers of services who qualify as micro, small and medium-sized enterprises as defined in Commission Recommendation 2003/361/EC ([17])and who act as credit intermediaries in an ancillary capacity or who grant credit in the form of deferred payment for the purchase of goods and services offered by them, without any third party offering credit, if the credit is provided free of interest and charges, except for limited charges for late payments in accordance with national law. That possible exemption should not be used by large undertakings to avoid admission and registration requirements laid down in this Directive.

(85) This Directive regulates only certain obligations of credit intermediaries in relation to consumers. Member States should therefore remain free to maintain or introduce additional obligations incumbent on credit intermediaries, including the conditions under which a credit intermediary may receive fees from a consumer who has requested that credit intermediary's service.

([14]) Regulation (EU) No 575/2013 of the European Parliament and of the Council of 26 June 2013 on prudential requirements for credit institutions and investment firms and amending Regulation (EU) No 648/2012 (OJ L 176, 27.6.2013, p. 1).

([15]) Directive (EU) 2015/2366 of the European Parliament and of the Council of 25 November 2015 on payment services in the internal market, amending Directives 2002/65/EC, 2009/110/EC and 2013/36/EU and Regulation (EU) No 1093/2010, and repealing Directive 2007/64/EC (OJ L 337, 23.12.2015, p. 35).

([16]) Directive 2009/110/EC of the European Parliament and of the Council of 16 September 2009 on the taking up, pursuit and prudential supervision of the business of electronic money institutions amending Directives 2005/60/EC and 2006/48/EC and repealing Directive 2000/46/EC (OJ L 267, 10.10.2009, p. 7).

([17]) Commission Recommendation 2003/361/EC of 6 May 2003 concerning the definition of micro, small and medium-sized enterprises (OJ L 124, 20.5.2003, p. 36).

(86) Assignment of the creditor's rights under a credit agreement should not have the effect of placing the consumer in a less favourable position. The consumer should also be properly informed when the credit agreement is assigned to a third party. However, where the initial creditor, in agreement with the assignee, continues to service the credit vis-à-vis the consumer, the consumer has no significant interest in being informed of the assignment. Therefore, a requirement at Union level that the consumer be informed of the assignment in such cases would be excessive.

(87) Member States should remain free to maintain or introduce national rules providing for collective forms of communication where this is necessary for purposes relating to the effectiveness of complex transactions such as securitisations or liquidation of assets that take place in the compulsory administrative liquidation of banks.

(88) Consumers should have access to adequate, prompt and effective alternative dispute resolution procedures for the settlement of disputes arising out of rights and obligations relating to credit agreements, using existing entities where appropriate. Such access is already ensured by Directive 2013/11/EU of the European Parliament and of the Council ([18]) in so far as relevant contractual disputes are concerned. However, consumers should also have access to alternative dispute resolution procedures in the event of pre-contractual disputes concerning rights and obligations established by this Directive, for example in relation to pre-contractual information requirements, advisory services and creditworthiness assessment and also in relation to the information given by credit intermediaries which are remunerated by creditors and therefore have no direct contractual relationship with consumers. Such alternative dispute resolution procedures and the entities offering them should comply with the quality requirements established by Directive 2013/11/EU.

(89) Member States should designate competent authorities empowered to ensure the enforcement of this Directive and should ensure that those competent authorities are granted investigation and enforcement powers and have adequate resources necessary for the performance of their duties. Member States should also be able to grant product intervention powers to national authorities where credit products are detrimental to consumers and need to be withdrawn. Member States should consider data on monthly default rates associated with different types of consumer credit products relevant to the scope of this Directive. Competent authorities of different Member States should cooperate with each other whenever necessary for the purpose of carrying out their duties under this Directive.

(90) Member States should lay down rules on penalties applicable to infringements of national provisions adopted pursuant to this Directive and should take all measures necessary to ensure that they are implemented. While the choice of penalties remains within the discretion of the Member States, the penalties provided for should be effective, proportionate and dissuasive. Member States should notify the Commission of those rules and of those measures and should notify it, without delay, of any subsequent amendment affecting them.

(91) Current national rules on penalties differ significantly across the Union. In particular, not all Member States ensure that effective, proportionate and dissuasive fines can be imposed on traders responsible for widespread infringements, or widespread infringements with a Union dimension. In certain cases, those traders can also be a group of companies. To ensure that Member States' authorities can impose effective, proportionate and dissuasive penalties in relation to widespread infringements, and to widespread infringements with a Union dimension, that are subject to coordinated investigation and enforcement measures in accordance with Regulation (EU) 2017/2394 of the European Parliament and of the Council ([19]), fines should be introduced as an element of the penalties for such infringements.

([18]) Directive 2013/11/EU of the European Parliament and of the Council of 21 May 2013 on alternative dispute resolution for consumer disputes and amending Regulation (EC) No 2006/2004 and Directive 2009/22/EC (Directive on consumer ADR) (OJ L 165, 18.6.2013, p. 63).

([19]) Regulation (EU) 2017/2394 of the European Parliament and of the Council of 12 December 2017 on cooperation between national authorities responsible for the enforcement of consumer protection laws and repealing Regulation (EC) No 2006/2004 (OJ L 345, 27.12.2017, p. 1).

(92) To enhance transparency and consumer confidence, competent authorities should be allowed to disclose to the public any administrative penalty that is imposed for infringement of measures adopted pursuant to this Directive, unless such disclosure would seriously jeopardise the financial markets or cause disproportionate damage to the parties involved.

(93) The efficient functioning of this Directive needs to be reviewed, together with the progress on the establishment of an internal market with a high level of consumer protection for credit agreements. Every four years, the Commission should undertake an evaluation of this Directive to assess the upper threshold of EUR 100 000 laid down in this Directive and the percentages used to calculate the compensation payable in the event of early repayment, as well as an assessment of whether the scope of this Directive remains appropriate in relation to credit agreements which are secured by non-residential immovable property. That evaluation should also include an analysis of the evolution of the market for consumer credits that support the green transition and an assessment of the need for further measures to improve the uptake of such credits, as well as an assessment of the implementation of penalties imposed in accordance with this Directive and in particular of their effectiveness and deterrent effect. When evaluating this Directive, the Commission should analyse the economic trends in the Union and the situation in the market concerned, such as the emergence of new forms of financial services, digital trends, and volumes and trends of the cross-border provision of credits. It should also look at the efficiency of this Directive, including the costs and benefits it entails for businesses and consumers. Moreover, crowdfunding is increasingly a form of finance available to consumers, typically for small expenses or investments. Regulation (EU) 2020/1503 of the European Parliament and of the Council ([20]) excludes from its scope crowdfunding services, including those facilitating the granting of credit, that are provided to consumers. The Commission should assess the need for further measures to protect consumers seeking to take out a credit or to invest through a provider of crowdfunding credit services.

(94) Since the objective of this Directive, namely the establishment of common rules for certain aspects of the laws, regulations and administrative provisions of the Member States concerning consumer credit, cannot be sufficiently achieved by the Member States considering market developments in the light of digitalisation and the goal to facilitate cross-border credit provision but can rather be better achieved at Union level, the Union may adopt measures, in accordance with the principle of subsidiarity as set out in Article 5 of the Treaty on European Union. In accordance with the principle of proportionality, as set out in that Article, this Directive does not go beyond what is necessary in order to achieve that objective.

(95) In order to amend non-essential elements of this Directive, the power to adopt acts in accordance with Article 290 TFEU should be delegated to the Commission in respect of additional assumptions for the calculation of the annual percentage rate of charge. It is of particular importance that the Commission carry out appropriate consultations during its preparatory work, including at expert level, and that those consultations be conducted in accordance with the principles laid down in the Interinstitutional Agreement of 13 April 2016 on Better Law-Making ([21]). In particular, to ensure equal participation in the preparation of delegated acts, the European Parliament and the Council receive all documents at the same time as Member States' experts, and their experts systematically have access to meetings of Commission expert groups dealing with the preparation of delegated acts.

(96) In accordance with the Joint Political Declaration of 28 September 2011 of Member States and the Commission on explanatory documents ([22]), Member States have undertaken to accompany, in justified cases, the notification of their transposition measures with one or more documents explaining the relationship between the components of a directive and the corresponding parts of national transposition instruments. With regard to this Directive, the legislator considers the transmission of such documents to be justified.

(97) Taking account of the number of amendments that need to be made to Directive 2008/48/EC due to the evolution of the consumer credit sector and in the interests of the clarity of Union legislation, that Directive should be repealed and replaced by this Directive.

([20]) Regulation (EU) 2020/1503 of the European Parliament and of the Council of 7 October 2020 on European crowdfunding service providers for business, and amending Regulation (EU) 2017/1129 and Directive (EU) 2019/1937 (OJ L 347, 20.10.2020, p. 1).
([21]) OJ L 123, 12.5.2016, p. 1.
([22]) OJ C 369, 17.12.2011, p. 14.

(98) The European Data Protection Supervisor was consulted in accordance with Article 42(1) of Regulation (EU) 2018/1725 of the European Parliament and of the Council ([23]) and delivered an opinion on 26 August 2021 ([24]),

HAVE ADOPTED THIS DIRECTIVE:

CHAPTER I

GENERAL PROVISIONS

Article 1

Subject matter

This Directive lays down a common framework for harmonisation of certain aspects of the laws, regulations and administrative provisions of the Member States concerning credit agreements for consumers.

Article 2

Scope

1. This Directive applies to credit agreements.

2. This Directive does not apply to the following:

(a) credit agreements which are secured either by a mortgage, or by another comparable security commonly used in a Member State on immovable property or secured by a right related to immovable property;

(b) credit agreements the purpose of which is to acquire or retain property rights in land or in an existing or projected building, including premises used for trade, business or a profession;

(c) credit agreements involving a total amount of credit of more than EUR 100 000;

(d) credit agreements where the credit is granted by employers to their employees as a secondary activity either free of interest or offered at annual percentage rates of charge which are lower than those prevailing on the market and which are not offered to the general public;

(e) credit agreements which are concluded with investment firms as defined in Article 4(1), point (1), of Directive 2014/65/EU of the European Parliament and of the Council ([25]) or with credit institutions as defined in Article 4(1), point (1), of Regulation (EU) No 575/2013 for the purposes of allowing an investor to carry out a transaction relating to one or more of the financial instruments listed in Section C of Annex I to Directive 2014/65/EU, where the investment firm or credit institution granting the credit is involved in that transaction;

(f) credit agreements which are the outcome of a settlement reached in court or before another statutory authority;

(g) hiring or leasing agreements where an obligation or an option to purchase the object of the agreement is not laid down either in the agreement itself or in any separate agreement;

([23]) Regulation (EU) 2018/1725 of the European Parliament and of the Council of 23 October 2018 on the protection of natural persons with regard to the processing of personal data by the Union institutions, bodies, offices and agencies and on the free movement of such data, and repealing Regulation (EC) No 45/2001 and Decision No 1247/2002/EC (OJ L 295, 21.11.2018, p. 39).
([24]) OJ C 403, 6.10.2021, p. 5.
([25]) Directive 2014/65/EU of the European Parliament and of the Council of 15 May 2014 on markets in financial instruments and amending Directive 2002/92/EC and Directive 2011/61/EU (OJ L 173, 12.6.2014, p. 349).

(h) deferred payments whereby:

(i) a supplier of goods or a provider of services, without a third party offering credit, gives the consumer time to pay for the goods or services supplied by that supplier or provider;

(ii) the purchase price is to be paid free of interest and without any other charges and with only limited charges payable by the consumer for late payments imposed in accordance with national law; and

(iii) the payment is to be entirely executed within 50 days of the delivery of the good or service.

In the case of deferred payments offered by suppliers of goods or providers of services which are not micro, small or medium-sized enterprises as defined in Recommendation 2003/361/EC where such suppliers or providers offer information society services within the meaning of Article 1(1), point (b), of Directive (EU) 2015/1535 of the European Parliament and of the Council ([26]) consisting of the conclusion of distance contracts with consumers for the sale of goods or supply of services within the meaning of Article 2, point 7 of Directive 2011/83/EU, this exclusion from the scope of this Directive shall apply only where the following conditions are fulfilled:

(i) a third party is neither offering nor purchasing credit;

(ii) the payment is to be entirely executed within 14 days of the delivery of the goods or services; and

(iii) the purchase price is to be paid free of interest and without any other charges and with only limited charges payable by the consumer for late payments imposed in accordance with national law;

(i) credit agreements which relate to the deferred payment, free of charge, of an existing debt;

(j) credit agreements where the consumer is requested to deposit an item as security in the creditor's safe-keeping and the liability of the consumer is strictly limited to that deposited item;

(k) credit agreements which relate to loans granted to a restricted public under a statutory provision with a general interest purpose, and at lower borrowing rates than those prevailing on the market or free of interest or on other terms which are more favourable to the consumer than those prevailing on the market;

(l) credit agreements existing on 20 November 2026; however, Articles 23 and 24, Article 25(1), second sentence, Article 25(2) and Articles 28 and 39 shall apply to all open-end credit agreements existing on 20 November 2026.

3. Notwithstanding paragraph 2, point (c), this Directive applies to credit agreements involving a total amount of credit of more than EUR 100 000 which are not secured either by a mortgage, or by another comparable security commonly used in a Member State on immovable property or by a right related to immovable property, where the purpose of those credit agreements is the renovation of a residential immovable property.

4. In the case of credit agreements in the form of overrunning, only the following Articles shall apply:

(a) Articles 1, 2, 3, 17, 19, 25, 31, 35, 36 and 39 to 50; and

(b) Article 18, unless otherwise determined by Member States.

5. Member States may exempt from the application of this Directive credit agreements in the form of deferred debit cards:

(a) which are provided by a credit or payment institution;

(b) under the terms of which the credit has to be repaid within 40 days; and

(c) which are free of interest and with only limited charges for the provision of the payment service.

([26]) Directive (EU) 2015/1535 of the European Parliament and of the Council of 9 September 2015 laying down a procedure for the provision of information in the field of technical regulations and of rules on Information Society services (OJ L 241, 17.9.2015, p. 1).

6. Member States may determine that only Articles 1, 2, 3, 7, 8, 11, 19 and 20, Article 21(1), first subparagraph, points (a) to (h) and (l), Article 21(3) and Articles 23, 25 and 28 to 50 apply to credit agreements which are concluded by an organisation whose membership is restricted to persons residing or employed in a particular location or to employees and retired employees of a particular employer, or to persons meeting other qualifications laid down under national law as the basis for the existence of a common bond between the members and which fulfils all of the following conditions:

(a) it is established for the mutual benefit of its members;

(b) it does not make profits for any other person than its members;

(c) it fulfils a social purpose required by national law;

(d) it receives and manages the savings of, and provides sources of credit to, its members only;

(e) it provides credit on the basis of an annual percentage rate of charge which is lower than that prevailing on the market or which is subject to a ceiling laid down by national law.

Member States may exempt from the application of this Directive credit agreements concluded by an organisation referred to in the first subparagraph where the total value of all existing credit agreements entered into by that organisation is insignificant in relation to the total value of all existing credit agreements in the Member State in which the organisation is based and the total value of all existing credit agreements entered into by all such organisations in that Member State is less than 1 % of the total value of all existing credit agreements entered into in that Member State.

Member States shall each year review whether the conditions for the application of any such exemption as referred to in the second subparagraph are still fulfilled and shall take action to withdraw the exemption where they consider that they are no longer met.

7. Member States may determine that only Articles 1, 2, 3, 7, 8, 11, 19 and 20, Article 21(1), first subparagraph, points (a) to (h), (l) and (r), Article 21(3) and Articles 23, 25, 28 to 38 and 40 to 50 shall apply to credit agreements between the creditor and the consumer in respect of deferred payment or of repayment methods, where the consumer is already in default or is likely to default on the initial credit agreement and where the following conditions are fulfilled:

(a) the arrangement is likely to avert the possibility of legal proceedings concerning the default of the consumer;

(b) the consumer would not, by entering into the arrangement, be subject to terms less favourable than those laid down in the initial credit agreement.

8. Member States may determine that Article 8(3), points (d), (e) and (f), Article 10(5), Article 11(4) and Article 21(3) do not apply to one or more of the following credit agreements:

(a) credit agreements involving a total amount of credit of less than EUR 200;

(b) credit agreements where credit is granted free of interest and without any other charges;

(c) credit agreements under the terms of which credit has to be repaid within three months and only insignificant charges are payable.

Article 3

Definitions

For the purposes of this Directive, the following definitions apply:

(1) ‘consumer’ means a natural person who acts for purposes which are outside his or her trade, business or profession;

(2) 'creditor' means a natural or legal person who grants or promises to grant credit in the course of that person's trade, business or profession;

(3) 'credit agreement' means an agreement whereby a creditor grants or promises to grant to a consumer credit in the form of a deferred payment, loan or other similar financial accommodation, except for agreements for the provision on a continuing basis of services or for the supply of goods of the same kind, where the consumer pays for such services or goods for the duration of their provision by means of instalments;

(4) 'ancillary service' means a service offered to the consumer in conjunction with the credit agreement;

(5) 'total cost of the credit to the consumer' means all the costs, including interest, commissions, taxes and any other kind of fees which the consumer is required to pay in connection with the credit agreement and which are known to the creditor, except for notarial costs; costs in respect of ancillary services relating to the credit agreement, in particular insurance premiums, are also included in the total cost of the credit to the consumer where, in addition, the conclusion of a contract regarding such ancillary services is compulsory in order to obtain the credit or to obtain it on the terms and conditions marketed;

(6) 'total amount payable by the consumer' means the sum of the total amount of credit and the total cost of the credit to the consumer;

(7) 'annual percentage rate of charge' or 'APR' means the total cost of the credit to the consumer, expressed as an annual percentage of the total amount of credit and calculated as set out in Article 30;

(8) 'borrowing rate' means the interest rate expressed as a fixed or variable percentage applied on an annual basis to the amount of credit drawn down;

(9) 'fixed borrowing rate' means the borrowing rate that the creditor and the consumer agree on in the credit agreement for the entire duration of the credit agreement, or several borrowing rates that the creditor and the consumer agree on in the credit agreement for partial periods for which the borrowing rates are determined exclusively by a fixed specific percentage; if not all borrowing rates are determined in the credit agreement, the borrowing rate shall be deemed to be fixed only for the partial periods for which the borrowing rates are determined exclusively by a fixed specific percentage agreed on the conclusion of the credit agreement;

(10) 'total amount of credit' means the ceiling or the total sums made available under a credit agreement;

(11) 'durable medium' means any instrument which enables the consumer to store information addressed personally to him or her in a way accessible for future reference for a period of time adequate for the purposes of the information and which allows the unchanged reproduction of the information stored;

(12) 'credit intermediary' means a natural or legal person that is not acting as a creditor or notary and not merely introducing, either directly or indirectly, a consumer to a creditor, and who, in the course of that person's trade, business or profession, for remuneration, which may take a pecuniary form or any other agreed form of financial consideration:

(a) presents or offers credit agreements to consumers;

(b) assists consumers by undertaking preparatory work or other pre-contractual administration in respect of credit agreements other than as referred to in point (a); or

(c) concludes credit agreements with consumers on behalf of the creditor;

(13) 'pre-contractual information' means the information which is provided before the consumer is bound by a credit agreement or, where applicable, by the submission of a binding offer and which the consumer needs in order to be able to compare different credit offers and take an informed decision on whether to conclude the credit agreement;

(14) 'profiling' means profiling as defined in Article 4, point (4), of Regulation (EU) 2016/679;

(15) 'tying practice' means the offering or the selling of a credit agreement in a package with other distinct financial products or services where the credit agreement is not made available to the consumer separately;

(16) 'bundling practice' means the offering or the selling of a credit agreement in a package with other distinct financial products or services where the credit agreement is also made available to the consumer separately but not necessarily on the same terms or conditions as when offered bundled with those other products or services;

(17) 'advisory services' means personal recommendations to a consumer in respect of one or more transactions relating to credit agreements and that constitute a separate activity from the granting of a credit and from the credit intermediation activities as set out in point (12);

(18) 'overdraft facility' means an explicit credit agreement whereby a creditor makes available to a consumer funds which exceed the current balance in the consumer's current account;

(19) 'overrunning' means a tacitly accepted overdraft whereby a creditor makes available to a consumer funds which exceed the current balance in the consumer's current account or the agreed overdraft facility;

(20) 'linked credit agreement' means a credit agreement where:

(a) the credit or services in question serve exclusively to finance an agreement for the supply of specific goods or the provision of a specific service; and

(b) those two agreements form, from an objective point of view, a commercial unit; a commercial unit shall be deemed to exist where the supplier of goods or the provider of services himself or herself finances the credit for the consumer or, if it is financed by a third party, where the creditor uses the services of the supplier of goods or the provider of services in connection with the marketing, conclusion or preparation of the credit agreement, or where the specific goods or the provision of a specific service are explicitly specified in the credit agreement;

(21) 'early repayment' means the full or partial discharge of the consumer's obligations under a credit agreement, before the date agreed in the credit agreement;

(22) 'debt advisory services' means personalised assistance of a technical, legal or psychological nature provided by independent professional operators which are not, in particular, creditors or credit intermediaries as defined in this Directive, or credit purchasers or credit servicers as defined in Article 3, points (6) and (8), of Directive (EU) 2021/2167 of the European Parliament and of the Council ([27]), in favour of consumers who experience or might experience difficulties in meeting their financial commitments.

Article 4

Conversion of amounts expressed in euro into national currency

1. For the purposes of this Directive, those Member States which convert the amounts expressed in euro into their national currency shall initially use in that conversion the exchange rate prevailing on 19 November 2023.

2. Member States may round off the amounts resulting from the conversion referred to in paragraph 1, provided that such rounding off does not exceed EUR 10.

Article 5

Obligation to provide information free of charge to consumers

Member States shall require that, when information is provided to consumers in accordance with this Directive, such information is provided without charge to the consumer regardless of the media used to provide it.

([27]) Directive (EU) 2021/2167 of the European Parliament and of the Council of 24 November 2021 on credit servicers and credit purchasers and amending Directives 2008/48/EC and 2014/17/EU (OJ L 438, 8.12.2021, p. 1).

Article 6

Non-discrimination

Member States shall ensure that the conditions to be fulfilled for being granted a credit do not discriminate against consumers legally resident in the Union on ground of their nationality or place of residence or on any ground as referred to in Article 21 of the Charter of Fundamental Rights of the European Union, when those consumers request, conclude or hold a credit agreement within the Union.

The first paragraph shall be without prejudice to the possibility of offering different conditions of access to a credit where those different conditions are duly justified by objective criteria.

CHAPTER II

INFORMATION TO BE PROVIDED PRIOR TO THE CONCLUSION OF THE CREDIT AGREEMENT

Article 7

Advertising and marketing of credit agreements

Without prejudice to Directive 2005/29/EC, Member States shall require that any advertising and marketing communications concerning credit agreements are fair, clear and not misleading. Wording in such advertising and marketing communications that may create false expectations for a consumer regarding the availability or the cost of credit or the total amount payable by the consumer shall be prohibited.

Article 8

Standard information to be included in advertising of credit agreements

1. Member States shall require that advertising concerning credit agreements include a clear and prominent warning to make consumers aware that borrowing costs money, using the wording 'Caution! Borrowing money costs money' or an equivalent wording.

2. Member States shall require that advertising concerning credit agreements which indicates an interest rate or any figures relating to any cost of credit to the consumer include standard information in accordance with this Article.

The obligation referred to in the first subparagraph shall not apply where national law requires the indication of the annual percentage rate of charge in advertising concerning credit agreements which does not indicate an interest rate or any figures relating to any cost of credit to the consumer within the meaning of the first subparagraph.

3. The standard information shall be easily legible or clearly audible, as appropriate, and adapted to the technical constraints of the medium used for advertising and shall specify, in a clear, concise and prominent way, all of the following elements:

(a) the borrowing rate, fixed or variable or both, together with particulars of any charges included in the total cost of the credit to the consumer;

(b) the total amount of credit;

(c) the annual percentage rate of charge;

(d) where applicable, the duration of the credit agreement;

(e) in the case of credit in the form of deferred payment for specific goods or services, the cash price and the amount of any advance payment;

(f) where applicable, the total amount payable by the consumer and the amount of the instalments.

In specific and justified cases where the medium used to communicate the standard information referred to in the first subparagraph does not allow the information to be visually displayed, points (e) and (f) of that subparagraph shall not apply.

4. The standard information referred to in paragraph 3, first subparagraph, shall be specified by means of a representative example.

5. Where the conclusion of a contract regarding an ancillary service relating to the credit agreement is compulsory in order to obtain the credit or to obtain it on the terms and conditions marketed, and the cost of that service cannot be determined in advance, the standard information referred to in paragraph 3, first subparagraph, shall specify in a clear, concise and prominent way the obligation to enter into that contract.

6. Without prejudice to Directive 2005/29/EC, in specific and justified cases where the electronic medium used to communicate the standard information referred to in paragraph 3 of this Article does not allow that information to be visually displayed in a prominent and clear manner, the consumer shall be able to access the information referred to in points (e) and (f) of the first subparagraph of that paragraph by means of clicking, scrolling or swiping.

7. Member States shall prohibit advertising for credit products which:

(a) encourages consumers to seek credit by suggesting that credit would improve the financial situation of those consumers;

(b) specifies that outstanding credit agreements or registered credit in databases have little or no influence on the assessment of a credit application;

(c) falsely suggests that credit leads to an increase in financial resources, constitutes a substitute for savings or can raise a consumer's living standards.

8. Member States may prohibit, inter alia, advertising for credit products which:

(a) highlights the ease or speed with which credit can be obtained;

(b) states that a discount is conditional upon taking up credit;

(c) offers 'grace periods' of more than three months for the repayment of credit instalments.

Article 9

General information

1. Member States shall ensure that clear and comprehensible general information about credit agreements is made available to consumers by creditors or, where applicable, by credit intermediaries, at all times on paper or on another durable medium chosen by the consumer.

General information about credit agreements which is made available by creditors or, where applicable, by credit intermediaries at their premises shall be made available to consumers at least on paper.

2. The general information referred to in paragraph 1 shall include at least the following:

(a) the identity, geographical address, telephone number and email address of the issuer of the information;

(b) the purposes for which the credit may be used;

(c) the possible duration of the credit agreement;

(d) types of available borrowing rate, indicating whether fixed or variable or both, with a short description of the characteristics of a fixed and variable rate, including related implications for the consumer;

(e) a representative example of the total amount of credit, the total cost of the credit to the consumer, the total amount payable by the consumer and the annual percentage rate of charge;

(f) an indication of possible further costs, not included in the total cost of the credit to the consumer, to be paid in connection with a credit agreement;

(g) the range of different options available for reimbursing the credit to the creditor, including the number, frequency and amount of the regular repayment instalments;

(h) a description of the conditions directly relating to early repayment;

(i) a description of the right of withdrawal;

(j) indication of ancillary services the consumer is obliged to acquire in order to obtain the credit or to obtain it on the terms and conditions marketed and, where applicable, a clarification that the ancillary services may be purchased from a provider that is not the creditor; and

(k) a general warning concerning possible consequences of non-compliance with the commitments linked to the credit agreement.

Article 10

Pre-contractual information

1. Member States shall require that the creditor and, where applicable, the credit intermediary provide the consumer with the clear and comprehensible pre-contractual information needed to compare different offers in order to take an informed decision on whether to conclude a credit agreement on the basis of the credit terms and conditions offered by the creditor and, where applicable, the preferences expressed and information supplied by the consumer. Such pre-contractual information shall be provided to the consumer in good time before the consumer is bound by any credit agreement or offer, including where means of distance communication as defined in Article 2, point (e) of Directive 2002/65/EC are used.

In the event that the pre-contractual information referred to in the first subparagraph of this paragraph is provided less than one day before the consumer is bound by the credit agreement or offer, Member States shall require that the creditor and, where applicable, the credit intermediary send a reminder to the consumer of the possibility to withdraw from the credit agreement and of the procedure to follow for withdrawing, in accordance with Article 26. That reminder shall be provided to the consumer, on paper or on another durable medium chosen by the consumer and specified in the credit agreement, between one and seven days after the conclusion of the credit agreement or, where applicable, the submission of the binding credit offer by the consumer.

2. The pre-contractual information referred to in paragraph 1 shall be provided on paper or on another durable medium chosen by the consumer by means of the Standard European Consumer Credit Information form set out in Annex I. All the information provided in the form shall be equally prominent. The creditor shall be deemed to have fulfilled the information requirements laid down in this paragraph and in Article 3(1) and (2) of Directive 2002/65/EC if that creditor has supplied that form.

3. The pre-contractual information referred to in paragraph 1 shall specify all of the following elements in a prominent way in the first part of the Standard European Consumer Credit Information form on one page:

(a) the identity of the creditor as well as, where applicable, of the credit intermediary involved;

(b) the total amount of credit;

(c) the duration of the credit agreement;

(d) the borrowing rate, or all borrowing rates if different borrowing rates apply in different circumstances;

(e) the annual percentage rate of charge and the total amount payable by the consumer;

(f) in the case of a credit in the form of deferred payment for specific goods or services and in the case of linked credit agreements, the specific goods or services and their cash price;

(g) the costs in the case of late payments, i.e. the interest rate applicable in the case of late payments and the arrangements for its adjustment and, where applicable, any charges payable for default;

(h) the amount, number and frequency of payments to be made by the consumer and, where appropriate, the order in which payments will be allocated to different outstanding balances charged at different borrowing rates for the purposes of reimbursement;

(i) warning regarding the consequences of missing or late payments;

(j) the existence or absence of a right of withdrawal and, where applicable, the withdrawal period;

(k) the existence of a right of early repayment, and, where applicable, information concerning the creditor's right to compensation;

(l) the geographical address, telephone number and email address of the creditor as well as, where applicable, the geographical address, telephone number and email address of the credit intermediary involved.

4. In the event that all the elements referred to in paragraph 3 cannot be displayed in a prominent way on one page, they shall be displayed in the first part of the Standard European Consumer Credit Information form on two pages at most. In that case, the information referred to in points (a) to (g) of that paragraph shall be displayed on the first page of the form.

5. The pre-contractual information referred to in paragraph 1 shall specify all of the following elements, which shall be displayed after and noticeably separated from the elements listed in paragraph 3:

(a) the type of credit;

(b) the conditions governing the drawdown;

(c) where different borrowing rates apply in different circumstances, the conditions governing the application of each borrowing rate and, where available, any index or reference rate applicable to each initial borrowing rate, as well as the periods, conditions and procedures for changing each borrowing rate;

(d) where a credit agreement provides different ways of drawdown with different charges or borrowing rates and the creditor uses the assumption set out in Annex III, Part II, point (b), an indication that other drawdown mechanisms for the relevant type of credit agreement may result in higher annual percentage rates of charge;

(e) where applicable, the charges for maintaining one or more compulsory accounts recording both payment transactions and drawdowns, the charges for using a means of payment for both payment transactions and drawdowns, any other charges deriving from the credit agreement, and the conditions under which any of those charges may be changed;

(f) a representative example illustrating the annual percentage rate of charge and the total amount payable by the consumer, referring to all of the assumptions used in order to calculate that rate; where the consumer has informed the creditor of one or more components of his or her preferred credit, such as the duration of the credit agreement and the total amount of credit, the creditor shall take those components into account;

(g) where applicable, any costs payable by the consumer to a notary on conclusion of the credit agreement;

(h) the obligation, if any, to enter into an ancillary service contract relating to the credit agreement, where the conclusion of such a contract is compulsory in order to obtain the credit or to obtain it on the terms and conditions marketed;

(i) where applicable, the sureties required;

(j) where applicable, information concerning the way in which the creditor's compensation will be determined in the event of early repayment;

(k) the consumer's right to be informed immediately and free of charge, pursuant to Article 19(6), of the result of a database consultation carried out for the purposes of assessing his or her creditworthiness;

(l) the consumer's right, as set out in paragraph 8 of this Article, to be supplied, on request on paper or on another durable medium and free of charge, with a copy of the draft credit agreement, provided that the creditor, at the time of the request, is willing to proceed to the conclusion of the credit agreement;

(m) where applicable, an indication that the price was personalised on the basis of automated processing, including profiling;

(n) where applicable, the period of time during which the creditor is bound by the pre-contractual information provided in accordance with this Article;

(o) the possibility for the consumer of having recourse to an out-of-court complaint and redress mechanism and the methods for having access to it;

(p) a warning and explanation regarding the legal and financial consequences of non-compliance with the other commitments linked to the specific credit agreement;

(q) a repayment schedule containing all payments and repayments over the duration of the credit agreement, including the payments and repayments for any ancillary services relating to the credit agreement which are sold simultaneously, whereby payments and repayments, in the event that different borrowing rates apply in different circumstances, are based on reasonable upward changes in the borrowing rate.

Where the credit agreement references a benchmark as defined in Article 3(1), point (3), of Regulation (EU) 2016/1011 of the European Parliament and of the Council ([28]), the name of that benchmark and of its administrator and potential implications of that benchmark for the consumer shall be specified in a separate document which may be annexed to the Standard European Consumer Credit Information form.

6. Information displayed in the Standard European Consumer Credit Information form shall be consistent. It shall be clearly legible and shall take into account the technical constraints of the medium on which it is displayed. Information shall be displayed in an adequate and suitable way on the different channels taking into account interoperability.

Any additional information which the creditor may provide to the consumer shall be clearly legible and given in a separate document, which may be annexed to the Standard European Consumer Credit Information form.

7. By way of derogation from paragraph 5 of this Article, in the case of voice telephony communications, as referred to in Article 3(3) of Directive 2002/65/EC, the description of the main characteristics of the financial service to be provided pursuant to Article 3(3), point (b), second indent, of that Directive shall include at least the elements referred to in paragraph 3 of this Article. In such case, the creditor and, where applicable, the credit intermediary shall provide the consumer with the Standard European Consumer Credit Information form on a durable medium immediately after the conclusion of the credit agreement.

8. Upon request from the consumer, the creditor and, where applicable, the credit intermediary shall, in addition to the Standard European Consumer Credit Information form, provide the consumer free of charge with a copy of the draft credit agreement on paper or on another durable medium, provided that the creditor, at the time of the request, is willing to proceed to the conclusion of the credit agreement with the consumer.

9. In the case of a credit agreement under which payments made by the consumer do not give rise to an immediate corresponding amortisation of the total amount of credit, but are used to constitute capital during periods and under conditions laid down in the credit agreement, or in an ancillary agreement, the creditor and, where applicable, the credit intermediary shall in the pre-contractual information referred to in paragraph 1 include a clear and concise statement that such credit agreements do not provide for a guarantee of repayment of the total amount of credit drawn down under the credit agreement, unless such a guarantee is given expressly.

([28]) Regulation (EU) 2016/1011 of the European Parliament and of the Council of 8 June 2016 on indices used as benchmarks in financial instruments and financial contracts or to measure the performance of investment funds and amending Directives 2008/48/EC and 2014/17/EU and Regulation (EU) No 596/2014 (OJ L 171, 29.6.2016, p. 1).

10. This Article shall not apply to suppliers of goods or providers of services acting as credit intermediaries in an ancillary capacity. This is without prejudice to the creditor's, or where applicable, credit intermediary's obligation to ensure that the consumer receives the pre-contractual information referred to in this Article.

Article 11

Pre-contractual information with regard to credit agreements referred to in Article 2(6) or (7)

1. For credit agreements referred to in Article 2(6) or (7), the pre-contractual information referred to in Article 10(1) shall, by way of derogation from Article 10(2), be provided on paper or on another durable medium chosen by the consumer by means of the European Consumer Credit Information form set out in Annex II. That information shall be clear and comprehensible. All information provided in that form shall be equally prominent. The creditor shall be deemed to have fulfilled the information requirements laid down in this paragraph and in Article 3(1) and (2), of Directive 2002/65/EC if that creditor has supplied that form.

2. For credit agreements referred to in Article 2(6) or (7), the pre-contractual information referred to in Article 10(1) shall, by way of derogation from Article 10(3), specify all of the following elements, in a prominent way in the first part of the European Consumer Credit Information form on one page:

(a) the identity of the creditor as well as, where applicable, of the credit intermediary involved;

(b) the total amount of credit;

(c) the duration of the credit agreement;

(d) the borrowing rate, or all borrowing rates if different borrowing rates apply in different circumstances;

(e) the annual percentage rate of charge and the total amount payable by the consumer;

(f) in the case of a credit in the form of deferred payment for specific goods or services and in the case of linked credit agreements, the specific goods or services and their cash price;

(g) the costs in the case of late payments, i.e. the interest rate applicable in the case of late payments and the arrangements for its adjustment, and, where applicable, any charges payable for default;

(h) the amount, number and frequency of payments to be made by the consumer and, where appropriate, the order in which payments will be allocated to different outstanding balances charged at different borrowing rates for the purposes of reimbursement;

(i) warning regarding the consequences of missing or late payments;

(j) the existence or absence of a right of withdrawal;

(k) the existence of a right of early repayment, and, where applicable, information concerning the creditor's right to compensation;

(l) the geographical address, telephone number and email address of the creditor as well as, where applicable, the geographical address, telephone number and email address of the credit intermediary involved.

3. In the event that all the elements referred to in paragraph 2 cannot be displayed in a prominent way on one page, they shall be displayed in the first part of the European Consumer Credit Information form on two pages at most. In that case, the information referred to in points (a) to (g) of that paragraph shall be displayed on the first page of the form.

4. The pre-contractual information referred to in paragraph 1 shall specify all of the following elements, which shall be displayed after and noticeably separated from the elements listed in paragraph 2:

(a) the type of credit;

(b) where different borrowing rates apply in different circumstances, the conditions governing the application of each borrowing rate, any index or reference rate applicable to the initial borrowing rate, the charges applicable from the time the credit agreement is concluded, and, where applicable, the conditions under which those charges may be changed;

(c) a representative example illustrating the annual percentage rate of charge and the total amount payable by the consumer, referring to all of the assumptions used in order to calculate that rate;

(d) the conditions and procedure for terminating the credit agreement;

(e) where applicable, information concerning the way in which the creditor's compensation will be determined in the event of early repayment;

(f) where applicable, an indication that the consumer may be requested to repay the amount of credit in full at any time;

(g) a reference to the consumer's right to be informed immediately and free of charge, pursuant to Article 19(6), of the result of a database consultation carried out for the purposes of assessing his or her creditworthiness;

(h) where applicable, an indication that the price was personalised on the basis of automated processing, including profiling;

(i) where applicable, the period of time during which the creditor is bound by the pre-contractual information provided in accordance with this Article;

(j) a reference to the possibility for the consumer of having recourse to an out-of-court complaint and redress mechanism and the methods for having access to it;

(k) a warning and explanation regarding the legal and financial consequences of non-compliance with the other commitments linked to the specific credit agreement;

(l) a repayment schedule containing all payments and repayments over the duration of the credit agreement, including the payments and repayments for any ancillary services relating to the credit agreement which are sold simultaneously, whereby payments and repayments, in the event that different borrowing rates apply in different circumstances, are based on reasonable upward changes in the borrowing rate.

5. Information displayed in the European Consumer Credit Information form shall be consistent. It shall be clearly legible and shall take into account the technical constraints of the medium on which it is displayed. Information shall be displayed in an adequate and suitable way on the different channels, taking into account interoperability.

6. By way of derogation from paragraph 4 of this Article, in the case of voice telephony communications, as referred to in Article 3(3) of Directive 2002/65/EC, the description of the main characteristics of the financial service to be provided pursuant to Article 3(3), point (b), second indent, of that Directive shall include at least the elements referred to in paragraph 2 of this Article. In such case, the creditor and, where applicable, the credit intermediary shall provide the consumer with the European Consumer Credit Information form on a durable medium immediately after the conclusion of the credit agreement.

7. Upon request from the consumer, the creditor and, where applicable, the credit intermediary shall, in addition to the European Consumer Credit Information form, provide the consumer free of charge with a copy of the draft credit agreement, provided that the creditor, at the time of the request, is willing to proceed to the conclusion of the credit agreement with the consumer.

8. This Article shall not apply to suppliers of goods or providers of services acting as credit intermediaries in an ancillary capacity. This is without prejudice to the creditor's or, where applicable, the credit intermediary's obligation to ensure that the consumer receives the pre-contractual information referred to in this Article.

Article 12

Adequate explanations

1. Member States shall ensure that creditors and, where applicable, credit intermediaries are required to provide adequate explanations to the consumer on the proposed credit agreements and any ancillary services that make it possible for the consumer to assess whether the proposed credit agreements and ancillary services are adapted to the consumer's needs and financial situation. Such explanations shall be provided free of charge and before concluding the credit agreement. The explanations shall include the following elements:

(a) the information referred to in Articles 10, 11 and 38;

(b) the essential characteristics of the credit agreement or of the ancillary services proposed;

(c) the specific effects that the credit agreement or the ancillary services proposed may have on the consumer, including the consequences of payment default or late payment by the consumer;

(d) where ancillary services are bundled with a credit agreement, whether each component of the bundle can be terminated separately and the implications for the consumer of such termination.

2. Member States may, in justified cases, adapt the requirement referred to in paragraph 1 with regard to the manner in which the explanations are to be given and the extent to which they are to be given to the following:

(a) the circumstances of the situation in which the credit is offered;

(b) the person to whom the credit is offered;

(c) the type of the credit offered.

Article 13

Personalised offers on the basis of automated processing

Without prejudice to Regulation (EU) 2016/679, Member States shall require that creditors and credit intermediaries inform consumers in a clear and comprehensible manner when they are presented with a personalised offer that is based on automated processing of personal data.

CHAPTER III

TYING AND BUNDLING PRACTICES, INFERRED AGREEMENT, ADVISORY SERVICES AND UNSOLICITED GRANTING OF CREDIT

Article 14

Tying and bundling practices

1. Member States shall allow bundling practices but shall prohibit tying practices.

2. By way of derogation from paragraph 1 and without prejudice to the application of competition law, Member States may allow creditors to request the consumer to open or maintain a payment or savings account, where the only purpose of such an account is one of the following:

(a) to accumulate capital to repay the credit;

(b) to service the credit;

(c) to pool resources to obtain the credit;

(d) to provide additional security for the creditor in the event of default.

3. Member States may allow creditors to require the consumer to hold a relevant insurance policy related to the credit agreement, taking into account proportionality considerations. In such cases, Member States shall ensure that the creditor is required to accept the insurance policy from a supplier different to his or her preferred supplier where such insurance policy has a level of guarantee equivalent to the one the creditor has proposed, without modifying the conditions of the credit offered to the consumer.

4. Member States shall require that personal data concerning consumers' diagnoses of oncological diseases are not used for the purpose of an insurance policy related to a credit agreement after a period of time determined by the Member States, not exceeding 15 years following the end of the consumers' medical treatment.

5. In order for consumers to have additional time to compare insurance offers related to credit agreements before purchasing an insurance policy as referred to in paragraph 3, Member States shall require that consumers are given at least three days to compare insurance offers related to credit agreements without such offers being changed, and consumers shall be informed thereof. Consumers may conclude an insurance policy prior to the expiry of that three-day period if they explicitly so request.

Article 15

Inferred agreement for the conclusion of any credit agreement or the purchase of ancillary services

1. Member States shall ensure that creditors and credit intermediaries do not infer the agreement of the consumer for the conclusion of any credit agreement or for the purchase of ancillary services presented through default options. Default options include pre-ticked boxes.

2. The agreement of the consumer to the conclusion of any credit agreement or to the purchase of ancillary services presented through boxes shall be given by an unambiguous and clear affirmative act establishing a freely given, specific, informed and unambiguous indication of the consumer's approval to the content and substance associated to the boxes.

Article 16

Advisory services

1. Member States shall require that the creditor and, where applicable, the credit intermediary explicitly inform the consumer, in the context of a given transaction, whether advisory services are being or can be provided to the consumer.

2. Member States shall require that the creditor and, where applicable, the credit intermediary, before the provision of advisory services or the conclusion of a contract for the provision of such services, provide the consumer with the following information on paper or another durable medium chosen by the consumer:

(a) an indication of whether the recommendation will be based on only their own product range or on a wide range of products from across the market in accordance with paragraph 3, point (c);

(b) where applicable, an indication of the fee payable by the consumer for the advisory services or, where the amount of such fee cannot be established at the time when the information is provided, the method used for its calculation.

The information referred to in the first subparagraph of this paragraph may be provided to the consumer in the form of additional pre-contractual information in accordance with Article 10(6), second subparagraph.

3. Where advisory services are provided to consumers, Member States shall require that creditors and, where applicable, credit intermediaries:

(a) obtain the necessary information regarding the consumer's financial situation, preferences and objectives related to the credit agreement, in order for the creditor or the credit intermediary to recommend credit agreements that are suitable to the consumer;

(b) assess the financial situation and the needs of the consumer on the basis of the information referred to in point (a), which shall be up to date at the time of the assessment, taking into account reasonable assumptions as to the risks to the consumer's financial situation over the term of the recommended credit agreement;

(c) consider a sufficiently large number of credit agreements in their product range and on that basis recommend one or more credit agreements from among that product range that are suitable to the consumer's needs, financial situation and personal circumstances;

(d) act in the best interests of the consumer; and

(e) give the consumer a record of the recommendation provided, on paper or on another durable medium chosen by the consumer and specified in the contract for the provision of advisory services.

4. Member States may prohibit the use of the terms 'advice' and 'advisor' or similar terms when the advisory services are being marketed and provided to consumers by creditors or, where applicable, credit intermediaries.

Where Member States do not prohibit the use of the terms 'advice' and 'advisor' or similar terms, they shall impose the following conditions on the use of the term 'independent advice' or 'independent advisor' by creditors and credit intermediaries providing advisory services:

(a) creditors and, where applicable, credit intermediaries shall consider a sufficiently large number of credit agreements available on the market; and

(b) credit intermediaries shall not be remunerated for the advisory services by one or more creditors.

Point (b) of the second subparagraph shall apply only where the number of creditors considered is less than a majority of the market.

Member States may impose more stringent requirements for the use of the terms 'independent advice' or 'independent advisor' by creditors and, where applicable, credit intermediaries.

5. Member States shall require that creditors and, where applicable, credit intermediaries warn a consumer when a credit agreement may induce a specific risk for the consumer considering the consumer's financial situation.

6. Member States shall ensure that advisory services may only be provided by creditors and, where applicable, credit intermediaries.

Member States may, by way of derogation from the first subparagraph, allow other persons than those referred to in the first subparagraph to provide advisory services where one of the following conditions is fulfilled:

(a) the advisory services are provided in an incidental manner in the course of a professional activity that is regulated by legal or regulatory provisions or a code of ethics which do not exclude the provision of those services;

(b) the advisory services are provided in the context of management of existing debt by insolvency practitioners and where that management activity is regulated by legal or regulatory provisions;

(c) the advisory services are provided in the context of management of existing debt by public or voluntary providers of debt advisory services as referred to in Article 36 which do not operate on a commercial basis;

(d) the advisory services are provided by persons that are authorised and supervised by competent authorities.

Article 17

Ban on unsolicited granting of credit

Member States shall prohibit any granting of credit to consumers without their prior request and explicit agreement.

CHAPTER IV

ASSESSMENT OF CREDITWORTHINESS AND DATABASE ACCESS

Article 18

Obligation to assess the creditworthiness of the consumer

1. Member States shall require that, before concluding a credit agreement, the creditor carry out a thorough assessment of the consumer's creditworthiness. That assessment shall be carried out in the interest of the consumer, to prevent irresponsible lending practices and over-indebtedness, and shall take appropriate account of factors relevant to verifying the prospect of the consumer meeting his or her obligations under the credit agreement.

2. Member States shall ensure that credit intermediaries accurately submit the necessary information obtained from the consumer to the relevant creditor in accordance with Regulation (EU) 2016/679 to enable the creditworthiness assessment to be carried out.

3. The assessment of creditworthiness shall be carried out on the basis of relevant and accurate information on the consumer's income and expenses and other financial and economic circumstances which is necessary and proportionate to the nature, duration, value and risks of the credit for the consumer. That information may include evidence of income or other sources of repayment, information on financial assets and liabilities, or information on other financial commitments. That information shall not include special categories of data referred to in Article 9(1) of Regulation (EU) 2016/679. The information shall be obtained from relevant internal or external sources, including the consumer and, where necessary, on the basis of a consultation of a database referred to in Article 19 of this Directive. Social networks shall not be considered as an external source for the purpose of this Directive.

The information obtained in accordance with this paragraph shall be appropriately verified, where necessary through reference to independently verifiable documentation.

4. Member States shall require the creditor to establish procedures for the assessment referred to in paragraph 1 and to document and maintain such procedures.

Member States shall also require the creditor to document and maintain the information referred to in paragraph 3.

5. If the credit application is submitted jointly by more than one consumer, the creditor shall perform the creditworthiness assessment on the basis of the joint repayment capacity of the consumers.

6. Member States shall ensure that the creditor only makes the credit available to the consumer where the result of the creditworthiness assessment indicates that the obligations resulting from the credit agreement are likely to be met in the manner required under that agreement, taking into account relevant factors as referred to in paragraph 1.

7. Member States shall ensure that, where a creditor concludes a credit agreement with a consumer, the creditor shall not subsequently cancel or modify the credit agreement to the detriment of the consumer on the grounds that the assessment of creditworthiness was incorrectly conducted. This paragraph shall not apply where it is demonstrated that the consumer knowingly withheld or falsified the information referred to in paragraph 3 provided to the creditor.

8. Where the creditworthiness assessment involves the use of automated processing of personal data, Member States shall ensure that the consumer has the right to request and obtain from the creditor human intervention, consisting of the right to:

(a) request and obtain from the creditor a clear and comprehensible explanation of the assessment of creditworthiness, including on the logic and risks involved in the automated processing of personal data as well as its significance and effects on the decision;

(b) express the consumer's own point of view to the creditor; and

(c) request a review of the assessment of the creditworthiness and the decision on the granting of the credit by the creditor.

Member States shall ensure that the consumer is informed of the right as referred to in the first subparagraph.

9. Member States shall ensure that, where the credit application is rejected, the creditor is required to inform the consumer without delay of the rejection and, where relevant, refer the consumer to easily accessible debt advisory services. Where applicable, the creditor shall be required to inform the consumer of the fact that the assessment of creditworthiness is based on automated processing of data and about the consumer's right to human assessment and the procedure for contesting the decision.

10. Where the parties agree to change the total amount of credit after the conclusion of the credit agreement, Member States shall ensure that the creditor is required to reassess the consumer's creditworthiness on the basis of updated information before any significant increase in the total amount of credit is granted.

11. Member States may require creditors to assess the creditworthiness of consumers on the basis of a consultation of the relevant database. However, the assessment of creditworthiness shall not be based exclusively on the consumer's credit history.

Article 19

Databases

1. Each Member State shall, in the case of cross-border credit, ensure access for creditors from other Member States to databases used in that Member State for assessing the creditworthiness of consumers. The conditions for access to such databases shall be non-discriminatory.

2. Member States shall ensure that only those creditors who are under the supervision of the national competent authority and who fully comply with Regulation (EU) 2016/679 have access to the databases used for assessing the creditworthiness of consumers.

3. Paragraph 1 shall apply both to public and private databases.

4. The databases referred to in paragraph 1 which contain information on credit agreements for consumers shall hold at least information on consumers' arrears in repayment of credit, the type of credit and the identity of the creditor.

5. Creditors and credit intermediaries shall not process special categories of data as referred to in Article 9(1) of Regulation (EU) 2016/679 and personal data processed from social networks that may be contained in databases referred to in paragraph 1 of this Article.

6. Where the credit application is rejected on the basis of a consultation of a database referred to in paragraph 1, Member States shall require that the creditor informs the consumer without undue delay and free of charge of the result of such consultation and of the details of the database consulted as well as the categories of data taken into account.

7. For the purpose of credit agreements, database providers shall have processes in place to ensure that information contained in their databases is up-to-date and accurate. Member States shall ensure that consumers are informed:

(a) within 30 days of the registration of any arrears in repayment of credit in a database; and

(b) of their rights in accordance with Regulation (EU) 2016/679.

8. For the purpose of credit agreements, Member States shall ensure that complaint procedures are in place in order to facilitate consumers' challenges to the content of databases, including information that can be obtained by third parties through those databases.

CHAPTER V

FORM AND CONTENT OF CREDIT AGREEMENTS

Article 20

Form of the credit agreement

1. Member States shall require that credit agreements and any modifications of such agreements are drawn up on paper or another durable medium and that all the contracting parties are provided with a copy of the credit agreement.

2. Member States may introduce or maintain national rules regarding the validity of the conclusion of credit agreements which are in conformity with Union law.

Article 21

Information to be included in the credit agreement

1. Member States shall require that the credit agreement specify in a clear and concise manner all of the following elements:

(a) the type of credit;

(b) the identities, geographical addresses, telephone numbers and email addresses of the contracting parties as well as, where applicable, the identity and geographical address of the credit intermediary involved;

(c) the total amount of credit and the conditions governing the drawdown;

(d) the duration of the credit agreement;

(e) in case of a credit in the form of deferred payment for specific goods or services and in the case of linked credit agreements, the specific goods or services and their cash price;

(f) the borrowing rate, or all borrowing rates where different borrowing rates apply in different circumstances, the conditions governing the application of each borrowing rate and, where available, any index or reference rate applicable to each initial borrowing rate, as well as the periods, conditions and procedures for changing each borrowing rate;

(g) the annual percentage rate of charge and the total amount payable by the consumer, calculated at the time the credit agreement is concluded and an indication of all assumptions used in that calculation;

(h) the amount, number and frequency of payments to be made by the consumer and, where appropriate, the order in which payments will be allocated to different outstanding balances charged at different borrowing rates for the purposes of reimbursement;

(i) where capital amortisation of a credit agreement with a fixed duration is involved, a reference to the right of the consumer to receive, on request and free of charge, at any time throughout the duration of the credit agreement, a statement of account in the form of an amortisation table;

(j) where charges and interest are to be paid without capital amortisation, a statement showing the periods and conditions for the payment of the interest and of any associated recurrent and non-recurrent charges;

(k) where applicable, the charges for maintaining one or more compulsory accounts recording both payment transactions and drawdowns, the charges for using a means of payment for both payment transactions and drawdowns, any other charges deriving from the credit agreement, and the conditions under which those charges may be changed;

(l) the interest rate applicable in the case of late payments as applicable at the time of the conclusion of the credit agreement and the arrangements for its adjustment and, where applicable, any charges payable for default;

(m) a warning regarding the consequences of missing or late payments;

(n) where applicable, a statement that notarial fees will be payable;

(o) where applicable, the sureties and insurance required;

(p) the existence or absence of a right of withdrawal, the withdrawal period, where applicable, and other conditions governing the exercise thereof, including the durable medium to be used for the notification referred to in Article 26(5), first subparagraph, point (a), information concerning the obligation of the consumer set out in Article 26(5), first subparagraph, point (b), to pay the capital drawn down and the interest, and the amount of interest payable per day;

(q) the type of durable medium on which the consumer chooses to receive the following:

(i) where applicable, the reminder referred to in Article 10(1), second subparagraph;

(ii) the information referred to in Article 22;

(iii) the information on the change in the borrowing rate referred to in Article 23(1), first subparagraph;

(iv) where applicable, the information referred to in Article 24(1) and (2); and

(v) where applicable, the information on the termination of an open-end credit agreement referred to in Article 28(1), second subparagraph, and Article 28(2);

(r) where applicable, information concerning the rights set out in Article 27 as well as the conditions for the exercise of those rights;

(s) a reference to the right of early repayment set out in Article 29, the procedure for early repayment, as well as, where applicable, information concerning the creditor's right to compensation and a transparent and comprehensible explanation how the compensation due to the creditor by the consumer is to be calculated;

(t) the procedure to be followed in exercising the right of termination of the credit agreement;

(u) the possibility of having recourse to an out-of-court complaint and redress mechanism for the consumer and the methods for having access to it;

(v) where applicable, other contractual terms and conditions;

(w) the name and address of the competent supervisory authority;

(x) the relevant contact details of providers of debt advisory services and a recommendation for the consumer to contact such providers in the event of repayment difficulties.

The information referred to in the first subparagraph shall be clearly legible and adapted to take into account the technical constraints of the medium on which it is displayed. Information shall be displayed in an adequate and suitable way on the different channels.

2. Where paragraph 1, first subparagraph, point (i), applies, the creditor shall make available to the consumer, free of charge and at any time throughout the duration of the credit agreement, a statement of account in the form of an amortisation table.

The amortisation table referred to in the first subparagraph shall indicate the payments owing and the periods and conditions relating to the payment of such amounts.

The amortisation table shall also contain a breakdown of each repayment specifying the capital amortisation, the interest calculated on the basis of the borrowing rate and, where applicable, any additional costs.

Where the borrowing rate is not fixed or the additional costs may be changed under the credit agreement, the amortisation table shall indicate, clearly and concisely, that the data contained in the table will remain valid only until such time as that borrowing rate or those costs are changed in accordance with the credit agreement.

3. In the case of a credit agreement under which payments made by the consumer do not give rise to an immediate corresponding amortisation of the total amount of credit, but are used to constitute capital during periods and under conditions laid down in the credit agreement, or in an ancillary agreement, the credit agreement shall, in addition to the information referred to in paragraph 1, include a clear and concise statement that such credit agreements do not provide for a guarantee of repayment of the total amount of credit drawn down under the credit agreement, unless such a guarantee is given expressly.

CHAPTER VI

MODIFICATIONS OF THE CREDIT AGREEMENT AND CHANGES IN THE BORROWING RATE

Article 22

Information regarding the modification of the credit agreement

Without prejudice to other obligations provided for in this Directive, Member States shall ensure that prior to modifying the terms and conditions of the credit agreement, the creditor communicates on paper or another durable medium specified in the credit agreement the following information to the consumer:

(a) a clear description of the proposed changes and, where applicable, the need for consumer consent or an explanation of the changes introduced by operation of law;

(b) the timescale for the implementation of the changes referred to in point (a);

(c) the means for complaint available to the consumer regarding the changes referred to in point (a);

(d) the time period available for lodging any such complaint;

(e) the name and address of the competent authority where that complaint may be submitted.

Article 23

Changes in the borrowing rate

1. Where creditors are allowed to change borrowing rates of existing credit agreements, Member States shall require that the creditor inform the consumer of any change in the borrowing rate on paper or another durable medium specified in the credit agreement, in good time before the change enters into force.

The information referred to in the first subparagraph shall include the amount of the payments to be made after the entry into force of the new borrowing rate and, where the number or frequency of the payments changes, the particulars thereof.

2. By way of derogation from paragraph 1, the information referred to in that paragraph may be given to the consumer periodically where all of the following conditions are fulfilled:

(a) the parties have agreed on such periodical information in the credit agreement;

(b) the change in the borrowing rate is caused by a change in a reference rate;

(c) the new reference rate is made publicly available in a timely manner by appropriate means;

(d) the information concerning the new reference rate is also available:

(i) at the premises of the creditor;

(ii) where the creditor has a website, on that website; and

(iii) where the creditor has a mobile application, via that mobile application.

CHAPTER VII

OVERDRAFT FACILITIES AND OVERRUNNING

Article 24

Overdraft facilities

1. Where a credit has been granted in the form of an overdraft facility, Member States shall require that the creditor, throughout the duration of the credit agreement, keeps the consumer regularly, at least once per month, informed by means of statements of account, on paper or another durable medium specified in the credit agreement, containing the following elements:

(a) the precise period to which the statement of account relates;

(b) the amounts and dates of drawdowns;

(c) the balance from the previous statement, and the date thereof;

(d) the new balance;

(e) the dates and amounts of payments made by the consumer;

(f) the borrowing rate applied;

(g) any charges that have been applied;

(h) where applicable, the minimum amount to be paid by the consumer.

2. Where a credit has been granted in the form of an overdraft facility, Member States shall require that the creditor informs the consumer, on paper or another durable medium specified in the credit agreement, of increases in the borrowing rate or in any charges payable, in good time before the change in question enters into force.

By way of derogation from the first subparagraph, the information referred to in that subparagraph may be given periodically in the manner provided for in paragraph 1 where the following conditions are fulfilled:

(a) the parties have agreed on such periodical information in the credit agreement;

(b) the change in the borrowing rate is caused by a change in a reference rate;

(c) the new reference rate is made publicly available by appropriate means;

(d) the information concerning the new reference rate is also available:

(i) at the premises of the creditor;

(ii) where the creditor has a website, on that website; and

(iii) where the creditor has a mobile application, via that mobile application.

3. Member States shall require the creditor to notify the consumer in an agreed manner of each reduction or cancellation of the overdraft facility at least 30 days prior to the day when the actual reduction or cancellation of the overdraft facility takes effect.

4. Where the overdraft facility is reduced or cancelled, Member States shall require that the creditor offer the consumer, before the enforcement proceedings have been initiated, at no additional cost, the possibility to repay the amount actually drawn down to the extent of that reduction or cancellation. Such a repayment shall be made in 12 equal monthly instalments unless the consumer chooses to repay earlier, at the borrowing rate applicable to the overdraft facility.

5. Member States may maintain or adopt more stringent provisions on matters related to the protection of consumers holding an overdraft facility other than those referred to in this Article, in accordance with Union law.

Article 25

Overrunning

1. In the case of an agreement to open a current account, where there is a possibility that the consumer is allowed an overrun, Member States shall require that the creditor includes information on that possibility in that agreement, as well as information on the borrowing rate, the conditions governing the application of that rate, any index or reference rate applicable to the initial borrowing rate, the charges applicable from the time the credit agreement is concluded, and, where applicable, the conditions under which those charges may be changed. The creditor shall in any case provide the consumer with that information on paper or another durable medium chosen by the consumer and specified in the agreement to open a current account, on a regular basis.

2. In the event of a significant overrunning exceeding a period of one month, Member States shall require that the creditor informs the consumer without delay, on paper or another durable medium chosen by the consumer and specified in the agreement to open a current account, of all of the following:

(a) the overrunning;

(b) the amount involved;

(c) the borrowing rate;

(d) any penalties, charges or interest on arrears applicable;

(e) the repayment date.

In addition, in the case of regular overrunning, the creditor shall offer the consumer advisory services, where available, and redirect the consumer at no cost towards debt advisory services.

3. This Article shall be without prejudice to any rule of national law requiring the creditor to offer another kind of credit product when the duration of the overrunning is significant.

4. Member States shall require the creditor to notify the consumer in an agreed manner when the overrunning is not allowed anymore or the limit of the overrunning is reduced at least 30 days prior to the day when the actual cancellation or reduction of the overrunning takes effect.

5. Where the overrunning is reduced or cancelled, Member States shall require that the creditor offer the consumer, before the enforcement proceedings have been initiated, at no additional cost, the possibility to repay the amount actually drawn down to the extent of that reduction or cancellation. Such a repayment shall be made in 12 equal monthly instalments unless the consumer chooses to repay earlier, at the borrowing rate applicable to the overrunning.

6. Member States may maintain or adopt more stringent provisions on matters related to the protection of consumers holding an overrunning other than those referred to in this Article, in accordance with Union law.

CHAPTER VIII

WITHDRAWAL, TERMINATION AND EARLY REPAYMENT

Article 26

Right of withdrawal

1. Member States shall ensure that the consumer may withdraw from the credit agreement without giving any reason within a period of 14 calendar days.

The withdrawal period referred to in the first subparagraph shall begin either:

(a) from the day of the conclusion of the credit agreement; or

(b) from the day on which the consumer receives the contractual terms and conditions and the information in accordance with Articles 20 and 21, if that day is later than the date referred to in point (a) of this subparagraph.

The deadline referred to in the first subparagraph shall be deemed to have been met if the notification referred to in paragraph 5, first subparagraph, point (a), is dispatched by the consumer to the creditor before that deadline expires.

2. If the consumer has not received the contractual terms and conditions and the information in accordance with Articles 20 and 21, the withdrawal period shall in any event expire 12 months and 14 days after the conclusion of the credit agreement. This shall not apply if the consumer has not been informed about his or her right of withdrawal in accordance with Article 21(1), first subparagraph, point (p).

3. In the case of a linked credit agreement for the purchase of a good with a return policy that ensures a full refund for a certain period of time exceeding 14 calendar days, the right of withdrawal shall be extended to match the duration of such return policy.

4. Where, in the case of a linked credit agreement, national legislation applicable on 19 November 2023 already provides that funds cannot be made available to the consumer before the expiry of a specific period, Member States may, by way of derogation from paragraph 1, provide that the period referred to in that paragraph may be reduced to the same duration as that specific period at the explicit request of the consumer.

5. If the consumer exercises the right of withdrawal, he or she shall take the following measures:

(a) notify the creditor in accordance with the information given by the creditor pursuant to Article 21(1), first subparagraph, point (p), on paper or another durable medium chosen by the consumer and specified in the credit agreement within the deadline set out in paragraph 1 of this Article;

(b) pay to the creditor the capital and the interest accrued thereon from the date on which the credit was drawn down until the date on which the capital is repaid, without any undue delay and in any event no later than 30 calendar days after the dispatch of the notification referred to in point (a).

The interest referred to in the first subparagraph, point (b), shall be calculated on the basis of the agreed borrowing rate. The creditor shall not be entitled to any other compensation from the consumer in the event of withdrawal, except compensation for any non-refundable charges paid by the creditor to any public administrative body.

6. Where an ancillary service relating to the credit agreement is provided by the creditor, or by a third party on the basis of an agreement between that third party and the creditor, the consumer shall no longer be bound by the ancillary service contract if the consumer exercises the right of withdrawal from the credit agreement in accordance with this Article.

7. If the consumer has a right of withdrawal under paragraphs 1, 5 and 6 of this Article, Articles 6 and 7 of Directive 2002/65/EC shall not apply.

8. Member States may provide that paragraphs 1 to 6 of this Article shall not apply to credit agreements which are required under national law to be concluded through the services of a notary, provided that the notary confirms that the consumer is guaranteed the rights provided for under Articles 10, 11, 20 and 21.

9. This Article shall be without prejudice to any rule of national law establishing a period of time during which the performance of the contract may not begin.

Article 27

Linked credit agreements

1. Member States shall ensure that a consumer who has exercised the right of withdrawal, based on Union law, concerning a contract for the supply of goods or the provision of services, is no longer bound by a linked credit agreement.

2. Where the goods or services covered by a linked credit agreement are not supplied or provided, or are supplied or provided only in part, or are not in conformity with the contract for the supply or provision thereof, the consumer shall have the right to pursue remedies against the creditor if the consumer has pursued remedies against the supplier or provider but has failed to obtain the satisfaction to which he is entitled according to the law or the contract for the supply of those goods or the provision of those services. Member States shall determine to what extent and under what conditions those remedies are exercisable.

3. This Article shall be without prejudice to national law rendering the creditor jointly and severally liable in respect of any claim which the consumer may have against the supplier or provider where the purchase of goods or services from the supplier or provider has been financed by a credit agreement.

Article 28

Open-end credit agreements

1. Member States shall ensure that the consumer may effect standard termination of an open-end credit agreement free of charge at any time, unless the parties have agreed on a period of notice. Such a period shall not exceed one month.

Member States shall ensure that the creditor may, where agreed in the credit agreement, effect standard termination of an open-end credit agreement by giving the consumer at least two months' notice on paper or another durable medium specified in the credit agreement.

2. Member States shall ensure that the creditor may, where agreed in the credit agreement, for objectively justified reasons, terminate the consumer's right to draw down on an open-end credit agreement. The creditor shall inform the consumer of the termination and the reasons for it on paper or another durable medium specified in the credit agreement, where possible before the termination and at the latest immediately thereafter, unless the provision of such information is prohibited by Union or national law or is contrary to objectives of public policy or public security.

Article 29

Early repayment

1. Member States shall ensure that the consumer is at any time entitled to early repayment. In such cases, the consumer shall be entitled to a reduction in the total cost of the credit to the consumer for the remaining duration of the contract. When calculating that reduction, all the costs imposed on the consumer by the creditor shall be taken into consideration.

2. Member States shall ensure that the creditor, in the event of early repayment, is entitled to fair and objectively justified compensation for possible costs directly linked to the early repayment, provided that the early repayment falls within a period of time for which the borrowing rate is fixed.

The compensation referred to in the first subparagraph shall not exceed 1 % of the amount of credit subject to early repayment where the period of time between the early repayment and the agreed date of termination of the credit agreement exceeds one year. Where that period does not exceed one year, the compensation shall not exceed 0,5 % of the amount of credit subject to early repayment.

3. Member States shall ensure that the creditor is not entitled to the compensation referred to in paragraph 2 where one of the following conditions is fulfilled:

(a) the repayment has been made under an insurance contract intended to provide a credit repayment guarantee;

(b) the credit is granted in the form of an overdraft facility;

(c) the repayment falls within a period for which the borrowing rate is not fixed.

4. By way of derogation from paragraph 2, Member States may provide that:

(a) the creditor is only entitled to the compensation referred to in paragraph 2 on the condition that the amount of the early repayment exceeds the threshold set out in national law, which shall not exceed EUR 10 000 within any period of 12 months;

(b) the creditor may exceptionally claim higher compensation if the creditor can prove that the loss suffered due to early repayment exceeds the amount determined in accordance with paragraph 2.

Where the compensation claimed by the creditor exceeds the loss actually suffered due to the early repayment, the consumer shall be entitled to a corresponding reduction.

In that case, the loss shall consist of the difference between the initially agreed borrowing rate and the interest rate at which the creditor can lend out the amount subject to early repayment on the market at the time of that repayment, and shall take into account the impact of the early repayment on the administrative costs.

5. The compensation referred to in paragraph 2 and paragraph 4, point (b), shall not in any case exceed the amount of interest that the consumer would have paid during the period of time between the early repayment and the agreed date of termination of the credit agreement.

CHAPTER IX

ANNUAL PERCENTAGE RATE OF CHARGE AND MEASURES TO LIMIT RATES AND COSTS

Article 30

Calculation of the annual percentage rate of charge

1. The annual percentage rate of charge shall be calculated in accordance with the mathematical formula set out in Part I of Annex III. It shall equate, on an annual basis, to the present value of all commitments (drawdowns, repayments and charges), future or existing, agreed by the creditor and the consumer.

2. For the purpose of calculating the annual percentage rate of charge, the total cost of the credit to the consumer shall be determined, with the exception of any charges payable by the consumer for non-compliance with any of his or her commitments laid down in the credit agreement and charges other than the purchase price which, for purchases of goods or services, he or she is obliged to pay whether the transaction is effected in cash or on credit.

The costs of maintaining an account recording both payment transactions and drawdowns, the costs of using a means of payment for both payment transactions and drawdowns, and other costs relating to payment transactions shall be included in the total cost of the credit to the consumer unless the opening of the account is optional and the costs of the account have been clearly and separately identified in the credit agreement, or in any other agreement concluded with the consumer.

3. The calculation of the annual percentage rate of charge shall be based on the assumption that the credit agreement is to remain valid for the period agreed and that the creditor and the consumer will fulfil their obligations under the terms and by the dates specified in the credit agreement.

4. In the case of credit agreements containing clauses that allow variations in the borrowing rate or variations in certain charges contained in the annual percentage rate of charge which make them unquantifiable at the time of calculation, the annual percentage rate of charge shall be calculated on the assumption that the borrowing rate and other charges will remain fixed in relation to the initial level and will remain applicable until the end of the credit agreement.

5. Where necessary, the additional assumptions set out in Part II of Annex III shall be used in calculating the annual percentage rate of charge.

Where the assumptions set out in this Article and in Part II of Annex III do not suffice to calculate the annual percentage rate of charge in a uniform manner or are no longer adapted to the commercial situations in the market, the Commission is empowered to adopt delegated acts in accordance with Article 45 in order to amend this Article and Part II of Annex III to add the necessary additional assumptions for the calculation of the annual percentage rate of charge or to modify the existing ones.

Article 31

Measures to limit borrowing rates, annual percentage rates of charge or total costs of credit to the consumer

1. Member States shall introduce measures to effectively prevent abuse and to ensure that consumers cannot be charged with excessively high borrowing rates, annual percentage rates of charge or total costs of credit to the consumer, such as caps.

2. Member States may adopt prohibitions or limitations regarding specific charges or fees applied by creditors on their territory.

3. By 20 November 2027, the Commission shall make the measures introduced by Member States in accordance with paragraph 1 publicly available. Member States shall report to the Commission on those measures by 20 November 2026.

4. By 20 November 2029 the European Banking Authority shall publish a report on the implementation of the measures referred to in paragraph 1. That report shall include an assessment of the measures put in place in Member States, including methodologies to establish caps where relevant, and of their effectiveness in limiting the excessively high borrowing rates, annual percentage rates of charge or total costs of credit to the consumer, and shall include a best practice approach for establishing such measures.

CHAPTER X

CONDUCT OF BUSINESS OBLIGATIONS AND REQUIREMENTS FOR STAFF

Article 32

Conduct of business obligations when providing credit to consumers

1. Member States shall require that the creditor and the credit intermediary act honestly, fairly, transparently and professionally and take account of the rights and interests of the consumers when carrying out any of the following activities:

(a) manufacturing credit products;

(b) advertising credit products in accordance with Articles 7 and 8;

(c) granting, intermediating or facilitating the granting of credit;

(d) providing advisory services;

(e) providing ancillary services to consumers;

(f) executing a credit agreement.

The activities referred to in the first subparagraph, points (c) and (d), shall be based on information about the consumer's circumstances and any specific requirement communicated by a consumer and on reasonable assumptions about risks to the consumer's situation throughout the duration of the credit agreement.

The activities referred to in the first subparagraph, point (d), shall also be based on the information required under Article 16(3), point (a).

2. Member States shall ensure that the manner in which creditors remunerate their staff and credit intermediaries and the manner in which credit intermediaries remunerate their staff do not impede compliance with the obligation set out in paragraph 1.

3. Member States shall ensure that, when establishing and applying remuneration policies for staff responsible for the assessment of creditworthiness, creditors comply with the following principles in a way and to the extent that is appropriate to their size, internal organisation and the nature, scope and complexity of their activities:

(a) the remuneration policy is consistent with and promotes sound and effective risk management and does not encourage risk-taking that exceeds the level of tolerated risk of the creditor;

(b) the remuneration policy is in line with the business strategy, objectives, values and long-term interests of the creditor, and incorporates measures to avoid conflicts of interest, in particular by providing that remuneration is not contingent on the number or proportion of accepted applications for credit.

4. Member States shall ensure that where creditors or credit intermediaries provide advisory services, the remuneration structure of the staff involved does not prejudice their ability to act in the consumer's best interest and is not contingent on sales targets. In order to achieve that goal, Member States may also ban commissions paid by the creditor to the credit intermediary.

5. Member States may prohibit or impose restrictions on the payments from a consumer to a creditor or a credit intermediary prior to the conclusion of a credit agreement.

Article 33

Knowledge and competence requirements for staff

1. Member States shall ensure that creditors and credit intermediaries require their staff to possess and keep up-to-date an appropriate level of knowledge and competence in relation to the manufacturing, the offering and the granting of credit agreements, the carrying out of credit intermediation activities and the provision of advisory services, as well as in relation to consumer rights in the area of their trade. Where the conclusion of a credit agreement includes ancillary services, appropriate knowledge and competence in relation to those ancillary services shall be required.

2. Member States shall establish minimum knowledge and competence requirements for the staff of creditors and of credit intermediaries.

3. Member States shall ensure that compliance with the requirements set out in paragraph 1 is supervised by the competent authorities, and that the competent authorities have powers to require creditors and credit intermediaries to provide the evidence that the competent authority deems necessary to enable such supervision.

CHAPTER XI

FINANCIAL EDUCATION AND SUPPORT TO CONSUMERS IN FINANCIAL DIFFICULTIES

Article 34

Financial education

1. Member States shall promote measures that support the education of consumers in relation to responsible borrowing and debt management, in particular in relation to credit agreements. Clear and general information on the credit granting process shall be provided to consumers in order to guide them, in particular those who take out, particularly by means of digital tools, consumer credit for the first time. In creating and promoting those measures, Member States shall consult relevant stakeholders, including consumer organisations.

Member States shall also ensure that information regarding the guidance that consumer organisations and national authorities may provide to consumers is disseminated.

2. The Commission shall assess and publish a report on the financial education available to consumers in the Member States and identify examples of best practices which could be further developed in order to increase the financial awareness of consumers.

Article 35

Arrears and forbearance measures

1. Member States shall require creditors to exercise, where appropriate, reasonable forbearance before enforcement proceedings are initiated. Such forbearance measures shall take into account, among other elements, the consumer's individual circumstances. Creditors shall not be required to offer forbearance measures reiteratively to consumers, unless in justified cases.

Creditors shall not be required to perform a creditworthiness assessment in accordance with Article 18 when modifying the existing terms and conditions of a credit agreement in accordance with the third subparagraph, point (b) of this paragraph, provided that the total amount payable by the consumer is not significantly increased when modifying the credit agreement.

The forbearance measures referred to in the first subparagraph:

(a) may include, among other possibilities a total or partial refinancing of a credit agreement;

(b) shall include modification of the existing terms and conditions of a credit agreement, which may, among other possibilities include:

  (i) extending the term of the credit agreement;

  (ii) changing the type of the credit agreement;

  (iii) deferring payment of all or part of the repayment of instalments for a period;

  (iv) reducing the borrowing rate;

  (v) offering a payment holiday;

  (vi) partial repayments;

  (vii) currency conversions;

  (viii) partial forgiveness and debt consolidation.

2. The list of potential measures in paragraph 1, third subparagraph, point (b), shall be without prejudice to national law and shall not require Member States to provide for all of those measures in national law.

3. Where Member States allow creditors to define and impose charges on the consumer arising from a default, those Member States may require that those charges are no greater than is necessary to compensate the creditor for costs it has incurred as a result of the default.

4. Where Member States allow creditors to impose additional charges on the consumer in the event of default, those Member States shall place a cap on those charges.

5. Member States shall not prevent the parties to a credit agreement from expressly agreeing that the return or transfer to the creditor of goods covered by a linked credit agreement or proceeds from the sale of such goods is sufficient to repay the credit.

Article 36

Debt advisory services

1. Member States shall ensure that independent debt advisory services are made available to consumers who experience or might experience difficulties in meeting their financial commitments, with only limited charges payable for such services.

2. For the purpose of fulfilling the obligations laid down in paragraph 1, creditors shall have processes and policies in place for the early detection of consumers experiencing financial difficulties.

3. Member States shall ensure that creditors refer consumers who experience difficulties in meeting their financial commitments to debt advisory services easily accessible to the consumer.

4. The Commission shall, by 20 November 2028, present a report providing an overview of the availability of debt advisory services across Member States and identifying best practices for the further development of such services. Member States shall, by 20 November 2026, and every year thereafter, report to the Commission on available debt advisory services.

CHAPTER XII

CREDITORS AND CREDIT INTERMEDIARIES

Article 37

Admission, registration and supervision of non-credit institutions and non-payment institutions

1. Member States shall ensure that creditors and credit intermediaries are subject to an adequate admission process, to registration and to supervision arrangements set up by an independent competent authority.

2. The requirement of an adequate admission process and of registration shall not apply to creditors that are:

(a) credit institutions as defined in Article 4(1), point (1), of Regulation (EU) No 575/2013;

(b) payment institutions as defined in Article 4, point (4), of Directive (EU) 2015/2366, for the services referred to in Annex I, point 4, of that Directive; or

(c) electronic money institutions as defined in Article 2, point (1), of Directive 2009/110/EC, for the granting of credit referred to in Article 6(1), first subparagraph, point (b), of that Directive.

3. Member States may decide not to apply admission and registration requirements as referred to in paragraph 1 to suppliers of goods or providers of services who qualify as micro, small and medium-sized enterprises as defined in Recommendation 2003/361/EC, acting as:

(a) credit intermediaries in an ancillary capacity; or

(b) creditors in an ancillary capacity, granting credit in the form of deferred payment to purchase goods and services offered by them, if the credit is provided free of interest and with only limited charges payable by the consumer for late payments imposed in accordance with national law.

Article 38

Specific obligations for credit intermediaries

Member States shall require that credit intermediaries:

(a) indicate, in advertising and documentation intended for consumers, the extent of their powers and whether they work exclusively with one or more creditors or as an independent intermediary;

(b) disclose to the consumer any fees payable by the consumer to the credit intermediary for services to be provided;

(c) reach an agreement with the consumer on any fees referred to in point (b) on paper or another durable medium before the conclusion of the credit agreement;

(d) communicate any fees referred to in point (b) to the creditor, for the purpose of calculation of the annual percentage rate of charge.

CHAPTER XIII

ASSIGNMENTS OF RIGHTS AND DISPUTE RESOLUTION

Article 39

Assignment of rights

1. Member States shall ensure that the consumer, in the event of assignment to a third party of the creditor's rights under a credit agreement or of the credit agreement itself, is entitled to plead against the assignee any defence which was available to him or her against the original creditor, including set-off where such defence is permitted in the Member State concerned.

2. Member States shall require that the original creditor inform the consumer of the assignment referred to in paragraph 1, except where the original creditor, by agreement with the assignee, continues to service the credit vis-à-vis the consumer.

Article 40

Out-of-court dispute resolution

1. Member States shall ensure that consumers have access to adequate, prompt and effective out-of-court dispute resolution procedures for the settlement of disputes between consumers and creditors or credit intermediaries concerning rights and obligations relating to credit agreements established under this Directive, using existing entities performing out-of-court dispute resolution where appropriate. Such out-of-court dispute resolution procedures and the entities offering them shall comply with the quality requirements laid down by Directive 2013/11/EU.

2. Member States shall encourage the entities performing out-of-court dispute resolution referred to in paragraph 1 to cooperate in order to resolve cross-border disputes concerning credit agreements.

CHAPTER XIV

COMPETENT AUTHORITIES

Article 41

Competent authorities

1. Member States shall designate the national competent authorities empowered to ensure the application and enforcement of this Directive and shall ensure that they are granted investigating and enforcement powers and adequate resources necessary for the efficient and effective performance of their duties.

The competent authorities shall be either public authorities or bodies recognised by national law or by public authorities expressly empowered for that purpose by national law. They shall not be creditors or credit intermediaries.

2. Member States shall ensure that competent authorities, all persons who work or who have worked for the competent authorities, as well as auditors and experts instructed by the competent authorities, are bound by the obligation of professional secrecy. No confidential information which they may receive in the course of their duties may be divulged to any person or authority whatsoever, save in summary or aggregate form, without prejudice to cases covered by criminal law or by this Directive. This shall not, however, prevent the competent authorities from exchanging or transmitting confidential information in accordance with Union and national law.

3. Member States shall ensure that the competent authorities are either of the following:

(a) competent authorities as defined in Article 4, point (2), of Regulation (EU) No 1093/2010 of the European Parliament and of the Council ([29]); or

(b) authorities other than the competent authorities referred to in point (a), provided that national laws, regulations or administrative provisions require those authorities to cooperate with the competent authorities referred to in point (a) whenever necessary in order to carry out their duties under this Directive.

4. Member States shall ensure that the competent authorities fulfil the criteria set out in Article 5 of Regulation (EU) 2017/2394.

5. Member States shall inform the Commission of the designation of the competent authorities and any changes thereto, and, where there is more than one competent authority on their territory, indicate any division of the respective duties between those competent authorities. The first such notification shall be made as soon as possible and at the latest by 20 November 2025.

6. The competent authorities shall exercise their powers in conformity with national law either:

(a) directly under their own authority or under the supervision of the judicial authorities; or

(b) by application to courts which are competent to grant the necessary decision, including, where appropriate, by appeal, if the application to grant the necessary decision is not successful.

7. Where there is more than one competent authority on their territory, Member States shall ensure that their respective duties are clearly defined and that those authorities collaborate closely so that they can discharge their respective duties effectively.

8. The Commission shall publish a list of the competent authorities in the *Official Journal of the European Union* at least once a year, and shall update that list continuously on its website.

([29]) Regulation (EU) No 1093/2010 of the European Parliament and of the Council of 24 November 2010 establishing a European Supervisory Authority (European Banking Authority), amending Decision No 716/2009/EC and repealing Commission Decision 2009/78/EC (OJ L 331, 15.12.2010, p. 12).

9. Member States may apply national legislation to grant product intervention powers to national competent authorities to withdraw credit products in justified cases.

CHAPTER XV

FINAL PROVISIONS

Article 42

Level of harmonisation

1. Insofar as this Directive contains harmonised provisions, Member States may not maintain or introduce in their national law provisions diverging from those laid down in this Directive unless provided otherwise in this Directive.

2. Pending further harmonisation, where a Member State makes use of the regulatory choices provided for in Article 2(5) to (8), Article 8(8), Article 14(2) and (3), Article 16(4) and (6), Article 18(11), Article 24(5), Article 25(6), Article 26(4) and (8), Article 29(4), Article 31(2), Article 32(4) and (5), Article 35(3) and (4), Article 37(3) and Article 41(9), that Member State shall notify the Commission without delay thereof, as well as of any subsequent changes. The Commission shall make that information public on a website or in another easily accessible way. Member States shall also take the appropriate measures to diffuse that information amongst national creditors, credit intermediaries and consumers.

Article 43

Imperative nature of this Directive

1. Member States shall ensure that consumers may not waive the rights conferred on them by the national measures transposing this Directive.

2. Member States shall ensure that the provisions adopted in order to transpose this Directive cannot be circumvented as a result of the way in which agreements are formulated.

Article 44

Penalties

1. Member States shall lay down the rules on penalties applicable to infringements of the national provisions adopted pursuant to this Directive and shall take all measures necessary to ensure that they are implemented. The penalties provided for shall be effective, proportionate and dissuasive. Member States shall, by 20 November 2026, notify the Commission of those rules and of those measures and shall notify it, without delay, of any subsequent amendment affecting them.

2. Member States shall ensure that when penalties are to be imposed in accordance with Article 21 of Regulation (EU) 2017/2394, they include the possibility either to impose fines through administrative procedures or to initiate legal proceedings for the imposition of fines, or both.

3. Member States shall provide that the competent authorities may disclose to the public any administrative penalty that is imposed for infringement of the measures adopted pursuant to this Directive, unless such disclosure would seriously jeopardise the financial markets or cause disproportionate damage to the parties involved.

Article 45

Exercise of the delegation

1. The power to adopt delegated acts is conferred on the Commission subject to the conditions laid down in this Article.

2. The power to adopt delegated acts referred to in Article 30(5) shall be conferred on the Commission for a period of five years from 19 November 2023. The Commission shall draw up a report in respect of the delegation of power not later than nine months before the end of the five-year period. The delegation of power shall be tacitly extended for periods of an identical duration, unless the European Parliament or the Council opposes such extension not later than three months before the end of each period.

3. The delegation of power referred to in Article 30(5) may be revoked at any time by the European Parliament or by the Council. A decision to revoke shall put an end to the delegation of the power specified in that decision. It shall take effect the day following the publication of the decision in the *Official Journal of the European Union* or at a later date specified therein. It shall not affect the validity of any delegated acts already in force.

4. Before adopting a delegated act, the Commission shall consult experts designated by each Member State in accordance with the principles laid down in the Interinstitutional Agreement of 13 April 2016 on Better Law-Making.

5. As soon as it adopts a delegated act, the Commission shall notify it simultaneously to the European Parliament and to the Council.

6. A delegated act adopted pursuant to Article 30(5) shall enter into force only if no objection has been expressed either by the European Parliament or by the Council within a period of three months of notification of that act to the European Parliament and the Council or if, before the expiry of that period, the European Parliament and the Council have both informed the Commission that they will not object. That period shall be extended by two months at the initiative of the European Parliament or of the Council.

Article 46

Review and monitoring

1. The Commission shall undertake, by 20 November 2029 and every four years thereafter, an evaluation of this Directive. The evaluation shall include:

(a) an assessment of whether the scope of this Directive remains appropriate in relation to credit agreements which are secured by non-residential immovable property;

(b) an assessment of the thresholds laid down in Article 2(2), point (c), and in Part II of Annex III, and of the percentages used to calculate the compensation payable in the event of early repayment as referred to in Article 29(2), in the light of economic trends in the Union and the situation in the market concerned;

(c) an analysis of the evolution of the market for consumer credits that support the green transition and an assessment of the need for further measures relating to such credits; and

(d) an assessment of the implementation of Article 44(1) and (2), and in particular of the effectiveness and deterrent effect of the penalties imposed under that Article.

2. By 20 November 2025, the Commission shall assess the necessity of protecting consumers borrowing and investing via crowdfunding platforms, as defined in Article 2(1), point (d) of Regulation (EU) 2020/1503, where those platforms do not act as creditors or credit intermediaries, but facilitate the granting of credit between consumers.

3. The Commission shall, in particular, monitor the effect of the existence of the regulatory choices referred to in Article 42 on the functioning of the internal market and on consumers.

4. The Commission shall report the results of the evaluation and assessment referred to in paragraphs 1, 2 and 3 to the European Parliament and the Council, accompanied, if appropriate, by a legislative proposal.

Article 47

Repeal and transitional provisions

Directive 2008/48/EC is repealed with effect from 20 November 2026.

Notwithstanding the first paragraph, Directive 2008/48/EC shall continue to apply to credit agreements existing on 20 November 2026 until their termination.

However, Articles 23 and 24, Article 25(1), second sentence, Article 25(2) and Articles 28 and 39 of this Directive shall apply to all open-end credit agreements existing on 20 November 2026.

References to the repealed Directive shall be construed as references to this Directive and shall be read in accordance with the correlation table set out in Annex IV.

Article 48

Transposition

1. Member States shall adopt and publish, by 20 November 2025, the laws, regulations and administrative provisions necessary to comply with this Directive. They shall immediately communicate the text of those provisions to the Commission.

They shall apply those measures from 20 November 2026.

When Member States adopt those measures, they shall contain a reference to this Directive or be accompanied by such a reference on the occasion of their official publication. Member States shall determine how such reference is to be made.

2. Member States shall communicate to the Commission the text of the main measures of national law which they adopt in the field covered by this Directive.

Article 49

Entry into force

This Directive shall enter into force on the twentieth day following that of its publication in the *Official Journal of the European Union*.

Article 50

Addressees

This Directive is addressed to the Member States.

Done at Strasbourg, 18 October 2023.

For the European Parliament	*For the Council*
The President	*The President*
R. METSOLA	J. M. ALBARES BUENO

ANNEX I

STANDARD EUROPEAN CONSUMER CREDIT INFORMATION [1]

Key information

Part I [Always on the first page of the form]:

Creditor Where applicable Credit intermediary	[Identity] [Identity]
Total amount of credit *This means the ceiling or the total sums made available under the credit agreement.*	
Duration of the credit agreement	
The borrowing rate or, where applicable, different borrowing rates which apply to the credit agreement	[% — fixed, or — variable, — periods]
Annual percentage rate of charge (APR) *This is the total cost expressed as an annual percentage of the total amount of credit.* *The APR is there to help you compare different offers.*	
Total amount you will have to pay *This means the amount of borrowed capital plus interest and possible costs related to your credit.*	[Sum of total amount of credit and total cost of credit to the consumer]
Where applicable The credit is granted in the form of a deferred payment for specific goods or specific services or is linked to the supply of specific goods or the provision of specific services Name of good/service Cash price	
Costs in the case of late payments	You will be charged [… (applicable interest rate and arrangements for its adjustment and, where applicable, default charges)] for late payments.

[1] Wherever 'where applicable' is indicated, the creditor must fill in the box if the information is relevant to the type of credit, or delete the information or the entire row where the information is not relevant for the type of credit concerned.
The explanations in italics should help the consumer to better understand the figures.
Indications between square brackets provide explanations for the creditor or the credit intermediary and must be replaced with the corresponding information.

Part II [If following elements cannot be displayed in a prominent way on one page, they shall be displayed in the first part of the form on the second page]:

Instalments and, where appropriate, the order in which instalments will be allocated	You will have to pay the following: [The amount, number and frequency of payments to be made by the consumer] Interest and/or charges will be payable in the following manner:
Warning regarding the consequences of missing or late payments *Missing or late payments could have severe consequences for you (e.g. forced sale) and make it more difficult for you to obtain credit in the future.*	
Right of withdrawal *You have the right to withdraw from the credit agreement within a period of 14 calendar days.*	Yes/no
Early repayment *You have the right to repay the credit early at any time fully or partially.* Where applicable The creditor is entitled to compensation in the case of early repayment.	Yes
Creditor Geographical address Telephone number Email address Web address (*)	
Where applicable Credit intermediary Geographical address Telephone number Email address Web address (*)	

(*) This information is optional.

Additional information about the credit agreement

1. **Description of the main features of the credit product**

The type of credit	
The conditions governing the drawdown *This means how and when you will obtain the money.* Where applicable Other drawdown mechanisms for the relevant type of credit agreement may result in higher annual percentage rates of charge	[Where the credit agreement provides different ways of drawdown with different charges or borrowing rates and the creditor uses the assumption set out in Part II, point (b), of Annex III, include an indication that other drawdown mechanisms for the relevant type of credit agreement may result in higher annual percentage rates of charge]
Where applicable Sureties required *This is a description of the security to be provided by you in relation to the credit agreement.*	[Kind of sureties]
Where applicable Repayments do not give rise to immediate amortisation of the capital.	
Where applicable The price was personalised on the basis of automated decision-making.	

2. **Costs of the credit**

Where applicable The different borrowing rates that apply to the credit agreement	[% — fixed, or — variable (with the index or reference rate applicable to the initial borrowing rate), — periods, — conditions governing the application of each borrowing rate, — periods, conditions and procedures for changing each borrowing rate]
Representative example illustrating the annual percentage rate of charge (APR) and the total amount payable by the consumer	[% A representative example mentioning all the assumptions used for calculating the annual percentage rate of charge to be set out here]
Is it compulsory, in order to obtain the credit or to obtain it on the terms and conditions marketed, to take out — an insurance policy securing the credit, or — another ancillary service contract? *If the costs of these services are not known by the creditor, they are not included in the APR.*	Yes/no [if yes, specify the kind of insurance] Yes/no [if yes, specify the kind of ancillary service]

Related costs	
Where applicable Charges for maintaining one or more accounts which are required for recording both payment transactions and drawdowns	
Where applicable Amount of costs for using a specific means of payment (e.g. a credit card)	
Where applicable Any other costs deriving from the credit agreement	
Where applicable Conditions under which the abovementioned costs related to the credit agreement can be changed	
Where applicable Obligation to pay notarial fees	

3. **Other important legal aspects**

Where applicable The creditor is entitled to compensation in the case of early repayment	[Determination of the compensation (calculation method) in accordance with the provisions implementing Article 29 of Directive (EU) 2023/2225 of the European Parliament and of the Council ([1])]
Consultation of a database *The creditor must inform you immediately and without charge of the result of consulting a database, if a credit application is rejected on the basis of such a consultation.*	
Right to a draft credit agreement *You have the right, upon request, to obtain a copy of the draft credit agreement free of charge. This provision applies if the creditor is willing, at the time of your request, to proceed to the conclusion of the credit agreement with you.*	
Where applicable The period of time during which the creditor is bound by the pre-contractual information	The information contained in this form is valid from […] until […].
Concerning redress *You have the right to access an out-of-court complaint and redress mechanism*	[The out-of-court complaint and redress mechanism for the consumer and how to access it]

Warning regarding the legal and financial consequences of non-compliance *Non-compliance with the commitments linked to the credit agreement other than late or missed payments could have severe consequences for you.*	
Repayment schedule	[Repayment schedule containing all payments and repayments to be made by the consumer over the duration of the credit agreement, including the payments for any ancillary services]

([1]) Directive (EU) 2023/2225 of the European Parliament and of the Council of 18 October 2023 on credit agreements for consumers and repealing Directive 2008/48/EC (OJ L, 2023/2225, 30.10.2023, ELI: http://data.europa.eu/eli/dir/2023/2225/oj).

Where applicable

4. **Additional information in the case of the distance marketing of financial services**

(a) Concerning the creditor	
Where applicable Representative of the creditor in your Member State of residence Address Telephone number Email address Web address (*)	[Identity] [Geographical address to be used by the consumer]
Where applicable Registration	[The trade register in which the creditor is entered and their registration number or an equivalent means of identification in that register]
Where applicable The supervisory authority	
(b) Concerning the credit agreement	
Where applicable Exercise of the right of withdrawal	[Practical instructions for exercising the right of withdrawal indicating, inter alia, the period for exercising the right, the address to which notification of exercise of the right of withdrawal should be sent and the consequences of not exercising the right of withdrawal]
Where applicable The law taken by the creditor as the basis for the establishment of relations with you before the conclusion of the credit agreement	
Where applicable Clause stipulating the law applicable to the credit agreement and/or the competent court	[Relevant clause to be set out here]
Where applicable Language regime	Information and contractual terms will be supplied in [specific language]. With your consent, we intend to communicate in [specific language/languages] for the duration of the credit agreement.

(*) This information is optional for the creditor.

ANNEX II

EUROPEAN CONSUMER CREDIT INFORMATION [1]

Consumer credit offered by certain credit organisations (Article 2(6) of Directive (EU) 2023/2225 of the European Parliament and of the Council [2]**)**

Debt conversion (Article 2(7) of Directive (EU) 2023/2225)

Key information

Part I [Always on the first page of the form]:

Creditor Where applicable Credit intermediary	[Identity] [Identity]
The total amount of credit *This means the ceiling or the total sums made available under the credit agreement.*	
The duration of the credit agreement	
The borrowing rate or, where applicable, different borrowing rates which apply to the credit agreement	[% — fixed, or — variable, — periods]
Annual percentage rate of charge (APR) *This is the total cost expressed as an annual percentage of the total amount of credit.* *The APR is there to help you compare different offers.*	
The total amount you will have to pay *This means the amount of borrowed capital plus interest and possible costs related to your credit.*	[Sum of total amount of credit and total cost of credit to the consumer]
Where applicable The credit is granted in the form of a deferred payment for specific goods or specific services or is linked to the supply of specific goods or the provision of specific services Name of good/service Cash price	

(1) Wherever 'where applicable' is indicated, the creditor must fill in the box if the information is relevant to the type of credit, or delete the information or the entire row where the information is not relevant for the type of credit concerned.
The explanations in italics should help the consumer to better understand the figures.
Indications between square brackets provide explanations for the creditor or the credit intermediary and must be replaced with the corresponding information.

(2) Directive (EU) 2023/2225 of the European Parliament and of the Council of 18 October 2023 on credit agreements for consumers and repealing Directive 2008/48/EC (OJ L, 2023/2225, 30.10.2023, ELI: http://data.europa.eu/eli/dir/2023/2225/oj).

Costs in the case of late payments	You will be charged [… (applicable interest rate and arrangements for its adjustment and, where applicable, default charges)] for late payments.

Part II [If the following elements cannot be displayed in a prominent way on one page, they shall be displayed in the first part of the form on the second page]:

Instalments and, where appropriate, the order in which instalments will be allocated	You will have to pay the following: [The amount, number and frequency of payments to be made by the consumer] Interest and/or charges will be payable in the following manner:
Warning regarding the consequences of missing or late payments *Missing or late payments could have severe consequences for you (e.g. forced sale) and make it more difficult for you to obtain credit in the future.*	
Right of withdrawal	Yes/no
Early repayment *You have the right to repay the credit early at any time fully or partially.* Where applicable The creditor is entitled to compensation in the case of early repayment.	
Creditor Geographical address Telephone number Email address Web address (*)	
Where applicable Credit intermediary Geographical address Telephone number Email address Web address (*)	

(*) This information is optional.

Additional information about the credit agreement

1. **Description of the main features of the credit product**

The type of credit	
Where applicable Indication that the consumer may be requested to repay the amount of the credit in full at any time	
Where applicable The price was personalised on the basis of automated decision-making.	

2. **Costs of the credit**

Where applicable The different borrowing rates that apply to the credit agreement	[% — fixed, or — variable (with the index or reference rate applicable to the initial borrowing rate), — periods, — conditions governing the application of each borrowing rate]
Representative example illustrating the annual percentage rate of charge (APR) and the total amount payable by the consumer	[% A representative example mentioning all the assumptions used for calculating the annual percentage rate of charge to be set out here]
Where applicable Costs Where applicable The conditions under which those costs may be changed	[The costs applicable from the time the credit agreement is concluded]

3. **Other important legal aspects**

Termination of the credit agreement	[The conditions and procedure for terminating the credit agreement]
Where applicable The creditor is entitled to compensation in the case of early repayment	[Determination of the compensation (calculation method) in accordance with the provisions implementing Article 29 of Directive (EU) 2023/2225]
Consultation of a database *The creditor must inform you immediately and without charge of the result of consulting a database, if a credit application is rejected on the basis of such a consultation.*	
Where applicable The period of time during which the creditor is bound by the pre-contractual information	The information contained in this form is valid from […] until […].

Concerning redress *You have the right to access an out-of-court complaint and redress mechanism.*	[The out-of-court complaint and redress mechanism for the consumer and how to access it]
Warning regarding the legal and financial consequences of non-compliance *Non-compliance with the commitments linked to the credit agreement other than late or missed payments could have severe consequences for you.*	
Repayment schedule	[Repayment schedule containing all payments and repayments to be made by the consumer over the duration of the contract, including those payments for any ancillary services]

Where applicable

4. **Additional information in the case of the distance marketing of financial services**

(a) Concerning the creditor	
Where applicable Representative of the creditor in your Member State of residence Address Telephone number Email address Web address (*)	[Identity] [Geographical address to be used by the consumer]
Where applicable Registration	[The trade register in which the creditor is entered and their registration number or an equivalent means of identification in that register]
Where applicable The supervisory authority	
(b) Concerning the credit agreement	
Where applicable Exercise of the right of withdrawal	[Practical instructions for exercising the right of withdrawal indicating, inter alia, the withdrawal period, the address to which notification of exercise of the right of withdrawal should be sent and the consequences of not exercising the right of withdrawal]
Where applicable The law taken by the creditor as a basis for the establishment of relations with you before the conclusion of the credit agreement	

Where applicable Clause stipulating the law applicable to the credit agreement and/or the competent court	[Relevant clause to be set out here]
Where applicable Language regime	Information and contractual terms will be supplied in [specific language]. With your consent, we intend to communicate in [specific language/languages] for the duration of the credit agreement.

(*) This information is optional for the creditor.

ANNEX III

I. The basic equation expressing the equivalence of drawdowns on the one hand and repayments and charges on the other.

The basic equation, which establishes the annual percentage rate of charge (APR), equates, on an annual basis, the total present value of drawdowns on the one hand and the total present value of repayments and payments of charges on the other hand, i.e.:

$$\sum_{k=1}^{m} C_k (1+X)^{-t_k} = \sum_{l=1}^{m'} D_l (1+X)^{-S_l}$$

where:

– X	is the APR,
– m	is the number of the last drawdown,
– k	is the number of a drawdown, thus $1 \leq k \leq m$,
– C_k	is the amount of drawdown k,
– t_k	is the interval, expressed in years and fractions of a year, between the date of the first drawdown and the date of each subsequent drawdown, thus $t_1 = 0$,
– m'	is the number of the last repayment or payment of charges,
– l	is the number of a repayment or payment of charges,
– D_l	is the amount of a repayment or payment of charges,
– s_l	is the interval, expressed in years and fractions of a year, between the date of the first drawdown and the date of each repayment or payment of charges.

Remarks

(a) The amounts paid by both parties at different times shall not necessarily be equal and shall not necessarily be paid at equal intervals.

(b) The starting date shall be that of the first drawdown.

(c) Intervals between dates used in the calculations shall be expressed in years or in fractions of a year. A year is presumed to have 365 days (or 366 days for leap years), 52 weeks or 12 equal months. A month is presumed to have 30,41666 days (i.e. 365/12) regardless of whether or not it is a leap year.

Where intervals between dates used in the calculations cannot be expressed as a whole number of weeks, months or years, the intervals shall be expressed as a whole number of one of those periods in combination with a number of days. When using days:

(i) every day shall be counted, including weekends and holidays;

(ii) equal periods and then days shall be counted backwards to the date of the initial drawdown;

(iii) the length of the period of days shall be obtained excluding the first day and including the last day and shall be expressed in years by dividing this period by the number of days (365 or 366) of the complete year counted backwards from the last day to the same day of the previous year.

(d) The result of the calculation shall be expressed with an accuracy of at least one decimal place. If the figure at the following decimal place is greater than or equal to 5, the figure at that particular decimal place shall be increased by one.

(e) The equation can be rewritten using a single sum and the concept of flows (A_k), which can be positive or negative, in other words either paid or received during periods 1 to n, expressed in years, i.e.:

$$S = \sum_{k=1}^{n} A_k (1 + X)^{-t_k}$$

,

where S is the present balance of flows. If the aim is to maintain the equivalence of flows, the value of S will be zero.

II. The additional assumptions for calculating the APR shall be as follows.

(a) Where a credit agreement gives the consumer freedom of drawdown, the total amount of credit shall be deemed to be drawn down immediately and in full.

(b) Where a credit agreement gives the consumer freedom of drawdown in general but imposes, amongst the different ways of drawing down, a limitation with regard to the amount of credit and period of time, the amount of credit shall be deemed to be drawn down on the earliest date fixed in the credit agreement and in accordance with those drawdown limits.

(c) Where a credit agreement provides different ways of drawing down with different charges or borrowing rates, the total amount of credit shall be deemed to be drawn down at the highest charge and borrowing rate applied to the most common drawdown mechanism for that type of credit agreement.

(d) In the case of an overdraft facility, the total amount of credit shall be deemed to be drawn down in full and for the whole duration of the credit agreement. If the duration of the overdraft facility is not known, the APR shall be calculated on the assumption that the duration of the credit is three months.

(e) In the case of an open-end credit agreement, other than an overdraft facility, it shall be assumed that:

(i) the credit is provided for a period of one year starting from the date of the initial drawdown, and that the final payment made by the consumer clears the balance of capital, interest and other charges, if any;

(ii) the capital is repaid by the consumer in equal monthly payments, starting one month after the date of the initial drawdown. However, in cases where the capital must be repaid only in full in a single payment, within each payment period, successive drawdowns and repayments of the entire capital by the consumer shall be assumed to occur over the period of one year. Interest and other charges shall be applied in accordance with those drawdowns and repayments of capital and as set out in the credit agreement.

For the purposes of this point, an open-end credit agreement is a credit agreement without a fixed duration and includes credits that must be repaid in full within or after a period but, once repaid, become available to be drawn down again.

(f) In the case of credit agreements other than overdrafts and open-end credit agreements as referred to in the assumptions set out in points (d) and (e):

(i) where the date or amount of a repayment of capital to be made by the consumer cannot be ascertained, it shall be assumed that the repayment is made at the earliest date provided for in the credit agreement and is for the lowest amount for which the credit agreement provides;

(ii) where the interval between the date of initial drawdown and the date of the first payment to be made by the consumer cannot be ascertained, it shall be assumed to be the shortest interval.

(g) Where the date or amount of a payment to be made by the consumer cannot be ascertained on the basis of the credit agreement or the assumptions set out in point (d), (e) or (f), it shall be assumed that the payment is made in accordance with the dates and conditions required by the creditor and, when those dates and conditions are unknown:

(i) interest charges are paid together with the repayments of capital;

(ii) a non-interest charge expressed as a single sum is paid at the date of the conclusion of the credit agreement;

(iii) non-interest charges expressed as several payments are paid at regular intervals, starting with the date of the first repayment of capital, and where the amount of such payments is not known they shall be assumed to be equal amounts;

(iv) the final payment clears the balance of capital, interest and other charges, if any.

(h) Where the ceiling applicable to the credit has not yet been agreed, it is assumed to be EUR 1 500.

(i) Where different borrowing rates and charges are offered for a limited period or amount, the borrowing rate and the charges shall be deemed to be the highest rate for the whole duration of the credit agreement.

(j) For credit agreements for consumers for which a fixed borrowing rate is agreed for the initial period, at the end of which a new borrowing rate is determined and subsequently periodically adjusted according to an agreed indicator, the calculation of the APR shall be based on the assumption that, at the end of the fixed borrowing rate period, the borrowing rate is the same as at the time of calculating the APR, based on the value of the agreed indicator at that time.

ANNEX IV

Correlation table

Directive 2008/48/EC	This Directive
Article 1	Article 1
Article 2(1)	Article 2(1)
–	
Article 2(2), points (a), (b) and (c)	Article 2(2), points (a), (b) and (c)
Article 2(2), point (d)	Article 2(2), point (g)
Article 2(2), points (e) and (f)	–
Article 2(2), points (g), (h), (i), (j), (k) and (l)	Article 2(2), points (d), (e), (f), (i), (j) and (k)
Article 2(2a)	Article 2(3)
Article 2(3)	–
Article 2(4), (5) and (6)	Article 2(4), (6) and (7)
Article 3, points (a), (b) and (c)	Article 3, points 1, 2 and 3
–	Article 3, point 4
Article 3, points (d) and (e)	Article 3, points 18 and 19
Article 3, point (f)	Article 3, point 12
Article 3, points (g), (h), (i), (j), (k), (l) and (m)	Article 3, points 5, 6, 7, 8, 9, 10 and 11
Article 3, point (n)	Article 3, point 20
–	Article 3, points 13, 14, 15, 16, 17, 18, 21 and 22
–	Article 5
–	Article 6
–	Article 7
Article 4	Article 8
–	Article 9
Article 5(1)	Article 10(1), (3), (5) and (6)
Article 5(2)	Article 10(7)
Article 5(4)	Article 10(8)
Article 5(5)	Article 10(9)
Article 5(6)	Article 12(1), points (a), (b) and (c), and Article 12(2)
Article 6(1) and (3)	Article 11(1), (2) and (4)
Article 6(2)	–
Article 6(4)	Article 11(6)
Article 6(5)	–
Article 6(6)	Article 11(7)
Article 6(7)	–
Article 7	Article 10(10) and Article 11(8)
–	Article 13

Article 8	Article 18
–	Article 14
–	Article 15
–	Article 16
–	Article 17
Article 9	Article 19
Article 10(1)	Article 20
Article 10(2), 10(3) and 10(4)	Article 21
Article 10(5)	–
Article 11a	Article 22
Article 11	Article 23
Article 12	Article 24
Article 13	Article 28
Article 14	Article 26
Article 15	Article 27
Article 16	Article 29
Article 17	Article 39
Article 18	Article 25
Article 19	Article 30
–	Article 31
–	Article 32
–	Article 33
–	Article 34
Article 16a	Article 35
–	Article 36
Article 20	Article 37
Article 21	Article 38
–	Article 41
Article 22	Articles 42 and 43
Article 23	Article 44
Article 24	Article 40
Article 24a	Article 45
Article 26	Article 42(2)
Article 27(1)	Article 48
Article 27(2)	Article 46
Article 28	Article 4
Article 29	Article 47
Article 30	Article 47
Article 31	Article 49

Article 32	Article 50
Annex I	Annex III
Annex II	Annex I
Annex III	Annex II
–	Annex IV

I

(Legislative acts)

REGULATIONS

REGULATION (EU) 2022/2554 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 14 December 2022

on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011

(Text with EEA relevance)

THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION,

Having regard to the Treaty on the Functioning of the European Union, and in particular Article 114 thereof,

Having regard to the proposal from the European Commission,

After transmission of the draft legislative act to the national parliaments,

Having regard to the opinion of the European Central Bank ([1]),

Having regard to the opinion of the European Economic and Social Committee ([2]),

Acting in accordance with the ordinary legislative procedure ([3]),

Whereas:

(1) In the digital age, information and communication technology (ICT) supports complex systems used for everyday activities. It keeps our economies running in key sectors, including the financial sector, and enhances the functioning of the internal market. Increased digitalisation and interconnectedness also amplify ICT risk, making society as a whole, and the financial system in particular, more vulnerable to cyber threats or ICT disruptions. While the ubiquitous use of ICT systems and high digitalisation and connectivity are today core features of the activities of Union financial entities, their digital resilience has yet to be better addressed and integrated into their broader operational frameworks.

(2) The use of ICT has in the past decades gained a pivotal role in the provision of financial services, to the point where it has now acquired a critical importance in the operation of typical daily functions of all financial entities. Digitalisation now covers, for instance, payments, which have increasingly moved from cash and paper-based methods to the use of digital solutions, as well as securities clearing and settlement, electronic and algorithmic trading, lending and funding operations, peer-to-peer finance, credit rating, claim management and back-office operations. The insurance sector has also been transformed by the use of ICT, from the emergence of insurance

([1]) OJ C 343, 26.8.2021, p. 1.
([2]) OJ C 155, 30.4.2021, p. 38.
([3]) Position of the European Parliament of 10 November 2022 (not yet published in the Official Journal) and decision of the Council of 28 November 2022.

intermediaries offering their services online operating with InsurTech, to digital insurance underwriting. Finance has not only become largely digital throughout the whole sector, but digitalisation has also deepened interconnections and dependencies within the financial sector and with third-party infrastructure and service providers.

(3) The European Systemic Risk Board (ESRB) reaffirmed in a 2020 report addressing systemic cyber risk how the existing high level of interconnectedness across financial entities, financial markets and financial market infrastructures, and particularly the interdependencies of their ICT systems, could constitute a systemic vulnerability because localised cyber incidents could quickly spread from any of the approximately 22 000 Union financial entities to the entire financial system, unhindered by geographical boundaries. Serious ICT breaches that occur in the financial sector do not merely affect financial entities taken in isolation. They also smooth the way for the propagation of localised vulnerabilities across the financial transmission channels and potentially trigger adverse consequences for the stability of the Union's financial system, such as generating liquidity runs and an overall loss of confidence and trust in financial markets.

(4) In recent years, ICT risk has attracted the attention of international, Union and national policy makers, regulators and standard-setting bodies in an attempt to enhance digital resilience, set standards and coordinate regulatory or supervisory work. At international level, the Basel Committee on Banking Supervision, the Committee on Payments and Market Infrastructures, the Financial Stability Board, the Financial Stability Institute, as well as the G7 and G20 aim to provide competent authorities and market operators across various jurisdictions with tools to bolster the resilience of their financial systems. That work has also been driven by the need to duly consider ICT risk in the context of a highly interconnected global financial system and to seek more consistency of relevant best practices.

(5) Despite Union and national targeted policy and legislative initiatives, ICT risk continues to pose a challenge to the operational resilience, performance and stability of the Union financial system. The reforms that followed the 2008 financial crisis primarily strengthened the financial resilience of the Union financial sector and aimed to safeguard the competitiveness and stability of the Union from economic, prudential and market conduct perspectives. Although ICT security and digital resilience are part of operational risk, they have been less in the focus of the post-financial crisis regulatory agenda and have developed in only some areas of the Union's financial services policy and regulatory landscape, or in only a few Member States.

(6) In its Communication of 8 March 2018 entitled 'FinTech Action plan: For a more competitive and innovative European financial sector', the Commission highlighted the paramount importance of making the Union financial sector more resilient, including from an operational perspective to ensure its technological safety and good functioning, its quick recovery from ICT breaches and incidents, ultimately enabling the effective and smooth provision of financial services across the whole Union, including under situations of stress, while also preserving consumer and market trust and confidence.

(7) In April 2019, the European Supervisory Authority (European Banking Authority), (EBA) established by Regulation (EU) No 1093/2010 of the European Parliament and of the Council ([4]), the European Supervisory Authority (European Insurance and Occupational Pensions Authority), ('EIOPA') established by Regulation (EU) No 1094/2010 of the European Parliament and of the Council ([5]) and the European Supervisory Authority (European Securities and Markets Authority), ('ESMA') established by Regulation (EU) No 1095/2010 of the

([4]) Regulation (EU) No 1093/2010 of the European Parliament and of the Council of 24 November 2010 establishing a European Supervisory Authority (European Banking Authority), amending Decision No 716/2009/EC and repealing Commission Decision 2009/78/EC (OJ L 331, 15.12.2010, p. 12).

([5]) Regulation (EU) No 1094/2010 of the European Parliament and of the Council of 24 November 2010 establishing a European Supervisory Authority (European Insurance and Occupational Pensions Authority), amending Decision No 716/2009/EC and repealing Commission Decision 2009/79/EC (OJ L 331, 15.12.2010, p. 48).

European Parliament and of the Council ([6]) (known collectively as 'European Supervisory Authorities' or 'ESAs') jointly issued technical advice calling for a coherent approach to ICT risk in finance and recommending to strengthen, in a proportionate way, the digital operational resilience of the financial services industry through a sector-specific initiative of the Union.

(8) The Union financial sector is regulated by a Single Rulebook and governed by a European system of financial supervision. Nonetheless, provisions tackling digital operational resilience and ICT security are not yet fully or consistently harmonised, despite digital operational resilience being vital for ensuring financial stability and market integrity in the digital age, and no less important than, for example, common prudential or market conduct standards. The Single Rulebook and system of supervision should therefore be developed to also cover digital operational resilience, by strengthening the mandates of competent authorities to enable them to supervise the management of ICT risk in the financial sector in order to protect the integrity and efficiency of the internal market, and to facilitate its orderly functioning.

(9) Legislative disparities and uneven national regulatory or supervisory approaches with regard to ICT risk trigger obstacles to the functioning of the internal market in financial services, impeding the smooth exercise of the freedom of establishment and the provision of services for financial entities operating on a cross-border basis. Competition between the same type of financial entities operating in different Member States could also be distorted. This is the case, in particular, for areas where Union harmonisation has been very limited, such as digital operational resilience testing, or absent, such as the monitoring of ICT third-party risk. Disparities stemming from developments envisaged at national level could generate further obstacles to the functioning of the internal market to the detriment of market participants and financial stability.

(10) To date, due to the ICT risk related provisions being only partially addressed at Union level, there are gaps or overlaps in important areas, such as ICT-related incident reporting and digital operational resilience testing, and inconsistencies as a result of emerging divergent national rules or cost-ineffective application of overlapping rules. This is particularly detrimental for an ICT-intensive user such as the financial sector since technology risks have no borders and the financial sector deploys its services on a wide cross-border basis within and outside the Union. Individual financial entities operating on a cross-border basis or holding several authorisations (e.g. one financial entity can have a banking, an investment firm, and a payment institution licence, each issued by a different competent authority in one or several Member States) face operational challenges in addressing ICT risk and mitigating adverse impacts of ICT incidents on their own and in a coherent cost-effective way.

(11) As the Single Rulebook has not been accompanied by a comprehensive ICT or operational risk framework, further harmonisation of key digital operational resilience requirements for all financial entities is required. The development of ICT capabilities and overall resilience by financial entities, based on those key requirements, with a view to withstanding operational outages, would help preserve the stability and integrity of the Union financial markets and thus contribute to ensuring a high level of protection of investors and consumers in the Union. Since this Regulation aims to contribute to the smooth functioning of the internal market, it should be based on the provisions of Article 114 of the Treaty on the Functioning of the European Union (TFEU) as interpreted in accordance with the consistent case law of the Court of Justice of the European Union (Court of Justice).

(12) This Regulation aims to consolidate and upgrade ICT risk requirements as part of the operational risk requirements that have, up to this point, been addressed separately in various Union legal acts. While those acts covered the main categories of financial risk (e.g. credit risk, market risk, counterparty credit risk and liquidity risk, market conduct risk), they did not comprehensively tackle, at the time of their adoption, all components of operational resilience. The operational risk rules, when further developed in those Union legal acts, often favoured a traditional quantitative approach to addressing risk (namely setting a capital requirement to cover ICT risk) rather than targeted qualitative rules for the protection, detection, containment, recovery and repair capabilities against ICT-related

([6]) Regulation (EU) No 1095/2010 of the European Parliament and of the Council of 24 November 2010 establishing a European Supervisory Authority (European Securities and Markets Authority), amending Decision No 716/2009/EC and repealing Commission Decision 2009/77/EC (OJ L 331, 15.12.2010, p. 84).

incidents, or for reporting and digital testing capabilities. Those acts were primarily meant to cover and update essential rules on prudential supervision, market integrity or conduct. By consolidating and upgrading the different rules on ICT risk, all provisions addressing digital risk in the financial sector should for the first time be brought together in a consistent manner in one single legislative act. Therefore, this Regulation fills in the gaps or remedies inconsistencies in some of the prior legal acts, including in relation to the terminology used therein, and explicitly refers to ICT risk via targeted rules on ICT risk-management capabilities, incident reporting, operational resilience testing and ICT third-party risk monitoring. This Regulation should thus also raise awareness of ICT risk and acknowledge that ICT incidents and a lack of operational resilience have the possibility to jeopardise the soundness of financial entities.

(13) Financial entities should follow the same approach and the same principle-based rules when addressing ICT risk taking into account their size and overall risk profile, and the nature, scale and complexity of their services, activities and operations. Consistency contributes to enhancing confidence in the financial system and preserving its stability especially in times of high reliance on ICT systems, platforms and infrastructures, which entails increased digital risk. Observing basic cyber hygiene should also avoid imposing heavy costs on the economy by minimising the impact and costs of ICT disruptions.

(14) A Regulation helps reduce regulatory complexity, fosters supervisory convergence and increases legal certainty, and also contributes to limiting compliance costs, especially for financial entities operating across borders, and to reducing competitive distortions. Therefore, the choice of a Regulation for the establishment of a common framework for the digital operational resilience of financial entities is the most appropriate way to guarantee a homogenous and coherent application of all components of ICT risk management by the Union financial sector.

(15) Directive (EU) 2016/1148 of the European Parliament and of the Council ([7]) was the first horizontal cybersecurity framework enacted at Union level, applying also to three types of financial entities, namely credit institutions, trading venues and central counterparties. However, since Directive (EU) 2016/1148 set out a mechanism of identification at national level of operators of essential services, only certain credit institutions, trading venues and central counterparties that were identified by the Member States, have been brought into its scope in practice, and hence required to comply with the ICT security and incident notification requirements laid down in it. Directive (EU) 2022/2555 of the European Parliament and of the Council ([8]) sets a uniform criterion to determine the entities falling within its scope of application (size-cap rule) while also keeping the three types of financial entities in its scope.

(16) However, as this Regulation increases the level of harmonisation of the various digital resilience components, by introducing requirements on ICT risk management and ICT-related incident reporting that are more stringent in comparison to those laid down in the current Union financial services law, this higher level constitutes an increased harmonisation also in comparison with the requirements laid down in Directive (EU) 2022/2555. Consequently, this Regulation constitutes *lex specialis* with regard to Directive (EU) 2022/2555. At the same time, it is crucial to maintain a strong relationship between the financial sector and the Union horizontal cybersecurity framework as currently laid out in Directive (EU) 2022/2555 to ensure consistency with the cyber security strategies adopted by Member States and to allow financial supervisors to be made aware of cyber incidents affecting other sectors covered by that Directive.

([7]) Directive (EU) 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union (OJ L 194, 19.7.2016, p. 1).

([8]) Directive (EU) 2022/2555 of the European Parliament and of the Council of 14 December 2022 on measures for a high common level of cybersecurity across the Union, amending Regulation (EU) No 910/2014 and Directive (EU) 2018/1972, and repealing Directive (EU) 2016/1148 (NIS 2 Directive) (see page 80 of this Official Journal).

(17) In accordance with Article 4(2) of the Treaty on European Union and without prejudice to the judicial review by the Court of Justice, this Regulation should not affect the responsibility of Member States with regard to essential State functions concerning public security, defence and the safeguarding of national security, for example concerning the supply of information which would be contrary to the safeguarding of national security.

(18) To enable cross-sector learning and to effectively draw on experiences of other sectors in dealing with cyber threats, the financial entities referred to in Directive (EU) 2022/2555 should remain part of the 'ecosystem' of that Directive (for example, Cooperation Group and computer security incident response teams (CSIRTs)).The ESAs and national competent authorities should be able to participate in the strategic policy discussions and the technical workings of the Cooperation Group under that Directive, and to exchange information and further cooperate with the single points of contact designated or established in accordance with that Directive. The competent authorities under this Regulation should also consult and cooperate with the CSIRTs. The competent authorities should also be able to request technical advice from the competent authorities designated or established in accordance with Directive (EU) 2022/2555 and establish cooperation arrangements that aim to ensure effective and fast-response coordination mechanisms.

(19) Given the strong interlinkages between the digital resilience and the physical resilience of financial entities, a coherent approach with regard to the resilience of critical entities is necessary in this Regulation and Directive (EU) 2022/2557 of the European Parliament and the Council ([9]). Given that the physical resilience of financial entities is addressed in a comprehensive manner by the ICT risk management and reporting obligations covered by this Regulation, the obligations laid down in Chapters III and IV of Directive (EU) 2022/2557 should not apply to financial entities falling within the scope of that Directive.

(20) Cloud computing service providers are one category of digital infrastructure covered by Directive (EU) 2022/2555. The Union Oversight Framework ('Oversight Framework') established by this Regulation applies to all critical ICT third-party service providers, including cloud computing service providers providing ICT services to financial entities, and should be considered complementary to the supervision carried out pursuant to Directive (EU) 2022/2555. Moreover, the Oversight Framework established by this Regulation should cover cloud computing service providers in the absence of a Union horizontal framework establishing a digital oversight authority.

(21) In order to maintain full control over ICT risk, financial entities need to have comprehensive capabilities to enable a strong and effective ICT risk management, as well as specific mechanisms and policies for handling all ICT-related incidents and for reporting major ICT-related incidents. Likewise, financial entities should have policies in place for the testing of ICT systems, controls and processes, as well as for managing ICT third-party risk. The digital operational resilience baseline for financial entities should be increased while also allowing for a proportionate application of requirements for certain financial entities, particularly microenterprises, as well as financial entities subject to a simplified ICT risk management framework. To facilitate an efficient supervision of institutions for occupational retirement provision that is proportionate and addresses the need to reduce administrative burdens on the competent authorities, the relevant national supervisory arrangements in respect of such financial entities should take into account their size and overall risk profile, and the nature, scale and complexity of their services, activities and operations even when the relevant thresholds established in Article 5 of Directive (EU) 2016/2341 of the European Parliament and of the Council ([10]) are exceeded. In particular, supervisory activities should focus primarily on the need to address serious risks associated with the ICT risk management of a particular entity.

([9]) Directive (EU) 2022/2557 of the European Parliament and of the Council of 14 December 2022 on the resilience of critical entities and repealing Council Directive 2008/114/EC (see page 164 of this Official Journal).

([10]) Directive (EU) 2016/2341 of the European Parliament and of the Council of 14 December 2016 on the activities and supervision of institutions for occupational retirement provision (IORPs) (OJ L 354, 23.12.2016, p. 37).

Competent authorities should also maintain a vigilant but proportionate approach in relation to the supervision of institutions for occupational retirement provision which, in accordance with Article 31 of Directive (EU) 2016/2341, outsource a significant part of their core business, such as asset management, actuarial calculations, accounting and data management, to service providers.

(22) ICT-related incident reporting thresholds and taxonomies vary significantly at national level. While common ground may be achieved through the relevant work undertaken by the European Union Agency for Cybersecurity (ENISA) established by Regulation (EU) 2019/881 of the European Parliament and of the Council ([11]) and the Cooperation Group under Directive (EU) 2022/2555, divergent approaches on setting the thresholds and use of taxonomies still exist, or can emerge, for the remainder of financial entities. Due to those divergences, there are multiple requirements that financial entities must comply with, especially when operating across several Member States and when part of a financial group. Moreover, such divergences have the potential to hinder the creation of further uniform or centralised Union mechanisms that speed up the reporting process and support a quick and smooth exchange of information between competent authorities, which is crucial for addressing ICT risk in the event of large-scale attacks with potentially systemic consequences.

(23) To reduce the administrative burden and potentially duplicative reporting obligations for certain financial entities, the requirement for the incident reporting pursuant to Directive (EU) 2015/2366 of the European Parliament and of the Council ([12]) should cease to apply to payment service providers that fall within the scope of this Regulation. Consequently, credit institutions, e-money institutions, payment institutions and account information service providers, as referred to in Article 33(1) of that Directive, should, from the date of application of this Regulation, report pursuant to this Regulation, all operational or security payment-related incidents which have been previously reported pursuant to that Directive, irrespective of whether such incidents are ICT-related.

(24) To enable competent authorities to fulfil supervisory roles by acquiring a complete overview of the nature, frequency, significance and impact of ICT-related incidents and to enhance the exchange of information between relevant public authorities, including law enforcement authorities and resolution authorities, this Regulation should lay down a robust ICT-related incident reporting regime whereby the relevant requirements address current gaps in financial services law, and remove existing overlaps and duplications to alleviate costs. It is essential to harmonise the ICT-related incident reporting regime by requiring all financial entities to report to their competent authorities through a single streamlined framework as set out in this Regulation. In addition, the ESAs should be empowered to further specify relevant elements for the ICT-related incident reporting framework, such as taxonomy, timeframes, data sets, templates and applicable thresholds. To ensure full consistency with Directive (EU) 2022/2555, financial entities should be allowed, on a voluntary basis, to notify significant cyber threats to the relevant competent authority, when they consider that the cyber threat is of relevance to the financial system, service users or clients.

(25) Digital operational resilience testing requirements have been developed in certain financial subsectors setting out frameworks that are not always fully aligned. This leads to a potential duplication of costs for cross-border financial entities and makes the mutual recognition of the results of digital operational resilience testing complex which, in turn, can fragment the internal market.

([11]) Regulation (EU) 2019/881 of the European Parliament and of the Council of 17 April 2019 on ENISA (the European Union Agency for Cybersecurity) and on information and communications technology cybersecurity certification and repealing Regulation (EU) No 526/2013 (Cybersecurity Act) (OJ L 151, 7.6.2019, p. 15).

([12]) Directive (EU) 2015/2366 of the European Parliament and of the Council of 25 November 2015 on payment services in the internal market, amending Directives 2002/65/EC, 2009/110/EC and 2013/36/EU and Regulation (EU) No 1093/2010, and repealing Directive 2007/64/EC (OJ L 337, 23.12.2015, p. 35).

(26) In addition, where no ICT testing is required, vulnerabilities remain undetected and result in exposing a financial entity to ICT risk and ultimately create a higher risk to the stability and integrity of the financial sector. Without Union intervention, digital operational resilience testing would continue to be inconsistent and would lack a system of mutual recognition of ICT testing results across different jurisdictions. In addition, as it is unlikely that other financial subsectors would adopt testing schemes on a meaningful scale, they would miss out on the potential benefits of a testing framework, in terms of revealing ICT vulnerabilities and risks, and testing defence capabilities and business continuity, which contributes to increasing the trust of customers, suppliers and business partners. To remedy those overlaps, divergences and gaps, it is necessary to lay down rules for a coordinated testing regime and thereby facilitate the mutual recognition of advanced testing for financial entities meeting the criteria set out in this Regulation.

(27) Financial entities' reliance on the use of ICT services is partly driven by their need to adapt to an emerging competitive digital global economy, to boost their business efficiency and to meet consumer demand. The nature and extent of such reliance has been continuously evolving in recent years, driving cost reduction in financial intermediation, enabling business expansion and scalability in the deployment of financial activities while offering a wide range of ICT tools to manage complex internal processes.

(28) The extensive use of ICT services is evidenced by complex contractual arrangements, whereby financial entities often encounter difficulties in negotiating contractual terms that are tailored to the prudential standards or other regulatory requirements to which they are subject, or otherwise in enforcing specific rights, such as access or audit rights, even when the latter are enshrined in their contractual arrangements. Moreover, many of those contractual arrangements do not provide for sufficient safeguards allowing for the fully-fledged monitoring of subcontracting processes, thus depriving the financial entity of its ability to assess the associated risks. In addition, as ICT third-party service providers often provide standardised services to different types of clients, such contractual arrangements do not always cater adequately for the individual or specific needs of financial industry actors.

(29) Even though Union financial services law contains certain general rules on outsourcing, monitoring of the contractual dimension is not fully anchored into Union law. In the absence of clear and bespoke Union standards applying to the contractual arrangements concluded with ICT third-party service providers, the external source of ICT risk is not comprehensively addressed. Consequently, it is necessary to set out certain key principles to guide financial entities' management of ICT third-party risk, which are of particular importance when financial entities resort to ICT third-party service providers to support their critical or important functions. Those principles should be accompanied by a set of core contractual rights in relation to several elements in the performance and termination of contractual arrangements with a view to providing certain minimum safeguards in order to strengthen financial entities' ability to effectively monitor all ICT risk emerging at the level of third-party service providers. Those principles are complementary to the sectoral law applicable to outsourcing.

(30) A certain lack of homogeneity and convergence regarding the monitoring of ICT third-party risk and ICT third-party dependencies is evident today. Despite efforts to address outsourcing, such as EBA Guidelines on outsourcing of 2019 and ESMA Guidelines on outsourcing to cloud service providers of 2021 the broader issue of counteracting systemic risk which may be triggered by the financial sector's exposure to a limited number of critical ICT third-party service providers is not sufficiently addressed by Union law. The lack of rules at Union level is compounded by the absence of national rules on mandates and tools that allow financial supervisors to acquire a good understanding of ICT third-party dependencies and to monitor adequately risks arising from the concentration of ICT third-party dependencies.

(31) Taking into account the potential systemic risk entailed by increased outsourcing practices and by the ICT third-party concentration, and mindful of the insufficiency of national mechanisms in providing financial supervisors with adequate tools to quantify, qualify and redress the consequences of ICT risk occurring at critical ICT third-party service providers, it is necessary to establish an appropriate Oversight Framework allowing for a continuous monitoring of the activities of ICT third-party service providers that are critical ICT third-party service providers to financial entities, while ensuring that the confidentiality and security of customers other than financial entities is preserved. While intra-group provision of ICT services entails specific risks and benefits, it should not be automatically considered less risky than the provision of ICT services by providers outside of a financial group and should therefore be subject to the same regulatory framework. However, when ICT services are provided from within the same financial group, financial entities might have a higher level of control over intra-group providers, which ought to be taken into account in the overall risk assessment.

(32) With ICT risk becoming more and more complex and sophisticated, good measures for the detection and prevention of ICT risk depend to a great extent on the regular sharing between financial entities of threat and vulnerability intelligence. Information sharing contributes to creating increased awareness of cyber threats. In turn, this enhances the capacity of financial entities to prevent cyber threats from becoming real ICT-related incidents and enables financial entities to more effectively contain the impact of ICT-related incidents and to recover faster. In the absence of guidance at Union level, several factors seem to have inhibited such intelligence sharing, in particular uncertainty about its compatibility with data protection, anti-trust and liability rules.

(33) In addition, doubts about the type of information that can be shared with other market participants, or with non-supervisory authorities (such as ENISA, for analytical input, or Europol, for law enforcement purposes) lead to useful information being withheld. Therefore, the extent and quality of information sharing currently remains limited and fragmented, with relevant exchanges mostly being local (by way of national initiatives) and with no consistent Union-wide information-sharing arrangements tailored to the needs of an integrated financial system. It is therefore important to strengthen those communication channels.

(34) Financial entities should be encouraged to exchange among themselves cyber threat information and intelligence, and to collectively leverage their individual knowledge and practical experience at strategic, tactical and operational levels with a view to enhancing their capabilities to adequately assess, monitor, defend against, and respond to cyber threats, by participating in information sharing arrangements. It is therefore necessary to enable the emergence at Union level of mechanisms for voluntary information-sharing arrangements which, when conducted in trusted environments, would help the community of the financial industry to prevent and collectively respond to cyber threats by quickly limiting the spread of ICT risk and impeding potential contagion throughout the financial channels. Those mechanisms should comply with the applicable competition law rules of the Union set out in the Communication from the Commission of 14 January 2011 entitled 'Guidelines on the applicability of Article 101 of the Treaty on the Functioning of the European Union to horizontal cooperation agreements', as well as with Union data protection rules, in particular Regulation (EU) 2016/679 of the European Parliament and of the Council ([13]). They should operate based on the use of one or more of the legal bases that are laid down in Article 6 of that Regulation, such as in the context of the processing of personal data that is necessary for the purposes of the legitimate interest pursued by the controller or by a third party, as referred to in Article 6(1), point (f), of that Regulation, as well as in the context of the processing of personal data necessary for compliance with a legal obligation to which the controller is subject, necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller, as referred to in Article 6(1), points (c) and (e), respectively, of that Regulation.

([13]) Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ L 119, 4.5.2016, p. 1).

(35) In order to maintain a high level of digital operational resilience for the whole financial sector, and at the same time to keep pace with technological developments, this Regulation should address risk stemming from all types of ICT services. To that end, the definition of ICT services in the context of this Regulation should be understood in a broad manner, encompassing digital and data services provided through ICT systems to one or more internal or external users on an ongoing basis. That definition should, for instance, include so called 'over the top' services, which fall within the category of electronic communications services. It should exclude only the limited category of traditional analogue telephone services qualifying as Public Switched Telephone Network (PSTN) services, landline services, Plain Old Telephone Service (POTS), or fixed-line telephone services.

(36) Notwithstanding the broad coverage envisaged by this Regulation, the application of the digital operational resilience rules should take into account the significant differences between financial entities in terms of their size and overall risk profile. As a general principle, when distributing resources and capabilities for the implementation of the ICT risk management framework, financial entities should duly balance their ICT-related needs to their size and overall risk profile, and the nature, scale and complexity of their services, activities and operations, while competent authorities should continue to assess and review the approach of such distribution.

(37) Account information service providers, referred to in Article 33(1) of Directive (EU) 2015/2366, are explicitly included in the scope of this Regulation, taking into account the specific nature of their activities and the risks arising therefrom. In addition, electronic money institutions and payment institutions exempted pursuant to Article 9(1) of Directive 2009/110/EC of the European Parliament and of the Council ([14]) and Article 32(1) of Directive (EU) 2015/2366 are included in the scope of this Regulation even if they have not been granted authorisation in accordance Directive 2009/110/EC to issue electronic money, or if they have not been granted authorisation in accordance with Directive (EU) 2015/2366 to provide and execute payment services. However, post office giro institutions, referred to in Article 2(5), point (3), of Directive 2013/36/EU of the European Parliament and of the Council ([15]), are excluded from the scope of this Regulation. The competent authority for payment institutions exempted pursuant to Directive (EU) 2015/2366, electronic money institutions exempted pursuant to Directive 2009/110/EC and account information service providers as referred to in Article 33(1) of Directive (EU) 2015/2366, should be the competent authority designated in accordance with Article 22 of Directive (EU) 2015/2366.

(38) As larger financial entities might enjoy wider resources and can swiftly deploy funds to develop governance structures and set up various corporate strategies, only financial entities that are not microenterprises in the sense of this Regulation should be required to establish more complex governance arrangements. Such entities are better equipped in particular to set up dedicated management functions for supervising arrangements with ICT third-party service providers or for dealing with crisis management, to organise their ICT risk management according to the three lines of defence model, or to set up an internal risk management and control model, and to submit their ICT risk management framework to internal audits.

(39) Some financial entities benefit from exemptions or are subject to a very light regulatory framework under the relevant sector-specific Union law. Such financial entities include managers of alternative investment funds referred to in Article 3(2) of Directive 2011/61/EU of the European Parliament and of the Council ([16]), insurance and reinsurance undertakings referred to in Article 4 of Directive 2009/138/EC of the European Parliament and of the Council ([17]), and institutions for occupational retirement provision which operate pension schemes which together

([14]) Directive 2009/110/EC of the European Parliament and of the Council of 16 September 2009 on the taking up, pursuit and prudential supervision of the business of electronic money institutions amending Directives 2005/60/EC and 2006/48/EC and repealing Directive 2000/46/EC (OJ L 267, 10.10.2009, p. 7).

([15]) Directive 2013/36/EU of the European Parliament and of the Council of 26 June 2013 on access to the activity of credit institutions and the prudential supervision of credit institutions, amending Directive 2002/87/EC and repealing Directives 2006/48/EC and 2006/49/EC (OJ L 176, 27.6.2013, p. 338).

([16]) Directive 2011/61/EU of the European Parliament and of the Council of 8 June 2011 on Alternative Investment Fund Managers and amending Directives 2003/41/EC and 2009/65/EC and Regulations (EC) No 1060/2009 and (EU) No 1095/2010 (OJ L 174, 1.7.2011, p. 1).

([17]) Directive 2009/138/EC of the European Parliament and of the Council of 25 November 2009 on the taking-up and pursuit of the business of Insurance and Reinsurance (Solvency II) (OJ L 335, 17.12.2009, p. 1).

do not have more than 15 members in total. In light of those exemptions it would not be proportionate to include such financial entities in the scope of this Regulation. In addition, this Regulation acknowledges the specificities of the insurance intermediation market structure, with the result that insurance intermediaries, reinsurance intermediaries and ancillary insurance intermediaries qualifying as microenterprises or as small or medium-sized enterprises should not be subject to this Regulation.

(40) Since the entities referred to in Article 2(5), points (4) to (23), of Directive 2013/36/EU are excluded from the scope of that Directive, Member States should consequently be able to choose to exempt from the application of this Regulation such entities located within their respective territories.

(41) Similarly, in order to align this Regulation to the scope of Directive 2014/65/EU of the European Parliament and of the Council ([18]), it is also appropriate to exclude from the scope of this Regulation natural and legal persons referred in Articles 2 and 3 of that Directive which are allowed to provide investment services without having to obtain an authorisation under Directive 2014/65/EU. However, Article 2 of Directive 2014/65/EU also excludes from the scope of that Directive entities which qualify as financial entities for the purposes of this Regulation such as, central securities depositories, collective investment undertakings or insurance and reinsurance undertakings. The exclusion from the scope of this Regulation of the persons and entities referred to in Articles 2 and 3 of that Directive should not encompass those central securities depositories, collective investment undertakings or insurance and reinsurance undertakings.

(42) Under sector-specific Union law, some financial entities are subject to lighter requirements or exemptions for reasons associated with their size or the services they provide. That category of financial entities includes small and non-interconnected investment firms, small institutions for occupational retirement provision which may be excluded from the scope of Directive (EU) 2016/2341 under the conditions laid down in Article 5 of that Directive by the Member State concerned and operate pension schemes which together do not have more than 100 members in total, as well as institutions exempted pursuant to Directive 2013/36/EU. Therefore, in accordance with the principle of proportionality and to preserve the spirit of sector-specific Union law, it is also appropriate to subject those financial entities to a simplified ICT risk management framework under this Regulation. The proportionate character of the ICT risk management framework covering those financial entities should not be altered by the regulatory technical standards that are to be developed by the ESAs. Moreover, in accordance with the principle of proportionality, it is appropriate to also subject payment institutions referred to in Article 32(1) of Directive (EU) 2015/2366 and electronic money institutions referred to in Article 9 of Directive 2009/110/EC exempted in accordance with national law transposing those Union legal acts to a simplified ICT risk management framework under this Regulation, while payment institutions and electronic money institutions which have not been exempted in accordance with their respective national law transposing sectoral Union law should comply with the general framework laid down by this Regulation.

(43) Similarly, financial entities which qualify as microenterprises or are subject to the simplified ICT risk management framework under this Regulation should not be required to establish a role to monitor their arrangements concluded with ICT third-party service providers on the use of ICT services; or to designate a member of senior management to be responsible for overseeing the related risk exposure and relevant documentation; to assign the responsibility for managing and overseeing ICT risk to a control function and ensure an appropriate level of independence of such control function in order to avoid conflicts of interest; to document and review at least once a year the ICT risk management framework; to subject to internal audit on a regular basis the ICT risk management framework; to perform in-depth assessments after major changes in their network and information system infrastructures and processes; to regularly conduct risk analyses on legacy ICT systems; to subject the implementation of the ICT Response and Recovery plans to independent internal audit reviews; to have a crisis management function, to expand the testing of business continuity and response and recovery plans to capture switchover scenarios between primary ICT infrastructure and redundant facilities; to report to competent authorities, upon their request, an estimation of aggregated annual costs and losses caused by major ICT-related incidents, to maintain redundant ICT capacities; to communicate to national competent authorities implemented

([18]) Directive 2014/65/EU of the European Parliament and of the Council of 15 May 2014 on markets in financial instruments and amending Directive 2002/92/EC and Directive 2011/61/EU (OJ L 173, 12.6.2014, p. 349).

changes following post ICT-related incident reviews; to monitor on a continuous basis relevant technological developments, to establish a comprehensive digital operational resilience testing programme as an integral part of the ICT risk management framework provided for in this Regulation, or to adopt and regularly review a strategy on ICT third-party risk. In addition, microenterprises should only be required to assess the need to maintain such redundant ICT capacities based on their risk profile. Microenterprises should benefit from a more flexible regime as regards digital operational resilience testing programmes. When considering the type and frequency of testing to be performed, they should properly balance the objective of maintaining a high digital operational resilience, the available resources and their overall risk profile. Microenterprises and financial entities subject to the simplified ICT risk management framework under this Regulation should be exempted from the requirement to perform advanced testing of ICT tools, systems and processes based on threat-led penetration testing (TLPT), as only financial entities meeting the criteria set out in this Regulation should be required to carry out such testing. In light of their limited capabilities, microenterprises should be able to agree with the ICT third-party service provider to delegate the financial entity's rights of access, inspection and audit to an independent third-party, to be appointed by the ICT third-party service provider, provided that the financial entity is able to request, at any time, all relevant information and assurance on the ICT third-party service provider's performance from the respective independent third-party.

(44) As only those financial entities identified for the purposes of the advanced digital resilience testing should be required to conduct threat-led penetration tests, the administrative processes and financial costs entailed in the performance of such tests should be borne by a small percentage of financial entities.

(45) To ensure full alignment and overall consistency between financial entities' business strategies, on the one hand, and the conduct of ICT risk management, on the other hand, the financial entities' management bodies should be required to maintain a pivotal and active role in steering and adapting the ICT risk management framework and the overall digital operational resilience strategy. The approach to be taken by management bodies should not only focus on the means of ensuring the resilience of the ICT systems, but should also cover people and processes through a set of policies which cultivate, at each corporate layer, and for all staff, a strong sense of awareness about cyber risks and a commitment to observe a strict cyber hygiene at all levels. The ultimate responsibility of the management body in managing a financial entity's ICT risk should be an overarching principle of that comprehensive approach, further translated into the continuous engagement of the management body in the control of the monitoring of the ICT risk management.

(46) Moreover, the principle of the management body's full and ultimate responsibility for the management of the ICT risk of the financial entity goes hand in hand with the need to secure a level of ICT-related investments and an overall budget for the financial entity that would enable the financial entity to achieve a high level of digital operational resilience.

(47) Inspired by relevant international, national and industry best practices, guidelines, recommendations and approaches to the management of cyber risk, this Regulation promotes a set of principles that facilitate the overall structure of ICT risk management. Consequently, as long as the main capabilities which financial entities put in place address the various functions in the ICT risk management (identification, protection and prevention, detection, response and recovery, learning and evolving and communication) set out in this Regulation, financial entities should remain free to use ICT risk management models that are differently framed or categorised.

(48) To keep pace with an evolving cyber threat landscape, financial entities should maintain updated ICT systems that are reliable and capable, not only for guaranteeing the processing of data required for their services, but also for ensuring sufficient technological resilience to allow them to deal adequately with additional processing needs due to stressed market conditions or other adverse situations.

(49) Efficient business continuity and recovery plans are necessary to allow financial entities to promptly and quickly resolve ICT-related incidents, in particular cyber-attacks, by limiting damage and giving priority to the resumption of activities and recovery actions in accordance with their back-up policies. However, such resumption should in no way jeopardise the integrity and security of the network and information systems or the availability, authenticity, integrity or confidentiality of data.

(50) While this Regulation allows financial entities to determine their recovery time and recovery point objectives in a flexible manner and hence to set such objectives by fully taking into account the nature and the criticality of the relevant functions and any specific business needs, it should nevertheless require them to carry out an assessment of the potential overall impact on market efficiency when determining such objectives.

(51) The propagators of cyber-attacks tend to pursue financial gains directly at the source, thus exposing financial entities to significant consequences. To prevent ICT systems from losing integrity or becoming unavailable, and hence to avoid data breaches and damage to physical ICT infrastructure, the reporting of major ICT-related incidents by financial entities should be significantly improved and streamlined. ICT-related incident reporting should be harmonised through the introduction of a requirement for all financial entities to report directly to their relevant competent authorities. Where a financial entity is subject to supervision by more than one national competent authority, Member States should designate a single competent authority as the addressee of such reporting. Credit institutions classified as significant in accordance with Article 6(4) of Council Regulation (EU) No 1024/2013 ([19]) should submit such reporting to the national competent authorities, which should subsequently transmit the report to the European Central Bank (ECB).

(52) The direct reporting should enable financial supervisors to have immediate access to information about major ICT-related incidents. Financial supervisors should in turn pass on details of major ICT-related incidents to public non-financial authorities (such as competent authorities and single points of contact under Directive (EU) 2022/2555, national data protection authorities, and to law enforcement authorities for major ICT-related incidents of a criminal nature) in order to enhance such authorities awareness of such incidents and, in the case of CSIRTs, to facilitate prompt assistance that may be given to financial entities, as appropriate. Member States should, in addition, be able to determine that financial entities themselves should provide such information to public authorities outside the financial services area. Those information flows should allow financial entities to swiftly benefit from any relevant technical input, advice about remedies, and subsequent follow-up from such authorities. The information on major ICT-related incidents should be mutually channelled: financial supervisors should provide all necessary feedback or guidance to the financial entity, while the ESAs should share anonymised data on cyber threats and vulnerabilities relating to an incident, to aid wider collective defence.

(53) While all financial entities should be required to carry out incident reporting, that requirement is not expected to affect all of them in the same manner. Indeed, relevant materiality thresholds, as well as reporting timelines, should be duly adjusted, in the context of delegated acts based on the regulatory technical standards to be developed by the ESAs, with a view to covering only major ICT-related incidents. In addition, the specificities of financial entities should be taken into account when setting timelines for reporting obligations.

(54) This Regulation should require credit institutions, payment institutions, account information service providers and electronic money institutions to report all operational or security payment-related incidents – previously reported under Directive (EU) 2015/2366 – irrespective of the ICT nature of the incident.

([19]) Council Regulation (EU) No 1024/2013 of 15 October 2013 conferring specific tasks on the European Central Bank concerning policies relating to the prudential supervision of credit institutions (OJ L 287, 29.10.2013, p. 63).

(55) The ESAs should be tasked with assessing the feasibility and conditions for a possible centralisation of ICT-related incident reports at Union level. Such centralisation could consist of a single EU Hub for major ICT-related incident reporting either directly receiving relevant reports and automatically notifying national competent authorities, or merely centralising relevant reports forwarded by the national competent authorities and thus fulfilling a coordination role. The ESAs should be tasked with preparing, in consultation with the ECB and ENISA, a joint report exploring the feasibility of setting up a single EU Hub.

(56) In order to achieve a high level of digital operational resilience, and in line with both the relevant international standards (e.g. the G7 Fundamental Elements for Threat-Led Penetration Testing) and with the frameworks applied in the Union, such as the TIBER-EU, financial entities should regularly test their ICT systems and staff having ICT-related responsibilities with regard to the effectiveness of their preventive, detection, response and recovery capabilities, to uncover and address potential ICT vulnerabilities. To reflect differences that exist across, and within, the various financial subsectors as regards financial entities' level of cybersecurity preparedness, testing should include a wide variety of tools and actions, ranging from the assessment of basic requirements (e.g. vulnerability assessments and scans, open source analyses, network security assessments, gap analyses, physical security reviews, questionnaires and scanning software solutions, source code reviews where feasible, scenario-based tests, compatibility testing, performance testing or end-to-end testing) to more advanced testing by means of TLPT. Such advanced testing should be required only of financial entities that are mature enough from an ICT perspective to reasonably carry it out. The digital operational resilience testing required by this Regulation should thus be more demanding for those financial entities meeting the criteria set out in this Regulation (for example, large, systemic and ICT-mature credit institutions, stock exchanges, central securities depositories and central counterparties) than for other financial entities. At the same time, the digital operational resilience testing by means of TLPT should be more relevant for financial entities operating in core financial services subsectors and playing a systemic role (for example, payments, banking, and clearing and settlement), and less relevant for other subsectors (for example, asset managers and credit rating agencies).

(57) Financial entities involved in cross-border activities and exercising the freedoms of establishment, or of provision of services within the Union, should comply with a single set of advanced testing requirements (i.e. TLPT) in their home Member State, which should include the ICT infrastructures in all jurisdictions where the cross-border financial group operates within the Union, thus allowing such cross-border financial groups to incur related ICT testing costs in one jurisdiction only.

(58) To draw on the expertise already acquired by certain competent authorities, in particular with regard to implementing the TIBER-EU framework, this Regulation should allow Member States to designate a single public authority as responsible in the financial sector, at national level, for all TLPT matters, or competent authorities, to delegate, in the absence of such designation, the exercise of TLPT related tasks to another national financial competent authority.

(59) Since this Regulation does not require financial entities to cover all critical or important functions in one single threat-led penetration test, financial entities should be free to determine which and how many critical or important functions should be included in the scope of such a test.

(60) Pooled testing within the meaning of this Regulation – involving the participation of several financial entities in a TLPT and for which an ICT third-party service provider can directly enter into contractual arrangements with an external tester – should be allowed only where the quality or security of services delivered by the ICT third-party service provider to customers that are entities falling outside the scope of this Regulation, or the confidentiality of the data related to such services, are reasonably expected to be adversely impacted. Pooled testing should also be subject to safeguards (direction by one designated financial entity, calibration of the number of participating financial entities) to ensure a rigorous testing exercise for the financial entities involved which meet the objectives of the TLPT pursuant to this Regulation.

(61) In order to take advantage of internal resources available at corporate level, this Regulation should allow the use of internal testers for the purposes of carrying out TLPT, provided there is supervisory approval, no conflicts of interest, and periodical alternation of the use of internal and external testers (every three tests), while also requiring the provider of the threat intelligence in the TLPT to always be external to the financial entity. The responsibility for conducting TLPT should remain fully with the financial entity. Attestations provided by authorities should be solely for the purpose of mutual recognition and should not preclude any follow-up action needed to address the ICT risk to which the financial entity is exposed, nor should they be seen as a supervisory endorsement of a financial entity's ICT risk management and mitigation capabilities.

(62) To ensure a sound monitoring of ICT third-party risk in the financial sector, it is necessary to lay down a set of principle-based rules to guide financial entities' when monitoring risk arising in the context of functions outsourced to ICT third-party service providers, particularly for ICT services supporting critical or important functions, as well as more generally in the context of all ICT third-party dependencies.

(63) To address the complexity of the various sources of ICT risk, while taking into account the multitude and diversity of providers of technological solutions which enable a smooth provision of financial services, this Regulation should cover a wide range of ICT third-party service providers, including providers of cloud computing services, software, data analytics services and providers of data centre services. Similarly, since financial entities should effectively and coherently identify and manage all types of risk, including in the context of ICT services procured within a financial group, it should be clarified that undertakings which are part of a financial group and provide ICT services predominantly to their parent undertaking, or to subsidiaries or branches of their parent undertaking, as well as financial entities providing ICT services to other financial entities, should also be considered as ICT third-party service providers under this Regulation. Lastly, in light of the evolving payment services market becoming increasingly dependent on complex technical solutions, and in view of emerging types of payment services and payment-related solutions, participants in the payment services ecosystem, providing payment-processing activities, or operating payment infrastructures, should also be considered to be ICT third-party service providers under this Regulation, with the exception of central banks when operating payment or securities settlement systems, and public authorities when providing ICT related services in the context of fulfilling State functions.

(64) A financial entity should at all times remain fully responsible for complying with its obligations set out in this Regulation. Financial entities should apply a proportionate approach to the monitoring of risks emerging at the level of the ICT third-party service providers, by duly considering the nature, scale, complexity and importance of their ICT-related dependencies, the criticality or importance of the services, processes or functions subject to the contractual arrangements and, ultimately, on the basis of a careful assessment of any potential impact on the continuity and quality of financial services at individual and at group level, as appropriate.

(65) The conduct of such monitoring should follow a strategic approach to ICT third-party risk formalised through the adoption by the financial entity's management body of a dedicated ICT third-party risk strategy, rooted in a continuous screening of all ICT third-party dependencies. To enhance supervisory awareness of ICT third-party dependencies, and with a view to further supporting the work in the context of the Oversight Framework established by this Regulation, all financial entities should be required to maintain a register of information with all contractual arrangements about the use of ICT services provided by ICT third-party service providers. Financial supervisors should be able to request the full register, or to ask for specific sections thereof, and thus to obtain essential information for acquiring a broader understanding of the ICT dependencies of financial entities.

(66) A thorough pre-contracting analysis should underpin and precede the formal conclusion of contractual arrangements, in particular by focusing on elements such as the criticality or importance of the services supported by the envisaged ICT contract, the necessary supervisory approvals or other conditions, the possible concentration risk entailed, as well as applying due diligence in the process of selection and assessment of ICT third-party service providers and assessing potential conflicts of interest. For contractual arrangements concerning critical or important functions, financial entities should take into consideration the use by ICT third-party service providers of the most up-to-date and highest information security standards. Termination of contractual arrangements could be prompted at least by a series of circumstances showing shortfalls at the ICT third-party service provider level, in

particular significant breaches of laws or contractual terms, circumstances revealing a potential alteration of the performance of the functions provided for in the contractual arrangements, evidence of weaknesses of the ICT third-party service provider in its overall ICT risk management, or circumstances indicating the inability of the relevant competent authority to effectively supervise the financial entity.

(67) To address the systemic impact of ICT third-party concentration risk, this Regulation promotes a balanced solution by means of taking a flexible and gradual approach to such concentration risk since the imposition of any rigid caps or strict limitations might hinder the conduct of business and restrain the contractual freedom. Financial entities should thoroughly assess their envisaged contractual arrangements to identify the likelihood of such risk emerging, including by means of in-depth analyses of subcontracting arrangements, in particular when concluded with ICT third-party service providers established in a third country. At this stage, and with a view to striking a fair balance between the imperative of preserving contractual freedom and that of guaranteeing financial stability, it is not considered appropriate to set out rules on strict caps and limits to ICT third-party exposures. In the context of the Oversight Framework, a Lead Overseer, appointed pursuant to this Regulation, should, in respect to critical ICT third-party service providers, pay particular attention to fully grasp the magnitude of interdependences, discover specific instances where a high degree of concentration of critical ICT third-party service providers in the Union is likely to put a strain on the Union financial system's stability and integrity and maintain a dialogue with critical ICT third-party service providers where that specific risk is identified.

(68) To evaluate and monitor on a regular basis the ability of an ICT third party service provider to securely provide services to a financial entity without adverse effects on a financial entity's digital operational resilience, several key contractual elements with ICT third-party service providers should be harmonised. Such harmonisation should cover minimum areas which are crucial for enabling a full monitoring by the financial entity of the risks that could emerge from the ICT third-party service provider, from the perspective of a financial entity's need to secure its digital resilience because it is deeply dependent on the stability, functionality, availability and security of the ICT services received.

(69) When renegotiating contractual arrangements to seek alignment with the requirements of this Regulation, financial entities and ICT third-party service providers should ensure the coverage of the key contractual provisions as provided for in this Regulation.

(70) The definition of 'critical or important function' provided for in this Regulation encompasses the 'critical functions' as defined in Article 2(1), point (35), of Directive 2014/59/EU of the European Parliament and of the Council ([20]). Accordingly, functions deemed to be critical pursuant to Directive 2014/59/EU are included in the definition of critical functions within the meaning of this Regulation.

(71) Irrespective of the criticality or importance of the function supported by the ICT services, contractual arrangements should, in particular, provide for a specification of the complete descriptions of functions and services, of the locations where such functions are provided and where data is to be processed, as well as an indication of service level descriptions. Other essential elements to enable a financial entity's monitoring of ICT third party risk are: contractual provisions specifying how the accessibility, availability, integrity, security and protection of personal data are ensured by the ICT third-party service provider, provisions laying down the relevant guarantees for enabling the access, recovery and return of data in the case of insolvency, resolution or discontinuation of the business operations of the ICT third-party service provider, as well as provisions requiring the ICT third-party service provider to provide assistance in case of ICT incidents in connection with the services provided, at no additional cost or at a cost determined *ex-ante*; provisions on the obligation of the ICT third-party service provider

([20]) Directive 2014/59/EU of the European Parliament and of the Council of 15 May 2014 establishing a framework for the recovery and resolution of credit institutions and investment firms and amending Council Directive 82/891/EEC, and Directives 2001/24/EC, 2002/47/EC, 2004/25/EC, 2005/56/EC, 2007/36/EC, 2011/35/EU, 2012/30/EU and 2013/36/EU, and Regulations (EU) No 1093/2010 and (EU) No 648/2012, of the European Parliament and of the Council (OJ L 173, 12.6.2014, p. 190).

to fully cooperate with the competent authorities and resolution authorities of the financial entity; and provisions on termination rights and related minimum notice periods for the termination of the contractual arrangements, in accordance with the expectations of competent authorities and resolution authorities.

(72) In addition to such contractual provisions, and with a view to ensuring that financial entities remain in full control of all developments occurring at third-party level which may impair their ICT security, the contracts for the provision of ICT services supporting critical or important functions should also provide for the following: the specification of the full service level descriptions, with precise quantitative and qualitative performance targets, to enable without undue delay appropriate corrective actions when the agreed service levels are not met; the relevant notice periods and reporting obligations of the ICT third-party service provider in the event of developments with a potential material impact on the ICT third-party service provider's ability to effectively provide their respective ICT services; a requirement upon the ICT third-party service provider to implement and test business contingency plans and have ICT security measures, tools and policies allowing for the secure provision of services, and to participate and fully cooperate in the TLPT carried out by the financial entity.

(73) Contracts for the provision of ICT services supporting critical or important functions should also contain provisions enabling the rights of access, inspection and audit by the financial entity, or an appointed third party, and the right to take copies as crucial instruments in the financial entities' ongoing monitoring of the ICT third-party service provider's performance, coupled with the service provider's full cooperation during inspections. Similarly, the competent authority of the financial entity should have the right, based on notices, to inspect and audit the ICT third-party service provider, subject to the protection of confidential information.

(74) Such contractual arrangements should also provide for dedicated exit strategies to enable, in particular, mandatory transition periods during which ICT third-party service providers should continue providing the relevant services with a view to reducing the risk of disruptions at the level of the financial entity, or to allow the latter effectively to switch to the use of other ICT third-party service providers or, alternatively, to change to in-house solutions, consistent with the complexity of the provided ICT service. Moreover, financial entities within the scope of Directive 2014/59/EU should ensure that the relevant contracts for ICT services are robust and fully enforceable in the event of resolution of those financial entities. Therefore, in line with the expectations of the resolution authorities, those financial entities should ensure that the relevant contracts for ICT services are resolution resilient. As long as they continue meeting their payment obligations, those financial entities should ensure, among other requirements, that the relevant contracts for ICT services contain clauses for non-termination, non-suspension and non-modification on grounds of restructuring or resolution.

(75) Moreover, the voluntary use of standard contractual clauses developed by public authorities or Union institutions, in particular the use of contractual clauses developed by the Commission for cloud computing services could provide further comfort to the financial entities and ICT third-party service providers, by enhancing their level of legal certainty regarding the use of cloud computing services in the financial sector, in full alignment with the requirements and expectations set out by the Union financial services law. The development of standard contractual clauses builds on measures already envisaged in the 2018 Fintech Action Plan that announced the Commission's intention to encourage and facilitate the development of standard contractual clauses for the use of cloud computing services outsourcing by financial entities, drawing on cross-sectorial cloud computing services stakeholders' efforts, which the Commission has facilitated with the help of the financial sector's involvement.

(76) With a view to promoting convergence and efficiency in relation to supervisory approaches when addressing ICT third-party risk in the financial sector, as well as to strengthening the digital operational resilience of financial entities which rely on critical ICT third-party service providers for the provision of ICT services that support the supply of financial services, and thereby to contributing to the preservation of the Union's financial system stability and the integrity of the internal market for financial services, critical ICT third-party service providers should be subject to a Union Oversight Framework. While the set-up of the Oversight Framework is justified by the added value of taking action at Union level and by virtue of the inherent role and specificities of the use of ICT services in

the provision of financial services, it should be recalled, at the same time, that this solution appears suitable only in the context of this Regulation specifically dealing with digital operational resilience in the financial sector. However, such Oversight Framework should not be regarded as a new model for Union supervision in other areas of financial services and activities.

(77) The Oversight Framework should apply only to critical ICT third-party service providers. There should therefore be a designation mechanism to take into account the dimension and nature of the financial sector's reliance on such ICT third-party service providers. That mechanism should involve a set of quantitative and qualitative criteria to set the criticality parameters as a basis for inclusion in the Oversight Framework. In order to ensure the accuracy of that assessment, and regardless of the corporate structure of the ICT third-party service provider, such criteria should, in the case of a ICT third-party service provider that is part of a wider group, take into consideration the entire ICT third-party service provider's group structure. On the one hand, critical ICT third-party service providers, which are not automatically designated by virtue of the application of those criteria, should have the possibility to opt in to the Oversight Framework on a voluntary basis, on the other hand, ICT third-party service providers, that are already subject to oversight mechanism frameworks supporting the fulfilment of the tasks of the European System of Central Banks as referred to in Article 127(2) TFEU, should be exempted.

(78) Similarly, financial entities providing ICT services to other financial entities, while belonging to the category of ICT third-party service providers under this Regulation, should also be exempted from the Oversight Framework since they are already subject to supervisory mechanisms established by the relevant Union financial services law. Where applicable, competent authorities should take into account, in the context of their supervisory activities, the ICT risk posed to financial entities by financial entities providing ICT services. Likewise, due to the existing risk monitoring mechanisms at group level, the same exemption should be introduced for ICT third-party service providers delivering services predominantly to the entities of their own group. ICT third-party service providers providing ICT services solely in one Member State to financial entities that are active only in that Member State should also be exempted from the designation mechanism because of their limited activities and lack of cross-border impact.

(79) The digital transformation experienced in financial services has brought about an unprecedented level of use of, and reliance upon, ICT services. Since it has become inconceivable to provide financial services without the use of cloud computing services, software solutions and data-related services, the Union financial ecosystem has become intrinsically co-dependent on certain ICT services provided by ICT service suppliers. Some of those suppliers, innovators in developing and applying ICT-based technologies, play a significant role in the delivery of financial services, or have become integrated into the financial services value chain. They have thus become critical to the stability and integrity of the Union financial system. This widespread reliance on services supplied by critical ICT third-party service providers, combined with the interdependence of the information systems of various market operators, create a direct, and potentially severe, risk to the Union financial services system and to the continuity of delivery of financial services if critical ICT third-party service providers were to be affected by operational disruptions or major cyber incidents. Cyber incidents have a distinctive ability to multiply and propagate throughout the financial system at a considerably faster pace than other types of risk monitored in the financial sector and can extend across sectors and beyond geographical borders. They have the potential to evolve into a systemic crisis, where trust in the financial system has been eroded due to the disruption of functions supporting the real economy, or to substantial financial losses, reaching a level which the financial system is unable to withstand, or which requires the deployment of heavy shock absorption measures. To prevent these scenarios from taking place and thereby endangering the financial stability and integrity of the Union, it is essential to provide the convergence of supervisory practices relating to ICT third-party risk in finance, in particular through new rules enabling the Union oversight of critical ICT third-party service providers.

(80) The Oversight Framework largely depends on the degree of collaboration between the Lead Overseer and the critical ICT third-party service provider delivering to financial entities services affecting the supply of financial services. Successful oversight is predicated, inter alia, upon the ability of the Lead Overseer to effectively conduct monitoring missions and inspections to assess the rules, controls and processes used by the critical ICT third-party service providers, as well as to assess the potential cumulative impact of their activities on financial stability and the integrity of the financial system. At the same time, it is crucial that critical ICT third-party service providers follow the Lead Overseer's recommendations and address its concerns. Since a lack of cooperation by a critical ICT third-party service provider providing services that affect the supply of financial services, such as the refusal to grant access to its premises or to submit information, would ultimately deprive the Lead Overseer of its essential tools in appraising ICT third-party risk, and could adversely impact the financial stability and the integrity of the financial system, it is necessary to also provide for a commensurate sanctioning regime.

(81) Against this background, the need of the Lead Overseer to impose penalty payments to compel critical ICT third-party service providers to comply with the transparency and access-related obligations set out in this Regulation should not be jeopardised by difficulties raised by the enforcement of those penalty payments in relation to critical ICT third-party service providers established in third countries. In order to ensure the enforceability of such penalties, and to allow a swift roll out of procedures upholding the critical ICT third-party service providers' rights of defence in the context of the designation mechanism and the issuance of recommendations, those critical ICT third-party service providers, providing services to financial entities that affect the supply of financial services, should be required to maintain an adequate business presence in the Union. Due to the nature of the oversight, and the absence of comparable arrangements in other jurisdictions, there are no suitable alternative mechanisms ensuring this objective by way of effective cooperation with financial supervisors in third countries in relation to the monitoring of the impact of digital operational risks posed by systemic ICT third-party service providers, qualifying as critical ICT third-party service providers established in third countries. Therefore, in order to continue its provision of ICT services to financial entities in the Union, an ICT third-party service provider established in a third country which has been designated as critical in accordance with this Regulation should undertake, within 12 months of such designation, all necessary arrangements to ensure its incorporation within the Union, by means of establishing a subsidiary, as defined throughout the Union *acquis*, namely in Directive 2013/34/EU of the European Parliament and of the Council ([21]).

(82) The requirement to set up a subsidiary in the Union should not prevent the critical ICT third-party service provider from supplying ICT services and related technical support from facilities and infrastructure located outside the Union. This Regulation does not impose a data localisation obligation as it does not require data storage or processing to be undertaken in the Union.

(83) Critical ICT third-party service providers should be able to provide ICT services from anywhere in the world, not necessarily or not only from premises located in the Union. Oversight activities should be first conducted on premises located in the Union and by interacting with entities located in the Union, including the subsidiaries established by critical ICT third-party service providers pursuant to this Regulation. However, such actions within the Union might be insufficient to allow the Lead Overseer to fully and effectively perform its duties under this Regulation. The Lead Overseer should therefore also be able to exercise its relevant oversight powers in third countries. Exercising those powers in third countries should allow the Lead Overseer to examine the facilities from which the ICT services or the technical support services are actually provided or managed by the critical ICT third-party service provider, and should give the Lead Overseer a comprehensive and operational understanding of the ICT risk management of the critical ICT third-party service provider. The possibility for the Lead Overseer, as a Union agency, to exercise powers outside the territory of the Union should be duly framed by relevant conditions, in particular the consent of the critical ICT third-party service provider concerned. Similarly, the relevant authorities of the third country should be informed of, and not have objected to, the exercise on their own territory of the activities of the Lead Overseer. However, in order to ensure efficient implementation, and without prejudice to the respective competences of the Union institutions and the Member States, such powers also need to be fully anchored in the conclusion of administrative cooperation arrangements with the relevant authorities of the third

([21]) Directive 2013/34/EU of the European Parliament and of the Council of 26 June 2013 on the annual financial statements, consolidated financial statements and related reports of certain types of undertakings, amending Directive 2006/43/EC of the European Parliament and of the Council and repealing Council Directives 78/660/EEC and 83/349/EEC (OJ L 182, 29.6.2013, p. 19).

country concerned. This Regulation should therefore enable the ESAs to conclude administrative cooperation arrangements with the relevant authorities of third countries, which should not otherwise create legal obligations in respect of the Union and its Member States.

(84) To facilitate communication with the Lead Overseer and to ensure adequate representation, critical ICT third-party service providers which are part of a group should designate one legal person as their coordination point.

(85) The Oversight Framework should be without prejudice to Member States' competence to conduct their own oversight or monitoring missions in respect to ICT third-party service providers which are not designated as critical under this Regulation, but which are regarded as important at national level.

(86) To leverage the multi-layered institutional architecture in the financial services area, the Joint Committee of the ESAs should continue to ensure overall cross-sectoral coordination in relation to all matters pertaining to ICT risk, in accordance with its tasks on cybersecurity. It should be supported by a new Subcommittee (the 'Oversight Forum') carrying out preparatory work both for the individual decisions addressed to critical ICT third-party service providers, and for the issuing of collective recommendations, in particular in relation to benchmarking the oversight programmes for critical ICT third-party service providers, and identifying best practices for addressing ICT concentration risk issues.

(87) To ensure that critical ICT third-party service providers are appropriately and effectively overseen on a Union level, this Regulation provides that any of the three ESAs could be designated as a Lead Overseer. The individual assignment of a critical ICT third-party service provider to one of the three ESAs should result from an assessment of the preponderance of financial entities operating in the financial sectors for which that ESA has responsibilities. This approach should lead to a balanced allocation of tasks and responsibilities between the three ESAs, in the context of exercising the oversight functions, and should make the best use of the human resources and technical expertise available in each of the three ESAs.

(88) Lead Overseers should be granted the necessary powers to conduct investigations, to carry out onsite and offsite inspections at the premises and locations of critical ICT third-party service providers and to obtain complete and updated information. Those powers should enable the Lead Overseer to acquire real insight into the type, dimension and impact of the ICT third-party risk posed to financial entities and ultimately to the Union's financial system. Entrusting the ESAs with the lead oversight role is a prerequisite for understanding and addressing the systemic dimension of ICT risk in finance. The impact of critical ICT third-party service providers on the Union financial sector and the potential issues caused by the ICT concentration risk entailed call for taking a collective approach at Union level. The simultaneous carrying out of multiple audits and access rights, performed separately by numerous competent authorities, with little or no coordination among them, would prevent financial supervisors from obtaining a complete and comprehensive overview of ICT third-party risk in the Union, while also creating redundancy, burden and complexity for critical ICT third-party service providers if they were subject to numerous monitoring and inspection requests.

(89) Due to the significant impact of being designated as critical, this Regulation should ensure that the rights of critical ICT third-party service providers are observed throughout the implementation of the Oversight Framework. Prior to being designated as critical, such providers should, for example, have the right to submit to the Lead Overseer a reasoned statement containing any relevant information for the purposes of the assessment related to their designation. Since the Lead Overseer should be empowered to submit recommendations on ICT risk matters and suitable remedies thereto, which include the power to oppose certain contractual arrangements ultimately affecting the stability of the financial entity or the financial system, critical ICT third-party service providers should also be given the opportunity to provide, prior to the finalisation of those recommendations, explanations regarding the expected impact of the solutions, envisaged in the recommendations, on customers that are entities falling outside the scope of this Regulation and to formulate solutions to mitigate risks. Critical ICT third-party service providers

disagreeing with the recommendations should submit a reasoned explanation of their intention not to endorse the recommendation. Where such reasoned explanation is not submitted or where it is considered to be insufficient, the Lead Overseer should issue a public notice summarily describing the matter of non-compliance.

(90) Competent authorities should duly include the task of verifying substantive compliance with recommendations issued by the Lead Overseer in their functions with regard to prudential supervision of financial entities. Competent authorities should be able to require financial entities to take additional measures to address the risks identified in the Lead Overseer's recommendations, and should, in due course, issue notifications to that effect. Where the Lead Overseer addresses recommendations to critical ICT third-party service providers that are supervised under Directive (EU) 2022/2555, the competent authorities should be able, on a voluntary basis and before adopting additional measures, to consult the competent authorities under that Directive in order to foster a coordinated approach to dealing with the critical ICT third-party service providers in question.

(91) The exercise of the oversight should be guided by three operational principles seeking to ensure: (a) close coordination among the ESAs in their Lead Overseer roles, through a joint oversight network (JON), (b) consistency with the framework established by Directive (EU) 2022/2555 (through a voluntary consultation of bodies under that Directive to avoid duplication of measures directed at critical ICT third-party service providers), and (c) applying diligence to minimise the potential risk of disruption to services provided by the critical ICT third-party service providers to customers that are entities falling outside the scope of this Regulation.

(92) The Oversight Framework should not replace, or in any way or for any part substitute for, the requirement for financial entities to manage themselves the risks entailed by the use of ICT third-party service providers, including their obligation to maintain an ongoing monitoring of contractual arrangements concluded with critical ICT third-party service providers. Similarly, the Oversight Framework should not affect the full responsibility of financial entities for complying with, and discharging, all the legal obligations laid down in this Regulation and in the relevant financial services law.

(93) To avoid duplications and overlaps, competent authorities should refrain from taking individually any measures aiming to monitor the critical ICT third-party service provider's risks and should, in that respect, rely on the relevant Lead Overseer's assessment. Any measures should in any case be coordinated and agreed in advance with the Lead Overseer in the context of the exercise of tasks in the Oversight Framework.

(94) To promote convergence at international level as regards the use of best practices in the review and monitoring of ICT third-party service providers' digital risk-management, the ESAs should be encouraged to conclude cooperation arrangements with relevant supervisory and regulatory third-country authorities.

(95) To leverage the specific competences, technical skills and expertise of staff specialising in operational and ICT risk within the competent authorities, the three ESAs and, on a voluntary basis, the competent authorities under Directive (EU) 2022/2555, the Lead Overseer should draw on national supervisory capabilities and knowledge and set up dedicated examination teams for each critical ICT third-party service provider, pooling multidisciplinary teams in support of the preparation and execution of oversight activities, including general investigations and inspections of critical ICT third-party service providers, as well as for any necessary follow-up thereto.

(96) Whereas costs resulting from oversight tasks would be fully funded from fees levied on critical ICT third-party service providers, the ESAs are. however, likely to incur, before the start of the Oversight Framework, costs for the implementation of dedicated ICT systems supporting the upcoming oversight, since dedicated ICT systems would need to be developed and deployed beforehand. This Regulation therefore provides for a hybrid funding model, whereby the Oversight Framework would, as such, be fully fee-funded, while the development of the ESAs' ICT systems would be funded from Union and national competent authorities' contributions.

(97) Competent authorities should have all required supervisory, investigative and sanctioning powers to ensure the proper exercise of their duties under this Regulation. They should, in principle, publish notices of the administrative penalties they impose. Since financial entities and ICT third-party service providers can be established in different Member States and supervised by different competent authorities, the application of this Regulation should be facilitated by, on the one hand, close cooperation among relevant competent authorities, including the ECB with regard to specific tasks conferred on it by Council Regulation (EU) No 1024/2013, and, on the other hand, by consultation with the ESAs through the mutual exchange of information and the provision of assistance in the context of relevant supervisory activities.

(98) In order to further quantify and qualify the criteria for the designation of ICT third-party service providers as critical and to harmonise oversight fees, the power to adopt acts in accordance with Article 290 TFEU should be delegated to the Commission to supplement this Regulation by further specifying the systemic impact that a failure or operational outage of an ICT third-party service provider could have on the financial entities it provides ICT services to, the number of global systemically important institutions (G-SIIs), or other systemically important institutions (O-SIIs), that rely on the ICT third-party service provider in question, the number of ICT third-party service providers active on a given market, the costs of migrating data and ICT workloads to other ICT third-party service providers, as well as the amount of the oversight fees and the way in which they are to be paid. It is of particular importance that the Commission carry out appropriate consultations during its preparatory work, including at expert level, and that those consultations be conducted in accordance with the principles laid down in the Interinstitutional Agreement of 13 April 2016 on Better Law-Making ([22]). In particular, to ensure equal participation in the preparation of delegated acts, the European Parliament and the Council should receive all documents at the same time as Member States' experts, and their experts should systematically have access to meetings of Commission expert groups dealing with the preparation of delegated acts.

(99) Regulatory technical standards should ensure the consistent harmonisation of the requirements laid down in this Regulation. In their roles as bodies endowed with highly specialised expertise, the ESAs should develop draft regulatory technical standards which do not involve policy choices, for submission to the Commission. Regulatory technical standards should be developed in the areas of ICT risk management, major ICT-related incident reporting, testing, as well as in relation to key requirements for a sound monitoring of ICT third-party risk. The Commission and the ESAs should ensure that those standards and requirements can be applied by all financial entities in a manner that is proportionate to their size and overall risk profile, and the nature, scale and complexity of their services, activities and operations. The Commission should be empowered to adopt those regulatory technical standards by means of delegated acts pursuant to Article 290 TFEU and in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

(100) To facilitate the comparability of reports on major ICT-related incidents and major operational or security payment-related incidents, as well as to ensure transparency regarding contractual arrangements for the use of ICT services provided by ICT third-party service providers, the ESAs should develop draft implementing technical standards establishing standardised templates, forms and procedures for financial entities to report a major ICT-related incident and a major operational or security payment-related incident, as well as standardised templates for the register of information. When developing those standards, the ESAs should take into account the size and the overall risk profile of the financial entity, and the nature, scale and complexity of its services, activities and operations. The Commission should be empowered to adopt those implementing technical standards by means of implementing acts pursuant to Article 291 TFEU and in accordance with Article 15 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

([22]) OJ L 123, 12.5.2016, p. 1.

(101) Since further requirements have already been specified through delegated and implementing acts based on technical regulatory and implementing technical standards in Regulations (EC) No 1060/2009 ([23]), (EU) No 648/2012 ([24]), (EU) No 600/2014 ([25]) and (EU) No 909/2014 ([26]) of the European Parliament and of the Council, it is appropriate to mandate the ESAs, either individually or jointly through the Joint Committee, to submit regulatory and implementing technical standards to the Commission for adoption of delegated and implementing acts carrying over and updating existing ICT risk management rules.

(102) Since this Regulation, together with Directive (EU) 2022/2556 of the European Parliament and of the Council ([27]), entails a consolidation of the ICT risk management provisions across multiple regulations and directives of the Union's financial services *acquis*, including Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014 and (EU) No 909/2014, and Regulation (EU) 2016/1011 of the European Parliament and of the Council ([28]), in order to ensure full consistency, those Regulations should be amended to clarify that the applicable ICT risk-related provisions are laid down in this Regulation.

(103) Consequently, the scope of the relevant articles related to operational risk, upon which empowerments laid down in Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014, and (EU) 2016/1011 had mandated the adoption of delegated and implementing acts, should be narrowed down with a view to carry over into this Regulation all provisions covering the digital operational resilience aspects which today are part of those Regulations.

(104) The potential systemic cyber risk associated with the use of ICT infrastructures that enable the operation of payment systems and the provision of payment processing activities should be duly addressed at Union level through harmonised digital resilience rules. To that effect, the Commission should swiftly assess the need for reviewing the scope of this Regulation while aligning such review with the outcome of the comprehensive review envisaged under Directive (EU) 2015/2366. Numerous large-scale attacks over the past decade demonstrate how payment systems have become exposed to cyber threats. Placed at the core of the payment services chain and showing strong interconnections with the overall financial system, payment systems and payment processing activities acquired a critical significance for the functioning of the Union financial markets. Cyber-attacks on such systems can cause severe operational business disruptions with direct repercussions on key economic functions, such as the facilitation of payments, and indirect effects on related economic processes. Until a harmonised regime and the supervision of operators of payment systems and processing entities are put in place at Union level, Member States may, with a view to applying similar market practices, draw inspiration from the digital operational resilience requirements laid down by this Regulation, when applying rules to operators of payment systems and processing entities supervised under their own jurisdictions.

([23]) Regulation (EC) No 1060/2009 of the European Parliament and of the Council of 16 September 2009 on credit rating agencies (OJ L 302, 17.11.2009, p. 1).

([24]) Regulation (EU) No 648/2012 of the European Parliament and of the Council of 4 July 2012 on OTC derivatives, central counterparties and trade repositories (OJ L 201, 27.7.2012, p. 1).

([25]) Regulation (EU) No 600/2014 of the European Parliament and of the Council of 15 May 2014 on markets in financial instruments and amending Regulation (EU) No 648/2012 (OJ L 173, 12.6.2014, p. 84).

([26]) Regulation (EU) No 909/2014 of the European Parliament and of the Council of 23 July 2014 on improving securities settlement in the European Union and on central securities depositories and amending Directives 98/26/EC and 2014/65/EU and Regulation (EU) No 236/2012 (OJ L 257, 28.8.2014, p. 1).

([27]) Directive (EU) 2022/2556 of the European Parliament and of the Council of 14 December 2022 amending Directives 2009/65/EC, 2009/138/EC, 2011/61/EU, 2013/36/EU, 2014/59/EU, 2014/65/EU, (EU) 2015/2366 and (EU) 2016/2341 as regards digital operational resilience for the financial sector (see page 153 of this Official Journal).

([28]) Regulation (EU) 2016/1011 of the European Parliament and of the Council of 8 June 2016 on indices used as benchmarks in financial instruments and financial contracts or to measure the performance of investment funds and amending Directives 2008/48/EC and 2014/17/EU and Regulation (EU) No 596/2014 (OJ L 171, 29.6.2016, p. 1).

(105) Since the objective of this Regulation, namely to achieve a high level of digital operational resilience for regulated financial entities, cannot be sufficiently achieved by the Member States because it requires harmonisation of various different rules in Union and national law, but can rather, by reason of its scale and effects, be better achieved at Union level, the Union may adopt measures in accordance with the principle of subsidiarity as set out in Article 5 of the Treaty on European Union. In accordance with the principle of proportionality as set out in that Article, this Regulation does not go beyond what is necessary in order to achieve that objective.

(106) The European Data Protection Supervisor was consulted in accordance with Article 42(1) of Regulation (EU) 2018/1725 of the European Parliament and of the Council [29] and delivered an opinion on 10 May 2021 [30],

HAVE ADOPTED THIS REGULATION:

CHAPTER I

General provisions

Article 1

Subject matter

1. In order to achieve a high common level of digital operational resilience, this Regulation lays down uniform requirements concerning the security of network and information systems supporting the business processes of financial entities as follows:

(a) requirements applicable to financial entities in relation to:

(i) information and communication technology (ICT) risk management;

(ii) reporting of major ICT-related incidents and notifying, on a voluntary basis, significant cyber threats to the competent authorities;

(iii) reporting of major operational or security payment-related incidents to the competent authorities by financial entities referred to in Article 2(1), points (a) to (d);

(iv) digital operational resilience testing;

(v) information and intelligence sharing in relation to cyber threats and vulnerabilities;

(vi) measures for the sound management of ICT third-party risk;

(b) requirements in relation to the contractual arrangements concluded between ICT third-party service providers and financial entities;

(c) rules for the establishment and conduct of the Oversight Framework for critical ICT third-party service providers when providing services to financial entities;

(d) rules on cooperation among competent authorities, and rules on supervision and enforcement by competent authorities in relation to all matters covered by this Regulation.

2. In relation to financial entities identified as essential or important entities pursuant to national rules transposing Article 3 of Directive (EU) 2022/2555, this Regulation shall be considered a sector-specific Union legal act for the purposes of Article 4 of that Directive.

3. This Regulation is without prejudice to the responsibility of Member States' regarding essential State functions concerning public security, defence and national security in accordance with Union law.

[29] Regulation (EU) 2018/1725 of the European Parliament and of the Council of 23 October 2018 on the protection of natural persons with regard to the processing of personal data by the Union institutions, bodies, offices and agencies and on the free movement of such data, and repealing Regulation (EC) No 45/2001 and Decision No 1247/2002/EC (OJ L 295, 21.11.2018, p. 39).

[30] OJ C 229, 15.6.2021, p. 16.

Article 2

Scope

1. Without prejudice to paragraphs 3 and 4, this Regulation applies to the following entities:

(a) credit institutions;

(b) payment institutions, including payment institutions exempted pursuant to Directive (EU) 2015/2366;

(c) account information service providers;

(d) electronic money institutions, including electronic money institutions exempted pursuant to Directive 2009/110/EC;

(e) investment firms;

(f) crypto-asset service providers as authorised under a Regulation of the European Parliament and of the Council on markets in crypto-assets, and amending Regulations (EU) No 1093/2010 and (EU) No 1095/2010 and Directives 2013/36/EU and (EU) 2019/1937 ('the Regulation on markets in crypto-assets') and issuers of asset-referenced tokens;

(g) central securities depositories;

(h) central counterparties;

(i) trading venues;

(j) trade repositories;

(k) managers of alternative investment funds;

(l) management companies;

(m) data reporting service providers;

(n) insurance and reinsurance undertakings;

(o) insurance intermediaries, reinsurance intermediaries and ancillary insurance intermediaries;

(p) institutions for occupational retirement provision;

(q) credit rating agencies;

(r) administrators of critical benchmarks;

(s) crowdfunding service providers;

(t) securitisation repositories;

(u) ICT third-party service providers.

2. For the purposes of this Regulation, entities referred to in paragraph 1, points (a) to (t), shall collectively be referred to as 'financial entities'.

3. This Regulation does not apply to:

(a) managers of alternative investment funds as referred to in Article 3(2) of Directive 2011/61/EU;

(b) insurance and reinsurance undertakings as referred to in Article 4 of Directive 2009/138/EC;

(c) institutions for occupational retirement provision which operate pension schemes which together do not have more than 15 members in total;

(d) natural or legal persons exempted pursuant to Articles 2 and 3 of Directive 2014/65/EU;

(e) insurance intermediaries, reinsurance intermediaries and ancillary insurance intermediaries which are microenterprises or small or medium-sized enterprises;

(f) post office giro institutions as referred to in Article 2(5), point (3), of Directive 2013/36/EU.

4. Member States may exclude from the scope of this Regulation entities referred to in Article 2(5), points (4) to (23), of Directive 2013/36/EU that are located within their respective territories. Where a Member State makes use of such option, it shall inform the Commission thereof as well as of any subsequent changes thereto. The Commission shall make that information publicly available on its website or other easily accessible means.

Article 3

Definitions

For the purposes of this Regulation, the following definitions shall apply:

(1) 'digital operational resilience' means the ability of a financial entity to build, assure and review its operational integrity and reliability by ensuring, either directly or indirectly through the use of services provided by ICT third-party service providers, the full range of ICT-related capabilities needed to address the security of the network and information systems which a financial entity uses, and which support the continued provision of financial services and their quality, including throughout disruptions;

(2) 'network and information system' means a network and information system as defined in Article 6, point 1, of Directive (EU) 2022/2555;

(3) 'legacy ICT system' means an ICT system that has reached the end of its lifecycle (end-of-life), that is not suitable for upgrades or fixes, for technological or commercial reasons, or is no longer supported by its supplier or by an ICT third-party service provider, but that is still in use and supports the functions of the financial entity;

(4) 'security of network and information systems' means security of network and information systems as defined in Article 6, point 2, of Directive (EU) 2022/2555;

(5) 'ICT risk' means any reasonably identifiable circumstance in relation to the use of network and information systems which, if materialised, may compromise the security of the network and information systems, of any technology dependent tool or process, of operations and processes, or of the provision of services by producing adverse effects in the digital or physical environment;

(6) 'information asset' means a collection of information, either tangible or intangible, that is worth protecting;

(7) 'ICT asset' means a software or hardware asset in the network and information systems used by the financial entity;

(8) 'ICT-related incident' means a single event or a series of linked events unplanned by the financial entity that compromises the security of the network and information systems, and have an adverse impact on the availability, authenticity, integrity or confidentiality of data, or on the services provided by the financial entity;

(9) 'operational or security payment-related incident' means a single event or a series of linked events unplanned by the financial entities referred to in Article 2(1), points (a) to (d), whether ICT-related or not, that has an adverse impact on the availability, authenticity, integrity or confidentiality of payment-related data, or on the payment-related services provided by the financial entity;

(10) 'major ICT-related incident' means an ICT-related incident that has a high adverse impact on the network and information systems that support critical or important functions of the financial entity;

(11) 'major operational or security payment-related incident' means an operational or security payment-related incident that has a high adverse impact on the payment-related services provided;

(12) 'cyber threat' means 'cyber threat' as defined in Article 2, point (8), of Regulation (EU) 2019/881;

(13) 'significant cyber threat' means a cyber threat the technical characteristics of which indicate that it could have the potential to result in a major ICT-related incident or a major operational or security payment-related incident;

(14) 'cyber-attack' means a malicious ICT-related incident caused by means of an attempt perpetrated by any threat actor to destroy, expose, alter, disable, steal or gain unauthorised access to, or make unauthorised use of, an asset;

(15) 'threat intelligence' means information that has been aggregated, transformed, analysed, interpreted or enriched to provide the necessary context for decision-making and to enable relevant and sufficient understanding in order to mitigate the impact of an ICT-related incident or of a cyber threat, including the technical details of a cyber-attack, those responsible for the attack and their modus operandi and motivations;

(16) 'vulnerability' means a weakness, susceptibility or flaw of an asset, system, process or control that can be exploited;

(17) 'threat-led penetration testing (TLPT)' means a framework that mimics the tactics, techniques and procedures of real-life threat actors perceived as posing a genuine cyber threat, that delivers a controlled, bespoke, intelligence-led (red team) test of the financial entity's critical live production systems;

(18) 'ICT third-party risk' means an ICT risk that may arise for a financial entity in relation to its use of ICT services provided by ICT third-party service providers or by subcontractors of the latter, including through outsourcing arrangements;

(19) 'ICT third-party service provider' means an undertaking providing ICT services;

(20) 'ICT intra-group service provider' means an undertaking that is part of a financial group and that provides predominantly ICT services to financial entities within the same group or to financial entities belonging to the same institutional protection scheme, including to their parent undertakings, subsidiaries, branches or other entities that are under common ownership or control;

(21) 'ICT services' means digital and data services provided through ICT systems to one or more internal or external users on an ongoing basis, including hardware as a service and hardware services which includes the provision of technical support via software or firmware updates by the hardware provider, excluding traditional analogue telephone services;

(22) 'critical or important function' means a function, the disruption of which would materially impair the financial performance of a financial entity, or the soundness or continuity of its services and activities, or the discontinued, defective or failed performance of that function would materially impair the continuing compliance of a financial entity with the conditions and obligations of its authorisation, or with its other obligations under applicable financial services law;

(23) 'critical ICT third-party service provider' means an ICT third-party service provider designated as critical in accordance with Article 31;

(24) 'ICT third-party service provider established in a third country' means an ICT third-party service provider that is a legal person established in a third-country and that has entered into a contractual arrangement with a financial entity for the provision of ICT services;

(25) 'subsidiary' means a subsidiary undertaking within the meaning of Article 2, point (10), and Article 22 of Directive 2013/34/EU;

(26) 'group' means a group as defined in Article 2, point (11), of Directive 2013/34/EU;

(27) 'parent undertaking' means a parent undertaking within the meaning of Article 2, point (9), and Article 22 of Directive 2013/34/EU;

(28) 'ICT subcontractor established in a third country' means an ICT subcontractor that is a legal person established in a third-country and that has entered into a contractual arrangement either with an ICT third-party service provider, or with an ICT third-party service provider established in a third country;

(29) 'ICT concentration risk' means an exposure to individual or multiple related critical ICT third-party service providers creating a degree of dependency on such providers so that the unavailability, failure or other type of shortfall of such provider may potentially endanger the ability of a financial entity to deliver critical or important functions, or cause it to suffer other types of adverse effects, including large losses, or endanger the financial stability of the Union as a whole;

(30) 'management body' means a management body as defined in Article 4(1), point (36), of Directive 2014/65/EU, Article 3(1), point (7), of Directive 2013/36/EU, Article 2(1), point (s), of Directive 2009/65/EC of the European Parliament and of the Council ([31]), Article 2(1), point (45), of Regulation (EU) No 909/2014, Article 3(1), point (20), of Regulation (EU) 2016/1011, and in the relevant provision of the Regulation on markets in crypto-assets, or the equivalent persons who effectively run the entity or have key functions in accordance with relevant Union or national law;

(31) 'credit institution' means a credit institution as defined in Article 4(1), point (1), of Regulation (EU) No 575/2013 of the European Parliament and of the Council ([32]);

(32) 'institution exempted pursuant to Directive 2013/36/EU' means an entity as referred to in Article 2(5), points (4) to (23), of Directive 2013/36/EU;

(33) 'investment firm' means an investment firm as defined in Article 4(1), point (1), of Directive 2014/65/EU;

(34) 'small and non-interconnected investment firm' means an investment firm that meets the conditions laid out in Article 12(1) of Regulation (EU) 2019/2033 of the European Parliament and of the Council ([33]);

(35) 'payment institution' means a payment institution as defined in Article 4, point (4), of Directive (EU) 2015/2366;

(36) 'payment institution exempted pursuant to Directive (EU) 2015/2366' means a payment institution exempted pursuant to Article 32(1) of Directive (EU) 2015/2366;

(37) 'account information service provider' means an account information service provider as referred to in Article 33(1) of Directive (EU) 2015/2366;

(38) 'electronic money institution' means an electronic money institution as defined in Article 2, point (1), of Directive 2009/110/EC of the European Parliament and of the Council;

(39) 'electronic money institution exempted pursuant to Directive 2009/110/EC' means an electronic money institution benefitting from a waiver as referred to in Article 9(1) of Directive 2009/110/EC;

(40) 'central counterparty' means a central counterparty as defined in Article 2, point (1), of Regulation (EU) No 648/2012;

(41) 'trade repository' means a trade repository as defined in Article 2, point (2), of Regulation (EU) No 648/2012;

(42) 'central securities depository' means a central securities depository as defined in Article 2(1), point (1), of Regulation (EU) No 909/2014;

(43) 'trading venue' means a trading venue as defined in Article 4(1), point (24), of Directive 2014/65/EU;

(44) 'manager of alternative investment funds' means a manager of alternative investment funds as defined in Article 4(1), point (b), of Directive 2011/61/EU;

(45) 'management company' means a management company as defined in Article 2(1), point (b), of Directive 2009/65/EC;

(46) 'data reporting service provider' means a data reporting service provider within the meaning of Regulation (EU) No 600/2014, as referred to in Article 2(1), points (34) to (36) thereof;

(47) 'insurance undertaking' means an insurance undertaking as defined in Article 13, point (1), of Directive 2009/138/EC;

(48) 'reinsurance undertaking' means a reinsurance undertaking as defined in Article 13, point (4), of Directive 2009/138/EC;

([31]) Directive 2009/65/EC of the European Parliament and of the Council of 13 July 2009 on the coordination of laws, regulations and administrative provisions relating to undertakings for collective investment in transferable securities (UCITS) (OJ L 302, 17.11.2009, p. 32).

([32]) Regulation (EU) No 575/2013 of the European Parliament and of the Council of 26 June 2013 on prudential requirements for credit institutions and amending Regulation (EU) No 648/2012 (OJ L 176, 27.6.2013, p. 1).

([33]) Regulation (EU) 2019/2033 of the European Parliament and of the Council of 27 November 2019 on the prudential requirements of investment firms and amending Regulations (EU) No 1093/2010, (EU) No 575/2013, (EU) No 600/2014 and (EU) No 806/2014 (OJ L 314, 5.12.2019, p. 1).

(49) 'insurance intermediary' means an insurance intermediary as defined in Article 2(1), point (3), of Directive (EU) 2016/97 of the European Parliament and of the Council ([34]);

(50) 'ancillary insurance intermediary' means an ancillary insurance intermediary as defined in Article 2(1), point (4), of Directive (EU) 2016/97;

(51) 'reinsurance intermediary' means a reinsurance intermediary as defined in Article 2(1), point (5), of Directive (EU) 2016/97;

(52) 'institution for occupational retirement provision' means an institution for occupational retirement provision as defined in Article 6, point (1), of Directive (EU) 2016/2341;

(53) 'small institution for occupational retirement provision' means an institution for occupational retirement provision which operates pension schemes which together have less than 100 members in total;

(54) 'credit rating agency' means a credit rating agency as defined in Article 3(1), point (b), of Regulation (EC) No 1060/2009;

(55) 'crypto-asset service provider' means a crypto-asset service provider as defined in the relevant provision of the Regulation on markets in crypto-assets;

(56) 'issuer of asset-referenced tokens' means an issuer of asset-referenced tokens as defined in the relevant provision of the Regulation on markets in crypto-assets;

(57) 'administrator of critical benchmarks' means an administrator of 'critical benchmarks' as defined in Article 3(1), point (25), of Regulation (EU) 2016/1011;

(58) 'crowdfunding service provider' means a crowdfunding service provider as defined in Article 2(1), point (e), of Regulation (EU) 2020/1503 of the European Parliament and of the Council ([35]);

(59) 'securitisation repository' means a securitisation repository as defined in Article 2, point (23), of Regulation (EU) 2017/2402 of the European Parliament and of the Council ([36]);

(60) 'microenterprise' means a financial entity, other than a trading venue, a central counterparty, a trade repository or a central securities depository, which employs fewer than 10 persons and has an annual turnover and/or annual balance sheet total that does not exceed EUR 2 million;

(61) 'Lead Overseer' means the European Supervisory Authority appointed in accordance with Article 31(1), point (b) of this Regulation;

(62) 'Joint Committee' means the committee referred to in Article 54 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010;

(63) 'small enterprise' means a financial entity that employs 10 or more persons, but fewer than 50 persons, and has an annual turnover and/or annual balance sheet total that exceeds EUR 2 million, but does not exceed EUR 10 million;

(64) 'medium-sized enterprise' means a financial entity that is not a small enterprise and employs fewer than 250 persons and has an annual turnover that does not exceed EUR 50 million and/or an annual balance sheet that does not exceed EUR 43 million;

(65) 'public authority' means any government or other public administration entity, including national central banks.

([34]) Directive (EU) 2016/97 of the European Parliament and of the Council of 20 January 2016 on insurance distribution (OJ L 26, 2.2.2016, p. 19).

([35]) Regulation (EU) 2020/1503 of the European Parliament and of the Council of 7 October 2020 on European crowdfunding service providers for business, and amending Regulation (EU) 2017/1129 and Directive (EU) 2019/1937 (OJ L 347, 20.10.2020, p. 1).

([36]) Regulation (EU) 2017/2402 of the European Parliament and of the Council of 12 December 2017 laying down a general framework for securitisation and creating a specific framework for simple, transparent and standardised securitisation, and amending Directives 2009/65/EC, 2009/138/EC and 2011/61/EU and Regulations (EC) No 1060/2009 and (EU) No 648/2012 (OJ L 347, 28.12.2017, p. 35).

Article 4

Proportionality principle

1. Financial entities shall implement the rules laid down in Chapter II in accordance with the principle of proportionality, taking into account their size and overall risk profile, and the nature, scale and complexity of their services, activities and operations.

2. In addition, the application by financial entities of Chapters III, IV and V, Section I, shall be proportionate to their size and overall risk profile, and to the nature, scale and complexity of their services, activities and operations, as specifically provided for in the relevant rules of those Chapters.

3. The competent authorities shall consider the application of the proportionality principle by financial entities when reviewing the consistency of the ICT risk management framework on the basis of the reports submitted upon the request of competent authorities pursuant to Article 6(5) and Article 16(2).

CHAPTER II

ICT risk management

Section I

Article 5

Governance and organisation

1. Financial entities shall have in place an internal governance and control framework that ensures an effective and prudent management of ICT risk, in accordance with Article 6(4), in order to achieve a high level of digital operational resilience.

2. The management body of the financial entity shall define, approve, oversee and be responsible for the implementation of all arrangements related to the ICT risk management framework referred to in Article 6(1).

For the purposes of the first subparagraph, the management body shall:

(a) bear the ultimate responsibility for managing the financial entity's ICT risk;

(b) put in place policies that aim to ensure the maintenance of high standards of availability, authenticity, integrity and confidentiality, of data;

(c) set clear roles and responsibilities for all ICT-related functions and establish appropriate governance arrangements to ensure effective and timely communication, cooperation and coordination among those functions;

(d) bear the overall responsibility for setting and approving the digital operational resilience strategy as referred to in Article 6(8), including the determination of the appropriate risk tolerance level of ICT risk of the financial entity, as referred to in Article 6(8), point (b);

(e) approve, oversee and periodically review the implementation of the financial entity's ICT business continuity policy and ICT response and recovery plans, referred to, respectively, in Article 11(1) and (3), which may be adopted as a dedicated specific policy forming an integral part of the financial entity's overall business continuity policy and response and recovery plan;

(f) approve and periodically review the financial entity's ICT internal audit plans, ICT audits and material modifications to them;

(g) allocate and periodically review the appropriate budget to fulfil the financial entity's digital operational resilience needs in respect of all types of resources, including relevant ICT security awareness programmes and digital operational resilience training referred to in Article 13(6), and ICT skills for all staff;

(h) approve and periodically review the financial entity's policy on arrangements regarding the use of ICT services provided by ICT third-party service providers;

(i) put in place, at corporate level, reporting channels enabling it to be duly informed of the following:

(i) arrangements concluded with ICT third-party service providers on the use of ICT services,

(ii) any relevant planned material changes regarding the ICT third-party service providers,

(iii) the potential impact of such changes on the critical or important functions subject to those arrangements, including a risk analysis summary to assess the impact of those changes, and at least major ICT-related incidents and their impact, as well as response, recovery and corrective measures.

3. Financial entities, other than microenterprises, shall establish a role in order to monitor the arrangements concluded with ICT third-party service providers on the use of ICT services, or shall designate a member of senior management as responsible for overseeing the related risk exposure and relevant documentation.

4. Members of the management body of the financial entity shall actively keep up to date with sufficient knowledge and skills to understand and assess ICT risk and its impact on the operations of the financial entity, including by following specific training on a regular basis, commensurate to the ICT risk being managed.

Section II

Article 6

ICT risk management framework

1. Financial entities shall have a sound, comprehensive and well-documented ICT risk management framework as part of their overall risk management system, which enables them to address ICT risk quickly, efficiently and comprehensively and to ensure a high level of digital operational resilience.

2. The ICT risk management framework shall include at least strategies, policies, procedures, ICT protocols and tools that are necessary to duly and adequately protect all information assets and ICT assets, including computer software, hardware, servers, as well as to protect all relevant physical components and infrastructures, such as premises, data centres and sensitive designated areas, to ensure that all information assets and ICT assets are adequately protected from risks including damage and unauthorised access or usage.

3. In accordance with their ICT risk management framework, financial entities shall minimise the impact of ICT risk by deploying appropriate strategies, policies, procedures, ICT protocols and tools. They shall provide complete and updated information on ICT risk and on their ICT risk management framework to the competent authorities upon their request.

4. Financial entities, other than microenterprises, shall assign the responsibility for managing and overseeing ICT risk to a control function and ensure an appropriate level of independence of such control function in order to avoid conflicts of interest. Financial entities shall ensure appropriate segregation and independence of ICT risk management functions, control functions, and internal audit functions, according to the three lines of defence model, or an internal risk management and control model.

5. The ICT risk management framework shall be documented and reviewed at least once a year, or periodically in the case of microenterprises, as well as upon the occurrence of major ICT-related incidents, and following supervisory instructions or conclusions derived from relevant digital operational resilience testing or audit processes. It shall be continuously improved on the basis of lessons derived from implementation and monitoring. A report on the review of the ICT risk management framework shall be submitted to the competent authority upon its request.

6. The ICT risk management framework of financial entities, other than microenterprises, shall be subject to internal audit by auditors on a regular basis in line with the financial entities' audit plan. Those auditors shall possess sufficient knowledge, skills and expertise in ICT risk, as well as appropriate independence. The frequency and focus of ICT audits shall be commensurate to the ICT risk of the financial entity.

7. Based on the conclusions from the internal audit review, financial entities shall establish a formal follow-up process, including rules for the timely verification and remediation of critical ICT audit findings.

8. The ICT risk management framework shall include a digital operational resilience strategy setting out how the framework shall be implemented. To that end, the digital operational resilience strategy shall include methods to address ICT risk and attain specific ICT objectives, by:

(a) explaining how the ICT risk management framework supports the financial entity's business strategy and objectives;

(b) establishing the risk tolerance level for ICT risk, in accordance with the risk appetite of the financial entity, and analysing the impact tolerance for ICT disruptions;

(c) setting out clear information security objectives, including key performance indicators and key risk metrics;

(d) explaining the ICT reference architecture and any changes needed to reach specific business objectives;

(e) outlining the different mechanisms put in place to detect ICT-related incidents, prevent their impact and provide protection from it;

(f) evidencing the current digital operational resilience situation on the basis of the number of major ICT-related incidents reported and the effectiveness of preventive measures;

(g) implementing digital operational resilience testing, in accordance with Chapter IV of this Regulation;

(h) outlining a communication strategy in the event of ICT-related incidents the disclosure of which is required in accordance with Article 14.

9. Financial entities may, in the context of the digital operational resilience strategy referred to in paragraph 8, define a holistic ICT multi-vendor strategy, at group or entity level, showing key dependencies on ICT third-party service providers and explaining the rationale behind the procurement mix of ICT third-party service providers.

10. Financial entities may, in accordance with Union and national sectoral law, outsource the tasks of verifying compliance with ICT risk management requirements to intra-group or external undertakings. In case of such outsourcing, the financial entity remains fully responsible for the verification of compliance with the ICT risk management requirements.

Article 7

ICT systems, protocols and tools

In order to address and manage ICT risk, financial entities shall use and maintain updated ICT systems, protocols and tools that are:

(a) appropriate to the magnitude of operations supporting the conduct of their activities, in accordance with the proportionality principle as referred to in Article 4;

(b) reliable;

(c) equipped with sufficient capacity to accurately process the data necessary for the performance of activities and the timely provision of services, and to deal with peak orders, message or transaction volumes, as needed, including where new technology is introduced;

(d) technologically resilient in order to adequately deal with additional information processing needs as required under stressed market conditions or other adverse situations.

Article 8

Identification

1. As part of the ICT risk management framework referred to in Article 6(1), financial entities shall identify, classify and adequately document all ICT supported business functions, roles and responsibilities, the information assets and ICT assets supporting those functions, and their roles and dependencies in relation to ICT risk. Financial entities shall review as needed, and at least yearly, the adequacy of this classification and of any relevant documentation.

2. Financial entities shall, on a continuous basis, identify all sources of ICT risk, in particular the risk exposure to and from other financial entities, and assess cyber threats and ICT vulnerabilities relevant to their ICT supported business functions, information assets and ICT assets. Financial entities shall review on a regular basis, and at least yearly, the risk scenarios impacting them.

3. Financial entities, other than microenterprises, shall perform a risk assessment upon each major change in the network and information system infrastructure, in the processes or procedures affecting their ICT supported business functions, information assets or ICT assets.

4. Financial entities shall identify all information assets and ICT assets, including those on remote sites, network resources and hardware equipment, and shall map those considered critical. They shall map the configuration of the information assets and ICT assets and the links and interdependencies between the different information assets and ICT assets.

5. Financial entities shall identify and document all processes that are dependent on ICT third-party service providers, and shall identify interconnections with ICT third-party service providers that provide services that support critical or important functions.

6. For the purposes of paragraphs 1, 4 and 5, financial entities shall maintain relevant inventories and update them periodically and every time any major change as referred to in paragraph 3 occurs.

7. Financial entities, other than microenterprises, shall on a regular basis, and at least yearly, conduct a specific ICT risk assessment on all legacy ICT systems and, in any case before and after connecting technologies, applications or systems.

Article 9

Protection and prevention

1. For the purposes of adequately protecting ICT systems and with a view to organising response measures, financial entities shall continuously monitor and control the security and functioning of ICT systems and tools and shall minimise the impact of ICT risk on ICT systems through the deployment of appropriate ICT security tools, policies and procedures.

2. Financial entities shall design, procure and implement ICT security policies, procedures, protocols and tools that aim to ensure the resilience, continuity and availability of ICT systems, in particular for those supporting critical or important functions, and to maintain high standards of availability, authenticity, integrity and confidentiality of data, whether at rest, in use or in transit.

3. In order to achieve the objectives referred to in paragraph 2, financial entities shall use ICT solutions and processes that are appropriate in accordance with Article 4. Those ICT solutions and processes shall:

(a) ensure the security of the means of transfer of data;

(b) minimise the risk of corruption or loss of data, unauthorised access and technical flaws that may hinder business activity;

(c) prevent the lack of availability, the impairment of the authenticity and integrity, the breaches of confidentiality and the loss of data;

(d) ensure that data is protected from risks arising from data management, including poor administration, processing-related risks and human error.

4. As part of the ICT risk management framework referred to in Article 6(1), financial entities shall:

(a) develop and document an information security policy defining rules to protect the availability, authenticity, integrity and confidentiality of data, information assets and ICT assets, including those of their customers, where applicable;

(b) following a risk-based approach, establish a sound network and infrastructure management structure using appropriate techniques, methods and protocols that may include implementing automated mechanisms to isolate affected information assets in the event of cyber-attacks;

(c) implement policies that limit the physical or logical access to information assets and ICT assets to what is required for legitimate and approved functions and activities only, and establish to that end a set of policies, procedures and controls that address access rights and ensure a sound administration thereof;

(d) implement policies and protocols for strong authentication mechanisms, based on relevant standards and dedicated control systems, and protection measures of cryptographic keys whereby data is encrypted based on results of approved data classification and ICT risk assessment processes;

(e) implement documented policies, procedures and controls for ICT change management, including changes to software, hardware, firmware components, systems or security parameters, that are based on a risk assessment approach and are an integral part of the financial entity's overall change management process, in order to ensure that all changes to ICT systems are recorded, tested, assessed, approved, implemented and verified in a controlled manner;

(f) have appropriate and comprehensive documented policies for patches and updates.

For the purposes of the first subparagraph, point (b), financial entities shall design the network connection infrastructure in a way that allows it to be instantaneously severed or segmented in order to minimise and prevent contagion, especially for interconnected financial processes.

For the purposes of the first subparagraph, point (e), the ICT change management process shall be approved by appropriate lines of management and shall have specific protocols in place.

Article 10

Detection

1. Financial entities shall have in place mechanisms to promptly detect anomalous activities, in accordance with Article 17, including ICT network performance issues and ICT-related incidents, and to identify potential material single points of failure.

All detection mechanisms referred to in the first subparagraph shall be regularly tested in accordance with Article 25.

2. The detection mechanisms referred to in paragraph 1 shall enable multiple layers of control, define alert thresholds and criteria to trigger and initiate ICT-related incident response processes, including automatic alert mechanisms for relevant staff in charge of ICT-related incident response.

3. Financial entities shall devote sufficient resources and capabilities to monitor user activity, the occurrence of ICT anomalies and ICT-related incidents, in particular cyber-attacks.

4. Data reporting service providers shall, in addition, have in place systems that can effectively check trade reports for completeness, identify omissions and obvious errors, and request re-transmission of those reports.

Article 11

Response and recovery

1. As part of the ICT risk management framework referred to in Article 6(1) and based on the identification requirements set out in Article 8, financial entities shall put in place a comprehensive ICT business continuity policy, which may be adopted as a dedicated specific policy, forming an integral part of the overall business continuity policy of the financial entity.

2. Financial entities shall implement the ICT business continuity policy through dedicated, appropriate and documented arrangements, plans, procedures and mechanisms aiming to:

(a) ensure the continuity of the financial entity's critical or important functions;

(b) quickly, appropriately and effectively respond to, and resolve, all ICT-related incidents in a way that limits damage and prioritises the resumption of activities and recovery actions;

(c) activate, without delay, dedicated plans that enable containment measures, processes and technologies suited to each type of ICT-related incident and prevent further damage, as well as tailored response and recovery procedures established in accordance with Article 12;

(d) estimate preliminary impacts, damages and losses;

(e) set out communication and crisis management actions that ensure that updated information is transmitted to all relevant internal staff and external stakeholders in accordance with Article 14, and report to the competent authorities in accordance with Article 19.

3. As part of the ICT risk management framework referred to in Article 6(1), financial entities shall implement associated ICT response and recovery plans which, in the case of financial entities other than microenterprises, shall be subject to independent internal audit reviews.

4. Financial entities shall put in place, maintain and periodically test appropriate ICT business continuity plans, notably with regard to critical or important functions outsourced or contracted through arrangements with ICT third-party service providers.

5. As part of the overall business continuity policy, financial entities shall conduct a business impact analysis (BIA) of their exposures to severe business disruptions. Under the BIA, financial entities shall assess the potential impact of severe business disruptions by means of quantitative and qualitative criteria, using internal and external data and scenario analysis, as appropriate. The BIA shall consider the criticality of identified and mapped business functions, support processes, third-party dependencies and information assets, and their interdependencies. Financial entities shall ensure that ICT assets and ICT services are designed and used in full alignment with the BIA, in particular with regard to adequately ensuring the redundancy of all critical components.

6. As part of their comprehensive ICT risk management, financial entities shall:

(a) test the ICT business continuity plans and the ICT response and recovery plans in relation to ICT systems supporting all functions at least yearly, as well as in the event of any substantive changes to ICT systems supporting critical or important functions;

(b) test the crisis communication plans established in accordance with Article 14.

For the purposes of the first subparagraph, point (a), financial entities, other than microenterprises, shall include in the testing plans scenarios of cyber-attacks and switchovers between the primary ICT infrastructure and the redundant capacity, backups and redundant facilities necessary to meet the obligations set out in Article 12.

Financial entities shall regularly review their ICT business continuity policy and ICT response and recovery plans, taking into account the results of tests carried out in accordance with the first subparagraph and recommendations stemming from audit checks or supervisory reviews.

7. Financial entities, other than microenterprises, shall have a crisis management function, which, in the event of activation of their ICT business continuity plans or ICT response and recovery plans, shall, inter alia, set out clear procedures to manage internal and external crisis communications in accordance with Article 14.

8. Financial entities shall keep readily accessible records of activities before and during disruption events when their ICT business continuity plans and ICT response and recovery plans are activated.

9. Central securities depositories shall provide the competent authorities with copies of the results of the ICT business continuity tests, or of similar exercises.

10. Financial entities, other than microenterprises, shall report to the competent authorities, upon their request, an estimation of aggregated annual costs and losses caused by major ICT-related incidents.

11. In accordance with Article 16 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010, the ESAs, through the Joint Committee, shall by 17 July 2024 develop common guidelines on the estimation of aggregated annual costs and losses referred to in paragraph 10.

Article 12

Backup policies and procedures, restoration and recovery procedures and methods

1. For the purpose of ensuring the restoration of ICT systems and data with minimum downtime, limited disruption and loss, as part of their ICT risk management framework, financial entities shall develop and document:

(a) backup policies and procedures specifying the scope of the data that is subject to the backup and the minimum frequency of the backup, based on the criticality of information or the confidentiality level of the data;

(b) restoration and recovery procedures and methods.

2. Financial entities shall set up backup systems that can be activated in accordance with the backup policies and procedures, as well as restoration and recovery procedures and methods. The activation of backup systems shall not jeopardise the security of the network and information systems or the availability, authenticity, integrity or confidentiality of data. Testing of the backup procedures and restoration and recovery procedures and methods shall be undertaken periodically.

3. When restoring backup data using own systems, financial entities shall use ICT systems that are physically and logically segregated from the source ICT system. The ICT systems shall be securely protected from any unauthorised access or ICT corruption and allow for the timely restoration of services making use of data and system backups as necessary.

For central counterparties, the recovery plans shall enable the recovery of all transactions at the time of disruption to allow the central counterparty to continue to operate with certainty and to complete settlement on the scheduled date.

Data reporting service providers shall additionally maintain adequate resources and have back-up and restoration facilities in place in order to offer and maintain their services at all times.

4. Financial entities, other than microenterprises, shall maintain redundant ICT capacities equipped with resources, capabilities and functions that are adequate to ensure business needs. Microenterprises shall assess the need to maintain such redundant ICT capacities based on their risk profile.

5. Central securities depositories shall maintain at least one secondary processing site endowed with adequate resources, capabilities, functions and staffing arrangements to ensure business needs.

The secondary processing site shall be:

(a) located at a geographical distance from the primary processing site to ensure that it bears a distinct risk profile and to prevent it from being affected by the event which has affected the primary site;

(b) capable of ensuring the continuity of critical or important functions identically to the primary site, or providing the level of services necessary to ensure that the financial entity performs its critical operations within the recovery objectives;

(c) immediately accessible to the financial entity's staff to ensure continuity of critical or important functions in the event that the primary processing site has become unavailable.

6. In determining the recovery time and recovery point objectives for each function, financial entities shall take into account whether it is a critical or important function and the potential overall impact on market efficiency. Such time objectives shall ensure that, in extreme scenarios, the agreed service levels are met.

7. When recovering from an ICT-related incident, financial entities shall perform necessary checks, including any multiple checks and reconciliations, in order to ensure that the highest level of data integrity is maintained. These checks shall also be performed when reconstructing data from external stakeholders, in order to ensure that all data is consistent between systems.

Article 13

Learning and evolving

1. Financial entities shall have in place capabilities and staff to gather information on vulnerabilities and cyber threats, ICT-related incidents, in particular cyber-attacks, and analyse the impact they are likely to have on their digital operational resilience.

2. Financial entities shall put in place post ICT-related incident reviews after a major ICT-related incident disrupts their core activities, analysing the causes of disruption and identifying required improvements to the ICT operations or within the ICT business continuity policy referred to in Article 11.

Financial entities, other than microenterprises, shall, upon request, communicate to the competent authorities, the changes that were implemented following post ICT-related incident reviews as referred to in the first subparagraph.

The post ICT-related incident reviews referred to in the first subparagraph shall determine whether the established procedures were followed and the actions taken were effective, including in relation to the following:

(a) the promptness in responding to security alerts and determining the impact of ICT-related incidents and their severity;

(b) the quality and speed of performing a forensic analysis, where deemed appropriate;

(c) the effectiveness of incident escalation within the financial entity;

(d) the effectiveness of internal and external communication.

3. Lessons derived from the digital operational resilience testing carried out in accordance with Articles 26 and 27 and from real life ICT-related incidents, in particular cyber-attacks, along with challenges faced upon the activation of ICT business continuity plans and ICT response and recovery plans, together with relevant information exchanged with counterparts and assessed during supervisory reviews, shall be duly incorporated on a continuous basis into the ICT risk assessment process. Those findings shall form the basis for appropriate reviews of relevant components of the ICT risk management framework referred to in Article 6(1).

4. Financial entities shall monitor the effectiveness of the implementation of their digital operational resilience strategy set out in Article 6(8). They shall map the evolution of ICT risk over time, analyse the frequency, types, magnitude and evolution of ICT-related incidents, in particular cyber-attacks and their patterns, with a view to understanding the level of ICT risk exposure, in particular in relation to critical or important functions, and enhance the cyber maturity and preparedness of the financial entity.

5. Senior ICT staff shall report at least yearly to the management body on the findings referred to in paragraph 3 and put forward recommendations.

6. Financial entities shall develop ICT security awareness programmes and digital operational resilience training as compulsory modules in their staff training schemes. Those programmes and training shall be applicable to all employees and to senior management staff, and shall have a level of complexity commensurate to the remit of their functions. Where appropriate, financial entities shall also include ICT third-party service providers in their relevant training schemes in accordance with Article 30(2), point (i).

7. Financial entities, other than microenterprises, shall monitor relevant technological developments on a continuous basis, also with a view to understanding the possible impact of the deployment of such new technologies on ICT security requirements and digital operational resilience. They shall keep up-to-date with the latest ICT risk management processes, in order to effectively combat current or new forms of cyber-attacks.

Article 14

Communication

1. As part of the ICT risk management framework referred to in Article 6(1), financial entities shall have in place crisis communication plans enabling a responsible disclosure of, at least, major ICT-related incidents or vulnerabilities to clients and counterparts as well as to the public, as appropriate.

2. As part of the ICT risk management framework, financial entities shall implement communication policies for internal staff and for external stakeholders. Communication policies for staff shall take into account the need to differentiate between staff involved in ICT risk management, in particular the staff responsible for response and recovery, and staff that needs to be informed.

3. At least one person in the financial entity shall be tasked with implementing the communication strategy for ICT-related incidents and fulfil the public and media function for that purpose.

Article 15

Further harmonisation of ICT risk management tools, methods, processes and policies

The ESAs shall, through the Joint Committee, in consultation with the European Union Agency on Cybersecurity (ENISA), develop common draft regulatory technical standards in order to:

(a) specify further elements to be included in the ICT security policies, procedures, protocols and tools referred to in Article 9(2), with a view to ensuring the security of networks, enable adequate safeguards against intrusions and data misuse, preserve the availability, authenticity, integrity and confidentiality of data, including cryptographic techniques, and guarantee an accurate and prompt data transmission without major disruptions and undue delays;

(b) develop further components of the controls of access management rights referred to in Article 9(4), point (c), and associated human resource policy specifying access rights, procedures for granting and revoking rights, monitoring anomalous behaviour in relation to ICT risk through appropriate indicators, including for network use patterns, hours, IT activity and unknown devices;

(c) develop further the mechanisms specified in Article 10(1) enabling a prompt detection of anomalous activities and the criteria set out in Article 10(2) triggering ICT-related incident detection and response processes;

(d) specify further the components of the ICT business continuity policy referred to in Article 11(1);

(e) specify further the testing of ICT business continuity plans referred to in Article 11(6) to ensure that such testing duly takes into account scenarios in which the quality of the provision of a critical or important function deteriorates to an unacceptable level or fails, and duly considers the potential impact of the insolvency, or other failures, of any relevant ICT third-party service provider and, where relevant, the political risks in the respective providers' jurisdictions;

(f) specify further the components of the ICT response and recovery plans referred to in Article 11(3);

(g) specifying further the content and format of the report on the review of the ICT risk management framework referred to in Article 6(5);

When developing those draft regulatory technical standards, the ESAs shall take into account the size and the overall risk profile of the financial entity, and the nature, scale and complexity of its services, activities and operations, while duly taking into consideration any specific feature arising from the distinct nature of activities across different financial services sectors.

The ESAs shall submit those draft regulatory technical standards to the Commission by 17 January 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in the first paragraph in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

Article 16

Simplified ICT risk management framework

1. Articles 5 to 15 of this Regulation shall not apply to small and non-interconnected investment firms, payment institutions exempted pursuant to Directive (EU) 2015/2366; institutions exempted pursuant to Directive 2013/36/EU in respect of which Member States have decided not to apply the option referred to in Article 2(4) of this Regulation; electronic money institutions exempted pursuant to Directive 2009/110/EC; and small institutions for occupational retirement provision.

Without prejudice to the first subparagraph, the entities listed in the first subparagraph shall:

(a) put in place and maintain a sound and documented ICT risk management framework that details the mechanisms and measures aimed at a quick, efficient and comprehensive management of ICT risk, including for the protection of relevant physical components and infrastructures;

(b) continuously monitor the security and functioning of all ICT systems;

(c) minimise the impact of ICT risk through the use of sound, resilient and updated ICT systems, protocols and tools which are appropriate to support the performance of their activities and the provision of services and adequately protect availability, authenticity, integrity and confidentiality of data in the network and information systems;

(d) allow sources of ICT risk and anomalies in the network and information systems to be promptly identified and detected and ICT-related incidents to be swiftly handled;

(e) identify key dependencies on ICT third-party service providers;

(f) ensure the continuity of critical or important functions, through business continuity plans and response and recovery measures, which include, at least, back-up and restoration measures;

(g) test, on a regular basis, the plans and measures referred to in point (f), as well as the effectiveness of the controls implemented in accordance with points (a) and (c);

(h) implement, as appropriate, relevant operational conclusions resulting from the tests referred to in point (g) and from post-incident analysis into the ICT risk assessment process and develop, according to needs and ICT risk profile, ICT security awareness programmes and digital operational resilience training for staff and management.

2. The ICT risk management framework referred to in paragraph 1, second subparagraph, point (a), shall be documented and reviewed periodically and upon the occurrence of major ICT-related incidents in compliance with supervisory instructions. It shall be continuously improved on the basis of lessons derived from implementation and monitoring. A report on the review of the ICT risk management framework shall be submitted to the competent authority upon its request.

3. The ESAs shall, through the Joint Committee, in consultation with the ENISA, develop common draft regulatory technical standards in order to:

(a) specify further the elements to be included in the ICT risk management framework referred to in paragraph 1, second subparagraph, point (a);

(b) specify further the elements in relation to systems, protocols and tools to minimise the impact of ICT risk referred to in paragraph 1, second subparagraph, point (c), with a view to ensuring the security of networks, enabling adequate safeguards against intrusions and data misuse and preserving the availability, authenticity, integrity and confidentiality of data;

(c) specify further the components of the ICT business continuity plans referred to in paragraph 1, second subparagraph, point (f);

(d) specify further the rules on the testing of business continuity plans and ensure the effectiveness of the controls referred to in paragraph 1, second subparagraph, point (g) and ensure that such testing duly takes into account scenarios in which the quality of the provision of a critical or important function deteriorates to an unacceptable level or fails;

(e) specify further the content and format of the report on the review of the ICT risk management framework referred to in paragraph 2.

When developing those draft regulatory technical standards, the ESAs shall take into account the size and the overall risk profile of the financial entity, and the nature, scale and complexity of its services, activities and operations.

The ESAs shall submit those draft regulatory technical standards to the Commission by 17 January 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in the first subparagraph in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

CHAPTER III

ICT-related incident management, classification and reporting

Article 17

ICT-related incident management process

1. Financial entities shall define, establish and implement an ICT-related incident management process to detect, manage and notify ICT-related incidents.

2. Financial entities shall record all ICT-related incidents and significant cyber threats. Financial entities shall establish appropriate procedures and processes to ensure a consistent and integrated monitoring, handling and follow-up of ICT-related incidents, to ensure that root causes are identified, documented and addressed in order to prevent the occurrence of such incidents.

3. The ICT-related incident management process referred to in paragraph 1 shall:

(a) put in place early warning indicators;

(b) establish procedures to identify, track, log, categorise and classify ICT-related incidents according to their priority and severity and according to the criticality of the services impacted, in accordance with the criteria set out in Article 18(1);

(c) assign roles and responsibilities that need to be activated for different ICT-related incident types and scenarios;

(d) set out plans for communication to staff, external stakeholders and media in accordance with Article 14 and for notification to clients, for internal escalation procedures, including ICT-related customer complaints, as well as for the provision of information to financial entities that act as counterparts, as appropriate;

(e) ensure that at least major ICT-related incidents are reported to relevant senior management and inform the management body of at least major ICT-related incidents, explaining the impact, response and additional controls to be established as a result of such ICT-related incidents;

(f) establish ICT-related incident response procedures to mitigate impacts and ensure that services become operational and secure in a timely manner.

Article 18

Classification of ICT-related incidents and cyber threats

1. Financial entities shall classify ICT-related incidents and shall determine their impact based on the following criteria:

(a) the number and/or relevance of clients or financial counterparts affected and, where applicable, the amount or number of transactions affected by the ICT-related incident, and whether the ICT-related incident has caused reputational impact;

(b) the duration of the ICT-related incident, including the service downtime;

(c) the geographical spread with regard to the areas affected by the ICT-related incident, particularly if it affects more than two Member States;

(d) the data losses that the ICT-related incident entails, in relation to availability, authenticity, integrity or confidentiality of data;

(e) the criticality of the services affected, including the financial entity's transactions and operations;

(f) the economic impact, in particular direct and indirect costs and losses, of the ICT-related incident in both absolute and relative terms.

2. Financial entities shall classify cyber threats as significant based on the criticality of the services at risk, including the financial entity's transactions and operations, number and/or relevance of clients or financial counterparts targeted and the geographical spread of the areas at risk.

3. The ESAs shall, through the Joint Committee and in consultation with the ECB and ENISA, develop common draft regulatory technical standards further specifying the following:

(a) the criteria set out in paragraph 1, including materiality thresholds for determining major ICT-related incidents or, as applicable, major operational or security payment-related incidents, that are subject to the reporting obligation laid down in Article 19(1);

(b) the criteria to be applied by competent authorities for the purpose of assessing the relevance of major ICT-related incidents or, as applicable, major operational or security payment-related incidents, to relevant competent authorities in other Member States', and the details of reports of major ICT-related incidents or, as applicable, major operational or security payment-related incidents, to be shared with other competent authorities pursuant to Article 19(6) and (7);

(c) the criteria set out in paragraph 2 of this Article, including high materiality thresholds for determining significant cyber threats.

4. When developing the common draft regulatory technical standards referred to in paragraph 3 of this Article, the ESAs shall take into account the criteria set out in Article 4(2), as well as international standards, guidance and specifications developed and published by ENISA, including, where appropriate, specifications for other economic sectors. For the purposes of applying the criteria set out in Article 4(2), the ESAs shall duly consider the need for microenterprises and small and medium-sized enterprises to mobilise sufficient resources and capabilities to ensure that ICT-related incidents are managed swiftly.

The ESAs shall submit those common draft regulatory technical standards to the Commission by 17 January 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in paragraph 3 in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

Article 19

Reporting of major ICT-related incidents and voluntary notification of significant cyber threats

1. Financial entities shall report major ICT-related incidents to the relevant competent authority as referred to in Article 46 in accordance with paragraph 4 of this Article.

Where a financial entity is subject to supervision by more than one national competent authority referred to in Article 46, Member States shall designate a single competent authority as the relevant competent authority responsible for carrying out the functions and duties provided for in this Article.

Credit institutions classified as significant, in accordance with Article 6(4) of Regulation (EU) No 1024/2013, shall report major ICT-related incidents to the relevant national competent authority designated in accordance with Article 4 of Directive 2013/36/EU, which shall immediately transmit that report to the ECB.

For the purpose of the first subparagraph, financial entities shall produce, after collecting and analysing all relevant information, the initial notification and reports referred to in paragraph 4 of this Article using the templates referred to in Article 20 and submit them to the competent authority. In the event that a technical impossibility prevents the submission of the initial notification using the template, financial entities shall notify the competent authority about it via alternative means.

The initial notification and reports referred to in paragraph 4 shall include all information necessary for the competent authority to determine the significance of the major ICT-related incident and assess possible cross-border impacts.

Without prejudice to the reporting pursuant to the first subparagraph by the financial entity to the relevant competent authority, Member States may additionally determine that some or all financial entities shall also provide the initial notification and each report referred to in paragraph 4 of this Article using the templates referred to in Article 20 to the competent authorities or the computer security incident response teams (CSIRTs) designated or established in accordance with Directive (EU) 2022/2555.

2. Financial entities may, on a voluntary basis, notify significant cyber threats to the relevant competent authority when they deem the threat to be of relevance to the financial system, service users or clients. The relevant competent authority may provide such information to other relevant authorities referred to in paragraph 6.

Credit institutions classified as significant, in accordance with Article 6(4) of Regulation (EU) No 1024/2013, may, on a voluntary basis, notify significant cyber threats to relevant national competent authority, designated in accordance with Article 4 of Directive 2013/36/EU, which shall immediately transmit the notification to the ECB.

Member States may determine that those financial entities that on a voluntary basis notify in accordance with the first subparagraph may also transmit that notification to the CSIRTs designated or established in accordance with Directive (EU) 2022/2555.

3. Where a major ICT-related incident occurs and has an impact on the financial interests of clients, financial entities shall, without undue delay as soon as they become aware of it, inform their clients about the major ICT-related incident and about the measures that have been taken to mitigate the adverse effects of such incident.

In the case of a significant cyber threat, financial entities shall, where applicable, inform their clients that are potentially affected of any appropriate protection measures which the latter may consider taking.

4. Financial entities shall, within the time limits to be laid down in accordance with Article 20, first paragraph, point (a), point (ii), submit the following to the relevant competent authority:

(a) an initial notification;

(b) an intermediate report after the initial notification referred to in point (a), as soon as the status of the original incident has changed significantly or the handling of the major ICT-related incident has changed based on new information available, followed, as appropriate, by updated notifications every time a relevant status update is available, as well as upon a specific request of the competent authority;

(c) a final report, when the root cause analysis has been completed, regardless of whether mitigation measures have already been implemented, and when the actual impact figures are available to replace estimates.

5. Financial entities may outsource, in accordance with Union and national sectoral law, the reporting obligations under this Article to a third-party service provider. In case of such outsourcing, the financial entity remains fully responsible for the fulfilment of the incident reporting requirements.

6. Upon receipt of the initial notification and of each report referred to in paragraph 4, the competent authority shall, in a timely manner, provide details of the major ICT-related incident to the following recipients based, as applicable, on their respective competences:

(a) EBA, ESMA or EIOPA;

(b) the ECB, in the case of financial entities referred to in Article 2(1), points (a), (b) and (d);

(c) the competent authorities, single points of contact or CSIRTs designated or established in accordance with Directive (EU) 2022/2555;

(d) the resolution authorities, as referred to in Article 3 of Directive 2014/59/EU, and the Single Resolution Board (SRB) with respect to entities referred to in Article 7(2) of Regulation (EU) No 806/2014 of the European Parliament and of the Council ([37]), and with respect to entities and groups referred to in Article 7(4)(b) and (5) of Regulation (EU) No 806/2014 if such details concern incidents that pose a risk to ensuring critical functions within the meaning of Article 2(1), point (35), of Directive 2014/59/EU; and

(e) other relevant public authorities under national law.

7. Following receipt of information in accordance with paragraph 6, EBA, ESMA or EIOPA and the ECB, in consultation with ENISA and in cooperation with the relevant competent authority, shall assess whether the major ICT-related incident is relevant for competent authorities in other Member States. Following that assessment, EBA, ESMA or EIOPA shall, as soon as possible, notify relevant competent authorities in other Member States accordingly. The ECB shall notify the members of the European System of Central Banks on issues relevant to the payment system. Based on that notification, the competent authorities shall, where appropriate, take all of the necessary measures to protect the immediate stability of the financial system.

([37]) Regulation (EU) No 806/2014 of the European Parliament and of the Council of 15 July 2014 establishing uniform rules and a uniform procedure for the resolution of credit institutions and certain investment firms in the framework of a Single Resolution Mechanism and a Single Resolution Fund and amending Regulation (EU) No 1093/2010 (OJ L 225, 30.7.2014, p. 1).

8. The notification to be done by ESMA pursuant to paragraph 7 of this Article shall be without prejudice to the responsibility of the competent authority to urgently transmit the details of the major ICT-related incident to the relevant authority in the host Member State, where a central securities depository has significant cross-border activity in the host Member State, the major ICT-related incident is likely to have severe consequences for the financial markets of the host Member State and where there are cooperation arrangements among competent authorities related to the supervision of financial entities.

Article 20

Harmonisation of reporting content and templates

The ESAs, through the Joint Committee, and in consultation with ENISA and the ECB, shall develop:

(a) common draft regulatory technical standards in order to:

(i) establish the content of the reports for major ICT-related incidents in order to reflect the criteria laid down in Article 18(1) and incorporate further elements, such as details for establishing the relevance of the reporting for other Member States and whether it constitutes a major operational or security payment-related incident or not;

(ii) determine the time limits for the initial notification and for each report referred to in Article 19(4);

(iii) establish the content of the notification for significant cyber threats.

When developing those draft regulatory technical standards, the ESAs shall take into account the size and the overall risk profile of the financial entity, and the nature, scale and complexity of its services, activities and operations, and in particular, with a view to ensuring that, for the purposes of this paragraph, point (a), point (ii), different time limits may reflect, as appropriate, specificities of financial sectors, without prejudice to maintaining a consistent approach to ICT-related incident reporting pursuant to this Regulation and to Directive (EU) 2022/2555. The ESAs shall, as applicable, provide justification when deviating from the approaches taken in the context of that Directive;

(b) common draft implementing technical standards in order to establish the standard forms, templates and procedures for financial entities to report a major ICT-related incident and to notify a significant cyber threat.

The ESAs shall submit the common draft regulatory technical standards referred to in the first paragraph, point (a), and the common draft implementing technical standards referred to in the first paragraph, point (b), to the Commission by 17 July 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the common regulatory technical standards referred to in the first paragraph, point (a), in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

Power is conferred on the Commission to adopt the common implementing technical standards referred to in the first paragraph, point (b), in accordance with Article 15 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

Article 21

Centralisation of reporting of major ICT-related incidents

1. The ESAs, through the Joint Committee, and in consultation with the ECB and ENISA, shall prepare a joint report assessing the feasibility of further centralisation of incident reporting through the establishment of a single EU Hub for major ICT-related incident reporting by financial entities. The joint report shall explore ways to facilitate the flow of ICT-related incident reporting, reduce associated costs and underpin thematic analyses with a view to enhancing supervisory convergence.

2. The joint report referred to in paragraph 1 shall comprise at least the following elements:

(a) prerequisites for the establishment of a single EU Hub;

(b) benefits, limitations and risks, including risks associated with the high concentration of sensitive information;

(c) the necessary capability to ensure interoperability with regard to other relevant reporting schemes;

(d) elements of operational management;

(e) conditions of membership;

(f) technical arrangements for financial entities and national competent authorities to access the single EU Hub;

(g) a preliminary assessment of financial costs incurred by setting-up the operational platform supporting the single EU Hub, including the requisite expertise.

3. The ESAs shall submit the report referred to in paragraph 1 to the European Parliament, to the Council and to the Commission by 17 January 2025.

Article 22

Supervisory feedback

1. Without prejudice to the technical input, advice or remedies and subsequent follow-up which may be provided, where applicable, in accordance with national law, by the CSIRTs under Directive (EU) 2022/2555, the competent authority shall, upon receipt of the initial notification and of each report as referred to in Article 19(4), acknowledge receipt and may, where feasible, provide in a timely manner relevant and proportionate feedback or high-level guidance to the financial entity, in particular by making available any relevant anonymised information and intelligence on similar threats, and may discuss remedies applied at the level of the financial entity and ways to minimise and mitigate adverse impact across the financial sector. Without prejudice to the supervisory feedback received, financial entities shall remain fully responsible for the handling and for consequences of the ICT-related incidents reported pursuant to Article 19(1).

2. The ESAs shall, through the Joint Committee, on an anonymised and aggregated basis, report yearly on major ICT-related incidents, the details of which shall be provided by competent authorities in accordance with Article 19(6), setting out at least the number of major ICT-related incidents, their nature and their impact on the operations of financial entities or clients, remedial actions taken and costs incurred.

The ESAs shall issue warnings and produce high-level statistics to support ICT threat and vulnerability assessments.

Article 23

Operational or security payment-related incidents concerning credit institutions, payment institutions, account information service providers, and electronic money institutions

The requirements laid down in this Chapter shall also apply to operational or security payment-related incidents and to major operational or security payment-related incidents, where they concern credit institutions, payment institutions, account information service providers, and electronic money institutions.

CHAPTER IV

Digital operational resilience testing

Article 24

General requirements for the performance of digital operational resilience testing

1. For the purpose of assessing preparedness for handling ICT-related incidents, of identifying weaknesses, deficiencies and gaps in digital operational resilience, and of promptly implementing corrective measures, financial entities, other than microenterprises, shall, taking into account the criteria set out in Article 4(2), establish, maintain and review a sound and comprehensive digital operational resilience testing programme as an integral part of the ICT risk-management framework referred to in Article 6.

2. The digital operational resilience testing programme shall include a range of assessments, tests, methodologies, practices and tools to be applied in accordance with Articles 25 and 26.

3. When conducting the digital operational resilience testing programme referred to in paragraph 1 of this Article, financial entities, other than microenterprises, shall follow a risk-based approach taking into account the criteria set out in Article 4(2) duly considering the evolving landscape of ICT risk, any specific risks to which the financial entity concerned is or might be exposed, the criticality of information assets and of services provided, as well as any other factor the financial entity deems appropriate.

4. Financial entities, other than microenterprises, shall ensure that tests are undertaken by independent parties, whether internal or external. Where tests are undertaken by an internal tester, financial entities shall dedicate sufficient resources and ensure that conflicts of interest are avoided throughout the design and execution phases of the test.

5. Financial entities, other than microenterprises, shall establish procedures and policies to prioritise, classify and remedy all issues revealed throughout the performance of the tests and shall establish internal validation methodologies to ascertain that all identified weaknesses, deficiencies or gaps are fully addressed.

6. Financial entities, other than microenterprises, shall ensure, at least yearly, that appropriate tests are conducted on all ICT systems and applications supporting critical or important functions.

Article 25

Testing of ICT tools and systems

1. The digital operational resilience testing programme referred to in Article 24 shall provide, in accordance with the criteria set out in Article 4(2), for the execution of appropriate tests, such as vulnerability assessments and scans, open source analyses, network security assessments, gap analyses, physical security reviews, questionnaires and scanning software solutions, source code reviews where feasible, scenario-based tests, compatibility testing, performance testing, end-to-end testing and penetration testing.

2. Central securities depositories and central counterparties shall perform vulnerability assessments before any deployment or redeployment of new or existing applications and infrastructure components, and ICT services supporting critical or important functions of the financial entity.

3. Microenterprises shall perform the tests referred to in paragraph 1 by combining a risk-based approach with a strategic planning of ICT testing, by duly considering the need to maintain a balanced approach between the scale of resources and the time to be allocated to the ICT testing provided for in this Article, on the one hand, and the urgency, type of risk, criticality of information assets and of services provided, as well as any other relevant factor, including the financial entity's ability to take calculated risks, on the other hand.

Article 26

Advanced testing of ICT tools, systems and processes based on TLPT

1. Financial entities, other than entities referred to in Article 16(1), first subparagraph, and other than microenterprises, which are identified in accordance with paragraph 8, third subparagraph, of this Article, shall carry out at least every 3 years advanced testing by means of TLPT. Based on the risk profile of the financial entity and taking into account operational circumstances, the competent authority may, where necessary, request the financial entity to reduce or increase this frequency.

2. Each threat-led penetration test shall cover several or all critical or important functions of a financial entity, and shall be performed on live production systems supporting such functions.

Financial entities shall identify all relevant underlying ICT systems, processes and technologies supporting critical or important functions and ICT services, including those supporting the critical or important functions which have been outsourced or contracted to ICT third-party service providers.

Financial entities shall assess which critical or important functions need to be covered by the TLPT. The result of this assessment shall determine the precise scope of TLPT and shall be validated by the competent authorities.

3. Where ICT third-party service providers are included in the scope of TLPT, the financial entity shall take the necessary measures and safeguards to ensure the participation of such ICT third-party service providers in the TLPT and shall retain at all times full responsibility for ensuring compliance with this Regulation.

4. Without prejudice to paragraph 2, first and second subparagraphs, where the participation of an ICT third-party service provider in the TLPT, referred to in paragraph 3, is reasonably expected to have an adverse impact on the quality or security of services delivered by the ICT third-party service provider to customers that are entities falling outside the scope of this Regulation, or on the confidentiality of the data related to such services, the financial entity and the ICT third-party service provider may agree in writing that the ICT third-party service provider directly enters into contractual arrangements with an external tester, for the purpose of conducting, under the direction of one designated financial entity, a pooled TLPT involving several financial entities (pooled testing) to which the ICT third-party service provider provides ICT services.

That pooled testing shall cover the relevant range of ICT services supporting critical or important functions contracted to the respective ICT third-party service provider by the financial entities. The pooled testing shall be considered TLPT carried out by the financial entities participating in the pooled testing.

The number of financial entities participating in the pooled testing shall be duly calibrated taking into account the complexity and types of services involved.

5. Financial entities shall, with the cooperation of ICT third-party service providers and other parties involved, including the testers but excluding the competent authorities, apply effective risk management controls to mitigate the risks of any potential impact on data, damage to assets, and disruption to critical or important functions, services or operations at the financial entity itself, its counterparts or to the financial sector.

6. At the end of the testing, after reports and remediation plans have been agreed, the financial entity and, where applicable, the external testers shall provide to the authority, designated in accordance with paragraph 9 or 10, a summary of the relevant findings, the remediation plans and the documentation demonstrating that the TLPT has been conducted in accordance with the requirements.

7. Authorities shall provide financial entities with an attestation confirming that the test was performed in accordance with the requirements as evidenced in the documentation in order to allow for mutual recognition of threat led penetration tests between competent authorities. The financial entity shall notify the relevant competent authority of the attestation, the summary of the relevant findings and the remediation plans.

Without prejudice to such attestation, financial entities shall remain at all times fully responsible for the impact of the tests referred to in paragraph 4.

8. Financial entities shall contract testers for the purposes of undertaking TLPT in accordance with Article 27. When financial entities use internal testers for the purposes of undertaking TLPT, they shall contract external testers every three tests.

Credit institutions that are classified as significant in accordance with Article 6(4) of Regulation (EU) No 1024/2013, shall only use external testers in accordance with Article 27(1), points (a) to (e).

Competent authorities shall identify financial entities that are required to perform TLPT taking into account the criteria set out in Article 4(2), based on an assessment of the following:

(a) impact-related factors, in particular the extent to which the services provided and activities undertaken by the financial entity impact the financial sector;

(b) possible financial stability concerns, including the systemic character of the financial entity at Union or national level, as applicable;

(c) specific ICT risk profile, level of ICT maturity of the financial entity or technology features involved.

9. Member States may designate a single public authority in the financial sector to be responsible for TLPT-related matters in the financial sector at national level and shall entrust it with all competences and tasks to that effect.

10. In the absence of a designation in accordance with paragraph 9 of this Article, and without prejudice to the power to identify the financial entities that are required to perform TLPT, a competent authority may delegate the exercise of some or all of the tasks referred to in this Article and Article 27 to another national authority in the financial sector.

11. The ESAs shall, in agreement with the ECB, develop joint draft regulatory technical standards in accordance with the TIBER-EU framework in order to specify further:

(a) the criteria used for the purpose of the application of paragraph 8, second subparagraph;

(b) the requirements and standards governing the use of internal testers;

(c) the requirements in relation to:

  (i) the scope of TLPT referred to in paragraph 2;

  (ii) the testing methodology and approach to be followed for each specific phase of the testing process;

  (iii) the results, closure and remediation stages of the testing;

(d) the type of supervisory and other relevant cooperation which are needed for the implementation of TLPT, and for the facilitation of mutual recognition of that testing, in the context of financial entities that operate in more than one Member State, to allow an appropriate level of supervisory involvement and a flexible implementation to cater for specificities of financial sub-sectors or local financial markets.

When developing those draft regulatory technical standards, the ESAs shall give due consideration to any specific feature arising from the distinct nature of activities across different financial services sectors.

The ESAs shall submit those draft regulatory technical standards to the Commission by 17 July 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in the first subparagraph in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

Article 27

Requirements for testers for the carrying out of TLPT

1. Financial entities shall only use testers for the carrying out of TLPT, that:

(a) are of the highest suitability and reputability;

(b) possess technical and organisational capabilities and demonstrate specific expertise in threat intelligence, penetration testing and red team testing;

(c) are certified by an accreditation body in a Member State or adhere to formal codes of conduct or ethical frameworks;

(d) provide an independent assurance, or an audit report, in relation to the sound management of risks associated with the carrying out of TLPT, including the due protection of the financial entity's confidential information and redress for the business risks of the financial entity;

(e) are duly and fully covered by relevant professional indemnity insurances, including against risks of misconduct and negligence.

2. When using internal testers, financial entities shall ensure that, in addition to the requirements in paragraph 1, the following conditions are met:

(a) such use has been approved by the relevant competent authority or by the single public authority designated in accordance with Article 26(9) and (10);

(b) the relevant competent authority has verified that the financial entity has sufficient dedicated resources and ensured that conflicts of interest are avoided throughout the design and execution phases of the test; and

(c) the threat intelligence provider is external to the financial entity.

3. Financial entities shall ensure that contracts concluded with external testers require a sound management of the TLPT results and that any data processing thereof, including any generation, store, aggregation, draft, report, communication or destruction, do not create risks to the financial entity.

CHAPTER V

Managing of ICT third-party risk

Section I

Key principles for a sound management of ICT third-party risk

Article 28

General principles

1. Financial entities shall manage ICT third-party risk as an integral component of ICT risk within their ICT risk management framework as referred to in Article 6(1), and in accordance with the following principles:

(a) financial entities that have in place contractual arrangements for the use of ICT services to run their business operations shall, at all times, remain fully responsible for compliance with, and the discharge of, all obligations under this Regulation and applicable financial services law;

(b) financial entities' management of ICT third-party risk shall be implemented in light of the principle of proportionality, taking into account:

(i) the nature, scale, complexity and importance of ICT-related dependencies,

(ii) the risks arising from contractual arrangements on the use of ICT services concluded with ICT third-party service providers, taking into account the criticality or importance of the respective service, process or function, and the potential impact on the continuity and availability of financial services and activities, at individual and at group level.

2. As part of their ICT risk management framework, financial entities, other than entities referred to in Article 16(1), first subparagraph, and other than microenterprises, shall adopt, and regularly review, a strategy on ICT third-party risk, taking into account the multi-vendor strategy referred to in Article 6(9), where applicable. The strategy on ICT third-party risk shall include a policy on the use of ICT services supporting critical or important functions provided by ICT third-party service providers and shall apply on an individual basis and, where relevant, on a sub-consolidated and consolidated basis. The management body shall, on the basis of an assessment of the overall risk profile of the financial entity and the scale and complexity of the business services, regularly review the risks identified in respect to contractual arrangements on the use of ICT services supporting critical or important functions.

3. As part of their ICT risk management framework, financial entities shall maintain and update at entity level, and at sub-consolidated and consolidated levels, a register of information in relation to all contractual arrangements on the use of ICT services provided by ICT third-party service providers.

The contractual arrangements referred to in the first subparagraph shall be appropriately documented, distinguishing between those that cover ICT services supporting critical or important functions and those that do not.

Financial entities shall report at least yearly to the competent authorities on the number of new arrangements on the use of ICT services, the categories of ICT third-party service providers, the type of contractual arrangements and the ICT services and functions which are being provided.

Financial entities shall make available to the competent authority, upon its request, the full register of information or, as requested, specified sections thereof, along with any information deemed necessary to enable the effective supervision of the financial entity.

Financial entities shall inform the competent authority in a timely manner about any planned contractual arrangement on the use of ICT services supporting critical or important functions as well as when a function has become critical or important.

4. Before entering into a contractual arrangement on the use of ICT services, financial entities shall:

(a) assess whether the contractual arrangement covers the use of ICT services supporting a critical or important function;

(b) assess if supervisory conditions for contracting are met;

(c) identify and assess all relevant risks in relation to the contractual arrangement, including the possibility that such contractual arrangement may contribute to reinforcing ICT concentration risk as referred to in Article 29;

(d) undertake all due diligence on prospective ICT third-party service providers and ensure throughout the selection and assessment processes that the ICT third-party service provider is suitable;

(e) identify and assess conflicts of interest that the contractual arrangement may cause.

5. Financial entities may only enter into contractual arrangements with ICT third-party service providers that comply with appropriate information security standards. When those contractual arrangements concern critical or important functions, financial entities shall, prior to concluding the arrangements, take due consideration of the use, by ICT third-party service providers, of the most up-to-date and highest quality information security standards.

6. In exercising access, inspection and audit rights over the ICT third-party service provider, financial entities shall, on the basis of a risk-based approach, pre-determine the frequency of audits and inspections as well as the areas to be audited through adhering to commonly accepted audit standards in line with any supervisory instruction on the use and incorporation of such audit standards.

Where contractual arrangements concluded with ICT third-party service providers on the use of ICT services entail high technical complexity, the financial entity shall verify that auditors, whether internal or external, or a pool of auditors, possess appropriate skills and knowledge to effectively perform the relevant audits and assessments.

7. Financial entities shall ensure that contractual arrangements on the use of ICT services may be terminated in any of the following circumstances:

(a) significant breach by the ICT third-party service provider of applicable laws, regulations or contractual terms;

(b) circumstances identified throughout the monitoring of ICT third-party risk that are deemed capable of altering the performance of the functions provided through the contractual arrangement, including material changes that affect the arrangement or the situation of the ICT third-party service provider;

(c) ICT third-party service provider's evidenced weaknesses pertaining to its overall ICT risk management and in particular in the way it ensures the availability, authenticity, integrity and, confidentiality, of data, whether personal or otherwise sensitive data, or non-personal data;

(d) where the competent authority can no longer effectively supervise the financial entity as a result of the conditions of, or circumstances related to, the respective contractual arrangement.

8. For ICT services supporting critical or important functions, financial entities shall put in place exit strategies. The exit strategies shall take into account risks that may emerge at the level of ICT third-party service providers, in particular a possible failure on their part, a deterioration of the quality of the ICT services provided, any business disruption due to inappropriate or failed provision of ICT services or any material risk arising in relation to the appropriate and continuous deployment of the respective ICT service, or the termination of contractual arrangements with ICT third-party service providers under any of the circumstances listed in paragraph 7.

Financial entities shall ensure that they are able to exit contractual arrangements without:

(a) disruption to their business activities,

(b) limiting compliance with regulatory requirements,

(c) detriment to the continuity and quality of services provided to clients.

Exit plans shall be comprehensive, documented and, in accordance with the criteria set out in Article 4(2), shall be sufficiently tested and reviewed periodically.

Financial entities shall identify alternative solutions and develop transition plans enabling them to remove the contracted ICT services and the relevant data from the ICT third-party service provider and to securely and integrally transfer them to alternative providers or reincorporate them in-house.

Financial entities shall have appropriate contingency measures in place to maintain business continuity in the event of the circumstances referred to in the first subparagraph.

9. The ESAs shall, through the Joint Committee, develop draft implementing technical standards to establish the standard templates for the purposes of the register of information referred to in paragraph 3, including information that is common to all contractual arrangements on the use of ICT services. The ESAs shall submit those draft implementing technical standards to the Commission by 17 January 2024.

Power is conferred on the Commission to adopt the implementing technical standards referred to in the first subparagraph in accordance with Article 15 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

10. The ESAs shall, through the Joint Committee, develop draft regulatory technical standards to further specify the detailed content of the policy referred to in paragraph 2 in relation to the contractual arrangements on the use of ICT services supporting critical or important functions provided by ICT third-party service providers.

When developing those draft regulatory technical standards, the ESAs shall take into account the size and the overall risk profile of the financial entity, and the nature, scale and complexity of its services, activities and operations. The ESAs shall submit those draft regulatory technical standards to the Commission by 17 January 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in the first subparagraph in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

Article 29

Preliminary assessment of ICT concentration risk at entity level

1. When performing the identification and assessment of risks referred to in Article 28(4), point (c), financial entities shall also take into account whether the envisaged conclusion of a contractual arrangement in relation to ICT services supporting critical or important functions would lead to any of the following:

(a) contracting an ICT third-party service provider that is not easily substitutable; or

(b) having in place multiple contractual arrangements in relation to the provision of ICT services supporting critical or important functions with the same ICT third-party service provider or with closely connected ICT third-party service providers.

Financial entities shall weigh the benefits and costs of alternative solutions, such as the use of different ICT third-party service providers, taking into account if and how envisaged solutions match the business needs and objectives set out in their digital resilience strategy.

2. Where the contractual arrangements on the use of ICT services supporting critical or important functions include the possibility that an ICT third-party service provider further subcontracts ICT services supporting a critical or important function to other ICT third-party service providers, financial entities shall weigh benefits and risks that may arise in connection with such subcontracting, in particular in the case of an ICT subcontractor established in a third-country.

Where contractual arrangements concern ICT services supporting critical or important functions, financial entities shall duly consider the insolvency law provisions that would apply in the event of the ICT third-party service provider's bankruptcy as well as any constraint that may arise in respect to the urgent recovery of the financial entity's data.

Where contractual arrangements on the use of ICT services supporting critical or important functions are concluded with an ICT third-party service provider established in a third country, financial entities shall, in addition to the considerations referred to in the second subparagraph, also consider the compliance with Union data protection rules and the effective enforcement of the law in that third country.

Where the contractual arrangements on the use of ICT services supporting critical or important functions provide for subcontracting, financial entities shall assess whether and how potentially long or complex chains of subcontracting may impact their ability to fully monitor the contracted functions and the ability of the competent authority to effectively supervise the financial entity in that respect.

Article 30

Key contractual provisions

1. The rights and obligations of the financial entity and of the ICT third-party service provider shall be clearly allocated and set out in writing. The full contract shall include the service level agreements and be documented in one written document which shall be available to the parties on paper, or in a document with another downloadable, durable and accessible format.

2. The contractual arrangements on the use of ICT services shall include at least the following elements:

(a) a clear and complete description of all functions and ICT services to be provided by the ICT third-party service provider, indicating whether subcontracting of an ICT service supporting a critical or important function, or material parts thereof, is permitted and, when that is the case, the conditions applying to such subcontracting;

(b) the locations, namely the regions or countries, where the contracted or subcontracted functions and ICT services are to be provided and where data is to be processed, including the storage location, and the requirement for the ICT third-party service provider to notify the financial entity in advance if it envisages changing such locations;

(c) provisions on availability, authenticity, integrity and confidentiality in relation to the protection of data, including personal data;

(d) provisions on ensuring access, recovery and return in an easily accessible format of personal and non-personal data processed by the financial entity in the event of the insolvency, resolution or discontinuation of the business operations of the ICT third-party service provider, or in the event of the termination of the contractual arrangements;

(e) service level descriptions, including updates and revisions thereof;

(f) the obligation of the ICT third-party service provider to provide assistance to the financial entity at no additional cost, or at a cost that is determined *ex-ante*, when an ICT incident that is related to the ICT service provided to the financial entity occurs;

(g) the obligation of the ICT third-party service provider to fully cooperate with the competent authorities and the resolution authorities of the financial entity, including persons appointed by them;

(h) termination rights and related minimum notice periods for the termination of the contractual arrangements, in accordance with the expectations of competent authorities and resolution authorities;

(i) the conditions for the participation of ICT third-party service providers in the financial entities' ICT security awareness programmes and digital operational resilience training in accordance with Article 13(6).

3. The contractual arrangements on the use of ICT services supporting critical or important functions shall include, in addition to the elements referred to in paragraph 2, at least the following:

(a) full service level descriptions, including updates and revisions thereof with precise quantitative and qualitative performance targets within the agreed service levels to allow effective monitoring by the financial entity of ICT services and enable appropriate corrective actions to be taken, without undue delay, when agreed service levels are not met;

(b) notice periods and reporting obligations of the ICT third-party service provider to the financial entity, including notification of any development that might have a material impact on the ICT third-party service provider's ability to effectively provide the ICT services supporting critical or important functions in line with agreed service levels;

(c) requirements for the ICT third-party service provider to implement and test business contingency plans and to have in place ICT security measures, tools and policies that provide an appropriate level of security for the provision of services by the financial entity in line with its regulatory framework;

(d) the obligation of the ICT third-party service provider to participate and fully cooperate in the financial entity's TLPT as referred to in Articles 26 and 27;

(e) the right to monitor, on an ongoing basis, the ICT third-party service provider's performance, which entails the following:

(i) unrestricted rights of access, inspection and audit by the financial entity, or an appointed third party, and by the competent authority, and the right to take copies of relevant documentation on-site if they are critical to the operations of the ICT third-party service provider, the effective exercise of which is not impeded or limited by other contractual arrangements or implementation policies;

(ii) the right to agree on alternative assurance levels if other clients' rights are affected;

(iii) the obligation of the ICT third-party service provider to fully cooperate during the onsite inspections and audits performed by the competent authorities, the Lead Overseer, financial entity or an appointed third party; and

(iv) the obligation to provide details on the scope, procedures to be followed and frequency of such inspections and audits;

(f) exit strategies, in particular the establishment of a mandatory adequate transition period:

(i) during which the ICT third-party service provider will continue providing the respective functions, or ICT services, with a view to reducing the risk of disruption at the financial entity or to ensure its effective resolution and restructuring;

(ii) allowing the financial entity to migrate to another ICT third-party service provider or change to in-house solutions consistent with the complexity of the service provided.

By way of derogation from point (e), the ICT third-party service provider and the financial entity that is a microenterprise may agree that the financial entity's rights of access, inspection and audit can be delegated to an independent third party, appointed by the ICT third-party service provider, and that the financial entity is able to request information and assurance on the ICT third-party service provider's performance from the third party at any time.

4. When negotiating contractual arrangements, financial entities and ICT third-party service providers shall consider the use of standard contractual clauses developed by public authorities for specific services.

5. The ESAs shall, through the Joint Committee, develop draft regulatory technical standards to specify further the elements referred to in paragraph 2, point (a), which a financial entity needs to determine and assess when subcontracting ICT services supporting critical or important functions.

When developing those draft regulatory technical standards, the ESAs shall take into consideration the size and overall risk profile of the financial entity, and the nature, scale and complexity of its services, activities and operations.

The ESAs shall submit those draft regulatory technical standards to the Commission by 17 July 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in the first subparagraph in accordance with Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

Section II

Oversight Framework of critical ICT third-party service providers

Article 31

Designation of critical ICT third-party service providers

1. The ESAs, through the Joint Committee and upon recommendation from the Oversight Forum established pursuant to Article 32(1), shall:

(a) designate the ICT third-party service providers that are critical for financial entities, following an assessment that takes into account the criteria specified in paragraph 2;

(b) appoint as Lead Overseer for each critical ICT third-party service provider the ESA that is responsible, in accordance with Regulations (EU) No 1093/2010, (EU) No 1094/2010 or (EU) No 1095/2010, for the financial entities having together the largest share of total assets out of the value of total assets of all financial entities using the services of the relevant critical ICT third-party service provider, as evidenced by the sum of the individual balance sheets of those financial entities.

2. The designation referred to in paragraph 1, point (a), shall be based on all of the following criteria in relation to ICT services provided by the ICT third-party service provider:

(a) the systemic impact on the stability, continuity or quality of the provision of financial services in the event that the relevant ICT third-party service provider would face a large scale operational failure to provide its services, taking into account the number of financial entities and the total value of assets of financial entities to which the relevant ICT third-party service provider provides services;

(b) the systemic character or importance of the financial entities that rely on the relevant ICT third-party service provider, assessed in accordance with the following parameters:

(i) the number of global systemically important institutions (G-SIIs) or other systemically important institutions (O-SIIs) that rely on the respective ICT third-party service provider;

(ii) the interdependence between the G-SIIs or O-SIIs referred to in point (i) and other financial entities, including situations where the G-SIIs or O-SIIs provide financial infrastructure services to other financial entities;

(c) the reliance of financial entities on the services provided by the relevant ICT third-party service provider in relation to critical or important functions of financial entities that ultimately involve the same ICT third-party service provider, irrespective of whether financial entities rely on those services directly or indirectly, through subcontracting arrangements;

(d) the degree of substitutability of the ICT third-party service provider, taking into account the following parameters:

(i) the lack of real alternatives, even partial, due to the limited number of ICT third-party service providers active on a specific market, or the market share of the relevant ICT third-party service provider, or the technical complexity or sophistication involved, including in relation to any proprietary technology, or the specific features of the ICT third-party service provider's organisation or activity;

(ii) difficulties in relation to partially or fully migrating the relevant data and workloads from the relevant ICT third-party service provider to another ICT third-party service provider, due either to significant financial costs, time or other resources that the migration process may entail, or to increased ICT risk or other operational risks to which the financial entity may be exposed through such migration.

3. Where the ICT third-party service provider belongs to a group, the criteria referred to in paragraph 2 shall be considered in relation to the ICT services provided by the group as a whole.

4. Critical ICT third-party service providers which are part of a group shall designate one legal person as a coordination point to ensure adequate representation and communication with the Lead Overseer.

5. The Lead Overseer shall notify the ICT third-party service provider of the outcome of the assessment leading to the designation referred in paragraph 1, point (a). Within 6 weeks from the date of the notification, the ICT third-party service provider may submit to the Lead Overseer a reasoned statement with any relevant information for the purposes of the assessment. The Lead Overseer shall consider the reasoned statement and may request additional information to be submitted within 30 calendar days of the receipt of such statement.

After designating an ICT third-party service provider as critical, the ESAs, through the Joint Committee, shall notify the ICT third-party service provider of such designation and the starting date as from which they will effectively be subject to oversight activities. That starting date shall be no later than one month after the notification. The ICT third-party service provider shall notify the financial entities to which they provide services of their designation as critical.

6. The Commission is empowered to adopt a delegated act in accordance with Article 57 to supplement this Regulation by specifying further the criteria referred to in paragraph 2 of this Article, by 17 July 2024.

7. The designation referred to in paragraph 1, point (a), shall not be used until the Commission has adopted a delegated act in accordance with paragraph 6.

8. The designation referred to in paragraph 1, point (a), shall not apply to the following:

(i) financial entities providing ICT services to other financial entities;

(ii) ICT third-party service providers that are subject to oversight frameworks established for the purposes of supporting the tasks referred to in Article 127(2) of the Treaty on the Functioning of the European Union;

(iii) ICT intra-group service providers;

(iv) ICT third-party service providers providing ICT services solely in one Member State to financial entities that are only active in that Member State.

9. The ESAs, through the Joint Committee, shall establish, publish and update yearly the list of critical ICT third-party service providers at Union level.

10. For the purposes of paragraph 1, point (a), competent authorities shall, on a yearly and aggregated basis, transmit the reports referred to in Article 28(3), third subparagraph, to the Oversight Forum established pursuant to Article 32. The Oversight Forum shall assess the ICT third-party dependencies of financial entities based on the information received from the competent authorities.

11. The ICT third-party service providers that are not included in the list referred to in paragraph 9 may request to be designated as critical in accordance with paragraph 1, point (a).

For the purpose of the first subparagraph, the ICT third-party service provider shall submit a reasoned application to EBA, ESMA or EIOPA, which, through the Joint Committee, shall decide whether to designate that ICT third-party service provider as critical in accordance with paragraph 1, point (a).

The decision referred to in the second subparagraph shall be adopted and notified to the ICT third-party service provider within 6 months of receipt of the application.

12. Financial entities shall only make use of the services of an ICT third-party service provider established in a third country and which has been designated as critical in accordance with paragraph 1, point (a), if the latter has established a subsidiary in the Union within the 12 months following the designation.

13. The critical ICT third-party service provider referred to in paragraph 12 shall notify the Lead Overseer of any changes to the structure of the management of the subsidiary established in the Union.

Article 32

Structure of the Oversight Framework

1. The Joint Committee, in accordance with Article 57(1) of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010, shall establish the Oversight Forum as a sub-committee for the purposes of supporting the work of the Joint Committee and of the Lead Overseer referred to in Article 31(1), point (b), in the area of ICT third-party risk across financial sectors. The Oversight Forum shall prepare the draft joint positions and the draft common acts of the Joint Committee in that area.

The Oversight Forum shall regularly discuss relevant developments on ICT risk and vulnerabilities and promote a consistent approach in the monitoring of ICT third-party risk at Union level.

2. The Oversight Forum shall, on a yearly basis, undertake a collective assessment of the results and findings of the oversight activities conducted for all critical ICT third-party service providers and promote coordination measures to increase the digital operational resilience of financial entities, foster best practices on addressing ICT concentration risk and explore mitigants for cross-sector risk transfers.

3. The Oversight Forum shall submit comprehensive benchmarks for critical ICT third-party service providers to be adopted by the Joint Committee as joint positions of the ESAs in accordance with Article 56(1) of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

4. The Oversight Forum shall be composed of:

(a) the Chairpersons of the ESAs;

(b) one high-level representative from the current staff of the relevant competent authority referred to in Article 46 from each Member State;

(c) the Executive Directors of each ESA and one representative from the Commission, from the ESRB, from ECB and from ENISA as observers;

(d) where appropriate, one additional representative of a competent authority referred to in Article 46 from each Member State as observer;

(e) where applicable, one representative of the competent authorities designated or established in accordance with Directive (EU) 2022/2555 responsible for the supervision of an essential or important entity subject to that Directive, which has been designated as a critical ICT third-party service provider, as observer.

The Oversight Forum may, where appropriate, seek the advice of independent experts appointed in accordance with paragraph 6.

5. Each Member State shall designate the relevant competent authority whose staff member shall be the high-level representative referred in paragraph 4, first subparagraph, point (b), and shall inform the Lead Overseer thereof.

The ESAs shall publish on their website the list of high-level representatives from the current staff of the relevant competent authority designated by Member States.

6. The independent experts referred to in paragraph 4, second subparagraph, shall be appointed by the Oversight Forum from a pool of experts selected following a public and transparent application process.

The independent experts shall be appointed on the basis of their expertise in financial stability, digital operational resilience and ICT security matters. They shall act independently and objectively in the sole interest of the Union as a whole and shall neither seek nor take instructions from Union institutions or bodies, from any government of a Member State or from any other public or private body.

7. In accordance with Article 16 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010, the ESAs shall by 17 July 2024 issue, for the purposes of this Section, guidelines on the cooperation between the ESAs and the competent authorities covering the detailed procedures and conditions for the allocation and execution of tasks between competent authorities and the ESAs and the details on the exchanges of information which are necessary for competent authorities to ensure the follow-up of recommendations pursuant to Article 35(1), point (d), addressed to critical ICT third-party service providers.

8. The requirements set out in this Section shall be without prejudice to the application of Directive (EU) 2022/2555 and of other Union rules on oversight applicable to providers of cloud computing services.

9. The ESAs, through the Joint Committee and based on preparatory work conducted by the Oversight Forum, shall, on yearly basis, submit a report on the application of this Section to the European Parliament, the Council and the Commission.

Article 33

Tasks of the Lead Overseer

1. The Lead Overseer, appointed in accordance with Article 31(1), point (b), shall conduct the oversight of the assigned critical ICT third-party service providers and shall be, for the purposes of all matters related to the oversight, the primary point of contact for those critical ICT third-party service providers.

2. For the purposes of paragraph 1, the Lead Overseer shall assess whether each critical ICT third-party service provider has in place comprehensive, sound and effective rules, procedures, mechanisms and arrangements to manage the ICT risk which it may pose to financial entities.

The assessment referred to in the first subparagraph shall focus mainly on ICT services provided by the critical ICT third-party service provider supporting the critical or important functions of financial entities. Where necessary to address all relevant risks, that assessment shall extend to ICT services supporting functions other than those that are critical or important.

3. The assessment referred to in paragraph 2 shall cover:

(a) ICT requirements to ensure, in particular, the security, availability, continuity, scalability and quality of services which the critical ICT third-party service provider provides to financial entities, as well as the ability to maintain at all times high standards of availability, authenticity, integrity or confidentiality of data;

(b) the physical security contributing to ensuring the ICT security, including the security of premises, facilities, data centres;

(c) the risk management processes, including ICT risk management policies, ICT business continuity policy and ICT response and recovery plans;

(d) the governance arrangements, including an organisational structure with clear, transparent and consistent lines of responsibility and accountability rules enabling effective ICT risk management;

(e) the identification, monitoring and prompt reporting of material ICT-related incidents to financial entities, the management and resolution of those incidents, in particular cyber-attacks;

(f) the mechanisms for data portability, application portability and interoperability, which ensure an effective exercise of termination rights by the financial entities;

(g) the testing of ICT systems, infrastructure and controls;

(h) the ICT audits;

(i) the use of relevant national and international standards applicable to the provision of its ICT services to the financial entities.

4. Based on the assessment referred to in paragraph 2, and in coordination with the Joint Oversight Network (JON) referred to in Article 34(1), the Lead Overseer shall adopt a clear, detailed and reasoned individual oversight plan describing the annual oversight objectives and the main oversight actions planned for each critical ICT third-party service provider. That plan shall be communicated yearly to the critical ICT third-party service provider.

Prior to the adoption of the oversight plan, the Lead Overseer shall communicate the draft oversight plan to the critical ICT third-party service provider.

Upon receipt of the draft oversight plan, the critical ICT third-party service provider may submit a reasoned statement within 15 calendar days evidencing the expected impact on customers which are entities falling outside of the scope of this Regulation and where appropriate, formulating solutions to mitigate risks.

5. Once the annual oversight plans referred to in paragraph 4 have been adopted and notified to the critical ICT third-party service providers, competent authorities may take measures concerning such critical ICT third-party service providers only in agreement with the Lead Overseer.

Article 34

Operational coordination between Lead Overseers

1. To ensure a consistent approach to oversight activities and with a view to enabling coordinated general oversight strategies and cohesive operational approaches and work methodologies, the three Lead Overseers appointed in accordance with Article 31(1), point (b), shall set up a JON to coordinate among themselves in the preparatory stages and to coordinate the conduct of oversight activities over their respective overseen critical ICT third-party service providers, as well as in the course of any action that may be needed pursuant to Article 42.

2. For the purposes of paragraph 1, the Lead Overseers shall draw up a common oversight protocol specifying the detailed procedures to be followed for carrying out the day-to-day coordination and for ensuring swift exchanges and reactions. The protocol shall be periodically revised to reflect operational needs, in particular the evolution of practical oversight arrangements.

3. The Lead Overseers may, on an ad-hoc basis, call on the ECB and ENISA to provide technical advice, share hands-on experience or join specific coordination meetings of the JON.

Article 35

Powers of the Lead Overseer

1. For the purposes of carrying out the duties laid down in this Section, the Lead Overseer shall have the following powers in respect of the critical ICT third-party service providers:

(a) to request all relevant information and documentation in accordance with Article 37;

(b) to conduct general investigations and inspections in accordance with Articles 38 and 39, respectively;

(c) to request, after the completion of the oversight activities, reports specifying the actions that have been taken or the remedies that have been implemented by the critical ICT third-party service providers in relation to the recommendations referred to in point (d) of this paragraph;

(d) to issue recommendations on the areas referred to in Article 33(3), in particular concerning the following:

(i) the use of specific ICT security and quality requirements or processes, in particular in relation to the roll-out of patches, updates, encryption and other security measures which the Lead Overseer deems relevant for ensuring the ICT security of services provided to financial entities;

(ii) the use of conditions and terms, including their technical implementation, under which the critical ICT third-party service providers provide ICT services to financial entities, which the Lead Overseer deems relevant for preventing the generation of single points of failure, the amplification thereof, or for minimising the possible systemic impact across the Union's financial sector in the event of ICT concentration risk;

(iii) any planned subcontracting, where the Lead Overseer deems that further subcontracting, including subcontracting arrangements which the critical ICT third-party service providers plan to enter into with ICT third-party service providers or with ICT subcontractors established in a third country, may trigger risks for the provision of services by the financial entity, or risks to the financial stability, based on the examination of the information gathered in accordance with Articles 37 and 38;

(iv) refraining from entering into a further subcontracting arrangement, where the following cumulative conditions are met:

— the envisaged subcontractor is an ICT third-party service provider or an ICT subcontractor established in a third country;

— the subcontracting concerns critical or important functions of the financial entity; and

— the Lead Overseer deems that the use of such subcontracting poses a clear and serious risk to the financial stability of the Union or to financial entities, including to the ability of financial entities to comply with supervisory requirements.

For the purpose of point (iv) of this point, ICT third-party service providers shall, using the template referred to in Article 41(1), point (b), transmit the information regarding subcontracting to the Lead Overseer.

2. When exercising the powers referred to in this Article, the Lead Overseer shall:

(a) ensure regular coordination within the JON, and in particular shall seek consistent approaches, as appropriate, with regard to the oversight of critical ICT third-party service providers;

(b) take due account of the framework established by Directive (EU) 2022/2555 and, where necessary, consult the relevant competent authorities designated or established in accordance with that Directive, in order to avoid duplication of technical and organisational measures that might apply to critical ICT third-party service providers pursuant to that Directive;

(c) seek to minimise, to the extent possible, the risk of disruption to services provided by critical ICT third-party service providers to customers that are entities falling outside the scope of this Regulation.

3. The Lead Overseer shall consult the Oversight Forum before exercising the powers referred to in paragraph 1.

Before issuing recommendations in accordance with paragraph 1, point (d), the Lead Overseer shall give the opportunity to the ICT third-party service provider to provide, within 30 calendar days, relevant information evidencing the expected impact on customers that are entities falling outside the scope of this Regulation and, where appropriate, formulating solutions to mitigate risks.

4. The Lead Overseer shall inform the JON of the outcome of the exercise of the powers referred to in paragraph 1, points (a) and (b). The Lead Overseer shall, without undue delay, transmit the reports referred to in paragraph 1, point (c), to the JON and to the competent authorities of the financial entities using the ICT services of that critical ICT third-party service provider.

5. Critical ICT third-party service providers shall cooperate in good faith with the Lead Overseer, and assist it in the fulfilment of its tasks.

6. In the event of whole or partial non-compliance with the measures required to be taken pursuant to the exercise of the powers under paragraph 1, points (a), (b) and (c), and after the expiry of a period of at least 30 calendar days from the date on which the critical ICT third-party service provider received notification of the respective measures, the Lead Overseer shall adopt a decision imposing a periodic penalty payment to compel the critical ICT third-party service provider to comply with those measures.

7. The periodic penalty payment referred to in paragraph 6 shall be imposed on a daily basis until compliance is achieved and for no more than a period of six months following the notification of the decision to impose a periodic penalty payment to the critical ICT third-party service provider.

8. The amount of the periodic penalty payment, calculated from the date stipulated in the decision imposing the periodic penalty payment, shall be up to 1 % of the average daily worldwide turnover of the critical ICT third-party service provider in the preceding business year. When determining the amount of the penalty payment, the Lead Overseer shall take into account the following criteria regarding non-compliance with the measures referred to in paragraph 6:

(a) the gravity and the duration of non-compliance;

(b) whether non-compliance has been committed intentionally or negligently;

(c) the level of cooperation of the ICT third-party service provider with the Lead Overseer.

For the purposes of the first subparagraph, in order to ensure a consistent approach, the Lead Overseer shall engage in consultation within the JON.

9. Penalty payments shall be of an administrative nature and shall be enforceable. Enforcement shall be governed by the rules of civil procedure in force in the Member State on the territory of which inspections and access shall be carried out. Courts of the Member State concerned shall have jurisdiction over complaints related to irregular conduct of enforcement. The amounts of the penalty payments shall be allocated to the general budget of the European Union.

10. The Lead Overseer shall disclose to the public every periodic penalty payment that has been imposed, unless such disclosure would seriously jeopardise the financial markets or cause disproportionate damage to the parties involved.

11. Before imposing a periodic penalty payment under paragraph 6, the Lead Overseer shall give the representatives of the critical ICT third-party service provider subject to the proceedings the opportunity to be heard on the findings and shall base its decisions only on findings on which the critical ICT third-party service provider subject to the proceedings has had an opportunity to comment.

The rights of the defence of the persons subject to the proceedings shall be fully respected in the proceedings. The critical ICT third-party service provider subject to the proceedings shall be entitled to have access to the file, subject to the legitimate interest of other persons in the protection of their business secrets. The right of access to the file shall not extend to confidential information or to the Lead Overseer's internal preparatory documents.

Article 36

Exercise of the powers of the Lead Overseer outside the Union

1. When oversight objectives cannot be attained by means of interacting with the subsidiary set up for the purpose of Article 31(12), or by exercising oversight activities on premises located in the Union, the Lead Overseer may exercise the powers, referred to in the following provisions, on any premises located in a third-country which is owned, or used in any way, for the purposes of providing services to Union financial entities, by a critical ICT third-party service provider, in connection with its business operations, functions or services, including any administrative, business or operational offices, premises, lands, buildings or other properties:

(a) in Article 35(1), point (a); and

(b) in Article 35(1), point (b), in accordance with Article 38(2), points (a), (b) and (d), and in Article 39(1) and (2), point (a).

The powers referred to in the first subparagraph may be exercised subject to all of the following conditions:

(i) the conduct of an inspection in a third-country is deemed necessary by the Lead Overseer to allow it to fully and effectively perform its duties under this Regulation;

(ii) the inspection in a third-country is directly related to the provision of ICT services to financial entities in the Union;

(iii) the critical ICT third-party service provider concerned consents to the conduct of an inspection in a third-country; and

(iv) the relevant authority of the third-country concerned has been officially notified by the Lead Overseer and raised no objection thereto.

2. Without prejudice to the respective competences of the Union institutions and of Member States, for the purposes of paragraph 1, EBA, ESMA or EIOPA shall conclude administrative cooperation arrangements with the relevant authority of the third country in order to enable the smooth conduct of inspections in the third country concerned by the Lead Overseer and its designated team for its mission in that third country. Those cooperation arrangements shall not create legal obligations in respect of the Union and its Member States nor shall they prevent Member States and their competent authorities from concluding bilateral or multilateral arrangements with those third countries and their relevant authorities.

Those cooperation arrangements shall specify at least the following elements:

(a) the procedures for the coordination of oversight activities carried out under this Regulation and any analogous monitoring of ICT third-party risk in the financial sector exercised by the relevant authority of the third country concerned, including details for transmitting the agreement of the latter to allow the conduct, by the Lead Overseer and its designated team, of general investigations and on-site inspections as referred to in paragraph 1, first subparagraph, on the territory under its jurisdiction;

(b) the mechanism for the transmission of any relevant information between EBA, ESMA or EIOPA and the relevant authority of the third country concerned, in particular in connection with information that may be requested by the Lead Overseer pursuant to Article 37;

(c) the mechanisms for the prompt notification by the relevant authority of the third-country concerned to EBA, ESMA or EIOPA of cases where an ICT third-party service provider established in a third country and designated as critical in accordance with Article 31(1), point (a), is deemed to have infringed the requirements to which it is obliged to adhere pursuant to the applicable law of the third country concerned when providing services to financial institutions in that third country, as well as the remedies and penalties applied;

(d) the regular transmission of updates on regulatory or supervisory developments on the monitoring of ICT third-party risk of financial institutions in the third country concerned;

(e) the details for allowing, if needed, the participation of one representative of the relevant third-country authority in the inspections conducted by the Lead Overseer and the designated team.

3. When the Lead Overseer is not able to conduct oversight activities outside the Union, referred to in paragraphs 1 and 2, the Lead Overseer shall:

(a) exercise its powers under Article 35 on the basis of all facts and documents available to it;

(b) document and explain any consequence of its inability to conduct the envisaged oversight activities as referred to in this Article.

The potential consequences referred to in point (b) of this paragraph shall be taken into consideration in the Lead Overseer's recommendations issued pursuant to Article 35(1), point (d).

Article 37

Request for information

1. The Lead Overseer may, by simple request or by decision, require critical ICT third-party service providers to provide all information that is necessary for the Lead Overseer to carry out its duties under this Regulation, including all relevant business or operational documents, contracts, policies, documentation, ICT security audit reports, ICT-related incident reports, as well as any information relating to parties to whom the critical ICT third-party service provider has outsourced operational functions or activities.

2. When sending a simple request for information under paragraph 1, the Lead Overseer shall:

(a) refer to this Article as the legal basis of the request;

(b) state the purpose of the request;

(c) specify what information is required;

(d) set a time limit within which the information is to be provided;

(e) inform the representative of the critical ICT third-party service provider from whom the information is requested that he or she is not obliged to provide the information, but in the event of a voluntary reply to the request the information provided must not be incorrect or misleading.

3. When requiring by decision to supply information under paragraph 1, the Lead Overseer shall:

(a) refer to this Article as the legal basis of the request;

(b) state the purpose of the request;

(c) specify what information is required;

(d) set a time limit within which the information is to be provided;

(e) indicate the periodic penalty payments provided for in Article 35(6) where the production of the required information is incomplete or when such information is not provided within the time limit referred to in point (d) of this paragraph;

(f) indicate the right to appeal the decision to ESA's Board of Appeal and to have the decision reviewed by the Court of Justice of the European Union (Court of Justice) in accordance with Articles 60 and 61 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

4. The representatives of the critical ICT third-party service providers shall supply the information requested. Lawyers duly authorised to act may supply the information on behalf of their clients. The critical ICT third-party service provider shall remain fully responsible if the information supplied is incomplete, incorrect or misleading.

5. The Lead Overseer shall, without delay, transmit a copy of the decision to supply information to the competent authorities of the financial entities using the services of the relevant critical ICT third-party service providers and to the JON.

Article 38

General investigations

1. In order to carry out its duties under this Regulation, the Lead Overseer, assisted by the joint examination team referred to in Article 40(1), may, where necessary, conduct investigations of critical ICT third-party service providers.

2. The Lead Overseer shall have the power to:

(a) examine records, data, procedures and any other material relevant to the execution of its tasks, irrespective of the medium on which they are stored;

(b) take or obtain certified copies of, or extracts from, such records, data, documented procedures and any other material;

(c) summon representatives of the critical ICT third-party service provider for oral or written explanations on facts or documents relating to the subject matter and purpose of the investigation and to record the answers;

(d) interview any other natural or legal person who consents to be interviewed for the purpose of collecting information relating to the subject matter of an investigation;

(e) request records of telephone and data traffic.

3. The officials and other persons authorised by the Lead Overseer for the purposes of the investigation referred to in paragraph 1 shall exercise their powers upon production of a written authorisation specifying the subject matter and purpose of the investigation.

That authorisation shall also indicate the periodic penalty payments provided for in Article 35(6) where the production of the required records, data, documented procedures or any other material, or the answers to questions asked to representatives of the ICT third-party service provider are not provided or are incomplete.

4. The representatives of the critical ICT third-party service providers are required to submit to the investigations on the basis of a decision of the Lead Overseer. The decision shall specify the subject matter and purpose of the investigation, the periodic penalty payments provided for in Article 35(6), the legal remedies available under Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010, and the right to have the decision reviewed by the Court of Justice.

5. In good time before the start of the investigation, the Lead Overseer shall inform competent authorities of the financial entities using the ICT services of that critical ICT third-party service provider of the envisaged investigation and of the identity of the authorised persons.

The Lead Overseer shall communicate to the JON all information transmitted pursuant to the first subparagraph.

Article 39

Inspections

1. In order to carry out its duties under this Regulation, the Lead Overseer, assisted by the joint examination teams referred to in Article 40(1), may enter in, and conduct all necessary onsite inspections on, any business premises, land or property of the ICT third-party service providers, such as head offices, operation centres, secondary premises, as well as to conduct off-site inspections.

For the purposes of exercising the powers referred to in the first subparagraph, the Lead Overseer shall consult the JON.

2. The officials and other persons authorised by the Lead Overseer to conduct an on-site inspection shall have the power to:

(a) enter any such business premises, land or property; and

(b) seal any such business premises, books or records, for the period of, and to the extent necessary for, the inspection.

The officials and other persons authorised by the Lead Overseer shall exercise their powers upon production of a written authorisation specifying the subject matter and the purpose of the inspection, and the periodic penalty payments provided for in Article 35(6) where the representatives of the critical ICT third-party service providers concerned do not submit to the inspection.

3. In good time before the start of the inspection, the Lead Overseer shall inform the competent authorities of the financial entities using that ICT third-party service provider.

4. Inspections shall cover the full range of relevant ICT systems, networks, devices, information and data either used for, or contributing to, the provision of ICT services to financial entities.

5. Before any planned on-site inspection, the Lead Overseer shall give reasonable notice to the critical ICT third-party service providers, unless such notice is not possible due to an emergency or crisis situation, or if it would lead to a situation where the inspection or audit would no longer be effective.

6. The critical ICT third-party service provider shall submit to on-site inspections ordered by decision of the Lead Overseer. The decision shall specify the subject matter and purpose of the inspection, fix the date on which the inspection shall begin and shall indicate the periodic penalty payments provided for in Article 35(6), the legal remedies available under Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010, as well as the right to have the decision reviewed by the Court of Justice.

7. Where the officials and other persons authorised by the Lead Overseer find that a critical ICT third-party service provider opposes an inspection ordered pursuant to this Article, the Lead Overseer shall inform the critical ICT third-party service provider of the consequences of such opposition, including the possibility for competent authorities of the relevant financial entities to require financial entities to terminate the contractual arrangements concluded with that critical ICT third-party service provider.

Article 40

Ongoing oversight

1. When conducting oversight activities, in particular general investigations or inspections, the Lead Overseer shall be assisted by a joint examination team established for each critical ICT third-party service provider.

2. The joint examination team referred to in paragraph 1 shall be composed of staff members from:

(a) the ESAs;

(b) the relevant competent authorities supervising the financial entities to which the critical ICT third-party service provider provides ICT services;

(c) the national competent authority referred to in Article 32(4), point (e), on a voluntary basis;

(d) one national competent authority from the Member State where the critical ICT third-party service provider is established, on a voluntary basis.

Members of the joint examination team shall have expertise in ICT matters and in operational risk. The joint examination team shall work under the coordination of a designated Lead Overseer staff member (the 'Lead Overseer coordinator').

3. Within 3 months of the completion of an investigation or inspection, the Lead Overseer, after consulting the Oversight Forum, shall adopt recommendations to be addressed to the critical ICT third-party service provider pursuant to the powers referred to in Article 35.

4. The recommendations referred to in paragraph 3 shall be immediately communicated to the critical ICT third-party service provider and to the competent authorities of the financial entities to which it provides ICT services.

For the purposes of fulfilling the oversight activities, the Lead Overseer may take into consideration any relevant third-party certifications and ICT third-party internal or external audit reports made available by the critical ICT third-party service provider.

Article 41

Harmonisation of conditions enabling the conduct of the oversight activities

1. The ESAs shall, through the Joint Committee, develop draft regulatory technical standards to specify:

(a) the information to be provided by an ICT third-party service provider in the application for a voluntary request to be designated as critical under Article 31(11);

(b) the content, structure and format of the information to be submitted, disclosed or reported by the ICT third-party service providers pursuant to Article 35(1), including the template for providing information on subcontracting arrangements;

(c) the criteria for determining the composition of the joint examination team ensuring a balanced participation of staff members from the ESAs and from the relevant competent authorities, their designation, tasks, and working arrangements.

(d) the details of the competent authorities' assessment of the measures taken by critical ICT third-party service providers based on the recommendations of the Lead Overseer pursuant to Article 42(3).

2. The ESAs shall submit those draft regulatory technical standards to the Commission by 17 July 2024.

Power is delegated to the Commission to supplement this Regulation by adopting the regulatory technical standards referred to in paragraph 1 in accordance with the procedure laid down in Articles 10 to 14 of Regulations (EU) No 1093/2010, (EU) No 1094/2010 and (EU) No 1095/2010.

Article 42

Follow-up by competent authorities

1. Within 60 calendar days of the receipt of the recommendations issued by the Lead Overseer pursuant to Article 35(1), point (d), critical ICT third-party service providers shall either notify the Lead Overseer of their intention to follow the recommendations or provide a reasoned explanation for not following such recommendations. The Lead Overseer shall immediately transmit this information to the competent authorities of the financial entities concerned.

2. The Lead Overseer shall publicly disclose where a critical ICT third-party service provider fails to notify the Lead Overseer in accordance with paragraph 1 or where the explanation provided by the critical ICT third-party service provider is not deemed sufficient. The information published shall disclose the identity of the critical ICT third-party service provider as well as information on the type and nature of the non-compliance. Such information shall be limited to what is relevant and proportionate for the purpose of ensuring public awareness, unless such publication would cause disproportionate damage to the parties involved or could seriously jeopardise the orderly functioning and integrity of financial markets or the stability of the whole or part of the financial system of the Union.

The Lead Overseer shall notify the ICT third-party service provider of that public disclosure.

3. Competent authorities shall inform the relevant financial entities of the risks identified in the recommendations addressed to critical ICT third-party service providers in accordance with Article 35(1), point (d).

When managing ICT third-party risk, financial entities shall take into account the risks referred to in the first subparagraph.

4. Where a competent authority deems that a financial entity fails to take into account or to sufficiently address within its management of ICT third-party risk the specific risks identified in the recommendations, it shall notify the financial entity of the possibility of a decision being taken, within 60 calendar days of the receipt of such notification, pursuant to paragraph 6, in the absence of appropriate contractual arrangements aiming to address such risks.

5. Upon receiving the reports referred to in Article 35(1), point (c), and prior to taking a decision as referred to in paragraph 6 of this Article, competent authorities may, on a voluntary basis, consult the competent authorities designated or established in accordance with Directive (EU) 2022/2555 responsible for the supervision of an essential or important entity subject to that Directive, which has been designated as a critical ICT third-party service provider.

6. Competent authorities may, as a measure of last resort, following the notification and, if appropriate, the consultation as set out in paragraph 4 and 5 of this Article, in accordance with Article 50, take a decision requiring financial entities to temporarily suspend, either in part or completely, the use or deployment of a service provided by the critical ICT third-party service provider until the risks identified in the recommendations addressed to critical ICT third-party service providers have been addressed. Where necessary, they may require financial entities to terminate, in part or completely, the relevant contractual arrangements concluded with the critical ICT third-party service providers.

7. Where a critical ICT third-party service provider refuses to endorse recommendations, based on a divergent approach from the one advised by the Lead Overseer, and such a divergent approach may adversely impact a large number of financial entities, or a significant part of the financial sector, and individual warnings issued by competent authorities have not resulted in consistent approaches mitigating the potential risk to financial stability, the Lead Overseer may, after consulting the Oversight Forum, issue non-binding and non-public opinions to competent authorities, in order to promote consistent and convergent supervisory follow-up measures, as appropriate.

8. Upon receiving the reports referred to in Article 35(1), point (c), competent authorities, when taking a decision as referred to in paragraph 6 of this Article, shall take into account the type and magnitude of risk that is not addressed by the critical ICT third-party service provider, as well as the seriousness of the non-compliance, having regard to the following criteria:

(a) the gravity and the duration of the non-compliance;

(b) whether the non-compliance has revealed serious weaknesses in the critical ICT third-party service provider's procedures, management systems, risk management and internal controls;

(c) whether a financial crime was facilitated, occasioned or is otherwise attributable to the non-compliance;

(d) whether the non-compliance has been intentional or negligent;

(e) whether the suspension or termination of the contractual arrangements introduces a risk for continuity of the financial entity's business operations notwithstanding the financial entity's efforts to avoid disruption in the provision of its services;

(f) where applicable, the opinion of the competent authorities designated or established in accordance with Directive (EU) 2022/2555 responsible for the supervision of an essential or important entity subject to that Directive, which has been designated as a critical ICT third-party service provider, requested on a voluntary basis in accordance with paragraph 5 of this Article.

Competent authorities shall grant financial entities the necessary period of time to enable them to adjust the contractual arrangements with critical ICT third-party service providers in order to avoid detrimental effects on their digital operational resilience and to allow them to deploy exit strategies and transition plans as referred to in Article 28.

9. The decision referred to in paragraph 6 of this Article shall be notified to the members of the Oversight Forum referred to in Article 32(4), points (a), (b) and (c), and to the JON.

The critical ICT third-party service providers affected by the decisions provided for in paragraph 6 shall fully cooperate with the financial entities impacted, in particular in the context of the process of suspension or termination of their contractual arrangements.

10. Competent authorities shall regularly inform the Lead Overseer on the approaches and measures taken in their supervisory tasks in relation to financial entities as well as on the contractual arrangements concluded by financial entities where critical ICT third-party service providers have not endorsed in part or entirely recommendations addressed to them by the Lead Overseer.

11. The Lead Overseer may, upon request, provide further clarifications on the recommendations issued to guide the competent authorities on the follow-up measures.

Article 43

Oversight fees

1. The Lead Overseer shall, in accordance with the delegated act referred to in paragraph 2 of this Article, charge critical ICT third-party service providers fees that fully cover the Lead Overseer's necessary expenditure in relation to the conduct of oversight tasks pursuant to this Regulation, including the reimbursement of any costs which may be incurred as a result of work carried out by the joint examination team referred to in Article 40, as well as the costs of advice provided by the independent experts as referred to in Article 32(4), second subparagraph, in relation to matters falling under the remit of direct oversight activities.

The amount of a fee charged to a critical ICT third-party service provider shall cover all costs derived from the execution of the duties set out in this Section and shall be proportionate to its turnover.

2. The Commission is empowered to adopt a delegated act in accordance with Article 57 to supplement this Regulation by determining the amount of the fees and the way in which they are to be paid by 17 July 2024.

Article 44

International cooperation

1. Without prejudice to Article 36, EBA, ESMA and EIOPA may, in accordance with Article 33 of Regulations (EU) No 1093/2010, (EU) No 1095/2010 and (EU) No 1094/2010, respectively, conclude administrative arrangements with third-country regulatory and supervisory authorities to foster international cooperation on ICT third-party risk across different financial sectors, in particular by developing best practices for the review of ICT risk management practices and controls, mitigation measures and incident responses.

2. The ESAs shall, through the Joint Committee, submit every five years a joint confidential report to the European Parliament, to the Council and to the Commission, summarising the findings of relevant discussions held with the third countries' authorities referred to in paragraph 1, focusing on the evolution of ICT third-party risk and the implications for financial stability, market integrity, investor protection and the functioning of the internal market.

CHAPTER VI

Information-sharing arrangements

Article 45

Information-sharing arrangements on cyber threat information and intelligence

1. Financial entities may exchange amongst themselves cyber threat information and intelligence, including indicators of compromise, tactics, techniques, and procedures, cyber security alerts and configuration tools, to the extent that such information and intelligence sharing:

(a) aims to enhance the digital operational resilience of financial entities, in particular through raising awareness in relation to cyber threats, limiting or impeding the cyber threats' ability to spread, supporting defence capabilities, threat detection techniques, mitigation strategies or response and recovery stages;

(b) takes places within trusted communities of financial entities;

(c) is implemented through information-sharing arrangements that protect the potentially sensitive nature of the information shared, and that are governed by rules of conduct in full respect of business confidentiality, protection of personal data in accordance with Regulation (EU) 2016/679 and guidelines on competition policy.

2. For the purpose of paragraph 1, point (c), the information-sharing arrangements shall define the conditions for participation and, where appropriate, shall set out the details on the involvement of public authorities and the capacity in which they may be associated to the information-sharing arrangements, on the involvement of ICT third-party service providers, and on operational elements, including the use of dedicated IT platforms.

3. Financial entities shall notify competent authorities of their participation in the information-sharing arrangements referred to in paragraph 1, upon validation of their membership, or, as applicable, of the cessation of their membership, once it takes effect.

CHAPTER VII

Competent authorities

Article 46

Competent authorities

Without prejudice to the provisions on the Oversight Framework for critical ICT third-party service providers referred to in Chapter V, Section II, of this Regulation, compliance with this Regulation shall be ensured by the following competent authorities in accordance with the powers granted by the respective legal acts:

(a) for credit institutions and for institutions exempted pursuant to Directive 2013/36/EU, the competent authority designated in accordance with Article 4 of that Directive, and for credit institutions classified as significant in accordance with Article 6(4) of Regulation (EU) No 1024/2013, the ECB in accordance with the powers and tasks conferred by that Regulation;

(b) for payment institutions, including payment institutions exempted pursuant to Directive (EU) 2015/2366, electronic money institutions, including those exempted pursuant to Directive 2009/110/EC, and account information service providers as referred to in Article 33(1) of Directive (EU) 2015/2366, the competent authority designated in accordance with Article 22 of Directive (EU) 2015/2366;

(c) for investment firms, the competent authority designated in accordance with Article 4 of Directive (EU) 2019/2034 of the European Parliament and of the Council ([38]);

(d) for crypto-asset service providers as authorised under the Regulation on markets in crypto-assets and issuers of asset-referenced tokens, the competent authority designated in accordance with the relevant provision of that Regulation;

(e) for central securities depositories, the competent authority designated in accordance with Article 11 of Regulation (EU) No 909/2014;

(f) for central counterparties, the competent authority designated in accordance with Article 22 of Regulation (EU) No 648/2012;

(g) for trading venues and data reporting service providers, the competent authority designated in accordance with Article 67 of Directive 2014/65/EU, and the competent authority as defined in Article 2(1), point (18), of Regulation (EU) No 600/2014;

(h) for trade repositories, the competent authority designated in accordance with Article 22 of Regulation (EU) No 648/2012;

(i) for managers of alternative investment funds, the competent authority designated in accordance with Article 44 of Directive 2011/61/EU;

(j) for management companies, the competent authority designated in accordance with Article 97 of Directive 2009/65/EC;

(k) for insurance and reinsurance undertakings, the competent authority designated in accordance with Article 30 of Directive 2009/138/EC;

(l) for insurance intermediaries, reinsurance intermediaries and ancillary insurance intermediaries, the competent authority designated in accordance with Article 12 of Directive (EU) 2016/97;

(m) for institutions for occupational retirement provision, the competent authority designated in accordance with Article 47 of Directive (EU) 2016/2341;

(n) for credit rating agencies, the competent authority designated in accordance with Article 21 of Regulation (EC) No 1060/2009;

(o) for administrators of critical benchmarks, the competent authority designated in accordance with Articles 40 and 41 of Regulation (EU) 2016/1011;

([38]) Directive (EU) 2019/2034 of the European Parliament and of the Council of 27 November 2019 on the prudential supervision of investment firms and amending Directives 2002/87/EC, 2009/65/EC, 2011/61/EU, 2013/36/EU, 2014/59/EU and 2014/65/EU (OJ L 314, 5.12.2019, p. 64).

(p) for crowdfunding service providers, the competent authority designated in accordance with Article 29 of Regulation (EU) 2020/1503;

(q) for securitisation repositories, the competent authority designated in accordance with Articles 10 and 14(1) of Regulation (EU) 2017/2402.

Article 47

Cooperation with structures and authorities established by Directive (EU) 2022/2555

1. To foster cooperation and enable supervisory exchanges between the competent authorities designated under this Regulation and the Cooperation Group established by Article 14 of Directive (EU) 2022/2555, the ESAs and the competent authorities may participate in the activities of the Cooperation Group for matters that concern their supervisory activities in relation to financial entities. The ESAs and the competent authorities may request to be invited to participate in the activities of the Cooperation Group for matters in relation to essential or important entities subject to Directive (EU) 2022/2555 that have also been designated as critical ICT third-party service providers pursuant to Article 31 of this Regulation.

2. Where appropriate, competent authorities may consult and share information with the single points of contact and the CSIRTs designated or established in accordance with Directive (EU) 2022/2555.

3. Where appropriate, competent authorities may request any relevant technical advice and assistance from the competent authorities designated or established in accordance with Directive (EU) 2022/2555 and establish cooperation arrangements to allow effective and fast-response coordination mechanisms to be set up.

4. The arrangements referred to in paragraph 3 of this Article may, inter alia, specify the procedures for the coordination of supervisory and oversight activities in relation to essential or important entities subject to Directive (EU) 2022/2555 that have been designated as critical ICT third-party service providers pursuant to Article 31 of this Regulation, including for the conduct, in accordance with national law, of investigations and on-site inspections, as well as for mechanisms for the exchange of information between the competent authorities under this Regulation and the competent authorities designated or established in accordance with that Directive which includes access to information requested by the latter authorities.

Article 48

Cooperation between authorities

1. Competent authorities shall cooperate closely among themselves and, where applicable, with the Lead Overseer.

2. Competent authorities and the Lead Overseer shall, in a timely manner, mutually exchange all relevant information concerning critical ICT third-party service providers which is necessary for them to carry out their respective duties under this Regulation, in particular in relation to identified risks, approaches and measures taken as part of the Lead Overseer's oversight tasks.

Article 49

Financial cross-sector exercises, communication and cooperation

1. The ESAs, through the Joint Committee and in collaboration with competent authorities, resolution authorities as referred to in Article 3 of Directive 2014/59/EU, the ECB, the Single Resolution Board as regards information relating to entities falling under the scope of Regulation (EU) No 806/2014, the ESRB and ENISA, as appropriate, may establish mechanisms to enable the sharing of effective practices across financial sectors to enhance situational awareness and identify common cyber vulnerabilities and risks across sectors.

They may develop crisis management and contingency exercises involving cyber-attack scenarios with a view to developing communication channels and gradually enabling an effective coordinated response at Union level in the event of a major cross-border ICT-related incident or related threat having a systemic impact on the Union's financial sector as a whole.

Those exercises may, as appropriate, also test the financial sector's dependencies on other economic sectors.

2. Competent authorities, ESAs and the ECB shall cooperate closely with each other and exchange information to carry out their duties pursuant to Articles 47 to 54. They shall closely coordinate their supervision in order to identify and remedy breaches of this Regulation, develop and promote best practices, facilitate collaboration, foster consistency of interpretation and provide cross-jurisdictional assessments in the event of any disagreements.

Article 50

Administrative penalties and remedial measures

1. Competent authorities shall have all supervisory, investigatory and sanctioning powers necessary to fulfil their duties under this Regulation.

2. The powers referred to in paragraph 1 shall include at least the following powers to:

(a) have access to any document or data held in any form that the competent authority considers relevant for the performance of its duties and receive or take a copy of it;

(b) carry out on-site inspections or investigations, which shall include but shall not be limited to;

  (i) summoning representatives of the financial entities for oral or written explanations on facts or documents relating to the subject matter and purpose of the investigation and to record the answers;

  (ii) interviewing any other natural or legal person who consents to be interviewed for the purpose of collecting information relating to the subject matter of an investigation;

(c) require corrective and remedial measures for breaches of the requirements of this Regulation.

3. Without prejudice to the right of Member States to impose criminal penalties in accordance with Article 52, Member States shall lay down rules establishing appropriate administrative penalties and remedial measures for breaches of this Regulation and shall ensure their effective implementation.

Those penalties and measures shall be effective, proportionate and dissuasive.

4. Member States shall confer on competent authorities the power to apply at least the following administrative penalties or remedial measures for breaches of this Regulation:

(a) issue an order requiring the natural or legal person to cease conduct that is in breach of this Regulation and to desist from a repetition of that conduct;

(b) require the temporary or permanent cessation of any practice or conduct that the competent authority considers to be contrary to the provisions of this Regulation and prevent repetition of that practice or conduct;

(c) adopt any type of measure, including of pecuniary nature, to ensure that financial entities continue to comply with legal requirements;

(d) require, insofar as permitted by national law, existing data traffic records held by a telecommunication operator, where there is a reasonable suspicion of a breach of this Regulation and where such records may be relevant to an investigation into breaches of this Regulation; and

(e) issue public notices, including public statements indicating the identity of the natural or legal person and the nature of the breach.

5. Where paragraph 2, point (c), and paragraph 4 apply to legal persons, Member States shall confer on competent authorities the power to apply the administrative penalties and remedial measures, subject to the conditions provided for in national law, to members of the management body, and to other individuals who under national law are responsible for the breach.

6. Member States shall ensure that any decision imposing administrative penalties or remedial measures set out in paragraph 2, point (c), is properly reasoned and is subject to a right of appeal.

Article 51

Exercise of the power to impose administrative penalties and remedial measures

1. Competent authorities shall exercise the powers to impose administrative penalties and remedial measures referred to in Article 50 in accordance with their national legal frameworks, where appropriate, as follows:

(a) directly;

(b) in collaboration with other authorities;

(c) under their responsibility by delegation to other authorities; or

(d) by application to the competent judicial authorities.

2. Competent authorities, when determining the type and level of an administrative penalty or remedial measure to be imposed under Article 50, shall take into account the extent to which the breach is intentional or results from negligence, and all other relevant circumstances, including the following, where appropriate:

(a) the materiality, gravity and the duration of the breach;

(b) the degree of responsibility of the natural or legal person responsible for the breach;

(c) the financial strength of the responsible natural or legal person;

(d) the importance of profits gained or losses avoided by the responsible natural or legal person, insofar as they can be determined;

(e) the losses for third parties caused by the breach, insofar as they can be determined;

(f) the level of cooperation of the responsible natural or legal person with the competent authority, without prejudice to the need to ensure disgorgement of profits gained or losses avoided by that natural or legal person;

(g) previous breaches by the responsible natural or legal person.

Article 52

Criminal penalties

1. Member States may decide not to lay down rules for administrative penalties or remedial measures for breaches that are subject to criminal penalties under their national law.

2. Where Member States have chosen to lay down criminal penalties for breaches of this Regulation, they shall ensure that appropriate measures are in place so that competent authorities have all the necessary powers to liaise with judicial, prosecuting, or criminal justice authorities within their jurisdiction to receive specific information related to criminal investigations or proceedings commenced for breaches of this Regulation, and to provide the same information to other competent authorities, as well as EBA, ESMA or EIOPA to fulfil their obligations to cooperate for the purposes of this Regulation.

Article 53

Notification duties

Member States shall notify the laws, regulations and administrative provisions implementing this Chapter, including any relevant criminal law provisions, to the Commission, ESMA, the EBA and EIOPA by 17 January 2025. Member States shall notify the Commission, ESMA, the EBA and EIOPA without undue delay of any subsequent amendments thereto.

Article 54

Publication of administrative penalties

1. Competent authorities shall publish on their official websites, without undue delay, any decision imposing an administrative penalty against which there is no appeal after the addressee of the penalty has been notified of that decision.

2. The publication referred to in paragraph 1 shall include information on the type and nature of the breach, the identity of the persons responsible and the penalties imposed.

3. Where the competent authority, following a case-by-case assessment, considers that the publication of the identity, in the case of legal persons, or of the identity and personal data, in the case of natural persons, would be disproportionate, including risks in relation to the protection of personal data, jeopardise the stability of financial markets or the pursuit of an ongoing criminal investigation, or cause, insofar as these can be determined, disproportionate damages to the person involved, it shall adopt one of the following solutions in respect of the decision imposing an administrative penalty:

(a) defer its publication until all reasons for non-publication cease to exist;

(b) publish it on an anonymous basis, in accordance with national law; or

(c) refrain from publishing it, where the options set out in points (a) and (b) are deemed either insufficient to guarantee a lack of any danger for the stability of financial markets, or where such a publication would not be proportionate to the leniency of the imposed penalty.

4. In the case of a decision to publish an administrative penalty on an anonymous basis in accordance with paragraph 3, point (b), the publication of the relevant data may be postponed.

5. Where a competent authority publishes a decision imposing an administrative penalty against which there is an appeal before the relevant judicial authorities, competent authorities shall immediately add on their official website that information and, at later stages, any subsequent related information on the outcome of such appeal. Any judicial decision annulling a decision imposing an administrative penalty shall also be published.

6. Competent authorities shall ensure that any publication referred to in paragraphs 1 to 4 shall remain on their official website only for the period which is necessary to bring forth this Article. This period shall not exceed five years after its publication.

Article 55

Professional secrecy

1. Any confidential information received, exchanged or transmitted pursuant to this Regulation shall be subject to the conditions of professional secrecy laid down in paragraph 2.

2. The obligation of professional secrecy applies to all persons who work, or who have worked, for the competent authorities pursuant to this Regulation, or for any authority or market undertaking or natural or legal person to whom those competent authorities have delegated their powers, including auditors and experts contracted by them.

3. Information covered by professional secrecy, including the exchange of information among competent authorities under this Regulation and competent authorities designated or established in accordance with Directive (EU) 2022/2555, shall not be disclosed to any other person or authority except by virtue of provisions laid down by Union or national law;

4. All information exchanged between the competent authorities pursuant to this Regulation that concerns business or operational conditions and other economic or personal affairs shall be considered confidential and shall be subject to the requirements of professional secrecy, except where the competent authority states, at the time of communication, that such information may be disclosed or where such disclosure is necessary for legal proceedings.

Article 56

Data Protection

1. The ESAs and the competent authorities shall be allowed to process personal data only where necessary for the purpose of carrying out their respective obligations and duties pursuant to this Regulation, in particular for investigation, inspection, request for information, communication, publication, evaluation, verification, assessment and drafting of oversight plans. The personal data shall be processed in accordance with Regulation (EU) 2016/679 or Regulation (EU) 2018/1725, whichever is applicable.

2. Except where otherwise provided in other sectoral acts, the personal data referred to in paragraph 1 shall be retained until the discharge of the applicable supervisory duties and in any case for a maximum period of 15 years, except in the event of pending court proceedings requiring further retention of such data.

CHAPTER VIII

Delegated acts

Article 57

Exercise of the delegation

1. The power to adopt delegated acts is conferred on the Commission subject to the conditions laid down in this Article.

2. The power to adopt delegated acts referred to in Articles 31(6) and 43(2) shall be conferred on the Commission for a period of five years from 17 January 2024. The Commission shall draw up a report in respect of the delegation of power not later than nine months before the end of the five-year period. The delegation of power shall be tacitly extended for periods of an identical duration, unless the European Parliament or the Council opposes such extension not later than three months before the end of each period.

3. The delegation of power referred to in Articles 31(6) and 43(2) may be revoked at any time by the European Parliament or by the Council. A decision to revoke shall put an end to the delegation of the power specified in that decision. It shall take effect the day following the publication of the decision in the *Official Journal of the European Union* or at a later date specified therein. It shall not affect the validity of any delegated acts already in force.

4. Before adopting a delegated act, the Commission shall consult experts designated by each Member State in accordance with the principles laid down in the Interinstitutional Agreement of 13 April 2016 on Better Law-Making.

5. As soon as it adopts a delegated act, the Commission shall notify it simultaneously to the European Parliament and to the Council.

6. A delegated act adopted pursuant to Articles 31(6) and 43(2) shall enter into force only if no objection has been expressed either by the European Parliament or by the Council within a period of three months of notification of that act to the European Parliament and the Council or if, before the expiry of that period, the European Parliament and the Council have both informed the Commission that they will not object. That period shall be extended by three months at the initiative of the European Parliament or of the Council.

CHAPTER IX

Transitional and final provisions

Section I

Article 58

Review clause

1. By 17 January 2028, the Commission shall, after consulting the ESAs and the ESRB, as appropriate, carry out a review and submit a report to the European Parliament and the Council, accompanied, where appropriate, by a legislative proposal. The review shall include at least the following:

(a) the criteria for the designation of critical ICT third-party service providers in accordance with Article 31(2);

(b) the voluntary nature of the notification of significant cyber threats referred to in Article 19;

(c) the regime referred to in Article 31(12) and the powers of the Lead Overseer provided for in Article 35(1), point (d), point (iv), first indent, with a view to evaluating the effectiveness of those provisions with regard to ensuring effective oversight of critical ICT third-party service providers established in a third country, and the necessity to establish a subsidiary in the Union.

For the purposes of the first subparagraph of this point, the review shall include an analysis of the regime referred to in Article 31(12), including in terms of access for Union financial entities to services from third countries and availability of such services on the Union market and it shall take into account further developments in the markets for the services covered by this Regulation, the practical experience of financial entities and financial supervisors with regard to the application and, respectively, supervision of that regime, and any relevant regulatory and supervisory developments taking place at international level.

(d) the appropriateness of including in the scope of this Regulation financial entities referred to in Article 2(3), point (e), making use of automated sales systems, in light of future market developments on the use of such systems;

(e) the functioning and effectiveness of the JON in supporting the consistency of the oversight and the efficiency of the exchange of information within the Oversight Framework.

2. In the context of the review of Directive (EU) 2015/2366, the Commission shall assess the need for increased cyber resilience of payment systems and payment-processing activities and the appropriateness of extending the scope of this Regulation to operators of payment systems and entities involved in payment-processing activities. In light of this assessment, the Commission shall submit, as part of the review of Directive (EU) 2015/2366, a report to the European Parliament and the Council no later than 17 July 2023.

Based on that review report, and after consulting ESAs, ECB and the ESRB, the Commission may submit, where appropriate and as part of the legislative proposal that it may adopt pursuant to Article 108, second paragraph, of Directive (EU) 2015/2366, a proposal to ensure that all operators of payment systems and entities involved in payment-processing activities are subject to an appropriate oversight, while taking into account existing oversight by the central bank.

3. By 17 January 2026, the Commission shall, after consulting the ESAs and the Committee of European Auditing Oversight Bodies, carry out a review and submit a report to the European Parliament and the Council, accompanied, where appropriate, by a legislative proposal, on the appropriateness of strengthened requirements for statutory auditors and audit firms as regards digital operational resilience, by means of the inclusion of statutory auditors and audit firms into the scope of this Regulation or by means of amendments to Directive 2006/43/EC of the European Parliament and of the Council ([39]).

Section II

Amendments

Article 59

Amendments to Regulation (EC) No 1060/2009

Regulation (EC) No 1060/2009 is amended as follows:

(1) in Annex I, Section A, point 4, the first subparagraph is replaced by the following:

'A credit rating agency shall have sound administrative and accounting procedures, internal control mechanisms, effective procedures for risk assessment, and effective control and safeguard arrangements for managing ICT systems in accordance with Regulation (EU) 2022/2554 of the European Parliament and of the Council (*).

(*) Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011 (OJ L 333, 27.12.2022, p. 1).';

(2) in Annex III, point 12 is replaced by the following:

'12. The credit rating agency infringes Article 6(2), in conjunction with point 4 of Section A of Annex I, by not having sound administrative or accounting procedures, internal control mechanisms, effective procedures for risk assessment, or effective control or safeguard arrangements for managing ICT systems in accordance with Regulation (EU) 2022/2554; or by not implementing or maintaining decision-making procedures or organisational structures as required by that point.'.

Article 60

Amendments to Regulation (EU) No 648/2012

Regulation (EU) No 648/2012 is amended as follows:

(1) Article 26 is amended as follows:

(a) paragraph 3 is replaced by the following:

'3. A CCP shall maintain and operate an organisational structure that ensures continuity and orderly functioning in the performance of its services and activities. It shall employ appropriate and proportionate systems, resources and procedures, including ICT systems managed in accordance with Regulation (EU) 2022/2554 of the European Parliament and of the Council (*).

(*) Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011 (OJ L 333, 27.12.2022, p. 1).';

([39]) Directive 2006/43/EC of the European Parliament and of the Council of 17 May 2006 on statutory audits of annual accounts and consolidated accounts, amending Council Directives 78/660/EEC and 83/349/EEC and repealing Council Directive 84/253/EEC (OJ L 157, 9.6.2006, p. 87).

(b) paragraph 6 is deleted;

(2) Article 34 is amended as follows:

(a) paragraph 1 is replaced by the following:

'1. A CCP shall establish, implement and maintain an adequate business continuity policy and disaster recovery plan, which shall include ICT business continuity policy and ICT response and recovery plans put in place and implemented in accordance with Regulation (EU) 2022/2554, aiming to ensure the preservation of its functions, the timely recovery of operations and the fulfilment of the CCP's obligations.';

(b) in paragraph 3, the first subparagraph is replaced by the following:

'3. In order to ensure consistent application of this Article, ESMA shall, after consulting the members of the ESCB, develop draft regulatory technical standards specifying the minimum content and requirements of the business continuity policy and of the disaster recovery plan, excluding ICT business continuity policy and disaster recovery plans.';

(3) in Article 56(3), the first subparagraph is replaced by the following:

'3. In order to ensure consistent application of this Article, ESMA shall develop draft regulatory technical standards specifying the details, other than for requirements related to ICT risk management, of the application for registration referred to in paragraph 1.';

(4) in Article 79, paragraphs 1 and 2 are replaced by the following:

'1. A trade repository shall identify sources of operational risk and minimise them also through the development of appropriate systems, controls and procedures, including ICT systems managed in accordance with Regulation (EU) 2022/2554.

2. A trade repository shall establish, implement and maintain an adequate business continuity policy and disaster recovery plan including ICT business continuity policy and ICT response and recovery plans established in accordance with Regulation (EU) 2022/2554, aiming to ensure the maintenance of its functions, the timely recovery of operations and the fulfilment of the trade repository's obligations.';

(5) in Article 80, paragraph 1 is deleted.

(6) in Annex I, Section II is amended as follows:

(a) points (a) and (b) are replaced by the following:

'(a) a trade repository infringes Article 79(1) by not identifying sources of operational risk or by not minimising those risks through the development of appropriate systems, controls and procedures including ICT systems managed in accordance with Regulation (EU) 2022/2554;

(b) a trade repository infringes Article 79(2) by not establishing, implementing or maintaining an adequate business continuity policy and disaster recovery plan established in accordance with Regulation (EU) 2022/2554, aiming to ensure the maintenance of its functions, the timely recovery of operations and the fulfilment of the trade repository's obligations;';

(b) point (c) is deleted.

(7) Annex III is amended as follows:

(a) Section II is amended as follows:

(i) point (c) is replaced by the following:

'(c) a Tier 2 CCP infringes Article 26(3) by not maintaining or operating an organisational structure that ensures continuity and orderly functioning in the performance of its services and activities or by not employing appropriate and proportionate systems, resources or procedures including ICT systems managed in accordance with Regulation (EU) 2022/2554;';

(ii) point (f) is deleted.

(b) in Section III, point (a) is replaced by the following:

'(a) a Tier 2 CCP infringes Article 34(1) by not establishing, implementing or maintaining an adequate business continuity policy and response and recovery plan set up in accordance with Regulation (EU) 2022/2554, aiming to ensure the preservation of its functions, the timely recovery of operations and the fulfilment of the CCP's obligations, which at least allows for the recovery of all transactions at the time of disruption to allow the CCP to continue to operate with certainty and to complete settlement on the scheduled date;'.

Article 61

Amendments to Regulation (EU) No 909/2014

Article 45 of Regulation (EU) No 909/2014 is amended as follows:

(1) paragraph 1 is replaced by the following:

'1. A CSD shall identify sources of operational risk, both internal and external, and minimise their impact also through the deployment of appropriate ICT tools, processes and policies set up and managed in accordance with Regulation (EU) 2022/2554 of the European Parliament and of the Council (*), as well as through any other relevant appropriate tools, controls and procedures for other types of operational risk, including for all the securities settlement systems it operates.

_____

(*) Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011 (OJ L 333, 27.12.2022, p. 1).';

(2) paragraph 2 is deleted;

(3) paragraphs 3 and 4 are replaced by the following:

'3. For services that it provides as well as for each securities settlement system that it operates, a CSD shall establish, implement and maintain an adequate business continuity policy and disaster recovery plan, including ICT business continuity policy and ICT response and recovery plans established in accordance with Regulation (EU) 2022/2554, to ensure the preservation of its services, the timely recovery of operations and the fulfilment of the CSD's obligations in the case of events that pose a significant risk to disrupting operations.

4. The plan referred to in paragraph 3 shall provide for the recovery of all transactions and participants' positions at the time of disruption to allow the participants of a CSD to continue to operate with certainty and to complete settlement on the scheduled date, including by ensuring that critical IT systems can resume operations from the time of disruption as provided for in Article 12(5) and (7) of Regulation (EU) 2022/2554.';

(4) paragraph 6 is replaced by the following:

'6. A CSD shall identify, monitor and manage the risks that key participants in the securities settlement systems it operates, as well as service and utility providers, and other CSDs or other market infrastructures might pose to its operations. It shall, upon request, provide competent and relevant authorities with information on any such risk identified. It shall also inform the competent authority and relevant authorities without delay of any operational incidents, other than in relation to ICT risk, resulting from such risks.';

(5) in paragraph 7, the first subparagraph is replaced by the following:

'7. ESMA shall, in close cooperation with the members of the ESCB, develop draft regulatory technical standards to specify the operational risks referred to in paragraphs 1 and 6, other than ICT risk, and the methods to test, to address or to minimise those risks, including the business continuity policies and disaster recovery plans referred to in paragraphs 3 and 4 and the methods of assessment thereof.'.

Article 62

Amendments to Regulation (EU) No 600/2014

Regulation (EU) No 600/2014 is amended as follows:

(1) Article 27g is amended as follows:

(a) paragraph 4 is replaced by the following:

'4. An APA shall comply with the requirements concerning the security of network and information systems set out in Regulation (EU) 2022/2554 of the European Parliament and of the Council (*).

(*) Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011 (OJ L 333, 27.12.2022, p. 1).';

(b) in paragraph 8, point (c) is replaced by the following:

'(c) the concrete organisational requirements laid down in paragraphs 3 and 5.';

(2) Article 27h is amended as follows:

(a) paragraph 5 is replaced by the following:

'5. A CTP shall comply with the requirements concerning the security of network and information systems set out in Regulation (EU) 2022/2554.'.

(b) in paragraph 8, point (e) is replaced by the following:

'(e) the concrete organisational requirements laid down in paragraph 4.';

(3) Article 27i is amended as follows:

(a) paragraph 3 is replaced by the following:

'3. An ARM shall comply with the requirements concerning the security of network and information systems set out in Regulation (EU) 2022/2554.';

(b) in paragraph 5, point (b) is replaced by the following:

'(b) the concrete organisational requirements laid down in paragraphs 2 and 4.'.

Article 63

Amendment to Regulation (EU) 2016/1011

In Article 6 of Regulation (EU) 2016/1011, the following paragraph is added:

'6. For critical benchmarks, an administrator shall have sound administrative and accounting procedures, internal control mechanisms, effective procedures for risk assessment, and effective control and safeguard arrangements for managing ICT systems in accordance with Regulation (EU) 2022/2554 of the European Parliament and of the Council (*).

(*) Regulation (EU) 2022/2554 of the European Parliament and of the Council of 14 December 2022 on digital operational resilience for the financial sector and amending Regulations (EC) No 1060/2009, (EU) No 648/2012, (EU) No 600/2014, (EU) No 909/2014 and (EU) 2016/1011 (OJ L 333, 27.12.2022, p. 1).'.

Article 64

Entry into force and application

This Regulation shall enter into force on the twentieth day following that of its publication in the *Official Journal of the European Union*.

It shall apply from 17 January 2025.

This Regulation shall be binding in its entirety and directly applicable in all Member States.

Done at Strasbourg, 14 December 2022.

For the European Parliament	*For the Council*
The President	*The President*
R. METSOLA	M. BEK

DIRECTIVE (EU) 2019/790 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL

of 17 April 2019

on copyright and related rights in the Digital Single Market and amending Directives 96/9/EC and 2001/29/EC

(Text with EEA relevance)

THE EUROPEAN PARLIAMENT AND THE COUNCIL OF THE EUROPEAN UNION,

Having regard to the Treaty on the Functioning of the European Union, and in particular Article 53(1) and Articles 62 and 114 thereof,

Having regard to the proposal from the European Commission,

After transmission of the draft legislative act to the national parliaments,

Having regard to the opinion of the European Economic and Social Committee ([1]),

Having regard to the opinion of the Committee of the Regions ([2]),

Acting in accordance with the ordinary legislative procedure ([3]),

Whereas:

(1) The Treaty on European Union (TEU) provides for the establishment of an internal market and the institution of a system ensuring that competition in the internal market is not distorted. Further harmonisation of the laws of the Member States on copyright and related rights should contribute to the achievement of those objectives.

(2) The directives that have been adopted in the area of copyright and related rights contribute to the functioning of the internal market, provide for a high level of protection for rightholders, facilitate the clearance of rights, and create a framework in which the exploitation of works and other protected subject matter can take place. That harmonised legal framework contributes to the proper functioning of the internal market, and stimulates innovation, creativity, investment and production of new content, also in the digital environment, in order to avoid the fragmentation of the internal market. The protection provided by that legal framework also contributes to the Union's objective of respecting and promoting cultural diversity, while at the same time bringing European common cultural heritage to the fore. Article 167(4) of the Treaty on the Functioning of the European Union requires the Union to take cultural aspects into account in its action.

(3) Rapid technological developments continue to transform the way works and other subject matter are created, produced, distributed and exploited. New business models and new actors continue to emerge. Relevant legislation needs to be future-proof so as not to restrict technological development. The objectives and the principles laid down by the Union copyright framework remain sound. However, legal uncertainty remains, for both rightholders and users, as regards certain uses, including cross-border uses, of works and other subject matter in the digital environment. As stated in the Commission Communication of 9 December 2015 entitled 'Towards a modern, more European copyright framework', in some areas it is necessary to adapt and supplement the existing Union copyright framework, while keeping a high level of protection of copyright and related rights. This Directive provides for rules to adapt certain exceptions and limitations to copyright and related rights to digital and cross-border environments, as well as for measures to facilitate certain licensing practices, in particular, but not only, as regards the dissemination of out-of-commerce works and other subject matter and the online availability of audiovisual works on video-on-demand platforms, with a view to ensuring wider access to content. It also contains rules to facilitate the use of content in the public domain. In order to achieve a well-functioning and fair marketplace for copyright, there should also be rules on rights in publications, on the use of works

([1]) OJ C 125, 21.4.2017, p. 27.
([2]) OJ C 207, 30.6.2017, p. 80.
([3]) Position of the European Parliament of 26 March 2019 (not yet published in the Official Journal) and decision of the Council of 15 April 2019.

or other subject matter by online service providers storing and giving access to user-uploaded content, on the transparency of authors' and performers' contracts, on authors' and performers' remuneration, as well as a mechanism for the revocation of rights that authors and performers have transferred on an exclusive basis.

(4) This Directive is based upon, and complements, the rules laid down in the directives currently in force in this area, in particular Directives 96/9/EC ([4]), 2000/31/EC ([5]), 2001/29/EC ([6]), 2006/115/EC ([7]), 2009/24/EC ([8]), 2012/28/EU ([9]) and 2014/26/EU ([10]) of the European Parliament and of the Council.

(5) In the fields of research, innovation, education and preservation of cultural heritage, digital technologies permit new types of uses that are not clearly covered by the existing Union rules on exceptions and limitations. In addition, the optional nature of exceptions and limitations provided for in Directives 96/9/EC, 2001/29/EC and 2009/24/EC in those fields could negatively impact the functioning of the internal market. This is particularly relevant as regards cross-border uses, which are becoming increasingly important in the digital environment. Therefore, the existing exceptions and limitations in Union law that are relevant for scientific research, innovation, teaching and preservation of cultural heritage should be reassessed in the light of those new uses. Mandatory exceptions or limitations for uses of text and data mining technologies, illustration for teaching in the digital environment and for preservation of cultural heritage should be introduced. The existing exceptions and limitations in Union law should continue to apply, including to text and data mining, education, and preservation activities, as long as they do not limit the scope of the mandatory exceptions or limitations provided for in this Directive, which need to be implemented by Member States in their national law. Directives 96/9/EC and 2001/29/EC should, therefore, be amended.

(6) The exceptions and limitations provided for in this Directive seek to achieve a fair balance between the rights and interests of authors and other rightholders, on the one hand, and of users on the other. They can be applied only in certain special cases that do not conflict with the normal exploitation of the works or other subject matter and do not unreasonably prejudice the legitimate interests of the rightholders.

(7) The protection of technological measures established in Directive 2001/29/EC remains essential to ensure the protection and the effective exercise of the rights granted to authors and to other rightholders under Union law. Such protection should be maintained while ensuring that the use of technological measures does not prevent the enjoyment of the exceptions and limitations provided for in this Directive. Rightholders should have the opportunity to ensure that through voluntary measures. They should remain free to choose the appropriate means of enabling the beneficiaries of the exceptions and limitations provided for in this Directive to benefit from them. In the absence of voluntary measures, Member States should take appropriate measures in accordance with the first subparagraph of Article 6(4) of Directive 2001/29/EC, including where works and other subject matter are made available to the public through on-demand services.

(8) New technologies enable the automated computational analysis of information in digital form, such as text, sounds, images or data, generally known as text and data mining. Text and data mining makes the processing of large amounts of information with a view to gaining new knowledge and discovering new trends possible. Text and data mining technologies are prevalent across the digital economy; however, there is widespread acknowledgment that text and data mining can, in particular, benefit the research community and, in so doing, support

([4]) Directive 96/9/EC of the European Parliament and of the Council of 11 March 1996 on the legal protection of databases (OJ L 77, 27.3.1996, p. 20).
([5]) Directive 2000/31/EC of the European Parliament and of the Council of 8 June 2000 on certain legal aspects of information society services, in particular electronic commerce, in the Internal Market (Directive on electronic commerce) (OJ L 178, 17.7.2000, p. 1).
([6]) Directive 2001/29/EC of the European Parliament and of the Council of 22 May 2001 on the harmonisation of certain aspects of copyright and related rights in the information society (OJ L 167, 22.6.2001, p. 10).
([7]) Directive 2006/115/EC of the European Parliament and of the Council of 12 December 2006 on rental right and lending right and on certain rights related to copyright in the field of intellectual property (OJ L 376, 27.12.2006, p. 28).
([8]) Directive 2009/24/EC of the European Parliament and of the Council of 23 April 2009 on the legal protection of computer programs (OJ L 111, 5.5.2009, p. 16).
([9]) Directive 2012/28/EU of the European Parliament and of the Council of 25 October 2012 on certain permitted uses of orphan works (OJ L 299, 27.10.2012, p. 5).
([10]) Directive 2014/26/EU of the European Parliament and of the Council of 26 February 2014 on collective management of copyright and related rights and multi-territorial licensing of rights in musical works for online use in the internal market (OJ L 84, 20.3.2014, p. 72).

innovation. Such technologies benefit universities and other research organisations, as well as cultural heritage institutions since they could also carry out research in the context of their main activities. However, in the Union, such organisations and institutions are confronted with legal uncertainty as to the extent to which they can perform text and data mining of content. In certain instances, text and data mining can involve acts protected by copyright, by the sui generis database right or by both, in particular, the reproduction of works or other subject matter, the extraction of contents from a database or both which occur for example when the data are normalised in the process of text and data mining. Where no exception or limitation applies, an authorisation to undertake such acts is required from rightholders.

(9) Text and data mining can also be carried out in relation to mere facts or data that are not protected by copyright, and in such instances no authorisation is required under copyright law. There can also be instances of text and data mining that do not involve acts of reproduction or where the reproductions made fall under the mandatory exception for temporary acts of reproduction provided for in Article 5(1) of Directive 2001/29/EC, which should continue to apply to text and data mining techniques that do not involve the making of copies beyond the scope of that exception.

(10) Union law provides for certain exceptions and limitations covering uses for scientific research purposes which may apply to acts of text and data mining. However, those exceptions and limitations are optional and not fully adapted to the use of technologies in scientific research. Moreover, where researchers have lawful access to content, for example through subscriptions to publications or open access licences, the terms of the licences could exclude text and data mining. As research is increasingly carried out with the assistance of digital technology, there is a risk that the Union's competitive position as a research area will suffer, unless steps are taken to address the legal uncertainty concerning text and data mining.

(11) The legal uncertainty concerning text and data mining should be addressed by providing for a mandatory exception for universities and other research organisations, as well as for cultural heritage institutions, to the exclusive right of reproduction and to the right to prevent extraction from a database. In line with the existing Union research policy, which encourages universities and research institutes to collaborate with the private sector, research organisations should also benefit from such an exception when their research activities are carried out in the framework of public-private partnerships. While research organisations and cultural heritage institutions should continue to be the beneficiaries of that exception, they should also be able to rely on their private partners for carrying out text and data mining, including by using their technological tools.

(12) Research organisations across the Union encompass a wide variety of entities the primary goal of which is to conduct scientific research or to do so together with the provision of educational services. The term 'scientific research' within the meaning of this Directive should be understood to cover both the natural sciences and the human sciences. Due to the diversity of such entities, it is important to have a common understanding of research organisations. They should for example cover, in addition to universities or other higher education institutions and their libraries, also entities such as research institutes and hospitals that carry out research. Despite different legal forms and structures, research organisations in the Member States generally have in common that they act either on a not-for-profit basis or in the context of a public-interest mission recognised by the State. Such a public-interest mission could, for example, be reflected through public funding or through provisions in national laws or public contracts. Conversely, organisations upon which commercial undertakings have a decisive influence allowing such undertakings to exercise control because of structural situations, such as through their quality of shareholder or member, which could result in preferential access to the results of the research, should not be considered research organisations for the purposes of this Directive.

(13) Cultural heritage institutions should be understood as covering publicly accessible libraries and museums regardless of the type of works or other subject matter that they hold in their permanent collections, as well as archives, film or audio heritage institutions. They should also be understood to include, inter alia, national libraries and national archives, and, as far as their archives and publicly accessible libraries are concerned, educational establishments, research organisations and public sector broadcasting organisations.

(14) Research organisations and cultural heritage institutions, including the persons attached thereto, should be covered by the text and data mining exception with regard to content to which they have lawful access. Lawful access should be understood as covering access to content based on an open access policy or through contractual arrangements between rightholders and research organisations or cultural heritage institutions, such as subscriptions, or through other lawful means. For instance, in the case of subscriptions taken by research organisations or cultural heritage institutions, the persons attached thereto and covered by those subscriptions should be deemed to have lawful access. Lawful access should also cover access to content that is freely available online.

(15) Research organisations and cultural heritage institutions could in certain cases, for example for subsequent verification of scientific research results, need to retain copies made under the exception for the purposes of carrying out text and data mining. In such cases, the copies should be stored in a secure environment. Member States should be free to decide, at national level and after discussions with relevant stakeholders, on further specific arrangements for retaining the copies, including the ability to appoint trusted bodies for the purpose of storing such copies. In order not to unduly restrict the application of the exception, such arrangements should be proportionate and limited to what is needed for retaining the copies in a safe manner and preventing unauthorised use. Uses for the purpose of scientific research, other than text and data mining, such as scientific peer review and joint research, should remain covered, where applicable, by the exception or limitation provided for in Article 5(3)(a) of Directive 2001/29/EC.

(16) In view of a potentially high number of access requests to, and downloads of, their works or other subject matter, rightholders should be allowed to apply measures when there is a risk that the security and integrity of their systems or databases could be jeopardised. Such measures could, for example, be used to ensure that only persons having lawful access to their data can access them, including through IP address validation or user authentication. Those measures should remain proportionate to the risks involved, and should not exceed what is necessary to pursue the objective of ensuring the security and integrity of the system and should not undermine the effective application of the exception.

(17) In view of the nature and scope of the exception, which is limited to entities carrying out scientific research, any potential harm created to rightholders through this exception would be minimal. Member States should, therefore, not provide for compensation for rightholders as regards uses under the text and data mining exceptions introduced by this Directive.

(18) In addition to their significance in the context of scientific research, text and data mining techniques are widely used both by private and public entities to analyse large amounts of data in different areas of life and for various purposes, including for government services, complex business decisions and the development of new applications or technologies. Rightholders should remain able to license the uses of their works or other subject matter falling outside the scope of the mandatory exception provided for in this Directive for text and data mining for the purposes of scientific research and of the existing exceptions and limitations provided for in Directive 2001/29/EC. At the same time, consideration should be given to the fact that users of text and data mining could be faced with legal uncertainty as to whether reproductions and extractions made for the purposes of text and data mining can be carried out on lawfully accessed works or other subject matter, in particular when the reproductions or extractions made for the purposes of the technical process do not fulfil all the conditions of the existing exception for temporary acts of reproduction provided for in Article 5(1) of Directive 2001/29/EC. In order to provide for more legal certainty in such cases and to encourage innovation also in the private sector, this Directive should provide, under certain conditions, for an exception or limitation for reproductions and extractions of works or other subject matter, for the purposes of text and data mining, and allow the copies made to be retained for as long as is necessary for those text and data mining purposes.

This exception or limitation should only apply where the work or other subject matter is accessed lawfully by the beneficiary, including when it has been made available to the public online, and insofar as the rightholders have not reserved in an appropriate manner the rights to make reproductions and extractions for text and data mining. In the case of content that has been made publicly available online, it should only be considered

appropriate to reserve those rights by the use of machine-readable means, including metadata and terms and conditions of a website or a service. Other uses should not be affected by the reservation of rights for the purposes of text and data mining. In other cases, it can be appropriate to reserve the rights by other means, such as contractual agreements or a unilateral declaration. Rightholders should be able to apply measures to ensure that their reservations in this regard are respected. This exception or limitation should leave intact the mandatory exception for text and data mining for scientific research purposes provided for in this Directive, as well as the existing exception for temporary acts of reproduction provided for in Article 5(1) of Directive 2001/29/EC.

(19) Article 5(3)(a) of Directive 2001/29/EC allows Member States to introduce an exception or limitation to the rights of reproduction, communication to the public and making available to the public of works or other subject matter in such a way that members of the public may access them from a place and a time individually chosen by them, for the sole purpose of illustration for teaching. In addition, Articles 6(2)(b) and 9(b) of Directive 96/9/EC permit the use of a database and the extraction of a substantial part of its contents for the purpose of illustration for teaching. The scope of those exceptions or limitations as they apply to digital uses is unclear. In addition, there is a lack of clarity as to whether those exceptions or limitations would apply where teaching is provided online and at a distance. Moreover, the existing legal framework does not provide for a cross-border effect. This situation could hamper the development of digitally supported teaching activities and distance learning. Therefore, the introduction of a new mandatory exception or limitation is necessary to ensure that educational establishments benefit from full legal certainty when using works or other subject matter in digital teaching activities, including online and across borders.

(20) While distance learning and cross-border education programmes are mostly developed at higher education level, digital tools and resources are increasingly used at all education levels, in particular to improve and enrich the learning experience. The exception or limitation provided for in this Directive should, therefore, benefit all educational establishments recognised by a Member State, including those involved in primary, secondary, vocational and higher education. It should apply only to the extent that the uses are justified by the non-commercial purpose of the particular teaching activity. The organisational structure and the means of funding of an educational establishment should not be the decisive factors in determining whether the activity is non-commercial in nature.

(21) The exception or limitation provided for in this Directive for the sole purpose of illustration for teaching should be understood as covering digital uses of works or other subject matter to support, enrich or complement the teaching, including learning activities. The distribution of software allowed under that exception or limitation should be limited to digital transmission of software. In most cases, the concept of illustration would, therefore, imply the use only of parts or extracts of works, which should not substitute for the purchase of materials primarily intended for the educational market. When implementing the exception or limitation, Member States should remain free to specify, for the different types of works or other subject matter, in a balanced manner, the proportion of a work or other subject matter that can be used for the sole purpose of illustration for teaching. Uses allowed under the exception or limitation should be understood to cover the specific accessibility needs of persons with a disability in the context of illustration for teaching.

(22) The use of works or other subject matter under the exception or limitation for the sole purpose of illustration for teaching provided for in this Directive should only take place in the context of teaching and learning activities carried out under the responsibility of educational establishments, including during examinations or teaching activities that take place outside the premises of educational establishments, for example in a museum, library or another cultural heritage institution, and should be limited to what is necessary for the purpose of such activities. The exception or limitation should cover both uses of works or other subject matter made in the classroom or in other venues through digital means, for example electronic whiteboards or digital devices which might be connected to the internet, as well as uses made at a distance through secure electronic environments, such as in the context of online courses or access to teaching material complementing a given course. Secure electronic environments should be understood as digital teaching and learning environments access to which is limited to an educational establishment's teaching staff and to pupils or students enrolled in a study programme, in particular through appropriate authentication procedures including password-based authentication.

(23) Different arrangements, based on the implementation of the exception or limitation provided for in Directive 2001/29/EC or on licensing agreements covering further uses, are in place in a number of Member States in order to facilitate educational uses of works and other subject matter. Such arrangements have usually been developed taking account of the needs of educational establishments and of different levels of education. While it is essential to harmonise the scope of the new mandatory exception or limitation in relation to digital uses and cross-border teaching activities, the arrangements for implementation can vary from one Member State to another, to the extent that they do not hamper the effective application of the exception or limitation or cross-border uses. Member States should, for example, remain free to require that the use of works or other subject matter respect the moral rights of authors and performers. This should allow Member States to build on the existing arrangements concluded at national level. In particular, Member States could decide to subject the application of the exception or limitation, fully or partially, to the availability of suitable licences, covering at least the same uses as those allowed under the exception or limitation. Member States should ensure that where licences cover only partially the uses allowed under the exception or limitation, all the other uses remain subject to the exception or limitation.

Member States could, for example, use this mechanism to give precedence to licences for material that is primarily intended for the educational market or licences for sheet music. In order to avoid that subjecting the application of the exception to the availability of licences results in legal uncertainty or an administrative burden for educational establishments, Member States adopting such an approach should take concrete measures to ensure that licensing schemes allowing digital uses of works or other subject matter for the purpose of illustration for teaching are easily available, and that educational establishments are aware of the existence of such licensing schemes. Such licensing schemes should meet the needs of educational establishments. Information tools aimed at ensuring that existing licensing schemes are visible could also be developed. Such schemes could, for example, be based on collective licensing or on extended collective licensing, in order to avoid educational establishments having to negotiate individually with rightholders. In order to guarantee legal certainty, Member States should specify under which conditions an educational establishment can use protected works or other subject matter under that exception and, conversely, when it should act under a licensing scheme.

(24) Member States should remain free to provide that rightholders receive fair compensation for the digital uses of their works or other subject matter under the exception or limitation provided for in this Directive for illustration for teaching. In setting the level of fair compensation, due account should be taken, inter alia, of Member States' educational objectives and of the harm to rightholders. Member States that decide to provide for fair compensation should encourage the use of systems that do not create an administrative burden for educational establishments.

(25) Cultural heritage institutions are engaged in the preservation of their collections for future generations. An act of preservation of a work or other subject matter in the collection of a cultural heritage institution might require a reproduction and consequently require the authorisation of the relevant rightholders. Digital technologies offer new ways of preserving the heritage contained in those collections but they also create new challenges. In view of those new challenges, it is necessary to adapt the existing legal framework by providing for a mandatory exception to the right of reproduction in order to allow such acts of preservation by such institutions.

(26) The existence of different approaches in the Member States with regard to acts of reproduction for preservation by cultural heritage institutions hampers cross-border cooperation, the sharing of means of preservation and the establishment of cross-border preservation networks in the internal market by such institutions, leading to an inefficient use of resources. That can have a negative impact on the preservation of cultural heritage.

(27) Member States should, therefore, be required to provide for an exception to permit cultural heritage institutions to reproduce works and other subject matter permanently in their collections for preservation purposes, for example to address technological obsolescence or the degradation of original supports or to insure such works and other subject matter. Such an exception should allow the making of copies by the appropriate preservation tool, means or technology, in any format or medium, in the required number, at any point in the life of a work or other subject matter and to the extent required for preservation purposes. Acts of reproduction undertaken by

cultural heritage institutions for purposes other than the preservation of works and other subject matter in their permanent collections should remain subject to the authorisation of rightholders, unless permitted by other exceptions or limitations provided for in Union law.

(28) Cultural heritage institutions do not necessarily have the technical means or expertise to undertake the acts required to preserve their collections themselves, particularly in the digital environment, and might, therefore, have recourse to the assistance of other cultural institutions and other third parties for that purpose. Under the exception for preservation purposes provided for by this Directive, cultural heritage institutions should be allowed to rely on third parties acting on their behalf and under their responsibility, including those that are based in other Member States, for the making of copies.

(29) For the purposes of this Directive, works and other subject matter should be considered to be permanently in the collection of a cultural heritage institution when copies of such works or other subject matter are owned or permanently held by that institution, for example as a result of a transfer of ownership or a licence agreement, legal deposit obligations or permanent custody arrangements.

(30) Cultural heritage institutions should benefit from a clear framework for the digitisation and dissemination, including across borders, of works or other subject matter that are considered to be out of commerce for the purposes of this Directive. However, the particular characteristics of the collections of out-of-commerce works or other subject matter, together with the amount of works and other subject matter involved in mass digitisation projects, mean that obtaining the prior authorisation of the individual rightholders can be very difficult. This can be due, for example, to the age of the works or other subject matter, their limited commercial value or the fact that they were never intended for commercial use or that they have never been exploited commercially. It is therefore necessary to provide for measures to facilitate certain uses of out-of-commerce works or other subject matter that are permanently in the collections of cultural heritage institutions.

(31) All Member States should have legal mechanisms in place allowing licences issued by relevant and sufficiently representative collective management organisations to cultural heritage institutions, for certain uses of out-of-commerce works or other subject matter, to also apply to the rights of rightholders that have not mandated a representative collective management organisation in that regard. It should be possible, pursuant to this Directive, for such licences to cover all Member States.

(32) The provisions on collective licensing of out-of-commerce works or other subject matter introduced by this Directive might not provide a solution for all cases in which cultural heritage institutions encounter difficulties in obtaining all the necessary authorisations from rightholders for the use of such out-of-commerce works or other subject matter. That could be the case for example, where there is no practice of collective management of rights for a certain type of work or other subject matter or where the relevant collective management organisation is not sufficiently representative for the category of the rightholders and of the rights concerned. In such particular instances, it should be possible for cultural heritage institutions to make out-of-commerce works or other subject matter that are permanently in their collection available online in all Member States under a harmonised exception or limitation to copyright and related rights. It is important that uses under such exception or limitation only take place when certain conditions, in particular as regards the availability of licensing solutions, are fulfilled. A lack of agreement on the conditions of the licence should not be interpreted as a lack of availability of licensing solutions.

(33) Member States should, within the framework provided for in this Directive, have flexibility in choosing the specific type of licensing mechanism, such as extended collective licensing or presumptions of representation, that they put in place for the use of out-of-commerce works or other subject matter by cultural heritage institutions, in accordance with their legal traditions, practices or circumstances. Member States should also have flexibility in determining what the requirements for collective management organisations to be sufficiently representative are, as long as that determination is based on a significant number of rightholders in the relevant type of works or other subject matter having given a mandate allowing the licensing of the relevant type of use.

Member States should be free to establish specific rules applicable to cases in which more than one collective management organisation is representative for the relevant works or other subject matter, requiring for example joint licences or an agreement between the relevant organisations.

(34) For the purpose of those licensing mechanisms, a rigorous and well-functioning collective management system is important. Directive 2014/26/EU provides for such a system and that system includes in particular rules on good governance, transparency and reporting, as well as the regular, diligent and accurate distribution and payment of amounts due to individual rightholders.

(35) Appropriate safeguards should be available for all rightholders, who should be given the opportunity of excluding the application of the licensing mechanisms and of the exception or limitation, introduced by this Directive for the use of out-of-commerce works or other subject matter, in relation to all their works or other subject matter, in relation to all licences or all uses under the exception or limitation, in relation to particular works or other subject matter, or in relation to particular licences or uses under the exception or limitation, at any time before or during the term of the licence or before or during the use under the exception or limitation. Conditions governing those licensing mechanisms should not affect their practical relevance for cultural heritage institutions. It is important that, where a rightholder excludes the application of such mechanisms or of such exception or limitation to one or more works or other subject matter, any ongoing uses are terminated within a reasonable period, and, where they take place under a collective licence, that the collective management organisation once informed ceases to issue licences covering the uses concerned. Such exclusion by rightholders should not affect their claims to remuneration for the actual use of the work or other subject matter under the licence.

(36) This Directive does not affect the ability of Member States to decide who is to have legal responsibility as regards the compliance of the licensing of out-of-commerce works or other subject matter, and of their use, with the conditions set out in this Directive, and as regards the compliance of the parties concerned with the terms of those licences.

(37) Considering the variety of works and other subject matter in the collections of cultural heritage institutions, it is important that the licensing mechanisms and the exception or limitation provided for by this Directive are available and can be used in practice for different types of works and other subject matter, including photographs, software, phonograms, audiovisual works and unique works of art, including where they have never been commercially available. Never-in-commerce works can include posters, leaflets, trench journals or amateur audiovisual works, but also unpublished works or other subject matter, without prejudice to other applicable legal constraints, such as national rules on moral rights. When a work or other subject matter is available in any of its different versions, such as subsequent editions of literary works and alternate cuts of cinematographic works, or in any of its different manifestations, such as digital and printed formats of the same work, that work or other subject matter should not be considered out of commerce. Conversely, the commercial availability of adaptations, including other language versions or audiovisual adaptations of a literary work, should not preclude a work or other subject matter from being deemed to be out of commerce in a given language. In order to reflect the specificities of different types of works and other subject matter as regards modes of publication and distribution, and to facilitate the usability of those mechanisms, specific requirements and procedures might have to be established for the practical application of those licensing mechanisms, such as a requirement for a certain time period to have elapsed since the work or other subject matter was first commercially available. It is appropriate that Member States consult rightholders, cultural heritage institutions and collective management organisations when establishing such requirements and procedures.

(38) When determining whether works or other subject matter are out of commerce, a reasonable effort should be required to assess their availability to the public in the customary channels of commerce, taking into account the characteristics of the particular work or other subject matter or of the particular set of works or other subject matter. Member States should be free to determine the allocation of responsibilities for making that reasonable effort. The reasonable effort should not have to involve repeated action over time but it should nevertheless involve taking account of any easily accessible evidence of upcoming availability of works or other subject matter in the customary channels of commerce. A work-by-work assessment should only be required where that is considered reasonable in view of the availability of relevant information, the likelihood of commercial availability

and the expected transaction cost. Verification of availability of a work or other subject matter should normally take place in the Member State where the cultural heritage institution is established, unless verification across borders is considered reasonable, for example in cases where there is easily available information that a literary work was first published in a given language version in another Member State. In many cases, the out-of-commerce status of a set of works or other subject matter could be determined through a proportionate mechanism, such as sampling. The limited availability of a work or other subject matter, such as its availability in second-hand shops, or the theoretical possibility that a licence for a work or other subject matter could be obtained should not be considered as availability to the public in the customary channels of commerce.

(39) For reasons of international comity, the licensing mechanism and the exception or limitation provided for in this Directive for the digitisation and dissemination of out-of-commerce works or other subject matter should not apply to sets of out-of-commerce works or other subject matter where there is evidence available to presume that they predominantly consist of works or other subject matter of third countries, unless the collective management organisation concerned is sufficiently representative for that third country, for example via a representation agreement. That assessment could be based on the evidence available following the making of the reasonable effort to determine whether the works or other subject matter are out of commerce, without the need to search for further evidence. A work-by-work assessment of the origin of out-of-commerce works or other subject matter should only be required insofar as it is also required for making the reasonable effort to determine whether they are commercially available.

(40) Contracting cultural heritage institutions and collective management organisations should remain free to agree on the territorial scope of licences, including the option of covering all Member States, the licence fee and the uses allowed. Uses covered by such licences should not be for profit-making purposes, including where copies are distributed by the cultural heritage institution, such as in the case of promotional material about an exhibition. At the same time, given that the digitisation of the collections of cultural heritage institutions can entail significant investments, any licences granted under the mechanism provided for in this Directive should not prevent cultural heritage institutions from covering the costs of the licence and the costs of digitising and disseminating the works or other subject matter covered by the licence.

(41) Information regarding the ongoing and future use of out-of-commerce works and other subject matter by cultural heritage institutions on the basis of this Directive and the arrangements in place for all rightholders to exclude the application of licences or of the exception or limitation to their works or other subject matter should be adequately publicised both before and during the use under a licence or under the exception or limitation, as appropriate. Such publicising is particularly important when uses take place across borders in the internal market. It is therefore appropriate to provide for the creation of a single publicly accessible online portal for the Union in order to make such information available to the public for a reasonable period of time before the use takes place. Such portal should make it easier for rightholders to exclude the application of licences or of the exception or limitation to their works or other subject matter. Under Regulation (EU) No 386/2012 of the European Parliament and of the Council ([11]), the European Union Intellectual Property Office is entrusted with certain tasks and activities, financed by making use of its own budgetary means and aimed at facilitating and supporting the activities of national authorities, the private sector and Union institutions in the fight against, including the prevention of, infringement of intellectual property rights. It is therefore appropriate to rely on that Office to establish and manage the portal making such information available.

In addition to making the information available through the portal, further appropriate publicity measures might need to be taken on a case-by-case basis in order to increase the awareness in that regard of the rightholders concerned, for example through the use of additional channels of communication to reach a wider public. The necessity, the nature and the geographic scope of the additional publicity measures should depend on the characteristics of the relevant out-of-commerce works or other subject matter, the terms of the licences or the type of use under the exception or limitation, and the existing practices in Member States. Publicity measures should be effective without the need to inform each rightholder individually.

([11]) Regulation (EU) No 386/2012 of the European Parliament and of the Council of 19 April 2012 on entrusting the Office for Harmonization in the Internal Market (Trade Marks and Designs) with tasks related to the enforcement of intellectual property rights, including the assembling of public and private-sector representatives as a European Observatory on Infringements of Intellectual Property Rights (OJ L 129, 16.5.2012, p. 1).

(42) In order to ensure that the licensing mechanisms established by this Directive for out-of-commerce works or other subject matter are relevant and function properly, that rightholders are adequately protected, that licences are properly publicised and that legal certainty is provided with regard to the representativeness of collective management organisations and the categorisation of works, Member States should foster sector-specific stakeholder dialogue.

(43) The measures provided for in this Directive to facilitate the collective licensing of rights in out-of-commerce works or other subject matter that are permanently in the collections of cultural heritage institutions should be without prejudice to the use of such works or other subject matter under exceptions or limitations provided for in Union law, or under other licences with an extended effect, where such licensing is not based on the out-of-commerce status of the covered works or other subject matter. Those measures should also be without prejudice to national mechanisms for the use of out-of-commerce works or other subject matter based on licences between collective management organisations and users other than cultural heritage institutions.

(44) Mechanisms of collective licensing with an extended effect allow a collective management organisation to offer licences as a collective licensing body on behalf of rightholders, irrespective of whether they have authorised the organisation to do so. Systems built on mechanisms such as extended collective licensing, legal mandates or presumptions of representation, are a well-established practice in several Member States and can be used in different areas. A functioning copyright framework that works for all parties requires the availability of proportionate, legal mechanisms for the licensing of works or other subject matter. Member States should, therefore, be able to rely on solutions allowing collective management organisations to offer licences covering a potentially large number of works or other subject matter for certain types of use, and to distribute the revenue resulting from such licences to rightholders, in accordance with Directive 2014/26/EU.

(45) Given the nature of some uses, together with the usually large amount of works or other subject matter involved, the transaction cost of individual rights clearance with every rightholder concerned is prohibitively high. As a result, it is unlikely that, without effective collective licensing mechanisms, all the transactions in the areas concerned that are required to enable the use of such works or other subject matter would take place. Extended collective licensing by collective management organisations and similar mechanisms can make it possible to conclude agreements in those areas where collective licensing based on an authorisation by rightholders does not provide an exhaustive solution for covering all works or other subject matter to be used. Such mechanisms complement collective management of rights based on individual authorisation by rightholders, by providing full legal certainty to users in certain cases. At the same time, they provide an opportunity to rightholders to benefit from the legitimate use of their works.

(46) Given the increasing importance of the ability to offer flexible licensing schemes in the digital age, and the increasing use of such schemes, Member States should be able to provide for licensing mechanisms which permit collective management organisations to conclude licences, on a voluntary basis, irrespective of whether all rightholders have authorised the organisation concerned to do so. Member States should have the ability to maintain and introduce such mechanisms in accordance with their national traditions, practices or circumstances, subject to the safeguards provided for in this Directive and in compliance with Union law and the international obligations of the Union. Such mechanisms should only have effect in the territory of the Member State concerned, unless otherwise provided for in Union law. Member States should have flexibility in choosing the specific type of mechanism allowing licences for works or other subject matter to extend to the rights of rightholders that have not authorised the organisation that concludes the agreement, provided that such mechanism is in compliance with Union law, including with the rules on collective management of rights provided for in Directive 2014/26/EU. In particular, such mechanisms should also ensure that Article 7 of Directive 2014/26/EU applies to rightholders that are not members of the organisation that concludes the agreement. Such mechanisms could include extended collective licensing, legal mandates and presumptions of representation. The provisions of this Directive concerning collective licensing should not affect the existing ability of Member States to apply mandatory collective management of rights or other collective licensing mechanisms with an extended effect, such as that included in Article 3 of Council Directive 93/83/EEC ([12]).

([12]) Council Directive 93/83/EEC of 27 September 1993 on the coordination of certain rules concerning copyright and rights related to copyright applicable to satellite broadcasting and cable retransmission (OJ L 248, 6.10.1993, p. 15).

(47) It is important that mechanisms of collective licensing with an extended effect are only applied in well-defined areas of use, in which obtaining authorisation from rightholders on an individual basis is typically onerous and impractical to a degree that makes the required licensing transaction, namely one involving a licence that covers all rightholders concerned, unlikely to occur due to the nature of the use or of the types of works or other subject matter concerned. Such mechanisms should be based on objective, transparent and non-discriminatory criteria as regards the treatment of rightholders, including rightholders who are not members of the collective management organisation. In particular, the mere fact that the rightholders affected are not nationals or residents of, or established in, the Member State of the user who is seeking a licence, should not be in itself a reason to consider the clearance of rights to be so onerous and impractical as to justify the use of such mechanisms. It is equally important that the licensed use neither affect adversely the economic value of the relevant rights nor deprive rightholders of significant commercial benefits.

(48) Member States should ensure that appropriate safeguards are in place to protect the legitimate interests of rightholders that have not mandated the organisation offering the licence and that those safeguards apply in a non-discriminatory manner. Specifically, in order to justify the extended effect of the mechanisms, such an organisation should be, on the basis of authorisations from rightholders, sufficiently representative of the types of works or other subject matter and of the rights which are the subject of the licence. Member States should determine the requirements to be satisfied for those organisations to be considered sufficiently representative, taking into account the category of rights managed by the organisation, the ability of the organisation to manage the rights effectively, the creative sector in which it operates, and whether the organisation covers a significant number of rightholders in the relevant type of works or other subject matter who have given a mandate allowing the licensing of the relevant type of use, in accordance with Directive 2014/26/EU. To provide legal certainty and ensure that there is confidence in the mechanisms, Member States should be allowed to decide who is to have legal responsibility as regards uses authorised by the licence agreement. Equal treatment should be guaranteed to all rightholders whose works are exploited under the licence, including in particular as regards access to information on the licensing and the distribution of remuneration. Publicity measures should be effective throughout the duration of the licence and should not involve imposing a disproportionate administrative burden on users, collective management organisations or rightholders, and without the need to inform each rightholder individually.

In order to ensure that rightholders can easily regain control of their works, and prevent any uses of their works that would be prejudicial to their interests, it is essential that rightholders be given an effective opportunity to exclude the application of such mechanisms to their works or other subject matter for all uses and works or other subject matter, or for specific uses and works or other subject matter, including before the conclusion of a licence and during the term of the licence. In such cases, any ongoing use should be terminated within a reasonable period. Such exclusion by rightholders should not affect their claims for remuneration for the actual use of the work or other subject matter under the licence. Member States should also be able to decide that additional measures are appropriate to protect rightholders. Such additional measures could include, for example, encouraging the exchange of information among collective management organisations and other interested parties across the Union to raise awareness about such mechanisms and the option available to rightholders to exclude their works or other subject matter from those mechanisms.

(49) Member States should ensure that the purpose and scope of any licence granted as a result of mechanisms of collective licensing with an extended effect, as well as the possible uses, should always be carefully and clearly defined in law or, if the underlying law is a general provision, in the licensing practices applied as a result of such general provisions, or in the licences granted. The ability to operate a licence under such mechanisms should also be limited to collective management organisations that are subject to national law implementing Directive 2014/26/EU.

(50) Given the different traditions and experiences in relation to mechanisms of collective licensing with an extended effect across Member States, and their applicability to rightholders irrespective of their nationality or their Member State of residence, it is important to ensure that there is transparency and dialogue at Union level about the practical functioning of such mechanisms, including as regards the effectiveness of safeguards for rightholders, the usability of such mechanisms, their effect on rightholders who are not members of the collective management organisation, or on rightholders who are nationals of, or resident in, another Member State, and the

impact on the cross-border provision of services, including the potential need to lay down rules to give such mechanisms cross-border effect within the internal market. To ensure transparency, information about the use of such mechanisms under this Directive should be regularly published by the Commission. Member States that have introduced such mechanisms should, therefore, inform the Commission about relevant national provisions and their application in practice, including the scope and types of licensing introduced on the basis of general provisions, the scale of licensing and the collective management organisations involved. Such information should be discussed with Member States in the contact committee established in Article 12(3) of Directive 2001/29/EC. The Commission should publish a report on the use of such mechanisms in the Union and their impact on licensing and rightholders, on the dissemination of cultural content and on the cross-border provision of services in the area of collective management of copyright and related rights, as well as on the impact on competition.

(51) Video-on-demand services have the potential to play a decisive role in the dissemination of audiovisual works across the Union. However, the availability of such works, in particular European works, on video-on-demand services remains limited. Agreements on the online exploitation of such works can be difficult to conclude due to issues related to the licensing of rights. Such issues could, for instance, arise when the holder of the rights for a given territory has a low economic incentive to exploit a work online and does not license or holds back the online rights, which can lead to audiovisual works being unavailable on video-on-demand services. Other issues could relate to windows of exploitation.

(52) To facilitate the licensing of rights in audiovisual works to video-on-demand services, Member States should be required to provide for a negotiation mechanism allowing parties willing to conclude an agreement to rely on the assistance of an impartial body or of one or more mediators. For that purpose, Member States should be allowed either to establish a new body or rely on an existing one that fulfils the conditions established by this Directive. Member States should be able to designate one or more competent bodies or mediators. The body or the mediators should meet with the parties and help with the negotiations by providing professional, impartial and external advice. Where a negotiation involves parties from different Member States and where those parties decide to rely on the negotiation mechanism, the parties should agree beforehand on the competent Member State. The body or the mediators could meet with the parties to facilitate the start of negotiations or in the course of the negotiations to facilitate the conclusion of an agreement. Participation in that negotiation mechanism and the subsequent conclusion of agreements should be voluntary and should not affect the parties' contractual freedom. Member States should be free to decide on the specific functioning of the negotiation mechanism, including the timing and duration of the assistance to negotiations and the bearing of the costs. Member States should ensure that administrative and financial burdens remain proportionate to guarantee the efficiency of the negotiation mechanism. Without it being an obligation for them, Member States should encourage dialogue between representative organisations.

(53) The expiry of the term of protection of a work entails the entry of that work into the public domain and the expiry of the rights that Union copyright law provides in relation to that work. In the field of visual arts, the circulation of faithful reproductions of works in the public domain contributes to the access to and promotion of culture, and the access to cultural heritage. In the digital environment, the protection of such reproductions through copyright or related rights is inconsistent with the expiry of the copyright protection of works. In addition, differences between the national copyright laws governing the protection of such reproductions give rise to legal uncertainty and affect the cross-border dissemination of works of visual arts in the public domain. Certain reproductions of works of visual arts in the public domain should, therefore, not be protected by copyright or related rights. All of that should not prevent cultural heritage institutions from selling reproductions, such as postcards.

(54) A free and pluralist press is essential to ensure quality journalism and citizens' access to information. It provides a fundamental contribution to public debate and the proper functioning of a democratic society. The wide availability of press publications online has given rise to the emergence of new online services, such as news aggregators or media monitoring services, for which the reuse of press publications constitutes an important part of their business models and a source of revenue. Publishers of press publications are facing problems in

licensing the online use of their publications to the providers of those kinds of services, making it more difficult for them to recoup their investments. In the absence of recognition of publishers of press publications as rightholders, the licensing and enforcement of rights in press publications regarding online uses by information society service providers in the digital environment are often complex and inefficient.

(55) The organisational and financial contribution of publishers in producing press publications needs to be recognised and further encouraged to ensure the sustainability of the publishing industry and thereby foster the availability of reliable information. It is therefore necessary to provide at Union level for harmonised legal protection for press publications in respect of online uses by information society service providers, which leaves the existing copyright rules in Union law applicable to private or non-commercial uses of press publications by individual users unaffected, including where such users share press publications online. Such protection should be effectively guaranteed through the introduction, in Union law, of rights related to copyright for the reproduction and making available to the public of press publications of publishers established in a Member State in respect of online uses by information society service providers within the meaning of Directive (EU) 2015/1535 of the European Parliament and of the Council ([13]). The legal protection for press publications provided for by this Directive should benefit publishers that are established in a Member State and have their registered office, central administration or principal place of business within the Union.

The concept of publisher of press publications should be understood as covering service providers, such as news publishers or news agencies, when they publish press publications within the meaning of this Directive.

(56) For the purposes of this Directive, it is necessary to define the concept of 'press publication' so that it only covers journalistic publications, published in any media, including on paper, in the context of an economic activity that constitutes a provision of services under Union law. The press publications that should be covered include, for instance, daily newspapers, weekly or monthly magazines of general or special interest, including subscription-based magazines, and news websites. Press publications contain mostly literary works, but increasingly include other types of works and other subject matter, in particular photographs and videos. Periodical publications published for scientific or academic purposes, such as scientific journals, should not be covered by the protection granted to press publications under this Directive. Neither should that protection apply to websites, such as blogs, that provide information as part of an activity that is not carried out under the initiative, editorial responsibility and control of a service provider, such as a news publisher.

(57) The rights granted to the publishers of press publications under this Directive should have the same scope as the rights of reproduction and making available to the public provided for in Directive 2001/29/EC, insofar as online uses by information society service providers are concerned. The rights granted to publishers of press publications should not extend to acts of hyperlinking. They should also not extend to mere facts reported in press publications. The rights granted to publishers of press publications under this Directive should also be subject to the same provisions on exceptions and limitations as those applicable to the rights provided for in Directive 2001/29/EC, including the exception in the case of quotations for purposes such as criticism or review provided for in Article 5(3)(d) of that Directive.

(58) The use of press publications by information society service providers can consist of the use of entire publications or articles but also of parts of press publications. Such uses of parts of press publications have also gained economic relevance. At the same time, the use of individual words or very short extracts of press publications by information society service providers may not undermine the investments made by publishers of press publications in the production of content. Therefore, it is appropriate to provide that the use of individual words or very short extracts of press publications should not fall within the scope of the rights provided for in this Directive. Taking into account the massive aggregation and use of press publications by information society service providers, it is important that the exclusion of very short extracts be interpreted in such a way as not to affect the effectiveness of the rights provided for in this Directive.

([13]) Directive (EU) 2015/1535 of the European Parliament and of the Council of 9 September 2015 laying down a procedure for the provision of information in the field of technical regulations and of rules on Information Society services (OJ L 241, 17.9.2015, p. 1).

(59) The protection granted to publishers of press publications under this Directive should not affect the rights of the authors and other rightholders in the works and other subject matter incorporated therein, including as regards the extent to which authors and other rightholders can exploit their works or other subject matter independently from the press publication in which they are incorporated. Publishers of press publications should, therefore, not be able to invoke the protection granted to them under this Directive against authors and other rightholders or against other authorised users of the same works or other subject matter. That should be without prejudice to contractual arrangements concluded between the publishers of press publications, on the one hand, and authors and other rightholders, on the other. Authors whose works are incorporated in a press publication should be entitled to an appropriate share of the revenues that press publishers receive for the use of their press publications by information society service providers. That should be without prejudice to national laws on ownership or exercise of rights in the context of employment contracts, provided that such laws are in compliance with Union law.

(60) Publishers, including those of press publications, books or scientific publications and music publications, often operate on the basis of the transfer of authors' rights by means of contractual agreements or statutory provisions. In that context, publishers make an investment with a view to the exploitation of the works contained in their publications and can in some instances be deprived of revenues where such works are used under exceptions or limitations such as those for private copying and reprography, including the corresponding existing national schemes for reprography in the Member States, or under public lending schemes. In several Member States, compensation for uses under those exceptions or limitations is shared between authors and publishers. In order to take account of this situation and to improve legal certainty for all parties concerned, this Directive allows Member States that have existing schemes for the sharing of compensation between authors and publishers to maintain them. That is particularly important for Member States that had such compensation-sharing mechanisms before 12 November 2015, although in other Member States compensation is not shared and is due solely to authors in accordance with national cultural policies. While this Directive should apply in a non-discriminatory way to all Member States, it should respect the traditions in this area and not oblige Member States that do not currently have such compensation-sharing schemes to introduce them. It should not affect existing or future arrangements in Member States regarding remuneration in the context of public lending.

It should also leave national arrangements relating to the management of rights and to remuneration rights unaffected, provided that they are in compliance with Union law. All Member States should be allowed but not obliged to provide that, where authors have transferred or licensed their rights to a publisher or otherwise contribute with their works to a publication, and there are systems in place to compensate for the harm caused to them by an exception or limitation, including through collective management organisations that jointly represent authors and publishers, publishers are entitled to a share of such compensation. Member States should remain free to determine how publishers are to substantiate their claims for compensation or remuneration, and to lay down the conditions for the sharing of such compensation or remuneration between authors and publishers in accordance with their national systems.

(61) In recent years, the functioning of the online content market has gained in complexity. Online content-sharing services providing access to a large amount of copyright-protected content uploaded by their users have become a main source of access to content online. Online services are a means of providing wider access to cultural and creative works and offer great opportunities for cultural and creative industries to develop new business models. However, although they enable diversity and ease of access to content, they also generate challenges when copyright-protected content is uploaded without prior authorisation from rightholders. Legal uncertainty exists as to whether the providers of such services engage in copyright-relevant acts, and need to obtain authorisation from rightholders for content uploaded by their users who do not hold the relevant rights in the uploaded content, without prejudice to the application of exceptions and limitations provided for in Union law. That uncertainty affects the ability of rightholders to determine whether, and under which conditions, their works and other subject matter are used, as well as their ability to obtain appropriate remuneration for such use. It is therefore important to foster the development of the licensing market between rightholders and online content-sharing service providers. Those licensing agreements should be fair and keep a reasonable balance

between both parties. Rightholders should receive appropriate remuneration for the use of their works or other subject matter. However, as contractual freedom should not be affected by those provisions, rightholders should not be obliged to give an authorisation or to conclude licensing agreements.

(62) Certain information society services, as part of their normal use, are designed to give access to the public to copyright-protected content or other subject matter uploaded by their users. The definition of an online content-sharing service provider laid down in this Directive should target only online services that play an important role on the online content market by competing with other online content services, such as online audio and video streaming services, for the same audiences. The services covered by this Directive are services, the main or one of the main purposes of which is to store and enable users to upload and share a large amount of copyright-protected content with the purpose of obtaining profit therefrom, either directly or indirectly, by organising it and promoting it in order to attract a larger audience, including by categorising it and using targeted promotion within it. Such services should not include services that have a main purpose other than that of enabling users to upload and share a large amount of copyright-protected content with the purpose of obtaining profit from that activity. The latter services include, for instance, electronic communication services within the meaning of Directive (EU) 2018/1972 of the European Parliament and of the Council ([14]), as well as providers of business-to-business cloud services and cloud services, which allow users to upload content for their own use, such as cyberlockers, or online marketplaces the main activity of which is online retail, and not giving access to copyright-protected content.

Providers of services such as open source software development and sharing platforms, not-for-profit scientific or educational repositories as well as not-for-profit online encyclopedias should also be excluded from the definition of online content-sharing service provider. Finally, in order to ensure a high level of copyright protection, the liability exemption mechanism provided for in this Directive should not apply to service providers the main purpose of which is to engage in or to facilitate copyright piracy.

(63) The assessment of whether an online content-sharing service provider stores and gives access to a large amount of copyright-protected content should be made on a case-by-case basis and should take account of a combination of elements, such as the audience of the service and the number of files of copyright-protected content uploaded by the users of the service.

(64) It is appropriate to clarify in this Directive that online content-sharing service providers perform an act of communication to the public or of making available to the public when they give the public access to copyright-protected works or other protected subject matter uploaded by their users. Consequently, online content-sharing service providers should obtain an authorisation, including via a licensing agreement, from the relevant rightholders. This does not affect the concept of communication to the public or of making available to the public elsewhere under Union law, nor does it affect the possible application of Article 3(1) and (2) of Directive 2001/29/EC to other service providers using copyright-protected content.

(65) When online content-sharing service providers are liable for acts of communication to the public or making available to the public under the conditions laid down in this Directive, Article 14(1) of Directive 2000/31/EC should not apply to the liability arising from the provision of this Directive on the use of protected content by online content-sharing service providers. That should not affect the application of Article 14(1) of Directive 2000/31/EC to such service providers for purposes falling outside the scope of this Directive.

(66) Taking into account the fact that online content-sharing service providers give access to content which is not uploaded by them but by their users, it is appropriate to provide for a specific liability mechanism for the purposes of this Directive for cases in which no authorisation has been granted. That should be without prejudice

([14]) Directive (EU) 2018/1972 of the European Parliament and of the Council of 11 December 2018 establishing the European Electronic Communications Code (OJ L 321, 17.12.2018, p. 36).

to remedies under national law for cases other than liability for copyright infringements and to national courts or administrative authorities being able to issue injunctions in compliance with Union law. In particular, the specific regime applicable to new online content-sharing service providers with an annual turnover below EUR 10 million, of which the average number of monthly unique visitors in the Union does not exceed 5 million, should not affect the availability of remedies under Union and national law. Where no authorisation has been granted to service providers, they should make their best efforts in accordance with high industry standards of professional diligence to avoid the availability on their services of unauthorised works and other subject matter, as identified by the relevant rightholders. For that purpose, rightholders should provide the service providers with relevant and necessary information taking into account, among other factors, the size of rightholders and the type of their works and other subject matter. The steps taken by online content-sharing service providers in cooperation with rightholders should not lead to the prevention of the availability of non-infringing content, including works or other protected subject matter the use of which is covered by a licensing agreement, or an exception or limitation to copyright and related rights. Steps taken by such service providers should, therefore, not affect users who are using the online content-sharing services in order to lawfully upload and access information on such services.

In addition, the obligations established in this Directive should not lead to Member States imposing a general monitoring obligation. When assessing whether an online content-sharing service provider has made its best efforts in accordance with the high industry standards of professional diligence, account should be taken of whether the service provider has taken all the steps that would be taken by a diligent operator to achieve the result of preventing the availability of unauthorised works or other subject matter on its website, taking into account best industry practices and the effectiveness of the steps taken in light of all relevant factors and developments, as well as the principle of proportionality. For the purposes of that assessment, a number of elements should be considered, such as the size of the service, the evolving state of the art as regards existing means, including potential future developments, to avoid the availability of different types of content and the cost of such means for the services. Different means to avoid the availability of unauthorised copyright-protected content could be appropriate and proportionate depending on the type of content, and, therefore, it cannot be excluded that in some cases availability of unauthorised content can only be avoided upon notification of rightholders. Any steps taken by service providers should be effective with regard to the objectives pursued but should not go beyond what is necessary to achieve the objective of avoiding and discontinuing the availability of unauthorised works and other subject matter.

If unauthorised works and other subject matter become available despite the best efforts made in cooperation with rightholders, as required by this Directive, the online content-sharing service providers should be liable in relation to the specific works and other subject matter for which they have received the relevant and necessary information from rightholders, unless those providers demonstrate that they have made their best efforts in accordance with high industry standards of professional diligence.

In addition, where specific unauthorised works or other subject matter have become available on online content-sharing services, including irrespective of whether the best efforts were made and regardless of whether rightholders have made available the relevant and necessary information in advance, the online content-sharing service providers should be liable for unauthorised acts of communication to the public of works or other subject matter, when, upon receiving a sufficiently substantiated notice, they fail to act expeditiously to disable access to, or to remove from their websites, the notified works or other subject matter. Additionally, such online content-sharing service providers should also be liable if they fail to demonstrate that they have made their best efforts to prevent the future uploading of specific unauthorised works, based on relevant and necessary information provided by rightholders for that purpose.

Where rightholders do not provide online content-sharing service providers with the relevant and necessary information on their specific works or other subject matter, or where no notification concerning the disabling of access to, or the removal of, specific unauthorised works or other subject matter has been provided by rightholders, and, as a result, those service providers cannot make their best efforts to avoid the availability of

unauthorised content on their services, in accordance with high industry standards of professional diligence, such service providers should not be liable for unauthorised acts of communication to the public or of making available to the public of such unidentified works or other subject matter.

(67) Similar to Article 16(2) of Directive 2014/26/EU, this Directive provides for rules as regards new online services. The rules provided for in this Directive are intended to take into account the specific case of start-up companies working with user uploads to develop new business models. The specific regime applicable to new service providers with a small turnover and audience should benefit genuinely new businesses, and should therefore cease to apply three years after their services first became available online in the Union. That regime should not be abused by arrangements aimed at extending its benefits beyond the first three years. In particular, it should not apply to newly created services or to services provided under a new name but which pursue the activity of an already existing online content-sharing service provider which could not benefit or no longer benefits from that regime.

(68) Online content-sharing service providers should be transparent with rightholders with regard to the steps taken in the context of cooperation. As various actions could be undertaken by online content-sharing service providers, they should provide rightholders, at the request of rightholders, with adequate information on the type of actions undertaken and the way in which they are undertaken. Such information should be sufficiently specific to provide enough transparency to rightholders, without affecting business secrets of online content-sharing service providers. Service providers should, however, not be required to provide rightholders with detailed and individualised information for each work or other subject matter identified. That should be without prejudice to contractual arrangements, which could contain more specific provisions on the information to be provided where agreements are concluded between service providers and rightholders.

(69) Where online content-sharing service providers obtain authorisations, including through licensing agreements, for the use on their service of content uploaded by the users of the service, those authorisations should also cover the copyright relevant acts in respect of uploads by users within the scope of the authorisation granted to the service providers, but only in cases where those users act for non-commercial purposes, such as sharing their content without any profit-making purpose, or where the revenue generated by their uploads is not significant in relation to the copyright relevant acts of the users covered by such authorisations. Where rightholders have explicitly authorised users to upload and make available works or other subject matter on an online content-sharing service, the act of communication to the public of the service provider is authorised within the scope of the authorisation granted by the rightholder. However, there should be no presumption in favour of online content-sharing service providers that their users have cleared all relevant rights.

(70) The steps taken by online content-sharing service providers in cooperation with rightholders should be without prejudice to the application of exceptions or limitations to copyright, including, in particular, those which guarantee the freedom of expression of users. Users should be allowed to upload and make available content generated by users for the specific purposes of quotation, criticism, review, caricature, parody or pastiche. That is particularly important for the purposes of striking a balance between the fundamental rights laid down in the Charter of Fundamental Rights of the European Union ('the Charter'), in particular the freedom of expression and the freedom of the arts, and the right to property, including intellectual property. Those exceptions and limitations should, therefore, be made mandatory in order to ensure that users receive uniform protection across the Union. It is important to ensure that online content-sharing service providers operate an effective complaint and redress mechanism to support use for such specific purposes.

Online content-sharing service providers should also put in place effective and expeditious complaint and redress mechanisms allowing users to complain about the steps taken with regard to their uploads, in particular where they could benefit from an exception or limitation to copyright in relation to an upload to which access has been disabled or that has been removed. Any complaint filed under such mechanisms should be processed without

undue delay and be subject to human review. When rightholders request the service providers to take action against uploads by users, such as disabling access to or removing content uploaded, such rightholders should duly justify their requests. Moreover, cooperation should not lead to any identification of individual users nor to the processing of personal data, except in accordance with Directive 2002/58/EC of the European Parliament and of the Council ([15]) and Regulation (EU) 2016/679 of the European Parliament and of the Council ([16]). Member States should also ensure that users have access to out-of-court redress mechanisms for the settlement of disputes. Such mechanisms should allow disputes to be settled impartially. Users should also have access to a court or another relevant judicial authority to assert the use of an exception or limitation to copyright and related rights.

(71) As soon as possible after the date of entry into force of this Directive, the Commission, in cooperation with Member States, should organise dialogues between stakeholders to ensure uniform application of the obligation of cooperation between online content-sharing service providers and rightholders and to establish best practices with regard to the appropriate industry standards of professional diligence. For that purpose, the Commission should consult relevant stakeholders, including users' organisations and technology providers, and take into account developments on the market. Users' organisations should also have access to information on actions carried out by online content-sharing service providers to manage content online.

(72) Authors and performers tend to be in the weaker contractual position when they grant a licence or transfer their rights, including through their own companies, for the purposes of exploitation in return for remuneration, and those natural persons need the protection provided for by this Directive to be able to fully benefit from the rights harmonised under Union law. That need for protection does not arise where the contractual counterpart acts as an end user and does not exploit the work or performance itself, which could, for instance, be the case in some employment contracts.

(73) The remuneration of authors and performers should be appropriate and proportionate to the actual or potential economic value of the licensed or transferred rights, taking into account the author's or performer's contribution to the overall work or other subject matter and all other circumstances of the case, such as market practices or the actual exploitation of the work. A lump sum payment can also constitute proportionate remuneration but it should not be the rule. Member States should have the freedom to define specific cases for the application of lump sums, taking into account the specificities of each sector. Member States should be free to implement the principle of appropriate and proportionate remuneration through different existing or newly introduced mechanisms, which could include collective bargaining and other mechanisms, provided that such mechanisms are in conformity with applicable Union law.

(74) Authors and performers need information to assess the economic value of rights of theirs that are harmonised under Union law. This is especially the case where natural persons grant a licence or a transfer of rights for the purposes of exploitation in return for remuneration. That need does not arise where the exploitation has ceased, or where the author or performer has granted a licence to the general public without remuneration.

(75) As authors and performers tend to be in the weaker contractual position when they grant licences or transfer their rights, they need information to assess the continued economic value of their rights, compared to the remuneration received for their licence or transfer, but they often face a lack of transparency. Therefore, the sharing of adequate and accurate information by their contractual counterparts or their successors in title is important for the transparency and balance in the system governing the remuneration of authors and

([15]) Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector (Directive on privacy and electronic communications) (OJ L 201, 31.7.2002, p. 37).

([16]) Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ L 119, 4.5.2016, p. 1).

performers. That information should be up-to-date to allow access to recent data, relevant to the exploitation of the work or performance, and comprehensive in a way that it covers all sources of revenues relevant to the case, including, where applicable, merchandising revenues. As long as exploitation is ongoing, contractual counterparts of authors and performers should provide information available to them on all modes of exploitation and on all relevant revenues worldwide with a regularity that is appropriate in the relevant sector, but at least annually. The information should be provided in a manner that is comprehensible to the author or performer and it should allow the effective assessment of the economic value of the rights in question. The transparency obligation should nevertheless apply only where copyright relevant rights are concerned. The processing of personal data, such as contact details and information on remuneration, that are necessary to keep authors and performers informed in relation to the exploitation of their works and performances, should be carried out in accordance with Article 6(1)(c) of Regulation (EU) 2016/679.

(76) In order to ensure that exploitation-related information is duly provided to authors and performers also in cases where the rights have been sub-licensed to other parties who exploit the rights, this Directive entitles authors and performers to request additional relevant information on the exploitation of the rights, in cases where the first contractual counterpart has provided the information available to them, but that information is not sufficient to assess the economic value of their rights. That request should be made either directly to sub-licensees or through the contractual counterparts of authors and performers. Authors and performers, and their contractual counterparts, should be able to agree to keep the shared information confidential, but authors and performers should always be able to use the shared information for the purpose of exercising their rights under this Directive. Member States should have the option, in compliance with Union law, to provide for further measures to ensure transparency for authors and performers.

(77) When implementing the transparency obligation provided for in this Directive, Member States should take into account the specificities of different content sectors, such as those of the music sector, the audiovisual sector and the publishing sector, and all relevant stakeholders should be involved when deciding on such sector-specific obligations. Where relevant, the significance of the contribution of authors and performers to the overall work or performance should also be considered. Collective bargaining should be considered as an option for the relevant stakeholders to reach an agreement regarding transparency. Such agreements should ensure that authors and performers have the same level of transparency as or a higher level of transparency than the minimum requirements provided for in this Directive. To enable the adaptation of existing reporting practices to the transparency obligation, a transitional period should be provided for. It should not be necessary to apply the transparency obligation in respect of agreements concluded between rightholders and collective management organisations, independent management entities or other entities subject to the national rules implementing Directive 2014/26/EU, as those organisations or entities are already subject to transparency obligations under Article 18 of Directive 2014/26/EU. Article 18 of Directive 2014/26/EU applies to organisations that manage copyright or related rights on behalf of more than one rightholder for the collective benefit of those rightholders. However, individually negotiated agreements concluded between rightholders and those of their contractual counterparts who act in their own interest should be subject to the transparency obligation provided for in this Directive.

(78) Certain contracts for the exploitation of rights harmonised at Union level are of long duration, offering few opportunities for authors and performers to renegotiate them with their contractual counterparts or their successors in title in the event that the economic value of the rights turns out to be significantly higher than initially estimated. Accordingly, without prejudice to the law applicable to contracts in Member States, a remuneration adjustment mechanism should be provided for as regards cases where the remuneration originally agreed under a licence or a transfer of rights clearly becomes disproportionately low compared to the relevant revenues derived from the subsequent exploitation of the work or fixation of the performance by the contractual counterpart of the author or performer. All revenues relevant to the case in question, including, where applicable, merchandising revenues, should be taken into account for the assessment of whether the remuneration is disproportionately low. The assessment of the situation should take account of the specific circumstances of each case, including the contribution of the author or performer, as well as of the specificities and remuneration practices in the different content sectors, and whether the contract is based on a collective bargaining agreement. Representatives of authors and performers duly mandated in accordance with national law in compliance with Union law, should be able to provide assistance to one or more authors or performers in relation to requests for the adjustment of the contracts, also taking into account the interests of other authors or performers where relevant.

Those representatives should protect the identity of the represented authors and performers for as long as that is possible. Where the parties do not agree on the adjustment of the remuneration, the author or performer should be entitled to bring a claim before a court or other competent authority. Such mechanism should not apply to contracts concluded by entities defined in Article 3(a) and (b) of Directive 2014/26/EU or by other entities subject to national rules implementing Directive 2014/26/EU.

(79) Authors and performers are often reluctant to enforce their rights against their contractual partners before a court or tribunal. Member States should therefore provide for an alternative dispute resolution procedure that addresses claims by authors and performers, or by their representatives on their behalf, related to obligations of transparency and the contract adjustment mechanism. For that purpose, Member States should be able to either establish a new body or mechanism, or rely on an existing one that fulfils the conditions established by this Directive, irrespective of whether those bodies or mechanisms are industry-led or public, including when part of the national judiciary system. Member States should have flexibility in deciding how the costs of the dispute resolution procedure are to be allocated. Such alternative dispute resolution procedure should be without prejudice to the right of parties to assert and defend their rights by bringing an action before a court.

(80) When authors and performers license or transfer their rights, they expect their work or performance to be exploited. However, it could be the case that works or performances that have been licensed or transferred are not exploited at all. Where those rights have been transferred on an exclusive basis, authors and performers cannot turn to another partner to exploit their works or performances. In such a case, and after a reasonable period of time has elapsed, authors and performers should be able to benefit from a mechanism for the revocation of rights allowing them to transfer or license their rights to another person. As exploitation of works or performances can vary depending on the sectors, specific provisions could be laid down at national level in order to take into account the specificities of the sectors, such as the audiovisual sector, or of the works or performances, in particular providing for time frames for the right of revocation. In order to protect the legitimate interests of licensees and transferees of rights and to prevent abuses, and taking into account that a certain amount of time is needed before a work or performance is actually exploited, authors and performers should be able to exercise the right of revocation in accordance with certain procedural requirements and only after a certain period of time following the conclusion of the licence or of the transfer agreement. Member States should be allowed to regulate the exercise of the right of revocation in the case of works or performances involving more than one author or performer, taking into account the relative importance of the individual contributions.

(81) The provisions regarding transparency, contract adjustment mechanisms and alternative dispute resolution procedures laid down in this Directive should be of a mandatory nature, and parties should not be able to derogate from those provisions, whether in contracts between authors, performers and their contractual counterparts, or in agreements between those counterparts and third parties, such as non-disclosure agreements. As a consequence, Article 3(4) of Regulation (EC) No 593/2008 of the European Parliament and of the Council ([17]) should apply to the effect that, where all other elements relevant to the situation at the time of the choice of applicable law are located in one or more Member States, the parties' choice of applicable law other than that of a Member State does not prejudice the application of the provisions regarding transparency, contract adjustment mechanisms and alternative dispute resolution procedures laid down in this Directive, as implemented in the Member State of the forum.

(82) Nothing in this Directive should be interpreted as preventing holders of exclusive rights under Union copyright law from authorising the use of their works or other subject matter for free, including through non-exclusive free licences for the benefit of any users.

(83) Since the objective of this Directive, namely the modernisation of certain aspects of the Union copyright framework to take account of technological developments and new channels of distribution of protected content in the internal market, cannot be sufficiently achieved by Member States but can rather, by reason of their scale, effects and cross-border dimension, be better achieved at Union level, the Union may adopt measures in

([17]) Regulation (EC) No 593/2008 of the European Parliament and of the Council of 17 June 2008 on the law applicable to contractual obligations (Rome I) (OJ L 177, 4.7.2008, p. 6).

accordance with the principle of subsidiarity as set out in Article 5 TEU. In accordance with the principle of proportionality, as set out in that Article, this Directive does not go beyond what is necessary in order to achieve that objective.

(84) This Directive respects the fundamental rights and observes the principles recognised in particular by the Charter. Accordingly, this Directive should be interpreted and applied in accordance with those rights and principles.

(85) Any processing of personal data under this Directive should respect fundamental rights, including the right to respect for private and family life and the right to protection of personal data set out in Articles 7 and 8, respectively, of the Charter and must be in compliance with Directive 2002/58/EC and Regulation (EU) 2016/679.

(86) In accordance with the Joint Political Declaration of 28 September 2011 of Member States and the Commission on explanatory documents ([18]), Member States have undertaken to accompany, in justified cases, the notification of their transposition measures with one or more documents explaining the relationship between the components of a directive and the corresponding parts of national transposition instruments. With regard to this Directive, the legislator considers the transmission of such documents to be justified,

HAVE ADOPTED THIS DIRECTIVE:

TITLE I

GENERAL PROVISIONS

Article 1

Subject matter and scope

1. This Directive lays down rules which aim to harmonise further Union law applicable to copyright and related rights in the framework of the internal market, taking into account, in particular, digital and cross-border uses of protected content. It also lays down rules on exceptions and limitations to copyright and related rights, on the facilitation of licences, as well as rules which aim to ensure a well-functioning marketplace for the exploitation of works and other subject matter.

2. Except in the cases referred to in Article 24, this Directive shall leave intact and shall in no way affect existing rules laid down in the directives currently in force in this area, in particular Directives 96/9/EC, 2000/31/EC, 2001/29/EC, 2006/115/EC, 2009/24/EC, 2012/28/EU and 2014/26/EU.

Article 2

Definitions

For the purposes of this Directive, the following definitions apply:

(1) 'research organisation' means a university, including its libraries, a research institute or any other entity, the primary goal of which is to conduct scientific research or to carry out educational activities involving also the conduct of scientific research:

(a) on a not-for-profit basis or by reinvesting all the profits in its scientific research; or

(b) pursuant to a public interest mission recognised by a Member State;

in such a way that the access to the results generated by such scientific research cannot be enjoyed on a preferential basis by an undertaking that exercises a decisive influence upon such organisation;

(2) 'text and data mining' means any automated analytical technique aimed at analysing text and data in digital form in order to generate information which includes but is not limited to patterns, trends and correlations;

(3) 'cultural heritage institution' means a publicly accessible library or museum, an archive or a film or audio heritage institution;

([18]) OJ C 369, 17.12.2011, p. 14.

(4) 'press publication' means a collection composed mainly of literary works of a journalistic nature, but which can also include other works or other subject matter, and which:

(a) constitutes an individual item within a periodical or regularly updated publication under a single title, such as a newspaper or a general or special interest magazine;

(b) has the purpose of providing the general public with information related to news or other topics; and

(c) is published in any media under the initiative, editorial responsibility and control of a service provider.

Periodicals that are published for scientific or academic purposes, such as scientific journals, are not press publications for the purposes of this Directive;

(5) 'information society service' means a service within the meaning of point (b) of Article 1(1) of Directive (EU) 2015/1535;

(6) 'online content-sharing service provider' means a provider of an information society service of which the main or one of the main purposes is to store and give the public access to a large amount of copyright-protected works or other protected subject matter uploaded by its users, which it organises and promotes for profit-making purposes.

Providers of services, such as not-for-profit online encyclopedias, not-for-profit educational and scientific repositories, open source software-developing and-sharing platforms, providers of electronic communications services as defined in Directive (EU) 2018/1972, online marketplaces, business-to-business cloud services and cloud services that allow users to upload content for their own use, are not 'online content-sharing service providers' within the meaning of this Directive.

TITLE II

MEASURES TO ADAPT EXCEPTIONS AND LIMITATIONS TO THE DIGITAL AND CROSS-BORDER ENVIRONMENT

Article 3

Text and data mining for the purposes of scientific research

1. Member States shall provide for an exception to the rights provided for in Article 5(a) and Article 7(1) of Directive 96/9/EC, Article 2 of Directive 2001/29/EC, and Article 15(1) of this Directive for reproductions and extractions made by research organisations and cultural heritage institutions in order to carry out, for the purposes of scientific research, text and data mining of works or other subject matter to which they have lawful access.

2. Copies of works or other subject matter made in compliance with paragraph 1 shall be stored with an appropriate level of security and may be retained for the purposes of scientific research, including for the verification of research results.

3. Rightholders shall be allowed to apply measures to ensure the security and integrity of the networks and databases where the works or other subject matter are hosted. Such measures shall not go beyond what is necessary to achieve that objective.

4. Member States shall encourage rightholders, research organisations and cultural heritage institutions to define commonly agreed best practices concerning the application of the obligation and of the measures referred to in paragraphs 2 and 3 respectively.

Article 4

Exception or limitation for text and data mining

1. Member States shall provide for an exception or limitation to the rights provided for in Article 5(a) and Article 7(1) of Directive 96/9/EC, Article 2 of Directive 2001/29/EC, Article 4(1)(a) and (b) of Directive 2009/24/EC and Article 15(1) of this Directive for reproductions and extractions of lawfully accessible works and other subject matter for the purposes of text and data mining.

2. Reproductions and extractions made pursuant to paragraph 1 may be retained for as long as is necessary for the purposes of text and data mining.

3. The exception or limitation provided for in paragraph 1 shall apply on condition that the use of works and other subject matter referred to in that paragraph has not been expressly reserved by their rightholders in an appropriate manner, such as machine-readable means in the case of content made publicly available online.

4. This Article shall not affect the application of Article 3 of this Directive.

Article 5

Use of works and other subject matter in digital and cross-border teaching activities

1. Member States shall provide for an exception or limitation to the rights provided for in Article 5(a), (b), (d) and (e) and Article 7(1) of Directive 96/9/EC, Articles 2 and 3 of Directive 2001/29/EC, Article 4(1) of Directive 2009/24/EC and Article 15(1) of this Directive in order to allow the digital use of works and other subject matter for the sole purpose of illustration for teaching, to the extent justified by the non-commercial purpose to be achieved, on condition that such use:

(a) takes place under the responsibility of an educational establishment, on its premises or at other venues, or through a secure electronic environment accessible only by the educational establishment's pupils or students and teaching staff; and

(b) is accompanied by the indication of the source, including the author's name, unless this turns out to be impossible.

2. Notwithstanding Article 7(1), Member States may provide that the exception or limitation adopted pursuant to paragraph 1 does not apply or does not apply as regards specific uses or types of works or other subject matter, such as material that is primarily intended for the educational market or sheet music, to the extent that suitable licences authorising the acts referred to in paragraph 1 of this Article and covering the needs and specificities of educational establishments are easily available on the market.

Member States that decide to avail of the first subparagraph of this paragraph shall take the necessary measures to ensure that the licences authorising the acts referred to in paragraph 1 of this Article are available and visible in an appropriate manner for educational establishments.

3. The use of works and other subject matter for the sole purpose of illustration for teaching through secure electronic environments undertaken in compliance with the provisions of national law adopted pursuant to this Article shall be deemed to occur solely in the Member State where the educational establishment is established.

4. Member States may provide for fair compensation for rightholders for the use of their works or other subject matter pursuant to paragraph 1.

Article 6

Preservation of cultural heritage

Member States shall provide for an exception to the rights provided for in Article 5(a) and Article 7(1) of Directive 96/9/EC, Article 2 of Directive 2001/29/EC, Article 4(1)(a) of Directive 2009/24/EC and Article 15(1) of this Directive, in order to allow cultural heritage institutions to make copies of any works or other subject matter that are permanently in their collections, in any format or medium, for purposes of preservation of such works or other subject matter and to the extent necessary for such preservation.

Article 7

Common provisions

1. Any contractual provision contrary to the exceptions provided for in Articles 3, 5 and 6 shall be unenforceable.

2. Article 5(5) of Directive 2001/29/EC shall apply to the exceptions and limitations provided for under this Title. The first, third and fifth subparagraphs of Article 6(4) of Directive 2001/29/EC shall apply to Articles 3 to 6 of this Directive.

TITLE III

MEASURES TO IMPROVE LICENSING PRACTICES AND ENSURE WIDER ACCESS TO CONTENT

CHAPTER 1

Out-of-commerce works and other subject matter

Article 8

Use of out-of-commerce works and other subject matter by cultural heritage institutions

1. Member States shall provide that a collective management organisation, in accordance with its mandates from rightholders, may conclude a non-exclusive licence for non-commercial purposes with a cultural heritage institution for the reproduction, distribution, communication to the public or making available to the public of out-of-commerce works or other subject matter that are permanently in the collection of the institution, irrespective of whether all rightholders covered by the licence have mandated the collective management organisation, on condition that:

(a) the collective management organisation is, on the basis of its mandates, sufficiently representative of rightholders in the relevant type of works or other subject matter and of the rights that are the subject of the licence; and

(b) all rightholders are guaranteed equal treatment in relation to the terms of the licence.

2. Member States shall provide for an exception or limitation to the rights provided for in Article 5(a), (b), (d) and (e) and Article 7(1) of Directive 96/9/EC, Articles 2 and 3 of Directive 2001/29/EC, Article 4(1) of Directive 2009/24/EC, and Article 15(1) of this Directive, in order to allow cultural heritage institutions to make available, for non-commercial purposes, out-of-commerce works or other subject matter that are permanently in their collections, on condition that:

(a) the name of the author or any other identifiable rightholder is indicated, unless this turns out to be impossible; and

(b) such works or other subject matter are made available on non-commercial websites.

3. Member States shall provide that the exception or limitation provided for in paragraph 2 only applies to types of works or other subject matter for which no collective management organisation that fulfils the condition set out in point (a) of paragraph 1 exists.

4. Member States shall provide that all rightholders may, at any time, easily and effectively, exclude their works or other subject matter from the licensing mechanism set out in paragraph 1 or from the application of the exception or limitation provided for in paragraph 2, either in general or in specific cases, including after the conclusion of a licence or after the beginning of the use concerned.

5. A work or other subject matter shall be deemed to be out of commerce when it can be presumed in good faith that the whole work or other subject matter is not available to the public through customary channels of commerce, after a reasonable effort has been made to determine whether it is available to the public.

Member States may provide for specific requirements, such as a cut-off date, to determine whether works and other subject matter can be licensed in accordance with paragraph 1 or used under the exception or limitation provided for in paragraph 2. Such requirements shall not extend beyond what is necessary and reasonable, and shall not preclude being able to determine that a set of works or other subject matter as a whole is out of commerce, when it is reasonable to presume that all works or other subject matter are out of commerce.

6. Member States shall provide that the licences referred to in paragraph 1 are to be sought from a collective management organisation that is representative for the Member State where the cultural heritage institution is established.

7. This Article shall not apply to sets of out-of-commerce works or other subject matter if, on the basis of the reasonable effort referred to in paragraph 5, there is evidence that such sets predominantly consist of:

(a) works or other subject matter, other than cinematographic or audiovisual works, first published or, in the absence of publication, first broadcast in a third country;

(b) cinematographic or audiovisual works, of which the producers have their headquarters or habitual residence in a third country; or

(c) works or other subject matter of third country nationals, where after a reasonable effort no Member State or third country could be determined pursuant to points (a) and (b).

By way of derogation from the first subparagraph, this Article shall apply where the collective management organisation is sufficiently representative, within the meaning of point (a) of paragraph 1, of rightholders of the relevant third country.

Article 9

Cross-border uses

1. Member States shall ensure that licences granted in accordance with Article 8 may allow the use of out-of-commerce works or other subject matter by cultural heritage institutions in any Member State.

2. The uses of works and other subject matter under the exception or limitation provided for in Article 8(2) shall be deemed to occur solely in the Member State where the cultural heritage institution undertaking that use is established.

Article 10

Publicity measures

1. Member States shall ensure that information from cultural heritage institutions, collective management organisations or relevant public authorities, for the purposes of the identification of the out-of-commerce works or other subject matter, covered by a licence granted in accordance with Article 8(1), or used under the exception or limitation provided for in Article 8(2), as well as information about the options available to rightholders as referred to in Article 8(4), and, as soon as it is available and where relevant, information on the parties to the licence, the territories covered and the uses, is made permanently, easily and effectively accessible on a public single online portal from at least six months before the works or other subject matter are distributed, communicated to the public or made available to the public in accordance with the licence or under the exception or limitation.

The portal shall be established and managed by the European Union Intellectual Property Office in accordance with Regulation (EU) No 386/2012.

2. Member States shall provide that, if necessary for the general awareness of rightholders, additional appropriate publicity measures are taken regarding the ability of collective management organisations to license works or other subject matter in accordance with Article 8, the licences granted, the uses under the exception or limitation provided for in Article 8(2) and the options available to rightholders as referred to in Article 8(4).

The appropriate publicity measures referred to in the first subparagraph of this paragraph shall be taken in the Member State where the licence is sought in accordance with Article 8(1) or, for uses under the exception or limitation provided for in Article 8(2), in the Member State where the cultural heritage institution is established. If there is evidence, such as the origin of the works or other subject matter, to suggest that the awareness of rightholders could be more efficiently raised in other Member States or third countries, such publicity measures shall also cover those Member States and third countries.

Article 11

Stakeholder dialogue

Member States shall consult rightholders, collective management organisations and cultural heritage institutions in each sector before establishing specific requirements pursuant to Article 8(5), and shall encourage regular dialogue between representative users' and rightholders' organisations, including collective management organisations, and any other relevant stakeholder organisations, on a sector-specific basis, to foster the relevance and usability of the licensing mechanisms set out in Article 8(1) and to ensure that the safeguards for rightholders referred to in this Chapter are effective.

CHAPTER 2

Measures to facilitate collective licensing

Article 12

Collective licensing with an extended effect

1. Member States may provide, as far as the use on their territory is concerned and subject to the safeguards provided for in this Article, that where a collective management organisation that is subject to the national rules implementing Directive 2014/26/EU, in accordance with its mandates from rightholders, enters into a licensing agreement for the exploitation of works or other subject matter:

(a) such an agreement can be extended to apply to the rights of rightholders who have not authorised that collective management organisation to represent them by way of assignment, licence or any other contractual arrangement; or

(b) with respect to such an agreement, the organisation has a legal mandate or is presumed to represent rightholders who have not authorised the organisation accordingly.

2. Member States shall ensure that the licensing mechanism referred to in paragraph 1 is only applied within well-defined areas of use, where obtaining authorisations from rightholders on an individual basis is typically onerous and impractical to a degree that makes the required licensing transaction unlikely, due to the nature of the use or of the types of works or other subject matter concerned, and shall ensure that such licensing mechanism safeguards the legitimate interests of rightholders.

3. For the purposes of paragraph 1, Member States shall provide for the following safeguards:

(a) the collective management organisation is, on the basis of its mandates, sufficiently representative of rightholders in the relevant type of works or other subject matter and of the rights which are the subject of the licence, for the relevant Member State;

(b) all rightholders are guaranteed equal treatment, including in relation to the terms of the licence;

(c) rightholders who have not authorised the organisation granting the licence may at any time easily and effectively exclude their works or other subject matter from the licensing mechanism established in accordance with this Article; and

(d) appropriate publicity measures are taken, starting from a reasonable period before the works or other subject matter are used under the licence, to inform rightholders about the ability of the collective management organisation to license works or other subject matter, about the licensing taking place in accordance with this Article and about the options available to rightholders as referred to in point (c). Publicity measures shall be effective without the need to inform each rightholder individually.

4. This Article does not affect the application of collective licensing mechanisms with an extended effect in accordance with other provisions of Union law, including provisions that allow exceptions or limitations.

This Article shall not apply to mandatory collective management of rights.

Article 7 of Directive 2014/26/EU shall apply to the licensing mechanism provided for in this Article.

5. Where a Member State provides in its national law for a licensing mechanism in accordance with this Article, that Member State shall inform the Commission about the scope of the corresponding national provisions, about the purposes and types of licences that may be introduced under those provisions, about the contact details of organisations issuing licences in accordance with that licensing mechanism, and about the means by which information on the licensing and on the options available to rightholders as referred to in point (c) of paragraph 3 can be obtained. The Commission shall publish that information.

6. Based on the information received pursuant to paragraph 5 of this Article and on the discussions within the contact committee established in Article 12(3) of Directive 2001/29/EC, the Commission shall, by 10 April 2021, submit to the European Parliament and to the Council a report on the use in the Union of the licensing mechanisms referred to in paragraph 1 of this Article, their impact on licensing and rightholders, including rightholders who are not members of the organisation granting the licences or who are nationals of, or resident in, another Member State, their effectiveness in facilitating the dissemination of cultural content, and their impact on the internal market, including the cross-border provision of services and competition. That report shall be accompanied, if appropriate, by a legislative proposal, including as regards the cross-border effect of such national mechanisms.

CHAPTER 3

Access to and availability of audiovisual works on video-on-demand platforms

Article 13

Negotiation mechanism

Member States shall ensure that parties facing difficulties related to the licensing of rights when seeking to conclude an agreement for the purpose of making available audiovisual works on video-on-demand services may rely on the assistance of an impartial body or of mediators. The impartial body established or designated by a Member State for the purpose of this Article and mediators shall provide assistance to the parties with their negotiations and help the parties reach agreements, including, where appropriate, by submitting proposals to them.

Member States shall notify the Commission of the body or mediators referred to in the first paragraph no later than 7 June 2021. Where Member States have chosen to rely on mediation, the notification to the Commission shall at least include, when available, the source where relevant information on the mediators entrusted can be found.

CHAPTER 4

Works of visual art in the public domain

Article 14

Works of visual art in the public domain

Member States shall provide that, when the term of protection of a work of visual art has expired, any material resulting from an act of reproduction of that work is not subject to copyright or related rights, unless the material resulting from that act of reproduction is original in the sense that it is the author's own intellectual creation.

TITLE IV

MEASURES TO ACHIEVE A WELL-FUNCTIONING MARKETPLACE FOR COPYRIGHT

CHAPTER 1

Rights in publications

Article 15

Protection of press publications concerning online uses

1. Member States shall provide publishers of press publications established in a Member State with the rights provided for in Article 2 and Article 3(2) of Directive 2001/29/EC for the online use of their press publications by information society service providers.

The rights provided for in the first subparagraph shall not apply to private or non-commercial uses of press publications by individual users.

The protection granted under the first subparagraph shall not apply to acts of hyperlinking.

The rights provided for in the first subparagraph shall not apply in respect of the use of individual words or very short extracts of a press publication.

2. The rights provided for in paragraph 1 shall leave intact and shall in no way affect any rights provided for in Union law to authors and other rightholders, in respect of the works and other subject matter incorporated in a press publication. The rights provided for in paragraph 1 shall not be invoked against those authors and other rightholders and, in particular, shall not deprive them of their right to exploit their works and other subject matter independently from the press publication in which they are incorporated.

When a work or other subject matter is incorporated in a press publication on the basis of a non-exclusive licence, the rights provided for in paragraph 1 shall not be invoked to prohibit the use by other authorised users. The rights provided for in paragraph 1 shall not be invoked to prohibit the use of works or other subject matter for which protection has expired.

3. Articles 5 to 8 of Directive 2001/29/EC, Directive 2012/28/EU and Directive (EU) 2017/1564 of the European Parliament of the Council ([19]) shall apply mutatis mutandis in respect of the rights provided for in paragraph 1 of this Article.

4. The rights provided for in paragraph 1 shall expire two years after the press publication is published. That term shall be calculated from 1 January of the year following the date on which that press publication is published.

Paragraph 1 shall not apply to press publications first published before 6 June 2019.

5. Member States shall provide that authors of works incorporated in a press publication receive an appropriate share of the revenues that press publishers receive for the use of their press publications by information society service providers.

Article 16

Claims to fair compensation

Member States may provide that where an author has transferred or licensed a right to a publisher, such a transfer or licence constitutes a sufficient legal basis for the publisher to be entitled to a share of the compensation for the use of the work made under an exception or limitation to the transferred or licensed right.

The first paragraph shall be without prejudice to existing and future arrangements in Member States concerning public lending rights.

CHAPTER 2

Certain uses of protected content by online services

Article 17

Use of protected content by online content-sharing service providers

1. Member States shall provide that an online content-sharing service provider performs an act of communication to the public or an act of making available to the public for the purposes of this Directive when it gives the public access to copyright-protected works or other protected subject matter uploaded by its users.

An online content-sharing service provider shall therefore obtain an authorisation from the rightholders referred to in Article 3(1) and (2) of Directive 2001/29/EC, for instance by concluding a licensing agreement, in order to communicate to the public or make available to the public works or other subject matter.

2. Member States shall provide that, where an online content-sharing service provider obtains an authorisation, for instance by concluding a licensing agreement, that authorisation shall also cover acts carried out by users of the services falling within the scope of Article 3 of Directive 2001/29/EC when they are not acting on a commercial basis or where their activity does not generate significant revenues.

3. When an online content-sharing service provider performs an act of communication to the public or an act of making available to the public under the conditions laid down in this Directive, the limitation of liability established in Article 14(1) of Directive 2000/31/EC shall not apply to the situations covered by this Article.

([19]) Directive (EU) 2017/1564 of the European Parliament and of the Council of 13 September 2017 on certain permitted uses of certain works and other subject matter protected by copyright and related rights for the benefit of persons who are blind, visually impaired or otherwise print-disabled and amending Directive 2001/29/EC on the harmonisation of certain aspects of copyright and related rights in the information society (OJ L 242, 20.9.2017, p. 6).

The first subparagraph of this paragraph shall not affect the possible application of Article 14(1) of Directive 2000/31/EC to those service providers for purposes falling outside the scope of this Directive.

4. If no authorisation is granted, online content-sharing service providers shall be liable for unauthorised acts of communication to the public, including making available to the public, of copyright-protected works and other subject matter, unless the service providers demonstrate that they have:

(a) made best efforts to obtain an authorisation, and

(b) made, in accordance with high industry standards of professional diligence, best efforts to ensure the unavailability of specific works and other subject matter for which the rightholders have provided the service providers with the relevant and necessary information; and in any event

(c) acted expeditiously, upon receiving a sufficiently substantiated notice from the rightholders, to disable access to, or to remove from their websites, the notified works or other subject matter, and made best efforts to prevent their future uploads in accordance with point (b).

5. In determining whether the service provider has complied with its obligations under paragraph 4, and in light of the principle of proportionality, the following elements, among others, shall be taken into account:

(a) the type, the audience and the size of the service and the type of works or other subject matter uploaded by the users of the service; and

(b) the availability of suitable and effective means and their cost for service providers.

6. Member States shall provide that, in respect of new online content-sharing service providers the services of which have been available to the public in the Union for less than three years and which have an annual turnover below EUR 10 million, calculated in accordance with Commission Recommendation 2003/361/EC ([20]), the conditions under the liability regime set out in paragraph 4 are limited to compliance with point (a) of paragraph 4 and to acting expeditiously, upon receiving a sufficiently substantiated notice, to disable access to the notified works or other subject matter or to remove those works or other subject matter from their websites.

Where the average number of monthly unique visitors of such service providers exceeds 5 million, calculated on the basis of the previous calendar year, they shall also demonstrate that they have made best efforts to prevent further uploads of the notified works and other subject matter for which the rightholders have provided relevant and necessary information.

7. The cooperation between online content-sharing service providers and rightholders shall not result in the prevention of the availability of works or other subject matter uploaded by users, which do not infringe copyright and related rights, including where such works or other subject matter are covered by an exception or limitation.

Member States shall ensure that users in each Member State are able to rely on any of the following existing exceptions or limitations when uploading and making available content generated by users on online content-sharing services:

(a) quotation, criticism, review;

(b) use for the purpose of caricature, parody or pastiche.

8. The application of this Article shall not lead to any general monitoring obligation.

Member States shall provide that online content-sharing service providers provide rightholders, at their request, with adequate information on the functioning of their practices with regard to the cooperation referred to in paragraph 4 and, where licensing agreements are concluded between service providers and rightholders, information on the use of content covered by the agreements.

9. Member States shall provide that online content-sharing service providers put in place an effective and expeditious complaint and redress mechanism that is available to users of their services in the event of disputes over the disabling of access to, or the removal of, works or other subject matter uploaded by them.

([20]) Commission Recommendation of 6 May 2003 concerning the definition of micro, small and medium-sized enterprises (OJ L 124, 20.5.2003, p. 36).

Where rightholders request to have access to their specific works or other subject matter disabled or to have those works or other subject matter removed, they shall duly justify the reasons for their requests. Complaints submitted under the mechanism provided for in the first subparagraph shall be processed without undue delay, and decisions to disable access to or remove uploaded content shall be subject to human review. Member States shall also ensure that out-of-court redress mechanisms are available for the settlement of disputes. Such mechanisms shall enable disputes to be settled impartially and shall not deprive the user of the legal protection afforded by national law, without prejudice to the rights of users to have recourse to efficient judicial remedies. In particular, Member States shall ensure that users have access to a court or another relevant judicial authority to assert the use of an exception or limitation to copyright and related rights.

This Directive shall in no way affect legitimate uses, such as uses under exceptions or limitations provided for in Union law, and shall not lead to any identification of individual users nor to the processing of personal data, except in accordance with Directive 2002/58/EC and Regulation (EU) 2016/679.

Online content-sharing service providers shall inform their users in their terms and conditions that they can use works and other subject matter under exceptions or limitations to copyright and related rights provided for in Union law.

10. As of 6 June 2019 the Commission, in cooperation with the Member States, shall organise stakeholder dialogues to discuss best practices for cooperation between online content-sharing service providers and rightholders. The Commission shall, in consultation with online content-sharing service providers, rightholders, users' organisations and other relevant stakeholders, and taking into account the results of the stakeholder dialogues, issue guidance on the application of this Article, in particular regarding the cooperation referred to in paragraph 4. When discussing best practices, special account shall be taken, among other things, of the need to balance fundamental rights and of the use of exceptions and limitations. For the purpose of the stakeholder dialogues, users' organisations shall have access to adequate information from online content-sharing service providers on the functioning of their practices with regard to paragraph 4.

CHAPTER 3

Fair remuneration in exploitation contracts of authors and performers

Article 18

Principle of appropriate and proportionate remuneration

1. Member States shall ensure that where authors and performers license or transfer their exclusive rights for the exploitation of their works or other subject matter, they are entitled to receive appropriate and proportionate remuneration.

2. In the implementation in national law of the principle set out in paragraph 1, Member States shall be free to use different mechanisms and take into account the principle of contractual freedom and a fair balance of rights and interests.

Article 19

Transparency obligation

1. Member States shall ensure that authors and performers receive on a regular basis, at least once a year, and taking into account the specificities of each sector, up to date, relevant and comprehensive information on the exploitation of their works and performances from the parties to whom they have licensed or transferred their rights, or their successors in title, in particular as regards modes of exploitation, all revenues generated and remuneration due.

2. Member States shall ensure that, where the rights referred to in paragraph 1 have subsequently been licensed, authors and performers or their representatives shall, at their request, receive from sub-licensees additional information, in the event that their first contractual counterpart does not hold all the information that would be necessary for the purposes of paragraph 1.

Where that additional information is requested, the first contractual counterpart of authors and performers shall provide information on the identity of those sub-licensees.

Member States may provide that any request to sub-licensees pursuant to the first subparagraph is made directly or indirectly through the contractual counterpart of the author or the performer.

3. The obligation set out in paragraph 1 shall be proportionate and effective in ensuring a high level of transparency in every sector. Member States may provide that in duly justified cases where the administrative burden resulting from the obligation set out in paragraph 1 would become disproportionate in the light of the revenues generated by the exploitation of the work or performance, the obligation is limited to the types and level of information that can reasonably be expected in such cases.

4. Member States may decide that the obligation set out in paragraph 1 of this Article does not apply when the contribution of the author or performer is not significant having regard to the overall work or performance, unless the author or performer demonstrates that he or she requires the information for the exercise of his or her rights under Article 20(1) and requests the information for that purpose.

5. Member States may provide that, for agreements subject to or based on collective bargaining agreements, the transparency rules of the relevant collective bargaining agreement are applicable, on condition that those rules meet the criteria provided for in paragraphs 1 to 4.

6. Where Article 18 of Directive 2014/26/EU is applicable, the obligation laid down in paragraph 1 of this Article shall not apply in respect of agreements concluded by entities defined in Article 3(a) and (b) of that Directive or by other entities subject to the national rules implementing that Directive.

Article 20

Contract adjustment mechanism

1. Member States shall ensure that, in the absence of an applicable collective bargaining agreement providing for a mechanism comparable to that set out in this Article, authors and performers or their representatives are entitled to claim additional, appropriate and fair remuneration from the party with whom they entered into a contract for the exploitation of their rights, or from the successors in title of such party, when the remuneration originally agreed turns out to be disproportionately low compared to all the subsequent relevant revenues derived from the exploitation of the works or performances.

2. Paragraph 1 of this Article shall not apply to agreements concluded by entities defined in Article 3(a) and (b) of Directive 2014/26/EU or by other entities that are already subject to the national rules implementing that Directive.

Article 21

Alternative dispute resolution procedure

Member States shall provide that disputes concerning the transparency obligation under Article 19 and the contract adjustment mechanism under Article 20 may be submitted to a voluntary, alternative dispute resolution procedure. Member States shall ensure that representative organisations of authors and performers may initiate such procedures at the specific request of one or more authors or performers.

Article 22

Right of revocation

1. Member States shall ensure that where an author or a performer has licensed or transferred his or her rights in a work or other protected subject matter on an exclusive basis, the author or performer may revoke in whole or in part the licence or the transfer of rights where there is a lack of exploitation of that work or other protected subject matter.

2. Specific provisions for the revocation mechanism provided for in paragraph 1 may be provided for in national law, taking into account the following:

(a) the specificities of the different sectors and the different types of works and performances; and

(b) where a work or other subject matter contains the contribution of more than one author or performer, the relative importance of the individual contributions, and the legitimate interests of all authors and performers affected by the application of the revocation mechanism by an individual author or performer.

Member States may exclude works or other subject matter from the application of the revocation mechanism if such works or other subject matter usually contain contributions of a plurality of authors or performers.

Member States may provide that the revocation mechanism can only apply within a specific time frame, where such restriction is duly justified by the specificities of the sector or of the type of work or other subject matter concerned.

Member States may provide that authors or performers can choose to terminate the exclusivity of the contract instead of revoking the licence or transfer of the rights.

3. Member States shall provide that the revocation provided for in paragraph 1 may only be exercised after a reasonable time following the conclusion of the licence or the transfer of the rights. The author or performer shall notify the person to whom the rights have been licensed or transferred and set an appropriate deadline by which the exploitation of the licensed or transferred rights is to take place. After the expiry of that deadline, the author or performer may choose to terminate the exclusivity of the contract instead of revoking the licence or the transfer of the rights.

4. Paragraph 1 shall not apply if the lack of exploitation is predominantly due to circumstances that the author or the performer can reasonably be expected to remedy.

5. Member States may provide that any contractual provision derogating from the revocation mechanism provided for in paragraph 1 is enforceable only if it is based on a collective bargaining agreement.

Article 23

Common provisions

1. Member States shall ensure that any contractual provision that prevents compliance with Articles 19, 20 and 21 shall be unenforceable in relation to authors and performers.

2. Members States shall provide that Articles 18 to 22 of this Directive do not apply to authors of a computer program within the meaning of Article 2 of Directive 2009/24/EC.

TITLE V

FINAL PROVISIONS

Article 24

Amendments to Directives 96/9/EC and 2001/29/EC

1. Directive 96/9/EC is amended as follows:

(a) In Article 6(2), point (b) is replaced by the following:

'(b) where there is use for the sole purpose of illustration for teaching or scientific research, as long as the source is indicated and to the extent justified by the non-commercial purpose to be achieved, without prejudice to the exceptions and limitations provided for in Directive (EU) 2019/790 of the European Parliament and of the Council (*);

(*) Directive (EU) 2019/790 of the European Parliament and of the Council of 17 April 2019 on copyright and related rights in the Digital Single Market and amending Directives 96/9/EC and 2001/29/EC (OJ L 130, 17.5.2019, p. 92).'.

(b) In Article 9, point (b) is replaced by the following:

'(b) in the case of extraction for the purposes of illustration for teaching or scientific research, as long as the source is indicated and to the extent justified by the non-commercial purpose to be achieved, without prejudice to the exceptions and limitations provided for in Directive (EU) 2019/790;'.

2. Directive 2001/29/EC is amended as follows:

(a) In Article 5(2), point (c) is replaced by the following:

'(c) in respect of specific acts of reproduction made by publicly accessible libraries, educational establishments or museums, or by archives, which are not for direct or indirect economic or commercial advantage, without prejudice to the exceptions and limitations provided for in Directive (EU) 2019/790 of the European Parliament and of the Council (*);

(*) Directive (EU) 2019/790 of the European Parliament and of the Council of 17 April 2019 on copyright and related rights in the Digital Single Market and amending Directives 96/9/EC and 2001/29/EC (OJ L 130, 17.5.2019, p. 92).'.

(b) In Article 5(3), point (a) is replaced by the following:

'(a) use for the sole purpose of illustration for teaching or scientific research, as long as the source, including the author's name, is indicated, unless this turns out to be impossible and to the extent justified by the non-commercial purpose to be achieved, without prejudice to the exceptions and limitations provided for in Directive (EU) 2019/790;'.

(c) In Article 12(4), the following points are added:

'(e) to examine the impact of the transposition of Directive (EU) 2019/790 on the functioning of the internal market and to highlight any transposition difficulties;

(f) to facilitate the exchange of information on relevant developments in legislation and case law as well as on the practical application of the measures taken by Member States to implement Directive (EU) 2019/790;

(g) to discuss any other questions arising from the application of Directive (EU) 2019/790.'.

Article 25

Relationship with exceptions and limitations provided for in other directives

Member States may adopt or maintain in force broader provisions, compatible with the exceptions and limitations provided for in Directives 96/9/EC and 2001/29/EC, for uses or fields covered by the exceptions or limitations provided for in this Directive.

Article 26

Application in time

1. This Directive shall apply in respect of all works and other subject matter that are protected by national law in the field of copyright on or after 7 June 2021.

2. This Directive shall apply without prejudice to any acts concluded and rights acquired before 7 June 2021.

Article 27

Transitional provision

Agreements for the licence or transfer of rights of authors and performers shall be subject to the transparency obligation set out in Article 19 as from 7 June 2022.

Article 28

Protection of personal data

The processing of personal data carried out within the framework of this Directive shall be carried out in compliance with Directive 2002/58/EC and Regulation (EU) 2016/679.

Article 29

Transposition

1. Member States shall bring into force the laws, regulations and administrative provisions necessary to comply with this Directive by 7 June 2021. They shall immediately inform the Commission thereof.

When Member States adopt those provisions, they shall contain a reference to this Directive or be accompanied by such a reference on the occasion of their official publication. The methods of making such reference shall be laid down by Member States.

2. Member States shall communicate to the Commission the text of the main provisions of national law which they adopt in the field covered by this Directive.

Article 30

Review

1. No sooner than 7 June 2026, the Commission shall carry out a review of this Directive and present a report on the main findings to the European Parliament, the Council and the European Economic and Social Committee.

The Commission shall, by 7 June 2024, assess the impact of the specific liability regime set out in Article 17 applicable to online content-sharing service providers that have an annual turnover of less than EUR 10 million and the services of which have been available to the public in the Union for less than three years under Article 17(6) and, if appropriate, take action in accordance with the conclusions of its assessment.

2. Member States shall provide the Commission with the necessary information for the preparation of the report referred to in paragraph 1.

Article 31

Entry into force

This Directive shall enter into force on the twentieth day following that of its publication in the *Official Journal of the European Union*.

Article 32

Addressees

This Directive is addressed to the Member States.

Done at Strasbourg, 17 April 2019.

For the European Parliament	*For the Council*
The President	*The President*
A. TAJANI	G. CIAMBA

Décrets, arrêtés, circulaires

TEXTES GÉNÉRAUX

MINISTÈRE DE L'ÉCONOMIE, DES FINANCES ET DE LA SOUVERAINETÉ INDUSTRIELLE ET NUMÉRIQUE

Ordonnance n° 2025-880 du 3 septembre 2025 relative au crédit à la consommation

NOR : *ECOT2515537R*

Publics concernés : *prêteurs, intermédiaires de crédit, consommateurs et autorités de contrôle et de supervision.*

Objet : *transposition de la directive (UE) 2023/2225 du Parlement européen et du Conseil du 18 octobre 2023 relative aux contrats de crédit aux consommateurs et abrogeant la directive 2008/48/ CE.*

Entrée en vigueur : *les dispositions de la présente ordonnance entrent en vigueur le 20 novembre 2026.*

Application : *la présente ordonnance porte les mesures de coordination et d'adaptation relevant du domaine de la loi pour transposer la directive (UE) 2023/2225 du Parlement européen et du Conseil du 18 octobre 2023 relative aux contrats de crédit aux consommateurs et abrogeant la directive 2008/48/CE.*

Le Président de la République,

Sur le rapport du Premier ministre et du ministre de l'économie, des finances et de la souveraineté industrielle et numérique,

Vu la Constitution, notamment son article 38 ;

Vu la directive (UE) 2023/2225 du Parlement européen et du Conseil du 18 octobre 2023 relative aux contrats de crédit aux consommateurs et abrogeant la directive 2008/48/CE ;

Vu le code de commerce, notamment son article L. 230-1 ;

Vu le code de la consommation ;

Vu le code de justice administrative, notamment son article R. 123-20 ;

Vu le code monétaire et financier ;

Vu la loi n° 78-17 du 6 janvier 1978 modifiée relative à l'informatique, les fichiers et la liberté, notamment son article 6 ;

Vu la loi n° 2025-391 du 30 avril 2025 portant diverses dispositions d'adaptation au droit de l'Union européenne en matière économique, financière, environnementale, énergétique, de transport, de santé et de circulation des personnes, notamment son article 2 ;

Vu les avis du Comité consultatif de la législation et de la réglementation financières en date des 22 mai et 16 juillet 2025 ;

Le Conseil d'Etat (section des finances) entendu ;

Le conseil des ministres entendu,

Ordonne :

TITRE Ier

DISPOSITIONS MODIFIANT LE LIVRE II, LE LIVRE III ET LE LIVRE VII DU CODE DE LA CONSOMMATION

Article 1er

Les dispositions des livres II, III et VII du code de la consommation sont modifiées conformément aux dispositions des articles 2 à 85 de la présente ordonnance.

Chapitre Ier

DÉFINITIONS

Article 2

L'article L. 311-1 est ainsi modifié :

1° Au 6°, les mots : « délai de paiement » sont remplacés par les mots : « paiement différé » ;

2° Il est complété par trois alinéas ainsi rédigés :

« 17° Services de conseil, la fourniture à l'emprunteur de recommandations personnalisées en ce qui concerne un ou plusieurs contrats de crédit et qui constitue une activité distincte de l'octroi de crédit et de l'activité d'intermédiation ;

« 18° Services de conseil aux personnes endettées, une aide personnalisée, de nature technique, juridique ou psychologique en faveur d'emprunteurs qui ont ou pourraient avoir des difficultés à respecter leurs engagements financiers, apportée par des professionnels indépendants qui ne sont pas des prêteurs, des intermédiaires de crédit, des acheteurs de crédits ou des gestionnaires de crédits au sens des 3° et 4° de l'article L. 54-11-1 du code monétaire et financier ;

« 19° Remboursement anticipé, l'acquittement, intégral ou partiel, par l'emprunteur des obligations qui lui incombent en vertu d'un contrat de crédit, avant la date convenue pour son terme. »

Article 3

L'article L. 313-13 est ainsi modifié :

1° Le premier alinéa est complété par une phrase ainsi rédigée : « Il formule à son endroit une recommandation personnalisée. » ;

2° Le deuxième alinéa est supprimé.

Chapitre II

CHAMP D'APPLICATION

Article 4

L'article L. 312-1 est ainsi modifié :

1° Les mots : « égal ou supérieur à 200 euros et » sont supprimés ;

2° Le montant : « 75 000 euros » est remplacé par le montant : « 100 000 euros ».

Article 5

L'article L. 312-4 est ainsi modifié :

1° Au 3° :

a) Les mots : « inférieur à 200 euros ou » sont supprimés ;

b) Le montant : « 75 000 euros » est remplacé par le montant : « 100 000 euros » ;

2° Le 4° et le 5° sont remplacés par huit alinéas ainsi rédigés :

« 4° Les paiements différés accordés par un fournisseur de biens ou un prestataire de services, sauf lorsqu'il est une grande entreprise au sens du 4° de l'article L. 230-1 du code de commerce et que la conclusion du contrat a lieu à distance par voie électronique, s'ils répondent aux conditions cumulatives suivantes :

« *a)* Le paiement est entièrement exécuté dans un délai de cinquante jours à compter de la fourniture de biens ou de la prestation de services ;

« *b)* Le règlement du prix d'achat est sans intérêts et ne peut comporter que des frais limités dus par le consommateur en cas de retard de paiement ;

« *c)* Aucun tiers n'offre au consommateur un crédit pour le paiement du bien ou du service fourni ;

« 5° Les paiements différés accordés pour la conclusion de contrats à distance par voie électronique pour la vente de biens ou la prestation de services par des fournisseurs de biens ou des prestataires de services qui sont des grandes entreprises au sens du 4° de l'article L. 230-1 du code de commerce, s'ils répondent aux conditions cumulatives suivantes :

« *a)* Le paiement est entièrement exécuté dans un délai de quatorze jours à compter de la fourniture de biens ou de la prestation de services ;

« *b)* Le règlement du prix d'achat est sans intérêts et ne peut comporter que des frais limités dus par le consommateur en cas de retard de paiement ;

« *c)* Aucun tiers n'offre un crédit au consommateur pour le paiement du bien ou du service fourni ; »

3° L'article est complété par un alinéa ainsi rédigé :

« 12° Les contrats de crédit accordés à un nombre restreint d'emprunteurs en vertu d'une disposition législative ou réglementaire et à un taux d'intérêt débiteur inférieur à celui pratiqué sur le marché, sans intérêts ou à d'autres conditions plus favorables à l'emprunteur que celles en vigueur sur le marché. »

Article 6

Après l'article L. 312-4, il est ajouté un article L. 312-4-1 ainsi rédigé :

« *Art. L. 312-4-1.* – Les 4°, 5° et 6° de l'article L. 312-6, le IV de l'article L. 312-16, l'article L. 312-17 et les articles L. 312-48 à L. 312-53 ne s'appliquent pas, d'une part, aux opérations de crédit comportant un délai de remboursement ne dépassant pas trois mois et qui ne sont assorties d'aucun intérêt ni d'aucun frais ou qui sont assorties d'intérêts et de frais d'un montant négligeable et, d'autre part, aux opérations de crédit dont le montant total de crédit est inférieur à 200 euros.

« Les 4°, 5° et 6° de l'article L. 312-6 ne s'appliquent pas aux opérations comportant un délai de remboursement supérieur à trois mois et qui ne sont assorties d'aucun intérêt ni d'aucun frais. »

Article 7

A la seconde phrase du premier alinéa de l'article L. 314-6, le montant : « 75 000 euros » est remplacé par le montant : « 100 000 euros ».

Chapitre III

publicité

Article 8

L'article L. 312-5 est remplacé par les dispositions suivantes :

« *Art. L. 312-5.* – Toute publicité qui porte sur l'une des opérations mentionnées à l'article L. 312-1, quel qu'en soit le support, est claire, loyale et non trompeuse. Elle contient, quel que soit le support utilisé, la mention suivante : "Attention ! Un crédit coûte de l'argent et doit être remboursé". »

Article 9

L'article L. 312-6 est ainsi modifié :

1° Au premier alinéa, les mots : « précise et visible » sont remplacés par les mots : « précise, visible ou le cas échéant audible, » ;

2° Au 1° et au 3°, les mots : « , sauf pour les opérations de location-vente ou de location avec option d'achat, » sont supprimés ;

3° Au 5°, les mots : « délai de paiement » sont remplacés par les mots : « paiement différé » ;

4° Au début du 6°, sont ajoutés les mots suivants : « S'il y a lieu » ;

5° Après le 6°, sont insérés deux alinéas ainsi rédigés :

« Ces informations sont adaptées aux contraintes techniques du support utilisé.

« Lorsque le support électronique utilisé pour communiquer les informations visées au présent article ne permet pas d'afficher ces informations de manière visible et claire, l'emprunteur peut accéder aux informations visées au 5° et au 6° en cliquant, en faisant défiler ou en balayant l'écran. Dans le cas des publicités radiodiffusées, les informations visées au 5° et au 6° ne sont pas requises. »

Article 10

L'article L. 312-10 est ainsi modifié :

1° Au début de l'article L. 312-10, il est ajouté un alinéa ainsi rédigé :

« Les communications publicitaires et commerciales susceptibles de faire naître chez l'emprunteur de fausses attentes concernant la disponibilité, le coût du crédit ou encore le montant total dû sont interdites. » ;

2° Au début du troisième alinéa, il est ajouté une phrase ainsi rédigée : « Il est interdit dans toute publicité de mettre en avant la facilité d'obtention d'un crédit. »

Chapitre IV

informations générales

Article 11

Après l'article L. 312-11, il est inséré une section 2 *bis* ainsi rédigée :

« Section 2 bis

« Informations générales

« *Art. L. 312-11-1.* – Le prêteur ou, le cas échéant, l'intermédiaire de crédit assure gratuitement la disponibilité permanente, soit sur support papier, soit au moyen d'un autre support durable choisi par le consommateur, des informations générales, claires et compréhensibles sur les contrats de crédit relevant du chapitre II du livre III. Lorsque les informations générales sur les contrats de crédit sont mises à disposition des consommateurs, dans leurs locaux, par les prêteurs ou, le cas échéant, par les intermédiaires de crédit, elles le sont au moins sur support papier.

« Un décret en Conseil d'Etat précise les conditions d'application du présent article, notamment la liste et le contenu de ces informations générales. »

Chapitre V

INFORMATIONS PRÉCONTRACTUELLES

Article 12

L'article L. 312-12 est ainsi modifié :

1° Au premier alinéa :

a) Après la première occurrence du mot : « emprunteur », sont insérés les mots : « en temps utile » ;

b) Après la première occurrence du mot : « informations, », est inséré le mot : « soit » ;

c) La seconde occurrence du mot : « ou » est remplacée par le mot : « soit » ;

d) Après le mot : « durable », sont insérés les mots : « choisi par l'emprunteur » ;

e) Après la seconde occurrence du mot : « informations », sont insérés les mots : « claires et compréhensibles, » ;

f) Le mot : « clairement » est supprimé ;

2° Après le troisième alinéa, sont insérés deux alinéas ainsi rédigés :

« La présentation de ces informations tient compte des contraintes techniques du support au moyen duquel elles sont communiquées.

« Lorsque ces informations sont fournies moins d'un jour avant que l'emprunteur soit lié par un contrat ou une offre de crédit, le prêteur ou, le cas échéant, l'intermédiaire de crédit envoie un rappel à l'emprunteur l'informant de la possibilité qu'il a de se rétracter du contrat de crédit et lui indiquant la procédure à suivre à cet effet. Ce rappel est adressé à l'emprunteur, soit sur support papier soit au moyen d'un autre support durable choisi par celui-ci, entre un et sept jours après la conclusion du contrat de crédit. »

Article 13

L'article L. 312-13 est complété par l'alinéa suivant :

« Lorsqu'une offre de contrat est personnalisée au moyen d'un traitement automatisé de données à caractère personnel, le prêteur ou l'intermédiaire de crédit en informe l'emprunteur de manière claire et compréhensible. »

Chapitre VI

CONSENTEMENT, SERVICES DE CONSEIL ET OCTROI NON SOLLICITÉ D'UN CRÉDIT

Article 14

A l'intitulé de la section 4 du chapitre II du titre Ier du livre III, les mots : « et évaluation de sa solvabilité » sont remplacés par les mots : « , services de conseil et devoir de mise en garde ».

Article 15

Le premier alinéa de l'article L. 312-14 est remplacé par six alinéas ainsi rédigés :

« Le prêteur ou l'intermédiaire de crédit fournit gratuitement à l'emprunteur les explications lui permettant de déterminer si le contrat de crédit et les éventuels services accessoires proposés sont adaptés à ses besoins et à sa situation financière.

« Ces explications comprennent :

« 1° Les informations contenues dans la fiche mentionnée à l'article L. 312-12 et, le cas échéant, celles mentionnées à l'article L. 322-4 ;

« 2° Les caractéristiques essentielles du ou des contrats de crédit et des éventuels services accessoires proposés ;

« 3° Les conséquences que le ou les contrats de crédit et les éventuels services accessoires proposés peuvent avoir sur sa situation financière, y compris les conséquences en cas de retard ou de défaut de paiement ;

« 4° S'agissant des éventuels services accessoires au contrat de crédit, la possibilité ou non de résilier chaque composante séparément et les implications d'une telle procédure pour l'emprunteur. »

Article 16

Après l'article L. 312-15, sont insérées deux sous-sections 1 *bis* et 1 *ter* ainsi rédigées :

« Sous-section 1 bis

« Services de conseil

« *Art. L. 312-15-1.* – En plus des explications mentionnées à l'article L. 312-14, le prêteur ou l'intermédiaire peut fournir à l'emprunteur un service de conseil en matière de contrats de crédit soumis aux dispositions du présent chapitre sous la forme d'une recommandation personnalisée fournie sur support papier ou au moyen d'un autre support durable choisi par l'emprunteur.

« Cette recommandation personnalisée porte sur un ou plusieurs contrats de crédit adaptés aux besoins et à la situation financière de l'emprunteur et se fonde :

« – pour les prêteurs ainsi que pour les intermédiaires, lorsque ceux-ci agissent en vertu d'un mandat délivré par un prêteur, sur un nombre suffisamment important de contrats de crédit de leur gamme de produits ;

« – pour les intermédiaires, lorsque ceux-ci agissent en vertu d'un mandat délivré par un client au sens de l'article L. 519-2 du code monétaire et financier, sur un nombre suffisamment important de contrats de crédit disponibles sur le marché.

« Les conditions de fourniture du service de conseil sont précisées par décret en Conseil d'Etat.

« *Art. L. 312-15-2.* – Le conseil est qualifié d'indépendant dès lors qu'il est rendu à partir d'un nombre suffisamment important de contrats de crédit disponibles sur le marché et que sa fourniture ne donne lieu à aucune rémunération autre que celle versée, le cas échéant, par l'emprunteur. Le service de conseil indépendant ne peut en aucun cas donner lieu à une rémunération, sous quelque forme que ce soit, de la part d'un prêteur ou d'un intermédiaire de crédit.

« Le prêteur ou l'intermédiaire de crédit qui fournit un service de conseil indépendant peut se prévaloir de l'appellation de conseiller indépendant.

« Les conditions de fourniture du service de conseil indépendant sont précisées par décret en Conseil d'Etat.

« *Art. L. 312-15-3.* – Le cas échéant, le prêteur fournit à l'emprunteur une indication des frais qu'il doit payer pour les services de conseil ou, si le montant de ces frais ne peut être déterminé au moment où les informations sont fournies, la méthode employée pour les calculer.

« Le prêteur indique au consommateur, le cas échéant, qu'il ne fournit pas son service en qualité de conseil indépendant.

« Sous-section 1 ter

« Devoir de mise en garde

« *Art. L. 312-15-4.* – Sans préjudice de l'examen de solvabilité mentionné à l'article L. 312-16, le prêteur ou l'intermédiaire de crédit est tenu de mettre en garde, sans frais, l'emprunteur lorsque, compte tenu de sa situation financière, un contrat de crédit peut induire des risques spécifiques pour lui. »

Article 17

Après l'article L. 312-18, il est inséré un article L. 312-18-1 ainsi rédigé :

« *Art. L. 312-18-1.* – L'octroi d'un crédit qui n'a pas fait l'objet d'une demande préalable ni d'un accord explicite de la part de l'emprunteur est interdit.

« Le consentement de l'emprunteur à la conclusion de tout contrat de crédit ou à l'achat de services accessoires est exprimé par un accord exprès.

« Il est interdit au prêteur et à l'intermédiaire de crédit de présupposer le consentement de l'emprunteur à la conclusion de tout contrat de crédit ou d'achat de services accessoires, lorsque ce contrat comporte des options prédéterminées, notamment au moyen de cases pré-cochées. »

Chapitre VII

Évaluation de la solvabilité

Article 18

La sous-section 2 de la section 4 du chapitre II du titre Ier du livre III intitulée « Evaluation de la solvabilité de l'emprunteur » devient la section 4 *bis* du chapitre II du titre Ier du livre III.

Article 19

L'article L. 312-16 est remplacé par les dispositions suivantes :

« *Art. L. 312-16.* – I. – Avant de conclure le contrat de crédit, le prêteur procède à une évaluation minutieuse de la solvabilité de l'emprunteur. Cette évaluation tient compte des facteurs pertinents permettant de vérifier la probabilité que l'emprunteur remplisse l'ensemble des obligations stipulées par le contrat de crédit.

« II. – L'évaluation de la solvabilité s'effectue sur la base d'informations pertinentes et exactes relatives aux revenus et charges de l'emprunteur ainsi qu'à d'autres critères économiques et financiers, qui sont nécessaires et proportionnées à la nature, à la durée, au montant du crédit et aux risques qu'il présente pour l'emprunteur.

« III. – Les informations mentionnées au II peuvent comprendre des preuves de revenus ou d'autres types de ressources, des informations sur les actifs et passifs financiers ou des informations sur d'autres engagements financiers. Ces informations peuvent également comprendre l'existence de preuves suffisantes que le ou les crédits seront susceptibles d'apporter à l'emprunteur des revenus futurs, l'existence de sûretés ou d'autres formes de garanties que l'emprunteur pourrait fournir. Ces informations ne comprennent pas les catégories particulières de données visées au I de l'article 6 de la loi nº 78-17 du 6 janvier 1978.

« Ces informations sont recueillies par le prêteur auprès de toutes sources internes ou externes pertinentes, y compris auprès de l'emprunteur, et comprennent notamment les informations fournies, le cas échéant, par

l'intermédiaire de crédit. Les réseaux sociaux ne sont pas considérés comme une source externe pertinente aux fins du présent article.

« Les informations recueillies font l'objet d'une vérification, si nécessaire en se référant à des documents autres que ceux fournis par l'emprunteur.

« IV. – Le prêteur consulte le fichier prévu à l'article L. 751-1, dans les conditions prévues par l'arrêté mentionné à l'article L. 751-6, sauf dans le cas d'une opération mentionnée au 1 de l'article L. 511-6 ou au 1 du I de l'article L. 511-7 du code monétaire et financier. L'évaluation de la solvabilité ne se fonde pas exclusivement sur cette consultation.

« V. – Si la demande de crédit est présentée conjointement par plusieurs emprunteurs, le prêteur effectue l'évaluation de la solvabilité sur la base de la capacité de remboursement conjointe des emprunteurs.

« VI. – Le prêteur ne peut accorder le crédit à l'emprunteur que si le résultat de l'évaluation de la solvabilité indique que les obligations découlant du contrat de crédit seront vraisemblablement respectées conformément à ce qui est prévu par ce contrat compte tenu des facteurs pertinents mentionnés au I.

« VII. – Le prêteur ne peut ni résilier ni modifier ultérieurement le contrat de crédit conclu avec l'emprunteur au motif qu'il a vérifié la solvabilité de manière incorrecte, sauf dans l'hypothèse où il est avéré que des informations mentionnées au II ont été dissimulées ou falsifiées par l'emprunteur.

« VIII. – S'il y a lieu, le prêteur informe l'emprunteur de ce que l'évaluation de sa solvabilité est fondée sur un traitement automatisé des données à caractère personnel. Dans ce cas, il lui indique la procédure à suivre pour contester la décision de rejet de sa demande de crédit et de son droit à une intervention humaine.

« L'emprunteur a le droit d'obtenir une explication claire et compréhensible de l'évaluation de sa solvabilité, de la logique et des risques associés au traitement automatisé des données à caractère personnel ainsi que de sa signification et de ses effets sur la décision, d'exprimer son point de vue et de demander un réexamen de l'évaluation de sa solvabilité et de la décision prise par le prêteur sur sa demande de crédit.

« IX. – A l'issue de la vérification de la solvabilité de l'emprunteur, lorsque la demande de crédit est rejetée, le prêteur l'informe dans les meilleurs délais de ce rejet et peut l'orienter, le cas échéant, vers des services de conseil aux personnes endettées facilement accessibles mentionnés à l'article L. 312-35-2.

« Lorsque cette décision est fondée sur le résultat de la consultation du fichier mentionné au IV, le prêteur en informe l'emprunteur. Il lui communique sans délai et sans frais ce résultat ainsi que des informations sur ce fichier et la nature des données prises en considération.

« X. – Le prêteur réévalue la solvabilité de l'emprunteur, sur la base d'informations mises à jour, avant d'accorder une augmentation significative du montant total du crédit. »

Article 20

L'article L. 312-17 est ainsi modifié :

1° Au début du premier alinéa, sont ajoutés les mots : « Sans préjudice des dispositions de l'article L. 312-16 » ;

2° Au deuxième alinéa, la seconde occurrence du mot : « aux » est remplacée par les mots : « à la totalité des » ;

3° Au dernier alinéa, les mots : « pièces justificatives » sont remplacés par les mots : « pièces ou documents justificatifs ».

Chapitre VIII

Droit de rétractation

Article 21

L'article L. 222-11 est abrogé.

Article 22

Le deuxième alinéa de l'article L. 222-12 est supprimé.

Article 23

L'article L. 222-14 est abrogé.

Article 24

Après l'article L. 222-15, il est inséré un article L. 222-15-1 ainsi rédigé :

« *Art. L. 222-15-1.* – Les dispositions de la présente section ne s'appliquent pas au droit de rétractation en matière de contrats de crédit conclus à distance relevant du chapitre II du titre Ier du livre III. »

Article 25

L'article L. 312-19 est ainsi modifié :

1° Au début de l'article, est insérée la référence : « I. – » ;

2° Après le mot : « motifs », sont insérés les mots : « d'un contrat de crédit » ;

3° Les mots : « révolus à compter du jour de l'acceptation de l'offre de contrat de crédit comprenant les informations prévues à l'article L. 312-28 » sont supprimés ;

4° L'article est complété par les six alinéas suivants :

« II. – Le délai de rétractation mentionné au I court à compter du jour où :

« 1° L'offre de contrat de crédit comprenant les informations prévues à l'article L. 312-28 est acceptée ;

« 2° L'emprunteur reçoit les conditions contractuelles et les informations prévues à l'article L. 312-28, si leur date de réception est postérieure à celle mentionnée au 1° du présent article.

« III. – Si l'emprunteur n'a pas reçu l'offre de contrat de crédit ni les informations prévues à l'article L. 312-28, le délai de rétractation expire en tout état de cause douze mois et quatorze jours après la conclusion du contrat de crédit.

« Par dérogation à l'alinéa précédent, le délai de rétractation n'expire pas si l'emprunteur n'a pas été informé de son droit de rétractation par le prêteur.

« IV. – Le délai mentionné au I est réputé avoir été respecté si l'emprunteur envoie au prêteur sa rétractation avant l'expiration de ce délai. »

Article 26

L'article L. 312-20 est remplacé par les dispositions suivantes :

« *Art. L. 312-20.* – Dans le cas d'un contrat de crédit affecté conclu pour l'achat d'un bien pour lequel le vendeur garantit un remboursement intégral pendant une durée déterminée dépassant quatorze jours calendaires, le délai d'exercice du droit de rétractation est prolongé de la durée du délai prévu pour le retour du bien, sans pouvoir excéder celle du contrat de crédit. »

Chapitre IX

formation du contrat

Article 27

Au second alinéa de l'article L. 312-24, les mots : « au-delà du délai de sept jours mentionné à l'article L. 312-25 » sont supprimés.

Article 28

L'article L. 312-25 est ainsi modifié :

1° Au premier alinéa, les mots : « Pendant un délai de sept jours à compter de » sont remplacés par le mot : « Avant » ;

2° Au deuxième alinéa, les mots : « Pendant ce même délai, » sont remplacés par les mots : « Avant l'acceptation du contrat par l'emprunteur, ».

Article 29

Le second alinéa de l'article L. 312-26 est complété par les mots : « , à l'exception, le cas échéant, d'une indemnité limitée au montant des frais non récupérables que le prêteur a payés à une administration publique. »

Article 30

Après l'article L. 312-26, il est inséré un article L. 312-26-1 ainsi rédigé :

« *Art. L. 312-26-1.* – L'emprunteur qui a exercé son droit de rétractation d'un contrat de location avec option d'achat dont l'exécution a commencé avant la fin du délai de rétractation verse au bailleur un montant correspondant à l'usage du bien jusqu'à la notification de sa décision de se rétracter. Ce montant est proportionné à la valeur marchande du bien qui a été fourni.

« Le bailleur n'a droit à aucune indemnité versée par l'emprunteur en cas de rétractation, à l'exception le cas échéant d'une indemnité limitée au montant des frais non récupérables que le prêteur a payés à une administration publique. »

Article 31

Après l'article L. 314-11, il est inséré un article L. 314-11-1 ainsi rédigé :

« *Art. L. 314-11-1.* – Pour les opérations relevant de l'article L. 314-10 et soumises au chapitre II en application de l'article L. 314-11, pendant un délai de sept jours calendaires à compter de l'acceptation du contrat par l'emprunteur, aucun paiement, sous quelque forme et à quelque titre que ce soit, ne peut être fait par le prêteur à l'emprunteur ou pour le compte de celui-ci, ni par l'emprunteur au prêteur. Pendant ce même délai, l'emprunteur ne peut non plus faire, au titre de l'opération en cause, aucun dépôt au profit du prêteur ou pour le compte de celui-ci. »

Chapitre X

informations mentionnées dans le contrat

Article 32

L'article L. 312-28 est complété par un alinéa ainsi rédigé :

« La présentation de ces informations est lisible et adaptée aux contraintes techniques du support au moyen duquel elles sont communiquées. »

Article 33

L'article L. 312-29 est ainsi modifié :

1° A la première phrase du premier alinéa :

a) Après le mot : « emprunteur », sont insérés les mots : « dans un document distinct de l'offre de contrat » ;

b) Les mots : « tout autre support durable » sont remplacés par les mots : « au moyen de tout autre support durable » ;

2° Cet article est complété par un alinéa ainsi rédigé :

« Si l'assurance est exigée par le prêteur pour accorder le financement, l'emprunteur est informé de ce qu'il dispose d'un délai d'au moins trois jours à compter de la réception de la proposition mentionnée au premier alinéa pour comparer les offres d'assurance. Pendant ce délai, cette proposition n'est pas modifiée. L'emprunteur peut accepter un contrat d'assurance avant l'expiration du délai s'il en fait expressément la demande. »

Chapitre XI

modification du contrat

Article 34

L'article L. 312-31 est ainsi modifié :

1° A la première phrase du premier alinéa :

a) Après le mot : « informé », sont insérés les mots : « en temps utile » ;

b) Les mots : « sur un autre support durable » sont remplacés par les mots : « au moyen d'un autre support durable précisé dans le contrat de crédit » ;

2° Au second alinéa :

a) Après le mot : « public », sont insérés les mots : « en temps opportun » ;

b) Après le mot : « prêteur », sont insérés les mots : « et, si ce dernier en dispose, sur son site internet et sur son application mobile, ».

Article 35

L'article L. 312-31-1 est ainsi modifié :

1° A la première phrase du premier alinéa, après les mots : « Avant de modifier les », sont insérés les mots : « clauses et les » ;

2° Après les mots : « à l'emprunteur », sont insérés les mots : « par tout moyen, sur support papier ou au moyen de tout autre support durable précisé dans le contrat de crédit, ».

Chapitre XII

remboursement anticipé

Article 36

L'article L. 312-34 est ainsi modifié :

1° La seconde phrase du premier alinéa est remplacée par les deux phrases suivantes : « Dans ce cas, l'emprunteur a droit à une réduction du coût total du crédit pour la durée résiduelle du contrat de crédit, proportionnelle à la durée restante du contrat. Tous les frais imposés par le prêteur à l'emprunteur sont pris en compte lors du calcul de cette réduction. » ;

2° Au deuxième alinéa, les mots : « ne peut être » sont remplacés par les mots : « n'est » ;

3° Au sixième alinéa :

a) A la première phrase, les mots : « ne peut dépasser » sont remplacés par les mots : « ne dépasse pas » ;

b) A la deuxième phrase, les mots : « ne peut pas dépasser » sont remplacés par les mots : « ne dépasse pas » ;

4° Au dernier alinéa, les mots : « peuvent être » sont remplacés par le mot : « sont ».

Article 37

L'article L. 312-35 est remplacé par les dispositions suivantes :

« *Art. L. 312-35.* – Pour les opérations de location-vente et de location avec option d'achat, le locataire peut, à tout moment et à son initiative, acquérir par anticipation le bien loué. Dans ce cas, le locataire a droit à une réduction du coût total du contrat dans les conditions prévues au premier alinéa de l'article L. 312-34. Le montant que le prêteur peut exiger du locataire ne peut dépasser la somme du prix de la levée d'option d'achat au terme de la location tel que convenu dans le contrat et des loyers restant à échoir au moment de l'achat, diminuée de la moitié des intérêts restants dus ou d'une proportion supérieure lorsque cette moitié ne permet pas de garantir au locataire une réduction du coût total du contrat.

« Aucun autre intérêt ni aucun autre frais ne peuvent être mis à la charge du locataire en cas d'acquisition du bien par anticipation. »

Chapitre XIII

Mesures de renégociation

Article 38

L'article L. 312-35-1 est remplacé par les dispositions suivantes :

« *Art. L. 312-35-1.* – Le prêteur s'astreint à respecter un délai raisonnable avant d'engager une procédure d'exécution à l'encontre d'un emprunteur en difficulté financière et lui propose, s'il y a lieu, des mesures de renégociation tenant notamment compte de sa situation personnelle. Ces mesures peuvent être :

« 1° Le refinancement total ou partiel du contrat de crédit ;

« 2° La modification des conditions du contrat de crédit, qui peut comprendre entre autres :

« *a)* L'allongement de la durée du contrat de crédit ;

« *b)* La modification du type de contrat de crédit ;

« *c)* Le report de tout ou partie des versements du remboursement pendant une période donnée ;

« *d)* Une réduction du taux débiteur ;

« *e)* Le réaménagement de l'échéancier, notamment la réduction du montant des versements du remboursement ;

« *f)* Des remboursements partiels ;

« *g)* Une remise de dette partielle et la consolidation de la dette ;

« *h)* Une proposition de dispense temporaire de remboursement ;

« *i)* Des conversions de monnaie.

« Le prêteur n'est pas tenu de procéder à l'évaluation de solvabilité mentionnée à l'article L. 312-16 lorsqu'il modifie les conditions existantes d'un contrat de crédit conformément au 2°, sous réserve que le montant total dû par l'emprunteur n'augmente pas de manière significative.

« Sauf si la situation de l'emprunteur le justifie, le prêteur n'est pas tenu de proposer à plusieurs reprises des mesures de renégociation.

« Le prêteur formalise les modifications des clauses et conditions existantes d'un contrat de crédit mentionnées au 2° dans les conditions prévues à l'article L. 312-31-1. »

Chapitre XIV

Services de conseil aux personnes endettées

Article 39

Après l'article L. 312-35-1, il est inséré une sous-section 3 *bis* ainsi rédigée :

« Sous-section 3 bis

« Services de conseil aux personnes endettées

« *Art. L. 312-35-2.* – Le prêteur se dote d'un dispositif de détection des emprunteurs qui ont ou pourraient avoir des difficultés à respecter leurs engagements financiers. A ce titre, il peut utiliser le dispositif de détection des situations de fragilité financière mentionné à l'article L. 312-1-1-A du code monétaire et financier.

« Le prêteur oriente gratuitement les emprunteurs qui éprouvent des difficultés à respecter leurs engagements financiers vers des entités qui fournissent des services de conseil aux personnes endettées.

« Ces entités prodiguent une aide personnalisée, sont indépendantes des prêteurs, des intermédiaires de crédit, des acheteurs de crédits ou des gestionnaires de crédits et sont facilement accessibles pour les consommateurs. Cette aide est fournie à titre gratuit ou pour un coût limité.

« Les modalités d'application du présent article sont fixées par décret. »

Chapitre XV

crédit affecté

Article 40

Le deuxième alinéa de l'article L. 312-47 est remplacé par les dispositions suivantes :

« Toutefois, l'emprunteur peut, par une demande expresse, solliciter la livraison ou la fourniture immédiate du bien ou de la prestation de services. »

Article 41

A l'article L. 312-54, la référence : « 9° » est remplacée par la référence : « 11° ».

Chapitre XVI

autorisations de découvert

Article 42

I. – La seconde phrase du deuxième alinéa de l'article L. 222-6 est supprimée.

II. – Les articles L. 312-84, L. 312-85, L. 312-86 et L. 312-87 sont abrogés.

III. – Au premier alinéa de l'article L. 341-1, les mots : « ou, pour les opérations de découvert en compte, à l'article L. 312-85 » sont supprimés.

Article 43

L'article L. 312-88 est ainsi modifié :

1° Les mots : « remboursable dans un délai supérieur à un mois » sont supprimés ;

2° Après le mot : « régulièrement », sont insérés les mots : « et au moins une fois par mois » ;

3° Après le mot : « emprunteur, », sont insérés les mots : « pendant toute la durée du contrat de crédit, » ;

4° Les mots : « sur un autre support durable » sont remplacés par les mots : « au moyen d'un autre support durable précisé dans le contrat de crédit ».

Article 44

L'article L. 312-89 est ainsi modifié :

1° Au premier alinéa, les mots : « sur un autre support durable » sont remplacés par les mots : « au moyen d'un autre support durable précisé dans le contrat de crédit, en temps utile » ;

2° Au second alinéa :

a) Après le mot : « disponible », sont insérés les mots : « s'il y a lieu » ;

b) Après le mot : « prêteur, » sont insérés les mots : « et, si ce dernier en dispose, sur son site internet et sur son application mobile, ».

Article 45

L'article L. 312-90 est complété par les trois alinéas suivants :

« Si le contrat le prévoit, le prêteur a la faculté de résilier l'autorisation de découvert à durée indéterminée. La résiliation peut intervenir moyennant un préavis d'au moins deux mois. L'information doit en être donnée à l'emprunteur sur support papier ou au moyen d'un autre support durable précisé dans le contrat de crédit. Par dérogation, pour des motifs objectivement justifiés, la résiliation peut intervenir sans préavis et, dans ce cas, le prêteur en fournit les motifs à l'emprunteur, si possible avant la résiliation et au plus tard immédiatement après celle-ci à moins que la communication de cette information soit interdite par la loi ou que des motifs d'ordre public ou de sécurité publique s'y opposent.

« Lorsque l'autorisation de découvert à durée indéterminée est réduite par le prêteur, l'emprunteur a la possibilité de rembourser, sans frais supplémentaires, le montant utilisé au titre du découvert qui excède le nouveau plafond d'autorisation fixé par le prêteur avant que des procédures d'exécution soient engagées. Il en est de même dans le cas d'une résiliation de l'autorisation. Ce remboursement, formalisé par tout moyen, sur un support papier ou au moyen d'un autre support durable, est, à moins que l'emprunteur ne décide de rembourser dans un délai plus court, effectué en douze mensualités égales au taux débiteur applicable à l'autorisation de découvert.

« Ces dispositions s'appliquent sans préjudice de l'application de celles de l'article L. 312-35-1. »

Article 46

L'article L. 312-91 est remplacé par les dispositions suivantes :

« *Art. L. 312-91.* – Le prêteur a la faculté de réduire ou de résilier l'autorisation de découvert à durée déterminée moyennant un préavis d'au moins trente jours. L'information doit en être donnée à l'emprunteur selon les modalités convenues dans le contrat de crédit.

« Lorsque l'autorisation de découvert à durée déterminée est réduite par le prêteur, l'emprunteur a la possibilité de rembourser, sans frais supplémentaires, le montant utilisé au titre du découvert qui excède le nouveau plafond

d'autorisation fixé par le prêteur avant que des procédures d'exécution soient engagées. Il en est de même dans le cas d'une résiliation de l'autorisation de découvert. Ce remboursement, formalisé par tout moyen, sur un support papier ou au moyen d'un autre support durable, est, à moins que l'emprunteur ne décide de rembourser dans un délai plus court, effectué en douze mensualités égales au taux débiteur applicable à l'autorisation de découvert.

« Ces dispositions s'appliquent sans préjudice de l'application de celles de l'article L. 312-35-1. »

Chapitre XVII

DÉPASSEMENT

Article 47

L'article L. 312-92 est ainsi modifié :

1° A la première phrase du premier alinéa :

a) La référence : « I » est remplacée par la référence : « II » ;

b) Après les mots : « les frais applicables », sont ajoutés les mots : « à cette possibilité de dépassement dès la conclusion de la convention » ;

2° Il est inséré, après le premier alinéa, un deuxième alinéa ainsi rédigé :

« La signature de la convention de compte qui prévoit la possibilité d'un dépassement dans les conditions prévues au premier alinéa vaut accord explicite de la part de l'emprunteur au sens de l'article L. 312-18-1. » ;

3° Au second alinéa, qui devient le troisième :

a) Les mots : « sur un autre support durable » sont remplacés par les mots : « au moyen d'un autre support durable choisi par l'emprunteur et précisé dans la convention de compte. Il l'informe également » ;

b) Les mots : « débiteur et de tous » sont remplacés par les mots : « débiteur, de tous les » ;

c) Après les mots : « qui sont applicables », sont ajoutés les mots : « et de la date de remboursement » ;

4° Il est complété par un alinéa ainsi rédigé :

« Dans le cas d'un dépassement récurrent, le prêteur propose des services de conseil à l'emprunteur, lorsqu'ils sont disponibles, et l'oriente sans frais vers les services de conseil aux personnes endettées mentionnés à l'article L. 312-35-2. »

Article 48

L'article L. 312-93 est ainsi modifié :

1° La référence : « 4° » est remplacée par la référence : « 6° » ;

2° L'article est complété par trois alinéas ainsi rédigés :

« Le prêteur adresse une notification à l'emprunteur, selon les modalités convenues, lorsque le dépassement n'est plus autorisé ou que la limite du dépassement est réduite, au moins trente jours avant la date à laquelle l'annulation ou la réduction du dépassement prend effet.

« Lorsque, s'il y a lieu, la limite du dépassement est réduite ou que le dépassement n'est plus rendu possible par le prêteur, l'emprunteur peut rembourser, sans frais supplémentaires, le montant effectivement dû dans la mesure de cette réduction ou dénonciation avant que des procédures d'exécution soient engagées. A moins que l'emprunteur ne décide de rembourser dans un délai plus court, ce remboursement est effectué en douze mensualités égales au taux débiteur applicable au dépassement.

« Ces dispositions s'appliquent sans préjudice de l'application de celles de l'article L. 312-35-1. »

Article 49

L'article L. 312-94 est ainsi modifié :

1° Les références : « L. 312-27, L. 312-92 et L. 312-93 » sont remplacés par les références : « L. 311-1, L. 312-1 à L. 312-4-1, du premier alinéa de l'article L. 312-18-1, des articles L. 312-35-1, L. 312-35-2, L. 312-92, L. 312-93, L. 314-6, L. 752-1 du présent code et des articles L. 54-11-10 et L. 54-11-33 du code monétaire et financier » ;

2° La référence : « 11° » est remplacée par la référence : « 13° ».

Chapitre XVIII

RÈGLES DE CONDUITE ET EXIGENCES APPLICABLES AU PERSONNEL

Article 50

L'article L. 314-22 est ainsi modifié :

1° Au premier alinéa, les mots : « de l'élaboration, de l'octroi et de l'exécution d'un contrat de crédit » sont remplacés par les mots : « des activités d'élaboration, d'octroi, de facilitation de l'octroi, d'exécution d'un contrat de crédit, ou de publicité de produits de crédit » ;

2° Au second alinéa :

a) Les mots : « de crédit, de services accessoires ou de services de conseil s'appuie » sont remplacés par les mots : « et la facilitation de l'octroi de crédit ainsi que la fourniture de services de conseil s'appuient » ;

b) Les mots : « que la durée du contrat de crédit fait courir à l'emprunteur » sont remplacés par les mots : « pour l'emprunteur pendant toute la durée du contrat de crédit ».

Article 51

L'article L. 314-23 est ainsi modifié :

1° Au quatrième alinéa, les mots : « mentionnées à l'article L. 313-1 » sont remplacés par les mots : « relevant des chapitres II et III du présent livre » ;

2° Au dernier alinéa :

a) Les mots : « un service de conseil mentionné aux articles L. 313-13 et L. 313-14 » sont remplacés par les mots : « des services de conseil mentionnés aux articles L. 312-15-1, L. 312-15-2, L. 313-13 et L. 313-14 » ;

b) Le mot : « exclusivement » est supprimé.

Article 52

Le premier alinéa de l'article L. 314-24 est remplacé par les dispositions suivantes :

« Les prêteurs et intermédiaires de crédit veillent à ce que le personnel placé sous leur autorité possède et maintienne à jour des connaissances et compétences appropriées concernant l'élaboration, la proposition et l'octroi des contrats de crédit relevant des chapitres II et III du présent titre, la fourniture de services de conseil, les droits des consommateurs dans le domaine où ils exercent ainsi que, le cas échéant, l'activité d'intermédiation de crédit. »

Article 53

L'article L. 314-25 est ainsi modifié :

1° Après les mots : « Les personnes », sont insérés les mots : « autres que le personnel des prêteurs et intermédiaires de crédit » ;

2° Les mots : « à L. 312-3 » sont remplacés par les mots : « et L. 312-2 » ;

3° Les mots : « mentionnée à l'article L. 6353-1 du code du travail, établie par un des prêteurs dont les crédits sont proposés, sur le lieu de vente ou par un organisme de formation enregistré » sont remplacés par les mots : « établie par un organisme mentionné à l'article L. 6353-1 du code du travail ».

Chapitre XIX

Sanctions

Section 1

Crédit à la consommation

Article 54

Au début de la section 1 du chapitre Ier du titre IV du livre III de la partie législative nouvelle, il est inséré un article L. 340-1 ainsi rédigé :

« *Art. L. 340-1.* – Le maximum de l'amende administrative encourue en application des articles L. 340-2, L. 340-3, L. 341-1-1 et L. 341-12 à L. 341-20 est doublé en cas de réitération du manquement dans un délai de deux ans à compter de la date à laquelle la première décision de sanction est devenue définitive.

« Lorsque le prêteur est déchu du droit aux intérêts dans les conditions prévues aux articles L. 341-1 et L. 341-2 à L. 341-8, l'emprunteur n'est tenu qu'au seul remboursement du capital suivant l'échéancier prévu, ainsi que, le cas échéant, au paiement des intérêts dont le prêteur n'a pas été déchu. Les sommes déjà perçues par le prêteur au titre des intérêts, qui sont productives d'intérêts au taux de l'intérêt légal à compter du jour de leur versement, sont restituées par celui-ci ou imputées sur le capital restant dû. »

Article 55

Au début de la section 1 du chapitre Ier du titre IV du livre III de la partie législative nouvelle, il est inséré une sous-section 1 ainsi rédigée :

« Sous-section 1

« Publicité et informations générales

« *Art. L. 340-2.* – Tout manquement aux obligations relatives à la publicité et à la mention "crédit renouvelable" mentionnées aux articles L. 312-5 à L. 312-11, L. 312-41 et L. 312-58 à L. 312-61 est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale.

« L'autorité administrative compétente peut également prévoir la rectification de la publicité aux frais du professionnel.

« *Art. L. 340-3.* – Tout manquement aux obligations prévues à l'article L. 312-11-1 relatif aux informations générales est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale. »

Article 56

La sous-section 1 de la section 1 du chapitre Ier du titre IV du livre III de la partie législative nouvelle devient la sous-section 1 *bis* de la section 1 du chapitre Ier du titre IV du livre III de la partie législative nouvelle.

Article 57

Au début de la sous-section 1 de la section 1 du chapitre Ier du titre IV du livre III de la partie législative nouvelle, devenue la section 1 *bis*, il est inséré un paragraphe 1 intitulé : « Sanctions civiles ».

Article 58

Après l'article L. 341-1, il est inséré un paragraphe 2 ainsi rédigé :

« Paragraphe 2

« Sanctions administratives

« *Art. L. 341-1-1.* – Tout manquement aux obligations prévues aux articles L. 312-12 et L. 312-13 relatifs aux informations précontractuelles est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale. »

Article 59

L'article L. 341-4 est ainsi modifié :

1° Au premier alinéa, les mots : « ainsi que, pour les opérations de découvert en compte, par les articles L. 312-85 à L. 312-87 et L. 312-92, » sont remplacés par les mots : « ainsi que pour les dépassements par l'article L. 312-92 » ;

2° Il est complété par un alinéa ainsi rédigé :

« Le prêteur qui n'a pas respecté le délai prévu au troisième alinéa de l'article L. 312-29 ou qui n'a pas informé l'emprunteur de ce délai est déchu du droit aux intérêts. »

Article 60

A l'article L. 341-6, après la référence : « L. 312-89 », sont insérés les mots : « , et les obligations relatives à l'information de l'emprunteur en cas de modification du contrat fixées à l'article L. 312-31-1 ».

Article 61

L'article L. 341-8 est remplacé par les dispositions suivantes :

« *Art. L. 341-8.* – Le prêteur qui résilie ou réduit l'autorisation de découvert sans respecter les obligations prévues aux articles L. 312-90 et L. 312-91 est déchu du droit aux intérêts. »

Article 62

A l'article L. 341-9, le mot : « dernier » est remplacé par le mot : « troisième ».

Article 63

L'intitulé du paragraphe 2 de la sous-section 2 de la section 1 du chapitre Ier du titre IV du livre III est remplacé par un intitulé ainsi rédigé : « Sanctions administratives ».

Article 64

L'article L. 341-12 est remplacé par les dispositions suivantes :

« *Art. L. 341-12.* – Tout manquement aux obligations prévues aux articles L. 312-15 relatif à la prime en nature, L. 312-15-1 relatif à la remise d'une recommandation personnalisée répondant aux exigences de cet article, L. 312-15-3 relatif à l'indication des frais ou de la méthode de calcul des frais pour les services de conseil, L. 312-18 relatif à la remise de l'offre de contrat de crédit, L. 312-21 relatif au formulaire de rétractation, L. 312-28 relatif au contrat de crédit, L. 312-29 relatif à la notice d'assurance, L. 312-31-1 relatif à l'information de l'emprunteur en cas de modification du contrat, L. 312-32 relatif à l'information sur le capital restant dû et au dernier alinéa de l'article L. 312-35-1 relatif à la formalisation de la modification du contrat en cas de mesure de renégociation, est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale. »

Article 65

L'article L. 341-13 est remplacé par les dispositions suivantes :

« *Art. L. 341-13.* – Toute violation de la part d'un prestataire de service de conseil indépendant de l'interdiction, prévue par le premier alinéa de l'article L. 312-15-2, d'être rémunéré par le prêteur ou un

intermédiaire de crédit est passible d'une amende administrative dont le montant ne peut excéder 15 000 euros pour une personne physique et 75 000 euros pour une personne morale. »

Article 66

L'article L. 341-14 est remplacé par les dispositions suivantes :

« *Art. L. 341-14.* – Le fait pour le prêteur d'octroyer un crédit sans demande préalable ni accord explicite de la part de l'emprunteur, en méconnaissance des dispositions de l'article L. 312-18-1, est passible d'une amende administrative dont le montant ne peut excéder 300 000 euros pour une personne physique et 1 500 000 euros pour une personne morale.

« Le montant de l'amende peut être porté, de manière proportionnée aux avantages tirés du manquement, à 10 % du chiffre d'affaires moyen annuel, calculé sur les trois derniers chiffres d'affaires annuels connus à la date des faits. »

Article 67

L'article L. 341-15 est remplacé par les dispositions suivantes :

« *Art. L. 341-15.* – Est passible d'une amende administrative dont le montant ne peut excéder 300 000 euros pour une personne physique et 1 500 000 euros pour une personne morale :

« 1° Le fait pour le prêteur ou le vendeur de réclamer ou de recevoir de l'emprunteur ou de l'acheteur un paiement sous quelque forme que ce soit, en méconnaissance des dispositions de l'article L. 312-25 ainsi que, pour un contrat de crédit affecté, de celles de l'article L. 312-50 et, pour un contrat de regroupement de crédits soumis au chapitre II, de celles de l'article L. 314-11-1 ;

« 2° Le fait de faire signer une autorisation de prélèvements sur compte bancaire contenant des clauses contraires aux dispositions de l'article L. 312-25 et, pour un contrat de crédit affecté, à celles de l'article L. 312-50 et, pour un contrat de regroupement de crédits soumis au chapitre II, à celles de l'article L. 314-11-1 ;

« 3° Le fait de faire souscrire ou accepter ou avaliser par l'emprunteur ou l'acheteur des lettres de change ou des billets à ordre ;

« 4° Le fait d'enregistrer ou faire enregistrer sur un fichier, en méconnaissance des dispositions de l'article L. 312-22, le nom des personnes faisant usage de la faculté de rétractation ;

« 5° Le fait de faire signer par un même client une ou plusieurs offres de contrat de crédit d'un montant total en capital supérieur à la valeur payable à crédit du bien acheté ou de la prestation de services fournie. »

Article 68

L'article L. 341-16 est remplacé par les dispositions suivantes :

« *Art. L. 341-16.* – Tout manquement du vendeur aux obligations prévues à l'article L. 312-42 relatif au prix de vente d'un bien soumis à une opération de crédit gratuit est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale.

« Tout manquement du prêteur aux obligations prévues à l'article L. 312-43 relatif à la conclusion d'un contrat de crédit proposé concomitamment à une opération de crédit gratuit est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale. »

Article 69

L'article L. 341-17 est remplacé par les dispositions suivantes :

« *Art. L. 341-17.* – Tout manquement du vendeur ou du prestataire à l'obligation, prévue à l'article L. 312-45, de préciser dans le contrat que le paiement du prix est acquitté à l'aide d'un crédit est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale. »

Article 70

L'article L. 341-18 est remplacé par les dispositions suivantes :

« *Art. L. 341-18.* – Le fait pour le vendeur ou le prestataire de services de ne pas rembourser les sommes dues à l'acheteur en cas de résolution du contrat de vente ou de prestation de services, en méconnaissance des dispositions de l'article L. 312-53, est passible d'une amende administrative dont le montant ne peut excéder 300 000 euros pour une personne physique et 1 500 000 euros pour une personne morale. »

Article 71

L'article L. 341-19 est remplacé par les dispositions suivantes :

« *Art. L. 341-19.* – Tout manquement du prêteur ou de l'intermédiaire de crédit aux obligations concernant les crédits renouvelables prévues par les articles L. 312-62 et L. 312-63 relatifs à l'information précontractuelle, par les articles L. 312-64 à L. 312-66 relatifs au formalisme du contrat de crédit renouvelable, par l'article L. 312-67 relatif à la mention "carte de crédit", par l'article L. 312-68 relatif aux avantages liés à la carte à laquelle est assorti le crédit renouvelable, par l'article L. 312-71 relatif à l'état actualisé de l'exécution du contrat de crédit renouvelable et par les articles L. 312-75 à L. 312-83 relatifs à la reconduction est passible d'une amende

administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale. »

Article 72

L'article L. 341-20 est remplacé par les dispositions suivantes :

« *Art. L. 341-20.* – Tout manquement du prêteur aux obligations prévues aux articles L. 312-90 et L. 312-91 en matière de réduction ou résiliation de l'autorisation de découvert et à celles prescrites à l'article L. 312-93 en matière de réduction ou résiliation du dépassement est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale. »

Article 73

La sous-section 3 de la section 1 du chapitre Ier du titre IV du livre III de la partie législative nouvelle est supprimée.

Section 2

Dispositions communes au crédit à la consommation et au crédit immobilier

Article 74

Après l'article L. 341-48-1, il est inséré une sous-section 2 ainsi rédigée :

« Sous-section 2

« Sanctions administratives

« *Art. L. 341-49.* – Tout manquement à l'obligation prévue à l'article L. 314-5 de mentionner le taux effectif global exprimé avec une précision d'au moins une décimale est passible d'une amende administrative dont le montant ne peut excéder 150 000 euros pour une personne physique et 750 000 euros pour une personne morale.

« Le maximum de l'amende encourue est doublé en cas de réitération du manquement dans un délai de deux ans à compter de la date à laquelle la première décision de sanction est devenue définitive. »

Article 75

La sous-section 2 de la section 3 du chapitre Ier du titre IV du livre III de la partie législative nouvelle devient la sous-section 3 de la section 3 du chapitre Ier du titre IV du livre III de la partie législative nouvelle.

Article 76

L'article L. 341-49 est abrogé.

Article 77

L'intitulé de la section 5 du chapitre Ier du titre IV du livre III de la partie législative est remplacé par un intitulé ainsi rédigé : « Règle de conduite, rémunération et formation ».

Article 78

Au début de la section 5 du chapitre Ier du titre IV du livre III de la partie législative nouvelle, il est ajouté un article L. 341-51-1 ainsi rédigé :

« *Art. L. 341-51-1.* – Toute violation de l'interdiction prévue au troisième alinéa de l'article L. 314-23 de rémunérer un vendeur en fonction du taux du crédit ou du type de crédit qu'il a fait contracter est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale.

« Toute violation, par un vendeur, de l'interdiction prévue au troisième alinéa de l'article L. 314-23 d'être rémunéré en fonction du taux de crédit ou du type de crédit qu'il a fait contracter est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale.

« Le maximum de l'amende encourue est doublé en cas de réitération du manquement dans un délai de deux ans à compter de la date à laquelle la première décision de sanction est devenue définitive. »

Article 79

Après l'article L. 341-52, il est inséré un article L. 341-52-1 ainsi rédigé :

« *Art. L. 341-52-1.* – Tout manquement aux obligations prévues aux articles L. 314-24 et L. 314-25 en matière de formation est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale.

« Le maximum de l'amende encourue est doublé en cas de réitération du manquement dans un délai de deux ans à compter de la date à laquelle la première décision de sanction est devenue définitive. »

Article 80

Après l'article L. 341-52, il est inséré une section 5 *bis* ainsi rédigée :

« Section 5 bis

« Dispositions relatives à la mise à disposition ou remise d'informations ou documents sur tout autre support durable que le papier

« *Art. L. 341-52-2.* – Tout manquement aux obligations prévues au troisième alinéa de l'article L. 314-27 relatif à l'information de l'emprunteur de son droit de s'opposer à l'utilisation d'un support autre que papier, aux articles L. 314-28 relatif à l'exercice du droit d'opposition à l'utilisation d'un support autre que papier et L. 314-29 relatif à l'information de l'emprunteur de la disponibilité des documents sur l'espace personnel sécurisé, ainsi qu'aux obligations relatives aux délais prévus à l'article L. 314-30 est passible d'une amende administrative dont le montant ne peut excéder 1 500 euros pour une personne physique et 7 500 euros pour une personne morale.

« Le maximum de l'amende encourue est doublé en cas de réitération du manquement dans un délai de deux ans à compter de la date à laquelle la première décision de sanction est devenue définitive. »

Section 3

Habilitations relatives aux sûretés personnelles et à la mise à disposition ou remise d'informations ou documents sur tout autre support durable que le papier

Article 81

Au 6° de l'article L. 511-5, les mots : « Les sections 1, 2, 6 et 7 » sont remplacés par les mots : « Les sections 1, 2, 6, 7 et 9 ».

Chapitre XX

FICHIER NATIONAL DES INCIDENTS DE REMBOURSEMENT DES CRÉDITS AUX PARTICULIERS

Article 82

L'article L. 751-3 est ainsi modifié :

1° Le mot : « diffusion » est remplacé par le mot : « communication » ;

2° La référence : « L. 751-2 » est remplacée par la référence : « L. 752-1 ».

Article 83

L'article L. 751-4 est ainsi modifié :

1° Les mots : « au premier alinéa de » sont remplacés par le mot : « à » ;

2° La référence : « L. 751-2 » est remplacée par la référence : « L. 752-1 ».

Article 84

Au premier alinéa de l'article L. 751-5, la référence : « L. 751-2 » est remplacée par la référence : « L. 752-1 ».

Article 85

Le denier alinéa de l'article L. 752-1 est remplacé par les dispositions suivantes :

« Les informations relatives à ces incidents sont radiées immédiatement à la réception de la déclaration de paiement intégral des sommes dues effectuée par l'entreprise responsable de la gestion de l'inscription.

« En cas de cession du contrat de crédit ou de transfert des droits du créancier à une entreprise mentionnée au premier alinéa de l'article L. 751-2, cette dernière est responsable de la déclaration de paiement intégral des sommes dues.

« En cas de cession du contrat de crédit ou de transfert des droits du créancier à un acheteur de crédits mentionné à l'article L. 54-11 du code monétaire financier, le gestionnaire de crédits mentionné au même article est responsable de la déclaration de paiement intégral des sommes dues.

« Dans les cas mentionnés aux deux alinéas précédents, l'entreprise qui cède le contrat de crédit ou transfère ses droits sur celui-ci transmet au nouveau titulaire ou au gestionnaire de crédit toutes les informations utiles à la gestion de l'inscription.

« En cas de cession du contrat de crédit ou de transfert des droits du créancier à un tiers non-mentionné au présent article, ce dernier informe immédiatement l'entreprise responsable de la gestion de l'inscription du règlement intégral des sommes dues aux fins de radiation.

« Les informations relatives à ces incidents ne peuvent être conservées dans le fichier pendant plus de cinq ans à compter de la date d'enregistrement par la Banque de France de l'incident ayant entraîné la déclaration.

« Les conditions d'application du présent article sont fixées par l'arrêté mentionné à l'article L. 751-6, qui précise également les mesures à prendre par les entreprises mentionnées aux premier et quatrième alinéas, en cas de retrait de leur agrément, pour garantir la continuité de la gestion de l'inscription des créances dont elles ont eu la gestion. »

TITRE II

DISPOSITIONS MODIFIANT LES LIVRES III ET V DU CODE MONÉTAIRE ET FINANCIER

CHAPITRE Ier

SEUIL DE L'USURE

Article 86

L'article L. 313-5 du code monétaire et financier est remplacé par les dispositions suivantes :

« *Art. L. 313-5.* – La définition du taux de l'usure est fixée par les articles L. 314-6 à L. 314-9 du code de la consommation. »

CHAPITRE II

PRÊTEURS À TITRE ACCESSOIRE

Article 87

Au 1 du I de l'article L. 511-7 du même code, après le mot : « paiement », sont insérés les mots : « sans intérêts ni autres frais et avec des frais limités dus par le consommateur en cas de retard de paiement, sauf si elle est une grande entreprise au sens du 4° de l'article L. 230-1 du code de commerce qui consent des paiements différés relevant du chapitre II du livre III du code de la consommation ».

CHAPITRE III

RÈGLES DE CONDUITE ET EXIGENCES APPLICABLES AU PERSONNEL DES INTERMÉDIAIRES

Article 88

Au premier alinéa de l'article L. 519-1-1 du même code, les mots : « à l'article L. 313-1 » sont remplacés par les mots : « aux articles L. 312-1 et L. 313-1 ».

Article 89

Après le premier alinéa de l'article L. 519-4-1 du même code, il est inséré un alinéa ainsi rédigé :

« L'intermédiation de crédit et la prestation de services de conseil s'appuient sur les informations relatives à la situation du client et sur toute demande spécifique formulée par celui-ci, ainsi que sur les hypothèses raisonnables quant aux risques pour le client pendant toute la durée du contrat de crédit. »

Article 90

Après le deuxième alinéa de l'article L. 519-6 du même code, il est inséré un alinéa ainsi rédigé :

« La manière dont les intermédiaires de crédit rémunèrent leur personnel ne porte pas atteinte au respect des obligations mentionnées à l'article L. 519-4-1. »

Article 91

Au début de l'article L. 519-6-1 du même code, il est inséré un alinéa ainsi rédigé :

« La politique de rémunération du personnel fournissant des services de conseil mentionnés à l'article L. 519-1-1 ne porte pas atteinte à sa capacité de servir au mieux les intérêts du client et ne peut dépendre des objectifs de vente. »

CHAPITRE IV

CESSION DES CRÉANCES ET FICHIER DES INCIDENTS DE PAIEMENT

Article 92

Après l'article L. 54-11-33 du même code, il est ajouté une section 12 ainsi rédigée :

« Section 12

« Le secret professionnel

« *Art. L. 54-11-34.* – Tout membre d'un conseil d'administration et, selon le cas, d'un conseil de surveillance et toute personne qui, à un titre quelconque, participe à la direction ou à la gestion d'un gestionnaire de crédits ou qui est employée par un gestionnaire de crédits est tenu au secret professionnel.

« Outre les cas où la loi le prévoit, le secret professionnel ne peut être opposé à l'Autorité de contrôle prudentiel et de résolution, ni à la Banque de France, ni à l'Institut d'émission des départements d'outre-mer, ni à l'Institut d'émission d'outre-mer, ni à l'autorité judiciaire agissant dans le cadre d'une procédure pénale, ni aux commissions d'enquête créées en application de l'article 6 de l'ordonnance n° 57-1100 du 17 novembre 1958 relative au fonctionnement des assemblées parlementaires.

« Les gestionnaires de crédits peuvent par ailleurs communiquer des informations couvertes par le secret professionnel, aux personnes avec lesquelles ils négocient, concluent ou exécutent les opérations ci-après énoncées, dès lors que ces informations sont nécessaires à celles-ci :

« 1° Prises de participation ou de contrôle dans un gestionnaire de crédits ;

« 2° Cessions d'actifs ou de fonds de commerce ;

« 3° Cessions ou transferts de contrats ;

« 4° Contrats de prestations de services conclus avec un tiers en vue de lui confier des fonctions opérationnelles importantes ;

« 5° Lors de l'étude ou l'élaboration de tout type de contrats ou d'opérations, dès lors que ces entités appartiennent au même groupe que l'auteur de la communication.

« Outre les cas mentionnés ci-dessus, les gestionnaires de crédits peuvent communiquer des informations couvertes par le secret professionnel lorsque les personnes concernées leur ont expressément donné leur accord à cet effet.

« Les personnes recevant des informations couvertes par le secret professionnel, qui leur ont été transmises pour les besoins de l'une des opérations ci-dessus énoncées, doivent en assurer la confidentialité, quelle que soit l'issue de l'opération. Toutefois, dans l'hypothèse où l'opération susvisée aboutit, ces personnes peuvent à leur tour communiquer les informations couvertes par le secret professionnel dans les mêmes conditions que celles visées au présent article aux personnes avec lesquelles elles négocient, concluent ou exécutent les opérations mentionnées ci-dessus. »

Article 93

Après l'article L. 573-17 du même code, il est ajouté une section 5 ainsi rédigée :

« Section « 5

« Dispositions relatives aux gestionnaires de crédits

« *Art. L. 573-18.* – La méconnaissance par les personnes mentionnées à l'article L. 54-11-34 du secret professionnel est sanctionnée par les peines prévues aux articles 226-13 et 226-14 du code pénal. »

TITRE III

DISPOSITIONS RELATIVES AUX OUTRE-MER

CHAPITRE Ier

MODIFICATION DU CODE DE LA CONSOMMATION

Article 94

Le code de la consommation est ainsi modifié :

1° Au tableau de l'article L. 252-1, la ligne :

«

L. 222-1 à L. 222-6	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

»

est remplacée par les deux lignes suivantes :

«

L. 222-1 à L. 222-5	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 222-6	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

2° Au même tableau de l'article L. 252-1, la ligne :

«

L. 222-10 à L. 222-16	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

»

est remplacée par les cinq lignes suivantes :

«

L. 222-10	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 222-12	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 222-13, L. 222-15	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 222-15-1	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 222-16	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

».

Article 95

1° Au tableau de l'article L. 351-1, la ligne :

«

L. 311-1	Résultant de la loi n° 2017-203 du 21 février 2017

»

est remplacée par la ligne suivante :

«

L. 311-1	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

2° Au tableau de l'article L. 351-3 :

a) La ligne :

«

L. 312-1	Résultant de la loi n° 2017-203 du 21 février 2017

»

est remplacée par la ligne suivante :

«

L. 312-1	Résultant de de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

b) Les lignes :

«

L. 312-4	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016
L. 312-5 à L. 312-11	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-12 et L. 312-13	Résultant de l'ordonnance n° 2017-1433 du 4 octobre 2017
L. 312-14 à L. 312-16	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-17 et L. 312-18	Résultant de l'ordonnance n° 2017-1433 du 4 octobre 2017
L. 312-19 et L. 312-20	Résultant de la loi n° 2017-203 du 21 février 2017
L. 312-21 à L. 312-27	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-28 et L. 312-29	Résultant de l'ordonnance n° 2017-1433 du 4 octobre 2017

»

sont remplacées par les quatorze lignes suivantes :

«

L. 312-4 à L. 312-6	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 312-7 à L. 312-9	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-10	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 312-11	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-11-1 à L. 312-14	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 312-15	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-15-1 à L. 312-17	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 312-18	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-18-1 à L. 312-20	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 312-21	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-22 et. L. 312-23	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-24 à L. 312-26-1	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 312-27	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-28 et L. 312-29	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

c) Les lignes :

«

L. 312-31	Résultant de l'ordonnance n° 2017-1433 du 4 octobre 2017
L. 312-31-1	Résultant de l'ordonnance n° 2023-1139 du 6 décembre 2023

»

sont remplacées par la ligne suivante :

«

L. 312-31 et L. 312-31-1	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

d) Les lignes :

«

L. 312-33 à L. 312-35	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-35-1	Résultant de l'ordonnance n° 2023-1139 du 6 décembre 2023

»

sont remplacées par les deux lignes suivantes :

«

L. 312-33	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-34 à L. 312-35-2	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

e) La ligne :

«

L. 312-45 à L. 312-49	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

»

est remplacée par les trois lignes suivantes :

«

L. 312-45 et L. 312-46	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-47	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 312-48 et L. 312-49	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

» ;

f) La ligne :

«

L. 312-51 à L. 312-58	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

»

est remplacée par les trois lignes suivantes :

«

L. 312-51 à L. 312-53	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-54	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 312-55 à L. 312-58	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

» ;

g) Les lignes :

«

L. 312-82 à L. 312-84	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-85 à L. 312-89	Résultant de l'ordonnance n° 2017-1433 du 4 octobre 2017
L. 312-90	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-91 et L. 312-92	Résultant de l'ordonnance n° 2017-1433 du 4 octobre 2017
L. 312-93 et L. 312-94	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

»

sont remplacées par les deux lignes suivantes :

«

L. 312-82 et L. 312-83	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 312-88 à L. 312-94	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

3° A l'article L. 351-4 :

a) Au 1°, les mots : « Au 3° de l'article L. 312-4, » sont remplacés par les mots : « Au II de l'article L. 312-4-1 » ;

b) Le 3° est abrogé.

Article 96

1° Au tableau de l'article L. 351-5 :

a) La ligne :

«

L. 314-6	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016

»

est remplacée par la ligne suivante :

«

L. 314-6	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

b) Les lignes :

«

L. 314-22	Résultant de la loi n° 2017-203 du 21 février 2017
L. 314-23, à l'exception de son quatrième alinéa et de son dernier alinéa, L. 314-24 et L. 314-25	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016

»

sont remplacées par les quatre lignes suivantes :

«

L. 314-22	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 314-23, à l'exception de son quatrième alinéa et de son dernier alinéa	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016
L. 314-24 et L. 314-25	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

2° Le 2° de l'article L. 351-6 est remplacé par un alinéa ainsi rédigé :

« 2° A l'article L. 314-6, le montant : "100 000 euros" est converti en francs Pacifique selon la parité mentionnée à l'article D. 721-2 du code monétaire et financier ; »

3° Au tableau de l'article L. 351-7 :

a) La ligne :

«

L. 314-6	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016

»

est remplacée par la ligne suivante :

«

L. 314-6	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

b) Les lignes :

«

L. 314-22	Résultant de la loi n° 2017-203 du 21 février 2017
L. 314-23, à l'exception de son quatrième alinéa et de son dernier alinéa, L. 314-25 à L. 314-26	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016

»

sont remplacées par les quatre lignes suivantes :

«

L. 314-22	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025 du 3 septembre 2025
L. 314-23, à l'exception de son quatrième alinéa et de son dernier alinéa	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016
L. 314-24 et L. 314-25	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025 du 3 septembre 2025
L. 314-26	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016

» ;

4° L'article L. 351-8 est ainsi modifié :

a) Le 1° est remplacé par un alinéa ainsi rédigé :

« 1° A l'article L. 314-6, le montant : "100 000 euros" est converti en francs Pacifique selon la parité mentionnée à l'article D. 721-2 du code monétaire et financier ; »

b) Il est complété par un 5° ainsi rédigé :

« 5° A l'article L. 314-24, la référence au chapitre III est supprimée. » ;

5° Le tableau de l'article L. 354-2 est remplacé par le tableau suivant :

«

Articles applicables	Dans leur rédaction
L. 340-1 à L. 341-1-1	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 341-2 et L. 341-3	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 341-4	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 341-5	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 341-6	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 341-7	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 341-8 et L. 341-9	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 341-10 et L. 341-11	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 341-12 à L. 341-20	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 341-48-1	Résultant de l'ordonnance n° 2019-740 du 17 juillet 2019
L. 341-52-2	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

6° Après l'article L. 354-2, il est inséré un article L. 354-2-1 ainsi rédigé :

« *Art. L. 354-2-1.* – Pour l'application de l'article L. 354-2 :

« 1° Aux articles L. 340-2, L. 340-3, L. 341-1-1, L. 341-12 à L. 341-20 et L. 341-52-2, les montants en euros sont convertis en francs Pacifique selon la parité mentionnée à l'article D. 721-2 du code monétaire et financier ;

« 2° A l'article L. 341-15, la référence à l'article L. 314-11-1 est supprimée. » ;

7° Au tableau de l'article L. 354-3, la ligne :

«

L. 341-48 à L. 341-51 et L. 341-52	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016

»

est remplacée par les quatre lignes suivantes :

«

L. 341-48	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016
L. 341-49	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 341-50 et L. 341-51	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016
L. 341-51-1	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025
L. 341-52	Résultant de l'ordonnance n° 2016-351 du 25 mars 2016
L. 341-52-1	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

8° Après l'article L. 354-3, il est inséré un article L. 354-3-1 ainsi rédigé :

« *Art. L. 354-3-1.* – Pour l'application de l'article L. 354-3, les montants en euros mentionnés aux articles L. 341-49, L. 341-51-1 et L. 341-52-1 sont convertis en francs Pacifique selon la parité mentionnée à l'article D. 721-2 du code monétaire et financier. »

Article 97

1° Au tableau de l'article L. 771-2 :

a) Les lignes :

«

L. 751-1 à L. 751-4	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 751-5	Résultant de l'ordonnance n° 2018-1125 du 12 décembre 2018 prise en application de l'article 32 de la loi n° 2018-493 du 20 juin 2018 relative à la protection des données personnelles et portant modification de la loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés et diverses dispositions concernant la protection des données à caractère personnel.

»

sont remplacées par les deux lignes suivantes :

«

L. 751-1 et L. 751-2	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 751-3 à L. 751-5	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

b) La ligne :

«

L. 752-1	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016

»

est remplacée par la ligne suivante :

«

L. 752-1	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

2° Au tableau de l'article L. 771-5, les lignes :

«

L. 751-1 à L. 751-4	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 751-5	Résultant de l'ordonnance n° 2018-1125 du 12 décembre 2018 prise en application de l'article 32 de la loi n° 2018-493 du 20 juin 2018 relative à la protection des données personnelles et portant modification de la loi n° 78-17 du 6 janvier 1978 relative à l'informatique, aux fichiers et aux libertés et diverses dispositions concernant la protection des données à caractère personnel.

»

sont remplacées par les deux lignes suivantes :

«

L. 751-1 et L. 751-2	Résultant de l'ordonnance n° 2016-301 du 14 mars 2016
L. 751-3 à L. 751-5	Résultant de l'ordonnance n° 2025-880 du 3 septembre 2025

».

Chapitre II

Modification du code monétaire et financier

Article 98

Le code monétaire et financier est ainsi modifié :

1° Au tableau du I des articles L. 752-5, L. 753-5 et L. 754-3, la ligne :

«

L. 313-5	l'ordonnance n° 2016-301 du 14 mars 2016

»

est remplacée par la ligne suivante :

«

L. 313-5	l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

2° Au tableau du I des articles L. 773-2, L. 774-2 et L. 775-2, la ligne :

«

L. 511-7 à l'exception de ses troisième et neuvième alinéas	la loi n° 2018-1021 du 23 novembre 2018

»

est remplacée par la ligne suivante :

«

L. 511-7 à l'exception de ses troisième, neuvième et dixième alinéas	l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

3° Au tableau du I des articles L. 773-15, L. 774-15 et L. 775-14 :

a) La ligne :

«

L. 519-1-1	l'ordonnance n° 2016-351 du 25 mars 2016

»

est remplacée par la ligne suivante :

«

L. 519-1-1	l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

b) La ligne :

«

L. 519-4-1	l'ordonnance n° 2016-351 du 25 mars 2016

»

est remplacée par la ligne suivante :

«

L. 519-4-1	l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

c) Les lignes :

«

L. 519-6	la loi n° 2010-737 du 1er juillet 2010
L. 519-6-1	l'ordonnance n° 2016-351 du 25 mars 2016

»

sont remplacées par les lignes suivantes :

«

L. 519-6	l'ordonnance n° 2025-880 du 3 septembre 2025
L. 519-6-1	l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

4° Le tableau du I des articles L. 773-40-1, L. 774-40-1 et L. 775-34-1 est complété par une dernière ligne ainsi rédigée :

«

L. 54-11-34	l'ordonnance n° 2025-880 du 3 septembre 2025

» ;

5° L'intitulé de la sous-section 5 de la section 9 des chapitres III et IV et de la sous-section 4 de la section 8 du chapitre V du titre VII est ainsi modifié :

a) Le mot : « et » est remplacé par le signe : « , »

b) Après les mots : « aux intermédiaires en investissements participatifs », sont ajoutés les mots : « et aux gestionnaires de crédits » ;

6° Le tableau du I des articles L. 773-49, L. 774-49 et L. 775-42 est complété par une dernière ligne ainsi rédigée :

«

L. 573-18	l'ordonnance n° 2025-880 du 3 septembre 2025

».

TITRE IV

DISPOSITIONS TRANSITOIRES ET FINALES

Article 99

I. – La présente ordonnance entre en vigueur le 20 novembre 2026.

II. – Les contrats de crédit en cours au 20 novembre 2026 restent régis par les dispositions du code de la consommation et du code monétaire et financier dans leur rédaction antérieure à l'entrée en vigueur de la présente ordonnance.

III. – Par dérogation au II, les articles 34, 35, 43 à 45, 59 à 61, 64 et 72 s'appliquent à tous les contrats de crédit à durée indéterminée en cours à la date du 20 novembre 2026.

Article 100

Le Premier ministre, le ministre d'État, ministre des outre-mer, et le ministre de l'économie, des finances et de la souveraineté industrielle et numérique sont responsables, chacun en ce qui le concerne, de l'application de la présente ordonnance, qui sera publiée au *Journal officiel* de la République française.

Fait le 3 septembre 2025.

EMMANUEL MACRON

Par le Président de la République :

Le Premier ministre,
FRANÇOIS BAYROU

Le ministre de l'économie, des finances et de la souveraineté industrielle et numérique,
ÉRIC LOMBARD

Le ministre d'État, ministre des outre-mer,
MANUEL VALLS

Reports of Cases

JUDGMENT OF THE COURT (First Chamber)

7 December 2023 *

(Reference for a preliminary ruling – Protection of natural persons with regard to the processing of personal data – Regulation (EU) 2016/679 – Article 22 – Automated individual decision-making – Credit information agencies – Automated establishment of a probability value concerning the ability of a person to meet payment commitments in the future ('scoring') – Use of that probability value by third parties)

In Case C-634/21,

REQUEST for a preliminary ruling under Article 267 TFEU from the Verwaltungsgericht Wiesbaden (Administrative Court, Wiesbaden, Germany), made by decision of 1 October 2021, received at the Court on 15 October 2021, in the proceedings

OQ

v

Land Hessen,

intervener:

SCHUFA Holding AG,

THE COURT (First Chamber),

composed of A. Arabadjiev, President of the Chamber, T. von Danwitz, P.G. Xuereb, A. Kumin (Rapporteur) and I. Ziemele, Judges,

Advocate General: P. Pikamäe,

Registrar: C. Di Bella, Administrator,

having regard to the written procedure and further to the hearing on 26 January 2023,

after considering the observations submitted on behalf of:

– OQ, by U. Schmidt, Rechtsanwalt,

– the Land Hessen, by M. Kottmann and G. Ziegenhorn, Rechtsanwälte,

* Language of the case: German.

– SCHUFA Holding AG, by G. Thüsing and U. Wuermeling, Rechtsanwalt,

– the German Government, by P.-L. Krüger, acting as Agent,

– the Danish Government, by V. Pasternak Jørgensen, M. Søndahl Wolff and Y. Thyregod Kollberg, acting as Agents,

– the Portuguese Government, by P. Barros da Costa, I. Oliveira, J. Ramos and C. Vieira Guerra, acting as Agents,

– the Finnish Government, by M. Pere, acting as Agent,

– the European Commission, by A. Bouchagiar, F. Erlbacher and H. Kranenborg, acting as Agents,

after hearing the Opinion of the Advocate General at the sitting on 16 March 2023,

gives the following

Judgment

1 This request for a preliminary ruling concerns the interpretation of Article 6(1) and Article 22 of Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ 2016 L 119, p. 1, and corrigendum OJ 2018 L 127, p. 2; 'the GDPR').

2 The request has been made in proceedings between OQ and the Land Hessen (Federal State of Hesse, Germany) concerning the refusal of the Hessischer Beauftragter für Datenschutz und Informationsfreiheit (Data Protection and Freedom of Information Commissioner for the Federal State of Hesse, Germany; 'the HBDI') to order SCHUFA Holding AG ('SCHUFA') to grant an application lodged by OQ seeking to access and erase personal data concerning her.

Legal context

European Union law

3 Recital 71 of the GDPR provides:

'The data subject should have the right not to be subject to a decision, which may include a measure, evaluating personal aspects relating to him or her which is based solely on automated processing and which produces legal effects concerning him or her or similarly significantly affects him or her, such as automatic refusal of an online credit application or e-recruiting practices without any human intervention. Such processing includes "profiling" that consists of any form of automated processing of personal data evaluating the personal aspects relating to a natural person, in particular to analyse or predict aspects concerning the data subject's performance at work, economic situation, health, personal preferences or interests, reliability or behaviour, location or movements, where it produces legal effects concerning him or her or

similarly significantly affects him or her. However, decision-making based on such processing, including profiling, should be allowed where expressly authorised by Union or Member State law to which the controller is subject, including for fraud and tax-evasion monitoring and prevention purposes conducted in accordance with the regulations, standards and recommendations of [European] Union institutions or national oversight bodies and to ensure the security and reliability of a service provided by the controller, or necessary for the entering or performance of a contract between the data subject and a controller, or when the data subject has given his or her explicit consent. In any case, such processing should be subject to suitable safeguards, which should include specific information to the data subject and the right to obtain human intervention, to express his or her point of view, to obtain an explanation of the decision reached after such assessment and to challenge the decision. Such measure should not concern a child.

In order to ensure fair and transparent processing in respect of the data subject, taking into account the specific circumstances and context in which the personal data are processed, the controller should use appropriate mathematical or statistical procedures for the profiling, implement technical and organisational measures appropriate to ensure, in particular, that factors which result in inaccuracies in personal data are corrected and the risk of errors is minimised, secure personal data in a manner that takes account of the potential risks involved for the interests and rights of the data subject and that prevents, inter alia, discriminatory effects on natural persons on the basis of racial or ethnic origin, political opinion, religion or beliefs, trade union membership, genetic or health status or sexual orientation, or that result in measures having such an effect.'

4 Entitled 'Definitions', Article 4 of that regulation provides:

'For the purposes of this Regulation:

…

(4) "profiling" means any form of automated processing of personal data consisting of the use of personal data to evaluate certain personal aspects relating to a natural person, in particular to analyse or predict aspects concerning that natural person's performance at work, economic situation, health, personal preferences, interests, reliability, behaviour, location or movements;

…'

5 Entitled 'Principles relating to processing of personal data', Article 5 of that regulation provides:

'1. Personal data shall be:

(a) processed lawfully, fairly and in a transparent manner in relation to the data subject ("lawfulness, fairness and transparency");

(b) collected for specified, explicit and legitimate purposes and not further processed in a manner that is incompatible with those purposes; … ("purpose limitation");

(c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ("data minimisation");

(d) accurate and, where necessary, kept up to date; … (“accuracy”);

(e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed; … (“storage limitation”);

(f) processed in a manner that ensures appropriate security of the personal data … (“integrity and confidentiality”);

2. The controller shall be responsible for, and be able to demonstrate compliance with, paragraph 1 (“accountability”).’

6 Entitled ‘Lawfulness of processing’, Article 6 of the GDPR provides, in paragraphs 1 and 3 thereof:

‘1. Processing shall be lawful only if and to the extent that at least one of the following applies:

(a) the data subject has given consent to the processing of his or her personal data for one or more specific purposes;

(b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;

(c) processing is necessary for compliance with a legal obligation to which the controller is subject;

(d) processing is necessary in order to protect the vital interests of the data subject or of another natural person;

(e) processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller;

(f) processing is necessary for the purposes of the legitimate interests pursued by the controller or by a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data, in particular where the data subject is a child.

…

3. The basis for the processing referred to in point (c) and (e) of paragraph 1 shall be laid down by:

(a) Union law; or

(b) Member State law to which the controller is subject.

The purpose of the processing shall be determined in that legal basis or, as regards the processing referred to in point (e) of paragraph 1, shall be necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the controller. …’

7 Entitled ‘Processing of special categories of personal data’, Article 9 of that regulation is worded as follows:

‘1. Processing of personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, or trade union membership, and the processing of genetic data, biometric data for the purpose of uniquely identifying a natural person, data concerning health or data concerning a natural person’s sex life or sexual orientation shall be prohibited.

2. Paragraph 1 shall not apply if one of the following applies:

(a) the data subject has given explicit consent to the processing of those personal data for one or more specified purposes, except where Union or Member State law provide that the prohibition referred to in paragraph 1 may not be lifted by the data subject;

…

(g) processing is necessary for reasons of substantial public interest, on the basis of Union or Member State law which shall be proportionate to the aim pursued, respect the essence of the right to data protection and provide for suitable and specific measures to safeguard the fundamental rights and the interests of the data subject;

…’

8 Entitled ‘Information to be provided where personal data are collected from the data subject’, Article 13 of that regulation provides, in paragraph 2 thereof:

‘In addition to the information referred to in paragraph 1, the controller shall, at the time when personal data are obtained, provide the data subject with the following further information necessary to ensure fair and transparent processing:

…

(f) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.’

9 Entitled ‘Information to be provided where personal data have not been obtained from the data subject’, Article 14 of the GDPR provides, in paragraph 2 thereof:

‘In addition to the information referred to in paragraph 1, the controller shall provide the data subject with the following information necessary to ensure fair and transparent processing in respect of the data subject:

…

(g) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.’

10 Entitled 'Right of access by the data subject', Article 15 of that regulation provides, in paragraph 1 thereof:

'The data subject shall have the right to obtain from the controller confirmation as to whether or not personal data concerning him or her are being processed, and, where that is the case, access to the personal data and the following information:

…

(h) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.'

11 Entitled 'Automated individual decision-making, including profiling', Article 22 of that regulation provides:

'1. The data subject shall have the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning him or her or similarly significantly affects him or her.

2. Paragraph 1 shall not apply if the decision:

(a) is necessary for entering into, or performance of, a contract between the data subject and a data controller;

(b) is authorised by Union or Member State law to which the controller is subject and which also lays down suitable measures to safeguard the data subject's rights and freedoms and legitimate interests; or

(c) is based on the data subject's explicit consent.

3. In the cases referred to in points (a) and (c) of paragraph 2, the data controller shall implement suitable measures to safeguard the data subject's rights and freedoms and legitimate interests, at least the right to obtain human intervention on the part of the controller, to express his or her point of view and to contest the decision.

4. Decisions referred to in paragraph 2 shall not be based on special categories of personal data referred to in Article 9(1), unless point (a) or (g) of Article 9(2) applies and suitable measures to safeguard the data subject's rights and freedoms and legitimate interests are in place.'

12 Entitled 'Right to an effective judicial remedy against a supervisory authority', Article 78 of the GDPR provides, in paragraph 1 thereof:

'Without prejudice to any other administrative or non-judicial remedy, each natural or legal person shall have the right to an effective judicial remedy against a legally binding decision of a supervisory authority concerning them.'

German law

13 Entitled 'Protection of trade and commerce in the context of "scoring" and credit reports', Paragraph 31 of the Bundesdatenschutzgesetz (Federal Law on data protection) of 30 June 2017 (BGBl. I, p. 2097; 'the BDSG'), reads as follows:

'(1) The use of a probability value regarding specific future behaviour of a natural person for the purpose of deciding on the establishment, implementation or termination of a contractual relationship with that person ("scoring") shall be permissible only if

1. the provisions of data protection law have been complied with,

2. the data used to calculate the probability value are demonstrably relevant to the calculation of the probability of the specific behaviour, on the basis of a scientifically recognised mathematical statistical method,

3. the data used for the calculation of the probability value were not exclusively address data, and

4. where address data are used, the data subject has been notified of the intended use of such data before the calculation of the probability value; the notification must be documented.

(2) The use of a probability value determined by credit information agencies in relation to a natural person's ability and willingness to pay shall, in the case where information about claims against that person is taken into account, be permissible only if the conditions under subparagraph 1 are met and claims relating to a performance owed but not rendered despite falling due are taken into account only if they are claims

1. which have been established by a judgment which has become final or has been declared provisionally enforceable or for which there is a debt instrument pursuant to Paragraph 794 of the Zivilprozessordnung [(Code of Civil Procedure)],

2. which have been established in accordance with Paragraph 178 of the Insolvenzordnung [(Insolvency Code)] and not contested by the debtor at the meeting for verification of claims,

3. which the debtor has expressly acknowledged,

4. in respect of which
   (a) the debtor has been given formal notice in writing at least twice after the claim fell due,
   (b) the first formal notice was given at least four weeks previously,
   (c) the debtor has been informed in advance, but at the earliest at the time of the first formal notice, of the possibility that the claim might be taken into account by a credit information agency and
   (d) the debtor has not contested the claim, or

5. whose underlying contractual relationship may be terminated without notice on the ground of arrears in payment and in respect of which the debtor has been informed in advance of the possibility that account might be taken of them by a credit information agency.

The permissibility of the processing, including the determination of probability values and of other data relevant to creditworthiness, under general data protection law remains unaffected.'

The dispute in the main proceedings and the questions referred for a preliminary ruling

14 SCHUFA is a private company under German law which provides its contractual partners with information on the creditworthiness of third parties, in particular, consumers. To that end, it establishes a prognosis on the probability of a future behaviour of a person ('score'), such as the repayment of a loan, based on certain characteristics of that person, on the basis of mathematical and statistical procedures. The establishment of scores ('scoring') is based on the assumption that, by assigning a person to a group of other persons with comparable characteristics who have behaved in a certain way, similar behaviour can be predicted.

15 It is apparent from the request for a preliminary ruling that OQ was refused the granting of a loan by a third party after having been the subject of negative information established by SCHUFA and transmitted to that third party. OQ applied for SCHUFA to send her information on the personal data registered and to erase some of the data which was allegedly incorrect.

16 In response to that request, SCHUFA informed OQ of her score and outlined, in broad terms, the methods for calculating the scores. However, referring to trade secrecy, it refused to disclose the various elements taken into account for the purposes of that calculation and their weighting. Lastly, SCHUFA stated that it limited itself to sending information to its contractual partners and it was those contractual partners which made the actual contractual decisions.

17 By a complaint lodged on 18 October 2018, OQ asked the HBDI, the competent supervisory authority, to order SCHUFA to grant her request for access to information and erasure.

18 By decision of 3 June 2020, the HBDI rejected that application for an order, explaining that it was not established that SCHUFA did not comply with the requirements set out in Article 31 of the BDSG incumbent upon it with regard to its activity.

19 OQ appealed against that decision before the Verwaltungsgericht Wiesbaden (Administrative Court, Wiesbaden, Germany), the referring court, in accordance with Article 78(1) of the GDPR.

20 According to that court, it is important to determine, for the purposes of ruling on the dispute before it, whether the establishment of a probability value such as that at issue in the main proceedings constitutes automated individual decision-making within the meaning of Article 22(1) of the GDPR. If that question is answered in the affirmative, the lawfulness of that activity would be subject, under Article 22(2)(b) of that regulation, to the condition that that decision be authorised by EU law or Member State law to which the controller is subject.

21 In that regard, the referring court has doubts as to the argument that Article 22(1) of the GDPR is not applicable to the activity of companies such as SCHUFA. It bases its doubts, from a factual point of view, on the importance of a probability value such as that at issue in the main proceedings for the decision-making practice of third parties to which that probability value is transmitted and, from a legal point of view, mainly on the objectives pursued by that Article 22(1), and on the guarantees of legal protection enshrined by the GDPR.

22 More specifically, the referring court notes that it is the probability value which normally determines whether and how the third party will contract with the person concerned. Article 22 of the GDPR precisely aims to protect people against the risks linked to decisions purely based on automation.

23 By contrast, if Article 22(1) of the GDPR were to be interpreted as meaning that the status of 'automated individual decision-making' cannot be recognised, in a situation such as that at issue in the main proceedings, until the decision taken by the third party with regard to the data subject, this would result in a lacuna in legal protection. First, a company such as SCHUFA would not be required to provide access to the additional information to which the data subject is entitled under Article 15(1)(h) of that regulation because that company would not be the company which adopts 'automated decision-making' within the meaning of that provision and, consequently, within the meaning of Article 22(1) of that regulation. Secondly, the third party to whom the probability value is communicated could not provide that additional information because it does not have it.

24 Thus, according to the referring court, to avoid such a lacuna in legal protection, it would be necessary for the establishment of a probability value such as that at issue in the main proceedings to fall within the scope of application of Article 22(1) of the GDPR.

25 If such an interpretation were to be accepted, the lawfulness of that activity would then be subject to the existence of a legal basis at the level of the Member State concerned, under Article 22(2)(b) of that regulation. In the present case, while it is true that Article 31 of the BDSG may constitute such a legal basis in Germany, there are serious doubts as to the compatibility of that provision with Article 22 of the GDPR because the German legislature regulates only the 'use' of a probability value such as that at issue in the main proceedings, and not the establishment in itself of that value.

26 By contrast, if the establishment of such a probability value does not constitute automated individual decision-making within the meaning of Article 22 of the GDPR, the opening clause appearing in paragraph 2(b) of that Article 22 would also not apply to national regulations regarding that activity. In view of the exhaustive, in principle, nature of the GDPR and in the absence of any other normative competence for such national regulations, it seems that the German legislature, by subjecting the establishment of probability values to more advanced conditions of substantive lawfulness, specifies the regulated matter by going beyond the requirements set out in Articles 6 and 22 of the GDPR, without having regulatory power for this purpose. If this point of view were to be correct, this would modify the margin of examination of the national supervisory authority, which would then have to assess the compatibility of the activity of credit information agencies in the light of Article 6 of that regulation.

27 In those circumstances the Verwaltungsgericht Wiesbaden (Administrative Court, Wiesbaden) decided to stay the proceedings and to refer the following questions to the Court of Justice for a preliminary ruling:

'(1) Is Article 22(1) of the [GDPR] to be interpreted as meaning that the automated establishment of a probability value concerning the ability of a data subject to service a loan in the future already constitutes a decision based solely on automated processing, including profiling, which produces legal effects concerning the data subject or similarly significantly affects him or her, where that value, determined by means of personal data of the data subject, is transmitted by the controller to a third-party controller and the latter draws strongly on that value for its decision on the establishment, implementation or termination of a contractual relationship with the data subject?

(2) If the first question is answered in the negative:

are Articles 6(1) and 22 of the [GDPR] to be interpreted as precluding national legislation under which the use of a probability value – in the present case, in relation to a natural person's ability and willingness to pay, in the case where information about claims against that person is taken into account – regarding specific future behaviour of a natural person for the purpose of deciding on the establishment, implementation or termination of a contractual relationship with that person (scoring) is permissible only if certain further conditions, which are set out in more detail in the grounds of the request for a preliminary ruling, are met?'

Admissibility of the request for a preliminary ruling

28 SCHUFA challenges the admissibility of the request for a preliminary ruling by arguing, in the first place, that the referring court is not called upon to review the content of a decision on a complaint, adopted by a supervisory authority such as the HBDI, since the judicial remedy against such a decision, provided for in Article 78(1) of the GDPR, serves only to verify whether that authority has complied with the obligations incumbent upon it under that regulation, in particular that of processing complaints, it being specified that that authority has discretion to decide whether and how it should act.

29 In the second place, SCHUFA maintains that the referring court does not set out the specific reasons why the questions referred would be decisive for the resolution of the dispute in the main proceedings. The purpose of the latter would be a request for information on an actual score and the erasure of that score. In the present case, SCHUFA has sufficiently complied with its information obligation and has already erased the score subject to the procedure.

30 In that regard, it should be borne in mind that, according to settled case-law of the Court, it is solely for the national court hearing the case, which must assume responsibility for the subsequent judicial decision, to determine, with regard to the particular aspects of the case, both the need for a preliminary ruling in order to enable it to deliver judgment and the relevance of the questions which it refers to the Court. Consequently, where the questions submitted concern the interpretation of a rule of EU law, the Court is in principle bound to give a ruling (judgment of 12 January 2023, *DOBELES HES*, C-702/20 and C-17/21, EU:C:2023:1, paragraph 46 and the case-law cited).

31 Accordingly, questions concerning EU law enjoy a presumption of relevance. The Court may refuse to give a ruling on a question referred by a national court only where it is quite obvious that the interpretation of a rule of EU law that is sought bears no relation to the actual facts of the main action or its purpose, where the problem is hypothetical, or where the Court does not have before it the factual or legal material necessary to give a useful answer to the questions submitted to it (judgment of 12 January 2023, *DOBELES HES*, C-702/20 and C-17/21, EU:C:2023:1, paragraph 47 and the case-law cited).

32 As regards, in the first place, the plea of inadmissibility based on an allegedly limited judicial review to which decisions on complaints adopted by a supervisory authority are subject, it should be borne in mind that, under Article 78(1) of the GDPR, without prejudice to any other administrative or non-judicial remedy, each natural or legal person is to have the right to an effective judicial remedy against a legally binding decision of a supervisory authority concerning them.

33 In the present case, the decision adopted by the HBDI as supervisory authority constitutes a legally binding decision, within the meaning of Article 78(1) of the GDPR. Having examined the merits of the complaint brought before it, that authority ruled on it and found that the processing of personal data contested by the applicant in the main proceedings was lawful.

34 With regard to the extent of the judicial review exercised over such a decision in the context of an action brought under Article 78(1), it is sufficient to note that a decision on a complaint adopted by a supervisory authority is subject to full judicial review (judgment of 7 December 2023, *SCHUFA Holding (Discharge from remaining debts)*, C-26/22 and C-64/22, EU:C:2023:XXX, point 1 of the operative part).

35 The first plea of inadmissibility put forward by SCHUFA must therefore be rejected.

36 In the second place, it is clear from the request for a preliminary ruling that the referring court questions the criterion of review to be used when assessing, in the light of the GDPR, the processing of the personal data at issue in the main proceedings, that criterion depending on the applicability or not of Article 22(1) of that regulation.

37 Thus, it is not clear that the interpretation of the GDPR sought by the referring court bears no relation to the actual facts of the main action or its purpose and that the problem is hypothetical. Furthermore, the Court has before it the factual or legal material necessary to give a useful answer to the questions submitted to it.

38 Accordingly, the second plea of inadmissibility put forward by SCHUFA must also be rejected.

39 In those circumstances, the request for a preliminary ruling is admissible.

Consideration of the questions referred

The first question

40 By its first question, the referring court asks, in essence, whether Article 22(1) of the GDPR must be interpreted as meaning that the automated establishment, by a credit information agency, of a probability value based on personal data relating to a person and concerning his or her ability to meet payment commitments in the future constitutes 'automated individual decision-making' within the meaning of that provision, where a third party, to which that probability value is transmitted, draws strongly on that probability value to establish, implement or terminate a contractual relationship with that person.

41 In order to answer that question, it should be borne in mind, as a preliminary point, that the interpretation of a provision of EU law requires that account be taken not only of its wording, but also of its context and the objectives and purpose pursued by the act of which it forms part (judgment of 22 June 2023, *Pankki S*, C-579/21, EU:C:2023:501, paragraph 38 and the case-law cited).

42 As regards the wording of Article 22(1) of the GDPR, that provision provides that the data subject is to have the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning him or her or similarly significantly affects him or her.

43 The applicability of that provision is therefore subject to three cumulative conditions, namely, first, that there must be a 'decision', secondly, that that decision must be 'based solely on automated processing, including profiling', and, thirdly, that it must produce 'legal effects concerning [the interested party]' or 'similarly significantly [affect] him or her'.

44 As regards, first, the condition relating to the existence of a decision, it should be noted that the concept of 'decision', within the meaning of Article 22(1) of the GDPR, is not defined by that regulation. However, it is apparent from the very wording of that provision that that concept refers not only to acts which produce legal effects concerning the person at issue but also to acts which similarly significantly affect him or her.

45 The broad scope of the concept of 'decision' is confirmed by recital 71 of the GDPR, according to which a decision evaluating personal aspects relating to a person, to which that person should have the right not to be subject, 'may include a measure' which either produces 'legal effects concerning him or her', or, 'similarly significantly affects him or her'. Under that recital, the term 'decision' covers, for example, the automatic refusal of an online credit application or e-recruiting practices without human intervention.

46 The concept of 'decision' within the meaning of Article 22(1) of the GDPR is thus, as the Advocate General noted in point 38 of his Opinion, capable of including a number of acts which may affect the data subject in many ways, since that concept is broad enough to encompass the result of calculating a person's creditworthiness in the form of a probability value concerning that person's ability to meet payment commitments in the future.

47 As regards, secondly, the condition according to which the decision, within the meaning of that Article 22(1), must be 'based solely on automated processing, including profiling', as the Advocate General noted in point 33 of his Opinion, it is common ground that an activity such as that of SCHUFA meets the definition of 'profiling' appearing in Article 4(4) of the GDPR and therefore that that condition is met in the present case, since the wording of the first question referred explicitly refers to the automated establishment of a probability value based on personal data relating to a person and concerning that person's ability to repay a loan in the future.

48 As regards, thirdly, the condition that the decision must produce 'legal effects' concerning the person at issue or affect him or her 'similarly significantly', it is apparent from the very wording of the first question referred that the action of the third party to whom the probability value is transmitted draws 'strongly' on that value. Thus, according to the factual findings of the referring court, in the event where a loan application is sent by a consumer to a bank, an insufficient probability value leads, in almost all cases, to the refusal of that bank to grant the loan applied for.

49 In those circumstances, it must be stated that the third condition to which the application of Article 22(1) of the GDPR is subject is also fulfilled, since a probability value such as that at issue in the main proceedings affects, at the very least, the data subject significantly.

50 It follows that, in circumstances such as those at issue in the main proceedings, in which the probability value established by a credit information agency and communicated to a bank plays a determining role in the granting of credit, the establishment of that value must be qualified in itself as a decision producing vis-à-vis a data subject 'legal effects concerning him or her or similarly significantly [affecting] him or her' within the meaning of Article 22(1) of the GDPR.

51 That interpretation is corroborated by the context in which Article 22(1) of the GDPR takes place and by the objectives and purpose pursued by that regulation.

52 In this regard, it is important to note that, as the Advocate General observed in point 31 of his Opinion, Article 22(1) of the GDPR confers on the data subject the 'right' not to be the subject of a decision solely based on automated processing, including profiling. That provision lays down a prohibition in principle, the infringement of which does not need to be invoked individually by such a person.

53 As follows from a combined reading of Article 22(2) of the GDPR and recital 71 of that regulation, the adoption of a decision based solely on automated processing is authorised only in the cases referred to in that Article 22(2), namely where that decision is necessary for entering into, or performance of, a contract between the data subject and a data controller (point (a)), where it is authorised by EU or Member State law to which the controller is subject and which also lays down suitable measures to safeguard the data subject's rights and freedoms and legitimate interests (point (b)), or where it is based on the data subject's explicit consent (point (c)).

54 Furthermore, Article 22 of the GDPR provides, in paragraphs 2(b) and 3 thereof, that suitable measures to safeguard the data subject's rights and freedoms and legitimate interests must be taken. In the cases referred to in points (a) and (c) of Article 22(2) of that regulation, the data controller is to implement at least the right of the data subject to obtain human intervention, to express his or her point of view and to contest the decision.

55 In addition, under Article 22(4) of the GDPR, it is only in certain specific cases that automated individual decision-making within the meaning of Article 22 are to be based on special categories of personal data referred to in Article 9(1) of that regulation.

56 Furthermore, in the case of automated decision-making, such as that referred to in Article 22(1) of the GDPR, first, the controller is subject to additional information obligations under Article 13(2)(f) and Article 14(2)(g) of that regulation. Secondly, the data subject enjoys, under Article 15(1)(h) of that regulation, the right to obtain from the controller, in particular, 'meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject'.

57 Those enhanced requirements as to the lawfulness of automated decision-making and the additional information obligations of the controller and the related additional rights of access of the data subject are explained by the purpose pursued by Article 22 of the GDPR, consisting of protecting individuals against the particular risks to their rights and freedoms represented by the automated processing of personal data, including profiling.

58 That processing involves, as is apparent from recital 71 of the GDPR, the evaluation of personal aspects relating to the natural person concerned by that processing, in particular to analyse or predict aspects concerning the data subject's performance at work, economic situation, health, personal preferences or interests, reliability or behaviour, location or movements.

59 Those particular risks are, under that recital, likely to weigh on the legitimate interests and rights of the data subject, in particular taking account of discriminatory effects on natural persons on the basis of racial or ethnic origin, political opinion, religion or beliefs, trade union membership, genetic or health status or sexual orientation. It is therefore important, still according to that recital, to provide suitable safeguards and to ensure fair and transparent processing in respect of

the data subject, in particular through the use of appropriate mathematical or statistical procedures for the profiling and the implementation of technical and organisational measures appropriate to ensure that the risk of errors is minimised.

60 The interpretation set out in paragraphs 42 to 50 of this judgment, and in particular the broad scope of the concept of 'decision' within the meaning of Article 22(1) of the GDPR, reinforces the effective protection intended by that provision.

61 On the other hand, in circumstances such as those at issue in the main proceedings, in which three stakeholders are involved, there would be a risk of circumventing Article 22 of the GDPR and, consequently, a lacuna in legal protection if a restrictive interpretation of that provision was retained, according to which the establishment of the probability value must only be considered as a preparatory act and only the act adopted by the third party can, where appropriate, be classified as a 'decision' within the meaning of Article 22(1) of that regulation.

62 In that situation, the establishment of a probability value such as that at issue in the main proceedings would escape the specific requirements provided for in Article 22(2) to (4) of the GDPR, even though that procedure is based on automated processing and that it produces effects significantly affecting the data subject to the extent that the action of the third party to whom that probability value is transmitted draws strongly on it.

63 Furthermore, as the Advocate General noted in point 48 of his Opinion, first, the data subject would not be able to assert, from the credit information agency which establishes the probability value concerning him or her, his or her right of access to the specific information referred to in Article 15(1)(h) of the GDPR, in the absence of automated decision-making by that company. Secondly, even assuming that the act adopted by the third party falls within the scope of Article 22(1) of that regulation in so far as it fulfils the conditions for application of that provision, that third party would not be able to provide that specific information because it generally does not have it.

64 The fact that the establishment of a probability value such as that at issue in the main proceedings is covered by Article 22(1) of the GDPR has the consequence, as noted in paragraphs 53 to 55 of this judgment, that it is prohibited unless one of the exceptions set out in Article 22(2) of that regulation is applicable and the specific requirements provided for in Article 22(3) and (4) of that regulation are complied with.

65 With regard, more specifically, to Article 22(2)(b) of the GDPR, to which the referring court refers, it is apparent from the very wording of that provision that the national law which authorises the adoption of an automated individual decision must lay down suitable measures to safeguard the data subject's rights and freedoms and legitimate interests.

66 In the light of recital 71 of the GDPR, such measures must include, in particular, the obligation for the controller to use appropriate mathematical or statistical procedures, implement technical and organisational measures appropriate to ensure that the risk of errors is minimised and inaccuracies are corrected, and secure personal data in a manner that takes account of the potential risks involved for the interests and rights of the data subject and prevent, inter alia, discriminatory effects on that person. Those measures include, moreover, at least the right for the data subject to obtain human intervention on the part of the controller, to express his or her point of view and to challenge the decision taken in his or her regard.

67 It is also important to note that, in accordance with the settled case-law of the Court, any processing of personal data must, first, comply with the principles relating to the processing of data established in Article 5 of the GDPR and, secondly, in the light, in particular, of the principle of the lawfulness of processing, laid down in Article 5(1)(a), satisfy one of the conditions of the lawfulness of the processing listed in Article 6 of that regulation (judgment of 20 October 2022, *Digi*, C-77/21, EU:C:2022:805, paragraph 49 and the case-law cited). The controller must be able to demonstrate compliance with those principles, in accordance with the principle of accountability set out in Article 5(2) of that regulation (see, to that effect, judgment of 20 October 2022, *Digi*, C-77/21, EU:C:2022:805, paragraph 24).

68 Thus, in the event that the law of a Member State authorises, under Article 22(2)(b) of the GDPR, the adoption of a decision solely based on automated processing, that processing must comply not only with the conditions set out in the latter provision and in Article 22(4) of that regulation, but also with the requirements set out in Articles 5 and 6 of that regulation. Accordingly, Member States cannot adopt, under Article 22(2)(b) of the GDPR, regulations which authorise profiling in disregard of the requirements laid down by those Articles 5 and 6, as interpreted by the case-law of the Court.

69 With regard in particular to the conditions of lawfulness, provided for in Article 6(1)(a), (b), and (f) of the GDPR, which are likely to apply in a case such as that at issue in the main proceedings, Member States are not empowered to provide additional rules for the implementation of those conditions, such an option being, in accordance with Article 6(3) of that regulation, limited to the reasons referred to in Article 6(1)(c) and (e) of that regulation.

70 Furthermore, with regard more specifically to Article 6(1)(f) of the GDPR, Member States cannot, under Article 22(2)(b) of that regulation, dismiss the requirements resulting from the case-law of the Court following the judgment of 7 December 2023, *SCHUFA Holding (Discharge from remaining debts)* (C-26/22 and C-64/22, EU:C:2023:XXX), in particular, by definitively prescribing the result of the balancing of the rights and interests at issue (see, to that effect, judgment of 19 October 2016, *Breyer*, C-582/14, EU:C:2016:779, paragraph 62).

71 In the present case, the referring court states that only Paragraph 31 of the BDSG could constitute a national legal basis for the purposes of Article 22(2)(b) of the GDPR. However, it has serious doubts as to the compatibility of Paragraph 31 of the BDSG with EU law. Assuming that that provision is deemed incompatible with EU law, SCHUFA would act not only without legal basis, but would *ipso iure* disregard the prohibition laid down in Article 22(1) of the GDPR.

72 In this regard, it is for the referring court to verify whether Paragraph 31 of the BDSG can be classified as a legal basis authorising, under Article 22(2)(b) of the GDPR, the adoption of a decision solely based on automated processing. If that court were to reach the conclusion that Paragraph 31 of the BDSG constitutes such a legal basis, it would still be up to it to verify whether the conditions set out in Article 22(2)(b) and (4) of the GDPR and those laid down in Articles 5 and 6 of that regulation are fulfilled in this case.

73 In the light of all the foregoing considerations, the answer to the first question is that Article 22(1) of the GDPR must be interpreted as meaning that the automated establishment, by a credit information agency, of a probability value based on personal data relating to a person and concerning his or her ability to meet payment commitments in the future constitutes ‘automated

individual decision-making' within the meaning of that provision, where a third party, to which that probability value is transmitted, draws strongly on that probability value to establish, implement or terminate a contractual relationship with that person.

The second question

74 Given the answer to the first question, there is no need to answer the second question.

Costs

75 Since these proceedings are, for the parties to the main proceedings, a step in the action pending before the referring court, the decision on costs is a matter for that court. Costs incurred in submitting observations to the Court, other than the costs of those parties, are not recoverable.

On those grounds, the Court (First Chamber) hereby rules:

Article 22(1) of Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)

must be interpreted as meaning that the automated establishment, by a credit information agency, of a probability value based on personal data relating to a person and concerning his or her ability to meet payment commitments in the future constitutes 'automated individual decision-making' within the meaning of that provision, where a third party, to which that probability value is transmitted, draws strongly on that probability value to establish, implement or terminate a contractual relationship with that person.

[Signatures]

Reports of Cases

JUDGMENT OF THE COURT (First Chamber)

27 February 2025*

(Reference for a preliminary ruling – Protection of personal data – Regulation (EU) 2016/679 – Article 15(1)(h) – Automated decision-making, including profiling – Scoring – Assessment of the creditworthiness of a natural person – Access to meaningful information about the logic involved in profiling – Verification of the accuracy of the information provided – Directive (EU) 2016/943 – Point 1 of Article 2 – Trade secret – Personal data of third parties)

In Case C-203/22,

REQUEST for a preliminary ruling under Article 267 TFEU from the Verwaltungsgericht Wien (Administrative Court, Vienna, Austria), made by decision of 11 February 2022, received at the Court on 16 March 2022, in the proceedings

CK

v

Magistrat der Stadt Wien

other party:

Dun & Bradstreet Austria GmbH,

THE COURT (First Chamber),

composed of K. Lenaerts, President of the Court, acting as President of the First Chamber, T. von Danwitz (Rapporteur), Vice-President of the Court, A. Kumin, N. Jääskinen and I. Ziemele, Judges,

Advocate General: J. Richard de la Tour,

Registrar: A. Calot Escobar,

having regard to the written procedure,

after considering the observations submitted on behalf of:

– CK, by C. Wirthensohn, Rechtsanwalt,

* Language of the case: German.

– Dun & Bradstreet Austria GmbH, by D. Cooper, Solicitor, A.-S. Oberschelp de Meneses, avocate, K. Van Quathem and B. Van Vooren, advocaten,

– the Spanish Government, by A. Ballesteros Panizo, acting as Agent,

– the Netherlands Government, by M.K. Bulterman and C.S. Schillemans, acting as Agents,

– the Polish Government, by B. Majczyna, acting as Agent,

– the European Commission, by A. Bouchagiar, F. Erlbacher and H. Kranenborg, acting as Agents,

after hearing the Opinion of the Advocate General at the sitting on 12 September 2024,

gives the following

Judgment

1 This request for a preliminary ruling concerns the interpretation, first, of Article 15(1)(h) and Article 22 of Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ 2016 L 119, p. 1; 'the GDPR'), and, second, of point 1 of Article 2 of Directive (EU) 2016/943 of the European Parliament and of the Council of 8 June 2016 on the protection of undisclosed know-how and business information (trade secrets) against their unlawful acquisition, use and disclosure (OJ 2016 L 157, p. 1).

2 The request has been made in the proceedings between CK and the Magistrat der Stadt Wien (City Council of Vienna, Austria) concerning the enforcement of a court order requiring Bisnode Austria GmbH, now Dun & Bradstreet Austria GmbH ('D & B'), an undertaking specialising in the provision of credit assessments, to provide CK with meaningful information about the logic involved in profiling relating to her personal data.

Legal context

European Union law

The GDPR

3 Recitals 4, 11, 58, 63 and 71 of the GDPR state:

'(4) The processing of personal data should be designed to serve mankind. The right to the protection of personal data is not an absolute right; it must be considered in relation to its function in society and be balanced against other fundamental rights, in accordance with the principle of proportionality. This Regulation respects all fundamental rights and observes the freedoms and principles recognised in the [Charter of Fundamental Rights of the European Union ("the Charter")] as enshrined in the Treaties, in particular the respect for private and

family life, home and communications, the protection of personal data, freedom of thought, conscience and religion, freedom of expression and information, freedom to conduct a business, the right to an effective remedy and to a fair trial, and cultural, religious and linguistic diversity.

…

(11) Effective protection of personal data throughout the [European] Union requires the strengthening and setting out in detail of the rights of data subjects and the obligations of those who process and determine the processing of personal data, as well as equivalent powers for monitoring and ensuring compliance with the rules for the protection of personal data and equivalent sanctions for infringements in the Member States.

…

(58) The principle of transparency requires that any information addressed to the public or to the data subject be concise, easily accessible and easy to understand, and that clear and plain language and, additionally, where appropriate, visualisation be used. …

…

(63) A data subject should have the right of access to personal data which have been collected concerning him or her, and to exercise that right easily and at reasonable intervals, in order to be aware of, and verify, the lawfulness of the processing. … That right should not adversely affect the rights or freedoms of others, including trade secrets or intellectual property and in particular the copyright protecting the software. However, the result of those considerations should not be a refusal to provide all information to the data subject. …

…

(71) The data subject should have the right not to be subject to a decision, which may include a measure, evaluating personal aspects relating to him or her which is based solely on automated processing and which produces legal effects concerning him or her or similarly significantly affects him or her, such as automatic refusal of an online credit application or e-recruiting practices without any human intervention. Such processing includes "profiling" that consists of any form of automated processing of personal data evaluating the personal aspects relating to a natural person, in particular to analyse or predict aspects concerning the data subject's performance at work, economic situation, health, personal preferences or interests, reliability or behaviour, location or movements, where it produces legal effects concerning him or her or similarly significantly affects him or her. … In any case, such processing should be subject to suitable safeguards, which should include specific information to the data subject and the right to obtain human intervention, to express his or her point of view, to obtain an explanation of the decision reached after such assessment and to challenge the decision. …'

4 Article 4 of that regulation, entitled 'Definitions', provides, in point 4:

'For the purposes of this Regulation:

…

(4) “profiling” means any form of automated processing of personal data consisting of the use of personal data to evaluate certain personal aspects relating to a natural person, in particular to analyse or predict aspects concerning that natural person’s performance at work, economic situation, health, personal preferences, interests, reliability, behaviour, location or movements’.

5 Article 12 of the GDPR, entitled ‘Transparent information, communication and modalities for the exercise of the rights of the data subject’, provides, in paragraph 1:

‘The controller shall take appropriate measures to provide any information referred to in Articles 13 and 14 and any communication under Articles 15 to 22 and 34 relating to processing to the data subject in a concise, transparent, intelligible and easily accessible form, using clear and plain language, in particular for any information addressed specifically to a child. …’

6 Article 13 of that regulation, which concerns the information to be provided where personal data are collected from the data subject, and Article 14 thereof, which concerns the information to be provided where personal data have not been obtained from the data subject, provide, in paragraph 2(f) and paragraph 2(g), respectively, that the controller, to ensure fair and transparent processing in respect of the data subject, must provide the data subject with, inter alia, information as to ‘the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject’.

7 Article 15 of the GDPR, entitled ‘Right of access by the data subject’, is worded as follows:

‘1. The data subject shall have the right to obtain from the controller confirmation as to whether or not personal data concerning him or her are being processed, and, where that is the case, access to the personal data and the following information:

…

(h) the existence of automated decision-making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.

…

3. The controller shall provide a copy of the personal data undergoing processing. For any further copies requested by the data subject, the controller may charge a reasonable fee based on administrative costs. Where the data subject makes the request by electronic means, and unless otherwise requested by the data subject, the information shall be provided in a commonly used electronic form.

4. The right to obtain a copy referred to in paragraph 3 shall not adversely affect the rights and freedoms of others.’

8 Article 22 of that regulation, entitled 'Automated individual decision-making, including profiling', provides:

'1. The data subject shall have the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning him or her or similarly significantly affects him or her.

2. Paragraph 1 shall not apply if the decision:

(a) is necessary for entering into, or performance of, a contract between the data subject and a data controller;

(b) is authorised by Union or Member State law to which the controller is subject and which also lays down suitable measures to safeguard the data subject's rights and freedoms and legitimate interests; or

(c) is based on the data subject's explicit consent.

3. In the cases referred to in points (a) and (c) of paragraph 2, the data controller shall implement suitable measures to safeguard the data subject's rights and freedoms and legitimate interests, at least the right to obtain human intervention on the part of the controller, to express his or her point of view and to contest the decision.

4. Decisions referred to in paragraph 2 shall not be based on special categories of personal data referred to in Article 9(1), unless point (a) or (g) of Article 9(2) applies and suitable measures to safeguard the data subject's rights and freedoms and legitimate interests are in place.'

9 As set out in Article 23 of the GDPR, headed 'Restrictions':

'1. Union or Member State law to which the data controller or processor is subject may restrict by way of a legislative measure the scope of the obligations and rights provided for in Articles 12 to 22 and Article 34, as well as Article 5 in so far as its provisions correspond to the rights and obligations provided for in Articles 12 to 22, when such a restriction respects the essence of the fundamental rights and freedoms and is a necessary and proportionate measure in a democratic society to safeguard:

…

(i) the protection of the data subject or the rights and freedoms of others;

…

2. In particular, any legislative measure referred to in paragraph 1 shall contain specific provisions at least, where relevant, as to:

(a) the purposes of the processing or categories of processing;

(b) the categories of personal data;

(c) the scope of the restrictions introduced;

(d) the safeguards to prevent abuse or unlawful access or transfer;

(e) the specification of the controller or categories of controllers;

(f) the storage periods and the applicable safeguards taking into account the nature, scope and purposes of the processing or categories of processing;

(g) the risks to the rights and freedoms of data subjects; and

(h) the right of data subjects to be informed about the restriction, unless that may be prejudicial to the purpose of the restriction.'

10 Article 54 of that regulation, entitled 'Rules on the establishment of the supervisory authority', provides, in paragraph 2:

'The member or members and the staff of each supervisory authority shall, in accordance with Union or Member State law, be subject to a duty of professional secrecy both during and after their term of office, with regard to any confidential information which has come to their knowledge in the course of the performance of their tasks or exercise of their powers. During their term of office, that duty of professional secrecy shall in particular apply to reporting by natural persons of infringements of this Regulation.'

11 Article 58 of the GDPR, headed 'Powers', provides, in paragraph 1(e):

'Each supervisory authority shall have all of the following investigative powers:

(e) to obtain, from the controller and the processor, access to all personal data and to all information necessary for the performance of its tasks'.

Directive 2016/943

12 Recital 35 of Directive 2016/943 states:

'… this Directive should not affect the rights and obligations laid down in Directive 95/46/EC [of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data (OJ 1995 L 281, p. 31)], in particular the rights of the data subject to access his or her personal data being processed and to obtain the rectification, erasure or blocking of the data where it is incomplete or inaccurate …'

13 Point 1 of Article 2 of that directive provides:

'For the purposes of this Directive, the following definitions apply:

(1) "trade secret" means information which meets all of the following requirements:
   (a) it is secret in the sense that it is not, as a body or in the precise configuration and assembly of its components, generally known among or readily accessible to persons within the circles that normally deal with the kind of information in question;
   (b) it has commercial value because it is secret;

(c) it has been subject to reasonable steps under the circumstances, by the person lawfully in control of the information, to keep it secret'.

14 Article 9 of the directive, entitled 'Preservation of confidentiality of trade secrets in the course of legal proceedings', provides:

'1. Member States shall ensure that the parties, their lawyers or other representatives, court officials, witnesses, experts and any other person participating in legal proceedings relating to the unlawful acquisition, use or disclosure of a trade secret, or who has access to documents which form part of those legal proceedings, are not permitted to use or disclose any trade secret or alleged trade secret which the competent judicial authorities have, in response to a duly reasoned application by an interested party, identified as confidential and of which they have become aware as a result of such participation or access. In that regard, Member States may also allow competent judicial authorities to act on their own initiative.

The obligation referred to in the first subparagraph shall remain in force after the legal proceedings have ended. However, such obligation shall cease to exist in any of the following circumstances:

(a) where the alleged trade secret is found, by a final decision, not to meet the requirements set out in point 1 of Article 2; or

(b) where[,] over time, the information in question becomes generally known among or readily accessible to persons within the circles that normally deal with that kind of information.

2. Member States shall also ensure that the competent judicial authorities may, on a duly reasoned application by a party, take specific measures necessary to preserve the confidentiality of any trade secret or alleged trade secret used or referred to in the course of legal proceedings relating to the unlawful acquisition, use or disclosure of a trade secret. Member States may also allow competent judicial authorities to take such measures on their own initiative.

The measures referred to in the first subparagraph shall at least include the possibility:

(a) of restricting access to any document containing trade secrets or alleged trade secrets submitted by the parties or third parties, in whole or in part, to a limited number of persons;

(b) of restricting access to hearings, when trade secrets or alleged trade secrets may be disclosed, and the corresponding record or transcript of those hearings to a limited number of persons;

(c) of making available to any person other than those comprised in the limited number of persons referred to in points (a) and (b) a non-confidential version of any judicial decision, in which the passages containing trade secrets have been removed or redacted.

The number of persons referred to in points (a) and (b) of the second subparagraph shall be no greater than necessary in order to ensure compliance with the right of the parties to the legal proceedings to an effective remedy and to a fair trial, and shall include, at least, one natural person from each party and the respective lawyers or other representatives of those parties to the legal proceedings.

3. When deciding on the measures referred to in paragraph 2 and assessing their proportionality, the competent judicial authorities shall take into account the need to ensure the right to an effective remedy and to a fair trial, the legitimate interests of the parties and, where appropriate, of third parties, and any potential harm for either of the parties, and, where appropriate, for third parties, resulting from the granting or rejection of such measures.

4. Any processing of personal data pursuant to paragraphs 1, 2 or 3 shall be carried out in accordance with [Directive 95/46].'

Austrian law

15 Paragraph 4(6) of the Datenschutzgesetz (Law on Data Protection) of 17 August 1999 (BGBl. I, 165/1999), in its version applicable to the main proceedings ('the DSG'), precludes, as a rule, the data subject from having access to his or her personal data, provided for in Article 15 of the GDPR, where such access would compromise a business or trade secret of the controller or of a third party.

The dispute in the main proceedings and the questions referred for a preliminary ruling

16 CK was refused, by a mobile telephone operator, the conclusion or extension of a mobile telephone contract which would have required a monthly payment of EUR 10 on the ground that, according to an automated credit assessment, carried out by D & B, she did not have sufficient financial creditworthiness.

17 CK brought the matter before the Austrian data protection authority, which ordered D & B to disclose to CK meaningful information about the logic involved in the automated decision-making based on personal data concerning CK.

18 D & B brought an action against that decision before the Bundesverwaltungsgericht (Federal Administrative Court, Austria), claiming, in essence, that, due to a protected trade secret, it did not have to disclose to CK any information in addition to the information that had already been provided to her.

19 By decision of 23 October 2019 ('the decision of 23 October 2019'), that court found that D & B had infringed Article 15(1)(h) of the GDPR by failing to provide CK with meaningful information about the logic involved in the automated decision-making based on personal data concerning CK, or, at the very least, by failing to give a sufficient statement of reasons as to why it was unable to provide that information.

20 In particular, in that decision, the Bundesverwaltungsgericht (Federal Administrative Court) noted that D & B had not provided CK with sufficient explanations to enable her to understand how the prognosis on the probability of her future behaviour ('score') had been established in relation to her, which that undertaking communicated to CK, stating that, with a view to obtaining that 'score', certain socio-demographic data concerning CK had been 'given equal weighting'.

21 The decision of 23 October 2019 has become final and is enforceable under Austrian law. However, CK's application for enforcement of that decision, lodged by CK with the City Council of Vienna, which is the enforcing authority, was rejected on the ground that D & B had met, to the requisite standard, its obligation to provide information, even though that company had not provided any additional information after that decision was adopted.

22 CK brought an action against the decision of the City Council of Vienna before the Verwaltungsgericht Wien (Administrative Court, Vienna, Austria), which is the referring court, seeking enforcement of the decision of 23 October 2019.

23 The referring court takes the view that, under Austrian law, it is required to have that decision enforced, which would mean having to determine the specific acts that D & B is required to carry out pursuant to that decision.

24 Taking the view that that determination can only be made by an expert with the requisite expertise, the referring court appointed an expert who took the view that D & B was required to provide the following minimum information in order to meet its obligations with respect to CK:

– the personal data concerning CK which have been processed in order to formulate a 'factor' (date of birth, address, sex, etc.);

– the mathematical formula on which the calculation that led to the score at issue in the main proceedings is based;

– the specific value attributed to CK for each of the factors concerned; and

– the precise intervals within which the same value is attributed to different data for the same factor (interval or discrete evaluation or index/land-register-based evaluation).

25 In order to ensure that, after it has been provided, the accuracy of that minimum information can be verified by CK, D & B should also provide a list of scoring for the period covering the six months preceding and the six months following the establishment of CK's score, as obtained using the same calculation rule.

26 According to the referring court, only the disclosure of the minimum information specified by that expert would enable the consistency and accuracy of the information provided by a controller under Article 15(1)(h) of the GDPR to be verified.

27 In the present case, there are a number of clear indications that the information provided by D & B is contrary to the facts. While the information provided to CK, including, inter alia, the score obtained, showed CK to have very good credit standing, the actual profiling led to her being regarded as not creditworthy, including as regards the capacity to pay the amount of EUR 10 per month under a mobile telephone contract.

28 In the referring court's view, the question therefore arises whether Article 15(1)(h) of the GDPR guarantees the data subject the possibility to verify the accuracy of the information provided by the controller.

29 In the event that Article 15(1)(h) of the GDPR does not guarantee this, the right of access to the data subject's personal data and other information provided for therein would be rendered meaningless and useless, especially since each controller could in that case be able to provide incorrect information.

30 According to the referring court, the question also arises whether and, if so, to what extent the exception based on the existence of a trade secret is capable of restricting that right of access guaranteed by the combined provisions of Article 15(1)(h) and Article 22 of the GDPR.

31 In the light of the rules laid down in Article 9 of Directive 2016/943, it is necessary to assess whether it is conceivable that information classified as a 'trade secret' within the meaning of point 1 of Article 2 of that directive may be disclosed only to the authority or court seised in order for that authority or court to verify independently whether it must be found that there is in fact such a trade secret and whether that information provided by the controller, for the purposes of Article 15(1) of the GDPR, corresponds to the reality of the situation at issue.

32 Lastly, the referring court takes the view that it is necessary to examine whether a provision such as Paragraph 4(6) of the DSG, which excludes, as a rule, the data subject's right of access, provided for in Article 15 of the GDPR, where such access would compromise a business or trade secret of the controller or of a third party, may be regarded as consistent with the combined provisions of Article 15(1) and Article 22(3) of the GDPR.

33 In those circumstances, the Verwaltungsgericht Wien (Administrative Court, Vienna) decided to stay the proceedings and to refer the following questions to the Court of Justice for a preliminary ruling:

'(1) What requirements as to content does information provided need to satisfy in order to be regarded as sufficiently "meaningful" within the meaning of Article 15(1)(h) of [the GDPR]?

In the case of profiling, must the information essential for making the result of the automated decision transparent in each individual case also be disclosed by the controller – where necessary in compliance with an existing trade secret – as part of the disclosure of the "logic involved" which includes, in particular, (1) the disclosure of the data subject's processed data, (2) the disclosure of the parts of the algorithm on which the profiling is based that are necessary to provide transparency, and (3) the information relevant to establishing the connection between the processed information and the rating arrived at?

In cases involving profiling, must the party entitled to access for the purpose of Article 15(1)(h) of the GDPR be provided, as a minimum, with the following information on the specific processing concerning him or her, even if a trade secret is involved, in order to enable him or her to protect his or her rights under Article 22(3) of the GDPR:

(a) [the] communication of all potentially pseudo-anonymised information, in particular on the manner in which the data subject's data is being processed, which allows the data subject to check compliance with the GDPR,
(b) … the input data used for profiling,
(c) the parameters and input variables used in the determination of the rating,
(d) the influence of these parameters and input variables on the calculated rating,
(e) information on the origin of the parameters or input variables,
(f) an explanation as to why the party entitled to access for the purpose of Article 15(1)(h) of the GDPR has been assigned a specific rating and clarification of the implications of such rating,

(g) [the] listing [of] the profile categories and [the] explanation as to what rating implication is associated with each of the profile categories?

(2) Is the right of access granted by Article 15(1)(h) of the GDPR related to the rights guaranteed by Article 22(3) of the GDPR to express one's point of view and to challenge an automated decision taken within the meaning of Article 22 of the GDPR in so far as the scope of the information to be provided on the basis of an access request within the meaning of Article 15(1)(h) of the GDPR is only sufficiently "meaningful" if the party requesting access and the data subject for the purpose of Article 15(1)(h) of the GDPR is enabled to exercise the rights guaranteed by Article 22(3) of the GDPR to express his or her own point of view and to challenge the automated decision for the purpose of Article 22 of the GDPR concerning him or her in a real, profound and promising way?

(3) (a) Must Article 15(1)(h) of the GDPR be interpreted as meaning that information constitutes "meaningful information" for the purposes of this provision only if it is so broad that the party entitled to access for the purpose of Article 15(1)(h) of the GDPR is able to determine whether this information is accurate, i.e. whether the automatic decision specifically requested was actually based on the information provided?

(b) If the above question is answered in the affirmative: what is the procedure if the accuracy of the information provided by a controller can only be verified if third-party data protected by the GDPR must also be brought to the attention of the party entitled to access for the purpose of Article 15(1)(h) of the GDPR (black box)?

Can this tension between the right of access within the meaning of Article 15(1) of the GDPR and the data protection rights of third parties also be resolved by disclosing the data of third parties (which have also been subjected to the same profiling process) required for the accuracy check only to the authority or the court for the authority or the court to check independently whether the disclosed data of these third parties is accurate?

(c) If the above question is answered in the affirmative: which rights must be granted to the party entitled to access for the purpose of Article 15(1)(h) of the GDPR in the event that it is necessary to ensure the protection of third party rights within the meaning of Article 15(4) of the GDPR by creating the black box referred to in [Question 3(b)]?

Must the data of other persons to be disclosed by the controller for the purpose of Article 15(1) of the GDPR to the party entitled to access for the purpose of Article 15(1)(h) of the GDPR be disclosed in pseudo-anonymised form in order to ensure that the accuracy can be verified?

(4) (a) What is the procedure if the information to be provided in accordance with Article 15(1)(h) of the GDPR also meets the requirements of a trade secret within the meaning of [point 1 of Article 2 of Directive 2016/943]?

Can the tension between the right of access guaranteed by Article 15(1)(h) of the GDPR and the right to non-disclosure of a trade secret protected by [Directive 2016/943] be resolved by allowing the information to be disclosed as a trade secret within the meaning of [point 1 of Article 2 of Directive 2016/943] be disclosed to the authority or the court only, so that the authority or the court must independently verify whether it must be assumed that a trade secret within the meaning of [point 1 of Article 2 of Directive 2016/943] exists and whether the information provided by the controller within the meaning of Article 15(1) of the GDPR is accurate?

(b) If the above question is answered in the affirmative: which rights must be granted to the party entitled to access for the purpose of Article 15(1)(h) of the GDPR in the event that it is necessary to ensure the protection of third party rights within the meaning of Article 15(4) of the GDPR by creating the black box referred to in [Question 4(a)]?

In [the] case of discrepancy between the information to be disclosed to the authority or the court and the information to be disclosed to the person entitled to access within the meaning of Article 15(1)(h) of the GDPR, in cases involving profiling, must the party entitled to access for the purpose of Article 15(1)(h) of the GDPR also be provided, as a minimum, with the following information on the specific processing concerning him or her in order to enable him or her to protect his or her rights under Article 22(3) of the GDPR in their entirety:

– [the] communication of all potentially pseudo-anonymised information, in particular on the manner in which the data subject's data is being processed, which allows the data subject to check compliance with the GDPR,

– … the input data used for profiling,

– the parameters and input variables used in the determination of the rating,

– the influence of these parameters and input variables on the calculated rating,

– information on the origin of the parameters or input variables,

– an explanation as to why the party entitled to access for the purpose of Article 15(1)(h) of the GDPR has been assigned a specific rating and clarification of the implications of such rating,

– [the] listing [of] the profile categories and [the] explanation as to what rating implication is associated with each of the profile categories?

(5) Does the provision of Article 15(4) of the GDPR in any way limit the scope of the information to be provided pursuant to Article 15(1)(h) of the GDPR?

If this question is answered in the affirmative, is this right of access limited by Article 15(4) of the GDPR, and how is the extent of the limitation to be determined in each individual case?

(6) Is the provision of [Paragraph] 4(6) of the [DSG], according to which "the right of access of the data subject pursuant to Article 15 of the GDPR, as a rule, does not [exist] vis-à-vis the controller if the provision of such information would violate a business or trade secret of the controller or third parties" compatible with the requirements of Article 15(1) in conjunction with Article 22(3) of the GDPR? If the above question is answered in the affirmative, what are the conditions for such compatibility?'

Procedure before the Court

34 By decision of 8 December 2022, the President of the Court suspended the present proceedings pending final judgment in Case C-634/21, *SCHUFA Holding and Others (Scoring)*.

35 In accordance with the decision of the President of the Court of 13 December 2023, the Registry of the Court of Justice notified the referring court of the judgment of 7 December 2023, *SCHUFA Holding and Others (Scoring)* (C-634/21, EU:C:2023:957), by inviting it to indicate whether, in the light of that judgment, it wished to maintain its request for a preliminary ruling.

36 By letter received at the Court Registry on 29 January 2024, the referring court stated that it was maintaining its request for a preliminary ruling, since the judgment of 7 December 2023, *SCHUFA Holding and Others (Scoring)* (C-634/21, EU:C:2023:957), did not provide an answer to the questions which it had referred in the present case.

37 By decision of 14 February 2024, the President of the Court therefore ordered that the proceedings in the present case be resumed.

Consideration of the questions referred

Questions 1 and 2 and Question 3(a)

38 By Questions 1 and 2 and Question 3(a), which it is appropriate to examine together, the referring court asks, in essence, whether Article 15(1)(h) of the GDPR must be interpreted as meaning that, in the case of automated decision-making, including profiling, within the meaning of Article 22(1) of that regulation, the data subject may require the controller to provide, as 'meaningful information about the logic involved', an exhaustive explanation of the procedure and principles actually applied in order to use, by automated means, the personal data concerning that person with a view to obtaining a specific result, such as a credit profile.

39 In accordance with settled case-law of the Court, in interpreting a provision of EU law, it is necessary to consider not only its wording, but also the context in which it occurs and the objectives pursued by the rules of which it is part (judgment of 4 May 2023, *Österreichische Datenschutzbehörde and CRIF*, C-487/21, EU:C:2023:369, paragraph 19 and the case-law cited).

40 As regards, first of all, the wording of Article 15(1)(h) of the GDPR, it should be noted, first, that the generally accepted meanings of the concept of 'meaningful information' under that provision, in the various language versions of that provision, differ; some, like the French-language version, favour the functionality ('*nuttige*' in Dutch, '*úteis*' in Portuguese) or the relevance ('*pertinente*' in Romanian) of the information to be provided, while others place greater emphasis on the importance of that information ('*significativa*' in Spanish and '*istotne*' in Polish). Lastly, in both the German- and the English-language versions of that provision, the term used ('*aussagekräftig*' and 'meaningful', respectively) may be understood both as relating to the good intelligibility of that information and as referring to that information being of a certain value.

41 The diversity of generally accepted meanings in the various language versions must be understood in such a way that the various meanings set out in the preceding paragraph are complementary, which it is appropriate to take into account when interpreting the concept of 'meaningful information about the logic involved' under Article 15(1)(h) of the GDPR, as the Advocate General observed, in essence, in point 65 of his Opinion.

42 Second, in the light of its general wording, the reference, in that provision, to the 'logic involved' in automated decision-making, which constitutes the subject matter of that 'meaningful information', is capable of covering a wide range of 'logics' concerning the use of personal data

and other data with a view to obtaining a specific result by automated means. That interpretation is supported by certain language versions of that provision which use terms referring, in a complementary manner, to various aspects of the generally accepted meaning of the concept of 'logic'. Thus, for example, in the Czech- and Polish-language versions, reference is made to the terms '*postupu*' and '*zasady*', respectively, which may be translated as 'procedure' and 'principles'.

43 It must therefore be held that the wording of Article 15(1)(h) of the GDPR covers all relevant information concerning the procedure and principles relating to the use, by automated means, of personal data with a view to obtaining a specific result.

44 As regards, next, the context in which the concept of 'meaningful information about the logic involved', within the meaning of Article 15(1)(h) of the GDPR, occurs, it must be pointed out, in the first place, that that information is only part of the information covered by the right of access provided for in that article, which also concerns information concerning the importance and the envisaged consequences of the processing at issue for the data subject.

45 Although that information, which, according to the Guidelines on automated individual decision-making and profiling for the purposes of Regulation 2016/679 adopted on 3 October 2017 by the Working Party set up under Article 29 of Directive 95/46, as revised and adopted on 6 February 2018, in order to be meaningful and understandable, should be accompanied by 'real, tangible examples', is not the subject of the questions referred by the national court, it must nevertheless be taken into account as part of the context in which the concept of 'meaningful information about the logic involved' occurs.

46 In the second place, having regard to the fact that the concept of 'meaningful information about the logic involved' also appears in Article 13(2)(f) and Article 14(2)(g) of the GDPR, the Court has already held that, in the case of automated decision-making, within the meaning of Article 22(1) of that regulation, the right of access to such information enshrined in Article 15(1)(h) thereof forms a whole with the additional information obligations imposed on the controller under Article 13(2)(f) and Article 14(2)(g) of the GDPR (see, to that effect, judgment of 7 December 2023, *SCHUFA Holding and Others (Scoring)*, C-634/21, EU:C:2023:957, paragraph 56).

47 In the third place, as the Advocate General stated, in essence, in points 58 to 60 of his Opinion, in the contextual interpretation of the rights of access provided for in the case of automated decision-making, account must be taken of the case-law of the Court relating to the requirements to be met by the controller under Article 15(3) of the GDPR.

48 Thus, account must be taken, inter alia, of the fact that the requirement of transparency of the information provided, laid down in Article 12(1) of the GDPR, applies to all the data and information referred to in Article 15, including those relating to automated decision-making.

49 In order to ensure that the data subject is able fully to understand the information provided to him or her by the controller, Article 12(1) requires the controller to take appropriate measures, inter alia, to provide the data subject with those data and information in a concise, transparent, intelligible and easily accessible form, using plain and clear language (see, to that effect, judgment of 4 May 2023, *Österreichische Datenschutzbehörde and CRIF*, C-487/21, EU:C:2023:369, paragraph 38).

50 The examination of the context of which Article 15(1)(h) of the GDPR forms part thus supports the interpretation that emerges from the analysis of the wording of that provision, according to which 'meaningful information about the logic involved' in automated decision-making, within the meaning of that provision, covers all relevant information concerning the procedure and principles relating to the use of personal data with a view to obtaining, by automated means, a specific result, the obligation of transparency also requiring that that information be provided in a concise, transparent, intelligible and easily accessible form.

51 As regards, lastly, the purposes of the GDPR, it should be recalled that the objective of that regulation consists, inter alia, in ensuring a high level of protection of the fundamental rights and freedoms of natural persons, in particular their right to the protection of personal data, enshrined in Article 16 TFEU and guaranteed as a fundamental right in Article 8 of the Charter, which supplements the right to private life guaranteed in Article 7 thereof (see, to that effect, judgment of 4 October 2024, *Schrems (Communication of data to the general public)*, C-446/21, EU:C:2024:834, paragraph 45 and the case-law cited).

52 Thus, as stated moreover in recital 11, the purpose of the GDPR is to strengthen and set out in detail the rights of data subjects (judgment of 4 May 2023, *Österreichische Datenschutzbehörde and CRIF*, C-487/21, EU:C:2023:369, paragraph 33 and the case-law cited).

53 As regards, specifically, the right of access provided for in Article 15 of the GDPR, it is apparent from the case-law of the Court that that right must enable the data subject to ensure that the personal data concerning him or her are correct and that they are processed in a lawful manner (judgments of 4 May 2023, *Österreichische Datenschutzbehörde and CRIF*, C-487/21, EU:C:2023:369, paragraph 34, and of 26 October 2023, *FT (Copies of medical records)*, C-307/22, EU:C:2023:811, paragraph 73).

54 That right of access is necessary to enable the data subject to exercise, depending on the circumstances, his or her right to rectification, right to erasure ('right to be forgotten') or right to restriction of processing, conferred, respectively, by Articles 16, 17 and 18 of the GDPR, as well as the data subject's right to object to his or her personal data being processed, laid down in Article 21 of the GDPR, right of action and right to compensation, laid down in Articles 79 and 82 of the GDPR, respectively (see, to that effect, judgment of 4 May 2023, *Österreichische Datenschutzbehörde and CRIF*, C-487/21, EU:C:2023:369, paragraph 35).

55 In particular, in the specific context of the adoption of a decision based solely on automated processing, the main purpose of the data subject's right to obtain the information provided for in Article 15(1)(h) of the GDPR is to enable him or her effectively to exercise the rights conferred on him or her by Article 22(3) of that regulation, namely the right to express his or her point of view on that decision and to contest it.

56 If the individuals affected by an automated decision, including profiling, were not in a position to understand the reasons which led to that decision before expressing their point of view or contesting the decision, those rights would not, accordingly, satisfy in full their purpose of protecting those individuals against the particular risks to their rights and freedoms represented by the automated processing of their personal data (see, to that effect, judgment of 7 December 2023, *SCHUFA Holding and Others (Scoring)*, C-634/21, EU:C:2023:957, paragraph 57).

57 In that regard, it is apparent from recital 71 of the GDPR that, where the data subject is the subject of a decision which is based solely on automated processing and which significantly affects him or her, that data subject must have the right to obtain an explanation of that decision. As the Advocate General observed in point 67 of his Opinion, it must therefore be held that Article 15(1)(h) of the GDPR affords the data subject a genuine right to an explanation as to the functioning of the mechanism involved in automated decision-making of which that person was the subject and of the result of that decision.

58 It is apparent from the examination of the purposes of the GDPR and, in particular, those of Article 15(1)(h) thereof that the right to obtain 'meaningful information about the logic involved' in automated decision-making, within the meaning of that provision, must be understood as a right to an explanation of the procedure and principles actually applied in order to use, by automated means, the personal data of the data subject with a view to obtaining a specific result, such as a credit profile. In order to enable the data subject effectively to exercise the rights conferred on him or her by the GDPR and, in particular, Article 22(3) thereof, that explanation must be provided by means of relevant information and in a concise, transparent, intelligible and easily accessible form.

59 Those requirements cannot be satisfied either by the mere communication of a complex mathematical formula, such as an algorithm, or by the detailed description of all the steps in automated decision-making, since none of those would constitute a sufficiently concise and intelligible explanation.

60 As is apparent from page 25 of the Guidelines on automated individual decision-making and profiling for the purposes of Regulation 2016/679, referred to in paragraph 45 of the present judgment, first, the controller should find simple ways to tell the data subject about the rationale behind, or the criteria relied on in reaching the automated decision. Second, the GDPR requires the controller to provide meaningful information about the logic involved in that decision, but 'not necessarily a complex explanation of the algorithms used or disclosure of the full algorithm'.

61 Thus, the 'meaningful information about the logic involved' in automated decision-making, within the meaning of Article 15(1)(h) of the GDPR, must describe the procedure and principles actually applied in such a way that the data subject can understand which of his or her personal data have been used in what way in the automated decision-making at issue, with the complexity of the operations to be carried out in the context of automated decision-making not being capable of relieving the controller of the duty to provide an explanation.

62 As regards, specifically, profiling such as that at issue in the main proceedings, the referring court could, inter alia, find that it is sufficiently transparent and intelligible to inform the data subject of the extent to which a variation in the personal data taken into account would have led to a different result.

63 That said, it should also be stated that, as regards the question whether the information provided must allow the data subject to be able to verify the accuracy of the personal data concerning him or her and on which automated decision-making is based, the right of access to those data is covered not by Article 15(1)(h) of the GDPR, but by the introductory sentence of that paragraph, which guarantees the data subject the possibility to ensure that the data are correct, as is apparent from the case-law cited in paragraph 53 above.

64 Lastly, as regards the referring court's assertion that the information provided by D & B to CK, pursuant to Article 15(1)(h) of the GDPR, is contrary to the facts, since the 'actual' profiling led to her being regarded as not creditworthy although that information suggested the contrary, it should be noted that, if, according to that court, the non-compliance thus established results from D & B's failure to provide to CK the profiling carried out in respect of her on behalf of the mobile telephone undertaking which, on that basis, refused to conclude or renew a contract with her, it should be remedied by means of the right of access to the credit profile thus established. In that regard, it is apparent from the Court's case-law that personal data generated by the controller itself fall within the scope of Article 14 of the GDPR (see, to that effect, judgment of 28 November 2024, *Másdi*, C-169/23, EU:C:2024:988, paragraph 48).

65 By contrast, an explanation of the differences between the result of such 'actual' profiling, assuming it to be established, and the result communicated by D & B to CK and obtained, according to that company, by means of 'equal weighting' of the data relating to CK, would indeed fall within the scope of 'meaningful information about the logic involved' in the profiling thus carried out. In accordance with what has been stated in paragraph 58 above, D & B is therefore required to explain in a concise, transparent, intelligible and easily accessible form the procedure and principles pursuant to which the result of the 'actual' profiling was obtained.

66 It follows from all of the foregoing that the answer to Questions 1 and 2 and to Question 3(a) is that Article 15(1)(h) of the GDPR must be interpreted as meaning that, in the case of automated decision-making, including profiling, within the meaning of Article 22(1) of that regulation, the data subject may require the controller, as 'meaningful information about the logic involved', to explain, by means of relevant information and in a concise, transparent, intelligible and easily accessible form, the procedure and principles actually applied in order to use, by automated means, the personal data concerning that person with a view to obtaining a specific result, such as a credit profile.

Question 3(b) and (c), Question 4(a) and (b), and Questions 5 and 6

67 By Question 3(b) and (c), Question 4(a) and (b), and Questions 5 and 6, which it is appropriate to examine together, the referring court asks, in essence, whether Article 15(1)(h) of the GDPR must be interpreted as meaning that, where the controller takes the view that the information to be provided to the data subject in accordance with that provision contains data of third parties protected by that regulation or trade secrets, within the meaning of point 1 of Article 2 of Directive 2016/943, that controller is required to provide the allegedly protected information to the competent supervisory authority or court, which must balance the rights and interests at issue with a view to determining the extent of the data subject's right of access provided for in Article 15 of the GDPR.

68 In that regard, it should be recalled that, pursuant to recital 4 of the GDPR, the right to the protection of personal data is not an absolute right and must be balanced against other fundamental rights, in accordance with the principle of proportionality. Thus, the GDPR respects all the fundamental rights and observes the freedoms and principles recognised by the Charter, as enshrined by the Treaties (judgment of 26 October 2023, *FT (Copies of medical records)*, C-307/22, EU:C:2023:811, paragraph 59 and the case-law cited).

69 Moreover, recital 63 of that regulation states that the right for any data subject to have access to personal data which have been collected concerning him or her should not adversely affect the rights or freedoms of others, including trade secrets or intellectual property and in particular the copyright protecting the software.

70 However, the result of those considerations should not be a refusal to provide all information to the data subject. Thus, Article 23(1)(i) of that regulation provides, in essence, that a restriction of the scope of the obligations and rights provided for in, inter alia, Article 15 of the GDPR is possible only when such a restriction respects the essence of the fundamental rights and freedoms and is a necessary and proportionate measure in a democratic society to safeguard the protection of the rights and freedoms of others.

71 In the light of the related right to obtain a copy, enshrined in Article 15(4) of the GDPR, the Court has already held that its application must not adversely affect the rights and freedoms of others, including trade secrets or intellectual property, and in particular the copyright protecting the software (see, to that effect, judgment of 4 May 2023, *Österreichische Datenschutzbehörde and CRIF*, C-487/21, EU:C:2023:369, paragraph 43).

72 In that context, the Court has noted that, in the event of conflict between, on the one hand, exercising the right of full and complete access to personal data and, on the other hand, the rights or freedoms of others, a balance will have to be struck between the rights and freedoms in question. Wherever possible, means of communicating personal data that do not infringe the rights or freedoms of others should be chosen, bearing in mind that, as follows from recital 63 of the GDPR, 'the result of those considerations should not be a refusal to provide all information to the data subject' (judgment of 4 May 2023, *Österreichische Datenschutzbehörde and CRIF*, C-487/21, EU:C:2023:369, paragraph 44).

73 As to how the right of access enshrined in Article 15(1)(h) of the GDPR may be implemented in such a way as to respect the rights and freedoms of others, it should be recalled that, according to the case-law, a national court may take the view that the personal data of the parties or of third parties must be disclosed to it in order to be able to balance, in full knowledge of the facts and in accordance with the principle of proportionality, the interests involved. That assessment may, depending on the case, lead it to authorise the full or partial disclosure to the opposing party of the personal data thus communicated to it, if it finds that such disclosure does not go beyond what is necessary for the purpose of guaranteeing the effective enjoyment of the rights which individuals derive from Article 47 of the Charter (judgment of 2 March 2023, *Norra Stockholm Bygg*, C-268/21, EU:C:2023:145, paragraph 58).

74 As the Advocate General observed in point 94 of his Opinion, that case-law can be fully transposed to the situation in which the information to be provided to the data subject under the right of access guaranteed by Article 15(1)(h) of the GDPR is likely to result in an infringement of the rights and freedoms of others, in particular in so far as it contains personal data of third parties protected by that regulation or trade secrets, within the meaning of point 1 of Article 2 of Directive 2016/943. In that case too, that information must be disclosed to the competent supervisory authority or court, which must balance the rights and interests at issue with a view to determining the extent of the data subject's right of access to personal data concerning him or her.

75 Having regard to the need to make that determination on a case-by-case basis, Article 15(1)(h) of the GDPR precludes inter alia the application of a provision such as Paragraph 4(6) of the DSG which excludes, as a rule, the data subject's right of access, provided for in Article 15 of the

GDPR, where such access would compromise a business or trade secret of the controller or of a third party. In that regard, it should be borne in mind that a Member State cannot definitively prescribe the result of a case-by-case balancing of the rights and interests at issue imposed by EU law (see, to that effect, judgment of 7 December 2023, *SCHUFA Holding and Others (Scoring)*, C-634/21, EU:C:2023:957, paragraph 70 and the case-law cited).

76 In the light of all of the foregoing, the answer to Question 3(b) and (c), Question 4(a) and (b), and Questions 5 and 6 is that Article 15(1)(h) of the GDPR must be interpreted as meaning that, where the controller takes the view that the information to be provided to the data subject in accordance with that provision contains data of third parties protected by that regulation or trade secrets, within the meaning of point 1 of Article 2 of Directive 2016/943, that controller is required to provide the allegedly protected information to the competent supervisory authority or court, which must balance the rights and interests at issue with a view to determining the extent of the data subject's right of access provided for in Article 15 of the GDPR.

Costs

77 Since these proceedings are, for the parties to the main proceedings, a step in the action pending before the referring court, the decision on costs is a matter for that court. Costs incurred in submitting observations to the Court, other than the costs of those parties, are not recoverable.

On those grounds, the Court (First Chamber) hereby rules:

1. **Article 15(1)(h) of Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation)**

   must be interpreted as meaning that, in the case of automated decision-making, including profiling, within the meaning of Article 22(1) of that regulation, the data subject may require the controller, as 'meaningful information about the logic involved', to explain, by means of relevant information and in a concise, transparent, intelligible and easily accessible form, the procedure and principles actually applied in order to use, by automated means, the personal data concerning that person with a view to obtaining a specific result, such as a credit profile.

2. **Article 15(1)(h) of Regulation 2016/679**

   must be interpreted as meaning that, where the controller takes the view that the information to be provided to the data subject in accordance with that provision contains data of third parties protected by that regulation or trade secrets, within the meaning of point 1 of Article 2 of Directive (EU) 2016/943 of the European Parliament and of the Council of 8 June 2016 on the protection of undisclosed know-how and business information (trade secrets) against their unlawful acquisition, use and disclosure, that controller is required to provide the allegedly protected information to the competent supervisory authority or court, which must balance the rights and interests at issue with a view to determining the extent of the data subject's right of access provided for in Article 15 of that regulation.

[Signatures]